// DOSSIER DE PROJET · PROJECT REPORT

Hybrid InfraSec

Infrastructure sécurisée et évolution Zero-Trust de la société INFRASEC



TITRE PROFESSIONNEL · NIVEAU 6 · RNCP37680

Administrateur d'infrastructures sécurisées

CCP1 · Administrer et sécuriser · CCP2 · Concevoir une évolution · CCP3 · Gérer la cybersécurité

CCP1 | CCP2 | CCP3 | FR | EN

AIS 2026 · RJ

Juin – octobre 2026

github.com/0x1void/hybrid-infrasec

// DOSSIER DE PROJET · PROJECT REPORT

Hybrid InfraSec

Infrastructure sécurisée et évolution Zero-Trust de la société INFRASEC

Secure infrastructure and Zero-Trust evolution of INFRASEC

Auteur	**RJ**
Titre	**Administrateur d'infrastructures sécurisées (RNCP37680)**
Certificats	**CCP1 · CCP2 · CCP3 (titre complet)**
Période couverte	**Juin → 26 octobre 2026**
Contenu	**Socle, évolution Zero-Trust, supervision, cybersécurité, complément CCP3 d'octobre**
Langues	**Français, puis anglais**

Sommaire général · Contents

VERSION FRANÇAISE 7

Avertissement et résumé 8

Introduction : présentation du projet 10

1. Compétences mises en œuvre 12

CCP1 · Administrer et sécuriser les infrastructures 14

2. Cahier des charges : expression des besoins 42

3. Gestion de projet 46

4. Argumentation du choix des solutions retenues 53

5. Organisation de la mise en œuvre 58

6. Réalisations : supervision et gestion de la cybersécurité 63

7. Relations avec les principaux acteurs du projet 70

8. Synthèse et conclusion 72

C1 · Contexte et réponses au jury 76

C2 · Architecture du labo 79

C3 · Architecture par machine 84

C4 · L'organisation INFRASEC 97

C5 · Journal des incidents et constats 100

C6 · Détection et journaux 103

C7 · Continuité et sauvegarde 106

C8 · Bilan, limites et suite 109

C9 · Glossaire 111

Guide des annexes 114

Annexe A · Lettre de mission d'audit 115

Annexe B · Rapport d'audit de sécurité (PV-02) 118

Annexe C · Évaluation de conformité du rapport d'audit 121

Annexe D · Analyse de risques EBIOS Risk Manager 123

Annexe E · Politique de sécurité des systèmes d'information (PSSI) 136
Annexe F · Rapport de gel et de hardening 151
Annexe G · Procès-verbal de sauvegarde et de restauration (PV-01) 153
Annexe H · Support de sensibilisation et action de formation courte 155
Annexe I · Procès-verbal de détection d'incident et RETEX (PV-03) 158
Annexe J · Journal des incidents techniques et de sécurité 161
Annexe K · Dispositif de veille en cybersécurité 167
Annexe L · Glossaire et fiches de définitions 171
Annexe M · Manuel d'exploitation bilingue (Operations manual) 179
Annexe N · Schéma réseau de référence et couches OSI 186
Annexe O · Procès-verbal de recette et de supervision (PV-04) 190
Annexe P · Fiches CCP3 complètes (octobre 2026) 200
Annexe Q · Scripts d'exploitation lab et lab-backup 231
Annexe R · Registre d'intégrité des pièces (SHA-256) 235
Annexe S · Commandes de construction, de A à Z 237
Annexe T · Commandes de test (preuve de fonctionnement) 246

ENGLISH VERSION 249

Notice and summary 250
Introduction: the project 252
1. Skills demonstrated 254
CCP1 · Administering and securing the infrastructure 256
2. Requirements 283
3. Project management 287
4. Why I chose this solution 294
5. How I organized the implementation 299
6. Results: monitoring and cybersecurity management 304
7. Relations with the main stakeholders 311

8. Summary and conclusion 313

C1 · Context and answers to the jury 317

C2 · Lab architecture 320

C3 · Architecture per machine 325

C4 · The INFRASEC organisation 337

C5 · Incident and finding log 340

C6 · Detection and logs 343

C7 · Continuity and backup 346

C8 · Results, limits and next steps 349

C9 · Glossary 351

Annex guide 354

Annex A · Audit engagement letter 355

Annex B · Security audit report (PV-02) 358

Annex C · Compliance assessment of the audit report 361

Annex D · EBIOS Risk Manager risk analysis 363

Annex E · Information systems security policy (ISSP) 375

Annex F · Freeze and hardening report 390

Annex G · Backup and restore report (PV-01) 392

Annex H · Awareness material and short training session 394

Annex I · Incident detection report and lessons learned (PV-03) 396

Annex J · Technical and security incident log 399

Annex K · Cybersecurity threat watch process 404

Annex L · Glossary and definition sheets 408

Annex M · Operations manual 416

Annex N · Reference network diagram and OSI layers 420

Annex O · Acceptance and monitoring report (PV-04) 424

Annex P · Full CCP3 sheets (October 2026) 434

Annex Q · Operations scripts lab and lab-backup 464

Annex R · Integrity register (SHA-256) 468

Annex S · Build commands, A to Z 470

Annex T · Test commands (proof of concept) 478

01

BLOC 1

Version française

Le dossier complet, rédigé en français. Les termes techniques restent en anglais, comme on les emploie dans le métier.

CCP1 CCP2 CCP3

Avertissement et résumé

Le cadre. Ce dossier présente un projet réalisé pendant ma formation d'administrateur d'infrastructures sécurisées. La société INFRASEC est fictive. Elle me donne un client, un besoin et des contraintes réalistes. L'infrastructure, elle, est bien réelle : je l'ai construite, exploitée et sécurisée moi-même, dans un laboratoire virtualisé. Toutes les mesures, captures, logs et incidents cités sont réels.

Ce que le document ne contient pas. Les adresses utilisées sont des adresses privées (RFC 1918). Aucun mot de passe, aucune clé privée, aucune adresse IP publique et aucune donnée personnelle n'apparaît dans ce dossier. Seules des clés publiques peuvent être citées. Dans les annexes techniques, `admin` est mon identifiant d'administrateur. Chaque pièce est scellée par un hash SHA-256 (annexe P).

Comment le lire. Le dossier suit le plan demandé par le référentiel d'évaluation : compétences, cahier des charges, gestion de projet, choix des solutions, mise en œuvre, relations avec les acteurs, synthèse. Le chapitre 6 regroupe la supervision et la cybersécurité. La partie CCP1, placée juste après le chapitre 1, décrit le socle. Les documents complets sont en annexes, en fin de dossier, et le glossaire (annexe L) explique les termes techniques. Le même contenu existe en anglais dans le bloc 2.

Les termes techniques. J'ai gardé les mots anglais que l'on utilise vraiment sur le terrain : firewall, switch, router, backup, snapshot, dashboard, logs, rollback, peer, handshake, container, hardening. Je pense qu'un dossier écrit comme on parle en équipe se lit plus facilement.

La forme. Le dossier est écrit simplement, avec un bloc en anglais, des pages de garde et un sommaire cliquable. La recette du 11/10/2026 est décrite dans le procès-verbal PV-04 (annexe O).

Le titre complet. Ce dossier reprend le dossier de projet présenté pour les CCP2 et CCP3 et ajoute, en français et en anglais, la partie CCP1 : le socle administré et sécurisé lors de la première étape. Il réunit ainsi les trois certificats du titre.

00

INTRODUCTION

Présentation du projet

Qui est INFRASEC, d'où vient le besoin, d'où je viens, et ce que ce dossier démontre.

Contexte

Introduction : présentation du projet

L'entreprise et le service

INFRASEC est une petite entreprise de services. Une dizaine de collaborateurs travaillent régulièrement à distance. Son système d'information est petit mais complet : un firewall qui est le seul point de passage, un annuaire Active Directory, un serveur de fichiers, une plateforme de supervision et un SIEM. L'équipe informatique se résume à un administrateur d'infrastructures sécurisées. C'est le rôle que je tiens dans ce projet, sous l'autorité du RSSI pour les décisions de sécurité.

D'où vient le projet

Le projet s'est fait en deux étapes. Dans la première, j'ai construit et sécurisé le socle interne : virtualisation, segmentation, annuaire, stockage, hardening. Cette étape correspond au certificat « Administrer et sécuriser les infrastructures », que j'ai obtenu. La partie CCP1 de ce dossier décrit cette première étape. Le reste porte sur la seconde : faire évoluer ce socle pour répondre à un nouveau besoin, et gérer la sécurité de l'ensemble dans la durée.

Le besoin est venu avec le télétravail. Des collaborateurs doivent ouvrir le partage de fichiers depuis chez eux, et l'administrateur doit pouvoir intervenir sur l'infrastructure en déplacement. La solution facile aurait été d'ouvrir un service vers Internet. Je ne l'ai pas retenue, parce qu'elle cassait tout le modèle de sécurité du socle. Le projet consiste donc à concevoir, chiffrer, déployer et sécuriser un accès distant Zero-Trust, puis à montrer que la sécurité de l'infrastructure est mesurée, pilotée et capable de réagir à un incident.

Ce que démontre ce dossier

Volet	Ce que je démontre	Où le trouver
Administrer et sécuriser	Un socle virtualisé, filtré et durci : réseau, systèmes, virtualisation, exploitation documentée	Partie CCP1
Concevoir	Un besoin traduit en exigences mesurables, quatre solutions comparées avec une grille pondérée et un coût sur trois ans	Chapitres 2 et 4
Planifier	Un projet découpé en phases, avec des jalons, un suivi et des objectifs de qualité	Chapitre 3
Mettre en production	Un changement maîtrisé : étapes validées, recette, rollback, reprise testée, transfert	Chapitre 5
Superviser	Des indicateurs choisis et justifiés, des dashboards utiles, une alerte testée	Chapitre 6.1
Gérer la cybersécurité	Audit sur lettre de mission, analyse EBIOS RM, PSSI, hardening mesuré, backup vérifié, sensibilisation, détection, incidents, veille	Chapitres 6.2 à 6.4

01

CHAPITRE1

Compétences mises en œuvre

Les compétences du référentiel, et l'endroit du dossier où chacune est prouvée.

CCP1 | CP1 à CP4 | CCP2 | CP5 CP6 CP7 | CCP3 | CP8 CP9 CP10

1. Compétences mises en œuvre

Ce tableau reprend les intitulés exacts du référentiel pour les trois certificats du titre. Pour chaque compétence, j'indique ce que j'ai réalisé et où se trouve la preuve.

Compétence (intitulé du référentiel)	Ce que j'ai réalisé	Preuves
CP1. Appliquer les bonnes pratiques dans l'administration des infrastructures	Règles d'exploitation, snapshot avant chaque opération, ordre d'arrêt et de redémarrage, incidents tracés, tâches de maintien planifiées, documentation	Partie CCP1 · annexes J, M
CP2. Administrer et sécuriser les infrastructures réseaux	Firewall seul point de passage, filtrage par défaut, DNS et heure du segment, filtrage local, diagnostic par captures	Partie CCP1 · annexes B, N
CP3. Administrer et sécuriser les infrastructures systèmes	Active Directory et DNS, stockage ZFS joint au domaine, hardening Linux mesuré, scripts PowerShell, backup prouvé	Partie CCP1 · annexes F, G
CP4. Administrer et sécuriser les infrastructures virtualisées	Hyperviseur KVM/libvirt sous SELinux, réseaux virtuels, snapshots, containers Podman *rootless*	Partie CCP1 · annexe M
CP5. Concevoir une solution technique répondant à des besoins d'évolution del'infrastructure	Cahier des charges, comparaison de quatre solutions, grille de décision pondérée, coût total sur trois ans, architecture cible	Chap. 2 et 4
CP6. Mettre en production des évolutions del'infrastructure	Plan de mise en production par étapes, recette, plan de rollback, PRI et PCI, documentation d'exploitation, transfert de compétences	Chap. 5 · annexes G, M, O
CP7. Mettre en œuvre et optimiser la supervision des infrastructures	Prometheus, Grafana, exporters, Wazuh, Zabbix en SNMP ; indicateurs et seuils justifiés ; alerte testée ; dashboards	Chap. 6.1 · annexe O
CP8. Participer à la mesure et à l'analyse du niveau de sécurité de l'infrastructure	Lettre de mission d'audit, audit technique (11 constats), évaluation du rapport, analyse EBIOS Risk Manager	Chap. 6.2 · annexes A à D
CP9. Participer à l'élaboration et à la mise en œuvre de la politique de sécurité	PSSI en douze articles, hardening mesuré, backup conçu en 3-2-1-0 avec restauration prouvée, sensibilisation	Chap. 6.3 · annexes E à H
CP10. Participer à la détection et au traitement des incidents de sécurité	Chaîne de détection Wazuh, attaque simulée et RETEX, incident réel traité, journal d'incidents, veille, règle de détection locale testée	Chap. 6.4 · annexes I à K, O

Les compétences transversales. Pour *communiquer en français et en anglais*, ce dossier existe dans les deux langues (blocs 1 et 2), et le manuel d'exploitation est bilingue (annexe M). La plupart de la documentation technique que j'utilise est en anglais. Pour *apprendre en continu*, la veille (annexe K) et le journal d'incidents (annexe J) montrent comment chaque difficulté m'a donné une règle, une procédure ou une correction de documentation.

Le premier certificat. Les compétences CP1 à CP4 sont acquises. La partie CCP1, qui suit ce chapitre, décrit le socle tel qu'il fonctionne aujourd'hui.

C1

SOCLE

Administrer et sécuriser les infrastructures (CCP1)

Le socle du laboratoire : la virtualisation, le réseau, les systèmes, et les règles d'exploitation qui le maintiennent en condition opérationnelle.

CCP1 | CP1 CP2 CP3 CP4

CCP1 · Administrer et sécuriser les infrastructures

Cette partie raconte la première étape du projet : la construction du socle sur lequel repose l'évolution présentée dans les chapitres suivants. Je l'ai reconstruit sur un nouvel hyperviseur Fedora 44, machine par machine, dans l'ordre imposé par les dépendances. Il est en service depuis le 2 octobre 2026, avec ses cinq VM, l'annuaire et le partage de fichiers.

Je décris d'abord la méthode, puis chaque étape de construction avec ses commandes, son critère de passage et les difficultés rencontrées. Viennent ensuite une fiche par machine, puis l'administration au quotidien, rangée selon les quatre compétences du certificat : les bonnes pratiques et les procédures d'exploitation (CP1), le réseau (CP2), les systèmes (CP3) et la virtualisation (CP4). Comme dans le reste du dossier, je ne cite que ce que j'ai réellement fait et vérifié. Quand l'exécution s'est écartée du plan de construction, je le dis et j'explique pourquoi. Ce que le laboratoire ne couvre pas est listé à la fin.

◆ Le socle en un coup d'œil

Tout tient sur un seul poste physique, un ASUS ROG Strix G18 (32 Go de RAM, SSD NVMe chiffré par LUKS, BTRFS avec snapshots Snapper). Il sert d'hyperviseur sous Fedora 44, avec KVM/QEMU et libvirt. Je l'administre avec Cockpit et en ligne de commande.

Machine	Adresse	Rôle	Système	Administration
TeneT (hôte)	hôte physique	Hyperviseur	Fedora 44, KVM/QEMU, libvirt, SELinux *enforcing*	Cockpit, terminal
`pfsense-fw`	`10.10.10.254`	Firewall, router, DNS, seul point de passage	pfSense CE	Interface web, console
`Win-Server-DC`	`10.10.10.10`	Annuaire Active Directory et DNS, forêt `infrasec.local`	Windows Server 2025	Console, PowerShell
`truenas`	`10.10.10.20`	Stockage ZFS en miroir, partage SMB joint au domaine	TrueNAS SCALE 25.10	Interface web, shell
`fedora`	`10.10.10.30`	Containers *rootless* et supervision	Fedora 44 Server	Cockpit, SSH
`wazuh-siem`	`10.10.10.40`	SIEM	Ubuntu 26.04 LTS, Wazuh 4.14	Dashboard, SSH

Deux réseaux virtuels structurent le tout. Côté WAN, le réseau NAT de libvirt `192.168.122.0/24` (switch `virbr0`). Côté LAN, un bridge isolé, `br-tenet`, porte le segment interne `10.10.10.0/24`. Parmi les VM, seul le firewall est relié aux deux. L'hôte, lui, garde une adresse sur le LAN : c'est le constat F-01, traité plus loin. Le schéma ci-dessous reprend l'architecture physique (c'est aussi la figure 3 du chapitre 3.4) ; le schéma réseau de référence, avec sa matrice des flux, est en annexe N.

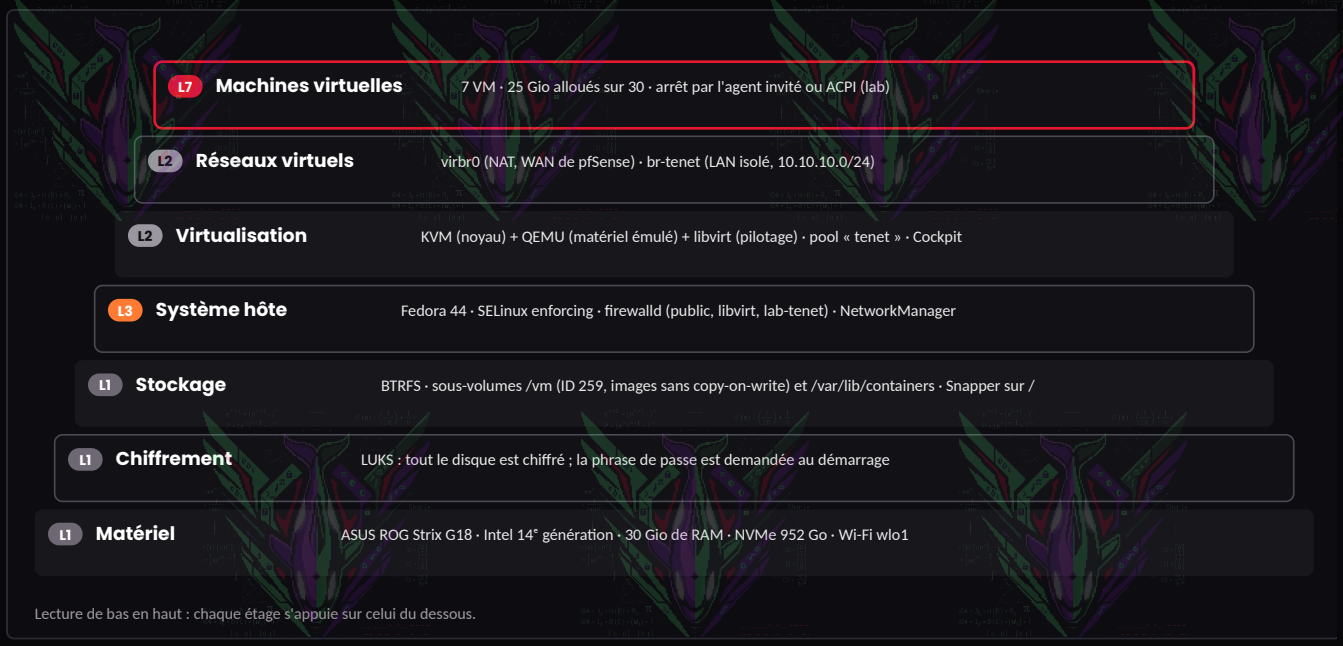


Figure 1 Architecture physique et virtualisation : du matériel aux machines virtuelles.

Abréviations — **L1…L7** : couches du modèle OSI : 1 physique, 2 liaison, 3 réseau, 4 transport, 5 session, 6 présentation, 7 application · **LUKS** : chiffrement complet du disque sous Linux (Linux Unified Key Setup) · **BTRFS** : système de fichiers à instantanés (B-tree file system) · **KVM** : hyperviseur intégré au noyau Linux (Kernel-based Virtual Machine) · **NAT** : traduction d'adresses (Network Address Translation) · **LAN** : réseau local du labo 10.10.10.0/24 · **WAN** : côté extérieur du pare-feu (réseau NAT 192.168.122.0/24) · **VM** : machine virtuelle · **ACPI** : signal d'alimentation simulé envoyé par l'hyperviseur (Advanced Configuration and Power Interface) · **agent invité** : service QEMU dans la VM qui reçoit les ordres de l'hyperviseur (guest agent) · **Gio / Go** : gibioctets (mémoire, 2^{30} octets) / gigaoctets (disque, 10^{9} octets)

Les cinq VM tournent en même temps dans un budget mémoire fixé à 22 Go sur 32, ce qui laisse à l'hôte la marge dont il a besoin.

Pourquoi ces choix. KVM est l'hyperviseur intégré au noyau Linux : QEMU émule le matériel de chaque VM, et libvirt fournit une interface unique pour les définir, les démarrer, les sauvegarder et les relier aux réseaux. Fedora apporte un noyau récent, SELinux actif par défaut et Cockpit, dans la même famille que Red Hat Enterprise Linux, que l'on rencontre en entreprise. pfSense est un firewall libre très répandu dans les petites structures. Windows Server reste la référence pour l'annuaire. TrueNAS SCALE apporte ZFS, qui protège l'intégrité des données. Wazuh est un SIEM libre complet. Chaque brique est donc représentative de ce qu'on administre en production.

◆ La méthode de construction

Un ordre dicté par les dépendances. Le LAN est isolé : rien n'y atteint Internet tant que le firewall ne route pas. Le contrôleur de domaine fournit ensuite le DNS et l'heure dont TrueNAS a besoin pour rejoindre le domaine. L'ordre de construction en découle :

```
pfsense-fw  ->  Win-Server-DC  ->  truenas  ->  fedora  ->  wazuh-siem
(passerelle)    (DNS, annuaire)    (joint AD)   (containers)  (SIEM)
```

Pendant les installations, chaque machine utilise pfSense comme passerelle et comme résolveur DNS. Dès que l'annuaire est en service, le DNS des serveurs bascule vers le contrôleur de domaine (`10.10.10.10`), parce que Kerberos a besoin de trouver ses enregistrements de service.

Un critère de passage par étape. Une machine n'est pas terminée tant que son test d'acceptation n'est pas vert : on ne passe pas à la suivante avec un critère rouge. Le critère est toujours un test qui prouve le service, pas un voyant : une résolution DNS qui répond, une jonction au domaine vérifiée, une métrique qui remonte.

Un snapshot à chaque critère validé. Deux types de points de restauration, toujours nommés de la même façon :

```
# VM : instantané à froid, pour un état cohérent
sudo virsh shutdown <vm>; sleep 25
sudo virsh snapshot-create-as <vm> <étiquette> "<description>"
sudo virsh start <vm>

# hôte : après tout changement de paquets, de réseau ou de SELinux
sudo snapper -c root create -d "POST-<OPÉRATION>-STABLE"
```

Un snapshot pris VM arrêtée est cohérent : aucune écriture n'est en cours. C'est indispensable pour le contrôleur de domaine, dont la base ne supporte pas d'être figée au milieu d'une transaction.

Des pièges notés au fur et à mesure. Trois pièges m'ont coûté du temps au début de la construction. Je les ai notés en tête du plan pour ne plus les subir :

Piège	Ce qui se passe	Parade
Ordre d'amorçage UEFI	L'option globale de démarrage est ignorée : l'ordre se règle disque par disque	`sudo virt-xml <vm> --edit target=<disque> --disk boot_order=<n>`
Média d'installation perdu	Après une redéfinition de la VM, le lecteur CD n'a plus d'image	`sudo virsh change-media <vm> <lecteur> /vm/iso/<image>.iso --config`
Windows : « Press any key to boot from CD »	L'invite expire avant qu'on ouvre la console	Ouvrir la console Cockpit avant le premier démarrage, ou `sudo virsh reset <vm>`

Une règle pour les secrets. Aucun mot de passe, aucune clé, aucun jeton dans un fichier ou dans une commande. Toutes les saisies sensibles sont interactives : `Read-Host -AsSecureString` sous Windows, invites des interfaces web ailleurs. Rien de tout cela n'entre dans le dossier.

Le calendrier de construction

Période	Étape	Repère
Septembre 2026	Préparation de l'hôte Fedora 44 : paquets, sous-volumes, SELinux, pool, réseaux, Cockpit, Snapper	Point Snapper `POST-SOCLE-FEDORA-TENET-STABLE`
Fin septembre au 2 octobre	Construction des cinq VM dans l'ordre des dépendances ; TrueNAS le 2 octobre (INC-01, INC-02)	Jalon du 2 octobre : cinq VM en service, annuaire et partage fonctionnels
4 octobre	Métriques du contrôleur de domaine (INC-03), audit (PV-02), test de restauration (PV-01), hardening	Lynis 69 → 76, rapport de gel
5 et 6 octobre	Accès distant WireGuard (évolution, CCP2)	Chapitre 5
11 octobre	Recette de l'évolution (PV-04), snapshots de gel `gel-20261011`	Annexes F et O

La date qui commandait tout était le dépôt du dossier. J'ai donc placé la construction du socle au plus tôt, pour que les étapes de sécurité (audit, restauration, hardening) s'appuient sur une base stable.

Étape 1 · L'hôte TeneT

L'hôte est la fondation de tout le reste : s'il est mal préparé, aucune VM ne démarre ou les disques se dégradent. J'ai donc traité son installation comme celle d'un serveur de production. Le disque est chiffré par LUKS dès l'installation de Fedora : si le poste est perdu ou volé, les disques des VM ne sont pas lisibles.

Les paquets. Je n'installe que ce qui sert : la virtualisation, son administration, les containers, SELinux et les snapshots, plus quelques outils réseau.

```
sudo dnf upgrade --refresh -y
sudo dnf install -y qemu-kvm libvirt libvirt-daemon-config-network virt-install \
  edk2-ovmf swtpm libosinfo guestfs-tools \
  cockpit cockpit-machines cockpit-podman cockpit-storaged cockpit-selinux \
  podman buildah skopeo policycoreutils-python-utils setroubleshoot-server \
  snapper btrfs-progs wireguard-tools nmap tcpdump bind-utils
```

Paquet	Rôle
`qemu-kvm`, `libvirt`, `virt-install`	Hyperviseur, gestion des VM, création en ligne de commande
`edk2-ovmf`, `swtpm`	Firmware UEFI et TPM émulé pour les VM qui en ont besoin
`cockpit-*`	Console web : VM, containers, stockage, SELinux
`podman`, `buildah`, `skopeo`	Containers sans démon, construction et copie d'images
`policycoreutils-python-utils`, `setroubleshoot-server`	`semanage` pour les contextes SELinux, `sealert` pour lire les refus
`snapper`, `btrfs-progs`	Snapshots du système et gestion des sous-volumes
`wireguard-tools`, `nmap`, `tcpdump`, `bind-utils`	Tests réseau et diagnostic

Les services de libvirt. Fedora 44 découpe libvirt en démons modulaires, activés à la demande par des sockets systemd. J'active chaque socket, puis j'ajoute mon compte aux groupes `libvirt` et `kvm` pour administrer sans être root à chaque commande :

```
for d in virtqemud virtnetworkd virtstoraged virtinterfaced virtnodedevd; do
  sudo systemctl enable --now ${d}.socket
done
sudo systemctl enable --now virtlogd.socket cockpit.socket firewalld
sudo usermod -aG libvirt,kvm "$USER"
```

Des sous-volumes dédiés. Les disques des VM et les couches des containers ont chacun leur sous- volume BTRFS, `/vm` et `/var/lib/containers`. Cela permet de les exclure des snapshots du système et de leur appliquer des options propres. La plus importante est l'attribut NOCOW (`chattr +C`). Un fichier qcow2 est réécrit en permanence ; sur un système de fichiers en copie à l'écriture, il se fragmente et les performances s'effondrent. L'attribut n'a pas d'effet rétroactif : il doit être posé sur le répertoire vide, avant la création de la première image.

```
sudo btrfs subvolume create /vm
sudo btrfs subvolume create /var/lib/containers
sudo chattr +C /vm /var/lib/containers
lsattr -d /vm /var/lib/containers        # doit afficher l'attribut C
```

Les deux sous-volumes sont montés par `/etc/fstab`, avec l'UUID du système de fichiers racine :

```
UUID=<UUID>  /vm                  btrfs  subvol=vm,nodatacow,noatime 0 0
```

```
UUID=<UUID> /var/lib/containers btrfs subvol=var/lib/containers,nodatacow,noatime 0 0
sudo systemctl daemon-reload && sudo mount -a
findmnt -t btrfs
```

SELinux, sans jamais le désactiver. C'est l'étape qui piège le plus : sans elle, aucune VM ne démarre, et libvirt ne mentionne pas SELinux dans son message d'erreur. Les images doivent porter le contexte `virt_image_t`. Je déclare la règle de façon permanente, puis je l'applique. Le répertoire n'est traversable que par son propriétaire et les services autorisés (`chmod 711`) :

```
sudo mkdir -p /vm/images /vm/iso
sudo semanage fcontext -a -t virt_image_t '/vm/images(/.*)?'
sudo restorecon -Rv /vm/images
sudo chmod 711 /vm/images
ls -dZ /vm/images          # attendu : system_u:object_r:virt_image_t:s0
```

La règle déclarée par `semanage` survit à un réétiquetage complet du système ; un simple `chcon` aurait été perdu au prochain `restorecon`.

Le pool de stockage. Un pool libvirt nommé `tenet` pointe sur `/vm/images`. Je l'ai testé de bout en bout avec une image jetable, qui doit hériter à la fois du contexte SELinux et de l'attribut NOCOW :

```
sudo virsh pool-define-as tenet dir --target /vm/images
sudo virsh pool-build tenet && sudo virsh pool-start tenet && sudo virsh pool-autostart tenet
sudo qemu-img create -f qcow2 /vm/images/test.qcow2 1G
ls -Z /vm/images/test.qcow2 && lsattr /vm/images/test.qcow2
sudo rm /vm/images/test.qcow2
```

Les deux réseaux. Le réseau `default` de libvirt (NAT, `192.168.122.0/24`, switch `virbr0`) sert de WAN : l'hôte y joue le rôle de router et traduit les adresses vers Internet. Un second réseau, `tenet`, est un bridge isolé (`br-tenet`), sans routage vers l'extérieur : il porte le LAN `10.10.10.0/24`, et sa seule sortie est le firewall. Je vérifie les deux avec `sudo virsh net-list --all`, qui doit les montrer actifs et à démarrage automatique.

Cockpit. La console web de Fedora remplace `virt-manager`. Depuis une seule interface, elle crée les VM, ouvre leurs consoles, gère les snapshots, les containers, le stockage et affiche les refus SELinux en clair, avec la correction proposée. Elle a un piège : à la création d'une VM, elle propose par défaut `/var/lib/libvirt/images`. Il faut choisir explicitement le pool `tenet`, sinon le disque perd à la fois le contexte SELinux et l'attribut NOCOW. Après chaque création, je contrôle donc `ls -Z /vm/images` et `lsattr /vm/images/*.qcow2`.

Snapper. L'hôte prend ses propres points de restauration. J'ai configuré Snapper sur la racine, avec une rétention bornée et ses timers, puis pris le point de référence du socle :

```
sudo snapper -c root create-config /
sudo snapper -c root set-config NUMBER_LIMIT=10 NUMBER_LIMIT_IMPORTANT=5
sudo systemctl enable --now snapper-timeline.timer snapper-cleanup.timer
sudo snapper -c root create -d "POST-SOCLE-FEDORA-TENET-STABLE"
```

Les sous-volumes `/vm` et `/var/lib/containers` ne sont pas inclus dans les snapshots de la racine : revenir en arrière sur le système ne fait jamais reculer les disques des VM, qui ont leurs propres snapshots.

Critère de passage de l'hôte.

Contrôle	Commande	Attendu
SELinux	`getenforce`	`Enforcing`
Sous-volumes	`findmnt -t btrfs ; lsattr -d /vm`	montés ; attribut `C`
Contexte des images	`ls -dZ /vm/images`	`virt_image_t`
Pool	`sudo virsh pool-info tenet`	`running`, démarrage automatique

Contrôle	Commande	Attendu
Réseaux	`sudo virsh net-list --all`	`default` et `tenet` actifs
Containers	`podman info --format '{{.Host.Security.Rootless}}'`	`true`
Refus SELinux	`sudo ausearch -m AVC -ts today`	aucun
Services	`systemctl --failed`	aucune unité en échec

Ce qu'il faut comprendre. KVM transforme le noyau Linux en hyperviseur : chaque VM est un processus QEMU, qui émule son matériel, et les instructions du processeur sont exécutées directement grâce aux extensions de virtualisation. libvirt pilote l'ensemble et fournit les réseaux virtuels. Un réseau NAT donne aux VM une sortie vers Internet derrière l'adresse de l'hôte, sans les rendre joignables depuis l'extérieur. Un réseau isolé n'a aucune sortie : c'est pour cela que le firewall doit être la seule machine reliée aux deux. Enfin, SELinux étiquette chaque processus QEMU et chaque disque : un processus ne peut ouvrir que les fichiers qui portent son étiquette.

◆ Étape 2 · Le firewall pfSense

La VM. Je l'ai créée depuis Cockpit, dans le pool `tenet`, avec deux cartes réseau virtio : la première sur le réseau `default` (WAN), la seconde sur `tenet` (LAN). L'installateur Netgate installe pfSense CE. La VM a d'abord été créée sous le nom `tenet-pfsense`. Je l'ai renommée `pfsense-fw` pour garder la convention de nommage du laboratoire :

```
sudo virsh shutdown tenet-pfsense
sudo virsh domrename tenet-pfsense pfsense-fw
sudo virsh start pfsense-fw
```

Les interfaces. Depuis la console (menu 1, puis 2) : `vtnet0` devient le WAN, en DHCP sur le NAT de libvirt (il obtient `192.168.122.95`) ; `vtnet1` devient le LAN, en `10.10.10.254/24`. Je vérifie ensuite la sortie vers Internet depuis le shell de pfSense (menu 8) :

```
ping -c3 1.1.1.1
host cloudflare.com
```

Une fois l'installation confirmée, j'éjecte le média, pour qu'un redémarrage ne relance jamais l'installateur :

```
sudo virsh domblklist pfsense-fw                  # repérer le lecteur CD
sudo virsh change-media pfsense-fw sda --eject --config
```

L'assistant de configuration. Dans l'interface web (*System → Setup Wizard*), le firewall reçoit son nom, `fw01`, et son domaine DNS, `infrasec.lab`, distinct de la forêt Active Directory `infrasec.local` pour ne pas les confondre. Le mot de passe d'administration est saisi de façon interactive et n'est noté nulle part dans le dossier.

Le filtrage. Le principe est le refus par défaut :

Réglage	Chemin	Valeur
Règles WAN	*Firewall → Rules → WAN*	Aucune : tout trafic entrant est refusé
Règles LAN	*Firewall → Rules → LAN*	Sorties explicites : DNS, mises à jour, remontée des journaux et des métriques
Journal des refus	*Status → System Logs → Firewall*	Consulté pendant chaque test

Les services du segment. pfSense porte le résolveur DNS du segment (*Services → DNS Resolver*, Unbound). Une fois l'annuaire en service, la zone `infrasec.local` est tenue par le contrôleur de domaine, et pfSense la relaie (PSSI, article 6.5). Il porte aussi le service NTP (*Services → NTP*) : c'est la référence de temps du segment, sur laquelle le contrôleur de domaine se synchronise.

La sauvegarde de sa configuration. L'export XML de pfSense (*Diagnostics → Backup & Restore*) est chiffré par une phrase secrète et rangé hors ligne. Il ne va jamais dans le dossier : il contient l'empreinte du mot de passe d'administration et la clé TLS de l'interface web. Cette reprise a été testée le 11 octobre (PV-04, annexe O) : après une modification témoin, la configuration complète a été restaurée depuis l'export en moins de cinq minutes, service vérifié de bout en bout.

Critère de passage. Depuis le LAN, Internet répond et les noms se résolvent. Depuis le WAN, l'interface d'administration est injoignable. Le lecteur CD est vide.

Un écart relevé plus tard. L'audit du 4 octobre a montré que l'interface d'administration répondait encore en HTTP sur le port 80, en plus de HTTPS (constat F-02). La correction est planifiée : forcer HTTPS et restreindre la source de gestion (annexe F).

Ce qu'il faut comprendre. pfSense est un firewall à états : quand une connexion sortante est autorisée, les réponses qui lui appartiennent sont acceptées automatiquement. Il suffit donc d'autoriser des sorties précises et de tout refuser en entrée. Le résolveur Unbound fonctionne par défaut en mode récursif : il interroge lui-même les serveurs DNS racine, sans dépendre d'un fournisseur. Donner au firewall un domaine DNS distinct de la forêt évite qu'un nom d'hôte du firewall soit confondu avec un enregistrement de l'annuaire.

◆ Étape 3 · Le contrôleur de domaine

La VM. Windows Server 2025 tourne avec un disque et une carte réseau virtio, les plus performants sous KVM. Windows ne voit pas un disque virtio sans pilote : au moment de choisir le disque d'installation, je charge le pilote `viostor` depuis l'ISO `virtio-win`, montée comme second lecteur. J'ouvre la console Cockpit avant le premier démarrage, pour ne pas manquer l'invite de démarrage sur le CD.

Réseau et nom. En PowerShell administrateur, une adresse fixe, le DNS sur lui-même (le futur serveur DNS du domaine), puis le nom `DC01` :

```
New-NetIPAddress -InterfaceAlias "Ethernet" -IPAddress 10.10.10.10 `
  -PrefixLength 24 -DefaultGateway 10.10.10.254
Set-DnsClientServerAddress -InterfaceAlias "Ethernet" -ServerAddresses 127.0.0.1
Rename-Computer -NewName "DC01" -Restart
```

La promotion. J'installe le rôle AD DS, puis je crée la forêt `infrasec.local` avec le DNS intégré. Le mot de passe du mode de restauration (DSRM) est saisi de façon interactive : il ne passe ni par un fichier ni par l'historique.

```
Install-WindowsFeature AD-Domain-Services -IncludeManagementTools
$dsrm = Read-Host -AsSecureString "Mot de passe DSRM"
Install-ADDSForest -DomainName "infrasec.local" -DomainNetbiosName "INFRASEC" `
  -InstallDns -SafeModeAdministratorPassword $dsrm -Force
```

Le serveur redémarre en contrôleur de domaine : il porte la forêt, le domaine, le catalogue global et la zone DNS intégrée à l'annuaire. Je vérifie l'ensemble avec quatre commandes, que je relance après chaque intervention :

```
Get-ADDomain | Select-Object Forest,DNSRoot,DomainMode
Get-ADForest  | Select-Object ForestMode,GlobalCatalogs
nltest /dsgetdc:infrasec.local
Resolve-DnsName infrasec.local
```

Commande	Ce qu'elle prouve
`Get-ADDomain`	Le domaine existe, avec sa racine DNS et son niveau fonctionnel
`Get-ADForest`	La forêt est en place et le contrôleur est catalogue global
`nltest /dsgetdc`	Un client trouve un contrôleur de domaine par le DNS
`Resolve-DnsName`	La zone `infrasec.local` répond

L'heure. Kerberos refuse toute authentification au-delà de 5 minutes d'écart. Le contrôleur de domaine est la référence de temps du domaine ; il se synchronise lui-même sur pfSense. Je n'avais pas réglé ce point au départ, et il a fait échouer la jonction de TrueNAS (INC-02, étape 4) : le fuseau horaire du contrôleur était mal réglé.

Les comptes. Un compte de service est dédié à la jonction de TrueNAS au domaine. Un groupe porte l'accès au partage de fichiers : les droits suivent les groupes, jamais les personnes. Les mots de passe sont saisis de façon interactive. Depuis INC-02, ceux des comptes utilisés sur plusieurs plateformes n'emploient que des caractères placés au même endroit sur les claviers français et américain (PSSI, article 5.4.3).

Une astuce de laboratoire. La console noVNC de Cockpit ne permet pas de coller du texte dans la VM. Pour éviter de retaper un script, je le sers depuis un autre nœud par un serveur HTTP temporaire et je l'exécute côté contrôleur. C'est réservé au laboratoire : en production, on passe par un partage d'administration ou un outil de déploiement.

Les agents. L'agent Wazuh s'installe par un MSI. J'utilise une installation qui attend la fin du programme, pour ne démarrer le service qu'une fois l'installation terminée :

```
Start-Process msiexec.exe -Wait -ArgumentList '/i','C:\chemin\wazuh-agent.msi', `
  'WAZUH_MANAGER=10.10.10.40','WAZUH_AGENT_NAME=Win-Server-DC','/qn'
Start-Service WazuhSvc
Get-Service WazuhSvc
```

L'exporter de métriques windows_exporter (port 9182) m'a demandé plus de travail. La version 0.31.8 a supprimé deux collecteurs que mon plan demandait (`cs` et `logon`) : le service s'arrêtait aussitôt démarré, sans message (INC-03). En le lançant au premier plan, j'ai obtenu l'erreur `unknown collector cs` , puis `unknown collector logon` . J'ai écrit un script qui teste le jeu de collecteurs, retire ceux que le service rejette, puis reconfigure le service. Le jeu retenu comprend `ad` et `dns` , propres au rôle de contrôleur de domaine :

```
msiexec /i windows_exporter.msi `
  ENABLED_COLLECTORS="cpu,logical_disk,net,os,service,system,memory,process,tcp,ad,dns" `
  /qn
Get-Service windows_exporter
Invoke-WebRequest http://localhost:9182/metrics -UseBasicParsing |
  Select-Object -Expand Content | Select-String windows_
```

Une règle propre au contrôleur de domaine. Il ne s'arrête jamais par `virsh destroy` : une coupure brutale peut corrompre la base Active Directory. Toujours `virsh shutdown` , et un snapshot à froid avant toute opération risquée.

Ce qu'il faut comprendre. Une forêt Active Directory contient un ou plusieurs domaines ; chaque contrôleur de domaine en porte une copie de la base. Le catalogue global permet de chercher un objet dans toute la forêt. Les clients ne trouvent pas le contrôleur par son nom : ils interrogent le DNS sur des enregistrements de service (SRV), comme `_ldap._tcp.dc._msdcs.infrasec.local` . C'est ce que vérifie `nltest /dsgetdc` , et c'est pourquoi tous les serveurs du domaine doivent utiliser le DNS du contrôleur. Kerberos authentifie par des tickets horodatés : au-delà de 5 minutes d'écart, un ticket est considéré comme rejoué et refusé. Le mode DSRM, enfin, permet de démarrer le contrôleur hors annuaire pour le réparer ou le restaurer : son mot de passe est un secret critique.

◆ Étape 4 · Le stockage TrueNAS

La VM. Trois disques virtio : un disque système de 16 Go et deux disques de données de 40 Go, destinés au miroir ZFS. Le disque système reste séparé des données, pour pouvoir réinstaller TrueNAS sans toucher au pool.

```
sudo virt-install --name truenas \
  --disk path=/vm/images/truenas-os.qcow2,size=16,format=qcow2,bus=virtio \
  --disk path=/vm/images/truenas-d1.qcow2,size=40,format=qcow2,bus=virtio \
  --disk path=/vm/images/truenas-d2.qcow2,size=40,format=qcow2,bus=virtio \
  --cdrom /vm/iso/<truenas-scale>.iso --network network=tenet,model=virtio \
  --graphics vnc --noautoconsole
```

Le premier incident : l'installateur ne démarre pas (INC-01). La VM restait bloquée sur le menu du firmware UEFI (OVMF), « Please select boot device ». Le firmware ne choisissait pas le lecteur CD malgré l'ordre d'amorçage, et la console web de Cockpit ne transmettait pas la touche Entrée. L'envoi de la touche depuis l'hôte (`virsh send-key`) échouait aussi, la VM s'étant arrêtée entre-temps. J'ai basculé la VM sur un firmware BIOS (SeaBIOS) : dans sa définition XML, j'ai retiré le bloc `<firmware>` , les éléments `<loader>` et `<nvram>` et l'attribut `firmware='efi'` de la section `<os>` , puis j'ai redéfini la VM :

```
sudo virsh dumpxml truenas > truenas.xml     # retrait des éléments UEFI
sudo virsh define truenas.xml
sudo virsh start truenas
```

SeaBIOS a démarré directement sur le CD, et l'installateur de TrueNAS SCALE 25.10.7 s'est lancé. Depuis, je choisis le BIOS pour les VM dont l'installation passe par la console web.

L'installation et le réseau. TrueNAS s'installe sur le disque de 16 Go. Depuis sa console, je lui donne une adresse fixe `10.10.10.20/24` , la passerelle `.254` et le DNS du contrôleur de domaine, `10.10.10.10` : Kerberos a besoin du DNS du domaine pour trouver ses enregistrements de service.

Le pool. Dans l'interface web (*Storage → Create Pool*), le pool `tank` est un miroir ZFS sur les deux disques de données. Un miroir survit à la perte d'un disque. ZFS calcule une somme de contrôle sur chaque bloc : il détecte les erreurs silencieuses et les corrige depuis l'autre copie du miroir, à condition de lancer un *scrub* régulier.

La jonction au domaine. Dans *Credentials → Directory Services*, je renseigne le domaine `INFRASEC.LOCAL` , le compte de service dédié et son mot de passe, saisi de façon interactive. C'est là qu'est survenu le second incident.

Le second incident : la jonction refusée (INC-02). La première tentative a été refusée : « Time offset from the domain controller exceeds the maximum permitted value ». J'ai comparé les horloges depuis l'hôte avec `virsh domtime` . TrueNAS était à l'heure UTC exacte, le contrôleur de domaine avait plus de 5 minutes d'écart, à cause d'un fuseau horaire mal réglé. Après correction du fuseau et la synchronisation NTP du contrôleur sur pfSense, une seconde erreur est apparue : « The bind password is not correct ». Le mot de passe du compte de jonction avait été saisi sur deux dispositions de clavier différentes (QWERTY et AZERTY), ce qui donnait deux chaînes différentes. J'ai réinitialisé le mot de passe avec des caractères neutres, et la jonction a abouti. Le service Active Directory de TrueNAS est passé à l'état HEALTHY : royaume `INFRASEC.LOCAL` , keytab du compte machine créé, cache des comptes activé.

Le partage. Le jeu de données `tank/partage` porte le partage SMB `partage` (*Shares → Windows (SMB) Shares*). Son accès est contrôlé par des ACL NFSv4, posées dans l'éditeur de permissions du jeu de données et attribuées au groupe Active Directory prévu à cet effet.

La protection des données. Dans *Data Protection* :

Tâche	Réglage
Snapshots périodiques de `tank/partage`	Toutes les heures, conservés deux semaines, nommés `auto-%Y-%m- %d_%H-%M` (visibles dans les « versions précédentes » de Windows)
Réplication	Vers `tank/partage_backup`, par `zfs send` et `zfs recv`
Scrub du pool `tank`	Planifié, pour vérifier toutes les sommes de contrôle

Critère de passage. Depuis le shell de TrueNAS (*System Settings → Shell*), la jonction est prouvée par Kerberos, pas seulement par l'accès au partage :

```
wbinfo -t             # relation d'approbation avec le domaine : OK
net ads testjoin      # jonction valide
zpool status tank     # miroir ONLINE, 0 erreur
```

La restauration a été prouvée ensuite par le procès-verbal PV-01 (annexe G) : trois fichiers supprimés puis restaurés en moins d'une seconde, empreintes SHA-256 conformes.

Ce qu'il faut comprendre. Avec deux disques de données, le miroir est la seule disposition redondante : chaque bloc est écrit sur les deux disques. ZFS écrit toujours les données modifiées à un nouvel emplacement (copie à l'écriture). Un snapshot est donc instantané : il fige la liste des blocs à un instant donné et n'occupe de place que pour les blocs modifiés ensuite. Il est en lecture seule, ce qui le protège d'une suppression ou d'un chiffrement par un rançongiciel côté client. Les ACL NFSv4 sont plus fines que les droits POSIX (héritage, droits séparés de lecture, d'écriture, de suppression) et correspondent aux ACL de Windows, ce qui les rend naturelles pour un partage SMB. La jonction crée un compte machine dans l'annuaire et une *keytab*, le fichier de clés qui permet à TrueNAS de s'authentifier par Kerberos.

◆ Étape 5 · Le nœud de containers

```
fedora
```

La VM. Fedora 44 Server, en adresse fixe `10.10.10.30/24`, passerelle `.254`, DNS `.10`. Elle s'administre par Cockpit (port 9090) et par SSH. Elle sert aussi de poste d'audit : la VM Parrot prévue pour l'audit n'a jamais démarré, et l'audit du 4 octobre a été lancé depuis ce nœud.

Un compte sans privilège pour les containers. Les containers tournent sous le compte `ais`, sans droits root. Podman *rootless* s'appuie sur des plages d'UID et de GID déléguées à ce compte (`/etc/subuid`, `/etc/subgid`) : root dans un container correspond à un utilisateur sans privilège sur l'hôte. Le *lingering* systemd permet aux services du compte de tourner sans session ouverte :

```
sudo loginctl enable-linger ais
grep ais /etc/subuid /etc/subgid
mkdir -p ~/.config/containers/systemd
```

Des services décrits par des Quadlets. Chaque container est décrit par un fichier `.container` dans `~/.config/containers/systemd/`. systemd en génère une unité utilisateur : démarrage automatique, redémarrage en cas d'échec, journaux dans `journalctl`. Ces fichiers sont la source de vérité : image, port publié, volumes, arguments. node_exporter illustre un cas particulier. Il doit lire le système de fichiers de l'hôte, mais on ne peut pas réétiqueter `/proc` ni `/sys` pour SELinux avec l'option `:Z`. Il partage donc le réseau de l'hôte et monte la racine en lecture seule :

```
[Unit]
Description=Prometheus node-exporter (rootless)
[Container]
Image=quay.io/prometheus/node-exporter:latest
Network=host
Volume=/:/host:ro,rslave
Exec=--path.rootfs=/host --collector.systemd
[Install]
WantedBy=default.target
systemctl --user daemon-reload
systemctl --user start node-exporter
systemctl --user status node-exporter
podman top node-exporter huser # l'UID réel sur l'hôte : pas root
```

La pile de supervision. Sur le même modèle tournent Prometheus et Grafana. Le plan prévoyait Prometheus sur son port habituel, 9090, mais Cockpit l'occupe déjà sur ce nœud : je l'ai publié sur 9091. Grafana écoute sur 3000. Zabbix, ajouté pendant l'évolution, interroge pfSense en SNMP. La configuration de la supervision elle-même relève de la compétence CP7 et est décrite au chapitre 6.1.

Le pare-feu local. firewalld n'ouvre que les ports nécessaires. Quand un port ne sert plus, je le ferme : celui de node_exporter (9100) a été retiré, puisque Prometheus l'interroge en local (constat F-05) :

```
sudo firewall-cmd --permanent --remove-port=9100/tcp
sudo firewall-cmd --reload && sudo firewall-cmd --list-all
```

Critère de passage. `systemctl --user status` actif pour chaque service, `podman ps` montre les containers, `podman top … huser` montre un UID non root, et les métriques répondent (`curl -s localhost:9100/metrics | head`). Le hardening de ce nœud est décrit avec la compétence CP3.

Ce qu'il faut comprendre. Un container *rootless* repose sur les *user namespaces* : l'UID 0 à l'intérieur du container correspond, sur l'hôte, à un UID pris dans la plage subordonnée du compte `ais` , sans aucun droit. Si un attaquant sortait du container, il se retrouverait avec un compte sans privilège, et non root. Pour la même raison, un container *rootless* ne peut pas, par défaut, écouter sur un port inférieur à 1024. Les Quadlets remplacent un outil de composition : c'est systemd lui-même qui démarre, surveille et relance les containers, comme n'importe quel service. L'option `:Z` d'un volume demande à Podman de lui donner une étiquette SELinux privée, lisible par ce seul container.

◆ Étape 6 · Le SIEM Wazuh

La VM. Ubuntu Server 26.04 LTS. J'ai choisi cette distribution parce qu'elle figure dans la matrice de support de Wazuh 4.14 et qu'elle est maintenue jusqu'en 2031 : un critère de supportabilité, le même que dans le cahier des charges. Adresse fixe `10.10.10.40/24` , passerelle `.254` .

L'installation. L'assistant officiel installe en une fois le gestionnaire, l'indexeur et le dashboard, dans une version figée :

```
curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh
sudo bash ./wazuh-install.sh -a
sudo systemctl status wazuh-manager wazuh-indexer wazuh-dashboard
```

Composant	Rôle
Gestionnaire (*manager*)	Reçoit les événements des agents, applique les règles de détection, génère les alertes
Indexeur (*indexer*)	Stocke et indexe les événements et les alertes
Dashboard	Interface web : alertes, conformité SCA, intégrité des fichiers, recherche

L'assistant génère un mot de passe d'administration et le range dans une archive. Je ne le note dans aucun livrable ; sa rotation par l'outil officiel (`wazuh-passwords-tool.sh`) reste à faire.

Les agents. Deux agents remontent leurs événements : le contrôleur de domaine et le nœud `fedora` . Ils se connectent au gestionnaire sur les ports 1514 et 1515, avec une authentification gérée par le gestionnaire. Le module SCA compare leur configuration aux benchmarks CIS, et le contrôle d'intégrité des fichiers (FIM) surveille les fichiers sensibles. Le firewall, TrueNAS et l'hyperviseur ne sont pas encore raccordés : c'est une limite connue.

Critère de passage. Le dashboard répond sur `https://10.10.10.40` , les trois services sont actifs et les deux agents apparaissent connectés.

Ce qu'il faut comprendre. Un agent s'enregistre d'abord auprès du gestionnaire sur le port 1515, qui lui délivre sa clé ; il envoie ensuite ses événements, chiffrés, sur le port 1514. Centraliser les journaux a un intérêt de sécurité direct : un attaquant qui prend la main sur un serveur ne peut plus effacer les traces déjà envoyées au SIEM. Le module SCA vérifie la configuration (est-elle conforme au référentiel ?), alors que le FIM surveille les changements (ce fichier a-t-il été modifié ?). Les deux se complètent.

◆ Étape 7 · Vérifier et figer le socle

Après chaque machine. Trois vérifications sur l'hôte, toujours les mêmes :

```
sudo virsh list --all
sudo ls -lZ /vm/images/      # svirt_image_t (VM démarrée) ou virt_image_t (arrêtée)
free -h
```

Si une VM refuse de démarrer, je regarde d'abord SELinux (`sudo ausearch -m AVC -ts recent` , ou la page SELinux de Cockpit, qui l'explique en clair).

Le bilan de la construction.

Machine	Critère de passage	Preuve
Hôte	SELinux *enforcing*, sous-volumes NOCOW, contexte `virt_image_t` , pool actif, Podman *rootless*	Point Snapper `POST-SOCLE-FEDORA-TENET-STABLE`
`pfsense-fw`	Internet depuis le LAN, interface d'administration injoignable depuis le WAN	Shell pfSense, journal du firewall
`Win-Server-DC`	Forêt `infrasec.local` , catalogue global, DNS	`Get-ADDomain` , `nltest` , `Resolve-DnsName`
`truenas`	Jonction Kerberos, pool en miroir sain	`wbinfo -t` , `net ads testjoin` , `zpool status`
`fedora`	Services *rootless* actifs, UID non root	`systemctl --user status` , `podman top`
`wazuh-siem`	Dashboard, services et agents actifs	`systemctl status` , dashboard

Le gel. Le 11 octobre, avant la soutenance, j'ai figé l'ensemble. Une boucle arrête proprement les cinq VM et prend leurs snapshots de gel (`gel-20261011`), puis un point Snapper est pris sur l'hôte (annexe F) :

```
for v in pfsense-fw Win-Server-DC truenas fedora wazuh-siem; do sudo virsh shutdown
"$v"; done
sleep 45
for v in pfsense-fw Win-Server-DC truenas fedora wazuh-siem; do
  sudo virsh snapshot-create-as "$v" gel-20261011 "État gelé pour la soutenance"
```

```
done
sudo snapper -c root create -d "POST-FREEZE-STABLE"
```

Ce qui a changé par rapport au plan. Le plan de construction était un guide, pas un texte figé. Voici les écarts, et pourquoi :

Prévu	Réalisé	Raison
TrueNAS en firmware UEFI	BIOS (SeaBIOS)	INC-01 : installateur bloqué dans la console web
Prometheus sur le port 9090	Port 9091	Cockpit occupe déjà 9090 sur le nœud
windows_exporter avec les collecteurs `cs` et `logon`	Jeu corrigé, sans ces deux collecteurs	INC-03 : collecteurs supprimés en 0.31.8
Tableau de bord Grafana 14694	Tableau 23942	Le 14694 dépend des métriques supprimées (INC-03)
VM d'audit Parrot	Audit lancé depuis le nœud `fedora`	Image préfabriquée non amorçable

◆ Les fiches des machines

Chaque fiche réunit ce qu'un exploitant doit savoir d'une machine : son rôle, ce qu'elle expose, comment l'administrer, comment elle est supervisée et sauvegardée, et ce qui reste à corriger. Les ports exposés sont ceux relevés par l'audit du 4 octobre (annexe B).

Hôte TeneT.

Rubrique	Contenu
Rôle	Hyperviseur, router du WAN `192.168.122.0/24`
Système	Fedora 44, KVM/QEMU, libvirt, Cockpit, firewalld, SELinux *enforcing*, disque chiffré par LUKS
Exposition sur le segment	Adresse d'administration `10.10.10.2`, tous les ports filtrés
Administration	Cockpit, terminal local
Reprise	Points Snapper `POST-…-STABLE`
À corriger	F-01 : l'adresse sur le segment contourne le firewall ; cible : réseau d'administration dédié (M-01)

`pfsense-fw` (`fw01.infrasec.lab`).

Rubrique	Contenu
Rôle	Seul point de passage, router, DNS (Unbound), NTP
Ports exposés	53 (DNS), 80 (HTTP), 443 (HTTPS)
Administration	Interface web, console Cockpit (menu 8 pour le shell)
Supervision	SNMP vers le collecteur Zabbix, ajouté pendant l'évolution
Reprise	Export XML chiffré hors ligne, restauration testée en moins de cinq minutes (PV-04) ; snapshot de la VM
À corriger	F-02 : interface encore en HTTP sur le port 80

`Win-Server-DC` (`DC01`).

Rubrique	Contenu
Rôle	Forêt `infrasec.local`, DNS, référence de temps du domaine
Ports exposés	53, 88, 135, 139, 389, 445, 464, 593, 636, 3268, 3269 (services AD), 3389 (RDP)
Administration	Console, PowerShell
Supervision	Agent Wazuh, windows_exporter (port 9182)
Reprise	Snapshot à froid de la VM, jamais de `virsh destroy`
À corriger	F-03 : RDP ouvert à tout le segment, alors qu'il ne sert pas

`truenas`.

Rubrique	Contenu
Rôle	Pool ZFS `tank` en miroir, partage SMB `partage` joint au domaine
Ports exposés	80, 443 (interface), 139, 445 (SMB), 5357 (WS-Discovery)
Administration	Interface web, shell
Supervision	Non raccordé au SIEM (limite connue)
Reprise	Snapshots horaires, réplication vers `tank/partage_backup`, restauration prouvée (PV-01)
À corriger	F-04 : WS-Discovery exposé

`fedora`.

Rubrique	Contenu
Rôle	Containers *rootless* : Prometheus, Grafana, node_exporter, Zabbix ; poste d'audit
Ports exposés	22 (SSH), 3000 (Grafana), 9090 (Cockpit), 9091 (Prometheus) ; 9100 fermé depuis F-05
Administration	Cockpit, SSH
Supervision	Agent Wazuh, node_exporter
Reprise	Snapshot de la VM ; les Quadlets décrivent chaque service
À corriger	F-06 : plan d'administration (SSH, Cockpit) joignable depuis tout le segment

`wazuh-siem`.

Rubrique	Contenu
Rôle	SIEM : gestionnaire, indexeur, dashboard
Ports exposés	22 (SSH), 443 (dashboard), 9090 (Cockpit)
Administration	Dashboard, SSH
Reprise	Snapshot de la VM
À corriger	Rotation du mot de passe d'administration généré à l'installation

Les contrôles de santé, machine par machine

Après une intervention ou un redémarrage, un voyant vert ne me suffit pas : je relance les contrôles du livret de commandes, machine par machine. Chacun a un résultat attendu précis. Si un résultat diffère, je m'arrête et je diagnostique avant d'aller plus loin, comme pendant la construction.

Machine	Commande	Résultat attendu
Hôte	`sudo virsh list --all`	Les cinq VM à l'état `running`
Hôte	`sudo ls -lZ /vm/images/`	`svirt_image_t` pour une VM démarrée, `virt_image_t` pour une VM arrêtée
Hôte	`free -h`	De la mémoire disponible pour l'hôte
Hôte	`sudo ausearch -m AVC -ts recent`	Aucun refus SELinux récent
pfSense, shell (menu 8)	`ping -c3 1.1.1.1`, puis `host cloudflare.com`	Une réponse, puis le nom résolu
pfSense, interface web	*Status → System Logs → Firewall*	Le journal du filtrage, à jour
Contrôleur de domaine	`Get-ADDomain` et `Get-ADForest`	La forêt et le domaine `infrasec.local`, le catalogue global
Contrôleur de domaine	`nltest /dsgetdc:infrasec.local`	Un contrôleur trouvé par le DNS
Contrôleur de domaine	`Resolve-DnsName infrasec.local`	La zone répond
Contrôleur de domaine	`Get-Service WazuhSvc` et `Get-Service windows_exporter`	`Running`
TrueNAS, shell	`zpool status tank`	Miroir `ONLINE`, 0 erreur
TrueNAS, shell	`wbinfo -t` et `net ads testjoin`	Relation d'approbation et jonction valides
fedora	`systemctl --user status <unité>`	`active (running)` pour chaque service
fedora	`podman top <container> huser`	Un UID mappé, non root
fedora	`curl -s localhost:9100/metrics`	Des métriques `node_`
wazuh-siem	`sudo systemctl status wazuh-manager wazuh-indexer wazuh-dashboard`	Les trois services `active (running)`
Prometheus	`http://10.10.10.30:9091`, *Status → Targets*	Toutes les cibles `UP`
Grafana	`http://10.10.10.30:3000`	Les dashboards affichent des données

Le dernier contrôle a un piège, appris avec INC-03 : un dashboard « No data » ne veut pas dire que la collecte est en panne. Si la cible est `UP` dans Prometheus, je vérifie d'abord que la source de données a bien été liée à l'import, puis que le dashboard est compatible avec la version de l'exporter. Le nom du job compte aussi : celui du contrôleur de domaine s'appelle `windows`, la convention qu'attendent les dashboards communautaires.

Le plan d'adressage et les flux du socle

Le segment est plat : une seule plage, `10.10.10.0/24`, avec des adresses fixes pour tous les serveurs. La PSSI attribue à chaque actif une classification et une criticité, qui fixent ses objectifs de sauvegarde et de reprise, ainsi que son rang au redémarrage (complément E.1) :

Hôte	Adresse	Rôle	Classification	Criticité
`pfSense`	`10.10.10.254`	Point de passage : firewall, DNS, passerelle	C2	Vitale
`Win-Server-DC`	`10.10.10.10`	AD DS, DNS, rôles et accès	C3	Vitale
`TrueNAS`	`10.10.10.20`	Stockage ZFS, SMB (ACL NFSv4)	C3/C2	Haute
`fedora`	`10.10.10.30`	Containers *rootless*, Prometheus, Grafana, Zabbix	C1	Moyenne
`wazuh-siem`	`10.10.10.40`	SIEM Wazuh 4.14 (SCA, FIM)	C2	Haute
`TeneT`	hôte physique	Hyperviseur Fedora 44, Cockpit, KVM/libvirt	C2	Vitale

C3 désigne les informations critiques (secrets, base de l'annuaire), C2 les informations confidentielles (configurations, journaux de sécurité), C1 les informations internes (dashboards, métriques). Les machines vitales redémarrent les premières.

Les flux autorisés du socle sont peu nombreux, et chacun a une raison (le schéma de référence et la matrice complète, avec les flux de l'accès distant, sont en annexe N) :

Source	Destination	Protocole et port	Usage
Serveurs du segment	DC `10.10.10.10`	DNS 53, Kerberos 88, LDAP 389 et 636, SMB 445	Services d'annuaire
Segment interne	pfSense `10.10.10.254`	DNS 53, HTTPS 443	Résolution, administration
fedora (Prometheus)	DC `10.10.10.10`	TCP 9182	Métriques windows_exporter
fedora (Prometheus)	fedora, en local	TCP 9100	Métriques node_exporter
fedora (Zabbix)	pfSense `10.10.10.254`	UDP 161	SNMP, ajouté pendant l'évolution
DC et fedora (agents)	wazuh-siem `10.10.10.40`	TCP 1514 et 1515	Événements, enregistrement des agents

Les objectifs de reprise du socle

La PSSI fixe, pour chaque type d'actif, la perte de données acceptable (RPO) et le délai de reprise (RTO). Le tableau ci-dessous les reprend, avec ce qui a été réellement testé :

Actif	RPO	RTO	Mécanisme	Testé
Données du partage (ZFS)	1 heure au plus (snapshots horaires)	Moins d'une seconde au niveau fichier	Snapshots ZFS et réplication	Oui, le 4 octobre (PV-01)
Configuration de pfSense	Dernier export	Moins de cinq minutes	Export chiffré, import	Oui, le 11 octobre (PV-04)

Actif	RPO	RTO	Mécanisme	Testé
État d'une VM après une opération majeure	Nul : snapshot pris avant	Immédiat : retour au snapshot	Snapshots libvirt, Snapper	Mécanisme en place ; pas de test chronométré
Annuaire Active Directory	Faible	Selon la procédure de restauration	Sauvegarde de l'état système, snapshot à froid de la VM	Non : aucune restauration del'annuaire n'a encore été éprouvée

La sauvegarde suit le modèle 3-2-1-0 :

Chiffre	Exigence	Dans le laboratoire
3	Trois copies des données	Données, snapshots ZFS, réplication
2	Deux supports différents	Non atteint : la réplication est sur le même pool ; second support en production
1	Une copie hors site	Non atteint : réplication vers un site distant en production
0	Zéro erreur vérifiée	Empreintes SHA-256 après restauration et sur la réplique

L'ordre de reprise suit la criticité : firewall, annuaire, puis les services qui en dépendent. C'est l'ordre de redémarrage du manuel d'exploitation, et c'est le cœur du plan de reprise du socle. Le point le plus faible est l'annuaire : aucune restauration n'en a encore été éprouvée, et le retour au snapshot de la VM ramènerait tout le contrôleur à un état antérieur. Tester une restauration de l'état système, objet par objet, est la prochaine étape.

◆ CP1 · Exploiter selon les bonnes pratiques

Des règles fixées avant d'agir. J'ai écrit en tête du livret de commandes les règles que je ne transgresse pas. Un snapshot avant toute opération destructrice : `virsh snapshot-create-as` pour une VM, `snapper` pour l'hôte. Jamais de `virsh destroy` sur le contrôleur de domaine. Jamais de `chmod 777` : les droits se règlent par le propriétaire (`chown`), des groupes et, pour les containers, des *user namespaces*. Des containers *rootless* par défaut. Aucun secret en clair dans un fichier ou une commande. Et jamais de `/var/run/docker.sock` monté dans un container sans avertir du risque, puisque cela revient à donner l'accès root à l'hôte.

Traiter les incidents avec méthode. Chaque difficulté entre au journal d'incidents (annexe J) avec la même structure : symptôme, diagnostic, cause racine, résolution, preuve, enseignement. Les trois incidents de construction (INC-01 à INC-03) sont décrits dans les étapes ci-dessus. Je les ai traités comme on le fait au niveau 2 ou 3 : pas de contournement, une cause identifiée et une règle retenue pour la suite.

Chaque incident a laissé une règle, écrite là où l'exploitant la trouvera :

Incident	Règle retenue	Où elle est écrite
INC-01, installateur bloqué	BIOS pour les installations qui passent par la console web	Journal (annexe J), plan de construction
INC-02, jonction refusée	Heure synchronisée avant toute jonction Kerberos ; caractères neutres pour les comptes utilisés sur plusieurs plateformes	PSSI (articles 5.4.3 et 9.1.3), journal
INC-03, exporter arrêté	Lire les notes de version avant de déployer ; script de déploiement qui se corrige seul ; tableau de bord compatible avec la version	Veille (annexe K), livret de commandes
INC-05, test faussé	Tester depuis un poste réellement extérieur au réseau protégé	Journal ; mesure M-01

Les tâches de maintien en condition opérationnelle. Le manuel d'exploitation fixe leur fréquence :

Fréquence	Tâche
Quotidienne	Dashboard Wazuh : alertes de niveau 10 et plus, agents déconnectés ; avis du CERT-FR
Hebdomadaire	Score de conformité SCA ; état des snapshots et de la réplication ZFS
Mensuelle	Revue des accès, correctifs, synthèse de veille
Après tout incident	Entrée au journal ; RETEX pour un incident de niveau P1 ou P2

Le reste est automatisé : snapshots ZFS horaires, *scrub* du pool et mises à jour automatiques sur le nœud `fedora` (`dnf5-automatic.timer`).

Les procédures courantes. Voici celles que j'applique, dans la forme où un autre exploitant peut les rejouer.

Arrêter et redémarrer l'infrastructure. L'arrêt commence par les services qui dépendent des autres et finit par le firewall ; le redémarrage suit l'ordre inverse. Les VM démarrent aussi automatiquement avec l'hôte (`virsh autostart`).

```
for vm in wazuh-siem fedora truenas Win-Server-DC pfsense-fw; do sudo virsh shutdown
"$vm"; done
sudo virsh list --all          # attendre que toutes les VM soient « shut off »
for vm in pfsense-fw Win-Server-DC truenas fedora wazuh-siem; do sudo virsh start
"$vm"; sleep 30; done
```

Mettre à jour un serveur. Toute mise à jour est précédée d'un snapshot et suivie d'une vérification du service (PSSI, article 7). Sur le nœud `fedora`, les mises à jour automatiques passent par `dnf5-automatic`. Pour une mise à jour manuelle :

```
sudo virsh shutdown fedora; sleep 25
sudo virsh snapshot-create-as fedora pre-update "Avant mise à jour"
sudo virsh start fedora
# sur le nœud : mise à jour, puis vérification des services
sudo dnf upgrade --refresh -y
systemctl --user status prometheus grafana node-exporter
```

Restaurer un fichier du partage. Les snapshots ZFS sont accessibles en lecture dans le répertoire caché `.zfs` du jeu de données. La restauration prend quelques secondes, et l'empreinte SHA-256 prouve qu'elle est exacte :

```
ls /mnt/tank/partage/.zfs/snapshot/
rsync -aA /mnt/tank/partage/.zfs/snapshot/<snapshot>/<fichier> /mnt/tank/partage/
sha256sum -c <registre>.sha256          # doit afficher « OK »
```

J'utilise `rsync -A`, et non `cp`, pour conserver les ACL : pendant le test du 4 octobre, `cp` restaurait bien le contenu mais signalait « Operation not permitted » sur les permissions (annexe G).

Reprendre la configuration du firewall. Snapshot de la VM, puis *Diagnostics → Backup & Restore → Restore Backup* avec l'export chiffré. Le firewall redémarre et réinstalle ses paquets. Je vérifie ensuite les règles, les interfaces et les services. Durée mesurée le 11 octobre : moins de cinq minutes (annexe O). La modification témoin portait sur le domaine DNS du firewall :

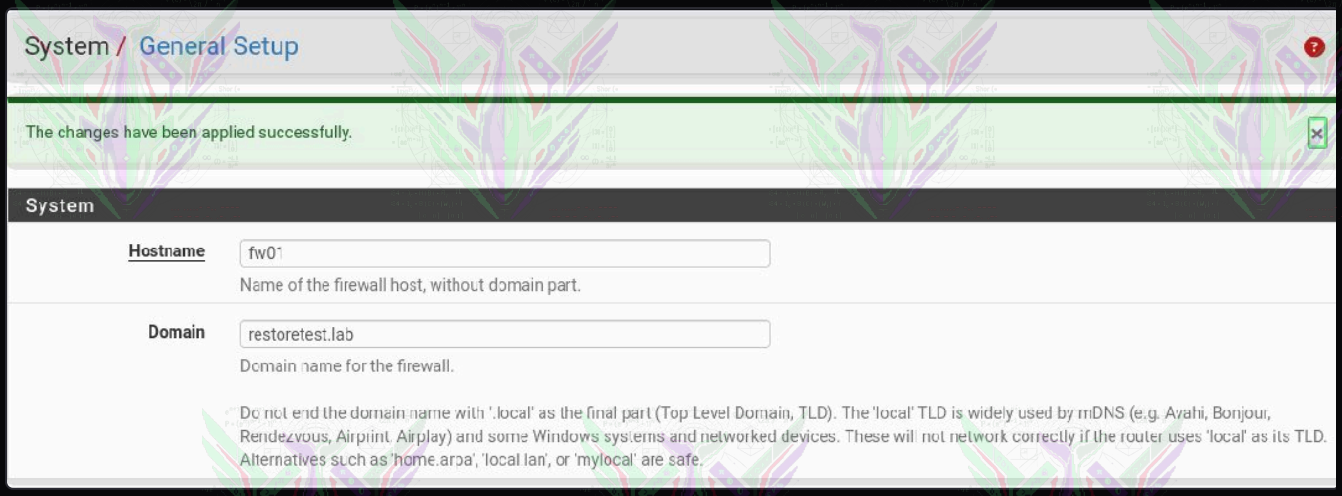


Figure 2 Avant la restauration : le domaine du firewall modifié pour le test

Capture d'écran réelle du labo ; les adresses sont privées (RFC 1918).

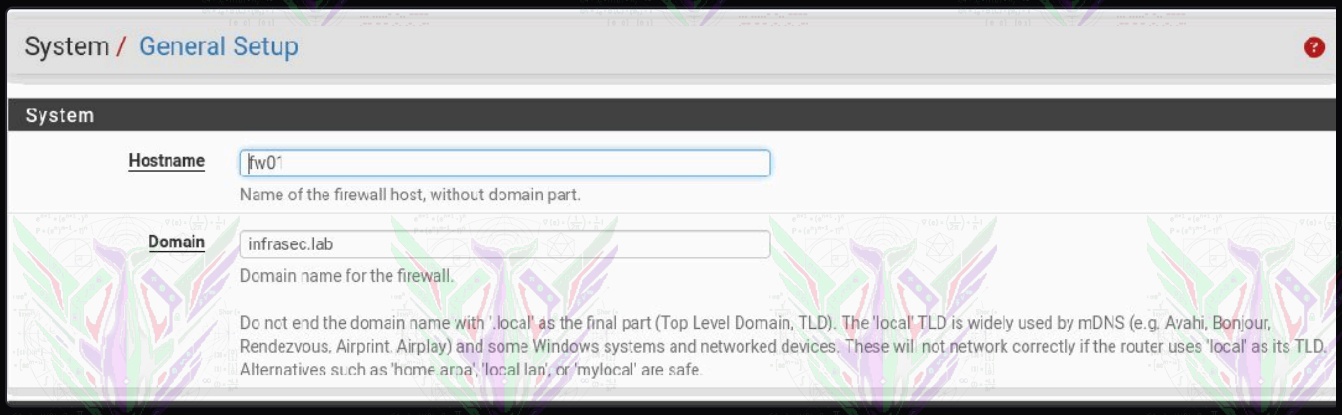


Figure 3 Après la restauration : le domaine d'origine est revenu avec l'export

Capture d'écran réelle du labo ; les adresses sont privées (RFC 1918).

Contrôler le pool de stockage.

```
zpool scrub tank
zpool status tank      # attendu : ONLINE, aucune erreur de lecture, d'écriture ou de
somme de contrôle
```

Diagnostiquer une VM qui ne démarre pas. SELinux d'abord, puis le contexte des disques, puis la mémoire :

```
sudo ausearch -m AVC -ts recent
sudo ls -lZ /vm/images/
free -h
```

Vérifier la santé de l'annuaire. Les quatre commandes de l'étape 3 (`Get-ADDomain`, `Get-ADForest`, `nltest`, `Resolve-DnsName`), plus, côté TrueNAS, `wbinfo -t` pour la relation d'approbation.

Gérer un service en container. Après toute modification d'un fichier Quadlet :

```
systemctl --user daemon-reload
systemctl --user restart <service>
systemctl --user status <service>
journalctl --user -u <service> --since "10 min ago"
```

Ajouter une machine au socle. Cette liste de contrôle reprend tout ce que la construction m'a appris :

Étape	Contrôle
Créer le disque dans le pool `tenet`	`ls -Z /vm/images` : `virt_image_t` ; `lsattr` : attribut `C`
Choisir le firmware	BIOS si l'installation passe par la console web (INC-01)
Disque et carte réseau virtio	Pilotes `virtio-win` chargés pour Windows
Adresse fixe du plan, passerelle `.254`, DNS `.10`	Résolution du domaine et sortie vers Internet
Heure synchronisée sur la référence du segment	Écart inférieur à 5 minutes avant toute jonction
Hardening de base et pare-feu local	Seuls les ports nécessaires sont ouverts
Agent Wazuh et exporter de métriques	Agent connecté, cible Prometheus active
Inventaire, classification et criticité	PSSI, complément E.1, à jour
Snapshot à froid et point Snapper	`POST-<MACHINE>-STABLE`

Documenter pour un autre exploitant. Trois documents suivent le socle : le livret de commandes, qui ne contient que des commandes réellement utilisées, avec la machine et le terminal où les lancer ; le manuel d'exploitation bilingue (annexe M) ; et le journal d'incidents. Je n'ai pas d'outil de gestion des actifs et des tickets de type GLPI dans le laboratoire. L'inventaire est tenu dans la PSSI (complément E.1) et le suivi dans le journal. En entreprise, GLPI tiendrait ce rôle.

Classer les changements. J'applique au socle les trois types de changement d'ITIL 4, déjà utilisés pour l'évolution (chapitre 5.1) :

Type	Exemple sur le socle	Traitement
Standard	Enrôler ou révoquer un accès, restaurer un fichier	Procédure écrite, autorisée d'avance
Normal	Ajouter une VM, modifier une règle du firewall, mettre à jour un composant majeur	Analyse d'impact, snapshot, validation, puis mise en œuvre et vérification
Urgent	Révoquer une clé exposée (INC-04)	Action immédiate, puis régularisation et RETEX

◆ CP2 · Sécuriser le réseau

Un seul point de passage. pfSense est la seule VM reliée à la fois au WAN et au LAN. Côté WAN, aucune connexion entrante n'est acceptée par défaut ; la seule exception, le port du tunnel WireGuard, appartient à l'évolution du chapitre 5. Les refus sont journalisés, ce qui m'a servi de preuve pendant les tests.

Les services du segment. pfSense résout les noms (Unbound) ; la zone `infrasec.local` est tenue par le contrôleur de domaine et relayée par pfSense (PSSI, article 6.5). Il sert aussi de référence de temps. Les serveurs ont des adresses fixes, recensées dans le plan d'adressage de la PSSI (complément E.1).

Le filtrage à l'intérieur du segment. Le trafic entre deux VM du même segment ne traverse pas pfSense. Je l'ai donc limité sur chaque machine : firewalld sur les hôtes Fedora, pare-feu Windows sur le contrôleur de domaine. L'audit du 4 octobre le confirme : sur chaque hôte, la quasi-totalité des ports testés est filtrée, et aucun service ancien ou non chiffré (Telnet, FTP, SMBv1) n'est exposé (annexe B).

Diagnostiquer couche par couche. Pour les pannes réseau, ma méthode est la capture successive : WAN, puis compteurs de la règle, puis LAN (*Diagnostics → Packet Capture*). C'est elle qui a localisé en quelques minutes les deux défauts de l'accès distant (INC-06 et INC-07, annexe J). Elle m'a aussi appris qu'un test réseau doit partir du bon endroit



: un essai lancé depuis l'hyperviseur, qui possède une route directe vers le segment, a « réussi » sans rien prouver (INC-05).

Ce que l'audit a relevé, et ce que j'en ai fait. Le socle n'est pas parfait, et je préfère le dire. L'hôte garde une adresse d'administration sur le segment de production, qui contourne le firewall (F-01). L'interface de pfSense répond encore en HTTP sur le port 80 (F-02). Le plan d'administration est joignable depuis tout le segment (F-06). Chaque constat a reçu une décision écrite : F-01 est accepté temporairement, avec une mesure compensatoire et une cible, un réseau d'administration dédié (mesure M-01) ; F-02 et F-06 sont planifiés (annexe F).

◆ CP3 · Sécuriser les systèmes

Le hardening d'un serveur Linux. Sur le nœud `fedora`, j'ai appliqué les recommandations de l'audit Lynis. Chaque mesure est dans un fichier dédié, pour qu'elle reste lisible et réversible :

Mesure	Fichier
SSH : pas de connexion root, pas de redirection, 3 essais au plus, journalisation détaillée, déconnexion des sessions inactives	`/etc/ssh/sshd_config.d/99-hardening.conf`
Durée de vie des mots de passe, `umask 027`	`/etc/login.defs`
Protocoles réseau inutiles neutralisés (`dccp`, `sctp`, `rds`, `tipc`)	`/etc/modprobe.d/99-disable-protocols.conf`
Stockage USB neutralisé	`/etc/modprobe.d/99-usb-storage.conf`
Pas de *core dump*	`/etc/security/limits.d/99-coredump.conf`
Mises à jour automatiques	`dnf5-automatic.timer`

Le fichier SSH, en entier :

```
PermitRootLogin no
AllowTcpForwarding no
X11Forwarding no
MaxAuthTries 3
ClientAliveInterval 300
ClientAliveCountMax 2
LogLevel VERBOSE
```

Avant de recharger SSH, je valide toujours la configuration, pour ne pas me couper l'accès :

```
sudo sshd -t && sudo systemctl reload sshd
sudo systemctl enable --now dnf5-automatic.timer
sudo lynis audit system
```

L'indice Lynis est passé de 69 à 76 sur 100 (253 tests, annexe F). Les mesures de neutralisation de modules ne s'appliquent complètement qu'après un redémarrage.

Les services exposés. RDP est actif sur le contrôleur de domaine, mais je ne l'utilise pas : j'administre par la console. Sa restriction est planifiée (constat F-03). WS-Discovery, exposé par TrueNAS, sera désactivé (F-04).

Les journaux et la conformité. Les agents Wazuh du contrôleur de domaine et du nœud `fedora` remontent leurs événements au SIEM. Le module SCA compare leur configuration aux benchmarks CIS (Windows Server et Linux). Le raccordement du firewall, de TrueNAS et de l'hyperviseur au SIEM reste à faire.

Le backup, prouvé par une restauration. Le 4 octobre, j'ai supprimé trois fichiers témoins du partage, puis je les ai restaurés depuis un snapshot ZFS : temps de reprise inférieur à une seconde au niveau fichier, empreintes SHA-256 conformes (3 sur 3) sur la copie restaurée et sur la copie répliquée (annexe G). La copie répliquée est sur le même pool : les critères « 2 supports » et « 1 copie hors site » de la règle 3-2-1-0 ne seront atteints qu'en production.

Les secrets. Aucun secret n'est écrit dans un fichier ou une commande : les saisies sensibles sont interactives. Le mot de passe d'administration généré par l'installation de Wazuh n'apparaît dans aucun livrable ; sa rotation reste à faire. L'export de configuration de pfSense est chiffré et conservé hors ligne.

Les rôles et les accès. La PSSI définit huit rôles et leurs droits sur chaque composant (article 5.2). Je les ai tous tenus, l'un après l'autre, ce qui est une limite propre au laboratoire ; le modèle reste celui qu'une équipe appliquerait :

Rôle	Hyperviseur	pfSense	Annuaire	TrueNAS	Containers	Wazuh
RSSI	Lecture	Lecture	Lecture	Lecture	Lecture	Lecture (administration)
Administrateur virtualisation	Administration	—	—	—	—	Agent
Administrateur annuaire	—	—	Administration	—	—	Agent
Administrateur réseau	—	Administration	—	—	—	Agent
Administrateur stockage	—	—	Jonction au domaine	Administration	—	Agent
Opérateur containers	—	—	—	Lecture de jeux dédiés	Administration (non root)	Agent
Analyste sécurité	Journaux	Journaux	Journaux	Journaux	Journaux	Administration
Auditeur	Lecture	Lecture	Lecture	Lecture	Lecture	Lecture

La PSSI fixe aussi les exigences des mots de passe (article 5.5) : 14 caractères au moins pour les utilisateurs et 20 pour les comptes à privilèges et de service, complexité, historique des 24 derniers, verrouillage après 5 échecs en 15 minutes, rotation des comptes à privilèges au moins tous les 90 jours, et changement de tous les mots de passe par défaut dès l'installation. L'authentification multifacteur y est recommandée pour l'administration, avec une compensation documentée quand un composant ne la propose pas.

Ce qui doit être journalisé. La PSSI liste, pour chaque source, les événements à remonter au SIEM (article 9.2), avec une conservation d'au moins 90 jours :

Source	Événements	Finalité
Contrôleur de domaine	Authentifications réussies et échouées, changements de comptes et de groupes, élévations de privilèges	Traçabilité des accès, détection d'abus
pfSense	Flux bloqués et autorisés, changements de règles, événements VPN et d'administration	Surveillance du point de passage
TrueNAS	Accès aux partages, changements d'ACL, erreurs ZFS, snapshots et réplication	Intégrité et accès aux données
fedora	Démarrage et arrêt des containers, usage de privilèges	Détection d'abus sur les containers

Source	Événements	Finalité
Hyperviseur	Connexions d'administration, actions libvirt, snapshots	Surveillance de l'hyperviseur

Aujourd'hui, seuls le contrôleur de domaine et le nœud `fedora` remontent leurs événements. Les trois autres sources sont l'écart principal entre la politique et l'existant ; il est suivi dans la PSSI elle-même.

Le socle de sécurité, mesure par mesure.

Mesure	État	Où le vérifier
Disque de l'hôte chiffré (LUKS)	Appliquée	Étape 1
SELinux *enforcing* sur l'hôte, contextes des images	Appliquée	`getenforce` , `ls -dZ /vm/images`
Refus par défaut sur le WAN	Appliquée	Règles WAN vides
Filtrage local sur chaque serveur	Appliquée	Audit (annexe B)
Hardening SSH, mots de passe, modules, *core dumps* (`fedora`)	Appliquée	Lynis 69 → 76 (annexe F)
Mises à jour automatiques (`fedora`)	Appliquée	`dnf5-automatic.timer`
Containers *rootless*	Appliquée	`podman top … huser`
Accès au partage par groupe (ACL NFSv4)	Appliquée	Permissions du jeu de données
Backup en snapshots et réplication, restauration vérifiée	Appliquée	PV-01 (annexe G)
Agents SIEM sur le contrôleur de domaine et `fedora`	Appliquée	Dashboard Wazuh
HTTPS seul sur l'interface de pfSense	Planifiée	F-02
RDP restreint ou désactivé	Planifiée	F-03
WS-Discovery désactivé sur TrueNAS	Planifiée	F-04
Plan d'administration restreint, réseau d'administration dédié	Planifiée	F-01, F-06, M-01
Firewall, TrueNAS et hyperviseur raccordés au SIEM	Planifiée	PSSI, article 9
Rotation du mot de passe d'administration de Wazuh	Planifiée	Rapport de gel (annexe F)

Les recommandations de l'ANSSI. Le guide d'hygiène informatique de l'ANSSI m'a servi de repère pour le socle. Voici, thème par thème, où en est le laboratoire :

Thème du guide	Dans le laboratoire
Connaître son système d'information	Inventaire, classification et criticité des actifs (PSSI, article 4)
Maîtriser les comptes et les droits	Comptes de service dédiés, droits par groupes, modèle de rôles ; comptes nominatifs séparés à généraliser
Authentifier	Politique de mots de passe écrite ; MFA à venir
Sécuriser les serveurs	Hardening mesuré sur `fedora` , SCA sur le contrôleur de domaine ; le reste à étendre
Sécuriser le réseau	Un seul point de passage, refus par défaut, filtrage local ; réseau d'administration à créer (M-01)
Sécuriser l'administration	Accès chiffrés ; plan d'administration encore trop ouvert (F-02, F-06)

Thème du guide	Dans le laboratoire
Mettre à jour	Automatique sur `fedora`, manuel ailleurs, toujours après un snapshot
Superviser, journaliser	SIEM en place pour deux sources, trois à raccorder
Sauvegarder et tester la restauration	Snapshots, réplication, restauration chronométrée et vérifiée (PV-01)

◆ CP4 · Sécuriser la virtualisation

L'isolation par SELinux. SELinux reste en mode *enforcing*. Les disques portent le contexte `virt_image_t`, qui devient `svirt_image_t` quand la VM tourne : chaque VM reçoit ses propres catégories, ce qui l'isole des autres et de l'hôte. Si une VM était compromise, elle ne pourrait pas lire le disque d'une autre. Si une VM refuse de démarrer, je cherche le refus et je corrige le contexte : je ne désactive jamais SELinux.

Les réseaux virtuels. Le NAT de libvirt côté WAN et le bridge isolé `br-tenet` côté LAN. L'hôte possède encore une adresse sur ce bridge : c'est le constat F-01. Il a même faussé un test (INC-05), ce qui confirme la priorité d'un réseau d'administration séparé.

Les containers. Ils tournent *rootless*, sous un compte sans privilège, avec des *user namespaces*. Aucun socket de démon n'est monté dans un container, et aucun container n'expose un port privilégié (inférieur à 1024).

Les ressources. Le budget mémoire (22 Go sur 32) laisse à l'hôte la marge nécessaire ; `free -h` après chaque démarrage de VM permet de vérifier qu'il n'est pas dépassé. La supervision de l'hôte et des VM par Prometheus est décrite au chapitre 6.1.

La reprise. Chaque VM peut revenir à un snapshot nommé, l'hôte à un point Snapper, et la configuration de pfSense à son export chiffré. Le manuel d'exploitation classe ces retours arrière du plus léger au plus complet (annexe M, section 8) :

```
sudo virsh snapshot-list <vm>
sudo virsh snapshot-revert <vm> <étiquette>     # retour à un état connu
sudo snapper -c root list
```

◆ Les critères du référentiel, et où je les démontre

Le référentiel du titre fixe des critères de performance pour chaque compétence. Je les reprends ici un par un, avec l'endroit du dossier qui en apporte la preuve. Quand la preuve n'est que partielle, je le dis.

Dans le laboratoire, les « accords de niveau de service » sont les objectifs de reprise fixés par la PSSI, présentés plus haut.

CP1 · Appliquer les bonnes pratiques dans l'administration des infrastructures.

Critère de performance	Où je le démontre
Les problèmes et incidents sont résolus	INC-01 à INC-03, chacun résolu jusqu'à sa cause racine, avec une preuve et une règle retenue (étapes 3 et 4, annexe J)
Les tâches planifiées pour le maintien en condition opérationnelle des infrastructures sont réalisées dans le respect des bonnes pratiques	Tâches quotidiennes, hebdomadaires et mensuelles du manuel d'exploitation ; snapshot avant toute mise à jour ; snapshots ZFS, *scrub* et mises à jour automatiques (section CP1)

Critère de performance	Où je le démontre
Le niveau de qualité des services est maintenu à la valeur attendue	Objectifs de reprise tenus là où ils ont été testés : moins d'une seconde pour un fichier (PV-01), moins de cinq minutes pour la configuration du firewall (PV-04). Partiel : aucune restauration de l'annuaire n'a encore été éprouvée
Les procédures établies sont conformes aux règles de bonne pratique	Des procédures écrites pour être rejouées par un autre exploitant : arrêt et redémarrage ordonnés, mise à jour, restauration vérifiée par SHA-256, reprise du firewall, ajout d'une machine (section CP1)
Les interventions et changements de configuration, ainsi que les tâches planifiées de maintien en condition opérationnelle, sont documentés dans un outil de suivi	Journal d'incidents, livret de commandes, manuel d'exploitation, inventaire de la PSSI, types de changement d'ITIL 4. Partiel : pas d'outil de suivi de type GLPI dans le laboratoire

CP2 · Administrer et sécuriser les infrastructures réseaux.

Critère de performance	Où je le démontre
L'infrastructure réseau est opérationnelle conformément aux accords de niveau de service	Un seul point de passage, Internet et résolution des noms depuis le LAN (étape 2) ; configuration du firewall reprise en moins de cinq minutes (PV-04)
Les tâches sont réalisées dans le respect des bonnes pratiques	Refus par défaut sur le WAN, sorties explicites sur le LAN, refus journalisés, diagnostic couche par couche par capture de paquets (section CP2)
Les règles de sécurité sont appliquées	Filtrage local sur chaque serveur ; aucun protocole ancien ou non chiffré exposé (annexe B) ; F-01, F-02 et F-06 suivis avec une décision écrite
La règlementation en vigueur est respectée	La PSSI fixe ce qui doit être journalisé au point de passage et la durée de conservation, 90 jours au moins (article 9.2). Partiel : pfSense n'est pas encore raccordé au SIEM

CP3 · Administrer et sécuriser les infrastructures systèmes.

Critère de performance	Où je le démontre
L'infrastructure système est opérationnelle conformément aux accords de niveau de service	Forêt `infrasec.local` et DNS, jonction de TrueNAS à l'état HEALTHY, services *rootless* actifs (étapes 3 à 6) ; restauration prouvée (PV-01)
Les tâches sont réalisées dans le respect des bonnes pratiques	Hardening rangé dans des fichiers dédiés, configuration SSH validée avant tout rechargement, contextes SELinux déclarés par `semanage`, secrets saisis de façon interactive (étape 1, section CP3)
Les règles de sécurité sont appliquées	Lynis 69 → 76 ; politique de mots de passe et matrice des rôles de la PSSI ; conformité SCA des agents. Planifié : F-03, F-04, rotation du mot de passe de Wazuh
La règlementation en vigueur est respectée	Le RGPD est pris en compte par la PSSI : notification d'une violation de données à la CNIL sous 72 heures (article 10.5.2) et conservation des journaux (article 9.2). Le disque de l'hôte est chiffré

CP4 · Administrer et sécuriser les infrastructures virtualisées.

Critère de performance	Où je le démontre
L'infrastructure virtualisée (on-premise et cloud) est opérationnelle conformément aux accords de niveaux de service	Cinq VM en service dans un budget mémoire de 22 Go sur 32, démarrage automatique avec l'hôte, contrôles de santé après chaque intervention (étape 7). Partiel : pas de cloud public (voir ci-dessous)

Critère de performance	Où je le démontre
Les tâches sont réalisées dans le respect des bonnes pratiques	Snapshots à froid avant toute opération risquée, sous-volumes NOCOW préparés avant la première image, pool dédié, jamais de `virsh destroy` sur le contrôleur de domaine ; cinq serveurs consolidés sur un seul poste, sobre en matériel et en énergie
Les règles de sécurité sont appliquées	SELinux *enforcing* et isolation des VM par catégories, bridge LAN isolé, containers *rootless* avec *user namespaces*, aucun socket de démon monté (section CP4)
La règlementation en vigueur est respectée	Disques des VM protégés au repos par le chiffrement LUKS de l'hôte ; journalisation de l'hyperviseur prévue par la PSSI (article 9.2). Partiel : l'hyperviseur n'est pas encore raccordé au SIEM

Les deux critères communs à CP2, CP3 et CP4 : l'anglais.

Critère de performance	Où je le démontre
Les informations et les documentations techniques sont comprises, y compris lorsqu'elles sont en anglais	Les interfaces et les messages des produits, en anglais, cités tels quels dans ce chapitre ; les notes de version et les avis des éditeurs suivis par la veille (annexe K) ; le diagnostic d'INC-03, conduit à partir des messages d'erreur et des notes de version de windows_exporter
Les échanges par écrit avec les professionnels sont clairs, concis, structurés et adaptés aux destinataires, y compris lorsqu'ils se font en anglais	La version anglaise de ce dossier, dont ce chapitre ; le manuel d'exploitation bilingue (annexe M)

Les mentions « Partiel » reprennent les limites déjà écrites dans ce chapitre, chacune rattachée à une décision.

◆ Ce que le laboratoire ne couvre pas

Le référentiel décrit un métier plus large qu'un laboratoire posé sur un seul poste. Voici ce que je n'ai pas mis en œuvre ici, pour que la lecture reste juste :

Domaine du référentiel	État dans le laboratoire
Switches physiques de niveau 2 et 3, VLAN, agrégat de liens, STP, HSRP, QoS	Non couvert : un seul segment, sur un bridge virtuel
Réseaux sans fil, BYOD, portail captif	Non couvert
Proxy filtrant, bastion d'administration	Non construit ; le bastion est la cible de la mesure M-01
IDS/IPS réseau	Non couvert : la détection repose sur Wazuh, au niveau des hôtes
Authentification forte (MFA, OTP), PKI interne	Non couvert : MFA prévu dans les perspectives (chapitre 8.4)
Annuaire hybride (Entra ID), Microsoft 365, services de bureau à distance	Non couvert
Outil de gestion des actifs et des tickets (GLPI)	Remplacé ici par l'inventaire de la PSSI et le journal d'incidents
Logiciel de backup dédié (Veeam, Backup Exec)	Remplacé par les snapshots et la réplication ZFS, les snapshots libvirt et Snapper
Haute disponibilité des hyperviseurs, cluster, répartition de charge	Non couvert : un seul hyperviseur
Cloud public (IaaS, PaaS), registre d'images, Kubernetes	Non couvert

Bilan du socle

Le socle a été construit dans l'ordre de ses dépendances, chaque étape fermée par un test et un snapshot. Il offre un seul point de passage filtré, une identité centralisée, un stockage contrôlé par groupes et un backup prouvé par une restauration. Le hardening est mesuré (Lynis 69 → 76) et chaque étape peut être annulée. Les trois incidents de construction ont chacun laissé une règle : le BIOS pour les installations par console web, l'heure synchronisée avant toute jonction Kerberos, la lecture des notes de version avant de déployer un exporter. Ses limites sont connues, écrites et rattachées à une décision : l'adresse de l'hôte sur le segment, l'administration encore trop ouverte, le SIEM qui ne couvre pas encore toutes les machines. C'est sur cette base, documentée et réversible, que j'ai pu concevoir et déployer l'accès distant Zero-Trust (chapitres 4 et 5) et gérer la sécurité de l'ensemble (chapitre 6).

02

CHAPITRE2

Cahier des charges

Ce que l'entreprise demande, et comment je l'ai traduit en exigences que l'on peut mesurer.

CCP2 CP5

2. Cahier des charges : expression des besoins

Le cahier des charges complet porte la référence CDC-2026-01. Ce chapitre en reprend le contenu. Le choix de la solution et son coût sont expliqués au chapitre 4.

2.1 Contexte et existant

Tout le système d'information d'INFRASEC tourne sur un seul hyperviseur. Un firewall pfSense filtre le trafic et c'est le seul point de passage vers le réseau interne `10.10.10.0/24`. Derrière lui, le switch du LAN relie un contrôleur de domaine Active Directory (forêt `infrasec.local`), un serveur de fichiers TrueNAS, un serveur de containers qui porte la supervision (Prometheus, Grafana) et un SIEM Wazuh. Il n'existe aucun accès distant maîtrisé.

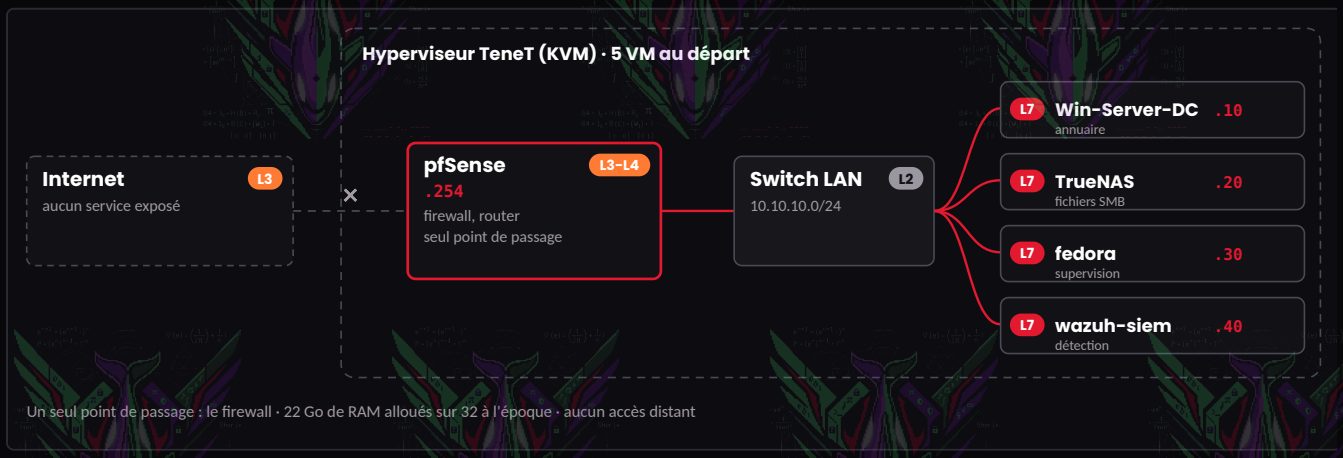


Figure 4 Le système d'information existant : un seul point de passage, quatre serveurs internes, aucun accès distant.

Abréviations — **L1…L7** : couches du modèle OSI : 1 physique, 2 liaison, 3 réseau, 4 transport, 5 session, 6 présentation, 7 application · **LAN** : réseau local du labo 10.10.10.0/24 · **SMB** : partage de fichiers Windows (Server Message Block), port 445 · **KVM** : hyperviseur intégré au noyau Linux (Kernel-based Virtual Machine) · **VM** : machine virtuelle · **SIEM** : collecte et corrélation des journaux de sécurité (Security Information and Event Management) · **RAM** : mémoire vive

2.2 Le besoin d'évolution

En une phrase : **permettre à des utilisateurs distants d'accéder depuis Internet aux seules ressources internes dont ils ont besoin, sans exposer le système d'information.**

J'ai identifié deux profils, avec des besoins volontairement différents. L'administrateur nomade doit atteindre le plan d'administration pour intervenir à distance. Le collaborateur en télétravail doit accéder au partage de fichiers, et à rien d'autre. Cette différence est le cœur du projet : c'est le moindre privilège, la base de l'approche Zero-Trust, appliqué à un cas concret.

2.3 Périmètre

Ce qui est **dans** le projet : le serveur VPN sur le firewall existant, les deux profils d'accès et leurs droits, les règles de filtrage par profil, la gestion des clés et l'enrôlement des postes, la supervision du service, la documentation d'exploitation et la procédure de révocation.

Ce qui est **hors** du projet : la refonte du réseau interne (faite dans la première étape), la posture des postes clients, l'authentification multifacteur et la redondance du firewall. Ces deux derniers points sont gardés pour la suite.

2.4 Contraintes

Contrainte	Ce qu'elle change dans le projet
Budget	Utiliser l'existant et le logiciel libre. Aucun achat de matériel ni de licence récurrente
Sécurité	Moindre privilège par profil, cryptographie moderne, aucun secret en clair. Les clés privées sont créées et restent sur chaque appareil. Recommandations de l'ANSSI
Production	Aucune coupure des services internes pendant le déploiement. Un changement réversible, documenté pour qu'un autre puisse l'exploiter
Environnement	Aucun serveur en plus. Un protocole léger pour le processeur, donc pour la consommation d'énergie
Réglementation	RGPD : chiffrement des données personnelles en transit et logs proportionnés. L'ANSSI comme référence de bonnes pratiques

2.5 Exigences fonctionnelles et techniques

Réf.	Exigence fonctionnelle	Priorité
EF1	Ouvrir un tunnel chiffré vers le SI depuis n'importe quel accès Internet	Essentielle
EF2	Deux profils : administrateur (plan d'administration) et collaborateur (partage de fichiers seulement)	Essentielle
EF3	Chaque profil n'atteint que ce qui lui est autorisé, tout le reste est bloqué	Essentielle
EF4	Enrôlement simple et rapide d'un poste (fichier ou code QR)	Importante
EF5	Révocation centralisée et immédiate d'un accès compromis	Essentielle
EF6	L'exploitant voit l'état des connexions	Importante

Réf.	Exigence technique	Seuil ou nature
ET1	Cryptographie moderne et éprouvée	Curve25519, ChaCha20-Poly1305
ET2	Cloisonnement à deux niveaux : routage par clé et filtrage stateful	Une règle dédiée par profil
ET3	Disponibilité du service	≥ 99,5 % en heures ouvrées
ET4	Peu de perte de performance	Protocole léger
ET5	Aucun secret en clair, clés privées non centralisées	Clés créées sur le poste client
ET6	Supervision de l'état du tunnel	Branchée sur la chaîne existante
ET7	Logs de connexion proportionnés	Conformes au RGPD
ET8	Déploiement réversible	Plan de rollback écrit

2.6 Niveaux de service attendus

Indicateur	Cible
Disponibilité de l'accès distant (heures ouvrées)	≥ 99,5 %
Délai de reprise après incident (RTO)	< 1 heure
Délai d'enrôlement d'un nouvel utilisateur	< 15 minutes
Délai de révocation d'un accès compromis	< 5 minutes

2.7 Livrables attendus

Le cahier des charges, les schémas d'architecture, le plan de mise en production et de rollback, la documentation d'exploitation avec la procédure de révocation, le dossier de supervision et le procès- verbal de recette. Tous se trouvent dans ce dossier ou dans ses annexes. Le procès-verbal de recette (PV- 04) est en annexe O.

03

CHAPITRE3

Gestion de projet

Comment j'ai découpé le travail, comment je l'ai suivi, et les risques que j'ai anticipés.

CCP2 CP5 CP6

3. Gestion de projet

3.1 Méthode et découpage

J'ai conduit le projet en phases. Chaque phase se ferme sur un critère que l'on peut vérifier. Le découpage s'inspire du cycle de vie des services d'ITIL : conception, transition, exploitation. Je me suis fixé une règle simple dès le départ : **une phase n'est finie que lorsque sa preuve existe**. Une preuve, c'est un procès-verbal, une mesure, une capture ou une entrée au journal. « Presque fini » ne compte pas.

Phase	Objet	Livrable de fin de phase	Compétence
P0	Reconstruction du socle sur un nouvel hyperviseur	Socle opérationnel, écarts notés	CP6
P1	Conception de l'évolution	Cahier des charges, comparatif, TCO	CP5
P2	Maquette et essais de la solution	Banc de test validé	CP5
P3	Mise en production de l'accès distant	Plan de mise en production, recette	CP6
P4	Supervision	Dashboards, indicateurs, seuils	CP7
P5	Backup et restauration	PV-01 : RTO mesuré, RPO déduit de la fréquence des snapshots	CP6, CP9
P6	Audit et analyse de risques	Lettre de mission, PV-02, évaluation, EBIOS RM	CP8
P7	Politique de sécurité et sensibilisation	PSSI, support de sensibilisation	CP9
P8	Détection et traitement d'incident	PV-03, RETEX	CP10
P9	Hardening et gel	Rapport de gel, registre SHA-256	CP9
P10	Documentation et préparation	Dossier, diaporama, répétitions	Transverse

3.2 Planning et suivi

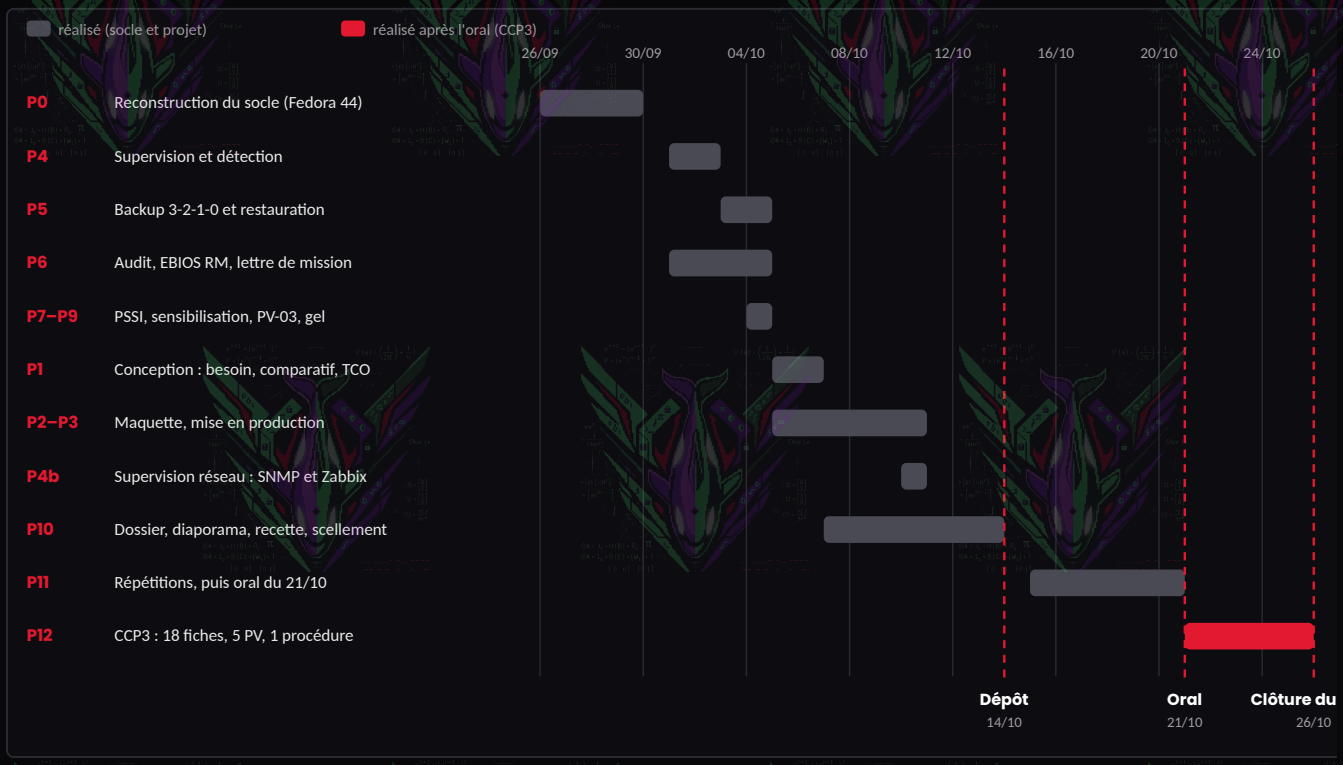


Figure 5 Planning du projet, du socle à la clôture du labo le 26/10/2026.

Abréviations — **EBIOS RM** : méthode d'analyse de risques de l'ANSSI (EBIOS Risk Manager) · **TCO** : coût total de possession (Total Cost of Ownership) · **SNMP** : supervision des équipements réseau (Simple Network Management Protocol), port UDP 161 · **PV** : procès-verbal de mise en œuvre ou de recette · **INC / F** : fiche d'incident / fiche de constat

Ce qui fixe la fin du projet, ce n'est pas la technique mais la documentation : la date ferme est le dépôt du dossier, le 14 octobre. J'ai donc placé les phases techniques tôt. J'ai aussi décidé d'avance ce que je sacrifierais en cas de retard : j'aurais sacrifié les options (supervision réseau par Zabbix, règle de détection en plus) avant le dossier, jamais l'inverse. Finalement, les deux options ont pu être faites le 11 octobre.

La conception (P1) et la maquette (P2) se sont chevauchées volontairement. La maquette a vérifié sur le firewall existant que la solution envisagée fonctionnait, avant la décision du 06/10. Ses incidents (INC-04 à INC-06) ont nourri le plan de mise en production écrit le 07/10.

Pour suivre le projet, j'ai utilisé trois outils simples. D'abord un tableau de couverture, qui relie chaque critère du référentiel au livrable qui le couvre, avec son état. Ensuite le journal d'incidents (annexe J), où je note chaque difficulté avec son diagnostic, sa cause et ce que j'en retiens. Enfin un snapshot à la fin de chaque phase, nommé `POST-[OPÉRATION]-STABLE`, pour pouvoir revenir en arrière à tout moment.

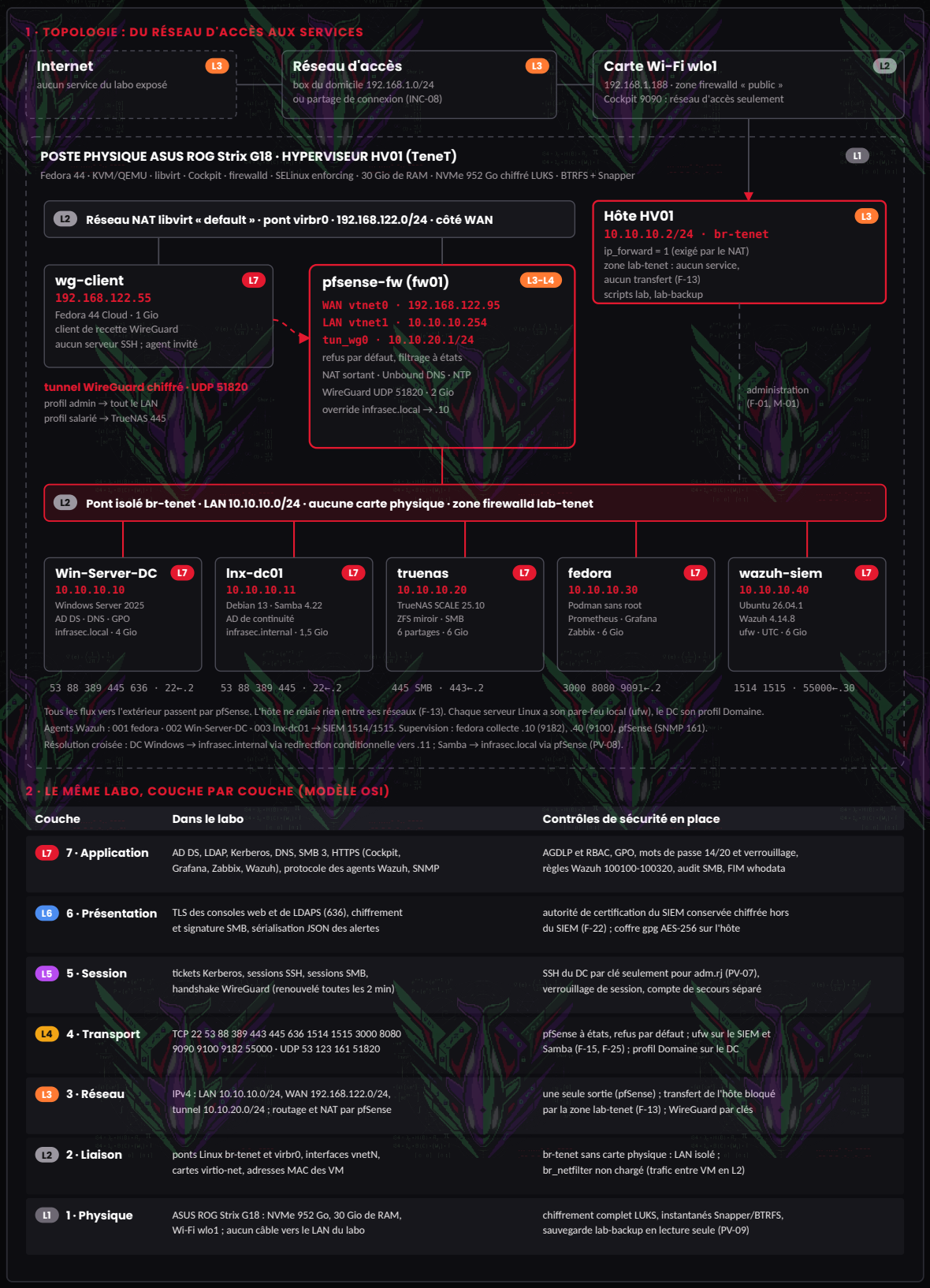
Jalon	Date	Critère de passage
Socle reconstruit	02/10	Cinq VM en service, annuaire et partage fonctionnels
Supervision active, sécurité mesurée	04/10	Supervision active ; PV-01, PV-02, PV-03, EBIOS RM, PSSI, rapport de gel
Évolution conçue et chiffrée	06/10	Cahier des charges et TCO validés
Évolution en production	11/10	Recette conforme (PV-04), gel, registre d'intégrité à jour
Dossier déposé	14/10	Dossier, diaporama et pièces administratives sur le Drive
Soutenance	21/10	(jalon final)

3.3 Environnement humain

J'ai mené ce projet seul, mais avec une organisation. La PSSI définit huit rôles : RSSI, administrateur système, annuaire, réseau, stockage, opérateur de containers, analyste sécurité et auditeur. Je les ai tenus l'un après l'autre, et j'ai noté chaque décision dans le document qui correspond au rôle. Quand j'écris la lettre de mission, je suis le client de l'audit. Quand j'écris le rapport, je suis l'auditeur. Quand je compare ce rapport à la lettre, je redeviens le client. Cette séparation sur le papier compense en partie le fait qu'une seule personne tient tous les rôles.

Les personnes réelles avec qui j'ai travaillé sont présentées au chapitre 7.

3.4 Environnement technique



2 · LE MÊME LABO, COUCHE PAR COUCHE (MODÈLE OSI)

Couche	Dans le labo	Contrôles de sécurité en place
L7 7 · Application	AD DS, LDAP, Kerberos, DNS, SMB 3, HTTPS (Cockpit, Grafana, Zabbix, Wazuh), protocole des agents Wazuh, SNMP	AGDLP et RBAC, GPO, mots de passe 14/20 et verrouillage, règles Wazuh 100100-100320, audit SMB, FIM whodata
L6 6 · Présentation	TLS des consoles web et de LDAPS (636), chiffrement et signature SMB, sérialisation JSON des alertes	autorité de certification du SIEM conservée chiffrée hors du SIEM (F-22) ; coffre gpg AES-256 sur l'hôte
L5 5 · Session	tickets Kerberos, sessions SSH, sessions SMB, handshake WireGuard (renouvelé toutes les 2 min)	SSH du DC par clé seulement pour adm.rj (PV-07), verrouillage de session, compte de secours séparé
L4 4 · Transport	TCP 22 53 88 389 443 445 636 1514 1515 3000 8080 9090 9100 9182 55000 · UDP 53 123 161 51820	pfSense à états, refus par défaut ; ufw sur le SIEM et Samba (F-15, F-25) ; profil Domaine sur le DC
L3 3 · Réseau	IPv4 : LAN 10.10.10.0/24, WAN 192.168.122.0/24, tunnel 10.10.20.0/24 ; routage et NAT par pfSense	une seule sortie (pfSense) ; transfert de l'hôte bloqué par la zone lab-tenet (F-13) ; WireGuard par clés
L2 2 · Liaison	ponts Linux br-tenet et virbr0, interfaces vnetN, cartes virtio-net, adresses MAC des VM	br-tenet sans carte physique : LAN isolé ; br_netfilter non chargé (trafic entre VM en L2)
L1 1 · Physique	ASUS ROG Strix G18 : NVMe 952 Go, 30 Gio de RAM, Wi-Fi wlo1 ; aucun câble vers le LAN du labo	chiffrement complet LUKS, instantanés Snapper/BTRFS, sauvegarde lab-backup en lecture seule (PV-09)

Figure 6 Architecture réseau générale du labo Hybrid InfraSec : topologie complète et lecture couche par couche du modèle OSI (état au 26/10/2026).

Abréviations — **L1…L7** : couches du modèle OSI : 1 physique, 2 liaison, 3 réseau, 4 transport, 5 session, 6 présentation, 7 application · **OSI** : modèle de référence en 7 couches (Open Systems Interconnection) · **HV01** : hyperviseur du labo, nom d'hôte TeneT · **KVM** : hyperviseur intégré au noyau Linux (Kernel-based Virtual Machine) · **LUKS** : chiffrement complet du disque sous Linux (Linux Unified Key Setup) · **BTRFS** : système de fichiers à instantanés (B-tree file system) · **NAT** : traduction d'adresses (Network Address Translation) · **WAN** : côté extérieur du pare-feu (réseau NAT 192.168.122.0/24) · **LAN** : réseau local du labo 10.10.10.0/24 · **WG** : WireGuard : tunnel VPN chiffré, port UDP 51820 · **DNS** : résolution des noms (Domain Name System) · **NTP** : synchronisation de l'heure (Network Time Protocol) · **AD DS** : services de domaine Active Directory · **LDAP** : protocole d'accès à l'annuaire (Lightweight Directory Access Protocol) · **SMB** : partage de fichiers Windows (Server Message Block), port 445 · **SNMP** : supervision des équipements réseau (Simple Network Management Protocol), port UDP 161 · **TLS** : chiffrement des échanges (Transport Layer Security) · **SSH** : administration à distance chiffrée

(Secure Shell), port 22 · **GPO** : stratégie de groupe Windows (Group Policy Object) · **AGDLP** : comptes → groupes Globaux → groupes de Domaine Local → Permissions · **RBAC** : contrôle d'accès fondé sur les rôles (Role-Based Access Control) · **FIM** : surveillance de l'intégrité des fichiers (File Integrity Monitoring) · **whodata** : mode FIM de Wazuh qui enregistre aussi l'auteur et le processus · **TCP / UDP** : protocoles de transport, avec ou sans connexion · **ufw** : pare-feu local de Debian et Ubuntu (Uncomplicated Firewall) · **DC** : contrôleur de domaine (Domain Controller) · **SIEM** : collecte et corrélation des journaux de sécurité (Security Information and Event Management) · **VM** : machine virtuelle · **Gio / Go** : gibioctets (mémoire, 2^{30} octets) / gigaoctets (disque, 10^9 octets) · **agent invité** : service QEMU dans la VM qui reçoit les ordres de l'hyperviseur (guest agent)

Couche	Composants
Poste physique	ASUS ROG Strix G18 : 32 Go de RAM, SSD NVMe, chiffrement LUKS, BTRFS avec snapshots Snapper
Hyperviseur	Fedora 44, KVM/QEMU, libvirt, Cockpit, firewalld, SELinux en mode *enforcing*
Réseaux virtuels	NAT libvirt `192.168.122.0/24` côté WAN (switch `virbr0`) ; bridge isolé `br-tenet` pour le LAN `10.10.10.0/24`
Firewall	pfSense CE : filtrage, router, DNS, serveur WireGuard (`10.10.20.0/24`)
Identité	Windows Server 2025 : AD DS, DNS, forêt `infrasec.local`
Stockage	TrueNAS SCALE 25.10 : ZFS en miroir, partage SMB joint au domaine
Containers et supervision	Fedora 44 Server : Podman *rootless*, Prometheus, Grafana, node_exporter, Zabbix ; windows_exporter sur le contrôleur de domaine
Détection	Ubuntu 26.04 LTS : Wazuh 4.14 (manager, indexer, dashboard, agents)
Audit	nmap, Lynis, module SCA de Wazuh

3.5 Objectifs de qualité

Objectif	Indicateur	Résultat
Aucun secret dans les livrables	Contrôle avant scellement : mots de passe, clés privées, adresses publiques	Respecté
Chaque étape validée par un test, pas par un voyant	Un critère de passage écrit pour chaque étape de mise en production	Appliqué (chap. 5)
Chaque incident expliqué	Diagnostic, cause et enseignement pour chaque entrée du journal	7 incidents documentés
Une sécurité mesurée, pas déclarée	Indice de hardening Lynis avant et après	69 → 76 / 100
Une reprise prouvée	Restauration faite, chronométrée et vérifiée par hash	RTO < 1 s, 0 erreur
L'intégrité des pièces	Hash SHA-256 de chaque livrable	Registre tenu à jour
La réversibilité	Un snapshot avant chaque opération importante	Convention appliquée

3.6 Risques du projet et parades

Risque	Ce qui s'est passé ou ce que je craignais	Parade
Pas assez de mémoire sur l'hôte	Impossible de faire tourner toutes les VM en même temps	Budget mémoire fixé (22 Go sur 32), VM d'audit lancée seulement pendant l'audit
Un outil qui ne marche pas	La VM d'audit toute prête n'a pas démarré	Couverture faite avec nmap, Lynis et le module SCA de Wazuh ; écart noté dans l'évaluation du rapport

Risque	Ce qui s'est passé ou ce que je craignais	Parade
Un logiciel qui change entre deux versions	Des collecteurs retirés dans windows_exporter (INC-03)	Script de déploiement qui se corrige seul ; lecture des notes de version ajoutée à la veille
Un retard de planning	Moins de temps pour le dossier	Règle de sacrifice fixée d'avance : les options d'abord, jamais le dossier

04

CHAPITRE 4

Le choix des solutions

Quatre solutions comparées avec la même méthode, un choix expliqué et chiffré sur trois ans.

CCP2 CP5

4. Argumentation du choix des solutions retenues

4.1 Solutions étudiées

J'ai étudié quatre familles de solutions : trois VPN que l'on héberge soi-même, et une offre commerciale ZTNA gérée par un prestataire.

WireGuard. Un protocole récent, avec un code volontairement très court (quelques milliers de lignes, donc possible à auditer) et une cryptographie moderne et figée. Il est intégré à pfSense. Il est rapide, consomme peu de processeur, et il est libre et gratuit. En contrepartie, il est plus jeune, et les fonctions d'entreprise comme l'authentification multifacteur ne sont pas intégrées.

OpenVPN. Mature, très répandu, basé sur TLS, souple, avec beaucoup d'options dont l'authentification multifacteur. Il est plus lourd et plus lent, et sa configuration est plus complexe, donc plus chère à exploiter et à auditer.

IPsec / IKEv2. Un standard reconnu, souvent présent nativement dans les systèmes. Sa configuration a la réputation d'être complexe, il passe mal le NAT et il consomme plus de ressources.

ZTNA commercial (offres du type Zscaler Private Access ou Twingate). C'est l'offre la plus riche : accès basé sur l'identité, authentification multifacteur, aucun port ouvert vers l'intérieur. En contrepartie, il y a un abonnement par utilisateur, une dépendance au fournisseur, et le trafic passe par le cloud d'un tiers. C'est un point sensible pour le RGPD et pour la maîtrise des données.

4.2 Méthode de sélection : une grille de décision pondérée

J'ai retenu sept critères, avec des poids qui viennent des contraintes d'INFRASEC (chapitre 2.4). Chaque solution est notée de 1 (mauvais) à 5 (excellent), et le score pondéré guide la décision. J'ai fixé les poids **avant** de noter les solutions. Sinon, on risque d'ajuster la grille pour justifier un choix déjà fait.

Critère	Poids	WireGuard	OpenVPN	IPsec/IKEv2	ZTNA commercial
Coût d'achat et d'exploitation	20 %	5	4	4	2
Niveau de sécurité, cryptographie	20 %	5	4	4	5
Performance et sobriété	15 %	5	3	3	4
Simplicité de déploiement et d'exploitation	15 %	4	3	2	5
Intégration au firewall existant	10 %	5	4	4	1
Code auditable et transparent	10 %	5	4	3	1
Maîtrise des données (RGPD)	10 %	5	5	5	2
Score pondéré sur 5	**100 %**	**4,85**	**3,80**	**3,55**	**3,15**

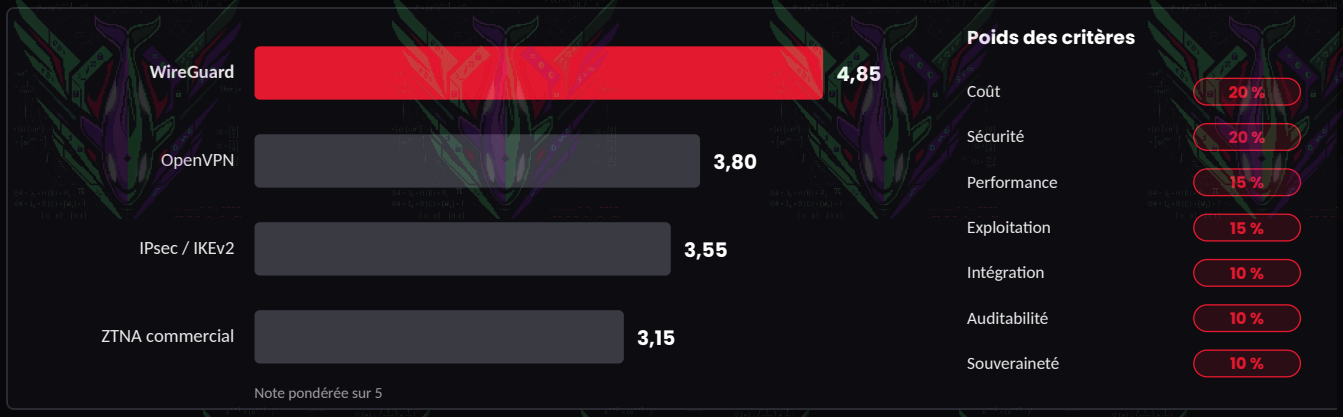


Figure 7 Scores pondérés des quatre solutions et poids des critères.

Abréviations — **ZTNA** : accès réseau Zero-Trust (Zero Trust Network Access) · **WG** : WireGuard : tunnel VPN chiffré, port UDP 51820

La grille montre aussi où WireGuard n'est pas le meilleur : pour la simplicité d'exploitation et la richesse des fonctions, l'offre commerciale passe devant. Je n'ai pas cherché la meilleure technologie dans l'absolu, mais la meilleure pour ce besoin et ces contraintes.

4.3 Coût total de possession sur trois ans

Le calcul repose sur des hypothèses que j'écris clairement, pour qu'on puisse les ajuster : un coût interne de 350 € par jour pour un administrateur, dix utilisateurs distants, aucun matériel ni licence à acheter pour la solution hébergée en interne.

Poste	WireGuard hébergé en interne	ZTNA commercial
Matériel	0 € (firewall existant)	0 €
Licences	0 € (logiciel libre)	(inclus dans l'abonnement)
Mise en œuvre (CAPEX)	4 j × 350 € = 1 400 €	forfait de mise en service : 500 €
Abonnement (OPEX par an)	aucun	10 utilisateurs × 6 €/mois × 12 = 720 €
Exploitation (OPEX par an)	3 j × 350 € = 1 050 €	2 j × 350 € = 700 € (service géré)
Énergie (OPEX par an)	≈ 20 € (protocole léger, matériel existant)	(non chiffré)
OPEX par an	**1 070 €**	**1 420 €**
TCO sur 3 ans	**1 400 + 3 × 1 070 = 4 610 €**	**500 + 3 × 1 420 = 4 760 €**

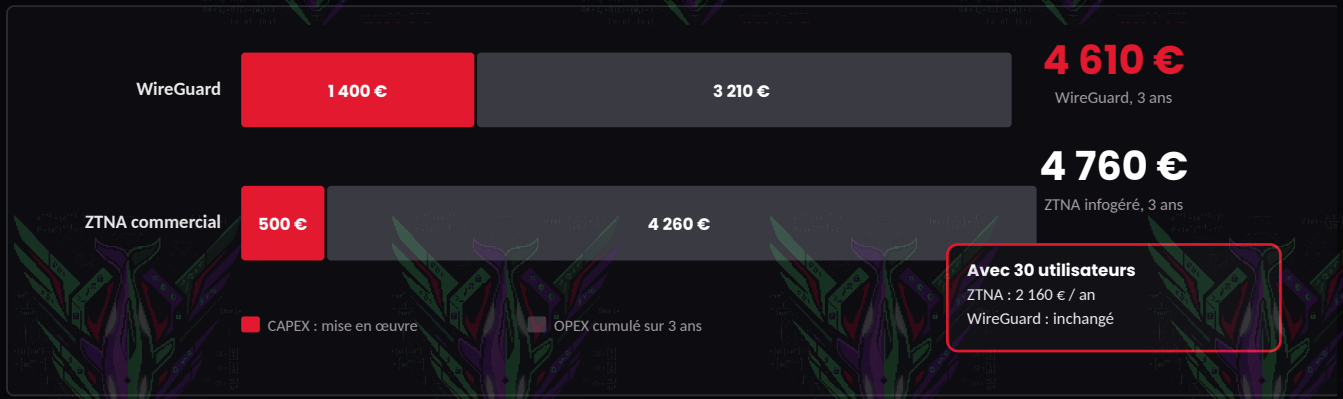


Figure 8 Coût total sur trois ans : mise en œuvre et exploitation cumulée.

Abréviations — **TCO** : coût total de possession (Total Cost of Ownership) · **CAPEX** : dépenses d'investissement : coût de mise en œuvre · **OPEX** : dépenses d'exploitation cumulées · **ZTNA** : accès réseau Zero-Trust (Zero Trust Network Access)

Ce que je retiens de ce calcul. Les deux coûts sont proches : 150 € d'écart sur trois ans, moins de 4 %. Le coût ne décide donc pas, et je préfère le dire franchement. Deux éléments font quand même la différence dans la durée. D'abord, le coût de WireGuard ne dépend pas du nombre d'utilisateurs, alors que l'abonnement commercial augmente avec chaque utilisateur : à trente utilisateurs, il atteindrait 2 160 € par an. Ensuite, avec WireGuard aucun trafic ne passe par un tiers, aucune donnée n'est confiée à un fournisseur, et aucun abonnement ne lie l'entreprise.

J'ai aussi chiffré à part une option de point d'accès hébergé dans le cloud (une petite instance, environ 11 € par mois) : 396 € sur trois ans. Elle n'est pas utile pour le besoin actuel.

◆ 4.4 Solution retenue et architecture

J'ai retenu **WireGuard sur le firewall pfSense existant, avec deux profils séparés selon le moindre privilège.** C'est la première solution de la grille (4,85 sur 5), et elle respecte toutes les contraintes : aucun coût d'achat, une cryptographie moderne, la sobriété, l'intégration au firewall, un code auditable et la maîtrise complète des données.

Élément	Choix
Serveur VPN	Tunnel `tun_wg0` sur pfSense, à l'écoute sur un seul port UDP (51820)
Réseau du tunnel	`10.10.20.0/24`, séparé du réseau interne ; firewall en `10.10.20.1`
Profil administrateur	Peer `admin-remote`, `10.10.20.2/32`, vers le réseau interne `10.10.10.0/24` pour l'administration ; règle à restreindre aux seules interfaces d'administration
Profil collaborateur	Peer `employe-remote`, `10.10.20.3/32`, vers le partage SMB de TrueNAS (TCP 445) **uniquement**
Authentification	Une paire de clés par appareil ; la clé privée est créée et reste sur l'appareil ; seule la clé publique est déclarée sur le firewall
Cloisonnement	Routage par clé (chaque peer ne possède que son adresse) + une règle stateful par profil + droits du groupe Active Directory sur le partage
Couches OSI	Tunnel de couche 3 (paquets IP chiffrés) transporté dans UDP (couche 4) ; filtrage pfSense en couches 3 et 4 ; droits sur le partage en couche 7 (annexe N)

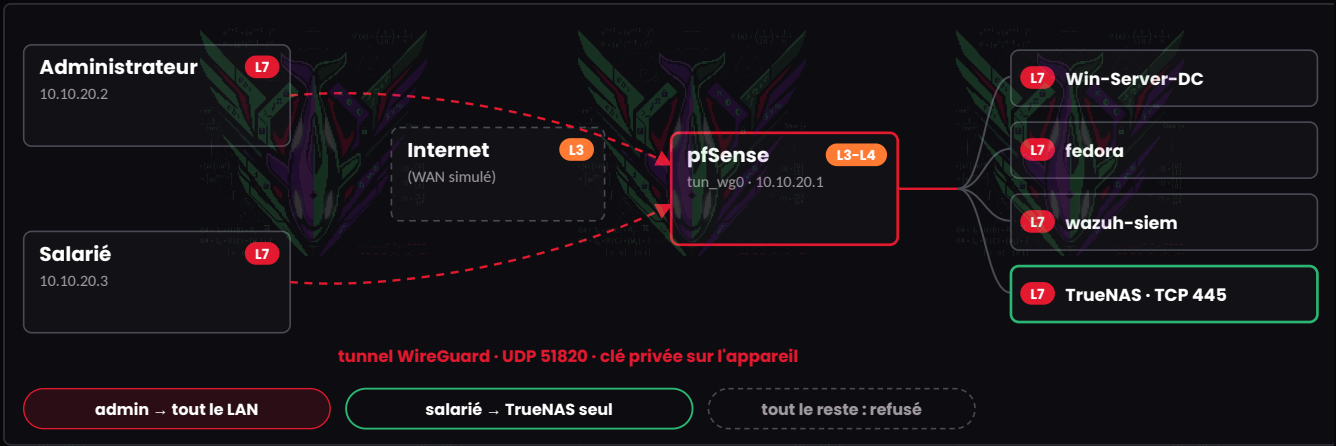


Figure 9 Architecture retenue : un port UDP, un tunnel, deux profils séparés.

Abréviations — **WG** : WireGuard : tunnel VPN chiffré, port UDP 51820 · **WAN** : côté extérieur du pare-feu (réseau NAT 192.168.122.0/24) · **LAN** : réseau local du labo 10.10.10.0/24 · **TCP / UDP** : protocoles de transport, avec ou sans connexion · **L1…L7** : couches du modèle OSI : 1 physique, 2 liaison, 3 réseau, 4 transport, 5 session, 6 présentation, 7 application



Figure 10 Ce que traverse une connexion du salarié : trois barrières.

Abréviations — **WG** : WireGuard : tunnel VPN chiffré, port UDP 51820 · **SMB** : partage de fichiers Windows (Server Message Block), port 445 · **AD DS** : services de domaine Active Directory

Ce schéma résume l'idée de sécurité. Une connexion du collaborateur passe trois contrôles différents. D'abord la clé : un appareil inconnu ne reçoit aucune réponse, et le port reste invisible quand on scanne. Ensuite la règle du firewall : seul TCP 445 vers le serveur de fichiers est ouvert. Enfin les droits de l'annuaire sur le partage. Aucun de ces contrôles ne suffit seul à ouvrir l'accès : c'est la défense en profondeur. Deux de ces contrôles reposent sur pfSense, donc son hardening, son backup et sa supervision font partie de la sécurité de l'accès distant. Le troisième dépend de l'annuaire et reste indépendant du firewall.

La solution peut grandir facilement. Pour ajouter un utilisateur, je déclare un peer et je le rattache à la règle de son profil. Pour ajouter un profil, je crée une règle. L'architecture ne change pas.

4.5 Les autres choix techniques du projet

L'accès distant n'est pas le seul choix que j'ai dû justifier. Voici les autres, avec le critère qui a décidé.

Choix	Solution écartée	Ce qui a décidé
Prometheus et Grafana pour la supervision	Zabbix seul	Collecte en mode *pull* et base de séries temporelles, adaptées à une infrastructure en containers. Zabbix reste le bon outil pour le firewall en SNMP et complète l'ensemble
Wazuh pour la détection	Plusieurs outils séparés	Une plateforme libre qui réunit l'agent (intégrité, détection, réponse active), le SIEM (collecte et corrélation) et la conformité (SCA)
Snapshots ZFS et réplication pour le backup	Un logiciel de backup externe	Snapshots immuables et presque instantanés, intégrité vérifiée bloc par bloc, réplication native : restauration en moins d'une seconde au niveau fichier
Podman rootless pour les containers	Docker avec un démon root	Aucun démon privilégié, containers lancés par un utilisateur sans privilège, aucun socket de démon exposé
Infrastructure as code (Terraform, état local) pour le firewall, dès la première étape	Configuration à la main seulement	On peut tout reconstruire à l'identique ; l'état reste en local, sans dépendre d'un service tiers

CHAPITRE 5

05

Organisation de la mise en œuvre

La mise en production étape par étape, la recette du 11 octobre, le rollback et la reprise.

CCP2 CP6

5. Organisation de la mise en œuvre

Ce chapitre reprend le plan de mise en production MEP-2026-01.

5.1 Le cadre : un changement maîtrisé

Je me suis appuyé sur les pratiques ITIL 4 de gestion des changements, de mise en production et de validation des services. L'évolution est un **changement normal** : elle modifie ce qui est exposé du système d'information, donc elle doit être évaluée puis autorisée avant d'être faite. L'évaluation s'appuie sur le cahier des charges, et l'autorisation, c'est la validation du plan de mise en production.

Dans le laboratoire, la maquette et la cible sont dans le même environnement. J'ai écrit le plan le 07/10 à partir de ce que la maquette m'avait appris, avec un critère de validation pour chaque étape. Les étapes E0 à E7 ont été vérifiées sur la configuration issue de la maquette. Les étapes E8 à E10 ont été faites le 11/10.

Une fois le service en place, ajouter ou révoquer un utilisateur devient un **changement standard** : autorisé d'avance, répétable, fait en suivant une procédure écrite, sans refaire toute l'évaluation.

5.2 Analyse d'impact et backups préalables

Le changement est **additif** : il ajoute une interface et des règles, sans toucher aux règles du réseau interne. Côté WAN, un seul port est ouvert (UDP 51820), et WireGuard ne répond à aucun paquet non authentifié. Avant de commencer, j'ai créé trois points de retour : un snapshot de la VM firewall, un export de la configuration pfSense **gardé hors ligne** (il contient le hash du mot de passe d'administration et la clé TLS de l'interface web), et un snapshot Snapper de l'hôte.

Un écart propre au laboratoire. Le WAN de pfSense est branché sur le réseau NAT de l'hyperviseur, donc sur une adresse privée. J'ai désactivé l'option « bloquer les réseaux privés » sur cette interface pour laisser passer le tunnel. En production, le WAN a une adresse publique et cette option reste activée.

5.3 Étapes et points de validation

Une étape n'est passée que si son critère de validation est rempli.

Étape	Action	Critère de validation	Résultat
E0	Backups préalables, information des utilisateurs	Snapshot et export présents	✅
E1	Installation du paquet WireGuard	Paquet installé, service disponible	✅
E2	Création du tunnel `tun_wg0`, clé serveur créée sur le firewall	Tunnel actif	✅
E3	Interface `WG_REMOTE` (`10.10.20.1/24`)	Interface active	✅ adressage statique corrigé en recette (INC-07)
E4	Déclaration des deux peers (clés publiques, un `/32` par peer)	Plages *Allowed IPs* uniques	✅ après correction (INC-06)
E5	Règles : WAN UDP 51820 ; administrateur vers le réseau interne ; collaborateur vers TCP 445 sur TrueNAS ; tout le reste refusé	Cloisonnement conforme	✅

Étape	Action	Critère de validation	Résultat
E6	Publication : redirection UDP 51820 del'hôte vers le WAN du firewall	Port joignable	✅
E7	Enrôlement des postes (clés créées sur le poste, code QR)	Handshake établi ; flux applicatif vérifié en recette (E8)	✅
E8	Recette avec la grille d'acceptation	Tous les critères conformes	✅ 11/10 (PV-04), après correction INC-07
E9	Branchement sur la supervision	L'exploitant voit l'état du tunnel	✅ état de `tun_wg0` collecté par Zabbix (SNMP)
E10	Gel : snapshots, registre d'intégrité, documentation	Registre et documentation à jour	✅ snapshots `gel-20261011`, registre SHA-256

Ce que les étapes E3 et E4 m'ont appris. Au début, les deux peers avaient la même plage *Allowed IPs*. Le tunnel montait, le voyant était vert, mais la réponse du serveur de fichiers ne revenait jamais au collaborateur, parce qu'aucune clé ne « possédait » son adresse. Une capture de paquets a montré où ça bloquait : le serveur répondait, mais le firewall ne renvoyait rien dans le tunnel. J'ai corrigé avec un `/32` unique par peer (INC-06). La recette m'a ensuite montré que cette correction était nécessaire, mais pas suffisante : l'interface du tunnel n'avait pas d'adresse fixe, et pfSense n'avait donc aucune route de retour vers les clients (INC-07). Depuis, un handshake réussi n'est plus pour moi qu'une étape. Je ne valide que sur un vrai flux applicatif, observé de bout en bout.

5.4 Recette

Critère de recette	Mesure	Seuil	État
Le tunnel monte	Handshake réussi, octets échangés dans les deux sens	Oui	✅ Validé
Le flux autorisé du collaborateur passe	Capture LAN : la requête arrive sur `10.10.10.20:445` et le serveur répond	Conforme	✅ Validé
Session complète du collaborateur	Connexion SMB de bout en bout depuis un poste distant	Établie	✅ Validé (après INC-07)
Tout autre flux du collaborateur est refusé	Essais vers le contrôleur de domaine (445, 3389), le serveur de containers (22), la console Wazuh (443)	Refusés	✅ Validé, 4 refus dans les logs de `WG_REMOTE`
Accès administrateur	Accès aux interfaces d'administration	Conforme	🟡 Règle vérifiée dans la configuration ; essai non refait avec le client de recette
Le trafic est chiffré	Capture côté WAN : uniquement del'UDP 51820 chiffré	Aucune donnée en clair	✅ Validé, 20 paquets, tous UDP 51820
Révocation d'un accès	Peer désactivé, accès refusé	< 5 min	✅ Validé, coupure en 1 seconde au plus (sonde chaque seconde)
Supervision	L'exploitant voit l'état du tunnel	Oui	✅ Validé, `tun_wg0` à `up (1)` dans Zabbix

Le choix du banc de test. Mon premier essai depuis l'hyperviseur a « réussi » sans rien prouver. L'hyperviseur a une route directe vers le réseau interne (constat d'audit F-01), et le trafic passait à côté du tunnel (INC-05). J'ai alors isolé le client de test dans un espace de noms réseau sans route vers le réseau interne. Cela m'a permis de valider le handshake et de trouver INC-06. La recette finale s'est faite depuis une VM cliente séparée, vraiment à l'extérieur du réseau protégé. Pour que les essais de refus aient un sens, ce client envoie tout le segment `10.10.10.0/24` dans le tunnel. Sinon, un flux interdit n'arriverait jamais au firewall, et le test ne pourrait pas échouer. Je lis les refus dans les logs de pfSense. Le détail heure par heure et les captures sont dans PV-04 (annexe O).

5.5 Rollback

Je déclenche un rollback si l'on perd l'accès aux services internes, si une règle bloque un flux de production, si le firewall devient instable, ou si un critère essentiel échoue pendant la fenêtre de changement. J'agis du plus léger au plus lourd : désactiver le tunnel (effet immédiat, le réseau interne n'est pas touché), retirer les règles du tunnel et la règle WAN, restaurer l'export de configuration, revenir au snapshot de la VM, puis au snapshot Snapper de l'hôte. L'objectif est de retrouver le service d'avant en moins d'une heure, comme le demande le RTO du cahier des charges. Dans presque tous les cas, les deux premières actions suffisent.

5.6 Reprise et continuité (PRI / PCI)

Procédure	Test	État
Reprise des **données** accessibles à distance (partage SMB)	Restauration chronométrée et vérifiée par hash SHA-256 (PV-01) : RTO < 1 s, 0 erreur	✅ Testée et validée
Reprise de la **configuration** du firewall et du tunnel	Restauration de l'export après un snapshot de sécurité ; modification témoin annulée ; tunnel et peers vérifiés de bout en bout	✅ Testée, service rétabli en moins de 5 min
Révocation d'un accès compromis	Rotation réelle de la clé administrateur après exposition (INC-04), puis révocation chronométrée en recette	✅ Exercée

La continuité. Si l'accès distant tombe, l'administrateur garde un accès de secours par la console de l'hyperviseur. Les collaborateurs travaillent en mode dégradé sur des copies locales autorisées, dans la limite du RTO.

5.7 Niveaux de service, documentation et transfert de compétences

Engagement	Comment je le mesure	État
Disponibilité ≥ 99,5 %	Supervision de l'état du tunnel et du firewall	Mesurable : état du tunnel collecté (Zabbix), alerted'indisponibilité active (Grafana)
Reprise < 1 heure	Procédure de rollback, PRI	Reprise de configuration testée : < 5 min ✅
Enrôlement < 15 minutes	Procédure standard chronométrée	Procédure écrite
Révocation < 5 minutes	Procédure de révocation	Chronométrée en recette : 1 seconde au plus ✅

La documentation mise à jour : le livret de commandes (partie WireGuard : création des clés, enrôlement, diagnostic, révocation), le manuel d'exploitation bilingue (annexe M), le journal d'incidents (INC-04 à INC-07), le support de sensibilisation (règle d'usage du code QR) et le registre d'intégrité.

Le transfert de compétences. Il repose sur une documentation que l'on peut exécuter telle quelle : un administrateur qui n'a pas fait le projet doit pouvoir enrôler, diagnostiquer et révoquer un accès sans aide. Il repose aussi sur une démonstration commentée (le tunnel, la preuve du cloisonnement, la révocation d'un peer) et sur une consigne pour les utilisateurs dans la sensibilisation. Je considère le transfert réussi quand l'exploitant fait seul un enrôlement et une révocation.

06

CHAPITRE6

Supervision et cybersécurité

Superviser, mesurer la sécurité, appliquer une politique, détecter et traiter les incidents.

CCP2 CP7 CCP3 CP8 CP9 CP10

6. Réalisations : supervision et gestion de la cybersécurité

Une évolution n'est sûre que si l'infrastructure qui la reçoit est surveillée, mesurée et capable de réagir. Ce chapitre présente ce que j'ai fait pour cela, compétence par compétence.

6.1 Supervision des infrastructures (CP7)

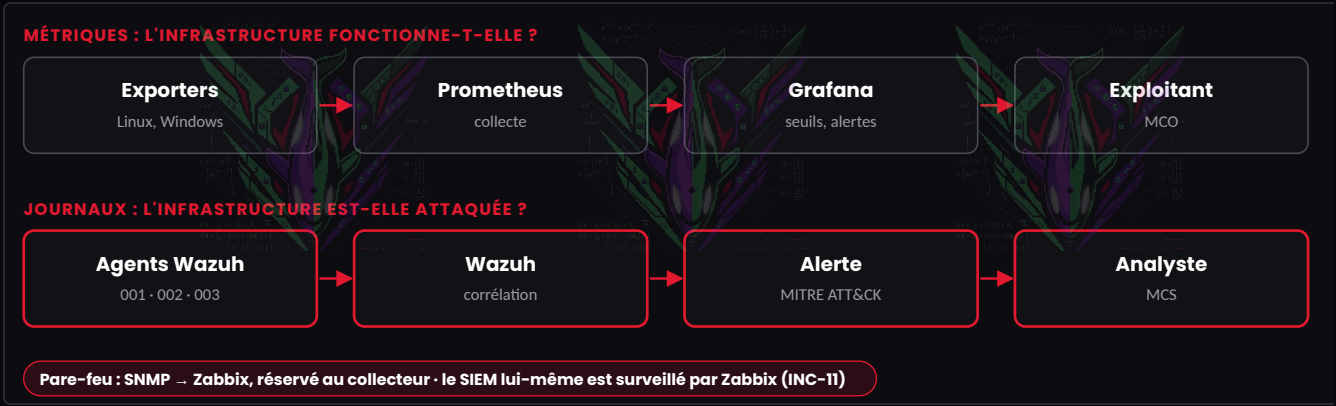


Figure 11 Deux flux de supervision : les métriques d'exploitation et les journaux de sécurité.

Abréviations — **MCO / MCS** : maintien en condition opérationnelle / de sécurité · **MITRE ATT&CK** : référentiel public des techniques d'attaque ; T1110 force brute, T1547.001 persistance au démarrage, T1562.001 neutralisation des défenses · **SNMP** : supervision des équipements réseau (Simple Network Management Protocol), port UDP 161 · **SIEM** : collecte et corrélation des journaux de sécurité (Security Information and Event Management) · **Wazuh** : SIEM libre : agents, manager, indexeur, tableau de bord

Je sépare la supervision en deux flux, parce qu'ils répondent à deux questions différentes. Les **métriques** répondent à « est-ce que l'infrastructure fonctionne ? ». Prometheus va chercher (mode *pull*) les données des exporters du serveur de containers (node_exporter) et du contrôleur de domaine (windows_exporter), et Grafana les affiche. Les **logs de sécurité** répondent à « est-ce que l'infrastructure est attaquée ? ». Les agents Wazuh envoient les logs, l'intégrité des fichiers et la conformité de configuration au manager, qui corrèle et lève les alertes.

Des indicateurs choisis, pas empilés. J'ai gardé chaque indicateur parce qu'il protège quelque chose d'important pour l'entreprise ou un engagement de service, pas parce qu'il était disponible.

Indicateur	Source	Pourquoi	Seuil d'alerte	État
Cibles joignables	Prometheus (up)	Voir l'arrêt d'une machine ou d'un service	Cible injoignable > 2 min : critique	Collecté ✅
Services de l'annuaire (AD DS, DNS, Netlogon)	windows_exporter	L'annuaire est l'élément le plus critique (EBIOS VM-1)	Service arrêté : critique	Collecté ✅
Processeur	exporters	Un service saturé	> 85 % pendant 10 min : avertissement	Collecté ✅
Mémoire	exporters	L'hôte a peu de marge (22 Go sur 32)	> 90 % : avertissement	Collecté ✅
Espace disque	exporters	Logs et snapshots remplissent les volumes	> 80 % : avertissement · > 90 % : critique	Collecté ✅

Indicateur	Source	Pourquoi	Seuil d'alerte	État
Alertes de sécurité de niveau ≥ 10	Wazuh	Une attaque en cours	Chaque alerte est traitée	Actif ✅
Agents Wazuh connectés	Wazuh	Un agent muet, c'est une zone aveugle (EBIOS ER-4)	Agent déconnecté > 5 min : critique	Actif ✅
Score de conformité SCA	Wazuh	Une configuration qui dérive	Score en baisse : revue	Actif ✅
État du tunnel WireGuard	pfSense, via Zabbix	Disponibilité de l'accès distant (≥ 99,5 %)	Aucun handshake > 3 min pour un peer actif	Collecté ✅ (alerte à paramétrer)
Interfaces et trafic du firewall	SNMP, collecté par Zabbix	La charge du seul point de passage	Interface saturée	Collecté ✅

Une alerte testée pour de vrai. J'ai créé dans Grafana la règle « Cible injoignable » et je l'ai testée le 11/10 (PV-04). À 13:11:18, j'ai arrêté le service de collecte du serveur de containers. L'alerte est passée en **Pending**, puis en **Firing** après les deux minutes prévues, et elle est revenue à **Normal** quand j'ai relancé le service. Un premier essai n'avait rien déclenché : le container était relancé en moins d'une seconde par un service systemd. C'était une bonne surprise sur la résilience, mais il fallait arrêter le service lui-même pour tester l'alerte. Les autres seuils suivront le même modèle. L'envoi des alertes par mail attend un serveur de messagerie.

Des dashboards utiles. Le contrôleur de domaine a un dashboard compatible avec la version récente de windows_exporter (processeur, mémoire, disques, réseau, état des services), choisi après le diagnostic d'INC-03. Wazuh fournit les vues de chasse aux menaces, de conformité et de cartographie MITRE ATT&CK que j'ai utilisées dans PV-03.

Une supervision elle-même sécurisée. Les containers de supervision tournent sans privilège (Podman *rootless*). J'ai fermé le port de node_exporter sur le firewall local, puisque Prometheus l'interroge en local (constat F-05). Les interfaces web d'administration sont en TLS, sauf l'écoute HTTP du firewall relevée en F-02, dont la correction est planifiée.

Optimiser, c'est aussi enlever. J'ai réduit windows_exporter aux seuls collecteurs utiles et valides (`cpu` , `logical_disk` , `net` , `os` , `service` , `system` , `memory` , `process` , `tcp` , plus `ad` et `dns` pour le contrôleur de domaine). Moins de bruit, aucune métrique morte.

La supervision réseau du firewall. Un firewall est un équipement réseau, alors je l'interroge en SNMP avec Zabbix, l'outil fait pour ça. Zabbix tourne en containers *rootless* et collecte 100 éléments, dont l'état du tunnel. SNMP v3 (authentification et chiffrement) est l'objectif. La version 2c, où la communauté circule en clair, n'est acceptée qu'en laboratoire, avec des protections : une communauté aléatoire, une écoute limitée au LAN, et une règle de firewall qui réserve l'interrogation au seul serveur Zabbix. Je l'ai vérifié : Zabbix reçoit une réponse, l'hyperviseur est refusé et le refus apparaît dans les logs (PV-04).

◆ 6.2 Mesure et analyse du niveau de sécurité (CP8)

J'ai suivi une boucle complète : lettre de mission, puis audit, puis évaluation du rapport, puis analyse de risques, puis traitement.

D'abord la lettre de mission (annexe A, 01/10/2026). Avant de contrôler quoi que ce soit, j'ai écrit le mandat : le contexte, les objectifs, le périmètre (cinq composants et le segment interne ; l'hyperviseur et les postes clients sont hors périmètre), les référentiels (ANSSI, CIS, EBIOS RM, MITRE ATT&CK, RGPD), la méthode, les règles d'engagement

(tests actifs autorisés, rien de destructif, aucune exfiltration, un seul point de contact), les livrables et les critères de conformité. Écrite avant l'audit, elle sert ensuite à juger le rapport : on ne peut évaluer un rapport qu'en le comparant à ce qui était demandé.

L'audit (annexe B, PV-02 du 04/10/2026) s'est fait en boîte blanche, sur trois couches qui se complètent :

Couche	Outil	Résultat
Exposition réseau	nmap 7.92	Six hôtes et leurs services cartographiés ; la plupart des ports sont filtrés par les firewalls locaux (le scan interne ne passe pas par pfSense) ; aucun vieux service dangereux (Telnet, FTP, SMBv1)
Hardening système	Lynis 3.1.7	Indice **69/100** sur le serveur Linux, 253 tests, 0 avertissement, 20 suggestions
Conformité de configuration	Wazuh SCA	Écarts au référentiel CIS par agent, y compris sur Windows, où Lynis ne fonctionne pas

Constat	Description	Gravité
F-01	L'adresse d'administration de l'hyperviseur est sur le segment de production	Élevée
F-02	L'administration du firewall est accessible en HTTP	Moyenne
F-03	Le RDP du contrôleur de domaine est ouvert à tout le segment	Moyenne à élevée
F-04	WS-Discovery exposé sur TrueNAS	Faible
F-05	node_exporter sans authentification	Faible
F-06	Le plan d'administration (SSH, Cockpit) est joignable depuis tout le segment	Moyenne
F-07 à F-11	SSH, mots de passe et umask, protocoles inutiles, stockage amovible, mises à jour automatiques	Faible

L'évaluation du rapport par rapport à la lettre (annexe C) conclut qu'il est conforme, avec un écart que j'assume : le scan de vulnérabilités dédié (OpenVAS) prévu dans la lettre n'a pas pu être fait, car la VM d'audit toute prête n'a pas démarré. Les autres couches ont assuré la couverture, et l'écart est noté comme action d'amélioration.

L'analyse de risques EBIOS Risk Manager (annexe D) part des constats comme de vraies vulnérabilités. Elle identifie quatre valeurs métier, six biens supports et sept événements redoutés. Elle retient quatre couples « source de risque / objectif visé » et décrit quatre scénarios opérationnels :

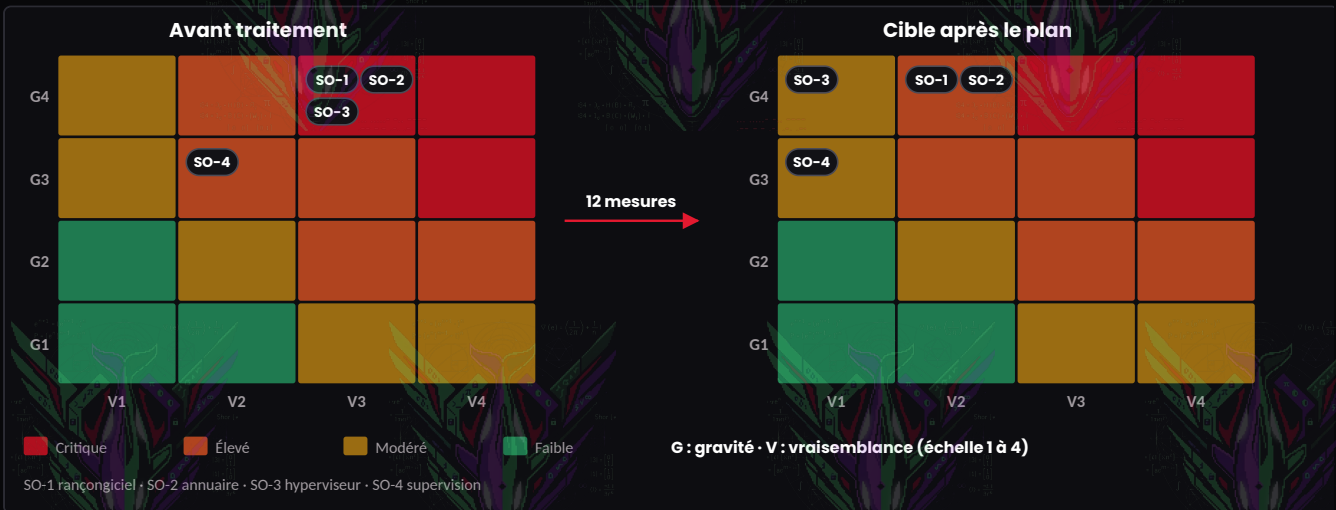


Figure 12 Cartographie des risques EBIOS RM : niveau de départ et niveau visé après le plan de traitement.

Abréviations — **G / V** : gravité / vraisemblance : les deux axes de la cartographie des risques EBIOS RM (de 1 à 4) · **SO-1…SO-4** : scénarios opérationnels de l'analyse EBIOS RM · **EBIOS RM** : méthode d'analyse de risques de l'ANSSI (EBIOS Risk Manager)

Avant traitement, trois scénarios sont critiques : un ransomware sur le partage SMB (SO-1), la compromission de l'annuaire par RDP (SO-2) et le rebond vers l'hyperviseur (SO-3). Les trois viennent du même défaut : un plan d'administration pas assez cloisonné. Le plan de traitement compte douze mesures, de M-01 (réseau d'administration dédié) à M-12 (hardening de Cockpit). Il s'appuie d'abord sur ce qui existe déjà (backup, SIEM, containers *rootless*). Une fois appliqué, il sort tous les scénarios de la zone critique. C'est une cible : aujourd'hui, les mesures de hardening (M-05 à M-09) sont appliquées en partie sur le serveur Linux, et les mesures de cloisonnement M-01 à M-04 sont planifiées. Le rebond vers l'hyperviseur (SO-3) reste donc le scénario prioritaire, avec une mesure compensatoire. SO-1 et SO-2 resteront élevés, parce que leur gravité vient du cœur du système. Ils sont acceptés sous surveillance : le backup garantit la reprise et la détection garantit la réaction.

La boucle se referme. Le constat F-01 n'est pas resté théorique. Il a servi de point de départ à l'attaque simulée de PV-03, puis il a faussé un test d'accès distant (INC-05). J'en retiens qu'un constat d'audit non traité, c'est un vrai chemin d'attaque.

◆ 6.3 Politique de sécurité et sa mise en œuvre (CP9)

Une PSSI en douze articles (annexe E) : objet et périmètre, cadre et références, organisation et rôles, classification des actifs, identités et accès, sécurité réseau et cloisonnement, hardening des systèmes et des containers, protection des données, backup et continuité, logs, supervision et détection, gestion des incidents (avec l'escalade vers le CERT-FR et la notification à la CNIL sous 72 heures), secrets et cryptographie, conformité et amélioration continue. J'ai écrit les règles pour qu'on puisse les vérifier (« DOIT », « NE DOIT PAS »), et je les ai déclinées en procédures concrètes : livret de commandes, plan de mise en production, procédures d'enrôlement et de révocation.

Un hardening mesuré, pas seulement annoncé (annexe F). J'ai traité les constats de Lynis sur le serveur Linux, puis j'ai relancé l'audit :

Constat	Mesure appliquée
F-07	SSH : connexion root interdite, redirections coupées, trois essais au maximum, délais d'inactivité, logs détaillés
F-08	Politique de mots de passe (durées de vie) et umask 027
F-09	Protocoles réseau inutiles désactivés (dccp, sctp, rds, tipc)
F-10	Stockage USB désactivé
F-11	Mises à jour automatiques activées
F-05	Port de node_exporter fermé sur le firewall local
Résultat	**Indice Lynis : 69 → 76 / 100**

Pour les constats réseau, j'ai pris des **décisions de traitement claires**, comme le demande l'atelier 5 d'EBIOS. F-01 est accepté pour l'instant, avec une mesure compensatoire (segment isolé, un seul opérateur, détection Wazuh active), en attendant le réseau d'administration dédié. F-02, F-03, F-04 et F- 06 sont planifiés. Accepter un risque ne veut pas dire l'oublier : on le décide, on explique pourquoi, et on note la date.

Un backup conçu en 3-2-1-0, et une restauration prouvée (annexe G, PV-01). Le partage SMB a trois copies : la production sur un pool ZFS en miroir, des snapshots toutes les heures gardés deux semaines, et une réplication `zfs send/recv` vers un second jeu de données. J'ai simulé une perte totale des données, puis restauré depuis le snapshot :

Indicateur	Résultat
RTO, au niveau fichier	**< 1 seconde**

Indicateur	Résultat
RPO	≤ 1 heure (fréquence des snapshots)
Intégrité après restauration	**0 erreur**, 3 hash SHA-256 sur 3 conformes
Intégrité de la copie répliquée	**0 erreur**, 3 sur 3

Le procès-verbal dit aussi ses limites. En laboratoire, la copie répliquée est sur le même pool. En production, elle irait sur un serveur distant : le mécanisme est le même, mais les critères « 2 supports » et « 1 copie hors site » ne sont atteints qu'en production. De plus, la restauration par simple copie ne garde pas les ACL. Je recommande donc une méthode de restauration qui les conserve.

Une sensibilisation pensée pour changer les habitudes (annexe H). La séance courte « Les bons réflexes de sécurité au quotidien » dure 45 minutes. Elle s'adresse à deux publics, les utilisateurs et l'équipe technique, avec un vocabulaire adapté à chacun. Elle couvre les mots de passe, le phishing, le poste de travail et l'accès distant, la protection des données, et comment signaler un incident. Pour mesurer son effet, je prévois un quiz de cinq questions à la fin, puis un faux phishing trente jours plus tard. Après l'incident INC-04, j'y ai ajouté une consigne : un code QR de configuration contient une clé secrète, et il ne se lit qu'avec l'application WireGuard.

◆ 6.4 Détection et traitement des incidents (CP10)

La chaîne de détection (figure 8) relie les agents Wazuh du contrôleur de domaine et du serveur de containers au manager. Celui-ci décode les logs, applique les règles, corrèle et qualifie les événements avec MITRE ATT&CK. La réponse suit la PSSI : détection, qualification, confinement, éradication, rétablissement, clôture, puis retour d'expérience.

Un exercice : l'attaque par force brute de PV-03 (annexe I). J'ai lancé quinze tentatives de connexion SSH sur un compte qui n'existe pas, depuis l'adresse d'administration de l'hyperviseur (le vecteur F-01), vers le serveur de containers.

Étape	Ce qui s'est passé
Détection	La règle Wazuh 5710 s'est déclenchée 15 fois, exactement autant que les tentatives ; corrélation de niveau 10 en moins d'une minute
Qualification	MITRE ATT&CK T1110 (force brute), T1110.001 (password guessing), T1021.004 (SSH), T1078 (comptes valides)
Confinement	Sur l'hôte visé : le trafic reste dans le segment et ne passe pas par pfSense, donc le blocage se fait sur le firewall local, ce que la réponse active de Wazuh peut automatiser
Éradication	Traitement de la cause F-01 décidé (accepté pour l'instant au gel) ; SSH durci
Rétablissement	Aucune compromission : le compte n'existe pas, toutes les tentatives ont échoué
RETEX	Activer la réponse active, limiter SSH à un poste d'administration, authentification par clé et MFA, traiter F-01 en priorité

Un incident réel : l'exposition d'une clé privée (INC-04). Pendant l'enrôlement de mon smartphone, j'ai lu le code QR du profil administrateur avec l'appareil photo au lieu de l'application WireGuard. L'appareil photo a envoyé le contenu à un service de recherche en ligne : la clé privée avait quitté le téléphone. Je l'ai traité comme un vrai incident de sécurité, avec la même chaîne. Qualification : un secret lié à un profil à privilèges, donc la clé est considérée comme compromise, sans attendre de preuve d'utilisation. Confinement : j'ai retiré tout de suite l'ancienne clé publique du firewall. Éradication : nouvelle paire de clés, nouveau code QR, enrôlement refait avec la bonne application. Rétablissement : handshake vérifié avec la nouvelle clé. RETEX : consigne ajoutée à la sensibilisation et au transfert de compétences. Aucun morceau de clé privée n'apparaît dans ce dossier.

Cet incident m'a plus appris qu'un exercice. Il prouve en situation réelle que la révocation fonctionne (exigence EF5), et il montre qu'une erreur humaine se traite avec la procédure, pas en la cachant.

Garder les preuves. Les éléments d'un incident sont horodatés, scellés par hash SHA-256 et gardés hors ligne. La PSSI (article 10.5) encadre leur transmission aux analystes, l'escalade vers le CERT-FR et la notification à la CNIL quand une donnée personnelle est concernée.

Le journal d'incidents (annexe J) applique la même méthode à toutes les difficultés du projet : symptôme, diagnostic, cause, résolution, preuve, enseignement.

Réf.	Incident	Ce que j'en retiens
INC-01	L'installateur TrueNAS ne démarre pas	Choisir le bon firmware selon l'usage de la console
INC-02	Jonction au domaine refusée (horloge, puis mot de passe)	Kerberos exige des horloges synchronisées à moins de cinq minutes
INC-03	Supervision Windows : collecteurs supprimés, dashboard incompatible	Ne jamais supposer qu'un logiciel reste stable d'une version à l'autre
INC-04	Exposition de la clé privée d'un accès administrateur	Un secret exposé est un secret compromis
INC-05	Test d'accès distant faussé par la position del'hyperviseur	Un test d'accès distant part d'un poste vraiment extérieur
INC-06	Tunnel WireGuard sans retour, à cause d'*Allowed IPs* en double	Un voyant vert ne prouve pas qu'un flux passe
INC-07	Réponses non routées vers le tunnel : interface sans adresse fixe	Deux causes peuvent donner le même symptôme ; corriger la première ne prouve rien

Une veille qui fait évoluer la détection (annexe K). Elle part de l'inventaire de l'infrastructure et privilégie les sources d'origine : CERT-FR, ANSSI, CVE et NVD, la liste des vulnérabilités exploitées de la CISA, les éditeurs, MITRE ATT&CK, la CNIL. Chaque information est qualifiée, puis je décide (corriger, compenser ou accepter), je la note dans un registre et, quand une technique d'attaque est en jeu, je la transforme en règle de détection. Un exemple : la corrélation de base de Wazuh tolère huit échecs en deux minutes. Pour une infrastructure de cette taille, j'ai déployé une règle locale plus stricte (100100, niveau 12, cinq tentatives en soixante secondes). J'ai rejoué l'attaque de PV-03 le 11/10 : l'alerte est tombée en deux secondes, dès la cinquième tentative, liée à la technique MITRE T1110.001 (PV-04).

07

CHAPITRE 7

Relations avec les acteurs

Avec qui le projet se construit, et comment j'adapte mes écrits à chaque lecteur.

Transverse

7. Relations avec les principaux acteurs du projet

J'ai mené ce projet seul, mais il concerne plusieurs personnes. Chacune reçoit une information adaptée à son rôle et à son niveau technique, et toujours par écrit, pour garder une trace.

Acteur	Rôle	Échanges et documents
Direction, client (DSI d'INFRASEC, fictive)	Exprime le besoin, décide du budget	Cahier des charges et TCO à valider ; plan de mise en production à autoriser ; synthèse mensuelle de veille
RSSI	Autorité de sécurité	Valide la PSSI ; autorise les tests actifs (lettre de mission) ; tranche les décisions de traitement du risque (F-01 accepté pour l'instant) ; reçoit l'escalade des incidents
Utilisateurs : collaborateurs en télétravail, administrateur nomade	Ceux pour qui l'évolution est faite	Information avant le changement ; enrôlement de leur appareil ; consignes d'usage ; sensibilisation ; signalement d'incident
Auditeur (interne, ou prestataire qualifié PASSI)	Mesure le niveau de sécurité	Mandaté par la lettre de mission ; remet son rapport ; évalué par rapport à la lettre
Équipe d'exploitation	Fait vivre le service dans la durée	Livret de commandes, manuel d'exploitation bilingue, démonstration commentée, procédures d'enrôlement et de révocation
Éditeurs et communautés (Netgate, Microsoft, Wazuh, Grafana…)	Fournissent les logiciels	Avis de sécurité et notes de version, suivis par la veille
ANSSI, CERT-FR, CNIL	Autorités et références	Référentiels et alertes ; escalade d'un incident majeur ; notification d'une violation de données personnelles

Écrire pour le bon lecteur. Je n'écris pas de la même façon pour tout le monde. Pour le client, je parle d'exigences et de critères mesurables. Pour l'exploitant, j'écris des procédures pas à pas. Pour l'utilisateur, je donne des consignes simples et concrètes. Le support de sensibilisation n'utilise aucun mot technique sans l'expliquer. Le livret de commandes, lui, ne contient que des commandes que j'ai vérifiées.

Les personnes réelles. En dehors de la société fictive, le projet s'est construit avec mon formateur et le référent pédagogique de la formation, dont les évaluations ont rythmé les compétences, et avec mon tuteur pendant ma période en entreprise, où j'ai travaillé sur l'automatisation du déploiement d'infrastructures.

08

CHAPITRE 8

Synthèse et conclusion

Le bilan par rapport aux objectifs, ce que j'ai appris, les limites que j'assume et la suite.

Bilan

8. Synthèse et conclusion

8.1 Bilan au regard des objectifs

Objectif	Résultat	Preuve
Concevoir une évolution qui répond au besoin	Accès distant Zero-Trust spécifié, quatre solutions comparées, WireGuard retenu (4,85/5), TCO de 4 610 € sur 3 ans	Chap. 2 et 4
La mettre en production sans risque pour l'existant	Changement additif, onze étapes sur onze validées, recette conforme le 11/10, rollback écrit, révocation chronométrée	Chap. 5, annexe O
Superviser	Indicateurs justifiés, dashboards, firewall supervisé en SNMP, alerte testée	Chap. 6.1
Mesurer la sécurité	Audit conforme à sa lettre de mission, 11 constats, EBIOS RM avec un plan qui ne laisse plus aucun scénario critique (cible)	Chap. 6.2
Appliquer la politique	PSSI, Lynis 69 → 76, restauration en moins d'une seconde sans erreur, sensibilisation prête	Chap. 6.3
Détecter et traiter	Attaque détectée en moins d'une minute, règle locale qui alerte en deux secondes, incident réel traité, sept incidents documentés, veille organisée	Chap. 6.4

8.2 Ce que le projet m'a appris

Un voyant vert ne prouve rien. Le tunnel WireGuard montait alors qu'aucune réponse ne pouvait revenir au collaborateur (INC-06), et la recette a montré une deuxième cause pour le même symptôme (INC-07). Aujourd'hui, je ne prends plus un état affiché pour une preuve. Je valide sur un flux réel, observé de bout en bout.

Un secret exposé est un secret compromis. Quand la clé a été lue par l'appareil photo (INC-04), la bonne décision n'était pas d'estimer le risque, mais de révoquer tout de suite. Ça a marché parce que l'architecture rend la révocation simple : il suffit de retirer une clé publique.

Tester depuis le bon endroit. Un test lancé depuis l'hyperviseur « réussissait » en passant à côté du tunnel (INC-05). Un test qui ne peut pas échouer n'apprend rien.

Accepter un risque est une décision. Je n'ai pas corrigé le constat F-01 avant la soutenance, parce qu'il porte aujourd'hui le seul chemin d'administration. Je l'ai accepté pour l'instant, en expliquant pourquoi, avec une mesure compensatoire, et cette décision est datée dans le rapport de gel (annexe F). C'est très différent de l'oublier.

8.3 Limites que j'assume

- Le plan d'administration de l'hyperviseur est toujours sur le segment de production (F-01), en attendant le réseau d'administration dédié (M-01).
- Le scan de vulnérabilités dédié (OpenVAS) prévu par la lettre de mission n'a pas été fait. La couverture a été assurée autrement.
- En laboratoire, la copie répliquée des backups est sur le même pool. En production, elle irait sur un site distant.
- La règle du profil administrateur couvre encore tout le segment interne. Je dois la limiter aux interfaces d'administration, puis refaire l'essai de ce profil avec le client de recette.
- L'accès distant n'a pas encore d'authentification multifacteur, et SNMP est encore en version 2c (protégé, mais la cible est la v3).
- Les alertes s'affichent dans Grafana mais ne sont pas encore envoyées par mail, faute de serveur de messagerie.
- Le changement du mot de passe administrateur de Wazuh est encore à faire.

8.4 Perspectives

À court terme : le réseau d'administration dédié et le retrait de F-01 (M-01), la restriction de la règle administrateur de l'accès distant, la restriction du RDP (M-02), l'administration du firewall en HTTPS seulement (M-04), et le changement du mot de passe administrateur de Wazuh. À moyen terme : l'authentification multifacteur sur l'accès distant, SNMP v3, un scan de vulnérabilités régulier, la réponse active automatique, l'envoi des alertes et la mise à jour de Wazuh après tests. Plus tard : un deuxième firewall en redondance (CARP) pour dépasser l'objectif de disponibilité, et la prise en compte de la posture des postes clients.

8.5 Conclusion

Ce projet m'a fait passer de la construction d'une infrastructure à sa conduite. J'ai appris à transformer un besoin en exigences mesurables, à comparer des solutions avec une méthode, à chiffrer honnêtement, à mettre en production sans mettre en danger l'existant, puis à mesurer, décider et réagir. Les résultats qui comptent le plus pour moi sont ceux que je peux prouver : une restauration chronométrée, un indice de hardening qui progresse, une attaque détectée en moins d'une minute, un accès révoqué en une seconde au plus, un incident réel traité en révoquant une clé.

C3

COMPLÉMENT CCP3

Octobre 2026 : exploitation, incidents et détection

Le travail mené du 21 au 26 octobre après l'oral : réponses au jury, architecture par machine, 18 fiches, 5 procès-verbaux, une procédure.

CP8 CP9 CP10

C1

CHAPITRE

Contexte et réponses au jury

Ce que ce dossier prouve, et comment il répond aux cinq remarques de l'oral du 21/10/2026.

CCP3 CP8 CP9 CP10

C1 · Contexte et réponses au jury

C1.1 Objet du dossier

Ce dossier présente le travail mené sur le labo Hybrid InfraSec pour le certificat « Participer à la gestion de la cyber-sécurité » (CCP3) du titre AIS. Après l'oral du 21/10/2026, j'ai repris le labo pendant six jours, du 21 au 26 octobre, avec une règle simple : chaque remarque du jury devait donner lieu à un travail réel, mesuré et prouvé, pas à un paragraphe de plus.

Le résultat tient en **18 fiches d'incident et de constat** (INC-08 à INC-11, F-13 à F-26), **5 procès-verbaux de mise en œuvre** (PV-05 à PV-09) et **1 procédure** (PROC-01). Chaque fiche suit le même plan : constat, cause racine, correction, preuve, enseignement. Chaque correction est prouvée par un test rejoué après coup, depuis une machine tierce quand il s'agit de filtrage. Les fiches complètes sont en annexe.

Toutes les preuves ont été obtenues sur le labo réel, à partir des journaux des machines, en ligne de commande. Les heures notées « UTC » viennent du SIEM, dont l'horloge est en temps universel ; les autres sont à l'heure de Paris.

C1.2 Réponses aux remarques du jury

Remarque du jury	Ce que j'ai fait	Où le vérifier
Lecture des journaux par l'interface graphique	Toutes les preuves sont obtenues en ligne de commande : `journalctl --list-boots` puis `-b -N`, `zgrep` sur les archives, `grep` dans `alerts.json`, `midclt call audit.query`, `journalctl -t lab`. Le contrôleur de domaine Windows est administré par SSH depuis l'hyperviseur, par clé seulement.	INC-11, F-14, F-19, F-20, PV-06, PV-07
Architecture par machine	Un schéma réseau général couche par couche (OSI), puis une fiche par machine : tableau, schéma de ses flux réseau, organigramme de ce qui s'y passe.	Chapitres 2 et 3
Les 10 salariés virtuels	Entreprise INFRASEC créée par script idempotent à partir d'un seul fichier `employes.csv` : 6 services, 10 salariés, modèle AGDLP, partages testés par 6 accès dont 2 refus, et la même entreprise rejouée sur un second domaine Samba.	Chapitre 4, PV-05, PV-06, PV-08
Confusion entre disponibilité et sécurité	Une section dédiée (1.3) et plusieurs fiches où une mesure de sécurité cassait la disponibilité, ou l'inverse, avec la façon de concilier les deux.	1.3, INC-08, F-22, F-23, F-24
Abréviations (CERT, G/V sur les figures)	Sous chaque figure, la liste de toutes les abréviations qu'elle contient. CERT : centre de réponse aux incidents de sécurité. G/V : gravité et vraisemblance, les deux axes de la cartographie EBIOS RM. Glossaire complet au chapitre 9.	Toutes les figures, chapitre 9

C1.3 Disponibilité et sécurité : la distinction retenue

La **sécurité** protège la confidentialité, l'intégrité et la traçabilité de l'information. La **disponibilité** garantit que le service répond quand on en a besoin. Dans la triade classique, la disponibilité fait partie de la sécurité ; mais en exploitation, les deux objectifs tirent souvent en sens contraire. Elles ne s'opposent pas : elles se conçoivent ensemble, et une bonne mesure protège sans rien casser.

Situation	La mesure qui cassait l'autre objectif	La mesure retenue
Cockpit de l'hyperviseur (INC-08)	Lier le service à une adresse : la console disparaît dès qu'on change de réseau (disponibilité perdue).	Restreindre l'accès par le pare-feu ; le service écoute partout, seule la source est filtrée.

Situation	La mesure qui cassait l'autre objectif	La mesure retenue
Clé de l'autorité de certification du SIEM (F-22)	La détruire : plus aucun certificat renouvelable (disponibilité future perdue). La garder en clair : confidentialité perdue.	La conserver chiffrée en AES-256, hors du SIEM, dans le coffre de l'hôte.
Mémoire de l'hyperviseur (F-23)	Réduire toutes les machines au hasard : le SIEM, déjà juste, serait tombé.	Mesurer chaque machine, réduire seulement les deux surdimensionnées.
Verrouillage des comptes (F-24)	Le seuil de verrouillage protège contre la force brute, mais un attaquant lent peut verrouiller tous les comptes (déni de service).	Garder le seuil et faire alerter le verrouillage lui-même (règle 100320).
Sauvegarde du labo (PV-09)	Une sauvegarde modifiable peut être chiffrée par un rançongiciel.	Sauvegarde en lecture seule : disponible pour la restauration, intouchable pour un attaquant.

C2

CHAPITRE

Architecture du labo

Un hyperviseur, sept machines virtuelles, une seule sortie : le pare-feu. Le schéma général, couche par couche.

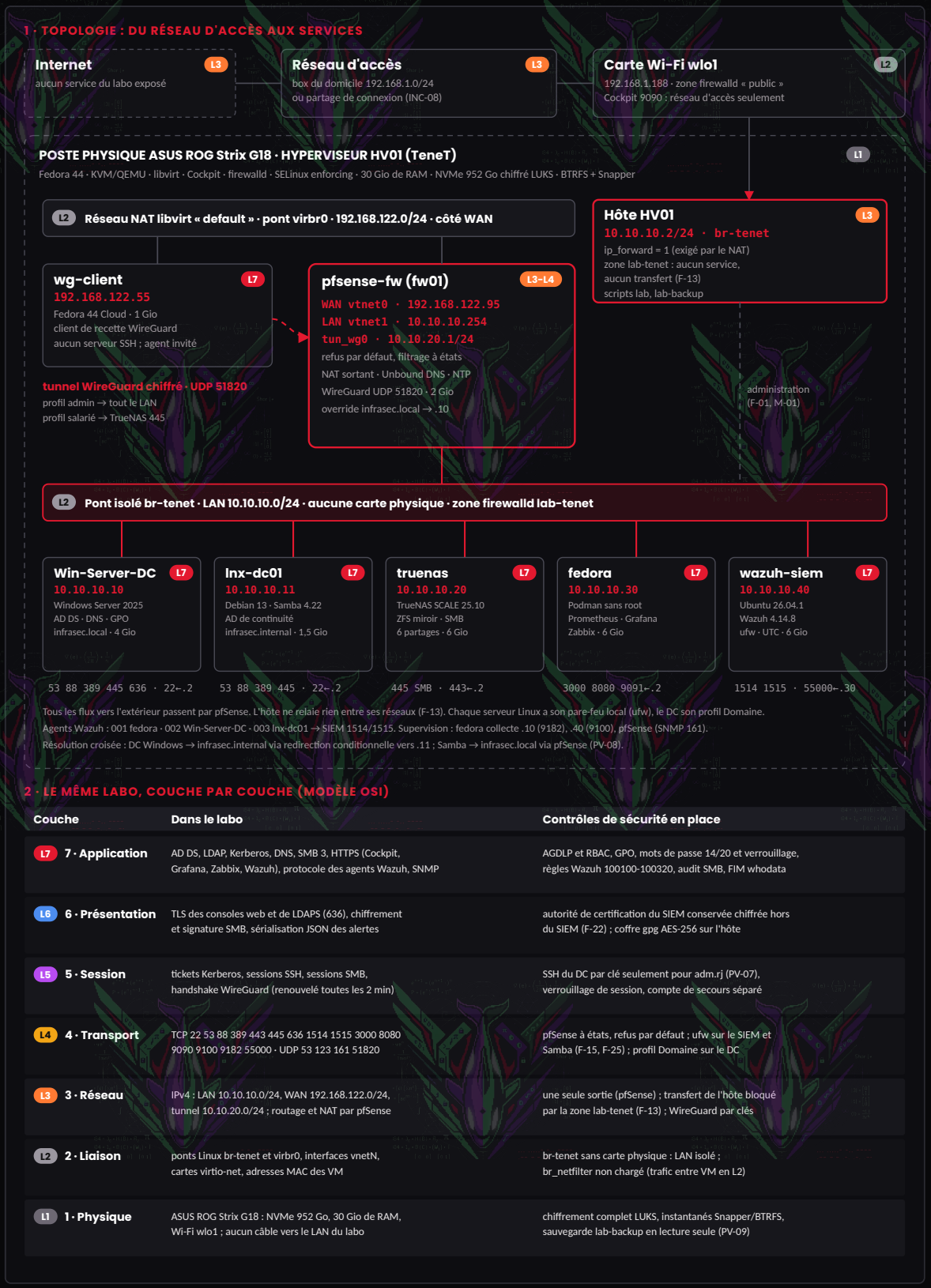
OSI L1 → L7 | HV01 | br-tenet

C2 · Architecture du labo

C2.1 Vue d'ensemble

Le labo tient sur un seul hyperviseur, **HV01** (nom d'hôte TeneT) : un ordinateur portable ASUS ROG Strix G18 sous Fedora 44, avec KVM et libvirt, 30 Gio de mémoire et un disque NVMe de 952 Go chiffré par LUKS. Les machines virtuelles partagent un réseau isolé, `10.10.10.0/24`, porté par le pont `br-tenet`, qui n'a aucune carte physique. Seul pfSense touche l'extérieur, par le réseau NAT `virbr0` de l'hyperviseur.

Le schéma qui suit se lit en deux temps : d'abord la topologie, du réseau d'accès jusqu'aux services ; ensuite le même labo couche par couche, du matériel (couche 1) jusqu'aux applications (couche 7), avec pour chaque couche ce qui existe et les contrôles de sécurité en place.



2 · LE MÊME LABO, COUCHE PAR COUCHE (MODÈLE OSI)

Couche	Dans le labo	Contrôles de sécurité en place
L7 7 · Application	AD DS, LDAP, Kerberos, DNS, SMB 3, HTTPS (Cockpit, Grafana, Zabbix, Wazuh), protocole des agents Wazuh, SNMP	AGDLP et RBAC, GPO, mots de passe 14/20 et verrouillage, règles Wazuh 100100-100320, audit SMB, FIM whodata
L6 6 · Présentation	TLS des consoles web et de LDAPS (636), chiffrement et signature SMB, sérialisation JSON des alertes	autorité de certification du SIEM conservée chiffrée hors du SIEM (F-22) ; coffre gpg AES-256 sur l'hôte
L5 5 · Session	tickets Kerberos, sessions SSH, sessions SMB, handshake WireGuard (renouvelé toutes les 2 min)	SSH du DC par clé seulement pour adm.rj (PV-07), verrouillage de session, compte de secours séparé
L4 4 · Transport	TCP 22 53 88 389 443 445 636 1514 1515 3000 8080 9090 9100 9182 55000 · UDP 53 123 161 51820	pfSense à états, refus par défaut ; ufw sur le SIEM et Samba (F-15, F-25) ; profil Domaine sur le DC
L3 3 · Réseau	IPv4 : LAN 10.10.10.0/24, WAN 192.168.122.0/24, tunnel 10.10.20.0/24 ; routage et NAT par pfSense	une seule sortie (pfSense) ; transfert de l'hôte bloqué par la zone lab-tenet (F-13) ; WireGuard par clés
L2 2 · Liaison	ponts Linux br-tenet et virbr0, interfaces vnetN, cartes virtio-net, adresses MAC des VM	br-tenet sans carte physique : LAN isolé ; br_netfilter non chargé (trafic entre VM en L2)
L1 1 · Physique	ASUS ROG Strix G18 : NVMe 952 Go, 30 Gio de RAM, Wi-Fi wlo1 ; aucun câble vers le LAN du labo	chiffrement complet LUKS, instantanés Snapper/BTRFS, sauvegarde lab-backup en lecture seule (PV-09)

Figure 13 Architecture réseau générale du labo Hybrid InfraSec : topologie complète et lecture couche par couche du modèle OSI (état au 26/10/2026).

Abréviations — **L1…L7** : couches du modèle OSI : 1 physique, 2 liaison, 3 réseau, 4 transport, 5 session, 6 présentation, 7 application · **OSI** : modèle de référence en 7 couches (Open Systems Interconnection) · **HV01** : hyperviseur du labo, nom d'hôte TeneT · **KVM** : hyperviseur intégré au noyau Linux (Kernel-based Virtual Machine) · **LUKS** : chiffrement complet du disque sous Linux (Linux Unified Key Setup) · **BTRFS** : système de fichiers à instantanés (B-tree file system) · **NAT** : traduction d'adresses (Network Address Translation) · **WAN** : côté extérieur du pare-feu (réseau NAT 192.168.122.0/24) · **LAN** : réseau local du labo 10.10.10.0/24 · **WG** : WireGuard : tunnel VPN chiffré, port UDP 51820 · **DNS** : résolution des noms (Domain Name System) · **NTP** : synchronisation de l'heure (Network Time Protocol) · **AD DS** : services de domaine Active Directory · **LDAP** : protocole d'accès à l'annuaire (Lightweight Directory Access Protocol) · **SMB** : partage de fichiers Windows (Server Message Block), port 445 · **SNMP** : supervision des équipements réseau (Simple Network Management Protocol), port UDP 161 · **TLS** : chiffrement des échanges (Transport Layer Security) · **SSH** : administration à distance chiffrée

(Secure Shell), port 22 · **GPO** : stratégie de groupe Windows (Group Policy Object) · **AGDLP** : comptes → groupes Globaux → groupes de Domaine Local → Permissions · **RBAC** : contrôle d'accès fondé sur les rôles (Role-Based Access Control) · **FIM** : surveillance de l'intégrité des fichiers (File Integrity Monitoring) · **whodata** : mode FIM de Wazuh qui enregistre aussi l'auteur et le processus · **TCP / UDP** : protocoles de transport, avec ou sans connexion · **ufw** : pare-feu local de Debian et Ubuntu (Uncomplicated Firewall) · **DC** : contrôleur de domaine (Domain Controller) · **SIEM** : collecte et corrélation des journaux de sécurité (Security Information and Event Management) · **VM** : machine virtuelle · **Gio / Go** : gibioctets (mémoire, 2^{30} octets) / gigaoctets (disque, 10^9 octets) · **agent invité** : service QEMU dans la VM qui reçoit les ordres de l'hyperviseur (guest agent)

C2.2 Les machines

Machine	Rôle	Adresse	Mémoire
`pfsense-fw` (`fw01`)	Pare-feu, passerelle, DNS récursif, NTP, VPN WireGuard	`10.10.10.254`	2 Gio
`Win-Server-DC` (`dc01`)	Contrôleur du domaine `infrasec.local` , Windows Server 2025	`10.10.10.10`	4 Gio
`lnx-dc01`	Contrôleur Samba du domaine de continuité `infrasec.internal`	`10.10.10.11`	1,5 Gio
`truenas`	Stockage : pool `tank` en miroir, partages SMB par service	`10.10.10.20`	6 Gio
`fedora`	Supervision : Prometheus, Grafana, Zabbix en Podman sans root	`10.10.10.30`	6 Gio
`wazuh-siem`	SIEM Wazuh 4.14.8 : manager, indexeur, tableau de bord	`10.10.10.40`	6 Gio
`wg-client`	Client du tunnel WireGuard (accès distant simulé)	`192.168.122.55`	1 Gio

L'heure de tout le labo vient de pfSense, sauf le SIEM, qui suit les serveurs NTP de Canonical et dont l'horloge est en UTC. Le DNS du domaine Windows est le contrôleur de domaine ; celui du domaine Samba est `lnx-dc01` , et la résolution entre les deux domaines est en place (PV-08).

C2.3 Flux d'administration et de collecte autorisés

Source	Destination	Port	Usage
Hôte `10.10.10.2`	SIEM	22, 443, 9090	SSH, tableau de bord Wazuh, Cockpit
Hôte `10.10.10.2`	Contrôleur de domaine Windows	22	PowerShell par SSH, clé `adm.rj` seulement (PV-07)
Hôte `10.10.10.2`	`lnx-dc01`	22	administration du domaine Samba
Réseau `10.10.10.0/24`	SIEM	1514, 1515	événements et enrôlement des agents
`fedora`	SIEM	55000, 9100	contrôle Zabbix de l'API, métriques Prometheus
`fedora`	pfSense	UDP 161	SNMP réservé au collecteur
Réseau `10.10.10.0/24`	`lnx-dc01`	53, 88, 389, 445, 464, 636, 3268-3269, RPC	services de l'annuaire Samba

Tout autre flux entrant sur le SIEM et sur `lnx-dc01` est refusé par défaut (F-15, F-25). Chaque règle a été vérifiée depuis une machine tierce, jamais depuis la cible : un test lancé depuis la cible passe par la boucle locale et ne peut pas échouer.

C2.4 Capacité de l'hyperviseur

Avant d'ajouter le contrôleur Samba, j'ai mesuré la mémoire machine par machine (F-23). L'hôte utilisait 4 Gio de swap avec 29 Gio alloués sur 30. J'ai réduit les deux machines surdimensionnées d'après leur consommation réelle ; le SIEM, la machine la plus juste, n'a pas été touché.

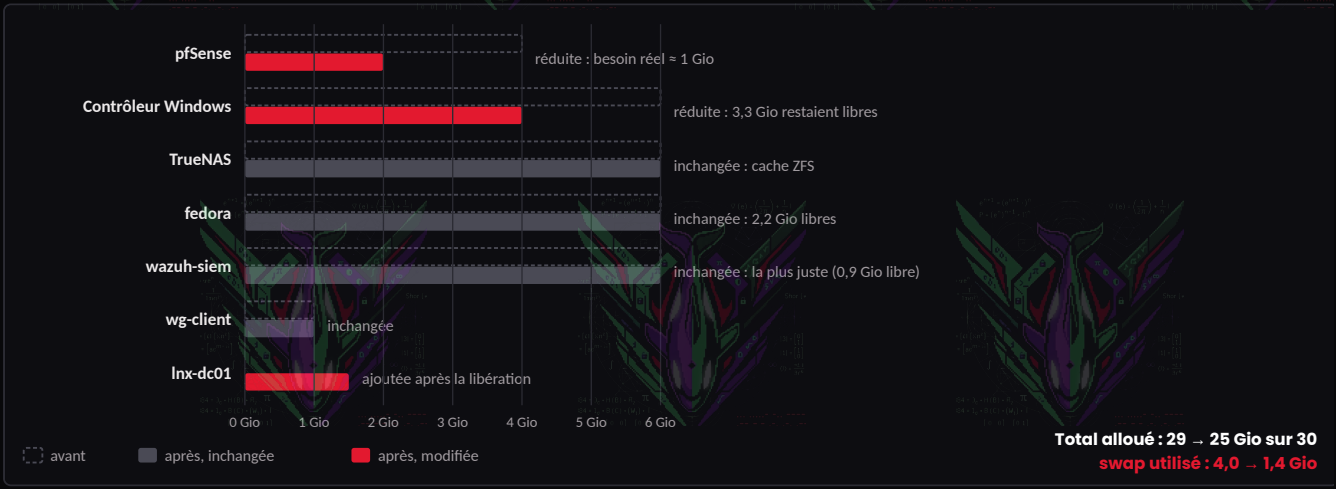


Figure 14 Mémoire allouée par machine, avant et après la correction du 25/10 (F-23).

Abréviations — **Gio / Go** : gibioctets (mémoire, 2^{30} octets) / gigaoctets (disque, 10^{9} octets) · **ZFS** : système de fichiers de TrueNAS, avec miroir et instantanés · **VM** : machine virtuelle

C2.5 Démarrer et arrêter le labo dans le bon ordre

Le labo est éteint la nuit. Démarré dans le désordre, il échouait en silence : le SIEM, plus rapide que Windows, cherchait son flux de vulnérabilités avant que le DNS du contrôleur de domaine réponde (F-14). Le script `lab` démarre maintenant les machines dans l'ordre de leurs dépendances et attend une **vraie** réponse de chaque service avant de passer au suivant. À l'arrêt, il passe par l'agent invité QEMU quand la machine en a un, par le signal ACPI sinon, et ne force jamais rien (F-26). Le 26/10, les 7 machines se sont arrêtées proprement en 66 secondes, contre trois refus du contrôleur Windows auparavant.

CHAPITRE

C3

Architecture par machine

Pour chaque machine : sa fiche, le schéma de ses flux réseau et l'organigramme de ce qui se passe à l'intérieur.

8 fiches · réseau · organigramme

C3 · Architecture par machine

Ce chapitre répond directement à la remarque du jury sur l'architecture par machine. Chaque fiche a trois parties : un tableau (rôle, configuration mesurée, filtrage, supervision, fiches liées), le schéma de ses flux réseau (qui peut la joindre, sur quel port, et ce qu'elle-même contacte), puis l'organigramme du travail principal qu'elle accomplit. Les unités sont écrites en toutes lettres : Go pour le disque, Gio pour la mémoire, vCPU pour un processeur virtuel.

C3.1 Hyperviseur HV01 (TeneT)

Rôle	héberge les 7 VM ; poste d'administration
Matériel	ASUS ROG Strix G18, 30 Gio de mémoire, 8 Gio de swap
Système	Fedora 44, KVM/libvirt, Cockpit, SELinux enforcing
Stockage	LUKS 952 Go (425 Go libres), BTRFS, Snapper ; /vm/images, /vm/iso (19 Go après ménage)
Réseau	br-tenet 10.10.10.2/24 (NetworkManager, INC-10) ; virbr0 192.168.122.0/24 ; wlo1
Filtrage	zone lab-tenet sans service ni transfert (F-13) ; Cockpit 9090 limité au réseau d'accès (INC-08)
Exploitation	lab (démarrage/arrêt ordonnés), lab-backup (PV-09), coffre ~/coffre (F-22)
Fiches	INC-08, INC-10, F-13, F-14, F-22, F-23, F-26, PV-09



Figure 15 Flux réseau de HV01 · TeneT : sources autorisées à gauche, destinations à droite.

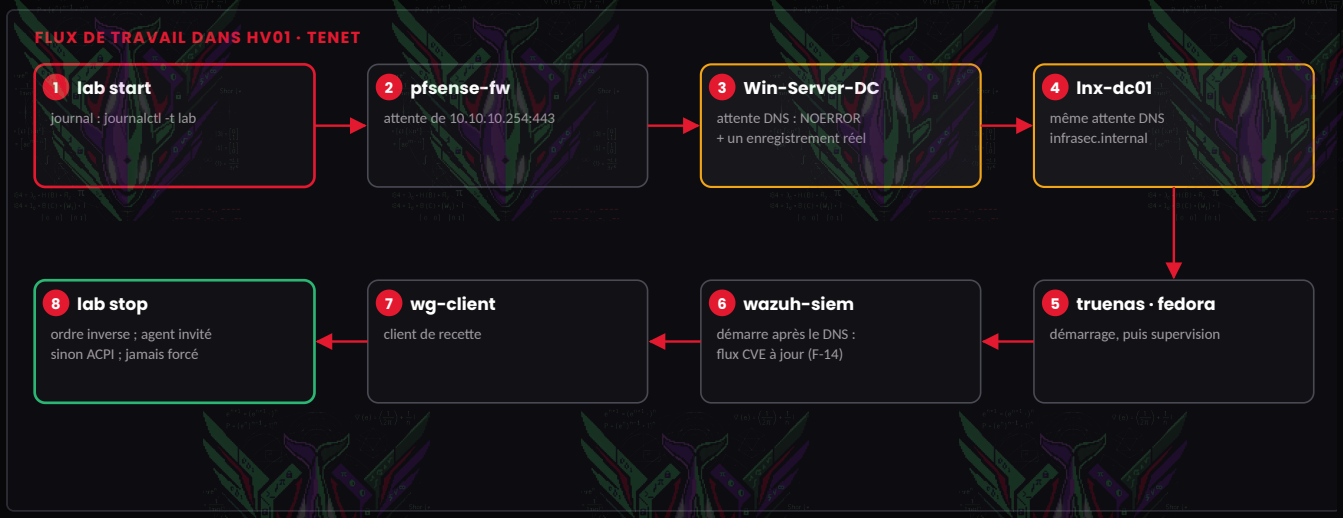


Figure 16 Organigramme de l'exploitation de l'hôte : démarrage ordonné par dépendances puis arrêt propre (script lab).

Abréviations (figures 15 et 16) — **HV01** : hyperviseur du labo, nom d'hôte TeneT · **KVM** : hyperviseur intégré au noyau Linux (Kernel-based Virtual Machine) · **LUKS** : chiffrement complet du disque sous Linux (Linux Unified Key Setup) · **BTRFS** : système de fichiers à instantanés (B-tree file system) · **LAN** : réseau local du labo 10.10.10.0/24 · **WAN** : côté extérieur du pare-feu (réseau NAT 192.168.122.0/24) · **DNS** : résolution des noms (Domain Name System) · **SSH** : administration à distance chiffrée (Secure Shell), port 22 · **ACPI** : signal d'alimentation simulé envoyé par l'hyperviseur (Advanced Configuration and Power Interface) · **agent invité** : service QEMU dans la VM qui reçoit les ordres de l'hyperviseur (guest agent) · **CVE** : identifiant public d'une vulnérabilité (Common Vulnerabilities and Exposures) · **VM** : machine virtuelle · **L1...L7** : couches du modèle OSI : 1 physique, 2 liaison, 3 réseau, 4 transport, 5 session, 6 présentation, 7 application · **Gio / Go** : gibioctets (mémoire, 2^{30} octets) / gigaoctets (disque, 10^{9} octets) · **INC / F** : fiche d'incident / fiche de constat · **PV** : procès-verbal de mise en œuvre ou de recette

C3.2 Pare-feu pfsense-fw (fw01)

Rôle	pare-feu, passerelle, DNS récursif (Unbound), source de temps, VPN WireGuard
Ressources	2 Gio de mémoire (F-23)
Adresses	LAN 10.10.10.254 ; WAN 192.168.122.95 sur virbr0 ; tun_wg0 10.10.20.1/24 (WG_REMOTE)
DNS	Domain Override infrasec.local → 10.10.10.10 (PV-08)
Administration	interface web 443 depuis le LAN ; HTTP 80 fermé depuis l'audit
Sauvegarde	export XML chiffré, rangé dans le coffre de l'hôte
Point d'attention	ISC DHCP en fin de vie signalé : passer à Kea
Fiches	F-13, F-14, PV-08

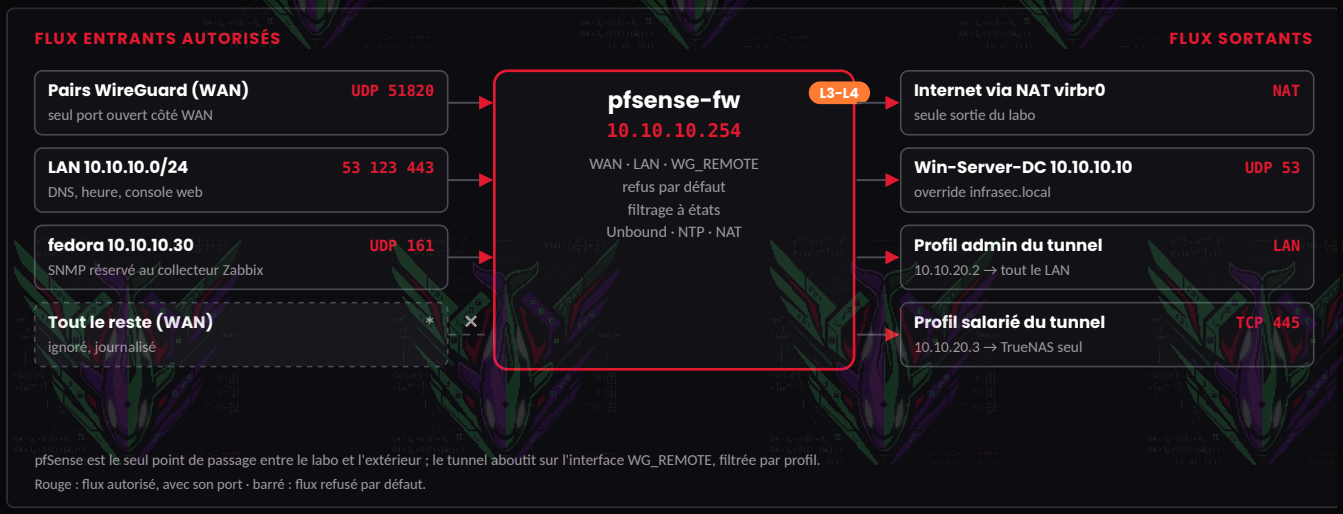


Figure 17 Flux réseau de pfsense-fw (fw01) : sources autorisées à gauche, destinations à droite.

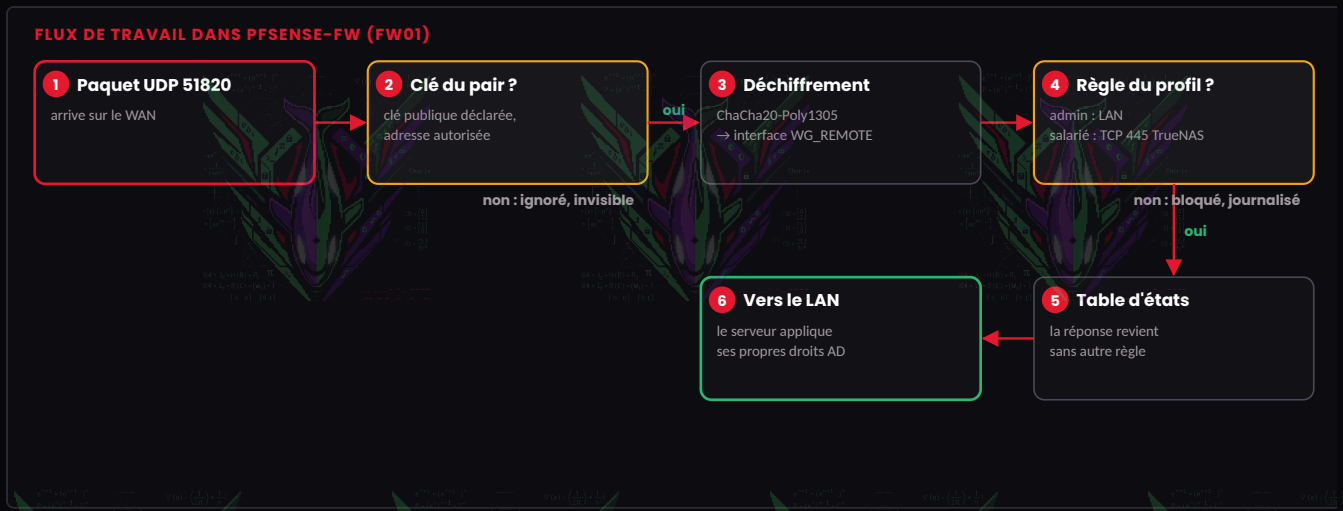


Figure 18 Organigramme du traitement d'une connexion distante par pfSense : clé, règle de profil, état.

Abréviations (figures 17 et 18) — **WAN** : côté extérieur du pare-feu (réseau NAT 192.168.122.0/24) · **LAN** : réseau local du labo 10.10.10.0/24 · **WG** : WireGuard : tunnel VPN chiffré, port UDP 51820 · **NAT** : traduction d'adresses (Network Address Translation) · **DNS** : résolution des noms (Domain Name System) · **NTP** : synchronisation de l'heure (Network Time Protocol) · **SNMP** : supervision des équipements réseau (Simple Network Management Protocol), port UDP 161 · **TCP / UDP** : protocoles de transport, avec ou sans connexion · **L1...L7** : couches du modèle OSI : 1 physique, 2 liaison, 3 réseau, 4 transport, 5 session, 6 présentation, 7 application · **Gio / Go** : gibioctets (mémoire, 2^{30} octets) / gigaoctets (disque, 10^{9} octets) · **AD DS** : services de domaine Active Directory · **INC / F** : fiche d'incident / fiche de constat · **PV** : procès-verbal de mise en œuvre ou de recette

C3.3 Contrôleur de domaine Win-Server-DC (dc01)

Rôle	contrôleur du domaine infrasec.local (NetBIOS INFRASEC), DNS, catalogue global
Système	Windows Server 2025 Standard, évaluation (fin vers le 27/03/2027, un réarmement restant)
Ressources	4 Gio, 4 vCPU, UEFI, disque de 60 Go
Annuaire	12 comptes, 27 groupes (AGDLP, ROLE_), mots de passe 14 caractères et verrouillage, PSO-Admins 20 (F-24)
Durcissement	GPO « DC - Navigation interdite » (F-17) ; OpenSSH limité à 10.10.10.2, clé adm.rj seulement (PV-07)
DNS	redirection conditionnelle infrasec.internal → 10.10.10.11 (PV-08)
Supervision	agent Wazuh 002 ; FIM whodata du dossier de démarrage (F-19) ; windows_exporter 9182 ; agent invité QEMU
Point d'attention	17 instantanés internes (124 Go sur l'hôte pour un disque de 60 Go) : à élaguer
Fiches	PV-05, PV-07, PV-08, F-17, F-18, F-19, F-24, F-26

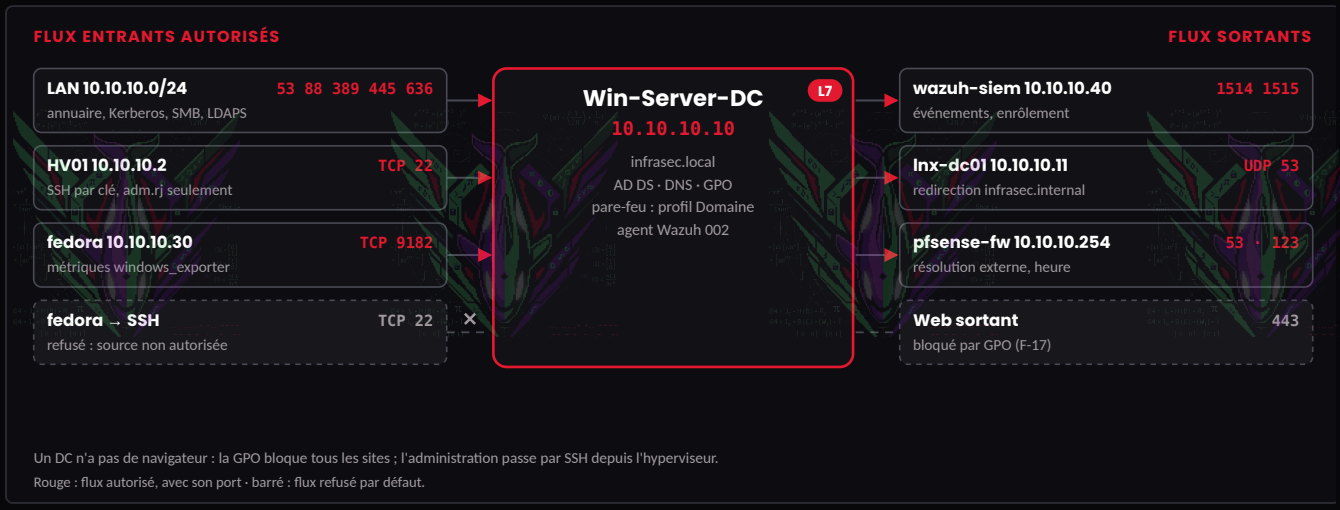


Figure 19 Flux réseau de Win-Server-DC (dc01) : sources autorisées à gauche, destinations à droite.



Figure 20 Organigramme d'un échec d'authentification sur le DC, jusqu'à l'alerte du SIEM (F-24).

Abréviations (figures 19 et 20) — **DC** : contrôleur de domaine (Domain Controller) · **AD DS** : services de domaine Active Directory · **DNS** : résolution des noms (Domain Name System) · **GPO** : stratégie de groupe Windows (Group Policy Object) · **LDAP** : protocole d'accès à l'annuaire (Lightweight Directory Access Protocol) · **SMB** : partage de fichiers Windows (Server Message Block), port 445 · **SSH** : administration à distance chiffrée (Secure Shell), port 22 · **PSO** : politique de mots de passe affinée (Password Settings Object) · **MITRE ATT&CK** : référentiel public des techniques d'attaque ; T1110 force brute, T1547.001 persistance au démarrage, T1562.001 neutralisation des défenses · **FIM** : surveillance de l'intégrité des fichiers (File Integrity Monitoring) · **whodata** : mode FIM de Wazuh qui enregistre aussi l'auteur et le processus · **LAN** : réseau local du labo 10.10.10.0/24 · **L1…L7** : couches du modèle OSI : 1 physique, 2 liaison, 3 réseau, 4 transport, 5 session, 6 présentation, 7 application · **vCPU** : processeur virtuel · **UEFI** : micrologiciel de démarrage · **Gio / Go** : gibioctets (mémoire, 2^{30} octets) / gigaoctets (disque, 10^{9} octets) · **agent invité** : service QEMU dans la VM qui reçoit les ordres de l'hyperviseur (guest agent) · **INC / F** : fiche d'incident / fiche de constat · **PV** : procès-verbal de mise en œuvre ou de recette

C3.4 Contrôleur de continuité lnx-dc01 (Samba AD)

Rôle	contrôleur du domaine de continuité infrasec.internal (NetBIOS INFRALNX)
Système	Debian 13.7 minimale, Samba 4.22 (DNS interne)
Ressources	1,5 Gio, 2 vCPU, disque de 12 Go
Annuaire	même entreprise que dc01 (même employes.csv, 7228c38a…) ; même politique de mots de passe (F-24)
Comptes système	rj avec sudo ; root verrouillé
Temps / DNS	pfSense seulement ; redirection DNS vers pfSense
Filtrage	ufw : SSH depuis l'hôte, annuaire depuis le LAN, NetBIOS fermé (F-25)
Supervision	agent Wazuh 003 (version identique au manager, bloquée)
Fiches	PV-08, F-24, F-25, PROC-01

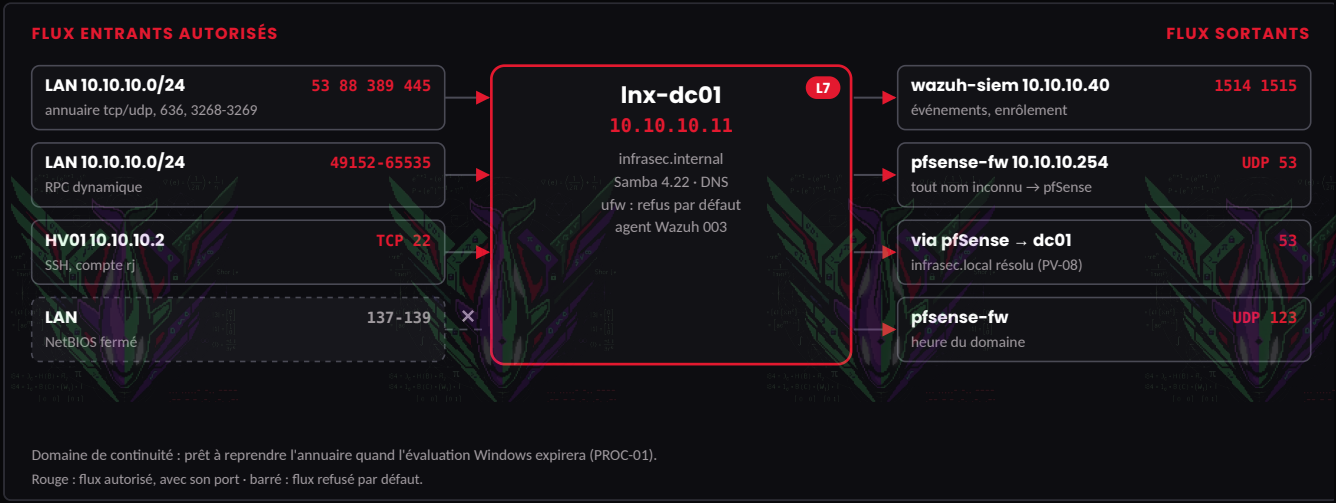


Figure 21 Flux réseau de lnx-dc01 : sources autorisées à gauche, destinations à droite.

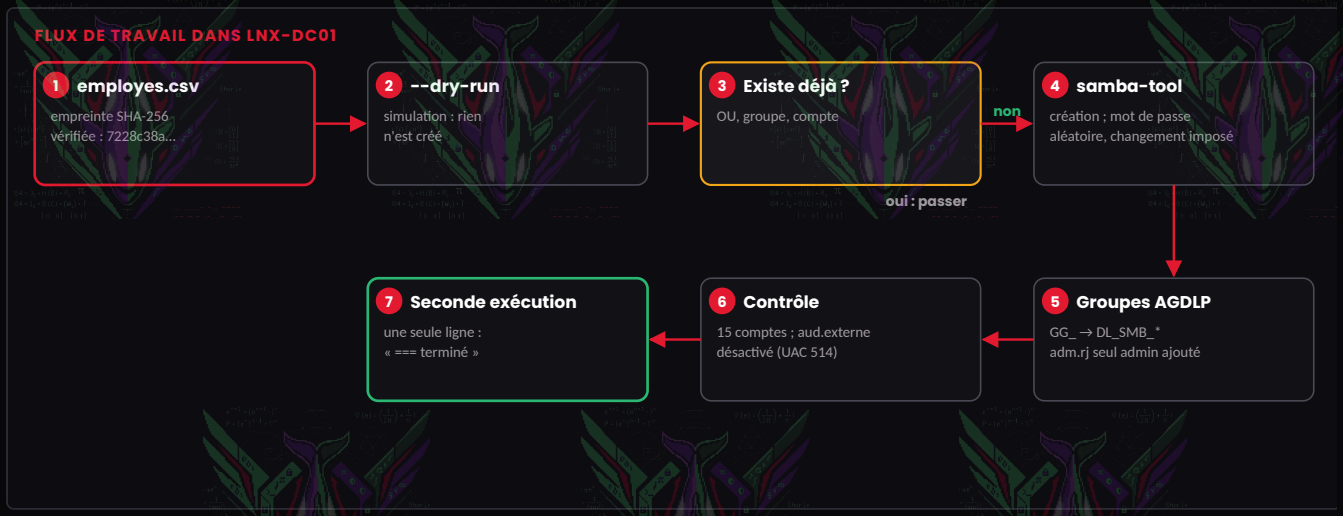


Figure 22 Organigramme du provisionnement idempotent de l'entreprise sur le domaine Samba (PV-08).

Abréviations (figures 21 et 22) — **AD DS** : services de domaine Active Directory · **DNS** : résolution des noms (Domain Name System) · **LDAP** : protocole d'accès à l'annuaire (Lightweight Directory Access Protocol) · **SMB** : partage de fichiers Windows (Server Message Block), port 445 · **RPC** : appel de procédure distante (ports dynamiques 49152-65535) · **ufw** : pare-feu local de Debian et Ubuntu (Uncomplicated Firewall) · **OU** : unité d'organisation de l'annuaire (Organizational Unit) · **AGDLP** : comptes → groupes Globaux → groupes de Domaine Local → Permissions · **GG_** : préfixe des groupes globaux : qui sont les personnes (leur service) · **DL_** : préfixe des groupes de domaine local : ce que le groupe permet sur un partage · **SHA-256** : empreinte cryptographique de 256 bits · **LAN** : réseau local du labo 10.10.10.0/24 · **vCPU** : processeur virtuel · **Gio / Go** : gibioctets (mémoire, 2^{30} octets) / gigaoctets (disque, 10^{9} octets) · **L1…L7** : couches du modèle OSI : 1 physique, 2 liaison, 3 réseau, 4 transport, 5 session, 6 présentation, 7 application · **INC / F** : fiche d'incident / fiche de constat · **PV** : procès-verbal de mise en œuvre ou de recette

C3.5 Stockage truenas

Rôle	stockage des partages de l'entreprise
Système	TrueNAS SCALE 25.10
Ressources	6 Gio ; pool tank en miroir ZFS (2 × 40 Go)
Adresse	10.10.10.20 ; joint au domaine INFRASEC
Partages	tank/entreprise (non partagé) et 5 partages SMB par service, droits AGDLP (PV-05)
Sauvegarde	instantanés ZFS récursifs toutes les heures, 2 semaines ; restauration éprouvée (PV-06)
Traçabilité	audit des accès aux fichiers sur les 6 partages (F-20)
Fiches	PV-05, PV-06, F-20

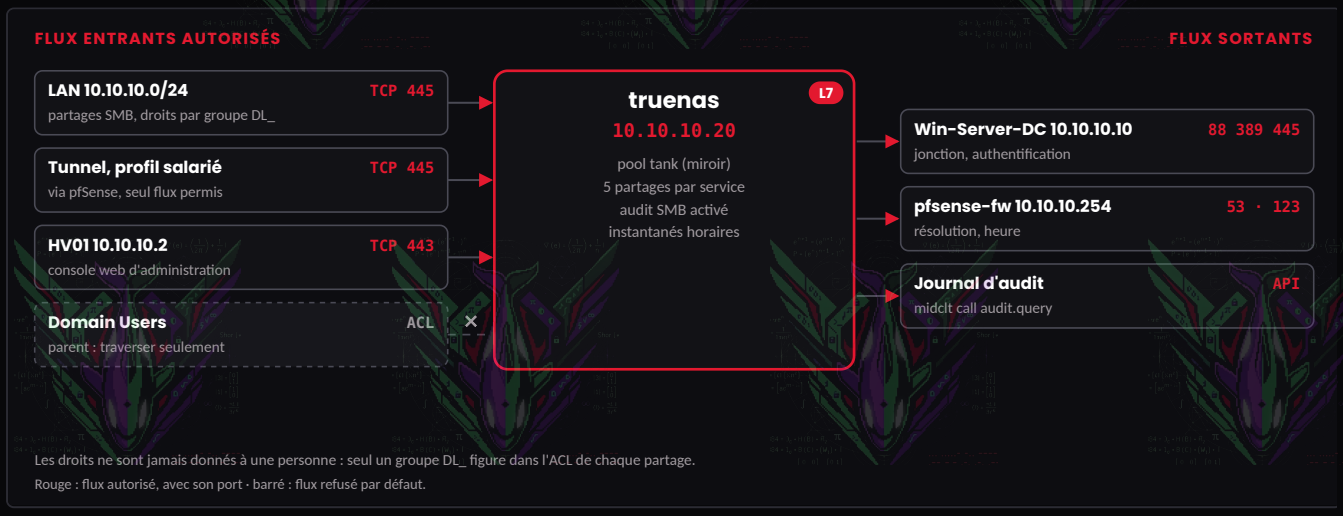


Figure 23 Flux réseau de truenas : sources autorisées à gauche, destinations à droite.

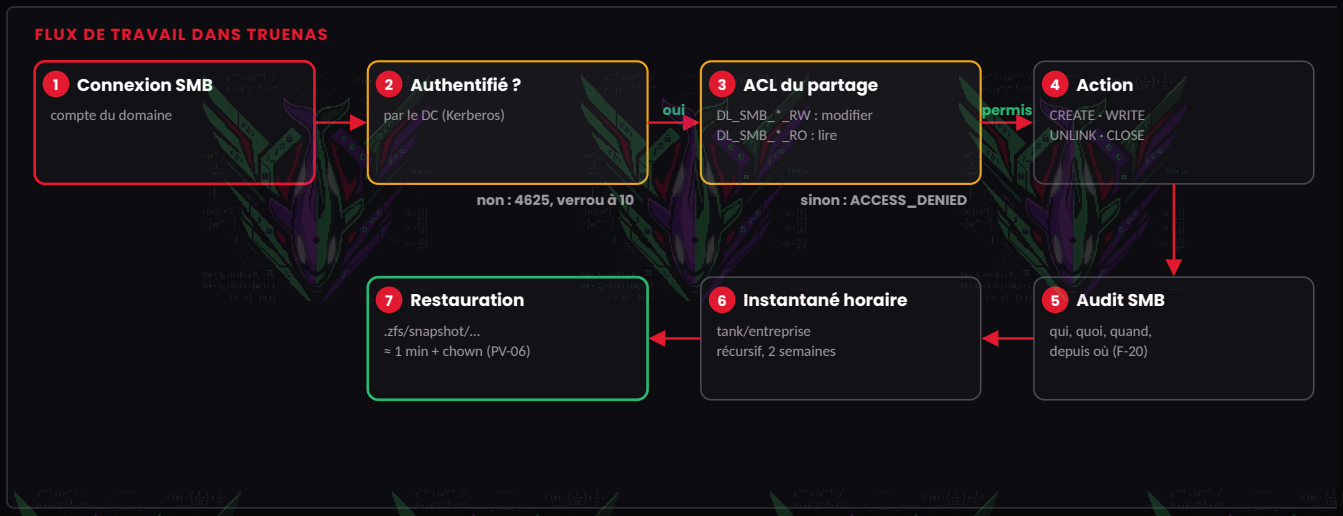


Figure 24 Organigramme d'un accès à un partage : authentification, ACL par groupe, audit, instantané, restauration.

Abréviations (figures 23 et 24) — **SMB** : partage de fichiers Windows (Server Message Block), port 445 · **ZFS** : système de fichiers de TrueNAS, avec miroir et instantanés · **ACL** : liste de contrôle d'accès (Access Control List) · **DL_** : préfixe des groupes de domaine local : ce que le groupe permet sur un partage · **AGDLP** : comptes → groupes Globaux → groupes de Domaine Local → Permissions · **DC** : contrôleur de domaine (Domain Controller) · **API** : interface de programmation (Application Programming Interface) · **LAN** : réseau local du labo 10.10.10.0/24 · **L1…L7** : couches du modèle OSI : 1 physique, 2 liaison, 3 réseau, 4 transport, 5 session, 6 présentation, 7 application · **Gio / Go** : gibioctets (mémoire, 2^{30} octets) / gigaoctets (disque, 10^{9} octets) · **INC / F** : fiche d'incident / fiche de constat · **PV** : procès-verbal de mise en œuvre ou de recette

C3.6 Nœud de supervision fedora

Rôle	supervision (métriques et disponibilité)
Ressources	6 Gio de mémoire
Adresse	10.10.10.30
Services	Podman sans root (compte ais, linger), unités Quadlet : Prometheus 9091, Grafana 3000, node-exporter, Zabbix 8080 (PostgreSQL, secret Podman, étiquette SELinux :Z)
Contrôles	métriques Linux et Windows ; alerte disque > 80 % (F-16) ; ports 55000 et 1514 du SIEM (INC-11) ; SNMP du pare-feu
Supervision	agent Wazuh 001
Fiches	INC-09, INC-11, F-16

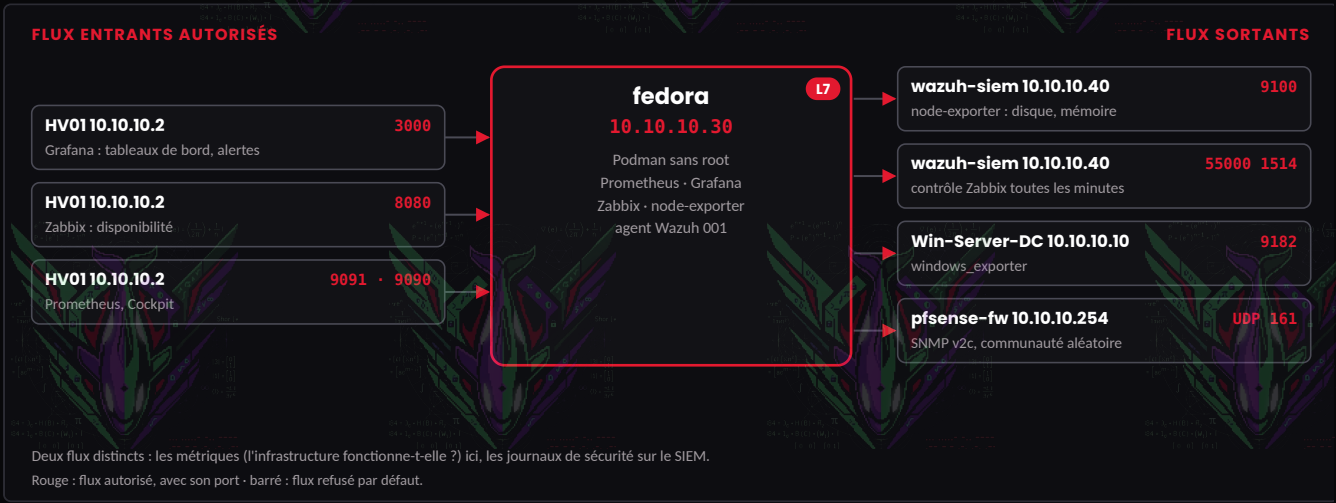


Figure 25 Flux réseau de fedora : sources autorisées à gauche, destinations à droite.

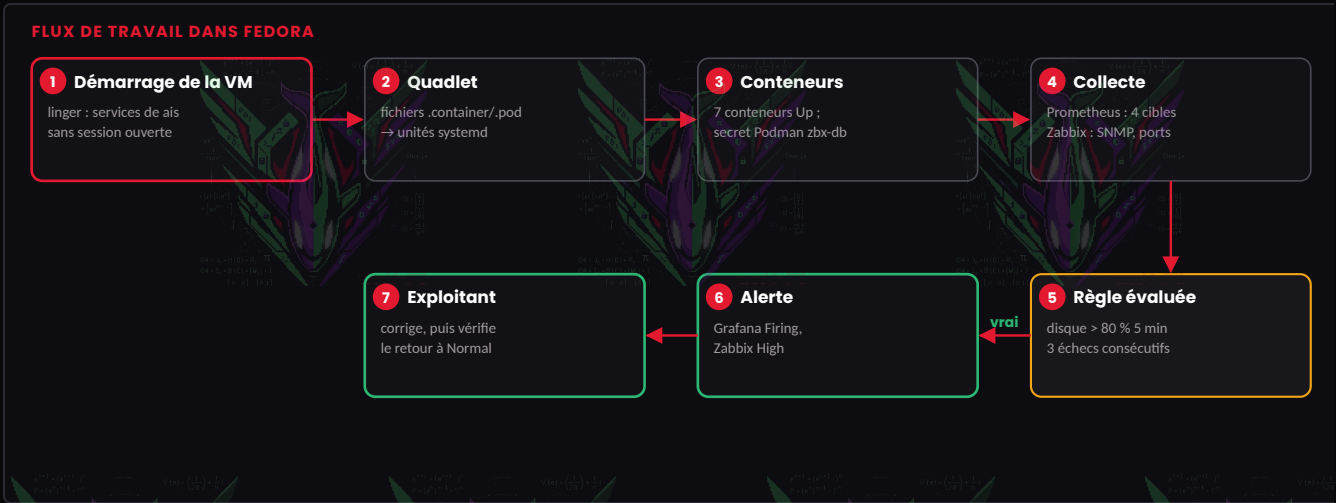


Figure 26 Organigramme du nœud de supervision : services déclarés, collecte, règle, alerte (INC-09, INC-11, F-16).

Abréviations (figures 25 et 26) — **Quadlet** : fichier qui déclare un conteneur Podman comme service systemd · **SNMP** : supervision des équipements réseau (Simple Network Management Protocol), port UDP 161 · **MCO / MCS** : maintien en condition opérationnelle / de sécurité · **SIEM** : collecte et corrélation des journaux de sécurité (Security Information and Event Management) · **API** : interface de programmation (Application Programming Interface) · **L1…L7** : couches du modèle OSI : 1 physique, 2 liaison, 3 réseau, 4 transport, 5 session, 6 présentation, 7 application · **Gio / Go** : gibioctets (mémoire, 2^{30} octets) / gigaoctets (disque, 10^{9} octets) · **INC / F** : fiche d'incident / fiche de constat

C3.7 SIEM wazuh-siem

Rôle	SIEM : collecte, corrélation, alertes
Système	Ubuntu 26.04.1, Wazuh 4.14.8 (manager, indexeur, tableau de bord), horloge en UTC
Ressources	6 Gio, disque de 40 Go (dont 11 Go de base CVE)
Adresse	10.10.10.40
Filtrage (ufw)	22, 443, 9090 depuis l'hôte ; 1514, 1515 depuis le LAN ; 55000, 9100 depuis fedora (F-15)
Règles locales	100100 SSH force brute, 100300 persistance, 100310 agent arrêté, 100320 verrouillage
Journaux	90 jours consultables (ISM), 365 jours scellés SHA-256 (F-21)
Résilience	Restart=on-failure du manager (INC-11) ; supervisé par Zabbix
Fiches	INC-11, F-14, F-15, F-16, F-18, F-19, F-21, F-22, F-24

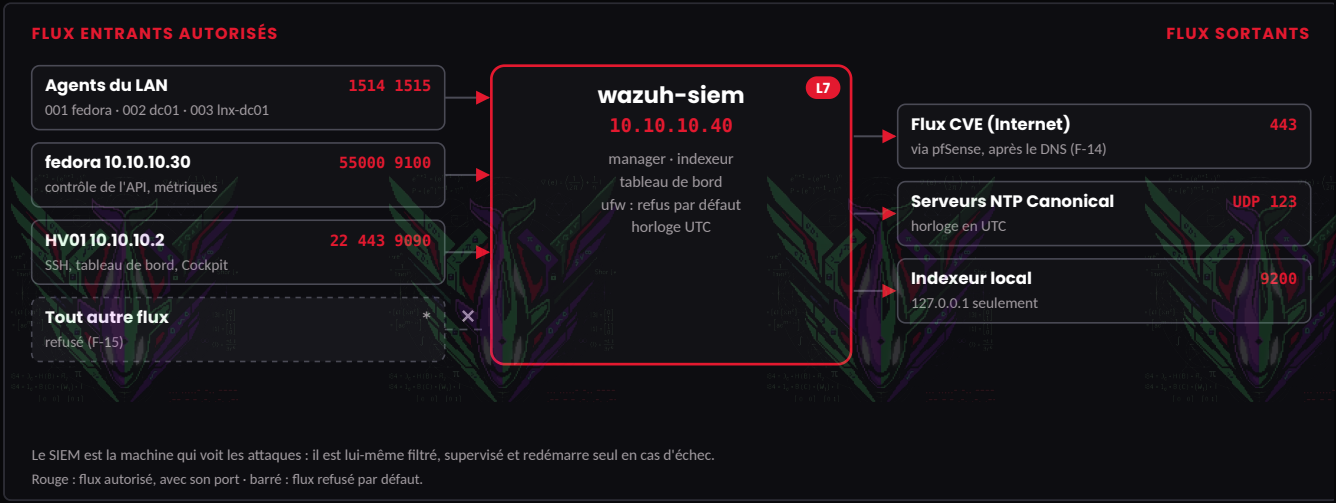


Figure 27 Flux réseau de wazuh-siem : sources autorisées à gauche, destinations à droite.

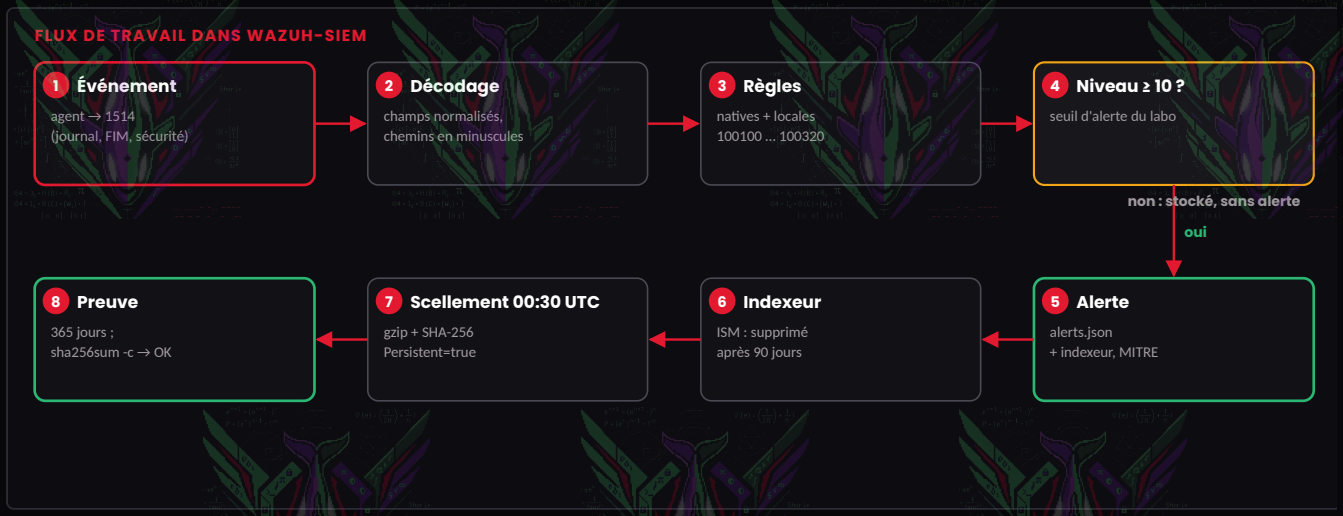


Figure 28 Organigramme du traitement d'un événement par le SIEM, de l'agent au journal scellé (F-19, F-21).

Abréviations (figures 27 et 28) — **SIEM** : collecte et corrélation des journaux de sécurité (Security Information and Event Management) · **FIM** : surveillance de l'intégrité des fichiers (File Integrity Monitoring) · **ISM** : gestion du cycle de vie des index de l'indexeur Wazuh (Index State Management) · **SHA-256** : empreinte cryptographique de 256 bits · **CVE** : identifiant public d'une vulnérabilité (Common Vulnerabilities and Exposures) · **NTP** : synchronisation de l'heure (Network Time Protocol) · **UTC** : temps universel coordonné ; heure de Paris = UTC + 2 h jusqu'au 25/10, + 1 h ensuite · **ufw** : pare-feu local de Debian et Ubuntu (Uncomplicated Firewall) · **MITRE ATT&CK** : référentiel public des techniques d'attaque ; T1110 force brute, T1547.001 persistance au démarrage, T1562.001 neutralisation des défenses · **API** : interface de programmation (Application Programming Interface) · **LAN** : réseau local du labo 10.10.10.0/24 · **L1…L7** : couches du modèle OSI : 1 physique, 2 liaison, 3 réseau, 4 transport, 5 session, 6 présentation, 7 application · **Gio / Go** : gibioctets (mémoire, 2^{30} octets) / gigaoctets (disque, 10^{9} octets) · **INC / F** : fiche d'incident / fiche de constat

C3.8 Client distant wg-client

Rôle	client du tunnel WireGuard (accès distant simulé, recette)
Système	Fedora 44 Cloud Edition
Ressources	1 Gio, 1 vCPU, disque de 10 Go (image de base wg-client-base.qcow2)
Adresse	192.168.122.55 (réseau NAT, côté Internet simulé) ; adresse de tunnel en 10.10.20.0/24
Stockage	/var/lib/libvirt/images, hors de /vm : inclus à part dans lab-backup (PV-09)
Point d'attention	aucun serveur SSH ; ignorait tout signal d'arrêt : arrêt par l'agent invité (F-26)
Fiches	F-26, PV-09

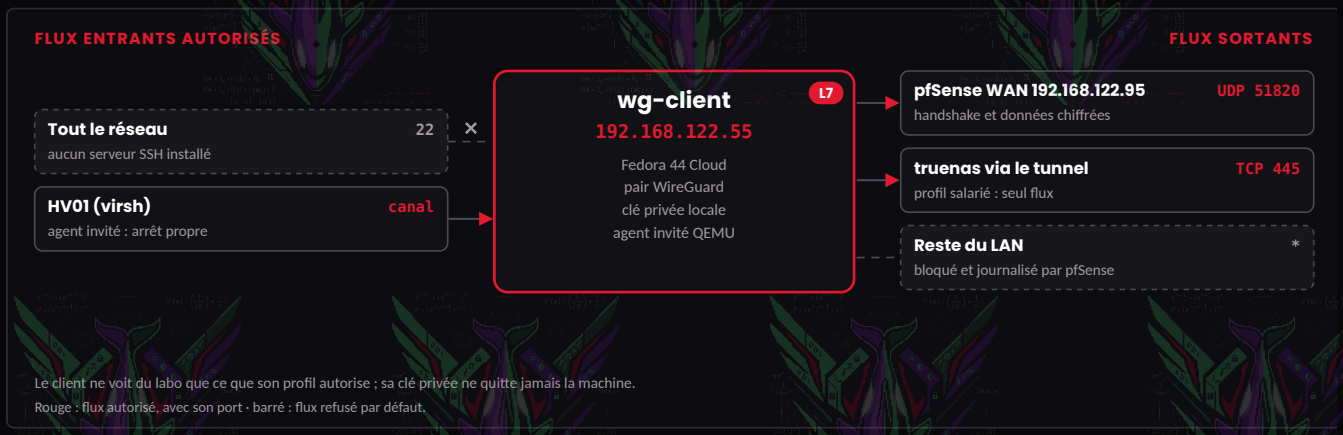


Figure 29 Flux réseau de wg-client : sources autorisées à gauche, destinations à droite.

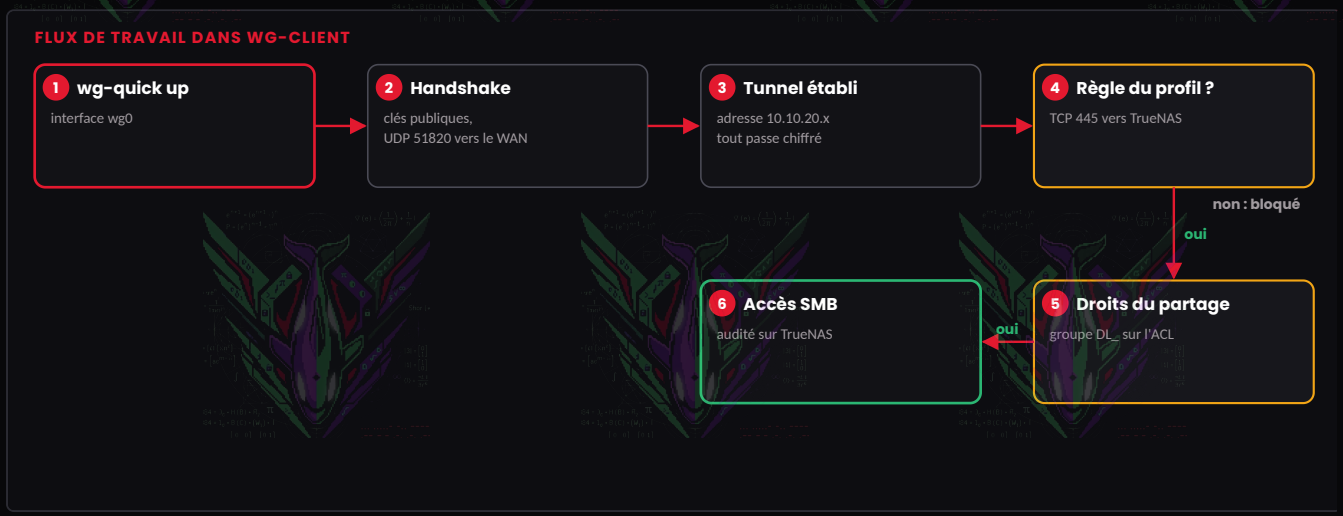


Figure 30 Organigramme de l'accès distant d'un salarié : trois barrières successives.

Abréviations (figures 29 et 30) — **WG** : WireGuard : tunnel VPN chiffré, port UDP 51820 · **WAN** : côté extérieur du pare-feu (réseau NAT 192.168.122.0/24) · **LAN** : réseau local du labo 10.10.10.0/24 · **NAT** : traduction d'adresses (Network Address Translation) · **SMB** : partage de fichiers Windows (Server Message Block), port 445 · **SSH** : administration à distance chiffrée (Secure Shell), port 22 · **ACL** : liste de contrôle d'accès (Access Control List) · **DL_** : préfixe des groupes de domaine local : ce que le groupe permet sur un partage · **vCPU** : processeur virtuel · **agent invité** : service QEMU dans la VM qui reçoit les ordres de l'hyperviseur (guest agent) · **L1…L7** : couches du modèle OSI : 1 physique, 2 liaison, 3 réseau, 4 transport, 5 session, 6 présentation, 7 application · **Gio / Go** : gibioctets (mémoire, 2^{30} octets) / gigaoctets (disque, 10^9 octets) · **INC / F** : fiche d'incident / fiche de constat · **PV** : procès-verbal de mise en œuvre ou de recette

C4

CHAPITRE

L'organisation INFRASEC

Une entreprise fictive de 10 salariés, des droits attribués par groupes, des partages par service, une politique de mots de passe enfin imposée.

AGDLP RBAC PV-05 F-24

C4 · L'organisation INFRASEC

C4.1 L'annuaire

L'entreprise fictive INFRASEC compte 10 salariés répartis en 6 services. Ils sont créés dans l'annuaire `infrasec.local` par le script idempotent `New-InfrasecCompany.ps1`, à partir d'un fichier unique `employes.csv` (PV-05). Le script a d'abord tourné en simulation (`-WhatIf`), après un instantané de la VM ; son empreinte SHA-256 a été vérifiée à l'arrivée sur le contrôleur.

- **14 unités d'organisation et 27 groupes** : 7 `GG_` (6 services et le télétravail), 10 `DL_SMB_<partage>_RW/RO`, 8 `ROLE_` qui reprennent la matrice RBAC de la PSSI ; 10 objets ordinateurs.
- **12 comptes** : les 10 salariés (mots de passe aléatoires de 24 caractères, changement imposé à la première connexion, jamais affichés), `adm.rj` (compte d'administration séparé, seul ajouté aux Admins du domaine) et `aud.externe` (désactivé hors mission d'audit).
- **Séparation des comptes** : le compte de travail `rj` n'a aucun droit d'administration ; `adm.rj` administre ; le compte `Administrator` intégré est réservé au secours et n'est plus joignable par SSH (PV-07).

Le SIEM a reçu les 12 événements Windows 4720 de création de compte, tous en moins de deux secondes. Constat noté : ils arrivent au niveau 8, sous le seuil d'alerte. Une création de comptes en masse reste donc un point à surveiller.

C4.2 Le modèle AGDLP

Les personnes entrent dans un groupe global (`GG_` : qui elles sont), membre d'un groupe de domaine local (`DL_` : ce qu'il permet), seul groupe posé sur l'ACL du partage. Un nouvel arrivant ne demande qu'un ajout de groupe, jamais une modification d'ACL.

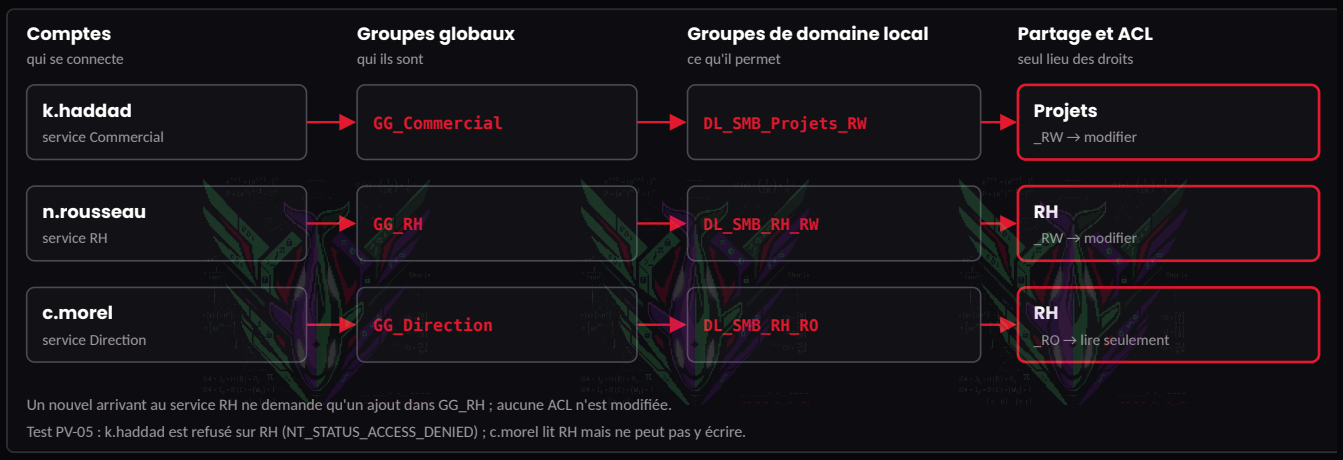


Figure 31 Le modèle AGDLP appliqué aux partages de l'entreprise, avec les comptes du test PV-05.

Abréviations — **AGDLP** : comptes → groupes Globaux → groupes de Domaine Local → Permissions · **GG_** : préfixe des groupes globaux : qui sont les personnes (leur service) · **DL_** : préfixe des groupes de domaine local : ce que le groupe permet sur un partage · **ACL** : liste de contrôle d'accès (Access Control List) · **SMB** : partage de fichiers Windows (Server Message Block), port 445 · **PV** : procès-verbal de mise en œuvre ou de recette

C4.3 Les partages TrueNAS

Le dataset parent `tank/entreprise` n'est pas partagé ; `Domain Users` n'y a que le droit de traverser, sans héritage. Cinq datasets enfants sont partagés en SMB : Commun, Direction, Comptabilite, RH, Projets. Sur chacun, `DL_SMB_<partage>_RW` a le droit de modifier, `DL_SMB_<partage>_RO` de lire, et rien d'autre n'est autorisé.

CONSTAT CORRIGÉ

Le préréglage SMB de TrueNAS donnait `Domain Users` en modification : les 12 comptes du domaine pouvaient écrire partout. Un préréglage n'est pas une politique. L'ACL a été ramenée au moindre privilège, puis prouvée par 6 accès, dont 2 refus attendus (PV-05).

Les partages sont protégés par des instantanés ZFS récursifs toutes les heures, conservés deux semaines. La restauration a été éprouvée du point de vue de l'utilisateur : un fichier supprimé par `k.haddad` est revenu en une minute environ (PV-06). L'audit des accès aux fichiers est activé sur les 6 partages : on sait désormais qui a fait quoi, pas seulement qui s'est connecté (F-20).

◆ C4.4 La politique de mots de passe, imposée par les deux domaines

La PSSI exigeait 14 caractères pour les utilisateurs et 20 pour les comptes à privilèges. Les deux domaines étaient restés aux valeurs par défaut : 7 caractères et aucun verrouillage. Les comptes respectaient la PSSI parce que le script avait généré leurs mots de passe, pas parce que le domaine l'imposait. C'est corrigé depuis le 26/10, de façon identique dans les deux domaines (F-24) :

Réglage	Comptes ordinaires	Administrateurs (`PSO-Admins`)
Longueur minimale	14 caractères	20 caractères
Verrouillage	après 10 échecs, pendant 15 min	après 5 échecs, pendant 30 min
Durée de vie	365 jours	180 jours

Le verrouillage a été prouvé : 11 connexions SMB avec un mot de passe faux donnent 10 échecs puis `NT_STATUS_ACCOUNT_LOCKED_OUT`, et l'événement 4740 nomme la machine d'origine.

CHAPITRE

C5

Journal des incidents et constats

18 fiches en six jours, toutes corrigées et prouvées ; deux points restent ouverts et sont assumés.

INC-08 → INC-11

F-13 → F-26

C5 · Journal des incidents et constats

C5.1 Chronologie

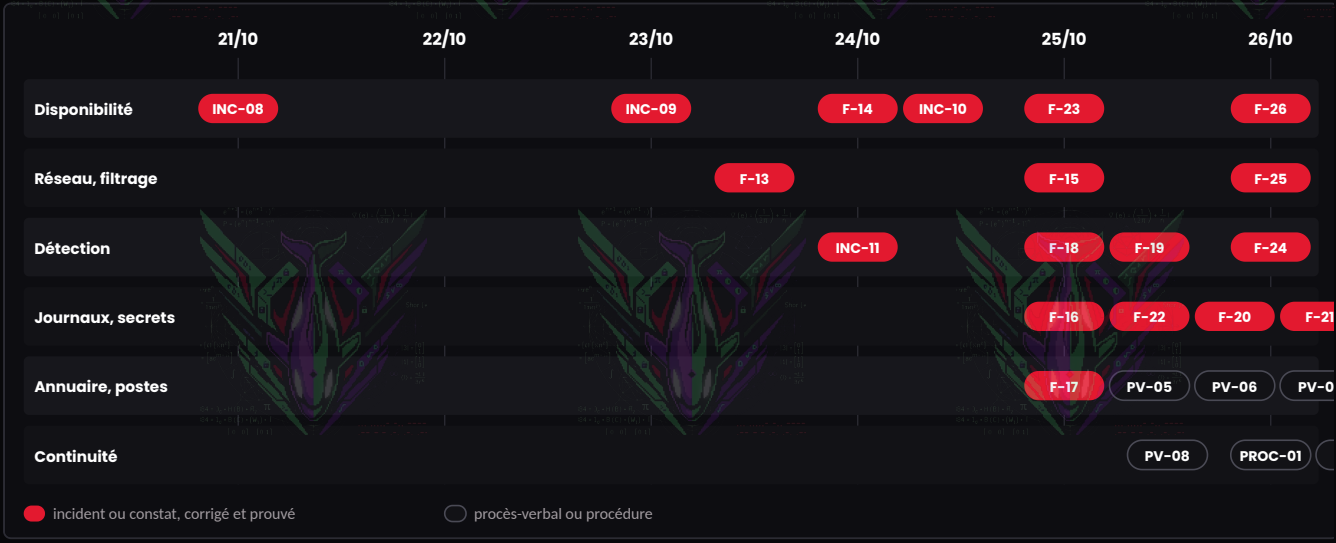


Figure 32 Chronologie des fiches du 21 au 26/10/2026, par domaine.

Abréviations — **INC / F** : fiche d'incident / fiche de constat · **PV** : procès-verbal de mise en œuvre ou de recette

C5.2 Les fiches en un tableau

Fiche	Constat	Gravité	Correction et preuve
INC-08	Cockpit injoignable hors du réseau domestique : service lié à une adresse	moyenne	écoute rétablie, accès filtré par firewalld ; testé sur partage de connexion
INC-09	Pod Zabbix lancé à la main, non relancé au démarrage ; mot de passe en clair	moyenne	unités Quadlet, secret Podman, rotation ; redémarrage complet prouvé
INC-10	L'hôte perd son adresse LAN au premier rechargement réseau	moyenne	adresse déclarée dans NetworkManager ; panne rejouée volontairement
INC-11	SIEM aveugle 3 h 10 sans alerte (manager en échec au démarrage)	élevée	`Restart=on-failure` et contrôle Zabbix ; détection en 2 min 23 s
F-13	L'hôte peut relayer du trafic vers le LAN hors de pfSense	moyenne à élevée	zone firewalld `lab-tenet` sans service ni transfert
F-14	Base CVE du SIEM pas à jour quand le labo démarre dans le désordre	moyenne	script `lab` : démarrage ordonné avec vraie attente DNS
F-15	SIEM sans pare-feu : 7 services ouverts au LAN	moyenne	ufw, une règle par flux légitime ; testé depuis deux machines tierces
F-16	Disque du SIEM non supervisé (et une fausse alerte de croissance)	moyenne	node-exporter, alerte Grafana à 80 % éprouvée
F-17	Navigation web sur le DC avec le compte Administrator intégré	élevée	GPO qui bloque tous les sites ; même test rejoué
F-18	Arrêter l'agent Wazuh du DC ne déclenche aucune alerte	élevée	règle 100310, niveau 10, T1562.001

Fiche	Constat	Gravité	Correction et preuve
F-19	Persistance par le dossier de démarrage détectée sous le seuil	élevée	règle 100300, niveau 12, alerte en 1,6 s
F-20	Audit SMB : connexions seulement, pas les fichiers	moyenne	audit activé sur les 6 partages ; lecture par l'API
F-21	Journaux sans durée de conservation, 9 jours sur 10 jamais scellés	moyenne	ISM 90 jours, scellement SHA-256 quotidien, rattrapage prouvé
F-22	Secrets d'installation du SIEM en clair sur le SIEM	élevée	chiffrés AES-256, déplacés dans le coffre de l'hôte, détruits sur le SIEM
F-23	29 Gio alloués sur 30, swap actif sur l'hyperviseur	moyenne	réduction mesurée de deux VM ; swap 4,0 → 1,4 Gio
F-24	Aucun verrouillage dans les deux domaines, puis verrouillage sans alerte	élevée	politique 14/20 et verrouillage ; règle 100320 prouvée par une attaque lente
F-25	Contrôleur Samba sans aucun pare-feu	moyenne	ufw, NetBIOS fermé ; testé depuis fedora et l'hôte
F-26	Deux VM ignorent la demande d'arrêt de l'hyperviseur	moyenne	agent invité QEMU, `lab` : 7 sur 7 arrêtées en 66 s

C5.3 Les défauts qui reviennent

En relisant les 18 fiches, quatre défauts reviennent. Ce sont eux qui m'ont le plus appris.

1. **Un test qui ne peut pas échouer.** Un contrôle DNS qui acceptait les messages d'erreur (F-14), un test de pare-feu lancé depuis la cible elle-même (F-15, PV-07), un `gpupdate` « réussi » alors que la GPO n'existait pas (F-17), un déchiffrement « sans erreur » qui avait produit un fichier vide (F-22). Règle tirée : avant de croire un test, je vérifie qu'il aurait pu échouer.
2. **Une configuration non déclarée.** Une adresse ajoutée à la main (INC-10), un pod lancé à la main (INC-09). Tout ce qui n'est pas dans l'outil de configuration disparaît au premier rechargement.
3. **Un événement vu mais sous le seuil.** La persistance (niveau 5), l'arrêt de l'agent (niveau 3), le verrouillage (niveau 9), la création de comptes (niveau 8). Voir ne suffit pas : il faut atteindre le niveau qui alerte.
4. **Une machine sans pare-feu ni supervision à son arrivée.** Le SIEM (F-15, F-16), le contrôleur Samba (F-25). Désormais, une machine entre dans le labo avec son pare-feu, son agent et sa supervision.

C6

CHAPITRE

Détection et journaux

Ce que le SIEM voyait sans alerter, ce qu'il alerte maintenant, et comment ses journaux sont conservés et scellés.

MITRE ATT&CK | 100300 → 100320 | F-21

C6 · Détection et journaux

C6.1 Avant et après les règles locales

Trois scénarios d'attaque ont été joués sur le contrôleur de domaine. Dans les trois cas, Wazuh voyait l'événement, mais à un niveau inférieur au seuil d'alerte du labo (10). J'ai écrit une règle locale pour chacun, validée par `wazuh-analysisd -t` avant rechargement, puis rejoué l'attaque.

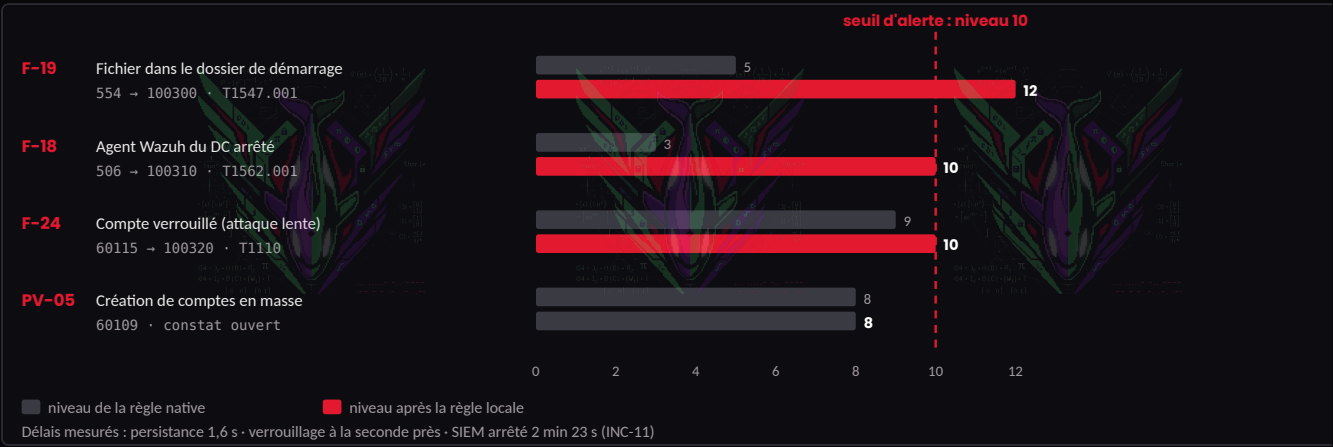


Figure 33 Niveau des alertes avant et après les règles locales : ce qui était vu sans alerter devient une alerte.

Abréviations — **MITRE ATT&CK** : référentiel public des techniques d'attaque ; T1110 force brute, T1547.001 persistance au démarrage, T1562.001 neutralisation des défenses · **DC** : contrôleur de domaine (Domain Controller) · **SIEM** : collecte et corrélation des journaux de sécurité (Security Information and Event Management) · **INC / F** : fiche d'incident / fiche de constat · **PV** : procès-verbal de mise en œuvre ou de recette

Règle	Technique MITRE	Parent	Niveau	Preuve
100300	T1547.001 : persistance par le dossier de démarrage	550, 554	12	`maj.bat` créé à 18:52:00 UTC, alerte à 18:52:01.582
100310	T1562.001 : neutralisation d'un outil de défense	506	10	`sc.exe stop WazuhSvc`, alerte à 18:52:35 UTC
100320	T1110 : force brute, y compris lente	60115	10	10 échecs en 8 min, alerte à 18:49:09.212 UTC sans 60204
100100	T1110 : force brute SSH	(projet)	12	règle du projet, reprise de PV-03

CE QU'IL FAUT RETENIR

Le filtre de chemin de la règle 100300 ignore la casse : Wazuh enregistre les chemins Windows en minuscules, et c'est pour cela que la recherche du tableau de bord ne trouvait rien. Quand l'interface ne montre rien, je lis le journal brut (`grep` dans `alerts.json`).

C6.2 Le SIEM surveillé à son tour

Un SIEM arrêté ne lève aucune alerte : c'est le pire des silences. Après INC-11, le manager redémarre seul en cas d'échec, et Zabbix contrôle chaque minute son API (55000) et la réception des agents (1514), avec une alerte après trois échecs consécutifs. Le disque du SIEM est surveillé par Prometheus, avec une alerte Grafana au-delà de 80 %, avant les seuils de l'indexeur (85 % puis blocage à 95 %).

C6.3 Conservation et scellement des journaux

J'ai mesuré avant de décider : environ 8 Mo d'alertes brutes par jour, 113 Ko une fois compressées, 4,4 Mo par jour dans l'indexeur. La copie consultable est conservée **90 jours** (politique ISM de l'indexeur), la copie brute scellée **365 jours**. Le scellement tourne chaque jour à 00:30 UTC avec `Persistent=true` : comme le labo est éteint la nuit, le minuteur rattrape le jour manqué au démarrage suivant. Le rattrapage a été prouvé le 26/10.

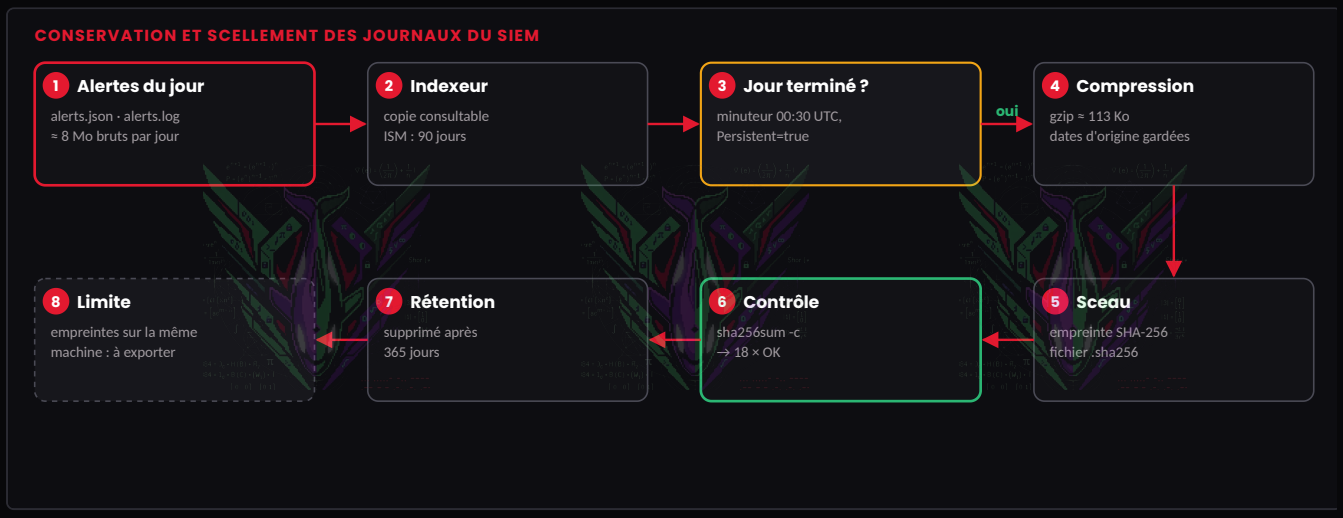


Figure 34 Conservation et scellement des journaux du SIEM, rattrapage compris quand le labo était éteint (F-21).

Abréviations — **ISM** : gestion du cycle de vie des index de l'indexeur Wazuh (Index State Management) · **SHA-256** : empreinte cryptographique de 256 bits · **UTC** : temps universel coordonné ; heure de Paris = UTC + 2 h jusqu'au 25/10, + 1 h ensuite · **SIEM** : collecte et corrélation des journaux de sécurité (Security Information and Event Management) · **Gio / Go** : gibioctets (mémoire, 2^{30} octets) / gigaoctets (disque, 10^{9} octets)

CHAPITRE

C7

Continuité et sauvegarde

Un second domaine prêt à reprendre l'annuaire, une procédure de migration, une sauvegarde immuable du labo.

PV-08 PROC-01 PV-09

C7 · Continuité et sauvegarde

C7.1 Pourquoi un second domaine

Le contrôleur Windows tourne sur une version d'évaluation, qui expire vers le 27/03/2027. À cette date, l'annuaire s'arrêterait : plus d'authentification, plus de partages. J'ai donc monté un domaine de continuité, `infrasec.internal`, sur un contrôleur Samba 4.22 sous Debian 13 (`lnx-dc01`), avec la même entreprise et la même politique.

C7.2 Ce qui est en place (PV-08)

- **La même entreprise** : le script bash `infrasec-samba-societe.sh` rejoue le **même** `employes.csv` (même empreinte, `7228c38a…`). Simulation d'abord, puis exécution ; une seconde exécution ne recrée rien (idempotence prouvée).
- **La même surveillance** : agent Wazuh 003, de la même version que le manager, bloquée contre les mises à jour.
- **Le même filtrage** : ufw, une règle par flux légitime, NetBIOS fermé (F-25).
- **La résolution croisée** entre les deux domaines :

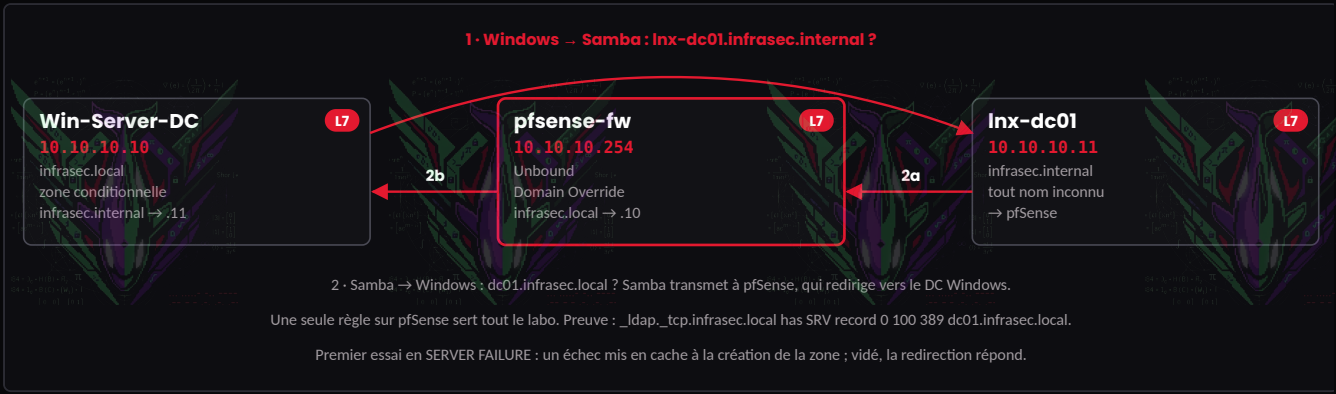


Figure 35 Résolution DNS croisée entre les deux domaines (PV-08).

Abréviations — **DNS** : résolution des noms (Domain Name System) · **DC** : contrôleur de domaine (Domain Controller) · **LDAP** : protocole d'accès à l'annuaire (Lightweight Directory Access Protocol) · **L1…L7** : couches du modèle OSI : 1 physique, 2 liaison, 3 réseau, 4 transport, 5 session, 6 présentation, 7 application · **PV** : procès-verbal de mise en œuvre ou de recette

C7.3 La migration, écrite avant d'en avoir besoin (PROC-01)

La procédure fixe les étapes, de J-30 à J+30, avec un registre des risques et un retour arrière possible jusqu'à J+30. Son critère de réussite est mesurable : les 6 cas de test de PV-05 donnent le résultat attendu sur le nouveau domaine, et une connexion échouée y produit l'alerte Wazuh correspondante.

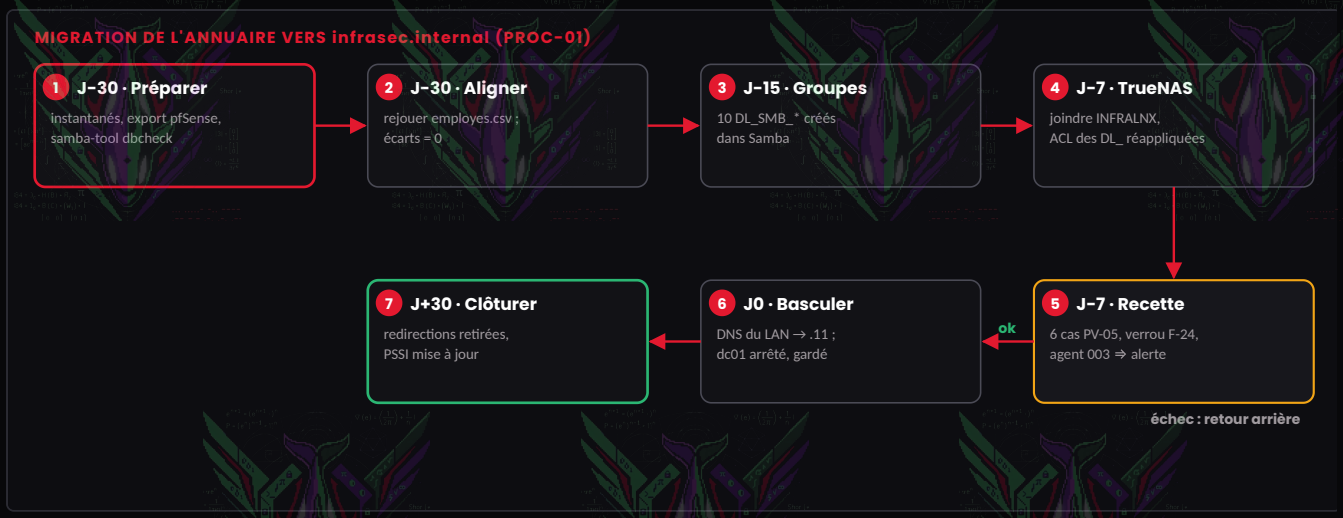


Figure 36 Procédure de migration de l'annuaire, avec son point de retour arrière (PROC-01).

Abréviations — **DL_** : préfixe des groupes de domaine local : ce que le groupe permet sur un partage · **ACL** : liste de contrôle d'accès (Access Control List) · **DNS** : résolution des noms (Domain Name System) · **PV** : procès-verbal de mise en œuvre ou de recette · **INC / F** : fiche d'incident / fiche de constat

◆ C7.4 La sauvegarde du labo (PV-09)

Aucune sauvegarde complète du labo n'existait en dehors des instantanés internes des VM. Faute de disque externe, j'ai écarté le repartitionnement du disque de l'hôte : réduire une partition chiffrée est l'opération la plus risquée possible sur ce disque. J'ai construit à la place un niveau local **immuable**, avec le sous-volume BTRFS `/vm` existant.

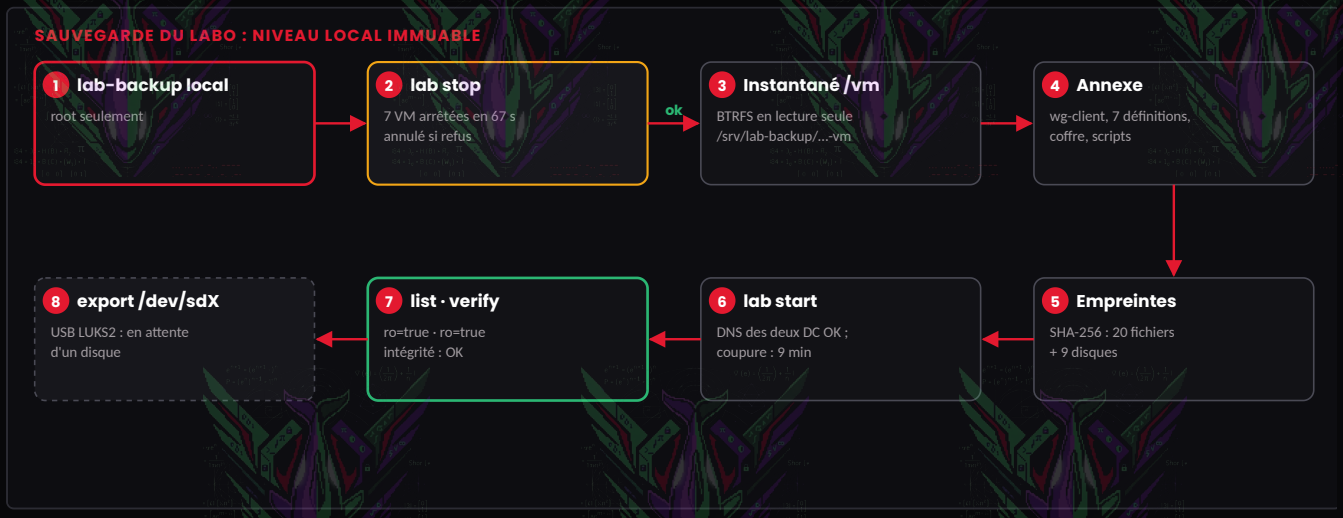


Figure 37 Le script lab-backup : arrêt propre, instantané en lecture seule, empreintes, redémarrage (PV-09).

Abréviations — **BTRFS** : système de fichiers à instantanés (B-tree file system) · **SHA-256** : empreinte cryptographique de 256 bits · **LUKS** : chiffrement complet du disque sous Linux (Linux Unified Key Setup) · **VM** : machine virtuelle · **DNS** : résolution des noms (Domain Name System) · **DC** : contrôleur de domaine (Domain Controller) · **PV** : procès-verbal de mise en œuvre ou de recette

L'inventaire préalable a évité deux pièges : `wg-client` était rangé hors de `/vm` et dépendait d'une image de base, et `/vm/iso` contenait 55 Go d'images inutiles, supprimées une par une après vérification. Après la sauvegarde, `lab-backup list` montre les deux parties en lecture seule, `lab-backup verify` recalcule toutes les empreintes, et une écriture par root est refusée (`Read-only file system`).

LIMITE ASSUMÉE

Ce niveau protège contre la fausse manipulation, la corruption et un rançongiciel. Il ne protège pas contre la panne ou le vol du disque de l'hôte. La commande `lab-backup export /dev/sdX` est prête : elle copiera la dernière sauvegarde sur un disque USB chiffré LUKS2 dès qu'il sera disponible.

C8

CHAPITRE

Bilan, limites et suite

Ce qui est fait, ce qui reste ouvert, et ce que ces six jours m'ont appris.

Bilan

C8 · Bilan, limites et suite

C8.1 Bilan

Domaine	Avant le 21/10	Au 26/10
Détection	règles natives, plusieurs attaques vues sous le seuil	4 règles locales prouvées, SIEM lui-même supervisé
Journaux	aucune durée de conservation, sceaux manquants	90 jours consultables, 365 jours scellés, rattrapage prouvé
Filtrage	SIEM et contrôleur Samba ouverts au LAN	une règle par flux légitime, testée depuis des machines tierces
Annuaire	politique par défaut, aucun verrouillage	14/20 caractères, verrouillage, alerte sur verrouillage
Continuité	un seul annuaire, en évaluation	second domaine prêt, procédure de migration écrite
Sauvegarde	instantanés internes des VM seulement	sauvegarde complète, en lecture seule, vérifiée
Exploitation	démarrage et arrêt à la main	script `lab` : ordonné, tracé, 7 machines arrêtées sur 7

C8.2 Travaux restants

- **Copie externe de la sauvegarde** : la commande `lab-backup export` est prête, il manque le disque USB.
- **Empreintes des journaux hors du SIEM** : root sur le SIEM pourrait modifier à la fois les journaux et leurs sceaux.
- **Élaguer les instantanés internes du contrôleur Windows** : 17 instantanés occupent 124 Go sur l'hôte pour un disque de 60 Go.
- **pfSense** : remplacer ISC DHCP, en fin de vie, par Kea.
- **Création de comptes en masse** : remonter l'événement 4720 groupé au-dessus du seuil d'alerte.
- **Réseau d'administration séparé** (mesure M-01) : l'hôte a encore une adresse dans le LAN qu'il administre.

C8.3 Ce que j'en retiens

Je retiens trois habitudes. Je prouve une correction en rejouant le test qui avait révélé le défaut, depuis une machine tierce. Je lis les journaux bruts quand l'interface ne montre rien, et je lis ceux du bon démarrage. Et je dis toujours précisément contre quoi une mesure protège, et contre quoi elle ne protège pas : c'est ce qui permet de concilier sécurité et disponibilité au lieu de les opposer.

CHAPITRE

C9

Glossaire

Toutes les abréviations du dossier, expliquées une par une.

CERT G/V OSI

C9 · Glossaire

Abréviation	Signification
ACL	liste de contrôle d'accès (Access Control List)
ACPI	signal d'alimentation simulé envoyé par l'hyperviseur (Advanced Configuration and Power Interface)
AD DS	services de domaine Active Directory
AES	chiffrement symétrique standard (Advanced Encryption Standard)
AGDLP	comptes → groupes Globaux → groupes de Domaine Local → Permissions
agent invité	service QEMU dans la VM qui reçoit les ordres de l'hyperviseur (guest agent)
API	interface de programmation (Application Programming Interface)
BTRFS	système de fichiers à instantanés (B-tree file system)
CAPEX	dépenses d'investissement : coût de mise en œuvre
CERT	centre de réponse aux incidents de sécurité (Computer Emergency Response Team) ; en France, le CERT-FR de l'ANSSI
CP7…CP10	compétences professionnelles du référentiel AIS
CVE	identifiant public d'une vulnérabilité (Common Vulnerabilities and Exposures)
DC	contrôleur de domaine (Domain Controller)
DL_	préfixe des groupes de domaine local : ce que le groupe permet sur un partage
DNS	résolution des noms (Domain Name System)
EBIOS RM	méthode d'analyse de risques de l'ANSSI (EBIOS Risk Manager)
FIM	surveillance de l'intégrité des fichiers (File Integrity Monitoring)
G / V	gravité / vraisemblance : les deux axes de la cartographie des risques EBIOS RM (de 1 à 4)
GG_	préfixe des groupes globaux : qui sont les personnes (leur service)
Gio / Go	gibioctets (mémoire, 2^{30} octets) / gigaoctets (disque, 10^{9} octets)
GPO	stratégie de groupe Windows (Group Policy Object)
HTTPS	web chiffré par TLS
HV01	hyperviseur du labo, nom d'hôte TeneT
INC / F	fiche d'incident / fiche de constat
ISM	gestion du cycle de vie des index de l'indexeur Wazuh (Index State Management)
KVM	hyperviseur intégré au noyau Linux (Kernel-based Virtual Machine)
L1…L7	couches du modèle OSI : 1 physique, 2 liaison, 3 réseau, 4 transport, 5 session, 6 présentation, 7 application
LAN	réseau local du labo 10.10.10.0/24
LDAP	protocole d'accès à l'annuaire (Lightweight Directory Access Protocol)
LUKS	chiffrement complet du disque sous Linux (Linux Unified Key Setup)

Abréviation	Signification
MCO / MCS	maintien en condition opérationnelle / de sécurité
MITRE ATT&CK	référentiel public des techniques d'attaque ; T1110 force brute, T1547.001 persistance au démarrage, T1562.001 neutralisation des défenses
NAT	traduction d'adresses (Network Address Translation)
NTP	synchronisation de l'heure (Network Time Protocol)
OPEX	dépenses d'exploitation cumulées
OSI	modèle de référence en 7 couches (Open Systems Interconnection)
OU	unité d'organisation de l'annuaire (Organizational Unit)
PSO	politique de mots de passe affinée (Password Settings Object)
PV	procès-verbal de mise en œuvre ou de recette
Quadlet	fichier qui déclare un conteneur Podman comme service systemd
RAM	mémoire vive
RBAC	contrôle d'accès fondé sur les rôles (Role-Based Access Control)
RPC	appel de procédure distante (ports dynamiques 49152-65535)
SHA-256	empreinte cryptographique de 256 bits
SIEM	collecte et corrélation des journaux de sécurité (Security Information and Event Management)
SMB	partage de fichiers Windows (Server Message Block), port 445
SNMP	supervision des équipements réseau (Simple Network Management Protocol), port UDP 161
SO-1...SO-4	scénarios opérationnels de l'analyse EBIOS RM
SSH	administration à distance chiffrée (Secure Shell), port 22
TCO	coût total de possession (Total Cost of Ownership)
TCP / UDP	protocoles de transport, avec ou sans connexion
TLS	chiffrement des échanges (Transport Layer Security)
UEFI	micrologiciel de démarrage
ufw	pare-feu local de Debian et Ubuntu (Uncomplicated Firewall)
UTC	temps universel coordonné ; heure de Paris = UTC + 2 h jusqu'au 25/10, + 1 h ensuite
vCPU	processeur virtuel
VM	machine virtuelle
WAN	côté extérieur du pare-feu (réseau NAT 192.168.122.0/24)
Wazuh	SIEM libre : agents, manager, indexeur, tableau de bord
WG	WireGuard : tunnel VPN chiffré, port UDP 51820
whodata	mode FIM de Wazuh qui enregistre aussi l'auteur et le processus
ZFS	système de fichiers de TrueNAS, avec miroir et instantanés
ZTNA	accès réseau Zero-Trust (Zero Trust Network Access)

ANNEXES

Annexes A à O

Les documents complets du projet, en français. L'annexe M (manuel d'exploitation) est bilingue.

Preuves

Guide des annexes

Les annexes sont des documents formels : elles gardent leur ton d'origine. Les termes techniques y sont en anglais, comme dans le reste du dossier, sauf dans le glossaire (annexe L), qui donne le terme français et son équivalent anglais. Les annexes P à R, ajoutées en octobre, regroupent les fiches CCP3 complètes, les scripts d'exploitation et le registre d'intégrité actualisé.

Annexe	Document	Contents (English)
A	Lettre de mission d'audit	Audit engagement letter: scope, rules of engagement, compliance criteria
B	Rapport d'audit de sécurité (PV-02)	Security audit report: nmap, Lynis, Wazuh SCA, 11 findings
C	Évaluation de conformité du rapport d'audit	Assessment of the audit report against the engagement letter
D	Analyse de risques EBIOS Risk Manager	EBIOS RM risk analysis: five workshops, twelve treatment measures
E	Politique de sécurité des systèmes d'information (PSSI)	Information security policy in twelve articles
F	Rapport de gel et de hardening	Freeze and hardening report: Lynis 69 → 76
G	Procès-verbal de sauvegarde et de restauration (PV-01)	Backup and restore test report: RTO < 1 s, 0 errors
H	Support de sensibilisation et action de formation courte	45-minute security awareness session and how its effect is measured
I	Procès-verbal de détection d'incident et RETEX (PV-03)	Simulated SSH brute-force attack, detection and lessons learned
J	Journal des incidents techniques et de sécurité	Incident log, INC-01 to INC-07
K	Dispositif de veille en cybersécurité	Threat watch process and local detection rule 100100
L	Glossaire et fiches de définitions	Glossary and definition sheets
M	Manuel d'exploitation bilingue (Operations manual)	Operations manual, in French then in English
N	Schéma réseau de référence et couches OSI	Reference network diagram, flow matrix and OSI layers
O	Procès-verbal de recette et de supervision (PV-04)	Acceptance test of Oct 11: remote access, restore, SNMP, alerting, rule 100100

Annexe A · Lettre de mission d'audit

Projet : Hybrid InfraSec — infrastructure Zero-Trust de la société INFRASEC

Référence : LM-AUDIT-2026-01

Date d'émission : 01/10/2026

Commanditaire : Direction des systèmes d'information (DSI), INFRASEC

Destinataire : équipe d'audit mandatée (audit interne réalisé sous la responsabilité de l'administrateur d'infrastructures sécurisées ; le présent cadre s'applique à l'identique à un prestataire tiers)

Rédacteur / référent technique : admin (administrateur d'infrastructures sécurisées)

1. Contexte INFRASEC exploite une infrastructure cible segmentée en Zero-Trust (point de passage unique pfSense, domaine Active Directory `infrasec.local`, stockage TrueNAS, nœud containers, SIEM Wazuh). Avant la mise en production d'une évolution d'accès distant (VPN WireGuard) et dans le cadre du maintien en condition de sécurité (MCS), la Direction souhaite faire établir un état des lieux objectif du niveau de sécurité du périmètre.

La présente lettre de mission définit le mandat, le périmètre, la méthode attendue, les règles d'engagement et les livrables de cet audit. Elle sert également de référentiel d'évaluation du rapport d'audit produit.

2. Objet et objectifs Évaluer le niveau de sécurité de l'infrastructure INFRASEC et fournir un rapport exploitable permettant de décider des mesures de traitement. Objectifs :

- identifier les vulnérabilités et les expositions des composants du périmètre ;
- caractériser les risques et menaces associés (criticité) ;
- mesurer l'écart par rapport aux bonnes pratiques (ANSSI, CIS) ;
- formuler des recommandations de remédiation priorisées ;
- alimenter l'analyse de risque (EBIOS Risk Manager) et la PSSI.

3. Périmètre

Dans le périmètre :

Composant	Adresse	Nature du contrôle
pfSense (firewall / passerelle)	`10.10.10.254`	exposition, règles de filtrage, interface d'administration
Win-Server-DC (AD DS / DNS)	`10.10.10.10`	services exposés, hardening, politique de comptes
TrueNAS (stockage / SMB)	`10.10.10.20`	services exposés, partages, jonction AD
fedora (nœud containers)	`10.10.10.30`	hardening système, SSH, containers rootless
wazuh-siem (SIEM)	`10.10.10.40`	exposition, configuration
Segment	`10.10.10.0/24`	cartographie d'exposition, cloisonnement

Hors périmètre : l'hôte de virtualisation physique, le réseau domestique amont, les postes clients, les services de cloud public simulés. Toute extension du périmètre fait l'objet d'un avenant écrit.

4. Cadre réglementaire et référentiels L'audit prend en compte :

- les recommandations de l'**ANSSI** (guides d'hygiène et de hardening) ;
- le **RGPD** pour la protection des données à caractère personnel (périmètre de traitement) ;

- une méthode de gestion des risques de type **EBIOS Risk Manager / ISO 27005** ;
- les référentiels de configuration **CIS** (via l'outil Lynis) ;
- le référentiel **MITRE ATT&CK** pour la qualification des menaces.

5. Méthodologie attendue

Phase	Méthode / outil	Résultat attendu
Reconnaissance /exposition	balayage réseau (nmap)	cartographie des services ouverts par hôte
Conformité système	audit de hardening (Lynis)	indice de hardening + écarts CIS par hôte
Conformité de configuration	Wazuh SCA (Security Configuration Assessment)	écarts par agent
Analyse de risque	EBIOS Risk Manager	scénarios, criticité, socle de sécurité
Qualification des menaces	MITRE ATT&CK	rattachement des constats aux techniques
Tests complémentaires	scan de vulnérabilités dédié (OpenVAS/GVM) depuis un poste d'audit de type Kali ou Parrot ; tentative d'authentification contrôlée	vulnérabilités référencées (CVE) par service ; validation de la détection

6. Règles d'engagement

- **Fenêtre d'intervention** autorisée : sur la maquette, hors contrainte de production.
- **Autorisation explicite** du commanditaire pour les tests actifs (balayage, tentative d'authentification contrôlée).
- **Caractère non destructif** : aucune altération volontaire des données ; aucune interruption de service non planifiée.
- **Aucune exfiltration** de données réelles ; travail sur données de laboratoire.
- **Point de contact** unique : le référent technique, joignable pendant toute la fenêtre.
- **Confidentialité** : les constats sont traités comme sensibles et ne sont pas diffusés hors du périmètre convenu.

7. Livrables attendus 1. **Rapport d'audit** présentant les points de contrôle, les mesures effectuées et l'évaluation du niveau de sécurité.

2. **Liste des vulnérabilités** identifiées, cotées par sévérité, avec recommandation de remédiation et phase de traitement.

3. **Caractérisation des risques et menaces** associés (rattachement MITRE ATT&CK le cas échéant).

4. **Registre d'intégrité (SHA-256)** des livrables produits.

Le rapport doit être **clair, structuré et exploitable** par une personne n'ayant pas réalisé l'audit.

8. Critères d'évaluation du travail Le rapport d'audit sera jugé conforme s'il :

- couvre l'intégralité du périmètre défini au §3 ;
- applique la méthodologie du §5 ;
- identifie les vulnérabilités et caractérise les risques (§2) ;
- fournit des recommandations priorisées et actionnables ;
- respecte les règles d'engagement du §6 ;
- respecte la politique de diffusion du §9.

9. Confidentialité et diffusion Les livrables ne contiennent **aucune adresse IP publique, adresse MAC réelle, secret d'authentification ni donnée à caractère personnel**. Le plan d'adressage relève des plages privées **RFC 1918** (`10.10.10.0/24`). Les documents sont scellés par empreinte **SHA-256**.

10. Planning

Jalon	Date
Émission de la lettre de mission	01/10/2026
Réalisation de l'audit	04/10/2026
Remise du rapport d'audit (PV-02)	04/10/2026
Évaluation de conformité du rapport	04/10/2026

11. Validation

Rôle	Nom	Date	Visa
Commanditaire (DSI INFRASEC)	*(fictif — dossier pédagogique)*	01/10/2026	—
Référent technique	admin	01/10/2026	—

Lettre de mission d'audit — Project Hybrid InfraSec · société fictive INFRASEC · dossier AIS (CCP3 / CP8).

Annexe B · Rapport d'audit de sécurité (PV-02)

Projet : Hybrid InfraSec — laboratoire Zero-Trust

Périmètre : segment `10.10.10.0/24`, chokepoint pfSense, 5 actifs (pfSense, DC, TrueNAS, fedora, Wazuh) + hyperviseur

Date de l'audit : 04/10/2026

Auditeur : admin

Poste d'audit : nœud `fedora` (10.10.10.30) — poste d'administration/audit. *En production, un poste dédié durci (Parrot/Kali) assurerait la séparation des rôles.*

1. Méthodologie Audit en trois couches complémentaires :

1. **Cartographie d'exposition réseau** — scan de services et d'OS (`nmap -sS -sV -O`) sur l'ensemble du segment.

2. **Hardening système** — audit CIS des hôtes Linux (`Lynis 3.1.7`).

3. **Conformité de configuration** — Security Configuration Assessment (SCA) natif de Wazuh, déjà actif sur les agents Windows (DC) et Linux (fedora).

Outils : `nmap 7.92`, `Lynis 3.1.7`, Wazuh 4.14 (module SCA).

2. Couche 1 — Cartographie d'exposition (nmap) 6 hôtes actifs détectés. Surface d'exposition par actif :

Actif	IP	Ports/services ouverts	Commentaire
pfSense (fw01)	.254	53 (DNS Unbound), **80 (HTTP nginx)**, 443 (HTTPS nginx)	Interface d'admin accessible en **clair sur :80**
Contrôleur de domaine	.10	53, 88, 135, 139, 389, 445, 464, 593, 636, 3268, 3269 (AD DS), **3389 (RDP)**	Services AD attendus ; **RDP ouvert à tout le segment**
TrueNAS	.20	80, 443 (UI), 139/445 (SMB 4.6.2), 5357 (WS-Discovery)	UI web et WSD exposés
fedora	.30	22 (SSH), 3000 (Grafana), 9090 (Cockpit), 9091 (Prometheus), 9100 (node-exporter)	Pile de supervision ; 9100 sans authentification
Wazuh	.40	22, 443 (dashboard), 9090 (Cockpit)	Conforme au besoin
Hyperviseur (TeneT)	.2	tous filtrés	**Adresse d'administration de l'hyperviseur présente sur le segment de production**

Points positifs relevés :

- Sur chaque hôte, l'essentiel des 1 000 ports testés est filtré : le balayage, lancé depuis le segment, ne traverse pas pfSense ; ce filtrage provient donc des firewalls locaux des hôtes. pfSense n'expose lui-même que la résolution DNS et ses interfaces d'administration (dont HTTP :80, constat F-02).
- Aucun service hérité ou non chiffré dangereux (pas de Telnet, FTP, SMBv1).
- TLS disponible sur les interfaces d'administration (443, Cockpit 9090, Grafana, dashboard Wazuh), à l'exception de l'écoute HTTP :80 de pfSense (F-02).

3. Couche 2 — Hardening système (Lynis / fedora)

- **Indice de hardening : 69/100** (253 tests exécutés)

- **Avertissements : 0**
- **Suggestions : 20** (axes d'amélioration, aucun défaut critique)

Principales suggestions :

- **SSH (SSH-7408)** : `AllowTcpForwarding` → NO, `ClientAliveCountMax` → 2, `LogLevel` → VERBOSE.
- **Politique de mots de passe (AUTH-9230/9286)** : définir `PASS_MIN_DAYS`, `PASS_MAX_DAYS`, rounds de hachage dans `/etc/login.defs`.
- **umask (AUTH-9328)** : passer la valeur par défaut à `027`.
- **Protocoles réseau inutiles (NETW-3200)** : désactiver `dccp`, `sctp`, `rds`, `tipc`.
- **Pilotes de stockage amovible (USB-1000, STRG-1846)** : désactiver USB/FireWire storage si non nécessaires.
- **Mises à jour automatiques (PKGS-7420)** : activer `dnf-automatic`.
- **Cloisonnement disque (FILE-6310)** : partitions séparées pour `/home` et `/var`.

4. Couche 3 — Conformité de configuration (Wazuh SCA) Le module **Security Configuration Assessment** de Wazuh évalue en continu les agents contre des référentiels CIS :

- **DC01 (Windows Server 2025)** — benchmark CIS Microsoft Windows Server.
- **fedora (Linux)** — benchmark CIS Distribution Independent Linux.

Preuve : dashboard Wazuh → module « Configuration Assessment » (captures d'écran conservées hors ligne par l'auditeur). Avantage : couverture Windows là où Lynis ne s'applique pas.

5. Synthèse des constats et plan de remédiation

ID	Constat	Gravité	Remédiation	Phase
F-01	IP d'administration del'hyperviseur (.2) présente sur le segment de production (mélange plan d'admin / plan de données)	**Élevée**	Retirer l'IP temporaire `10.10.10.2` (service systemd)	Freeze
F-02	Admin pfSense accessible en clair sur HTTP :80	**Moyenne**	Forcer HTTPS, désactiver l'écoute :80, restreindre la source de gestion	Freeze
F-03	RDP (3389) ouvert à tout le segment sur le DC	**Moyenne-Élevée**	Restreindre la source (règle firewall) au poste d'admin, imposer NLA	Freeze
F-04	WS-Discovery (5357) exposé sur TrueNAS	Faible	Désactiver WSD si non requis	Freeze
F-05	node-exporter (9100) sans authentification	Faible	Restreindre :9100 à l'hôte Prometheus via firewall local	Freeze
F-06	Plan d'administration (SSH 22, Cockpit 9090) joignable depuis tout le segment	Moyenne	Restreindre l'accès admin à un poste/segment dédié (principe Zero-Trust)	Hardening
F-07	Hardening SSH perfectible (forwarding, timeout, verbosité)	Faible	Appliquer les recommandations SSH-7408	Hardening
F-08	Politique de mots de passe et umask par défaut	Faible	Configurer `/etc/login.defs`, umask 027	Hardening
F-09	Protocoles réseau inutiles chargeables (dccp, sctp, rds, tipc)	Faible	Blacklister via modprobe	Hardening
F-10	Pilotes de stockage amovible actifs	Faible	Blacklister USB/FireWire storage	Hardening

ID	Constat	Gravité	Remédiation	Phase
F-11	Pas de mise à jour automatique	Faible	Activer `dnf-automatic` / `unattended-upgrades`	Hardening

6. Mesures de sécurité déjà en place (points forts)

- **Chokepoint unique** pfSense avec filtrage par défaut (deny) entre zones ; à l'intérieur du segment, le filtrage repose sur les firewalls locaux des hôtes.
- **Supervision** : SIEM Wazuh (événements + SCA + FIM) avec agents sur le contrôleur de domaine et le nœud fedora, et métriques Prometheus/Grafana sur ces deux hôtes.
- **Containers rootless** (Podman) sur le nœud fedora — pas de démon root, surface réduite.
- **Sauvegarde conçue en 3-2-1-0**, restauration vérifiée (PV-01) — snapshots ZFS + réplication + contrôle SHA-256.
- **Chiffrement en transit** (TLS) sur les interfaces d'administration, hors écoute HTTP :80 de pfSense (F-02).
- **Intégration AD** avec ACL NFSv4 sur le partage de fichiers (contrôle d'accès centralisé).

7. Conclusion Le laboratoire présente une **posture de sécurité saine** (indice de hardening 69/100, aucun service hérité dangereux, firewall effectif, supervision complète). Les constats relevés sont majoritairement de gravité faible à moyenne et relèvent du hardening incrémental ; les trois constats prioritaires ont fait l'objet d'une décision lors de la phase de gel : F-01 accepté temporairement avec mesure compensatoire, F-02 et F-03 planifiés (voir le rapport de gel). L'analyse de risque associée est développée dans le document EBIOS Risk Manager, et les mesures organisationnelles dans la PSSI.

Annexes : sortie `nmap` complète (`/tmp/nmap-infrasec_20261004.txt`), rapport Lynis (`/var/log/lynis-report.dat`), captures Wazuh SCA.

Annexe C · Évaluation de conformité du rapport d'audit

Projet : Hybrid InfraSec — société INFRASEC

Référence : EVAL-AUDIT-2026-01

Date : 04/10/2026

Évaluateur : admin (administrateur d'infrastructures sécurisées)

Document évalué : `PV-02 — Audit de sécurité` (rapport d'audit produit)

Référentiel d'évaluation : `LM-AUDIT-2026-01` (lettre de mission)

Objet — Vérifier que le rapport d'audit (PV-02) répond à l'ensemble des exigences fixées par la lettre de mission, conformément au critère de performance CP8 (« la conformité du rapport d'audit à la lettre de mission est évaluée correctement »).

1. Grille de conformité Légende : ✅ conforme · 🟡 partiellement conforme · ❌ non conforme

#	Exigence (lettre de mission)	Couverture dans le rapport d'audit (PV-02)	Verdict
§3	**Périmètre complet** (5 composants + segment)	Cartographie nmap des six hôtes (cinq composants et l'hôte d'administration) + segment `10.10.10.0/24`	✅
§5	**Reconnaissance / exposition** (nmap)	Cartographie des services ouverts par hôte	✅
§5	**Conformité système** (Lynis)	Indice de hardening fedora (69/100) + écarts	✅
§5	**Conformité de configuration** (Wazuh SCA)	Résultats SCA par agent	✅
§5	**Analyse de risque** (EBIOS RM)	Traitée dans le livrable dédié `EBIOS-RM`, réutilisant les constats F-01..F-11	✅
§5	**Qualification MITRE ATT&CK**	Appliquée au scénario d'incident (PV-03) ; rattachement du vecteur F-01	✅
§2 /§7	**Vulnérabilités identifiées et cotées**	Constats **F-01 à F-11**, cotés par sévérité	✅
§2	**Risques et menaces caractérisés**	Criticité par constat + reprise dans EBIOS RM	✅
§7	**Recommandations priorisées et actionnables**	Remédiation + phase de traitement par constat	✅
§7	**Registre d'intégrité SHA-256**	`Registre-Integrite-SHA256` couvrant les livrables	✅
§7	**Rapport clair, structuré, exploitable**	Structure par hôte + tableau de constats	✅
§6	**Règles d'engagement** (non destructif, autorisation, pas d'exfiltration)	Respectées — audit interne contrôlé, aucune altération	✅
§9	**Diffusion** (RFC 1918, aucun secret)	Respectée — plan `10.10.10.0/24`, aucun secret réel	✅
§5	**Tests complémentaires** (scan de vulnérabilités dédié, poste d'audit type Kali/Parrot)	Partiel — balayage + test de force brute contrôlé (PV-03) ; scan de vulnérabilités dédié (OpenVAS) non réalisé (VM d'audit abandonnée pour cause technique ; écart tracé dans la présente évaluation)	🟡



2. Écart identifié Un seul écart partiel : la lettre de mission évoque les outils d'audit de type distribution Kali. Le scanner de vulnérabilités dédié (OpenVAS) n'a pas pu être mis en œuvre — la machine d'audit préfabriquée n'a pas démarré. La couverture a été assurée autrement : balayage nmap pour l'exposition, Lynis pour le hardening, Wazuh SCA pour la configuration, et test de force brute contrôlé pour la détection (PV-03). L'objectif de la lettre de mission — identifier et coter les vulnérabilités — est atteint ; seule la méthode d'un des outils diffère.

Traitement : l'ajout d'un scan OpenVAS/GVM est consigné comme amélioration pour un prochain cycle d'audit. Il ne remet pas en cause les constats établis.

3. Verdict global Le rapport d'audit (PV-02) est jugé **conforme** à la lettre de mission `LM-AUDIT-2026-01`. L'intégralité des exigences de périmètre, de méthode, de livrables, de règles d'engagement et de diffusion est satisfaite. L'unique écart (outil de scan de vulnérabilités dédié) est partiel, justifié, sans impact sur la validité des constats, et fait l'objet d'une action d'amélioration tracée.

Évaluation de conformité — Project Hybrid InfraSec · dossier AIS (CCP3 / CP8). Boucle lettre de mission → audit → évaluation complète.

Annexe D · Analyse de risques EBIOS Risk Manager

Laboratoire de certification AIS « Hybrid InfraSec » — Architecture Zero-Trust

Objet	Appréciation des risques numériques selon la méthode EBIOS Risk Manager (ANSSI, édition 2018)
Périmètre	Laboratoire DevSecOps / CloudSec « Hybrid InfraSec »
Nature du livrable	Document formel d'évaluation de la sécurité — soutenance devant jury
Date	4 octobre 2026
Auteur	admin — administrateur d'infrastructures sécurisées (rôle d'analyste sécurité)
Référentiels	EBIOS RM (ANSSI), MITRE ATT&CK, Guide d'hygiène informatique ANSSI, ISO/IEC 27005
Documents d'entrée réutilisés	PV-01 (validation sauvegarde / RTO), PV-02 (audit de configuration — constats F-01 à F-11)

Avertissement de confidentialité — Le présent document décrit un environnement de laboratoire isolé. Aucune adresse IP publique, aucun secret d'authentification réel ni donnée à caractère personnel ne figure dans ce livrable. Les adresses mentionnées appartiennent au plan d'adressage privé RFC 1918 du laboratoire.

Synthèse à l'intention du jury (executive summary) Le laboratoire « Hybrid InfraSec » met en œuvre une infrastructure hybride de virtualisation (KVM/libvirt sur Fedora 44) organisée autour d'un **point de passage unique** — le firewall pfSense — selon une logique **Zero-Trust**. Il héberge un cœur de confiance Active Directory (`infrasec.local`), un stockage ZFS (TrueNAS), un nœud de containers **Podman rootless** supervisé par Prometheus/Grafana, et un SIEM Wazuh 4.14 assurant la détection (SCA, FIM, corrélation).

L'appréciation EBIOS RM conduite ci-après identifie **quatre valeurs métier** (service d'annuaire et d'authentification, intégrité/disponibilité des données stockées, chaîne de supervision et de détection, continuité d'activité) et **six biens supports**. Les événements redoutés les plus graves (gravité **G4 — Critique**) sont la **compromission de la forêt Active Directory** et le **chiffrement malveillant (rançongiciel) des partages SMB**.

Les constats d'audit PV-02 (F-01 à F-11) sont exploités comme **vulnérabilités avérées** nourrissant les scénarios opérationnels. Les deux vulnérabilités structurantes sont la **présence du plan d'administration de l'hyperviseur sur le segment de production** (F-01) et l'**exposition de RDP à l'ensemble du segment** (F-03), qui ouvrent des chemins d'attaque à forte vraisemblance.

Le plan de traitement (atelier 5) s'appuie sur les mesures **déjà en place** (Wazuh, pfSense, sauvegarde 3-2-1-0 avec RTO < 1 s, containers rootless) et sur la remédiation priorisée des constats PV-02. Une fois le plan appliqué, **aucun risque ne demeure en zone critique** (cible ; à date, le hardening est appliqué en partie et le cloisonnement M-01 à M-04 est planifié) ; les risques résiduels sont jugés acceptables sous réserve du suivi des mesures de l'échéancier court terme.

Atelier 1 — Cadrage et socle de sécurité

1.1 Objectif de l'atelier Définir le cadre de l'étude, identifier les valeurs métier et les biens supports, formaliser les événements redoutés associés avec leur gravité, puis évaluer l'écart entre le socle de sécurité attendu et l'état réel de l'environnement.

1.2 Périmètre métier et technique

Périmètre métier Le laboratoire « Hybrid InfraSec » a pour finalité de **démontrer la maîtrise d'une architecture Zero-Trust durcie** combinant services d'infrastructure d'entreprise (annuaire, fichiers), chaîne DevSecOps conteneurisée et supervision de sécurité. La « mission » du système consiste à fournir et à prouver :

- un service d'authentification et d'autorisation centralisé (Active Directory, RBAC) ;
- un service de stockage de fichiers résilient et sauvegardé ;
- une chaîne d'observabilité et de détection d'incidents (métriques + SIEM) ;
- la continuité d'activité (sauvegarde 3-2-1-0, RTO maîtrisé).

Périmètre technique Infrastructure virtualisée mono-segment avec chokepoint unique.

Composant	Rôle	Adresse	Détails techniques
TeneT (hôte)	Hyperviseur	— (administration)	Fedora 44, Cockpit, KVM/libvirt
pfSense	Firewall /chokepoint	`10.10.10.254`	Passerelle, DNS, DHCP — point de passage unique
Win-Server-DC	Contrôleur de domaine	`10.10.10.10`	AD DS, forêt `infrasec.local`, DNS, RBAC (OU/groupes)
TrueNAS	Stockage	`10.10.10.20`	ZFS miroir, partage SMB « partage » joint au domaine, ACL NFSv4
fedora	Nœud containers	`10.10.10.30`	Podman **rootless** : node-exporter, Prometheus, Grafana
wazuh-siem	SIEM	`10.10.10.40`	Wazuh 4.14 all-in-one, agents sur DC et fedora, SCA/FIM/détection

Segment réseau unique : `10.10.10.0/24`. Toute communication inter-zones transite théoriquement par pfSense (`.254`).

Hypothèses retenues : environnement de laboratoire non exposé à Internet pour les services internes ; accès d'administration réputé effectué depuis un poste d'opérateur ; absence de données réelles de production (données fictives de démonstration).

1.3 Valeurs métier

Réf.	Valeur métier	Nature	Description
VM-1	Service d'annuaire et d'authentification	Processus	Capacité à authentifier et autoriser (AD DS, Kerberos, RBAC). Socle de confiance de toute l'architecture.
VM-2	Intégrité et disponibilité des données stockées	Information	Fichiers du partage SMB « partage », jeux de données, configurations. Doivent rester disponibles, intègres et confidentiels.
VM-3	Chaîne de supervision et de détection	Processus	Collecte de métriques (Prometheus/Grafana) et détection d'incidents (Wazuh : SCA, FIM, corrélation). Garantit la visibilité.
VM-4	Continuité d'activité	Processus	Capacité à restaurer un état sain (sauvegarde 3-2-1-0, RTO < 1 s validé PV-01).

1.4 Biens supports Chaque bien support est rattaché aux valeurs métier qu'il porte.

Réf.	Bien support	VM portées	Composant / périmètre
BS-1	Contrôleur de domaine	VM-1	`Win-Server-DC` (AD DS, DNS, Kerberos, base NTDS)



Réf.	Bien support	VM portées	Composant / périmètre
BS-2	Stockage ZFS et partages	VM-2, VM-4	`TrueNAS` (pool ZFS miroir, SMB, snapshots, réplication)
BS-3	Nœud de containers	VM-3	`fedora` (Podman rootless, node-exporter, Prometheus, Grafana)
BS-4	SIEM	VM-3	`wazuh-siem` (indexeur, manager, agents DC/fedora)
BS-5	Firewall / chokepoint	VM-1 à VM-4	`pfSense` (filtrage, DNS, DHCP, passerelle)
BS-6	Hyperviseur	VM-1 à VM-4	`TeneT` (Fedora 44, KVM/libvirt, Cockpit) — bien support transverse de plus haute criticité

Note d'architecture — BS-6 (hyperviseur) est un bien support **transverse** : sa compromission entraîne la compromission de tous les biens supports virtualisés. BS-5 (pfSense) est le bien support **de cloisonnement** : sa compromission neutralise le modèle Zero-Trust.

1.5 Échelle de gravité

Niveau	Libellé	Critère (impact sur les valeurs métier du laboratoire)
G1	Mineure	Gêne ponctuelle, service dégradé, pas de perte de données, récupération immédiate.
G2	Significative	Indisponibilité partielle, perte de visibilité de supervision, remédiation courte.
G3	Grave	Indisponibilité prolongée d'un service clé, atteinte à l'intégrité partielle des données, perte de confiance dans la détection.
G4	Critique	Compromission du cœur de confiance (AD) ou perte/chiffrement des données ; remise en cause de la mission du laboratoire.

1.6 Événements redoutés

Réf.	Événement redouté	Valeur métier	Bien support	Impact	Gravité
ER-1	Compromission / prise de contrôle de la forêt AD `infrasec.local` (élévation jusqu'à Domain Admin)	VM-1	BS-1	Perte totale de confiance del'authentification ; pivot vers tout le domaine	**G4**
ER-2	Chiffrement malveillant (rançongiciel) ou destruction des données du partage SMB	VM-2, VM-4	BS-2	Indisponibilité et perte d'intégrité des données ; interruption de service	**G4**
ER-3	Prise de contrôle de l'hyperviseur TeneT (évasion / rebond d'administration)	VM-1 à VM-4	BS-6	Compromission de toutes les VMs ; effondrement du cloisonnement	**G4**
ER-4	Neutralisation ou aveuglement de la chaîne de supervision (arrêt Wazuh/agents, effacement de traces)	VM-3	BS-4, BS-3	Perte de détection ; attaque non vue ; impossibilité de réponse	**G3**
ER-5	Contournement du cloisonnement via le firewall pfSense (prise de main sur le chokepoint)	VM-1 à VM-4	BS-5	Perte du modèle Zero-Trust ; libre circulation latérale	**G3**
ER-6	Exfiltration de données sensibles (fichiers, secrets de configuration, hachés d'identifiants)	VM-2	BS-1, BS-2	Atteinte à la confidentialité ; réutilisation hors périmètre	**G3**

Réf.	Événement redouté	Valeur métier	Bien support	Impact	Gravité
ER-7	Altération / indisponibilité de la chaîne de métriques (Prometheus/Grafana)	VM-3	BS-3	Perte de visibilité opérationnelle ; décisions sur données faussées	G2

1.7 Socle de sécurité et écarts Le socle de sécurité attendu est fondé sur le **Guide d'hygiène informatique de l'ANSSI** et les principes Zero-Trust annoncés par le laboratoire. L'audit PV-02 (indice de hardening **Lynis 69/100**) révèle les écarts suivants, réutilisés comme **vulnérabilités** dans les ateliers 3 et 4.

Réf. constat	Écart au socle	Règle d'hygiène / principe visé	Niveau
F-01	IP d'administration de l'hyperviseur présente sur le segment de production	Séparation des réseaux d'administration (plan d'admin dédié)	**Élevée**
F-02	Administration pfSense en clair sur HTTP :80	Chiffrement des flux d'administration (TLS partout)	Moyenne
F-03	RDP (3389) ouvert à tout le segment sur le DC	Restriction des accès d'administration, moindre exposition	**Moyenne-Élevée**
F-04	WS-Discovery exposé (TrueNAS)	Réduction de la surface d'attaque (protocoles inutiles)	Faible
F-05	node-exporter :9100 sans authentification	Authentification des services exposés	Faible
F-06	Plan d'administration (SSH, Cockpit) joignable depuis tout le segment	Cloisonnement du plan d'administration	Moyenne
F-07	Hardening SSH insuffisant	Configuration SSH durcie	Faible
F-08	Politique de mots de passe perfectible	Gestion robuste des authentifiants	Faible
F-09	Protocoles inutiles actifs	Désactivation des services superflus	Faible
F-10	Pilotes de stockage amovible actifs (USB /FireWire)	Réduction de la surface d'attaque physique	Faible
F-11	Absence de mises à jour automatiques	Maintien en condition de sécurité (MCS)	Faible

Conclusion atelier 1 — L'architecture présente un socle cohérent (chokepoint, RBAC, sauvegarde, SIEM) mais **trois écarts structurants** (F-01, F-03, F-06) affaiblissent le modèle Zero-Trust affiché : le plan d'administration n'est pas cloisonné et des accès sensibles (hyperviseur, RDP) sont exposés à l'ensemble du segment.

Atelier 2 — Sources de risque et objectifs visés

2.1 Objectif de l'atelier Identifier les couples **Source de Risque (SR) / Objectif Visé (OV)** pertinents vis-à-vis des valeurs métier, puis les évaluer afin de retenir les plus prioritaires pour la suite de l'étude.

2.2 Critères d'évaluation

- **Motivation** : intérêt de la SR à atteindre l'OV (faible / moyenne / forte).
- **Ressources** : capacités techniques, financières, humaines (limitées / moyennes / fortes).
- **Activité / pertinence** : plausibilité au regard du périmètre du laboratoire.

Chaque couple reçoit une **pertinence** globale : *Peu pertinent* / *Pertinent* / *Très pertinent*.

2.3 Couples SR/OV identifiés et évalués

Réf.	Source de risque	Objectif visé	Motivation	Ressources	Pertinence	Retenu
SR-1	Cybercriminel organisé (opérateur de rançongiciel)	Gain financier par chiffrement / extorsion (ER-2)	Forte	Fortes	**Très pertinent**	✅
SR-2	Attaquant opportuniste /script-kiddie	Compromission facile d'un service exposé, défiguration, rebond (ER-4, ER-7)	Moyenne	Limitées	**Pertinent**	✅
SR-3	Employé / opérateur malveillant ou négligent (menace interne)	Abus de privilèges, exfiltration, sabotage (ER-6, ER-1)	Moyenne	Moyennes (accès légitime)	**Pertinent**	✅
SR-4	Acteur étatique / APT	Espionnage, persistance longue, exfiltration ciblée (ER-1, ER-6)	Faible (labo sans valeur stratégique)	Fortes	**Peu pertinent** (conservé comme référence de robustesse)	⚠️
SR-5	Prestataire / chaîne d'approvisionnement (image container, paquet)	Introduction de code malveillant via dépendance (ER-3, ER-4)	Moyenne	Moyennes	**Pertinent**	✅

2.4 Justification de la sélection

- **SR-1 (cybercriminel/rançongiciel)** : menace dominante actuelle ; cible directement les partages SMB et l'AD. **Priorité maximale.**
- **SR-2 (script-kiddie)** : les services exposés sans authentification (F-05 node-exporter, F-04 WS- Discovery, F-02 HTTP en clair) constituent des cibles de faible effort. Pertinent au regard des vulnérabilités avérées.
- **SR-3 (interne)** : un opérateur disposant d'accès légitimes (RDP ouvert à tout le segment, SSH/Cockpit joignables) peut abuser de ses droits. Pertinent.
- **SR-4 (APT)** : conservé comme **étalon de robustesse** mais écarté comme scénario prioritaire (le laboratoire n'a pas de valeur d'espionnage). Il n'est pas instancié en scénario opérationnel.
- **SR-5 (supply chain)** : la chaîne DevSecOps (images de containers) introduit une dépendance externe. Pertinent et moderne.

Couples retenus pour les ateliers 3 et 4 : SR-1, SR-2, SR-3, SR-5.

Atelier 3 — Scénarios stratégiques

3.1 Objectif de l'atelier Cartographier l'écosystème et les parties prenantes, tracer les **chemins d'attaque stratégiques** (vision macroscopique SR → cible), et confirmer la gravité des scénarios.

3.2 Cartographie de l'écosystème et des parties prenantes Le laboratoire étant un environnement interne quasi autonome, l'écosystème est resserré. Les parties prenantes (PP) sont évaluées selon leur **niveau de menace** (dépendance × pénétration × maturité cyber × confiance), échelle simple de 1 (faible) à 4 (fort).

Partie prenante	Type	Dépendance	Pénétration	Maturité cyber	Niveau de menace	Position
Opérateur / administrateur	Interne	Forte (4)	Forte (4)	Moyenne (2)	**Élevé**	Zone de contrôle — à surveiller (menace interne)

Partie prenante	Type	Dépendance	Pénétration	Maturité cyber	Niveau de menace	Position
Fournisseur d'images containers / registre	Numérique externe	Moyenne (3)	Moyenne (2)	Variable (2)	**Moyen**	Zone de danger — supply chain
Dépôts de paquets OS (Fedora, pfSense, Windows Update)	Numérique externe	Forte (3)	Faible (1)	Forte (3)	**Faible-Moyen**	Toléré, à maintenir à jour (F-11)
Poste d'administration /réseau d'accès	Interne	Forte (4)	Forte (3)	Moyenne (2)	**Élevé**	Point d'entrée privilégié des chemins d'attaque

Lecture Zero-Trust — Les parties prenantes à plus fort niveau de menace sont **internes** (opérateur, poste d'admin), ce qui confirme que le hardening du plan d'administration (F-01, F-03, F-06) est l'enjeu central.

3.3 Chemins d'attaque stratégiques

Réf.	Source de risque	Chemin d'attaque stratégique (macro)	Événement(s) redouté(s) visé(s)	Gravité
CS-1	SR-1 Cybercriminel	Point d'entrée segment → découverte services → accès au partage SMB → chiffrement de masse → extorsion	ER-2, ER-6	**G4**
CS-2	SR-1 / SR-3	Accès réseau au DC → exploitation RDP exposé → élévation vers Domain Admin → contrôle de la forêt	ER-1	**G4**
CS-3	SR-2 / SR-3	Accès au plan d'administration mal cloisonné → bascule sur l'hyperviseur → contrôle de toutes les VMs	ER-3, ER-5	**G4**
CS-4	SR-2	Scan du segment → service exposé sans authentification → neutralisation/aveuglement de la supervision	ER-4, ER-7	**G3**
CS-5	SR-5 Supply chain	Image container piégée → exécution sur le nœud fedora → persistance / rebond	ER-3, ER-4	**G3**

Conclusion atelier 3 — Trois chemins stratégiques convergent vers une gravité **G4** et reposent tous sur des **vulnérabilités déjà constatées** en PV-02. Ils sont instanciés techniquement en atelier 4.

Atelier 4 — Scénarios opérationnels

4.1 Objectif de l'atelier Décrire techniquement les scénarios stratégiques retenus, selon la logique **kill chain / MITRE ATT&CK**, et évaluer leur **vraisemblance**.

4.2 Échelle de vraisemblance

Niveau	Libellé	Critère
V1	Minime	Mode opératoire très difficile ; aucune vulnérabilité exploitable identifiée.
V2	Significative	Réalisable par un attaquant compétent ; une vulnérabilité à exploiter.
V3	Forte	Chemin direct exploitant une vulnérabilité avérée (PV-02) ; compétences courantes.
V4	Maximale	Exploitation triviale ; vulnérabilité exposée sans prérequis notable.

4.3 Scénario opérationnel SO-1 — Rançongiciel via le partage SMB (SR-1)

Chemin stratégique associé : CS-1 — Événements redoutés : ER-2 / ER-6 — Gravité G4.

Phase kill chain	Technique MITRE ATT&CK	Action concrète sur le laboratoire	Vulnérabilité exploitée
Reconnaissance	T1046 Network Service Scanning	Scan du segment `10.10.10.0/24` depuis un hôte compromis ; découverte de SMB sur `.20` et de WS-Discovery	F-04
Accès initial /Identifiants	T1078 Valid Accounts /T1110 Brute Force	Obtention d'un compte de domaine (politique de mots de passe faible) donnant accès SMB	F-08
Découverte	T1135 Network Share Discovery	Énumération du partage « partage » joint au domaine	—
Impact	T1486 Data Encrypted for Impact	Chiffrement massif des fichiers du partage SMB	—
Impact	T1490 Inhibit System Recovery	Tentative de suppression des snapshots	Contré par ZFS/3-2-1-0
Exfiltration	T1048 Exfiltration Over Alternative Protocol	Vol de fichiers avant chiffrement (double extorsion)	F-06

Facteurs aggravants : accès SMB depuis tout le segment, politique d'authentification perfectible (F-08).

Facteurs atténuants déjà en place : snapshots ZFS + réplication + vérification SHA-256 (RTO < 1 s, PV- 01) ; agent Wazuh du DC détectant les échecs d'authentification répétés. La détection des modifications massives sur le partage reste à mettre en place (M-03) : TrueNAS n'a pas d'agent Wazuh.

Vraisemblance : V3 (Forte) — la détection est partielle (authentifications seulement) et l'accès au partage est trop large.

4.4 Scénario opérationnel SO-2 — Compromission de l'AD via RDP exposé (SR-1 / SR-3)

Chemin stratégique associé : CS-2 — Événement redouté : ER-1 — Gravité G4.

Phase kill chain	Technique MITRE ATT&CK	Action concrète sur le laboratoire	Vulnérabilité exploitée
Reconnaissance	T1046	Découverte du port 3389 ouvert sur `Win-Server-DC` (`.10`) depuis tout le segment	**F-03**
Accès initial	T1133 External Remote Services /T1110.001 Password Guessing	Accès RDP, attaque par force brute ou identifiants valides	F-03, F-08
Exécution	T1059 Command and Scripting Interpreter	Exécution de commandes sur le DC	—
Escalade / Accès aux identifiants	T1003.001 LSASS Memory /T1558 Kerberoasting	Extraction de secrets, tickets Kerberos (comptes de service à mot de passe faible)	F-08
Mouvement latéral	T1021.001 Remote Desktop Protocol	Bascule vers Domain Admin, contrôle de la forêt `infrasec.local`	F-03
Persistance	T1098 Account Manipulation	Création de comptes/portes dérobées dans l'annuaire	—

Facteurs aggravants : RDP joignable par **tout** le segment (violation directe du Zero-Trust).

Facteurs atténuants déjà en place : agent Wazuh sur le DC (détection des authentifications anormales, SCA, FIM) ; RBAC limitant certains comptes.

Vraisemblance : V3 (Forte) — RDP exposé est un vecteur classique et avéré ; seule la détection Wazuh réduit l'impact.

4.5 Scénario opérationnel SO-3 — Rebond depuis le plan d'administration vers l'hyperviseur (SR- 2 / SR-3)

Chemin stratégique associé : CS-3 — Événements redoutés : ER-3 / ER-5 — Gravité G4.

Phase kill chain	Technique MITRE ATT&CK	Action concrète sur le laboratoire	Vulnérabilité exploitée
Reconnaissance	T1046	Scan révélant SSH/Cockpit et l'IP d'administration de l'hyperviseur sur le segment de production	**F-01**, F-06
Accès initial	T1078 / T1110	Accès SSH/Cockpit (hardening SSH insuffisant)	F-07, F-01
Escalade	T1068 Exploitation for Privilege Escalation	Prise de privilèges sur l'hôte TeneT (Fedora 44 / KVM)	F-11
Contrôle hyperviseur	T1611 Escape to Host (contexte VM)	Contrôle de libvirt/KVM → accès à toutes les VMs	—
Mouvement latéral	T1021.004 SSH	Accès aux autres VMs depuis l'hyperviseur	—
Impact	T1565 Data Manipulation	Altération / arrêt de n'importe quelle VM, y compris pfSense (ER-5)	F-01

Facteurs aggravants : F-01 (IP d'administration de l'hyperviseur sur le segment de production) est le **pire écart structurel** — il place le bien support le plus critique (BS-6) à portée du segment.

Facteurs atténuants déjà en place : Cockpit sur canal chiffré ; journalisation système ; mises à jour (partielles — F-11).

Vraisemblance : V3 (Forte) — chemin direct exploitant la vulnérabilité élevée F-01.

4.6 Scénario opérationnel SO-4 — Aveuglement de la supervision et exploitation d'un service non authentifié (SR-2 / SR-5)

Chemin stratégique associé : CS-4 / CS-5 — Événements redoutés : ER-4 / ER-7 — Gravité G3.

Phase kill chain	Technique MITRE ATT&CK	Action concrète sur le laboratoire	Vulnérabilité exploitée
Reconnaissance	T1046	Découverte de node-exporter `:9100` sans authentification sur `fedora` (`.30`)	**F-05**
Accès initial	T1190 Exploit Public-Facing Application / T1195 Supply Chain Compromise	Exploitation d'un service exposé ou d'une image container piégée	F-05, SR-5
Exécution	T1610 Deploy Container / T1059	Exécution dans un container Podman	Limité par **rootless**
Évasion défensive	T1562.001 Disable or Modify Tools	Tentative d'arrêt de l'agent Wazuh /node-exporter	—
Évasion défensive	T1070 Indicator Removal	Effacement de traces, faux signaux métriques (ER-7)	F-05

Phase kill chain	Technique MITRE ATT&CK	Action concrète sur le laboratoire	Vulnérabilité exploitée
Impact	T1498 Network Denial of Service	Perturbation de la collecte Prometheus/Grafana	—

Facteurs aggravants : service de métriques sans authentification (F-05) ; dépendance à la chaîne d'images (SR-5).

Facteurs atténuants déjà en place : **Podman rootless** limite fortement l'évasion de container et l'élévation ; Wazuh SCA/FIM sur fedora ; corrélation SIEM détectant l'arrêt d'agent.

Vraisemblance : V2 (Significative) — l'exposition est réelle mais le confinement rootless et la détection SIEM réduisent la portée.

4.7 Récapitulatif des scénarios opérationnels (gravité × vraisemblance)

Scénario	SR	ER visés	Gravité	Vraisemblance	Niveau de risque (avant traitement)
SO-1 Rançongiciel via SMB	SR-1	ER-2, ER-6	**G4**	**V3**	**Critique**
SO-2 Compromission AD via RDP	SR-1/SR-3	ER-1	**G4**	**V3**	**Critique**
SO-3 Rebond vers hyperviseur	SR-2/SR-3	ER-3, ER-5	**G4**	**V3**	**Critique**
SO-4 Aveuglement supervision /service non authentifié	SR-2/SR-5	ER-4, ER-7	**G3**	**V2**	**Élevé**

Atelier 5 — Traitement du risque

5.1 Objectif de l'atelier Définir le **plan d'amélioration continue de la sécurité (PACS)**, décliner les mesures en s'appuyant sur les contrôles existants et sur la remédiation des constats PV-02, puis apprécier les **risques résiduels** et produire la cartographie avant/après.

5.2 Stratégie de traitement La stratégie retenue est la **réduction** du risque (diminution de la vraisemblance par cloisonnement et authentification), appuyée sur une posture Zero-Trust restaurée. Le **transfert** n'est pas applicable (laboratoire) ; **l'évitement** n'est pas souhaitable (les services sont la mission du labo) ; **l'acceptation** est réservée aux risques résiduels faibles ou, pour un risque résiduel élevé dont la gravité est intrinsèque, à une décision explicite du RSSI : motivée, assortie de mesures de détection et de reprise, datée et revue périodiquement.

5.3 Mesures de sécurité déjà en place (socle à valoriser)

Mesure existante	Risque couvert	Apport
Sauvegarde **3-2-1-0** (snapshots ZFS + réplication + vérification SHA-256, RTO < 1 s — PV-01)	SO-1	Restauration quasi immédiate après chiffrement ; neutralise l'extorsion par indisponibilité
Wazuh 4.14 (SCA, FIM, corrélation, agents DC + fedora)	SO-1, SO-2, SO-4	Détection d'authentifications anormales, de modifications de fichiers sur les hôtes équipés d'un agent (FIM), d'arrêt d'agent
pfSense chokepoint unique	SO-2, SO-3	Capacité native de micro-segmentation à activer pleinement
Podman rootless	SO-4	Réduction drastique de l'impact d'une évasion de container
RBAC Active Directory (OU/groupes)	SO-2	Moindre privilège sur l'annuaire

Mesure existante	Risque couvert	Apport
Prometheus/Grafana	SO-4	Détection d'anomalies de disponibilité

5.4 Plan de traitement (PACS) — mesures de remédiation Priorités : **P1** court terme (immédiat) · **P2** moyen terme · **P3** amélioration continue.

Réf. mesure	Mesure	Constat(s) /scénario(s) traités	Type	Priorité	Effet attendu
M-01	Créer un **VLAN / réseau d'administration dédié** pour l'hyperviseur, SSH et Cockpit ; retirer l'IP d'admin de l'hyperviseur du segment de production	F-01, F-06 → SO-3	Préventive	**P1**	Vraisemblance SO-3 : V3 → V1
M-02	Restreindre **RDP** au seul poste d'administration par une règle *host-based* (firewall Windows du DC, le flux restant interne au segment) ; activer NLA ; journaliser dans Wazuh	F-03 → SO-2	Préventive	**P1**	Vraisemblance SO-2 : V3 → V2
M-03	Micro-segmenter le partage **SMB** : limiter l'accès aux seuls groupes AD nécessaires ; activer le hardening SMB ; alertes FIM sur taux de modification anormal	SO-1	Préventive + Détection	**P1**	Vraisemblance SO-1 : V3 → V2
M-04	Forcer l'**administration pfSense en HTTPS/TLS** ; désactiver HTTP :80	F-02 → SO-3	Préventive	**P1**	Supprime l'écoute en clair des identifiants d'admin
M-05	Authentifier et restreindre **node-exporter** (TLS + jeton /filtrage par IP Prometheus)	F-05 → SO-4	Préventive	**P2**	Vraisemblance SO-4 : V2 → V1
M-06	Désactiver **WS-Discovery**, les protocoles inutiles et les pilotes de stockage amovible	F-04, F-09, F-10 → SO-1	Préventive	**P2**	Réduction de la surface d'attaque
M-07	**Durcir SSH** (clés uniquement, désactivation root, MFA si possible) et appliquer une **politique de mots de passe** robuste AD	F-07, F-08 → SO-2/SO-3	Préventive	**P2**	Réduit la force brute et l'abus d'identifiants
M-08	Généraliser les **mises à jour automatiques** et un suivi de vulnérabilités (SCA Wazuh)	F-11 → SO-3	Corrective	**P2**	Réduit l'exploitation de failles connues (T1068)
M-09	Durcir les OS pour **relever l'indice Lynis** au-delà de 80/100 ; rejouer l'audit	F-07 à F-10 → tous	Corrective	**P3**	Amélioration continue mesurable
M-10	Vérifier et **signer la chaîne d'images containers** (images de confiance, scan, politique de registre)	SR-5 → SO-4	Préventive	**P3**	Réduit le risque supply chain



Réf. mesure	Mesure	Constat(s) /scénario(s) traités	Type	Priorité	Effet attendu
M-11	**Protéger les sauvegardes** (snapshots en lecture seule /immuables, isolation du canal de réplication)	SO-1 (T1490)	Préventive	**P2**	Garantit la restauration malgré une tentative de destruction
M-12	Durcir l'accès **Cockpit** (TLS, authentification forte, réseau d'admin)	F-06 → SO-3	Préventive	**P2**	Réduit le vecteur d'administration del'hyperviseur

5.5 Risques résiduels

Scénario	Niveau avant	Mesures du plan	Gravité résiduelle	Vraisemblance résiduelle	Niveau résiduel	Décision
SO-1 Rançongiciel SMB	Critique (G4×V3)	M-03, M-06, M-11 + 3-2-1-0, Wazuh	G4	**V2**	**Élevé**	Réduit — accepté sous suivi (restauration RTO < 1 s)
SO-2 Compromission AD	Critique (G4×V3)	M-02, M-07 + RBAC, Wazuh	G4	**V2**	**Élevé**	Réduit — suivi renforcé de la détection RDP
SO-3 Rebond hyperviseur	Critique (G4×V3)	M-01, M-04, M-08, M-12	G4	**V1**	**Modéré**	Fortement réduit — plan d'admin cloisonné
SO-4 Aveuglement supervision	Élevé (G3×V2)	M-05, M-06, M-10 + rootless, Wazuh	G3	**V1**	**Modéré**	Fortement réduit — accepté

Risque résiduel principal — Même après traitement, SO-1 et SO-2 conservent une gravité G4 (intrinsèque au cœur de confiance) avec une vraisemblance ramenée à V2. Ils sont **acceptés** car : (1) la sauvegarde 3-2-1-0 garantit la continuité (ER-2), et (2) la détection Wazuh assure la réactivité. Un suivi trimestriel de l'efficacité de la détection est recommandé.

5.6 Cartographie du risque — avant / après traitement Matrice Gravité (G1–G4) × Vraisemblance (V1–V4). Position de chaque scénario.

Avant traitement

Gravité / vraisemblance	V1	V2	V3	V4
G4			SO-1, SO-2, SO-3	
G3		SO-4		
G2				
G1				

Après traitement

Gravité / vraisemblance	V1	V2	V3	V4
G4	SO-3	SO-1, SO-2		



Gravité / vraisemblance	V1	V2	V3	V4
G3	SO-4			
G2				
G1				

Lecture — Le traitement déplace les trois scénarios critiques hors de la colonne V3 : SO-3 passe en V1 (cloisonnement du plan d'admin), SO-1 et SO-2 en V2 (restriction d'accès + détection). **Plus aucun scénario ne demeure en zone critique (G4×V3/V4).** Les risques résiduels se situent en zone « élevée maîtrisée » à « modérée ».

Conclusion générale L'appréciation EBIOS RM du laboratoire « Hybrid InfraSec » confirme la pertinence de l'architecture Zero- Trust visée, tout en objectivant l'écart entre l'intention affichée et la configuration auditée (PV-02, Lynis 69/100). Les trois risques critiques identifiés — **rançongiciel sur le partage SMB (SO-1)**, **compromission de l'Active Directory via RDP (SO-2)** et **rebond vers l'hyperviseur (SO-3)** — découlent tous d'un **défaut de cloisonnement du plan d'administration et d'accès trop larges** (F-01, F-03, F-06).

Le plan de traitement proposé s'appuie prioritairement sur les mesures **déjà présentes** (sauvegarde 3-2- 1-0 à RTO < 1 s, SIEM Wazuh, Podman rootless, chokepoint pfSense) et sur des remédiations ciblées et peu coûteuses (réseau d'administration dédié, restriction RDP, micro-segmentation SMB, TLS généralisé, authentification des services). Leur mise en œuvre ramène l'ensemble des scénarios hors de la zone de risque critique, rétablissant la cohérence du modèle Zero-Trust et portant l'infrastructure à un niveau de maturité conforme aux attentes de la certification AIS.

Complément D.1 — Traçabilité constats PV-02 → scénarios → mesures

Constat	Scénario(s)	Mesure(s) de traitement
F-01 (Élevée)	SO-3	M-01
F-02 (Moyenne)	SO-3	M-04
F-03 (Moyenne-Élevée)	SO-2	M-02
F-04 (Faible)	SO-1	M-06
F-05 (Faible)	SO-4	M-05
F-06 (Moyenne)	SO-3	M-01, M-12
F-07 (Faible)	SO-2, SO-3	M-07
F-08 (Faible)	SO-1, SO-2	M-07
F-09 (Faible)	SO-1	M-06
F-10 (Faible)	SO-1	M-06, M-09
F-11 (Faible)	SO-3	M-08

Complément D.2 — Correspondance valeurs métier / biens supports / événements redoutés

Valeur métier	Biens supports	Événements redoutés
VM-1 Annuaire / authentification	BS-1, BS-5, BS-6	ER-1, ER-6
VM-2 Intégrité/disponibilité des données	BS-2, BS-6	ER-2, ER-6
VM-3 Supervision / détection	BS-3, BS-4, BS-6	ER-4, ER-7
VM-4 Continuité d'activité	BS-2, BS-6	ER-2

Fin du document — EBIOS Risk Manager, laboratoire « Hybrid InfraSec ».

Annexe E · Politique de sécurité des systèmes d'information (PSSI)

Laboratoire « Hybrid InfraSec » — Architecture Zero-Trust (DevSecOps / CloudSec)

Rubrique	Valeur
Intitulé du document	Politique de Sécurité des Systèmes d'Information (PSSI)
Périmètre	Laboratoire de certification AIS « Hybrid InfraSec »
Référence	PSSI-HIS-2026-01
Révision	11 octobre 2026
Classification	Diffusion restreinte (jury / opérateur)
Date de publication	4 octobre 2026
Rédacteur	Responsable de la Sécurité des Systèmes d'Information (RSSI)
Validation	RSSI
Cycle de révision	Annuel ou après tout incident majeur / changement structurant

Note de rédaction — Le présent document emploie la terminologie normative : **DOIT** / **NE DOIT PAS** (exigence obligatoire), **DEVRAIT** (recommandation forte), **PEUT** (faculté). Aucune adresse IP publique, aucun secret réel ni aucune empreinte de clé ne figure dans ce livrable ; les valeurs présentées sont des conventions internes du laboratoire.

Sommaire

1. Article 1 — Objet, périmètre et portée
2. Article 2 — Cadre et références normatives
3. Article 3 — Organisation et gouvernance de la sécurité
4. Article 4 — Classification et gestion des actifs
5. Article 5 — Gestion des identités et des accès
6. Article 6 — Sécurité réseau et cloisonnement
7. Article 7 — Hardening des systèmes et des containers
8. Article 8 — Protection des données, sauvegarde et continuité
9. Article 9 — Journalisation, supervision et détection
10. Article 10 — Gestion des incidents de sécurité
11. Article 11 — Gestion des secrets et de la cryptographie
12. Article 12 — Conformité, audit et amélioration continue
13. Annexes

Article 1 — Objet, périmètre et portée

1.1 Objet

1.1.1 La présente Politique de Sécurité des Systèmes d'Information (ci-après « PSSI ») définit l'ensemble des règles, principes directeurs et exigences techniques et organisationnelles applicables au laboratoire de certification AIS « **Hybrid InfraSec** ».

1.1.2 La PSSI a pour finalité de garantir, de manière vérifiable et auditable, les propriétés de sécurité suivantes sur l'ensemble du périmètre :

- **Confidentialité** : les informations ne sont accessibles qu'aux entités autorisées.
- **Intégrité** : les données, configurations et logs ne peuvent être altérés de manière non autorisée ou non détectée.
- **Disponibilité** : les services et données sont accessibles selon les objectifs de continuité définis à l'Article 8.
- **Traçabilité / imputabilité** : toute action significative est journalisée et rattachable à une identité.
- **Preuve** : les éléments nécessaires à l'audit et au contentieux sont conservés et protégés.

1.2 Périmètre technique

1.2.1 Le périmètre couvre l'intégralité de l'infrastructure hébergée sur l'hôte physique **TeneT** et son réseau d'hébergement :

Composant	Hôte / Rôle	Adresse	Fonctions principales
TeneT	Hyperviseur Fedora 44	hôte physique	Cockpit, KVM/libvirt, administration de virtualisation
pfSense	Firewall / point de passage unique	`10.10.10.254`	Filtrage, routage, DNS résolveur, passerelle, DHCP
Win-Server-DC	Contrôleur de domaine	`10.10.10.10`	Active Directory DS (forêt `infrasec.local`), DNS AD, RBAC
TrueNAS	Stockage	`10.10.10.20`	ZFS miroir, partage SMB joint au domaine, ACL NFSv4
fedora	Nœud containers	`10.10.10.30`	Podman rootless : node-exporter, Prometheus, Grafana, Zabbix
wazuh-siem	SIEM	`10.10.10.40`	Wazuh 4.14 (gestionnaire, SCA, FIM, détection)

1.2.2 Le segment réseau unique du laboratoire est `10.10.10.0/24`. Tout trafic entrant dans le segment ou en sortant **DOIT** transiter par le point de passage unique (*chokepoint*) pfSense (`10.10.10.254`). À l'intérieur du segment, les flux entre machines ne traversent pas pfSense : ils sont restreints par le filtrage local des hôtes (cf. 6.3).

1.3 Périmètre organisationnel et portée

1.3.1 La PSSI s'applique à :

- l'opérateur du laboratoire et toute personne disposant d'un accès (administrateur, auditeur, membre du jury en évaluation) ;
- l'ensemble des actifs matériels, logiciels, virtuels, conteneurisés et informationnels listés à l'Article 4 ;
- tout prestataire ou outil tiers intervenant sur le périmètre.

1.3.2 Toute dérogation à une règle de la présente PSSI **DOIT** faire l'objet d'une demande formelle motivée, enregistrée, limitée dans le temps et validée par le RSSI. Les dérogations actives **DOIVENT** être recensées dans le registre des dérogations (Complément E.3) et réexaminées à chaque cycle d'audit.

1.3.3 Le non-respect des règles de la PSSI constitue une non-conformité pouvant entraîner la suspension immédiate des accès concernés et, le cas échéant, l'échec de la certification.

Article 2 — Cadre et références normatives

2.1 Principe d'alignement

2.1.1 La PSSI s'aligne, **à titre de référence méthodologique**, sur les cadres ci-dessous. Le laboratoire étant un environnement de certification pédagogique, cet alignement vise la cohérence et la vérifiabilité, sans prétention à une certification normative formelle des référentiels cités.

2.2 Référentiels de référence

Référentiel	Domaine couvert	Usage dans la PSSI
ISO/IEC 27001	Système de management de la sécurité del'information (SMSI)	Structure de gouvernance, approche par les risques, cycle PDCA (Art. 3, 12)
ISO/IEC 27002	Mesures de sécurité (bonnes pratiques)	Sélection et formulation des mesures (Art. 4 à 11)
ISO/IEC 27005	Gestion des risques	Appréciation et traitement des risques
Guides ANSSI	Hygiène informatique, administration sécurisée, journalisation, Active Directory	Hardening, plan d'administration, politique de journalisation (Art. 5, 6, 7, 9)
CIS Benchmarks	Configurations durcies (Windows Server / AD, Linux, Docker/Podman)	Hardening des systèmes et containers (Art. 7)
CIS Controls v8	Contrôles de sécurité priorisés	Gestion des actifs, des accès, journalisation
NIST SP 800-207	Architecture Zero-Trust	Principe directeur transverse (Art. 6)
OWASP (ASVS, Secrets Management)	Sécurité applicative et des secrets	Gestion des secrets (Art. 11)

2.3 Principes directeurs

2.3.1 L'ensemble de la PSSI est régi par les principes directeurs suivants, qui priment en cas d'ambiguïté d'interprétation d'une règle :

1. **Zero-Trust** — Aucune confiance implicite n'est accordée en fonction de la localisation réseau. Toute requête est authentifiée, autorisée et vérifiée.

2. **Moindre privilège** — Chaque identité, service ou container ne dispose que des droits strictement nécessaires à sa fonction.

3. **Défense en profondeur** — Les mesures de sécurité sont superposées (réseau, système, container, application, données) de sorte qu'aucune défaillance unique ne compromette le périmètre.

4. **Sécurité par défaut** — Les configurations livrées sont restrictives (*deny by default*) ; l'ouverture est l'exception motivée.

5. **Traçabilité intégrale** — Toute action d'administration ou de sécurité est journalisée de façon centralisée et horodatée.

6. **Chiffrement en transit** — Tout flux transportant des données d'authentification, d'administration ou sensibles **DOIT** être chiffré (TLS, SSH ou WireGuard).

Article 3 — Organisation et gouvernance de la sécurité

3.1 Rôles et responsabilités

3.1.1 La gouvernance de la sécurité repose sur une séparation des rôles. Un même individu **PEUT** cumuler plusieurs rôles dans ce laboratoire mono-opérateur, mais les actions **DOIVENT** rester tracées par rôle fonctionnel distinct (comptes dédiés — cf. Article 5).

Rôle	Responsabilités principales	Rattachement
RSSI	Définit, maintient et fait appliquer la PSSI ; valide les dérogations ; pilote l'analyse de risques et le PDCA ; approuve les changements structurants	Autorité de sécurité
Administrateur Système /Virtualisation	Exploite TeneT, KVM/libvirt, Cockpit ; applique le hardening des hôtes ; gère les snapshots	Exploitation
Administrateur Active Directory	Gère la forêt `infrasec.local`, les comptes, groupes, GPO et le RBAC	Exploitation
Administrateur Réseau / Firewall	Gère pfSense, les règles de filtrage, le DHCP, le DNS et la segmentation	Exploitation
Administrateur Stockage	Gère TrueNAS, les pools ZFS, les ACL NFSv4, les partages SMB, la réplication	Exploitation
Opérateur Containers (DevSecOps)	Exploite Podman rootless, Prometheus, Grafana, Zabbix ; applique le hardening OCI	Exploitation
Analyste Sécurité / SOC	Exploite Wazuh ; surveille, qualifie et traite les alertes ; conduit les RETEX	Détection & réponse
Auditeur	Contrôle la conformité ; produit les procès-verbaux (PV) d'audit	Contrôle (accès lecture)

3.1.2 Le principe de **séparation des tâches** (*Segregation of Duties*) **DOIT** être respecté dans son esprit : l'entité qui exploite un service **NE DOIT PAS** être la seule à contrôler ses propres logs. La fonction d'audit et la supervision SIEM **DOIVENT** disposer d'un accès en lecture indépendant et non modifiable par les administrateurs d'exploitation.

3.2 Comité et revue de sécurité

3.2.1 Une revue de sécurité **DOIT** être tenue au minimum à chaque fin de cycle d'audit et après tout incident majeur. Elle couvre : l'état des risques, les incidents, les dérogations actives, les résultats SCA/FIM, l'état des sauvegardes et le plan d'amélioration.

3.2.2 Les décisions de la revue **DOIVENT** être consignées dans un relevé de décisions daté et conservé au titre des éléments de preuve.

3.3 Documentation et maintien en condition

3.3.1 La PSSI, les procédures associées et les registres (actifs, dérogations, incidents, secrets) **DOIVENT** être maintenus à jour et versionnés.

3.3.2 Toute modification de la PSSI **DOIT** être approuvée par le RSSI, tracée (version, date, motif) et communiquée aux rôles concernés.

Article 4 — Classification et gestion des actifs

4.1 Inventaire des actifs

4.1.1 Un inventaire exhaustif des actifs **DOIT** être tenu à jour. Aucun actif (machine virtuelle, container, partage, pool ZFS, compte de service) **NE DOIT** exister en dehors de l'inventaire.

4.1.2 Chaque actif **DOIT** posséder un propriétaire (rôle responsable), un niveau de classification et un niveau de criticité.

4.2 Échelle de classification

4.2.1 Les informations et actifs sont classés selon l'échelle suivante :

Niveau	Libellé	Exemples sur le périmètre	Exigence minimale
C3	Critique / Secret	Secrets d'authentification, clés privées, base NTDS (AD), hachés de mots de passe	Chiffrement, accès nominatif restreint, journalisation renforcée
C2	Confidentiel	Configurations pfSense, GPO, règles Wazuh, logs de sécurité	Accès par rôle, chiffrement en transit, sauvegarde
C1	Interne	Dashboards Grafana, métriques Prometheus, documentation d'exploitation	Accès authentifié
C0	Public / Non sensible	Modèles de documents, bannières légales	Aucune restriction spécifique

4.3 Criticité et correspondance avec la continuité

4.3.1 La criticité de chaque actif détermine ses objectifs de sauvegarde et de reprise (cf. Article 8).

Actif	Classification	Criticité	Impact d'une compromission
`Win-Server-DC` (AD / forêt `infrasec.local`)	C3	Vitale	Perte de contrôle du RBAC et del'authentification de tout le périmètre
`pfSense` (chokepoint)	C2	Vitale	Perte du cloisonnement et du filtrage ; exposition latérale
`wazuh-siem`	C2	Haute	Perte de la détection et de la traçabilité
`TrueNAS` (données ZFS)	C3/C2	Haute	Perte / fuite de données stockées
`fedora` (containers)	C1	Moyenne	Perte de supervision applicative
`TeneT` (hyperviseur)	C2	Vitale	Compromission de l'ensemble des VM

4.4 Cycle de vie et mise au rebut

4.4.1 Tout actif en fin de vie (VM, snapshot, partage, compte) **DOIT** être désactivé puis supprimé de manière traçable, et retiré de l'inventaire.

4.4.2 Les supports et datasets contenant des données de niveau C2 ou C3 **DOIVENT** être effacés de manière sécurisée (destruction des datasets ZFS et de leurs snapshots) avant réutilisation ou mise au rebut.

Article 5 — Gestion des identités et des accès

5.1 Principes

5.1.1 L'autorité unique d'authentification et d'autorisation du périmètre est **Active Directory** (forêt `infrasec.local`), porté par `Win-Server-DC`. Les ressources susceptibles d'être intégrées au domaine (p. ex. partages SMB de TrueNAS) **DOIVENT** s'appuyer sur le RBAC Active Directory.

5.1.2 Le principe du **moindre privilège DOIT** s'appliquer à toute identité. Les droits sont accordés par appartenance à des groupes, jamais à titre individuel direct sur les ressources.

5.1.3 Chaque action **DOIT** être imputable à une identité nominative. Les comptes génériques partagés **SONT INTERDITS**, sauf comptes de service explicitement recensés (cf. 5.4).

5.2 Matrice de rôles et d'accès (RBAC)

5.2.1 Les accès sont attribués conformément à la matrice suivante. Toute attribution hors matrice **DOIT** faire l'objet d'une dérogation.

Groupe AD / Rôle	TeneT /Cockpit	pfSense	AD (Win-Server-DC)	TrueNAS (SMB)	fedora (containers)	Wazuh
RSSI	Lecture	Lecture	Lecture	Lecture	Lecture	Admin lecture
Admin Virtualisation	Admin	—	—	—	—	Agent (lecture)
Admin AD	—	—	Admin	—	—	Agent (lecture)
Admin Réseau	—	Admin	—	—	—	Agent (lecture)
Admin Stockage	—	—	Membre jonction domaine	Admin	—	Agent (lecture)
Opérateur Containers	—	—	—	Lecture datasets dédiés	Admin (non-root)	Agent (lecture)
Analyste SOC	Lecture logs	Lecture logs	Lecture logs	Lecture logs	Lecture logs	Admin
Auditeur	Lecture	Lecture	Lecture	Lecture	Lecture	Lecture
Utilisateur de service	—	—	selon SPN	selon ACL dataset	selon service	Agent

Légende : **Admin** = administration complète · **Lecture** = consultation · **—** = aucun accès · **Agent** = remontée de logs vers le SIEM.

5.3 Comptes à privilèges

5.3.1 Les comptes d'administration de domaine (p. ex. membres de *Domain Admins*, *Enterprise Admins*) **DOIVENT** être strictement limités, nominatifs, et **NE DOIVENT PAS** servir pour des tâches courantes ou la navigation.

5.3.2 L'administration **DOIT** suivre le principe du *tiering* : les comptes à privilèges élevés **NE DOIVENT PAS** être exposés sur des machines de moindre confiance. Le plan d'administration est restreint conformément à l'Article 6.

5.3.3 Les comptes à privilèges **DOIVENT** être désactivés dès qu'ils ne sont plus nécessaires et revus à chaque cycle d'audit.

5.4 Comptes de service

5.4.1 Chaque service (jonction SMB au domaine, agent Wazuh, exportateur de métriques, etc.) **DOIT** disposer d'un compte de service dédié, documenté dans l'inventaire, avec le périmètre de droits minimal.

5.4.2 Les comptes de service **NE DOIVENT PAS** disposer de droits interactifs d'ouverture de session lorsque ceux-ci ne sont pas requis.

5.4.3 Les mots de passe des comptes de service multi-plateformes (Windows / Linux / NAS) **DOIVENT** être composés en respectant la compatibilité des dispositions clavier afin d'éviter les saisies erronées entre plateformes, tout en conservant une entropie élevée (cf. 5.5).

5.5 Politique de mots de passe et authentification multifacteur

5.5.1 La politique de mots de passe est définie par GPO sur le domaine et **DOIT** respecter au minimum :

Paramètre	Exigence
Longueur minimale (comptes utilisateurs)	14 caractères
Longueur minimale (comptes à privilèges /service)	20 caractères
Complexité	Majuscules, minuscules, chiffres et caractères spéciaux
Compatibilité clavier (comptes multi-plateformes)	Caractères saisissables de manière identique sur les dispositions cibles
Historique	24 derniers mots de passe interdits à la réutilisation
Verrouillage	Après 5 tentatives échouées, sur une fenêtre de 15 minutes
Rotation comptes à privilèges / service	Au moins tous les 90 jours et à chaque suspicion de compromission
Stockage	Jamais en clair ; cf. Article 11

5.5.2 L'authentification multifacteur (**MFA**) **DEVRAIT** être activée pour tout accès d'administration lorsque le composant le permet (p. ex. interface pfSense, accès Cockpit via solution compatible). Lorsque le MFA n'est pas disponible nativement, la compensation **DOIT** être documentée (restriction réseau du plan d'administration, mots de passe à forte entropie, rotation renforcée).

5.5.3 Les mots de passe par défaut de tout composant (pfSense, TrueNAS, Grafana, Wazuh, Cockpit) **DOIVENT** être modifiés dès l'installation.

5.6 Cycle de vie des accès

5.6.1 Toute création, modification ou suppression d'accès **DOIT** être tracée et justifiée.

5.6.2 Une revue des comptes et des appartenances de groupes **DOIT** être conduite à chaque cycle d'audit afin de détecter les droits dormants ou excessifs.

Article 6 — Sécurité réseau et cloisonnement

6.1 Point de passage unique (chokepoint)

6.1.1 Le firewall **pfSense** (`10.10.10.254`) constitue le point de passage unique et obligatoire de l'ensemble des flux qui entrent dans le segment ou en sortent, y compris ceux de l'accès distant WireGuard. Il assure les fonctions de passerelle, de résolveur DNS, de serveur DHCP et de filtrage.

6.1.2 Aucun flux **NE DOIT** contourner le chokepoint. Toute route alternative, tunnel non autorisé ou interface réseau supplémentaire sur une VM constitue une non-conformité et **DOIT** être supprimé.

6.2 Filtrage par défaut interdit (deny by default)

6.2.1 La politique de filtrage **DOIT** reposer sur le principe *deny by default* : tout flux non explicitement autorisé est bloqué.

6.2.2 Les règles d'autorisation **DOIVENT** être nominatives (source, destination, port, protocole, justification) et recensées. Toute règle obsolète **DOIT** être supprimée.

6.2.3 Matrice de flux autorisés de référence (toute ligne absente est interdite) :

Source	Destination	Service / Port	Protocole	Justification
Postes / VM du segment	`pfSense .254`	DNS (53), DHCP (67/68)	UDP/TCP	Résolution et adressage

Source	Destination	Service / Port	Protocole	Justification
Toutes VM	`Win-Server-DC .10`	Kerberos (88), LDAP (389/636), DNS (53), SMB (445)	TCP/UDP	Authentification, RBAC, jonction domaine
`TrueNAS .20`	`Win-Server-DC .10`	Kerberos/LDAP	TCP/UDP	Jonction SMB au domaine
Clients autorisés	`TrueNAS .20`	SMB (445)	TCP	Accès partages selon ACL (service NFS non activé)
`fedora .30`	`Win-Server-DC .10`	DNS (53)	UDP/TCP	Résolution
Agents Wazuh (`Win-Server-DC`, `fedora`)	`wazuh-siem .40`	1514/1515	TCP	Remontée logs /enregistrement agents
`fedora .30` (Prometheus)	`Win-Server-DC .10` (windows_exporter)	9182	TCP	Métriques du DC ; node-exporter de fedora interrogé en local (9100 non exposé, F-05)
Plan d'administration	Interfaces d'admin (Cockpit, pfSense, TrueNAS, Grafana, Wazuh)	HTTPS (443) / ports admin	TCP (TLS)	Administration (cf. 6.4)
Internet	pfSense WAN	WireGuard (51820)	UDP	Accès distant chiffré (seul port ouvert côté WAN)
Peer `admin-remote10.10.20.2`	Segment `10.10.10.0/24`	Ports d'administration	TCP/UDP	Administration à distance (restriction aux seules interfaces d'administration planifiée)
Peer `employe-remote10.10.20.3`	`TrueNAS .20`	SMB (445)	TCP	Partage de fichiers du collaborateur
`fedora .30` (Zabbix)	`pfSense .254`	SNMP (161)	UDP	Supervision réseau du firewall, réservée au collecteur (v2c en laboratoire, v3 exigée en production)

6.3 Segmentation et micro-cloisonnement

6.3.1 Bien que le laboratoire repose sur un segment unique `10.10.10.0/24`, le principe Zero-Trust **DOIT** être appliqué par **micro-cloisonnement logique** : les flux qui entrent dans le segment ou en sortent sont filtrés par pfSense ; les communications entre VM du segment, qui ne traversent pas pfSense, sont restreintes par le filtrage hôte (règles locales) au strict nécessaire défini en 6.2.3, en attendant le réseau d'administration dédié (mesure EBIOS M-01).

6.3.2 Les communications entre VM **NE DOIVENT PAS** être autorisées globalement. L'absence de règle explicite vaut interdiction, y compris pour des machines du même sous-réseau.

6.4 Restriction du plan d'administration (Zero-Trust)

6.4.1 Les interfaces d'administration (Cockpit sur TeneT, console pfSense, interface TrueNAS, Grafana, dashboard Wazuh) **NE DOIVENT PAS** être exposées à l'ensemble du segment. Leur accès **DOIT** être restreint aux sources du plan d'administration explicitement autorisées.

6.4.2 Tout accès d'administration **DOIT** être chiffré (TLS / HTTPS / SSH). Les protocoles d'administration en clair (HTTP, Telnet) **SONT INTERDITS**.



6.4.3 Les services d'administration **NE DOIVENT PAS** écouter sur des interfaces ou adresses non nécessaires.

6.5 Services réseau

6.5.1 La résolution DNS interne est assurée par `Win-Server-DC` pour la zone `infrasec.local` et relayée/filtrée via pfSense. Les résolveurs non autorisés **SONT INTERDITS**.

6.5.2 Le serveur DHCP est porté exclusivement par pfSense. Tout autre service DHCP sur le segment constitue une non-conformité (risque de DHCP pirate).

Article 7 — Hardening des systèmes et des containers

7.1 Hardening des systèmes

7.1.1 Tous les systèmes (TeneT, VM Linux, `Win-Server-DC`) **DOIVENT** être durcis conformément aux **CIS Benchmarks** applicables et aux guides d'hygiène de l'ANSSI.

7.1.2 Les services, comptes et logiciels inutiles **DOIVENT** être désactivés ou supprimés (réduction de la surface d'attaque).

7.1.3 Les permissions de fichiers **DOIVENT** respecter le moindre privilège. **L'usage de `chmod 777` (ou de tout mode octroyant l'écriture à tous) EST INTERDIT.** La maîtrise des droits **DOIT** s'effectuer par un propriétaire approprié (`chown`), des groupes dédiés et, pour les containers, des *user namespaces*.

7.1.4 Un snapshot de reprise (**Snapper** / **ZFS**) **DOIT** être pris avant toute opération majeure (mise à jour, changement de configuration structurant, déploiement) afin de permettre un rollback rapide.

7.2 Hardening des containers (OCI rootless)

7.2.1 Les containers **DOIVENT** être exécutés en mode **OCI rootless par défaut** (Podman) sur le nœud `fedora`. L'isolation **DOIT** s'appuyer sur les *user namespaces*.

7.2.2 Tout besoin de **privilège root**, de container privilégié ou d'exposition d'un **port privilégié (< 1024) DOIT** faire l'objet d'une justification écrite, validée par le RSSI et recensée dans le registre des dérogations. En l'absence de justification, de telles configurations **SONT INTERDITES**.

7.2.3 Les images de containers **DOIVENT** provenir de sources de confiance, être versionnées (pas de recours systématique à `latest` en exploitation) et analysées pour vulnérabilités avant déploiement.

7.2.4 Les containers **DOIVENT** appliquer le moindre privilège : suppression des capacités Linux non nécessaires, systèmes de fichiers en lecture seule lorsque possible, et aucun secret en clair dans l'image ou les variables d'environnement persistées (cf. Article 11).

7.2.5 Récapitulatif des règles containers :

Règle	Exigence
Mode d'exécution	Rootless (Podman) par défaut
Isolation	User namespaces obligatoires
Root / privilégié	Interdit sauf dérogation justifiée et validée
Port < 1024	Interdit sauf dérogation justifiée et validée
`chmod 777` dans les volumes	Interdit (usage de `chown` + groupes)
Provenance des images	Sources de confiance, tag figé, scannées
Capacités Linux	Réduites au strict nécessaire

Règle	Exigence
Secrets	Jamais en clair (cf. Art. 11)

7.3 Gestion des vulnérabilités et mises à jour

7.3.1 Les systèmes et images **DOIVENT** faire l'objet d'une veille et d'une analyse de vulnérabilités régulières. Le module **SCA** (Security Configuration Assessment) de Wazuh **DOIT** être activé sur les agents pour évaluer la conformité aux référentiels de hardening.

7.3.2 Les correctifs de sécurité **DOIVENT** être appliqués dans des délais proportionnés à la criticité : sans délai pour une vulnérabilité critique activement exploitée affectant un actif vital ; dans le cycle de maintenance planifié pour les autres.

7.3.3 Toute mise à jour **DOIT** être précédée d'un snapshot de reprise (cf. 7.1.4) et suivie d'une vérification de bon fonctionnement.

Article 8 — Protection des données, sauvegarde et continuité

8.1 Protection des données au repos et en transit

8.1.1 Les données de niveau C2 et C3 **DOIVENT** être protégées. Le chiffrement au repos **DEVRAIT** être appliqué sur les datasets sensibles de TrueNAS lorsque la plateforme le permet (chiffrement ZFS natif).

8.1.2 Tout transport de données d'authentification, d'administration ou sensibles **DOIT** être chiffré en transit (TLS/SMB signé/NFS sécurisé/SSH/HTTPS).

8.2 Contrôle d'accès aux données (ACL)

8.2.1 Les partages SMB de TrueNAS **DOIVENT** être joints au domaine `infrasec.local` et leurs accès régis par le RBAC Active Directory via des groupes.

8.2.2 Les **ACL NFSv4 DOIVENT** être définies selon le moindre privilège, en évitant toute permission large (`everyone` / accès monde en écriture). L'usage de `chmod 777` sur les datasets partagés **EST INTERDIT** (cf. 7.1.3).

8.3 Stratégie de sauvegarde 3-2-1-0

8.3.1 La stratégie de sauvegarde **DOIT** respecter le modèle **3-2-1-0** :

Chiffre	Signification	Mise en œuvre dans le laboratoire
3	3 copies des données	Donnée de production + snapshot ZFS local + réplication
2	2 supports de stockage différents	Cible de réplication distincte (`tank/partage_backup`) ; second support physique en production (en laboratoire, même pool : voir PV-01)
1	1 copie hors site / isolée	Réplication vers un site distant en production (non atteint en laboratoire : voir PV-01)
0	0 erreur vérifiée	Contrôle d'intégrité par empreinte **SHA-256**

8.3.2 Les mécanismes **DOIVENT** inclure : snapshots ZFS planifiés, réplication des snapshots vers une cible distincte, et vérification d'intégrité par empreinte SHA-256 après chaque réplication.

8.3.3 La restauration **DOIT** être testée périodiquement (test de restauration documenté), une sauvegarde non restaurable n'ayant aucune valeur.

8.4 Objectifs de continuité (RPO / RTO) et PRA

8.4.1 Les objectifs de reprise par classe d'actif sont les suivants :

Actif / Donnée	RPO (perte de données max.)	RTO (délai de reprise max.)	Mécanisme
Datasets ZFS critiques (TrueNAS)	≤ 1 h (snapshots horaires)	**< 1 s** (bascule / retour snapshot)	Snapshots ZFS + réplication
État VM après opération majeure	0 (snapshot avant opération)	Immédiat (rollback)	Snapper / ZFS
Active Directory (`infrasec.local`)	Faible	Selon procédure de restauration AD	Sauvegarde de l'état système /snapshot
Configuration pfSense	Faible	Rapide (import de configuration)	Export de configuration

8.4.2 Un plan de reprise d'activité (**PRA**) **DOIT** documenter l'ordre de redémarrage (chokepoint pfSense, puis AD, puis services dépendants), les procédures de restauration et les responsables. Le PRA **DOIT** être testé au moins une fois par cycle.

8.4.3 Les snapshots et réplications **DOIVENT** être surveillés ; tout échec **DOIT** générer une alerte traitée selon l'Article 10.

Article 9 — Journalisation, supervision et détection

9.1 Journalisation centralisée

9.1.1 Tous les actifs du périmètre **DOIVENT** émettre leurs logs vers le SIEM centralisé **Wazuh** (`wazuh-siem`, `10.10.10.40`) via un agent ou un flux dédié. *État au 11/10/2026 : agents déployés sur `Win-Server-DC` et `fedora` ; le raccordement de pfSense, de TrueNAS et de l'hyperviseur au SIEM reste à réaliser (écart suivi).*

9.1.2 Les logs **NE DOIVENT PAS** pouvoir être modifiés ni supprimés par les administrateurs d'exploitation des machines surveillées. L'intégrité et la rétention sont gérées côté SIEM.

9.1.3 Les horloges de tous les systèmes **DOIVENT** être synchronisées (référence de temps commune) afin de garantir la cohérence des corrélations.

9.2 Politique de journalisation

9.2.1 Les événements suivants **DOIVENT** au minimum être journalisés et remontés :

Source	Événements journalisés	Finalité
`Win-Server-DC` (AD)	Authentifications (succès/échec), modifications de comptes/groupes, élévations de privilèges, GPO	Traçabilité RBAC, détection d'abus
`pfSense`	Flux bloqués/autorisés, changements de règles, événements VPN/admin	Surveillance du chokepoint
`TrueNAS`	Accès aux partages, modifications d'ACL, erreurs ZFS, snapshots/réplication	Intégrité et accès aux données
`fedora` / containers	Démarrage/arrêt containers, usage de privilèges, événements Podman	Détection d'abus containers
`TeneT` / Cockpit	Connexions d'administration, actions libvirt, snapshots	Surveillance de l'hyperviseur
`wazuh-siem`	Alertes, SCA, FIM, état des agents	Détection et conformité

9.2.2 La **durée de conservation** des logs **DOIT** être d'au minimum **90 jours** en ligne pour les logs de sécurité, et davantage pour les événements liés à un incident ouvert (conservés jusqu'à clôture et RETEX). Les logs **DOIVENT** rester exploitables et protégés sur toute la durée de conservation.

9.3 Détection (SCA, FIM)

9.3.1 Le module **SCA** (Security Configuration Assessment) de Wazuh **DOIT** être activé pour évaluer en continu la conformité des systèmes aux référentiels de hardening (Article 7).

9.3.2 Le module **FIM** (File Integrity Monitoring) **DOIT** surveiller l'intégrité des fichiers et répertoires sensibles (configurations, binaires critiques, fichiers d'ACL), et générer une alerte en cas de modification non attendue.

9.3.3 Les règles de détection **DOIVENT** être maintenues et ajustées pour limiter les faux positifs tout en couvrant les scénarios de menace pertinents (élévation de privilèges, mouvement latéral, altération de logs, création de port privilégié non justifié).

9.4 Supervision opérationnelle

9.4.1 La supervision des métriques est assurée par **Prometheus** (collecte via node-exporter et windows_exporter) et restituée par **Grafana** sur le nœud `fedora` ; le firewall est supervisé en SNMP par **Zabbix**.

9.4.2 Des seuils d'alerte **DOIVENT** être définis pour les indicateurs vitaux (disponibilité des services, saturation ressources, échec de snapshot/réplication, perte d'un agent Wazuh). La perte de remontée d'un agent **DOIT** être traitée comme un événement de sécurité.

Article 10 — Gestion des incidents de sécurité

10.1 Définition et détection

10.1.1 Constitue un incident de sécurité tout événement portant atteinte réelle ou suspectée à la confidentialité, l'intégrité, la disponibilité ou la traçabilité du périmètre.

10.1.2 La détection s'appuie principalement sur Wazuh (alertes, SCA, FIM), la supervision Prometheus/Grafana et les logs pfSense. Toute alerte qualifiée **DOIT** être enregistrée dans le registre des incidents.

10.2 Classification et priorisation

10.2.1 Les incidents **DOIVENT** être qualifiés selon leur gravité :

Niveau	Critère	Exemple	Délai de prise en charge cible
P1 — Critique	Atteinte à un actif vital /compromission avérée	Compromission AD, contournement du chokepoint, altération de logs	Immédiat
P2 — Majeur	Atteinte significative sans compromission globale	Container privilégié non justifié, accès anormal à un partage C3	Sous quelques heures
P3 — Mineur	Anomalie localisée	Dérive de configuration SCA, échec ponctuel de snapshot	Dans le cycle courant

10.3 Réponse à incident

10.3.1 La réponse **DOIT** suivre les étapes : **détection → qualification → confinement → éradication → rétablissement → clôture**.

10.3.2 Le **confinement PEUT** s'appuyer sur le chokepoint pfSense (isolement de la VM concernée par règle de blocage), sur le firewall local de l'hôte visé lorsque le flux reste interne au segment, la désactivation de comptes compromis dans AD, ou l'arrêt du container fautif.

10.3.3 Le **rétablissement DOIT** privilégier le retour à un état sain connu via snapshot ZFS/Snapper ou restauration de sauvegarde vérifiée (Article 8).

10.3.4 Les éléments de preuve (logs, snapshots) **DOIVENT** être préservés avant toute action destructive, dans la mesure du possible.

10.4 Retour d'expérience (RETEX)

10.4.1 Tout incident P1 ou P2 **DOIT** donner lieu à un RETEX documenté : chronologie, cause racine, mesures correctives, et mise à jour éventuelle de la PSSI ou des règles de détection.

10.4.2 Les actions correctives issues du RETEX **DOIVENT** être suivies jusqu'à clôture et alimenter le cycle d'amélioration continue (Article 12).

10.5 Escalade, notification et transmission des preuves

10.5.1 Tout incident P1, ou P2 dépassant les capacités internes, **DOIT** être escaladé sans délai au RSSI, qui décide du recours à un prestataire de réponse aux incidents de sécurité qualifié par l'ANSSI (PRIS) et du signalement au **CERT-FR**.

10.5.2 Lorsqu'un incident constitue une violation de données à caractère personnel, le RSSI **DOIT** la notifier à la **CNIL dans les 72 heures** après en avoir pris connaissance (RGPD, article 33) et, en cas de risque élevé pour les personnes, les en informer (article 34).

10.5.3 Les éléments transmis aux analystes (logs exportés, captures, snapshots) **DOIVENT** être accompagnés de leur empreinte SHA-256 et d'une chronologie horodatée ; chaque manipulation (qui, quand, quoi) **DOIT** être consignée afin de préserver la chaîne de traçabilité.

10.5.4 Chaque incident **DOIT** être inscrit au journal d'incidents avec sa qualification, les actions menées et sa clôture.

Article 11 — Gestion des secrets et de la cryptographie

11.1 Gestion des secrets

11.1.1 Aucun secret ni clé NE DOIT figurer en clair dans le code, les scripts, les images de containers, les fichiers de configuration versionnés ou les logs.

11.1.2 Les secrets **DOIVENT** être gérés via un mécanisme dédié : fichiers `.env` exclus du gestionnaire de versions et à droits restreints, ou, de préférence, un **coffre-fort de secrets (Vault)**.

11.1.3 Les secrets **DOIVENT** être injectés aux services / containers au moment de l'exécution, sans persistance en clair sur disque lorsque cela peut être évité.

11.1.4 Les secrets **DOIVENT** faire l'objet d'une **rotation** régulière (au minimum tous les 90 jours) et d'une rotation immédiate en cas de suspicion de compromission ou de départ d'un intervenant.

11.1.5 Un **registre des secrets** (identifiant, propriétaire, usage, date de dernière rotation — jamais la valeur) **DOIT** être tenu à jour. Les valeurs de secrets **NE DOIVENT JAMAIS** être consignées dans ce registre ni dans la présente PSSI.

11.2 Cryptographie

11.2.1 Les communications **DOIVENT** être protégées par **TLS** dans ses versions actuelles et robustes, ou par un protocole équivalent (SSH, WireGuard) ; les protocoles et suites cryptographiques obsolètes (p. ex. SSLv3, TLS 1.0/1.1) **SONT INTERDITS**.

11.2.2 Les empreintes d'intégrité (sauvegardes, vérifications FIM) **DOIVENT** utiliser **SHA-256** ou plus robuste. Les fonctions de hachage obsolètes (MD5, SHA-1) **NE DOIVENT PAS** être utilisées à des fins de sécurité.

11.2.3 Les clés privées et certificats **DOIVENT** être stockés de manière protégée, à accès restreint, et renouvelés avant expiration.

Article 12 — Conformité, audit et amélioration continue

12.1 Conformité

12.1.1 La conformité du périmètre à la présente PSSI **DOIT** être évaluée à chaque cycle d'audit et à chaque changement structurant.

12.1.2 Les écarts (non-conformités) **DOIVENT** être enregistrés, classés par gravité, assortis d'un plan d'action et d'un responsable, et suivis jusqu'à résolution.

12.2 Audit

12.2.1 Les audits **DOIVENT** s'appuyer sur des preuves vérifiables : configurations, logs Wazuh, rapports SCA/FIM, dashboards Grafana, registres (actifs, accès, secrets, dérogations, incidents) et tests de restauration.

12.2.2 Chaque audit **DOIT** donner lieu à un **procès-verbal (PV) d'audit** daté, référencé et conservé, recensant le périmètre contrôlé, les constats, les non-conformités et les recommandations. Les PV d'audit constituent la trace de conformité opposable du laboratoire.

12.3 Cycle d'amélioration continue (PDCA)

12.3.1 Le pilotage de la sécurité **DOIT** suivre le cycle **PDCA** :

Phase	Finalité	Mise en œuvre
Plan	Planifier	Analyse de risques, définition/mise à jour des règles et objectifs
Do	Mettre en œuvre	Application des mesures (hardening, RBAC, journalisation, sauvegarde)
Check	Contrôler	Audits, SCA/FIM, revue des incidents, tests de restauration, PV d'audit
Act	Améliorer	Actions correctives, RETEX, mise à jour de la PSSI

12.3.2 Les enseignements des incidents (Article 10) et des audits **DOIVENT** alimenter la mise à jour de la PSSI, qui **DOIT** être révisée au moins une fois par an.

Annexes

Complément E.1 — Récapitulatif des adresses et rôles (plan d'adressage interne)

Hôte	Adresse	Rôle	Classification	Criticité
`pfSense`	`10.10.10.254`	Chokepoint (FW/DNS/DHCP/GW)	C2	Vitale
`Win-Server-DC`	`10.10.10.10`	AD DS / DNS / RBAC	C3	Vitale
`TrueNAS`	`10.10.10.20`	Stockage ZFS / SMB (ACL NFSv4)	C3/C2	Haute
`fedora`	`10.10.10.30`	Containers Podman rootless /Prometheus / Grafana / Zabbix	C1	Moyenne
`wazuh-siem`	`10.10.10.40`	SIEM Wazuh 4.14 (SCA/FIM)	C2	Haute

Hôte	Adresse	Rôle	Classification	Criticité
TeneT	hôte physique	Hyperviseur Fedora 44 / Cockpit /KVM-libvirt	C2	Vitale

Complément E.2 — Synthèse des interdits majeurs

Interdit	Article de référence
`chmod 777` / écriture monde sur fichiers et datasets	Art. 7.1.3, 8.2.2
Container root / privilégié sans dérogation	Art. 7.2.2
Exposition d'un port < 1024 sans justification	Art. 7.2.2
Secret ou clé en clair dans code / image / config / logs	Art. 11.1.1
Contournement du chokepoint pfSense	Art. 6.1.2
Flux non explicitement autorisé (deny by default)	Art. 6.2
Protocoles d'administration en clair (HTTP/Telnet)	Art. 6.4.2
Protocoles / hachages cryptographiques obsolètes	Art. 11.2
Comptes génériques partagés (hors comptes de service recensés)	Art. 5.1.3
Mots de passe par défaut non modifiés	Art. 5.5.3
Service DHCP autre que pfSense	Art. 6.5.2

Complément E.3 — Registres obligatoires à tenir

Registre	Contenu	Article
Inventaire des actifs	Actifs, propriétaires, classification, criticité	Art. 4
Registre des accès	Comptes, groupes, droits, revues	Art. 5
Registre des secrets	Identifiant, propriétaire, usage, dernière rotation (jamais la valeur)	Art. 11.1.5
Registre des dérogations	Dérogations actives, motif, échéance, validation	Art. 1.3.2
Registre des incidents	Incidents, gravité, traitement, RETEX	Art. 10
PV d'audit	Constats, non-conformités, recommandations	Art. 12.2.2

Complément E.4 — Historique des révisions

Date	Auteur	Objet
2026-10-04	RSSI	Création et publication initiale de la PSSI du laboratoire « Hybrid InfraSec »
2026-10-11	RSSI	Flux de l'accès distant WireGuard et de la supervision SNMP ajoutés à la matrice (6.2.3), flux de métriques et de partage alignés sur l'existant ; mise en œuvre 3-2-1-0 et RPO précisés (8.3.1, 8.4.1) ; état du raccordement au SIEM et supervision SNMP (9.1.1, 9.4.1) ; protocoles chiffrés admis (2.3.1, 11.2.1) ; filtrage intra-segment précisé (1.2.2, 6.1.1, 6.3.1, 10.3.2)

Fin du document — PSSI-HIS-2026-01 — Diffusion restreinte.

Annexe F · Rapport de gel et de hardening

Projet : Hybrid InfraSec — laboratoire Zero-Trust

Date : 04/10/2026

Opérateur : admin

Objet : figer la configuration validée du laboratoire et consigner le hardening issu de l'audit (PV-02), en bouclant la chaîne **audit → traitement → preuve**.

1. Hardening appliqué — nœud fedora (.30) Mesures appliquées en réponse aux constats Lynis de l'audit PV-02 :

Constat	Mesure appliquée	Détail
F-07	Hardening SSH	`PermitRootLogin no`, `AllowTcpForwarding no`, `ClientAliveInterval 300`, `ClientAliveCountMax 2`, `LogLevel VERBOSE`, `MaxAuthTries 3`, `X11Forwarding no` (drop-in `/etc/ssh/sshd_config.d/99-hardening.conf`, config validée par `sshd -t`)
F-08	Politique de mots de passe + umask	`PASS_MAX_DAYS 90`, `PASS_MIN_DAYS 1`, `PASS_WARN_AGE 7`, `UMASK 027` (`/etc/login.defs`)
F-09	Désactivation de protocoles inutiles	`dccp`, `sctp`, `rds`, `tipc` neutralisés (`/etc/modprobe.d/99-disable-protocols.conf`)
F-10	Désactivation du stockage amovible	`usb-storage` neutralisé (`/etc/modprobe.d/99-usb-storage.conf`)
—	Restriction des core dumps	`* hard core 0` (`/etc/security/limits.d/99-coredump.conf`)
F-11	Mises à jour automatiques	`dnf5-automatic.timer` activé
F-05	Fermeture du port node-exporter	Port `9100/tcp` retiré du firewall (Prometheus interroge en local — exposition réseau inutile)

Résultat — indice de hardening Lynis

État	Indice
Avant hardening (audit PV-02)	**69 / 100**
Après hardening	**76 / 100**

Les mesures de type blacklist de modules (protocoles, USB) ne se traduisent pleinement qu'après redémarrage : l'indice progressera encore au prochain cycle.

2. Traitement des constats réseau (décisions de risque) Certains constats ne sont **pas corrigés en direct** avant la soutenance car ils affectent les chemins d'administration/démonstration. Conformément à la démarche EBIOS RM (atelier 5), chacun fait l'objet d'une **décision de traitement explicite** :

Constat	Décision	Justification / échéance
F-01 — IP d'administration del'hyperviseur sur le segment	**Risque accepté temporairement + mesure compensatoire**	C'est l'unique voie d'accès aux interfaces de gestion depuis le poste opérateur. Remédiation cible : **administration hors-bande** (réseau/bastion dédié). Mesure compensatoire actuelle : segment isolé, opérateur unique, supervision Wazuh active (l'incident PV-03 a prouvé la détection).
F-02 — admin pfSense en HTTP :80	**Planifié**	Forcer HTTPS, désactiver l'écoute :80, restreindre la source de gestion. À appliquer après la répétition de la démonstration.
F-03 — RDP ouvert sur le DC	**Planifié**	RDP non utilisé (administration par console/Cockpit). Désactivation ou restriction de la source.
F-04 — WS-Discovery sur TrueNAS	**Planifié**	Désactivation du service si non requis.
F-06 — plan d'administration joignable depuis tout le segment	**Planifié**	Restriction à un poste/bastion d'administration (principe Zero-Trust).

3. Posture de gel

- **Secrets** — rotation du mot de passe `admin` de Wazuh à effectuer via `/usr/share/wazuh-indexer/plugins/opensearch-security/tools/wazuh-passwords-tool.sh` (le mot de passe généré à l'installation ne figure dans aucun livrable).
- **WAN** — pfSense bloque par défaut les connexions entrantes depuis le WAN (filtrage « deny by default ») ; à confirmer avant gel définitif.
- **Intégrité du dossier** — registre d'empreintes SHA-256 établi (voir `Registre-Integrite-SHA256`).
- **Snapshots de gel** — à prendre sur l'ensemble des VM après hardening (`virsh snapshot-create-as ... freeze-YYYYMMDD`) + point Snapper hôte.
- **Diffusion** — aucun secret, IP publique, MAC réelle ou donnée personnelle dans les livrables (plan RFC 1918).

Mise à jour du 11/10/2026 (PV-04, annexe O). Les snapshots de gel `gel-20261011` ont été pris sur les cinq VM, avec les points Snapper de l'hôte ; la capture côté WAN ne montre que le trafic UDP 51820 du tunnel. La rotation du mot de passe `admin` de Wazuh reste à effectuer.

4. Conclusion Le hardening issu de l'audit est **appliqué et mesuré** (indice Lynis 69 → 76 sur fedora, port node-exporter fermé). Les constats réseau résiduels font l'objet de décisions de traitement tracées, cohérentes avec l'analyse EBIOS RM et la PSSI. La boucle **audit (PV-02) → analyse de risque (EBIOS) → incident/détection (PV-03) → hardening (présent rapport)** est complète et documentée.

Annexe G · Procès-verbal de sauvegarde et de restauration (PV-01)

Projet : Hybrid InfraSec — laboratoire Zero-Trust

Actif protégé : partage de fichiers SMB `partage` (jeu de données `tank/partage`), hébergé sur TrueNAS SCALE 25.10 (10.10.10.20), joint au domaine `infrasec.local`.

Date du test : 04/10/2026

Opérateur : admin

1. Objectif Démontrer la mise en œuvre de la règle de sauvegarde **3-2-1-0** et la capacité de restauration vérifiée des données, avec mesure du temps de reprise (RTO) et preuve d'intégrité.

Rappel de la règle **3-2-1-0** :

- **3** copies des données ;
- **2** supports de stockage différents ;
- **1** copie hors-site ;
- **0** erreur (restauration vérifiée).

2. Architecture de sauvegarde mise en place

Copie	Emplacement	Nature	Protection assurée
1 — Production	`tank/partage` (pool ZFS en miroir, 2 disques)	Données vivantes	Panne d'un disque (miroir ZFS)
2 — Snapshots	`tank/partage@auto-*`	Snapshots ZFS horodatés, immuables	Suppression / corruption / rançongiciel
3 — Réplication	`tank/partage_backup`	Flux ZFS répliqué (`zfs send | zfs recv`)	Perte du jeu de données source ; cible hors-site en production

Automatisation : tâche de snapshot périodique TrueNAS — jeu `tank/partage`, fréquence **horaire**, rétention **2 semaines**, schéma de nommage `auto-%Y-%m-%d_%H-%M` (compatible « Versions précédentes » Windows via SMB).

Intégrité native : le système de fichiers ZFS calcule une somme de contrôle sur chaque bloc (détection et correction d'erreur silencieuse), complétée par un *scrub* planifié du pool.

3. Déroulé du test de restauration

3.1. Données de référence (avant sinistre) Trois fichiers témoins créés dans le partage, puis empreinte SHA-256 enregistrée :

```
0b039914e2e1bcaee135e56ea7e827256326018cea19f6b71ca36e4e52e4f9b6
RESTORE-TEST/archive.bin
9df323f5008be2b99674fe9aa717f2442bcbbe295b6783df136436835ccbd05a
RESTORE-TEST/clients.csv
fd14fe25efccb093c98c124872639d771444292a9f302e177529163bf6a6eb87
RESTORE-TEST/rapport-q3.txt
```

Snapshot de référence pris : `tank/partage@auto-2026-10-04_15-09-02`.

3.2. Simulation de sinistre et restauration

Étape	Horodatage	Action
T1 — Sinistre	04/10/2026 15:10:35 CEST	Suppression complète de `RESTORE-TEST` (`rm -rf`) — données perdues
T2 — Restauration	04/10/2026 15:10:35 CEST	Restauration depuis le snapshot ZFS (`/.zfs/snapshot/.../RESTORE-TEST`)

3.3. Vérification d'intégrité (après restauration)

```
RESTORE-TEST/archive.bin: OK
RESTORE-TEST/clients.csv: OK
RESTORE-TEST/rapport-q3.txt: OK
```

3.4. Vérification de la copie répliquée (copie 3)

```
RESTORE-TEST/archive.bin: OK
RESTORE-TEST/clients.csv: OK
RESTORE-TEST/rapport-q3.txt: OK
```

4. Résultats

Indicateur	Résultat
RTO (temps de reprise, niveau fichier)	**< 1 seconde**
RPO (perte de données max.)	≤ 1 heure (fréquence des snapshots)
Intégrité après restauration	**0 erreur** — 3/3 empreintes SHA-256 conformes
Intégrité de la copie répliquée	**0 erreur** — 3/3 empreintes SHA-256 conformes
Nombre de copies vérifiées	3 (production + snapshot + réplication)

Conclusion : la règle 3-2-1-0 est mise en œuvre dans son principe — en laboratoire, la copie répliquée réside sur le même pool, si bien que les critères « 2 supports » et « 1 copie hors site » ne sont atteints qu'en production (voir §5) — et la restauration est prouvée, vérifiée et chronométrée.

5. Limites et axes d'amélioration (honnêteté technique)

- **ACL NFSv4 :** la restauration par `cp` a généré des avertissements « preserving permissions : Operation not permitted » — le contenu est intact (SHA-256 conforme), mais les ACL ne sont pas reportées par `cp`. En production, privilégier une restauration préservant les ACL (`rsync -A`, ou le mécanisme natif « Versions précédentes » de Windows exposé par SMB).
- **Hors-site réel :** dans ce laboratoire mono-NAS, la copie 3 réside sur le même pool. En production, la tâche de réplication ZFS cible un **TrueNAS distant sur un autre site** (le mécanisme `zfs send/recv` démontré est identique).
- **Immuabilité renforcée :** envisager des snapshots en rétention verrouillée (protection anti- rançongiciel) pour la copie 2.

6. Preuves associées

- Tâche de snapshot périodique TrueNAS (capture d'écran).
- Journal console du test de restauration (T1/T2, empreintes, RTO).
- Jeux de données `tank/partage` et `tank/partage_backup` (sortie `zfs list`).

Annexe H · Support de sensibilisation et action de formation courte

Projet : Hybrid InfraSec — société INFRASEC

Référence : SENS-2026-01

Date : 04/10/2026 · mise à jour le 05/10/2026 (consigne sur le code QR, après INC-04)

Auteur : admin (administrateur d'infrastructures sécurisées)

Public : utilisateurs INFRASEC (administratifs, télétravailleurs) et équipe technique

Cadre : déclinaison opérationnelle de la PSSI — critère de performance CP9 (sensibiliser les utilisateurs, préparer et animer une action de formation courte)

Partie 1 — Fiche de l'action de formation courte

Élément	Contenu
Intitulé	Les bons réflexes de sécurité au quotidien
Objectif pédagogique	À l'issue, chaque participant sait reconnaître un courriel d'hameçonnage, gérer un mot de passe robuste, utiliser l'accès distant sécurisé et signaler un incident.
Public visé	Deux groupes : utilisateurs métier (sensibilisation) et équipe technique (montée en compétences).
Durée	45 minutes (30 min de contenu + 15 min d'échanges / cas pratiques).
Modalité	Présentiel ou visioconférence, support projeté + fiche mémo distribuée.
Pré-requis	Aucun pour le groupe utilisateurs.
Évaluation	Quiz de 5 questions en fin de séance + exercice d'hameçonnage simulé à J+30.
Fréquence	À l'embauche, puis rappel annuel et après tout incident significatif.

Partie 2 — Support de sensibilisation (contenu diffusé aux utilisateurs)

1. Mots de passe et authentification Un mot de passe faible est la première porte d'entrée d'un attaquant. La politique INFRASEC (PSSI) impose :

- une **phrase de passe** longue (au moins 14 caractères, comme l'exige la PSSI, idéalement une suite de mots) plutôt qu'un mot court et complexe ;
- un mot de passe **différent par service** — jamais le même pour la messagerie et le domaine ;
- l'usage d'un **gestionnaire de mots de passe** pour ne pas les mémoriser ni les noter ;
- **ne jamais** communiquer son mot de passe, même à un collègue ou à un « support technique » qui le demande (aucun service légitime ne le demande).

L'authentification de l'accès distant repose sur une **clé par appareil** : votre poste est reconnu individuellement. La cible d'évolution ajoute une **authentification multifacteur (MFA)**.

2. Hameçonnage (phishing) L'hameçonnage reste le vecteur d'attaque le plus courant. Avant de cliquer :

- vérifier l'**adresse réelle de l'expéditeur** (pas seulement le nom affiché) ;
- se méfier de l'**urgence** et de la **menace** (« votre compte sera suspendu ») — ce sont des leviers de manipulation ;

- survoler un lien pour voir l'**URL réelle** avant de cliquer ; ne jamais saisir ses identifiants depuis un lien reçu par courriel ;
- ne pas ouvrir de **pièce jointe inattendue**, surtout les fichiers exécutables ou les documents demandant d'« activer les macros ».

En cas de doute : **ne pas cliquer, signaler** (voir §5).

3. Poste de travail et accès distant

- **Verrouiller sa session** dès que l'on quitte son poste (bureau propre, écran verrouillé).
- Ne pas brancher de **support USB** inconnu — le stockage amovible est neutralisé sur les serveurs pour cette raison.
- En **télétravail**, se connecter uniquement via le **VPN d'entreprise (WireGuard)** avant d'accéder aux ressources internes ; ne jamais exposer un partage de fichiers sur un réseau public.
- Le **code QR de configuration** remis à l'enrôlement contient votre clé secrète : le lire **uniquement avec l'application WireGuard**, jamais avec l'appareil photo ou un assistant, qui peuvent en transmettre le contenu à des services en ligne. En cas d'erreur, prévenir immédiatement le référent technique : la clé sera révoquée et remplacée (cas réel traité, INC-04).
- **Appareil perdu ou volé** : le signaler sans délai — l'accès de cet appareil est révoqué à distance en quelques minutes.
- Chaque profil n'accède qu'à ce dont il a besoin (**moindre privilège**) : un accès refusé n'est pas un dysfonctionnement, c'est la politique.

4. Protection des données (RGPD)

- Ne traiter des **données à caractère personnel** que dans le cadre de son activité et sur les espaces prévus (partage AD dédié).
- Ne pas copier de données sensibles sur un support personnel ou un service cloud non validé.
- Signaler toute **perte ou fuite** de données suspectée — un incident RGPD doit être qualifié rapidement.

5. Signaler un incident Un incident signalé tôt coûte beaucoup moins cher qu'un incident découvert tard. **Que faire :**

1. Ne pas tenter de « réparer » seul ni d'effacer les traces.

2. Noter l'heure, ce qui a été observé, les éventuels messages.

3. **Prévenir immédiatement** le référent technique (point de contact unique).

4. Isoler le poste si demandé (débrancher le réseau), sans l'éteindre si on vous le demande (préservation des preuves).

Le dispositif de détection (SIEM Wazuh) surveille l'infrastructure en continu : un signalement humain **complète** la détection technique, il ne la remplace pas.

Partie 3 — Quiz d'évaluation (5 questions) 1. Un courriel « urgent » de la DSI vous demande votre mot de passe pour « vérification ». Que faites-vous ?

2. Quelle est la différence entre un bon et un mauvais mot de passe ?

3. Avant d'accéder à un partage interne depuis chez vous, que devez-vous activer ?

4. Vous trouvez une clé USB sur le parking. Que faites-vous ?

5. Vous pensez avoir cliqué sur un lien d'hameçonnage. Quelles sont les deux premières choses à faire ?

(Corrigé remis à l'animateur ; réponses attendues conformes aux §1 à §5.)

Support de sensibilisation et fiche de formation courte — Project Hybrid InfraSec · société fictive INFRASEC · dossier AIS (CCP3 / CP9).

Annexe I · Procès-verbal de détection d'incident et RETEX (PV-03)

Projet : Hybrid InfraSec — laboratoire Zero-Trust

Scénario : attaque par force brute SSH détectée par le SIEM Wazuh

Date : 04/10/2026

Opérateur / analyste : admin

Chaîne de détection : agent Wazuh (fedora) → gestionnaire Wazuh (wazuh-siem .40) → dashboard

1. Objectif Démontrer la capacité du SIEM à **détecter, corréler et qualifier** une attaque réelle, et formaliser la chaîne **détection → réponse → RETEX**. L'exercice relie volontairement l'attaque à un constat de l'audit PV-02 (**F- 01**) afin de prouver l'enchaînement audit → risque → incident.

2. Scénario d'attaque (simulation maîtrisée)

Élément	Valeur
Technique	Force brute SSH / password guessing
MITRE ATT&CK	**T1110** (Brute Force), **T1110.001** (Password Guessing), **T1021.004** (Remote Services : SSH), **T1078** (Valid Accounts)
Source	`10.10.10.2` — adresse d'administration de l'hyperviseur présente sur le segment (**constat PV-02 F-01**)
Cible	`fedora` (10.10.10.30), service SSH (port 22)
Charge	15 tentatives d'authentification avec le compte inexistant `hacker`
Horodatage	04/10/2026 à 19:17:58 CEST

Commande utilisée (poste attaquant) :

```
for i in $(seq 1 15); do ssh -o BatchMode=yes -o ConnectTimeout=3 hacker@10.10.10.30
true; done
```

Le choix de la source `10.10.10.2` est significatif : il exploite précisément la faiblesse identifiée à l'audit (plan d'administration de l'hyperviseur joignable depuis le segment de production). L'audit a donc directement anticipé le vecteur d'attaque.

3. Détection (Wazuh)

Événements unitaires — règle **5710** « sshd: Attempt to login using a non-existent user », **niveau 5**, agent `fedora`, **15 occurrences** horodatées à 19:17:58 (concordance exacte avec les 15 tentatives émises).

Corrélation — pic d'alerte de **niveau 10** à 19:18 (règle de corrélation Wazuh 5712 : force brute sur un compte inexistant, huit échecs en deux minutes), consolidant les échecs répétés en un événement unique de sévérité élevée.

Qualification automatique MITRE ATT&CK — le dashboard « Threat Hunting » classe l'activité sous **Brute Force**, **Password Guessing**, **SSH** et **Valid Accounts**.

Indicateurs du dashboard (fenêtre 15 min) :



Indicateur	Valeur
Échecs d'authentification	**15**
Alertes de niveau ≥ 10	pic à 19:18 (corrélation force brute)
Agent concerné	`fedora` (10.10.10.30)
Délai de détection	temps réel (< 1 min entre l'attaque et l'alerte)

Preuves : captures du dashboard Threat Hunting (MITRE + évolution des niveaux) et de la liste des événements filtrée sur `agent.name: fedora` *(règle 5710 ×15).*

4. Réponse à incident (procédure)

Phase	Action
Identification	Alerte Wazuh niveau 10 (force brute SSH) sur `fedora`, source `10.10.10.2`.
Confinement	Blocage de la source sur l'hôte ciblé (firewall local `firewalld` du nœud `fedora`) : la source et la cible appartiennent au même segment, le flux ne transite donc **pas** par pfSense, qui ne peut pas le filtrer. La réponse active de Wazuh (`firewall-drop`) automatise ce blocage sur l'agent ; son activation permanente est retenue au RETEX.
Éradication	Traitement de la cause racine : le retrait de l'adresse d'administration `10.10.10.2` du segment (constat F-01) est décidé, puis requalifié au gel en **risque accepté temporairement avec mesure compensatoire**, dans l'attente d'un réseau d'administration dédié (mesure M-01). Hardening SSH appliqué sur la cible (F-07 : connexion root interdite, trois tentatives au maximum, délais d'inactivité, journalisation détaillée) ; l'authentification par clé seule est retenue en amélioration.
Récupération	Vérification de l'intégrité du service (aucun accès réussi — compte `hacker` inexistant, 0 compromission) ; retour à l'exploitation nominale.
Capitalisation	Rédaction du présent RETEX et mise à jour de la PSSI / du plan de hardening.

Résultat : aucune compromission (toutes les tentatives ont échoué sur un compte inexistant). L'incident est resté au stade de la tentative, **détecté en temps réel**.

5. RETEX — Retour d'expérience

Ce qui a bien fonctionné

- La chaîne de détection est **opérationnelle de bout en bout** : l'agent a remonté les logs, le gestionnaire a corrélé, le dashboard a qualifié l'attaque et l'a mappée sur MITRE ATT&CK — le tout en temps réel.
- La supervision **multi-sources** (Wazuh SIEM + SCA + logs système) offre une visibilité immédiate sur l'activité suspecte.
- L'exercice **valide la pertinence de l'audit** : le vecteur exploité (F-01) avait été identifié et coté avant l'incident.

Axes d'amélioration identifiés

- **Automatiser la réponse** : activer l'*active response* Wazuh pour bannir automatiquement les sources de force brute (réduction du temps de réaction).
- **Réduire la surface** : restreindre SSH à un poste/bastion d'administration (principe Zero-Trust) et passer à l'authentification par clé + MFA.
- **Traiter la cause racine** : retirer le plan d'administration de l'hyperviseur du segment de production (F-01) — priorité de la phase de gel.
- **Enrichir la détection** : ajouter des règles/seuils adaptés et des dashboards dédiés aux tentatives d'accès.

Enseignement principal Un constat d'audit non traité (F-01) constitue un **chemin d'attaque réel et exploitable.** La boucle **audit → analyse de risque (EBIOS) → détection (SIEM) → remédiation (hardening)** est ici démontrée de façon complète et cohérente.

6. Traçabilité

Référentiel	Correspondance
MITRE ATT&CK	T1110, T1110.001, T1021.004, T1078
Constat d'audit lié	PV-02 / F-01 (IP d'administration sur le segment)
Analyse de risque	EBIOS RM — scénario opérationnel SO-3 « rebond depuis le plan d'administration vers l'hyperviseur »
Mesure PSSI	Articles 5 (identités et accès), 6 (sécurité réseau et cloisonnement) et 10 (gestion des incidents)

Annexe J · Journal des incidents techniques et de sécurité

Registre des incidents rencontrés pendant la construction du laboratoire et de leur résolution. Chaque entrée sert de preuve de diagnostic et de maîtrise technique (CCP2 / CCP3). Les fiches sont numérotées dans l'ordre chronologique de survenue.

INC-01 — Échec d'amorçage de l'ISO d'installation (VM TrueNAS)

Date : 02/10/2026

Actif concerné : VM `truenas` (hyperviseur Fedora 44 / KVM-libvirt, gérée via Cockpit)

Symptôme La VM reste bloquée sur le menu du micrologiciel OVMF « Please select boot device » ; l'image ISO TrueNAS SCALE 25.10.7 ne démarre pas. Dans la console graphique (noVNC) de Cockpit, les flèches directionnelles fonctionnent mais la touche **Entrée** n'est pas transmise à la machine virtuelle. La VM finit par s'arrêter d'elle-même.

Diagnostic

1. L'amorçage UEFI (OVMF) ne sélectionne pas automatiquement le lecteur CD malgré un ordre d'amorçage « CD en premier ».

2. La console web ne relaie pas de façon fiable la touche Entrée → impossible de valider l'entrée surlignée.

3. L'injection de touche côté hôte (`virsh send-key … KEY_ENTER`) échoue par intermittence car la VM n'est plus en cours d'exécution au moment de la commande (« domain is not running »).

Cause racine Combinaison défavorable : micrologiciel **OVMF/UEFI** (autosélection de firmware + NVRAM persistant conservant un ordre d'amorçage périmé) et **limite de transmission clavier** de la console noVNC de Cockpit.

Résolution Bascule du micrologiciel de la VM d'**UEFI vers BIOS (SeaBIOS)** :

- suppression du bloc `<firmware>` (autosélection + secure-boot), de l'élément `<loader>` et de l'élément `<nvram>` ;
- retrait de l'attribut `firmware='efi'` de la section `<os>` ;
- redéfinition de la VM (`virsh define`) puis démarrage.

SeaBIOS amorce directement le CD et lance l'installateur TrueNAS, sans menu intermédiaire ni saisie clavier requise.

Preuve Capture d'écran de l'écran « TrueNAS 25.10.7 Console Setup » obtenu après bascule ; horodatage 02/10/2026 12:07.

Enseignement Pour les VM de laboratoire administrées via la console web de Cockpit, privilégier le micrologiciel **SeaBIOS** lorsque l'installation passe par une interaction clavier dans la console : l'amorçage de média amovible y est plus fiable et évite la dépendance à la transmission de touches spéciales.

INC-02 — Échec de la jonction Active Directory (horloge puis mot de passe)

Date : 02/10/2026

Actif concerné : VM `truenas` (10.10.10.20) — jonction au domaine `infrasec.local`

Symptôme 1 À la validation, erreur : « Time offset from the domain controller exceeds the maximum permitted value ». La jonction est refusée.

Diagnostic 1 Comparaison des horloges depuis l'hyperviseur (`virsh domtime`) : TrueNAS est à l'heure UTC correcte ; le contrôleur de domaine `DC01` présente un décalage UTC supérieur à 5 minutes. Cause : fuseau horaire du DC mal réglé, son heure UTC effective était décalée. Kerberos impose un écart maximal de 5 minutes.

Résolution 1 Correction du fuseau horaire et de l'heure sur `DC01` (UTC+1 Paris, heure d'été active), ce qui aligne son heure UTC sur l'heure réelle et sur TrueNAS. Configuration complémentaire de la synchronisation NTP du DC vers le firewall pfSense (autorité de temps du segment).

Symptôme 2 Nouvelle erreur : « The bind password is not correct. »

Diagnostic 2 Le mot de passe du compte de jonction était saisi dans une disposition clavier différente de celle utilisée lors de sa définition (US QWERTY vs FR AZERTY), produisant une chaîne différente.

Résolution 2 Réinitialisation du mot de passe du compte de jonction avec des caractères dont la position est identique sur les deux dispositions (caractères neutres), puis saisie vérifiée à l'affichage.

Preuve Statut Active Directory : **HEALTHY** — royaume `INFRASEC.LOCAL` , keytab `AD_MACHINE_ACCOUNT` créé, cache des comptes activé.

Enseignement Pour toute jonction Kerberos : (1) synchroniser l'heure de tous les membres sur une source unique (NTP depuis le DC ou le chokepoint) avant la jonction ; (2) pour les comptes de service multi-plateformes, éviter les caractères sensibles à la disposition clavier.

INC-03 — Supervision Windows : collecteurs obsolètes et dashboard incompatible

Date : 04/10/2026

Actif concerné : VM `Win-Server-DC` (10.10.10.10) — agent `windows_exporter` v0.31.8 ; serveur Prometheus/Grafana sur `fedora` (10.10.10.30)

Contexte Déploiement de l'exportateur de métriques `windows_exporter` sur le contrôleur de domaine pour supervision par Prometheus et visualisation Grafana. Installation via script distribué par serveur HTTP temporaire (contournement de la limitation copier-coller de la console web noVNC).

Symptôme 1 — service arrêté Après installation du MSI, le service `windows_exporter` reste à l'état **Stopped** ; `Start-Service` ne renvoie pas d'erreur mais le service se termine aussitôt.

Diagnostic 1 Exécution en avant-plan pour capturer l'erreur : `couldn't enable collectors" err="unknown collector cs"` , puis `unknown collector logon` . Les collecteurs `cs` (computer-system) et `logon` ont été supprimés dans les versions récentes ; le jeu demandé contenait des noms obsolètes.

Cause racine 1 Dérive de version (version drift) : noms de collecteurs non valides dans windows_exporter 0.31.8. Le service échoue dès qu'un collecteur inconnu est demandé.

Résolution 1 Script de déploiement auto-correctif : test itératif du jeu de collecteurs, suppression automatique de tout collecteur signalé « unknown », puis reconfiguration de l' `ImagePath` du service (registre) avec le jeu validé et redémarrage. Jeu final : `cpu, logical_disk, net, os, service, system, memory, process, tcp, ad, dns` (dont `ad` et `dns` , spécifiques au rôle contrôleur de domaine).

Symptôme 2 — dashboard « No data » Cible Prometheus `windows-dc` à l'état **UP** (scrape 26 ms), mais le dashboard Grafana ID 14694 n'affiche aucune donnée ; la variable « Server » reste vide (triangle d'alerte).

Diagnostic 2 Deux causes cumulées : (a) nom de tâche Prometheus `windows-dc` au lieu de la convention `windows` attendue ; (b) dashboard 14694 (publié en 2021) construit sur les métriques `windows_cs_*` fournies par le collecteur `cs` désormais supprimé — la variable d'instance ne peut donc plus se peupler.

Résolution 2 (a) Alignement du nom de tâche Prometheus sur `windows` et rechargement du service. (b) Remplacement du dashboard par un modèle à jour, explicitement compatible windows_exporter v0.31+ (Grafana ID 23942), avec liaison correcte de la source de données Prometheus à l'import.

Preuve Dashboard « Windows Exporter Dashboard 2025 » affichant l'ensemble des métriques du contrôleur de domaine DC01 : CPU, mémoire (5,93 Gio totale / 3,65 Gio libre), espace disque, réseau VirtIO, E/S disque, état des services, nombre de processus et de threads.

Enseignement (1) Ne jamais présumer la stabilité des noms de collecteurs/métriques entre versions d'un exportateur ; industrialiser le déploiement par script idempotent et auto-correctif. (2) Vérifier la compatibilité de version d'un dashboard communautaire avec la version de l'exportateur avant de conclure à une erreur de configuration. (3) Respecter les conventions de nommage des tâches (`job`) attendues par l'écosystème d'outils.

INC-04 — Incident de sécurité : exposition de la clé privée d'un accès administrateur

Date : 05/10/2026

Actif concerné : peer WireGuard `admin-remote` (`10.10.20.2`) — accès distant au plan d'administration ; firewall `fw01`

Fait générateur Lors de l'enrôlement du smartphone, le code QR de configuration du profil administrateur a été lu avec l'application **appareil photo** du téléphone au lieu de l'application WireGuard. Ce code contient la configuration complète du client, **clé privée comprise**. L'appareil photo a transmis son contenu à un service de recherche visuelle en ligne : la clé privée a quitté l'appareil et a été communiquée à un tiers.

Qualification Incident de sécurité réel — atteinte à la **confidentialité d'un secret d'authentification** rattaché à un profil à privilèges (accès au plan d'administration). L'exploitation suppose aussi d'atteindre le point de terminaison du tunnel, ce qui en réduit la vraisemblance dans le laboratoire ; la clé est néanmoins traitée comme **compromise**, selon le principe : *un secret exposé est un secret compromis*, sans attendre la preuve d'une exploitation.

Confinement Retrait immédiat de l'ancienne clé publique du peer `admin-remote` sur le firewall : la clé exposée n'ouvre plus aucun tunnel, quel que soit son détenteur.

Éradication et rétablissement Génération d'une **nouvelle paire de clés** (rotation), déclaration de la nouvelle clé publique sur le peer, production d'un nouveau code QR, enrôlement refait **exclusivement** avec l'application WireGuard. Vérification : la négociation aboutit avec la nouvelle clé ; le firewall ne connaît plus l'ancienne.

Préservation des éléments Chronologie et captures d'écran conservées hors ligne. Aucun élément de clé privée — ni l'ancienne ni la nouvelle — ne figure dans un livrable ; seules les clés publiques sont référencées.

Enseignements (RETEX)

(1) Un code QR de configuration WireGuard **est un secret** : il porte la clé privée du client. (2) Il ne se lit qu'avec l'application WireGuard ; les applications d'appareil photo et les assistants peuvent transmettre le contenu lu à des services en ligne. (3) La révocation par retrait de clé publique a fonctionné comme prévu : l'exigence EF5 du cahier des charges (révocation centralisée et immédiate) est démontrée **en situation réelle**. (4) Mesure organisationnelle : consigne ajoutée au support de sensibilisation et au transfert de compétences. Mesure technique envisagée : distribuer la configuration par fichier sur un canal chiffré et n'afficher le code QR que le temps de l'enrôlement.

INC-05 — Test d'accès distant faussé par la présence de l'hyperviseur sur le segment

Date : 06/10/2026

Actif concerné : banc de test de l'accès distant — hyperviseur `TeneT`

Symptôme Un premier test du profil collaborateur a été lancé depuis l'hyperviseur, utilisé comme client WireGuard. L'outil de connexion a refusé d'ajouter la route du tunnel (`RTNETLINK answers: File exists`) et le test de connexion vers le partage a pourtant **réussi**.

Diagnostic L'hyperviseur possède déjà une adresse et une route **directes** vers le segment `10.10.10.0/24` — c'est le constat d'audit **F-01**. Le flux n'empruntait donc pas le tunnel : le test « réussissait » sans rien prouver sur l'accès distant ni sur le cloisonnement.

Résolution Le client de test a été isolé dans un **espace de noms réseau** dédié, sans aucune route vers le segment interne : tout flux vers `10.10.10.0/24` y passe obligatoirement par le tunnel. Ce banc a permis de valider la négociation et de localiser le défaut de routage par clé (INC-06). La validation de bout en bout définitive est portée par un poste client distinct placé côté WAN.

Enseignement (1) Un test d'accès distant doit partir d'un poste **réellement extérieur** au réseau protégé ; sinon il mesure le mauvais chemin. (2) Le constat F-01 n'est pas théorique : il a ici **faussé un test**, comme il a servi de source à l'attaque simulée de PV-03. Il confirme la priorité de la mesure M-01 (réseau d'administration dédié).

INC-06 — WireGuard : plan de données rompu par des « Allowed IPs » dupliquées (cryptokey routing)

Date : 06/10/2026

Actif concerné : firewall `fw01` (pfSense CE, paquet WireGuard) — tunnel `tun_wg0` (10.10.20.0/24), peers `employe-remote` (10.10.20.3) et `admin-remote` (10.10.20.2)

Symptôme Le handshake WireGuard s'établit correctement (échange bidirectionnel d'octets, tunnel « vert »), mais aucune connexion TCP issue du client distant `employe-remote` (10.10.20.3) vers le partage SMB de TrueNAS (10.10.10.20:445) n'aboutit : `nc -zv -w3 10.10.10.20 445` renvoie systématiquement `TIMEOUT`. La capture de paquets sur l'interface LAN du firewall montre que le `SYN` du client est bien relayé jusqu'à TrueNAS, qui répond par un `SYN-ACK` — mais ce `SYN-ACK` est retransmis en boucle et ne repart jamais dans le tunnel vers le client.

Diagnostic

1. Le handshake fonctionnel écarte un problème de clés ou d'endpoint.

2. La capture LAN prouve que la règle de filtrage Zero-Trust autorise bien le flux et que le serveur de destination répond : le problème est localisé sur le **chemin de retour** du firewall vers le tunnel.

3. Inspection de l'onglet **VPN → WireGuard → Peers** : les deux peers portaient la même valeur **Allowed IPs =** `10.10.20.2/32` . Aucun peer ne « possédait » l'adresse `10.10.20.3` utilisée par le client employé.

Cause racine Erreur de configuration du **routage par clé (cryptokey routing)**. Dans WireGuard, le champ *Allowed IPs* côté serveur assure deux fonctions : (a) une liste de contrôle d'accès (quelles adresses sources sont acceptées depuis ce peer) et (b) une **table de routage interne** (vers quel peer chiffrer un paquet selon son adresse de destination). L'adresse `10.10.20.3` n'étant déclarée sur aucun peer, pfSense était incapable de déterminer vers quel peer chiffrer le `SYN-ACK` de retour → paquet abandonné. S'ajoutait une **collision** (deux peers revendiquant `10.10.20.2`), que pfSense signale explicitement : « traffic to the conflicting networks will only be routed to the last peer in the list ». Le handshake ne dépendant que des clés et de l'endpoint, le tunnel apparaissait sain malgré un plan de données rompu — piège classique.

Résolution Correction du champ *Allowed IPs* du peer `employe-remote` en `10.10.20.3/32` (peer `admin-remote` conservé en `10.10.20.2/32`), garantissant l'unicité des plages entre peers. Enregistrement (*Save Peer*) puis application (*Apply*). Vérification sur la liste des peers : `employe-remote → 10.10.20.3/32` , `admin-remote → 10.10.20.2/32` .

État / portée Correction appliquée et vérifiée au niveau de la configuration. Le test de bout en bout réalisé depuis le **banc de validation par espace de noms réseau (netns)** sur l'hyperviseur reste non concluant, en raison d'une **asymétrie propre au banc** : l'endpoint du client netns est vu par le firewall comme `192.168.122.1`, c'est-à-dire sur le **même sous-réseau que le WAN de pfSense** (`192.168.122.0/24`), ce qui crée un repli (hairpin) non représentatif d'un client réellement distant. La validation de bout en bout représentative est donc portée par la **recette** (étape E8 du plan de mise en production), depuis une machine cliente distincte placée sur le réseau WAN du laboratoire et dépourvue de toute route vers le segment interne hors du tunnel.

Preuve Captures de l'onglet Peers avant correction (deux peers en `10.10.20.2/32`) et après correction (`.3/32` et `.2/32`) ; capture de paquets LAN montrant le `SYN` relayé vers TrueNAS et le `SYN-ACK` retransmis.

Enseignement (1) Distinguer les deux rôles du champ *Allowed IPs* dans WireGuard : autorisation **et** routage par clé. (2) Un handshake établi ne prouve pas le bon fonctionnement du plan de données ; toujours valider le flux applicatif. (3) Les plages *Allowed IPs* doivent être **uniques** entre les peers d'un même tunnel. (4) Choisir un banc de test dont la topologie ne réintroduit pas d'asymétrie (endpoint client hors du sous-réseau WAN du firewall).

Mise à jour du 11/10/2026. La recette menée depuis un poste client distinct (PV-04) a montré que la correction des *Allowed IPs* était nécessaire mais **pas suffisante** : le même symptôme subsistait, avec une seconde cause, côté interface du firewall (INC-07). L'hypothèse d'une asymétrie propre au banc *netns* n'expliquait donc pas, à elle seule, l'échec observé le 06/10.

INC-07 — WireGuard : réponses du serveur non routées vers le tunnel (interface WG_REMOTE sans adressage statique)

Date : 11/10/2026

Actif concerné : firewall `fw01` — interface assignée `WG_REMOTE` (`tun_wg0`), peer `employe-remote` (`10.10.20.3`)

Symptôme Lors de la recette, depuis le client dédié `wg-client` placé côté WAN : négociation établie (`latest handshake: Now`), mais `nc -zv -w3 10.10.10.20 445` en échec (`Connection timed out`). La capture côté WAN montre le client émettre des paquets chiffrés chaque seconde sans aucune réponse du firewall.

Diagnostic

1. Le partage SMB répond depuis le réseau interne : le service TrueNAS est hors de cause.

2. Les compteurs de la règle `employe-remote → TrueNAS SMB (445)` augmentent : le firewall **autorise** et relaie la requête.

3. Capture sur l'interface LAN du firewall : TrueNAS **répond** (`SYN-ACK` vers `10.10.20.3`). La passerelle par défaut de TrueNAS (`10.10.10.254`) est correcte.

4. Le défaut est donc localisé, comme pour INC-06, sur le **chemin de retour** du firewall vers le tunnel.

Cause racine L'interface assignée `WG_REMOTE` était configurée avec le type d'adressage IPv4 **« None »**. Sans adresse ni préfixe sur l'interface, pfSense ne disposait d'aucune route connectée vers `10.10.20.0/24` : la réponse du serveur suivait la route par défaut (WAN) au lieu d'entrer dans le tunnel. Une première correction en `10.10.20.1/32` est restée sans effet (le préfixe /32 ne couvre pas le segment des clients).

Résolution Interface `WG_REMOTE` passée en **IPv4 statique** `10.10.20.1/24`, sans passerelle amont ; réinitialisation de la table d'états. Vérification immédiate : `Connection to 10.10.10.20 445 port`

```
[tcp/microsoft-ds] succeeded!
```

Preuve Capture WAN (paquets chiffrés sans réponse), capture LAN (`SYN-ACK` présent), succès de la connexion après correction ; recette complète consignée dans PV-04.

Enseignement (1) Sur pfSense, l'interface assignée à un tunnel WireGuard doit porter l'adresse et le **préfixe du segment des clients** : c'est elle qui crée la route de retour. (2) Deux causes indépendantes peuvent produire le même symptôme ; la correction de la première (INC-06) ne valait pas preuve. (3) Le diagnostic par captures successives — WAN, règle, LAN — localise le maillon défaillant en quelques minutes ; c'est la méthode retenue pour l'exploitation.

Annexe K · Dispositif de veille en cybersécurité

Projet « Hybrid InfraSec » — société INFRASEC

Référence	VEI-2026-01
Objet	Organiser la veille sur les menaces, les vulnérabilités, les évolutions des outils et la réglementation, et la traduire en actions de maintien en condition de sécurité et en règles de détection
Rédacteur	RJ — administrateur d'infrastructures sécurisées
Référentiel	Titre professionnel AIS — RNCP37680, CCP3 / CP10
Date	11 octobre 2026

1. Pourquoi une veille structurée Une infrastructure sécurisée le jour de sa mise en production ne l'est plus quelques mois plus tard si rien ne change autour d'elle : de nouvelles vulnérabilités sont publiées chaque semaine, les techniques d'attaque évoluent, les éditeurs modifient leurs produits. La veille est le capteur qui déclenche le maintien en condition de sécurité. Sans elle, les correctifs arrivent tard et les règles de détection vieillissent.

Le dispositif décrit ici répond à trois questions : **quoi surveiller** (le périmètre), **où regarder** (les sources), et **que faire de ce qu'on trouve** (le processus de décision et sa traçabilité).

2. Périmètre de veille — l'inventaire d'abord Une veille efficace part de l'inventaire : une alerte n'a de valeur que si elle concerne un composant réellement présent. Le périmètre reprend les actifs du projet.

Domaine	Composants surveillés
Périmètre et accès distant	pfSense CE, paquet WireGuard
Identité	Windows Server 2025 — Active Directory, DNS, Kerberos
Stockage	TrueNAS SCALE 25.10 — ZFS, SMB
Virtualisation	Fedora 44, KVM / libvirt / QEMU, Cockpit
Containers et supervision	Podman (rootless), Prometheus, Grafana, node_exporter, windows_exporter
Détection	Wazuh 4.14 (gestionnaire, indexeur, dashboard, agents)
Menaces	techniques d'attaque applicables à cette architecture (force brute, rançongiciel, rebond d'administration)
Réglementation	RGPD, NIS 2, recommandations de l'ANSSI

3. Sources de veille

Catégorie	Source	Contenu exploité	Fréquence
Institutionnelle	**CERT-FR** (cert.ssi.gouv.fr)	Alertes, avis de vulnérabilité, bulletins d'actualité — par flux RSS	Quotidienne
Institutionnelle	**ANSSI** (cyber.gouv.fr)	Guides et recommandations, panorama annuel de la cybermenace	Mensuelle / annuelle
Vulnérabilités	**CVE / NVD** (cve.org, nvd.nist.gov)	Description, score CVSS, produits affectés	À chaque avis pertinent

Catégorie	Source	Contenu exploité	Fréquence
Vulnérabilités	**Catalogue KEV de la CISA** (cisa.gov)	Vulnérabilités dont l'exploitation active est avérée — critère de priorisation	Hebdomadaire
Éditeurs	**Microsoft** (msrc.microsoft.com)	Correctifs mensuels du deuxième mardi	Mensuelle
Éditeurs	**Netgate** (avis de sécurité pfSense), **TrueNAS**, **Fedora**, **Wazuh**, **Grafana**, **Prometheus**	Avis de sécurité et notes de version	Hebdomadaire
Menaces	**MITRE ATT&CK** (attack.mitre.org)	Évolution des techniques ; qualification des incidents	Trimestrielle
Réglementaire	**CNIL** (cnil.fr), textes européens	Évolutions RGPD, obligations NIS 2	Trimestrielle
Automatisée	**Module de détection de vulnérabilités de Wazuh**	Croisement de l'inventaire logiciel des agents avec les bases CVE	Continue (module actif ; capture de ses résultats non jointe à ce dossier)

Le choix privilégie les sources **primaires** — l'autorité nationale, l'éditeur, la base de référence — plutôt que des relais secondaires, pour éviter les informations déformées ou tardives.

4. Processus : de l'information à l'action

```
Collecte → Qualification → Décision → Action → Traçabilité → Diffusion
```

Qualification. Chaque information est confrontée à l'inventaire (le composant est-il présent ? dans quelle version ? exposé ?) puis cotée : sévérité CVSS, exploitation active connue (catalogue KEV, alerte CERT-FR), exposition réelle dans l'architecture.

Décision. Trois issues possibles : corriger (mise à jour, changement de configuration) ; appliquer une mesure compensatoire en attendant le correctif (filtrage, désactivation d'un service, règle de détection) ; accepter le risque, de façon motivée et datée.

Délais cibles de traitement :

Criticité	Critère	Délai
Critique	CVSS ≥ 9, ou exploitation active avérée sur un composant exposé	Mesure compensatoire immédiate, correctif sous 72 h
Élevée	CVSS 7 à 8,9	15 jours
Moyenne	CVSS 4 à 6,9	Cycle mensuel de maintenance
Faible	CVSS < 4	Prochain cycle planifié

Action et adaptation de la détection. Lorsqu'une technique d'attaque applicable est identifiée, la veille ne se limite pas au correctif : elle interroge la capacité de détection. Une règle Wazuh est créée ou ajustée pour que la technique soit vue si elle est tentée.

Traçabilité. Chaque information retenue entre au registre de veille (§5). **Diffusion.** Alerte immédiate au RSSI pour une criticité critique ; synthèse mensuelle d'une page à la direction ; intégration au support de sensibilisation lorsqu'un comportement utilisateur est en jeu.

5. Registre de veille — entrées réelles du projet

Date	Source	Information	Actif	Décision	Action	Statut
04/10/2026	Notes de version de l'éditeur	windows_exporter 0.31 : retrait des collecteurs `cs` et `logon` ; dashboards communautaires anciens devenus incompatibles	Contrôleur de domaine	Corriger	Script de déploiement auto-correctif ; dashboard compatible (INC-03)	Clos
04/10/2026	Notes de version Wazuh	Versions majeures annoncées après la 4.14	SIEM	Accepter temporairement	Version **figée en 4.14** jusqu'à la fin de la période de certification ; montée de version planifiée ensuite, après test	Suivi
04/10/2026	MITRE ATT&CK	Force brute SSH (T1110, T1110.001) — technique observée lors de l'exercice PV-03	Nœud de containers	Adapter la détection	Règle locale à seuil abaissé (§6)	Clos — déployée et éprouvée le 11/10 (PV-04)
05/10/2026	Retour d'incident interne	Une application d'appareil photo transmet le contenu lu (code QR de configuration) à un service en ligne	Accès distant	Corriger	Rotation de la clé ; consigne ajoutée à la sensibilisation (INC-04)	Clos

6. Exemple d'adaptation de la détection L'exercice PV-03 a montré que la corrélation native de Wazuh (règle 5712) lève une alerte de niveau 10 après huit tentatives sur un compte inexistant en deux minutes. Pour une infrastructure de cette taille, où aucun utilisateur légitime ne se trompe de compte en rafale, ce seuil est trop tolérant. La veille sur cette technique conduit à une règle locale plus stricte :

```
<group name="local,sshd,">
  <rule id="100100" level="12" frequency="5" timeframe="60">
    <if_matched_sid>5710</if_matched_sid>
    <same_srcip />
    <description>INFRASEC - force brute SSH : tentatives répétées sur compte
inexistant depuis une même source</description>
    <mitre>
      <id>T1110.001</id>
    </mitre>
  </rule>
</group>
```

La règle est déposée dans `/var/ossec/etc/rules/local_rules.xml` du gestionnaire, validée par l'outil de test des règles de Wazuh, puis éprouvée en rejouant l'attaque de PV-03. **Résultat (11/10/2026, PV- 04) :** huit tentatives lancées à 13:44:10 ; alerte 100100 de niveau 12 à 13:44:12, dès la cinquième tentative, source `10.10.10.2` , technique T1110.001. Là où la corrélation native attendait huit tentatives au niveau 10, la règle locale alerte plus tôt et plus haut.

7. Indicateurs d'efficacité

Indicateur	Cible
Délai entre la publication d'une alerte critique pertinente et la mesure compensatoire	< 24 h

Indicateur	Cible
Part des avis pertinents traités dans le délai cible	≥ 90 %
Composants de l'inventaire couverts par au moins une source	100 %
Règles de détection revues ou créées à la suite de la veille	au moins une par trimestre

8. Organisation La veille quotidienne prend une dizaine de minutes (lecture des flux CERT-FR et des alertes du module de vulnérabilités) ; la revue hebdomadaire, environ une heure. La synthèse mensuelle et la revue trimestrielle des sources sont présentées en revue de sécurité (PSSI, article 3.2). Le dispositif lui-même est réévalué chaque année : une source qui ne produit jamais d'information exploitable est retirée, un composant nouveau ajoute ses sources éditeur.

Dispositif de veille VEI-2026-01 — Projet Hybrid InfraSec, société fictive INFRASEC. Référentiel RNCP37680, CCP3 / CP10, du 11 octobre 2026.

Annexe L · Glossaire et fiches de définitions

Projet « Hybrid InfraSec » — vocabulaire du référentiel AIS

Référence	GLO-2026-01
Objet	Définitions des notions du REAC, de l'architecture réseau, de la cybersécurité et de la supervision mobilisées dans le projet
Rédacteur	RJ — administrateur d'infrastructures sécurisées
Date	11 octobre 2026

Mode d'emploi. Chaque notion est donnée en une ou deux phrases, puis rattachée à une réalisation du projet (« Projet »), et accompagnée de son équivalent anglais (« EN »), utile pour le questionnaire professionnel. Une définition se dit sans notes ; le rattachement au projet transforme une récitation en preuve.

1. Gouvernance, risques et conformité

PSSI — Politique de sécurité des systèmes d'information *(EN : Information Security Policy)* Document de référence approuvé par la direction, qui fixe les objectifs, les règles et les responsabilités de sécurité d'un organisme et se décline en procédures opérationnelles. → *Projet :* PSSI en douze articles (accès, cloisonnement, durcissement, sauvegarde, journalisation, incidents, secrets), déclinée en procédures dans le livret de commandes.

MCO — Maintien en condition opérationnelle *(EN : operational maintenance)* Ensemble des activités qui garantissent qu'un système reste disponible et conforme à ses spécifications : maintenance préventive et corrective, supervision, mises à jour fonctionnelles. → *Projet :* supervision Prometheus/Grafana, instantanés avant chaque opération, journal d'incidents.

MCS — Maintien en condition de sécurité *(EN : security maintenance)* Ensemble des activités qui maintiennent le niveau de sécurité d'un système dans le temps, face à l'évolution des menaces : veille, correctifs de sécurité, revue des droits, audits périodiques. → *Projet :* audit PV-02, durcissement mesuré (Lynis 69 → 76), mises à jour automatiques, dispositif de veille.

SLA — Accord de niveau de service *(EN : Service Level Agreement)* Engagement mesurable entre un fournisseur de service et son client : disponibilité, délai de rétablissement, performance. Il s'appuie sur des objectifs (SLO) et des indicateurs (SLI). → *Projet :* disponibilité ≥ 99,5 % de l'accès distant, RTO < 1 h, enrôlement < 15 min, révocation < 5 min (cahier des charges).

EBIOS Risk Manager *(EN : risk assessment method — ANSSI)* Méthode d'appréciation et de traitement des risques numériques publiée par l'ANSSI en 2018, organisée en cinq ateliers : cadrage et socle de sécurité, sources de risque, scénarios stratégiques, scénarios opérationnels, traitement du risque. → *Projet :* quatre valeurs métier, six biens supports, quatre scénarios opérationnels dont trois critiques ramenés hors de la zone critique après traitement.

Menace, vulnérabilité, risque *(EN : threat, vulnerability, risk)* La menace est une cause potentielle d'incident (une source et une intention) ; la vulnérabilité est une faiblesse exploitable ; le risque est la combinaison de la vraisemblance et de la gravité d'un scénario dans lequel une menace exploite une vulnérabilité. → *Projet :* la vulnérabilité F-01 (hyperviseur sur le segment) a nourri le scénario SO-3 et servi de source à l'attaque simulée de PV-03.

DICT — Disponibilité, intégrité, confidentialité, traçabilité *(EN : CIA triad + accountability)* Les quatre critères de sécurité d'une information ou d'un service. La traçabilité est parfois appelée « preuve ». → *Projet :* sauvegarde 3-2-1-0 (D, I), chiffrement WireGuard (C), registre SHA-256 et journaux Wazuh (I, T).

Défense en profondeur *(EN : defense in depth)* Superposition de lignes de défense indépendantes, de sorte que la défaillance de l'une ne compromette pas l'ensemble. → *Projet :* le collaborateur distant est filtré par la clé (routage par clé), par la règle du pare-feu (TCP 445 seul), puis par les ACL du groupe AD sur le partage.

Zero Trust *(EN : Zero Trust)* Modèle de sécurité qui n'accorde aucune confiance implicite à un utilisateur, un appareil ou un flux du seul fait de sa position sur le réseau : chaque accès est authentifié, autorisé au plus juste et vérifié. → *Projet :* principe directeur de l'architecture et de l'évolution d'accès distant.

ZTNA — Accès réseau Zero Trust *(EN : Zero Trust Network Access)* Application du modèle Zero Trust à l'accès distant : l'utilisateur accède à des ressources précises selon son profil, jamais au réseau entier. → *Projet :* profil administrateur vers le plan d'administration, profil collaborateur vers le seul partage SMB.

Moindre privilège *(EN : least privilege)* Chaque identité ne reçoit que les droits strictement nécessaires à sa mission, ni plus, ni plus longtemps. → *Projet :* règle `employe-remote` limitée à `10.10.10.20:445` ; RBAC Active Directory ; conteneurs rootless.

ANSSI — Agence nationale de la sécurité des systèmes d'information *(EN : French national cybersecurity agency)* Autorité nationale de cybersécurité, rattachée au SGDSN. Elle publie guides et recommandations, qualifie produits et prestataires, et pilote le CERT-FR. → *Projet :* guide d'hygiène informatique et recommandations sur les accès distants comme référentiel de bonnes pratiques.

CERT / CSIRT — CERT-FR *(EN : Computer Emergency Response Team)* Équipe de réponse aux incidents de sécurité. Le CERT-FR, rattaché à l'ANSSI, publie alertes, avis de vulnérabilité et bulletins d'actualité. → *Projet :* source principale du dispositif de veille ; point d'escalade prévu par la procédure d'incident.

PASSI — Prestataire d'audit de la sécurité des systèmes d'information *(EN : ANSSI-qualified security auditor)* Qualification délivrée par l'ANSSI aux prestataires d'audit (architecture, configuration, code source, tests d'intrusion, audit organisationnel et physique). → *Projet :* la lettre de mission LM-AUDIT- 2026-01 est rédigée pour pouvoir s'appliquer à l'identique à un prestataire tiers de ce type.

Boîte blanche, grise, noire *(EN : white / grey / black box testing)* Niveau d'information remis à l'auditeur : toutes les informations (architecture, comptes, code) en boîte blanche, une partie en boîte grise, aucune en boîte noire, qui simule un attaquant externe. → *Projet :* audit PV-02 conduit en boîte blanche, avec accès à la configuration et aux comptes.

RGPD — Règlement général sur la protection des données *(EN : GDPR)* Règlement européen 2016/679, applicable depuis le 25 mai 2018, qui encadre le traitement des données à caractère personnel : licéité, minimisation, sécurité du traitement (article 32) et notification d'une violation à la CNIL sous 72 heures (article 33). → *Projet :* chiffrement des flux distants, journalisation proportionnée, aucune donnée personnelle réelle dans les livrables.

NIS 2 *(EN : NIS 2 Directive)* Directive européenne 2022/2555 qui renforce les obligations de cybersécurité des entités essentielles et importantes : gestion des risques, notification des incidents, responsabilité de la direction. → *Projet :* cadre réglementaire cité pour situer les obligations d'une organisation qui y serait soumise.

ISO/IEC 27001, 27002, 27005 *(EN : ISO/IEC 27000 family)* 27001 : exigences d'un système de management de la sécurité de l'information (SMSI), certifiable. 27002 : catalogue de mesures de sécurité. 27005 : gestion des risques de sécurité de l'information. → *Projet :* EBIOS RM est compatible avec la démarche de 27005 ; la PSSI suit le cycle d'amélioration continue (PDCA).

PDCA — Planifier, déployer, contrôler, agir *(EN : Plan-Do-Check-Act)* Cycle d'amélioration continue au cœur des systèmes de management. → *Projet :* audit (contrôler) → traitement des constats (agir) → nouvelle mesure Lynis (contrôler à nouveau).

ITIL *(EN : IT Infrastructure Library)* Référentiel de bonnes pratiques de gestion des services informatiques. ITIL 4 décrit 34 pratiques, dont la gestion des incidents, des problèmes, des changements et des mises en production. → *Projet :* l'évolution WireGuard est traitée comme un changement normal ; l'enrôlement d'un utilisateur devient ensuite un changement standard (plan MEP-2026-01).

TCO, CAPEX, OPEX *(EN : Total Cost of Ownership, capital / operating expenditure)* Le TCO est le coût total d'une solution sur une durée donnée : dépenses d'investissement (CAPEX : acquisition, mise en œuvre) et dépenses d'exploitation récurrentes (OPEX : maintenance, énergie, abonnements). → *Projet :* TCO sur 3 ans de 4 610 € pour WireGuard auto-hébergé contre 4 760 € pour un ZTNA commercial.

IaaS, PaaS, SaaS *(EN : cloud service models)* Modèles de service cloud : l'IaaS fournit l'infrastructure (VM, réseau, stockage) et le client gère le système et au-dessus ; le PaaS fournit la plateforme et le client gère applications et données ; le SaaS fournit le logiciel prêt à l'emploi. La responsabilité de sécurité est partagée selon le modèle. → *Projet :* l'option de point d'accès cloud (instance de type IaaS) chiffrée dans le TCO.

IaC — Infrastructure as Code *(EN : Infrastructure as Code)* Description de l'infrastructure par des fichiers versionnés et rejouables, plutôt que par des manipulations manuelles. → *Projet :* pare-feu décrit en Terraform (état local, `${path.module}`) ; stage en entreprise consacré au déploiement automatisé de machines virtuelles.

2. Continuité d'activité et sauvegarde

PCA — Plan de continuité d'activité *(EN : Business Continuity Plan)* Organisation et moyens qui permettent de poursuivre les activités essentielles pendant une crise, éventuellement en mode dégradé, sans interruption.

PRA — Plan de reprise d'activité *(EN : Disaster Recovery Plan)* Procédures qui permettent de redémarrer les activités après un sinistre qui les a interrompues.

PCI et PRI — Plans de continuité et de reprise informatiques *(EN : IT continuity / IT recovery plans)* Déclinaisons informatiques du PCA et du PRA : le PCI maintient les services du SI pendant l'incident (redondance, bascule) ; le PRI restaure systèmes et données après l'interruption (sauvegardes, instantanés, site de secours). → *Projet :* PRI des données testé (PV-01) ; PRI de la configuration du pare- feu et PCI de l'accès distant décrits dans le plan de mise en production.

RPO et RTO *(EN : Recovery Point Objective, Recovery Time Objective)* Le RPO est la perte de données maximale admissible, exprimée en durée ; le RTO est la durée maximale admissible d'interruption avant rétablissement. → *Projet* : RPO ≤ 1 h (instantanés horaires) et RTO < 1 s au niveau fichier, mesurés dans PV-01.

Règle 3-2-1-0 *(EN : 3-2-1-0 backup rule)* Trois copies des données, sur deux supports différents, dont une hors site, et zéro erreur constatée lors d'un test de restauration vérifié. Le « 0 » est la partie la plus souvent oubliée : une sauvegarde jamais restaurée n'est pas une sauvegarde prouvée. → *Projet :* production ZFS en miroir, instantanés, réplication `zfs send/recv`, restauration vérifiée par empreintes SHA-256 (3/3 conformes).

Sauvegarde complète, incrémentale, différentielle *(EN : full, incremental, differential backup)* La complète copie tout ; l'incrémentale copie ce qui a changé depuis la dernière sauvegarde quelle qu'elle soit ; la différentielle copie ce qui a changé depuis la dernière complète.

Instantané (snapshot) et sauvegarde *(EN : snapshot vs backup)* Un instantané fige l'état d'un système sur le même support : il protège contre l'erreur logique ou le rançongiciel, pas contre la perte du support. Une sauvegarde est une copie indépendante. Les deux se complètent. → *Projet :* instantanés ZFS (copie 2) complétés par une réplication (copie 3).

Immuabilité *(EN : immutability / WORM)* Propriété d'une copie qui ne peut être ni modifiée ni supprimée pendant sa durée de rétention, y compris par un administrateur compromis. → *Projet :* mesure M-11 de l'analyse de risques (instantanés verrouillés contre la destruction des sauvegardes).

3. Architecture réseau

Modèles OSI et TCP/IP *(EN : OSI / TCP-IP models)* Le modèle OSI décrit sept couches : physique, liaison, réseau, transport, session, présentation, application. Le modèle TCP/IP en retient quatre : accès réseau, internet, transport, application. → *Projet :* le pare-feu filtre aux couches 3 et 4 (adresses, protocoles, ports).

Adresse IP, masque, notation CIDR *(EN : IP address, subnet mask, CIDR)* Le masque sépare la partie réseau de la partie hôte. `10.10.10.0/24` (masque `255.255.255.0`) contient 256 adresses, dont 254 utilisables, de `.1` à `.254`. → *Projet :* segment interne `10.10.10.0/24` ; réseau de transport du tunnel `10.10.20.0/24`.

RFC 1918 *(EN : private address space)* Plages d'adresses privées non routées sur Internet : `10.0.0.0/8`, `172.16.0.0/12`, `192.168.0.0/16`. → *Projet :* tout l'adressage du dossier est en RFC 1918, aucune adresse publique n'est publiée.

Passerelle par défaut *(EN : default gateway)* Routeur auquel un hôte confie tout trafic destiné à un autre réseau. → *Projet :* pfSense (`10.10.10.254`) pour toutes les machines du segment.

Routage *(EN : routing)* Acheminement des paquets entre réseaux selon une table de routage, statique (routes déclarées) ou dynamique (protocoles comme OSPF ou BGP).

VLAN — Réseau local virtuel *(EN : Virtual LAN)* Segmentation logique d'un réseau de niveau 2 sur une même infrastructure physique ; chaque VLAN est un domaine de diffusion distinct. → *Projet* : réseau d'administration dédié prévu par la mesure M-01.

Trunk 802.1Q *(EN : 802.1Q trunk)* Lien qui transporte plusieurs VLAN : chaque trame porte une étiquette de 4 octets, dont l'identifiant de VLAN sur 12 bits (1 à 4094 utilisables).

Routage inter-VLAN *(EN : inter-VLAN routing)* Passage du trafic d'un VLAN à un autre par un équipement de niveau 3 (routeur, pare-feu, commutateur de niveau 3). C'est le point naturel d'application du filtrage entre zones.

NAT — Traduction d'adresses *(EN : Network Address Translation)* Réécriture des adresses d'un paquet. En sortie (SNAT, masquerade), plusieurs hôtes privés partagent une adresse ; en entrée (DNAT, redirection de port), un service interne est publié vers l'extérieur. → *Projet :* redirection UDP 51820 de l'hyperviseur vers le WAN de pfSense pour publier le tunnel.

DMZ — Zone démilitarisée *(EN : demilitarized zone)* Segment isolé qui héberge les services exposés à l'extérieur, séparé du réseau interne par le pare-feu, de sorte qu'une compromission d'un service exposé n'ouvre pas le réseau interne.

Pare-feu à état *(EN : stateful firewall)* Pare-feu qui suit l'état des connexions : le trafic de retour d'une connexion autorisée est accepté automatiquement, sans règle dédiée.

Filtrage par défaut interdit *(EN : deny by default)* Tout flux qui n'est pas explicitement autorisé est refusé. → *Projet :* politique du pare-feu pfSense ; pour le collaborateur distant, seul TCP 445 vers TrueNAS est ouvert.

Point de passage unique *(EN : chokepoint)* Équipement par lequel tout trafic entre zones doit obligatoirement passer, ce qui permet d'y concentrer filtrage et journalisation. → *Projet :* pfSense, seul point de passage du segment.

Segmentation et micro-segmentation *(EN : segmentation, micro-segmentation)* La segmentation sépare le réseau en zones ; la micro-segmentation applique un cloisonnement par charge de travail ou par flux, au plus fin. → *Projet :* règles par profil distant, chacune limitée à sa ressource.

Plan d'administration et plan de données *(EN : management plane, data plane)* Les flux qui servent à administrer les équipements doivent être séparés des flux métier, idéalement sur un réseau d'administration dédié (recommandation ANSSI). → *Projet :* constat F-01 (hyperviseur sur le segment de production) et mesure corrective M-01.

Bastion *(EN : bastion host / jump server)* Point d'accès unique, durci et journalisé, par lequel passent toutes les actions d'administration.

Haute disponibilité, CARP, VRRP *(EN : high availability)* Redondance d'équipements avec bascule automatique en cas de panne. CARP (sur pfSense) et VRRP partagent une adresse virtuelle entre deux équipements. → *Projet :* redondance du pare-feu citée en perspective, hors périmètre.

DNS et DHCP *(EN : Domain Name System, Dynamic Host Configuration Protocol)* Le DNS traduit les noms en adresses ; le DHCP attribue automatiquement la configuration réseau aux hôtes. → *Projet :* DNS de l'Active Directory sur le contrôleur de domaine, indispensable à Kerberos.

4. Accès distant et cryptographie

VPN site-à-site et VPN d'accès distant *(EN : site-to-site VPN, remote access VPN)* Le VPN site-à-site relie deux réseaux de passerelle à passerelle ; le VPN d'accès distant relie un poste isolé au réseau de l'entreprise. → *Projet :* accès distant pour un administrateur nomade et un collaborateur en télétravail.

IPsec *(EN : IPsec)* Suite de protocoles qui sécurise les communications au niveau réseau : IKE négocie les clés, ESP chiffre et authentifie les paquets. → *Projet :* alternative étudiée et écartée dans la grille de décision (complexité, empreinte).

OpenVPN *(EN : OpenVPN)* Solution VPN fondée sur TLS, mature et flexible, plus lourde à exploiter et à auditer. → *Projet :* alternative étudiée, deuxième de la grille de décision.

WireGuard *(EN : WireGuard)* Protocole VPN moderne, au code minimal, à cryptographie figée (Curve25519, ChaCha20-Poly1305, BLAKE2s), fonctionnant sur UDP. Chaque pair est identifié par sa clé publique ; un paquet non authentifié ne reçoit aucune réponse. → *Projet :* solution retenue (4,85/5 dans la grille de décision).

Routage par clé *(EN : cryptokey routing)* Dans WireGuard, le champ *Allowed IPs* associe des plages d'adresses à la clé publique d'un pair. Il sert à la fois de filtre en entrée et de table de routage en sortie : sans plage propre, un pair ne peut recevoir aucune réponse. → *Projet :* défaut de plages dupliquées diagnostiqué et corrigé (INC-06).

Chiffrement symétrique et asymétrique *(EN : symmetric / asymmetric encryption)* Le symétrique utilise une clé partagée, rapide (AES, ChaCha20) ; l'asymétrique utilise une paire clé publique / clé privée, pour l'échange de clés et la signature. → *Projet :* WireGuard échange les clés en asymétrique (Curve25519), puis chiffre en symétrique (ChaCha20-Poly1305).

Hachage *(EN : hashing)* Fonction à sens unique qui produit une empreinte de taille fixe ; la moindre modification de la donnée change l'empreinte. Le hachage garantit l'intégrité, il ne chiffre pas. → *Projet :* empreintes SHA-256 pour prouver la restauration (PV-01) et sceller les livrables (registre d'intégrité).

PKI — Infrastructure de gestion de clés *(EN : Public Key Infrastructure)* Ensemble d'autorités, de procédures et de certificats qui lie des clés publiques à des identités. → *Projet :* autorité de certification interne construite lors de la première phase (CCP1).

TLS *(EN : Transport Layer Security)* Protocole qui chiffre et authentifie une session applicative (HTTPS, LDAPS, syslog sur TLS). → *Projet :* toutes les interfaces d'administration en TLS ; constat F-02 sur l'écoute HTTP de pfSense.

MFA — Authentification multifacteur *(EN : multi-factor authentication)* Authentification combinant au moins deux facteurs de nature différente : ce que l'on sait, ce que l'on possède, ce que l'on est. → *Projet :* perspective d'amélioration de l'accès distant.

5. Identité et contrôle d'accès

Active Directory : forêt, domaine, OU, GPO *(EN : forest, domain, organizational unit, Group Policy Object)* La forêt est la frontière de sécurité ; le domaine regroupe comptes et ressources ; les unités d'organisation structurent l'annuaire ; les stratégies de groupe appliquent des réglages aux objets. → *Projet :* forêt `infrasec.local`, contrôleur de domaine sous Windows Server 2025.

Kerberos *(EN : Kerberos)* Protocole d'authentification par tickets délivrés par un centre de distribution de clés. Il exige des horloges synchronisées : au-delà de cinq minutes d'écart, l'authentification échoue. → *Projet :* jonction de TrueNAS au domaine bloquée par un décalage d'horloge, puis résolue (INC-02).

RBAC — Contrôle d'accès fondé sur les rôles *(EN : Role-Based Access Control)* Les droits sont attribués à des rôles, et les utilisateurs reçoivent des rôles, plutôt que des droits individuels. → *Projet :* groupes et unités d'organisation de l'annuaire ; matrice de rôles de la PSSI.

Séparation des tâches *(EN : segregation of duties)* Celui qui exploite un service ne doit pas être le seul à contrôler ses propres journaux. → *Projet :* principe inscrit dans la PSSI (article 3).

6. Détection et réponse aux incidents

Antivirus et EDR *(EN : antivirus vs Endpoint Detection and Response)* L'antivirus détecte des fichiers malveillants connus, par signature. L'EDR surveille en continu le comportement d'un poste ou d'un serveur, détecte des activités suspectes même inconnues et permet d'y répondre sur place (isolement, arrêt de processus). → *Projet :* l'agent Wazuh joue ce rôle sur le contrôleur de domaine et le nœud fedora (intégrité des fichiers, détection) ; sa réponse active est disponible mais pas encore activée (RETEX de PV-03).

XDR — Détection et réponse étendues *(EN : Extended Detection and Response)* Extension de l'EDR au- delà du poste — réseau, cloud, messagerie, identités — avec corrélation entre ces sources, généralement dans une plateforme intégrée d'un même éditeur.

SIEM — Gestion des informations et des événements de sécurité *(EN : Security Information and Event Management)* Collecte, normalise, corrèle et conserve les journaux de l'ensemble du SI, quelles qu'en soient les sources, pour générer des alertes, mener des investigations et prouver la conformité. → *Projet :* Wazuh, qui se définit comme plateforme unifiée XDR et SIEM.

SOAR *(EN : Security Orchestration, Automation and Response)* Orchestration et automatisation de la réponse par scénarios (*playbooks*), en aval de la détection.

MDR *(EN : Managed Detection and Response)* Service de détection et de réponse opéré par un prestataire : c'est une offre, pas une technologie.

UEBA *(EN : User and Entity Behavior Analytics)* Analyse du comportement des utilisateurs et des entités par rapport à une ligne de base, pour détecter les anomalies.

IDS et IPS ; NIDS et HIDS *(EN : intrusion detection / prevention system)* L'IDS détecte et alerte, l'IPS bloque. Le NIDS analyse le trafic réseau ; le HIDS surveille un hôte. → *Projet :* l'agent Wazuh joue le rôle de HIDS sur le contrôleur de domaine et sur le nœud de conteneurs.

SOC — Centre opérationnel de sécurité *(EN : Security Operations Center)* Équipe et outillage qui surveillent le SI, qualifient les alertes et traitent les incidents. → *Projet :* rôle d'analyste sécurité défini par la PSSI, tenu lors du traitement de PV-03 et d'INC-04.

FIM et SCA *(EN : File Integrity Monitoring, Security Configuration Assessment)* Le FIM surveille les modifications de fichiers sensibles ; le SCA compare la configuration d'un système à un référentiel de durcissement (CIS). → *Projet :* modules actifs sur les agents Wazuh ; résultats SCA utilisés dans l'audit PV- 02.

Événement et incident *(EN : event vs incident)* Un événement est une occurrence observée ; un incident de sécurité est un événement, ou une suite d'événements, qui porte atteinte ou menace de porter atteinte à la sécurité.

Incident et problème (ITIL) *(EN : incident vs problem)* L'incident est une interruption ou une dégradation qu'il faut rétablir au plus vite ; le problème est la cause racine d'un ou plusieurs incidents, qu'il faut éliminer. → *Projet :* l'attaque de PV-03 est l'incident ; F-01 est le problème sous-jacent.

Cycle de traitement d'un incident *(EN : incident response lifecycle)* Détection, qualification, confinement, éradication, rétablissement, puis retour d'expérience, en préservant les preuves à chaque étape. → *Projet :* appliqué à PV-03 (attaque simulée) et à INC-04 (incident réel).

RETEX — Retour d'expérience *(EN : lessons learned / post-incident review)* Analyse formalisée, après un incident ou un exercice, de ce qui a fonctionné et des écarts, pour produire des actions d'amélioration. → *Projet :* RETEX de PV-03 et d'INC-04.

Préservation de la preuve *(EN : evidence preservation, chain of custody)* Horodatage, empreinte d'intégrité, conservation hors ligne, absence d'altération et traçabilité de chaque manipulation. → *Projet :* empreintes SHA-256 et conservation hors ligne des captures.

IOC et IOA *(EN : Indicator of Compromise / of Attack)* L'indicateur de compromission est une trace d'attaque avérée (empreinte, adresse, domaine) ; l'indicateur d'attaque est un comportement en cours.

MITRE ATT&CK et kill chain *(EN : MITRE ATT&CK, cyber kill chain)* ATT&CK est une base de connaissances des tactiques et techniques observées chez les attaquants ; la kill chain décrit les étapes successives d'une attaque. → *Projet :* attaque PV-03 qualifiée T1110 (force brute), T1110.001, T1021.004 et T1078.

CVE, CWE, CVSS *(EN : Common Vulnerabilities and Exposures, Common Weakness Enumeration, Common Vulnerability Scoring System)* La CVE identifie publiquement une vulnérabilité précise ; la CWE classe le type de faiblesse ; le CVSS note la sévérité de 0 à 10.

7. Supervision

Supervision et observabilité *(EN : monitoring vs observability)* La supervision surveille des indicateurs connus et alerte au franchissement d'un seuil ; l'observabilité permet de comprendre un comportement imprévu à partir des métriques, des journaux et des traces.

Métriques, journaux, traces *(EN : metrics, logs, traces)* Les métriques sont des valeurs numériques horodatées ; les journaux sont des événements textuels ; les traces suivent le parcours d'une requête. → *Projet :* métriques avec Prometheus, journaux avec Wazuh.

SNMP — Protocole simple de gestion de réseau *(EN : Simple Network Management Protocol)* Protocole d'interrogation des équipements (*polling*, UDP 161) et d'alertes spontanées (*traps*, UDP 162). Les données sont organisées dans une MIB, chaque valeur étant identifiée par un OID. Les versions v1 et v2c s'authentifient par une « communauté » transmise en clair ; la v3 apporte authentification et chiffrement (niveau *authPriv*) et reste la seule acceptable en production. → *Projet :* collecte SNMP v2c du pare-feu par Zabbix, réservée au collecteur (PV-04) ; v3 visée en production.

WMI *(EN : Windows Management Instrumentation)* Interface de gestion et de collecte d'informations des systèmes Windows.

Syslog *(EN : syslog)* Protocole standard d'émission de journaux (UDP 514, ou TCP 6514 sur TLS).

Zabbix et Prometheus *(EN : Zabbix vs Prometheus)*

	Zabbix	Prometheus
Modèle	serveur central, agents et proxys, base relationnelle	collecte en *pull* HTTP sur des *exporters*, base de séries temporelles
Découverte	découverte de bas niveau (*low-level discovery*)	découverte de services (*service discovery*)
Alertes	déclencheurs (*triggers*) dans le serveur	règles PromQL et Alertmanager
Terrain de prédilection	équipements réseau, SNMP natif, parc hétérogène	infrastructures dynamiques, conteneurs, cloud

Choix retenu dans le projet. Prometheus est le socle de supervision des serveurs et des conteneurs : son modèle *pull* et sa base de séries temporelles conviennent à une infrastructure hybride et conteneurisée. Pour l'équipement réseau, SNMP reste le protocole de référence : le pare-feu est interrogé en SNMP par Zabbix, outil spécialisé dans ce terrain (mis en œuvre en conteneurs *rootless*, interrogation restreinte au collecteur — PV-04). Les deux outils sont ainsi employés chacun là où il excelle.

Agent et sans agent ; pull et push *(EN : agent / agentless ; pull / push)* Un agent installé sur la machine collecte et émet ; le sans-agent interroge à distance. En *pull*, le collecteur va chercher les données ; en *push*, la source les envoie.

Seuil, alerte, tableau de bord *(EN : threshold, alert, dashboard)* Un seuil déclenche une alerte quand un indicateur sort de sa plage normale ; un tableau de bord restitue les indicateurs utiles à la décision. → *Projet* : une disponibilité de 99,5 % sur 30 jours autorise au plus 3 h 36 d'interruption.

8. Les distinctions à ne jamais confondre

Couple	Ce qui les distingue
MCO / MCS	faire fonctionner / garder sûr dans la durée
PCA / PRA	ne pas s'arrêter / redémarrer après l'arrêt
PCI / PRI	continuité du SI pendant / reprise du SI après
RPO / RTO	combien de données perdues / combien de temps d'arrêt
Instantané / sauvegarde	même support / copie indépendante
Hachage / chiffrement	irréversible, intégrité / réversible avec la clé, confidentialité
Antivirus / EDR	signature / comportement et réponse
EDR / XDR / SIEM	le poste / plusieurs couches d'un éditeur / tout le SI, toutes sources
IDS / IPS	alerte / bloque
Incident / problème	rétablir vite / éliminer la cause
Menace / vulnérabilité / risque	la cause / la faiblesse / vraisemblance × gravité
VPN site-à-site / accès distant	réseau à réseau / poste à réseau
VLAN / sous-réseau	séparation de niveau 2 / plan d'adressage de niveau 3
SNMP v2c / v3	communauté en clair / authentification et chiffrement

Glossaire GLO-2026-01 — Projet Hybrid InfraSec, société fictive INFRASEC. Référentiel RNCP37680.

Annexe M · Manuel d'exploitation bilingue (Operations manual)

Service d'accès distant Zero-Trust et opérations courantes · Zero-Trust remote access service and routine operations

Référence / Reference	MAN-2026-01
Projet / Project	Hybrid InfraSec — société fictive INFRASEC / fictitious company INFRASEC
Rédacteur / Author	RJ — administrateur d'infrastructures sécurisées / secure infrastructure administrator
Date	11 octobre 2026 / October 11, 2026

Partie 1 en français, partie 2 en anglais américain. Les deux parties décrivent les mêmes procédures. *Part 1 is in French, part 2 in US English. Both parts describe the same procedures.*

Partie 1 — Français

1. Objet Ce manuel permet à un administrateur qui n'a pas réalisé le projet d'exploiter le service d'accès distant : enrôler un utilisateur, révoquer un accès, diagnostiquer une panne, sauvegarder et restaurer la configuration, revenir en arrière, et arrêter ou redémarrer l'infrastructure proprement.

2. Repères

Élément	Valeur
Firewall pfSense	LAN `10.10.10.254` · WAN `192.168.122.95` (réseau NAT de l'hyperviseur)
Tunnel WireGuard	`tun_wg0`, UDP `51820`, interface `WG_REMOTE`, firewall en `10.10.20.1/24`
Profil administrateur	`admin-remote` · `10.10.20.2/32` · accès au réseau interne `10.10.10.0/24`
Profil collaborateur	`employe-remote` · `10.10.20.3/32` · accès à TrueNAS `10.10.10.20`, TCP 445 uniquement
Contrôleur de domaine	`10.10.10.10` (forêt `infrasec.local`)
Serveur de fichiers	`10.10.10.20` (partage SMB `partage`)
Supervision	Grafana `10.10.10.30:3000` · Wazuh `https://10.10.10.40`

3. Règles d'or 1. **Aucun secret dans un fichier partagé.** Une clé privée ne quitte jamais l'appareil qui l'a générée. Seules les clés publiques sont déclarées sur le firewall ou citées dans un document.

2. **Un code QR de configuration est un secret.** Il ne se lit qu'avec l'application WireGuard, jamais avec l'appareil photo ou un assistant.

3. **Un snapshot avant toute modification.** Pas de snapshot, pas de changement.

4. **Une plage Allowed IPs unique par peer** (`/32`). Deux peers ne partagent jamais une adresse.

5. **Tester depuis un poste réellement extérieur.** Un test lancé depuis l'hyperviseur contourne le tunnel (INC-05).

6. **Arrêter proprement.** `virsh shutdown`, jamais `virsh destroy` sur le contrôleur de domaine.

4. Enrôler un utilisateur (changement standard — cible < 15 min)

Sur le poste de l'utilisateur (Linux ; sur smartphone, l'application WireGuard génère elle-même la paire) :

```
umask 077
wg genkey > utilisateur.key
wg pubkey < utilisateur.key > utilisateur.pub
cat utilisateur.pub          # seule cette valeur est transmise à l'administrateur
```

Sur le firewall (interface web) :

1. **VPN → WireGuard → Peers → Add Peer.** Tunnel `tun_wg0` ; description explicite ; *Dynamic Endpoint* coché ; clé publique de l'utilisateur ; *Allowed IPs* : une adresse **libre** du réseau `10.10.20.0/24` en `/32`.

2. **Save Peer**, puis **Apply Changes**.

3. **Firewall → Rules → WG_REMOTE** : rattacher l'adresse du nouveau peer à la règle de son profil (source = son adresse `/32`).

Fichier de configuration du client (exemple : profil collaborateur) :

```
[Interface]
PrivateKey = <clé privée du client — reste sur l'appareil>
Address = 10.10.20.3/32

[Peer]
PublicKey = <clé publique du pare-feu>
Endpoint = <adresse publique du point d'accès>:51820
AllowedIPs = 10.10.10.20/32
PersistentKeepalive = 25
```

Pour le profil administrateur : `Address = 10.10.20.2/32` et `AllowedIPs = 10.10.10.0/24`.

Remise par code QR (affiché dans le terminal le temps de l'enrôlement, puis le fichier est supprimé) :

```
qrencode -t ansiutf8 < utilisateur.conf
shred -u utilisateur.conf
```

Contrôle : sur le firewall, **VPN → WireGuard → Status** affiche une négociation récente pour le peer ; depuis le poste, `nc -zv -w3 10.10.10.20 445` répond.

5. Révoquer un accès (cible < 5 min) 1. **VPN → WireGuard → Peers** : désactiver le peer (icône d'interdiction), puis le supprimer.

2. **Apply Changes.**

3. Retirer l'adresse du peer de la règle de son profil.

4. **Contrôle :** dans **Status**, plus aucune négociation pour ce peer ; depuis l'appareil révoqué, la connexion n'aboutit plus.

5. Consigner la révocation au journal d'incidents s'il s'agit d'une compromission.

Essais de refus (recette). Configurer temporairement `AllowedIPs = 10.10.10.0/24` sur le client de test : un flux hors de la plage du client ne serait jamais présenté au firewall, et le test ne pourrait pas échouer. Lire les refus dans les logs de pfSense (interface `WG_REMOTE`), puis rétablir la configuration nominale du client.

6. Diagnostiquer Procéder du plus simple au plus profond, en notant chaque observation.

Étape	Vérification	Où
1	La négociation est-elle récente ? Des octets circulent-ils dans les deux sens ?	**VPN → WireGuard → Status** ; sur le client : `sudo wg show`
2	Chaque peer a-t-il une plage *Allowed IPs* **unique** ?	**VPN → WireGuard → Peers** (colonne *Allowed IPs*)
3	La règle du profil existe-t-elle, et dans le bon ordre ?	**Firewall → Rules → WG_REMOTE** ; logs : **Status → System Logs → Firewall**
4	Le flux arrive-t-il, la réponse repart-elle ?	**Diagnostics → Packet Capture** : interface `WG_REMOTE` puis `LAN`, champ *Host* = adresse du client, protocole TCP, port 445
5	La redirection de l'hyperviseur est-elle active ?	`sudo firewall-cmd --list-forward-ports` sur l'hyperviseur
6	Le test part-il d'un poste réellement extérieur ?	Jamais depuis l'hyperviseur (INC-05)

Rétablir la redirection sur l'hyperviseur (la commande sans `--permanent` ne survit pas à un redémarrage) :

```
sudo firewall-cmd --permanent --add-masquerade
sudo firewall-cmd --permanent --zone=libvirt --add-masquerade
sudo firewall-cmd --permanent --add-forward-
port=port=51820:proto=udp:toaddr=192.168.122.95:toport=51820
sudo firewall-cmd --reload
```

7. Sauvegarder et restaurer la configuration

Sauvegarde de la configuration pfSense : Diagnostics → Backup & Restore → Download configuration as XML, option de chiffrement activée, phrase secrète conservée dans le coffre de secrets. Le fichier est stocké **hors ligne** et n'est jamais versé à un dossier : il contient l'empreinte du mot de passe d'administration et la clé TLS de l'interface web.

Snapshot de la VM firewall (arrêt propre pour un snapshot cohérent) :

```
sudo virsh shutdown pfsense-fw
sudo virsh snapshot-create-as pfsense-fw POST-WIREGUARD-STABLE
sudo virsh start pfsense-fw
sudo snapper -c root create -d "POST-WIREGUARD-STABLE"
```

Restauration : Diagnostics → Backup & Restore → Restore Backup avec le fichier exporté ; ou, si la VM elle-même est en cause : `sudo virsh snapshot-revert pfsense-fw POST-WIREGUARD-STABLE`. Vérifier ensuite la remontée du tunnel et des peers dans **Status**.

8. Rollback d'un changement Du plus léger au plus complet, en s'arrêtant dès que le service antérieur est rétabli :

1. Désactiver le tunnel `tun_wg0` (effet immédiat, réseau interne non affecté).
2. Retirer les règles `WG_REMOTE` et la règle WAN UDP 51820.
3. Restaurer l'export de configuration.
4. Revenir au snapshot de la VM firewall.
5. Revenir au point Snapper de l'hyperviseur.

9. Opérations de sécurité courantes

Fréquence	Opération
Quotidienne	Dashboard Wazuh : alertes de niveau ≥ 10, agents déconnectés ; flux CERT-FR
Hebdomadaire	Score de conformité SCA ; avis de sécurité des éditeurs ; état des snapshots et de la réplication
Mensuelle	Revue des peers WireGuard actifs (révoquer les accès inutilisés) ; correctifs mensuels ; synthèse de veille
Après tout incident	Entrée au journal d'incidents ; RETEX si l'incident est de niveau P1 ou P2

10. Arrêt et redémarrage de l'infrastructure

Arrêt — services dépendants d'abord, firewall en dernier :

```
for vm in wazuh-siem fedora truenas Win-Server-DC pfsense-fw; do sudo virsh shutdown
"$vm"; done
sudo virsh list --all          # attendre que toutes les VM soient « shut off »
```

Redémarrage — dans l'ordre fixé par la PSSI (firewall, annuaire, puis services dépendants) :

```
for vm in pfsense-fw Win-Server-DC truenas fedora wazuh-siem; do sudo virsh start
"$vm"; sleep 30; done
```

Part 2 — English (US)

1. Purpose This manual lets an administrator who did not build the project operate the remote access service: enroll a user, revoke access, troubleshoot a failure, back up and restore the configuration, roll back a change, and shut down or restart the infrastructure cleanly.

2. Reference values

Item	Value
pfSense firewall	LAN `10.10.10.254` · WAN `192.168.122.95` (hypervisor NAT network)
WireGuard tunnel	`tun_wg0`, UDP `51820`, interface `WG_REMOTE`, firewall at `10.10.20.1/24`
Administrator profile	`admin-remote` · `10.10.20.2/32` · access to the internal network `10.10.10.0/24`
Employee profile	`employe-remote` · `10.10.20.3/32` · access to TrueNAS `10.10.10.20`, TCP 445 only
Domain controller	`10.10.10.10` (forest `infrasec.local`)
File server	`10.10.10.20` (SMB share `partage`)
Monitoring	Grafana `10.10.10.30:3000` · Wazuh `https://10.10.10.40`

3. Golden rules 1. **No secret in a shared file.** A private key never leaves the device that generated it. Only public keys are declared on the firewall or quoted in a document.

2. **A configuration QR code is a secret.** Scan it only with the WireGuard app — never with the camera app or a voice assistant.

3. **Snapshot before any change.** No snapshot, no change.

4. **One unique Allowed IPs range per peer** (`/32`). Two peers never share an address.

5. **Test from a truly external device.** A test run from the hypervisor bypasses the tunnel (INC-05).

6. **Shut down gracefully.** `virsh shutdown`, never `virsh destroy` on the domain controller.

4. Enroll a user (standard change — target < 15 min)

On the user's device (Linux; on a smartphone, the WireGuard app generates the key pair itself):

```
umask 077
wg genkey > user.key
wg pubkey < user.key > user.pub
cat user.pub                # only this value is sent to the administrator
```

On the firewall (web interface):

1. **VPN → WireGuard → Peers → Add Peer.** Tunnel `tun_wg0`; clear description; *Dynamic Endpoint* checked; the user's public key; *Allowed IPs*: one **unused** address from `10.10.20.0/24`, as a `/32`.

2. **Save Peer**, then **Apply Changes**.

3. **Firewall → Rules → WG_REMOTE**: attach the new peer's address to its profile rule (source = its `/32` address).

Client configuration file (example: employee profile):

```
[Interface]
PrivateKey = <client private key — stays on the device>
Address = 10.10.20.3/32

[Peer]
PublicKey = <firewall public key>
Endpoint = <public address of the access point>:51820
AllowedIPs = 10.10.10.20/32
PersistentKeepalive = 25
```

For the administrator profile: `Address = 10.10.20.2/32` and `AllowedIPs = 10.10.10.0/24`.

Delivery by QR code (shown in the terminal only during enrollment, then the file is destroyed):

```
qrencode -t ansiutf8 < user.conf
shred -u user.conf
```

Check: on the firewall, **VPN → WireGuard → Status** shows a recent handshake for the peer; from the device, `nc -zv -w3 10.10.10.20 445` succeeds.

5. Revoke access (target < 5 min) 1. **VPN → WireGuard → Peers**: disable the peer (prohibition icon), then delete it.

2. **Apply Changes.**

3. Remove the peer's address from its profile rule.

4. **Check:** in **Status**, no handshake remains for that peer; from the revoked device, the connection fails.

5. Log the revocation in the incident log if it follows a compromise.

Deny tests (acceptance). Temporarily set `AllowedIPs = 10.10.10.0/24` on the test client: traffic outside the client's range would never reach the firewall, so the test could not fail. Read the blocks in the pfSense logs (`WG_REMOTE` interface), then restore the client's nominal configuration.

6. Troubleshoot Work from the simplest check to the deepest, and write down every observation.

Step	Check	Where
1	Is the handshake recent? Do bytes flow both ways?	**VPN → WireGuard → Status**; on the client: `sudo wg show`
2	Does every peer have a **unique** *Allowed IPs* range?	**VPN → WireGuard → Peers** (*Allowed IPs* column)
3	Does the profile rule exist, in the right order?	**Firewall → Rules → WG_REMOTE**; logs: **Status → System Logs → Firewall**
4	Does the traffic arrive, and does the reply go back?	**Diagnostics → Packet Capture**: interface `WG_REMOTE`, then `LAN`; *Host* field = client address, protocol TCP, port 445
5	Is the hypervisor port forward active?	`sudo firewall-cmd --list-forward-ports` on the hypervisor
6	Does the test start from a truly external device?	Never from the hypervisor (INC-05)

Restore the hypervisor port forward (without `--permanent`, the rule does not survive a reboot):

```
sudo firewall-cmd --permanent --add-masquerade
sudo firewall-cmd --permanent --zone=libvirt --add-masquerade
sudo firewall-cmd --permanent --add-forward-
port=port=51820:proto=udp:toaddr=192.168.122.95:toport=51820
sudo firewall-cmd --reload
```

7. Back up and restore the configuration pfSense configuration backup: **Diagnostics → Backup & Restore → Download configuration as XML**, with encryption enabled and the passphrase kept in the secrets vault. The file is stored **offline** and never added to a deliverable: it contains the administrator password hash and the web interface TLS key.

Firewall VM snapshot (graceful shutdown for a consistent snapshot):

```
sudo virsh shutdown pfsense-fw
sudo virsh snapshot-create-as pfsense-fw POST-WIREGUARD-STABLE
sudo virsh start pfsense-fw
sudo snapper -c root create -d "POST-WIREGUARD-STABLE"
```

Restore: Diagnostics → Backup & Restore → Restore Backup with the exported file; or, if the VM itself is at fault: `sudo virsh snapshot-revert pfsense-fw POST-WIREGUARD-STABLE`. Then confirm in **Status** that the tunnel and peers are back.

8. Roll back a change From the lightest action to the most complete, stopping as soon as the previous service is restored:

1. Disable the `tun_wg0` tunnel (immediate effect, internal network unaffected).
2. Remove the `WG_REMOTE` rules and the WAN UDP 51820 rule.
3. Restore the configuration export.
4. Revert the firewall VM snapshot.
5. Revert the hypervisor Snapper snapshot.

9. Routine security operations



Frequency	Operation
Daily	Wazuh dashboard: level ≥ 10 alerts, disconnected agents; CERT-FR feed
Weekly	SCA compliance score; vendor security advisories; snapshot and replication status
Monthly	Review active WireGuard peers (revoke unused access); monthly patches; threat-watch summary
After any incident	Incident log entry; lessons-learned review for P1 or P2 incidents

10. Shutting down and restarting the infrastructure

Shutdown — dependent services first, firewall last:

```
for vm in wazuh-siem fedora truenas Win-Server-DC pfsense-fw; do sudo virsh shutdown
"$vm"; done
sudo virsh list --all          # wait until every VM is "shut off"
```

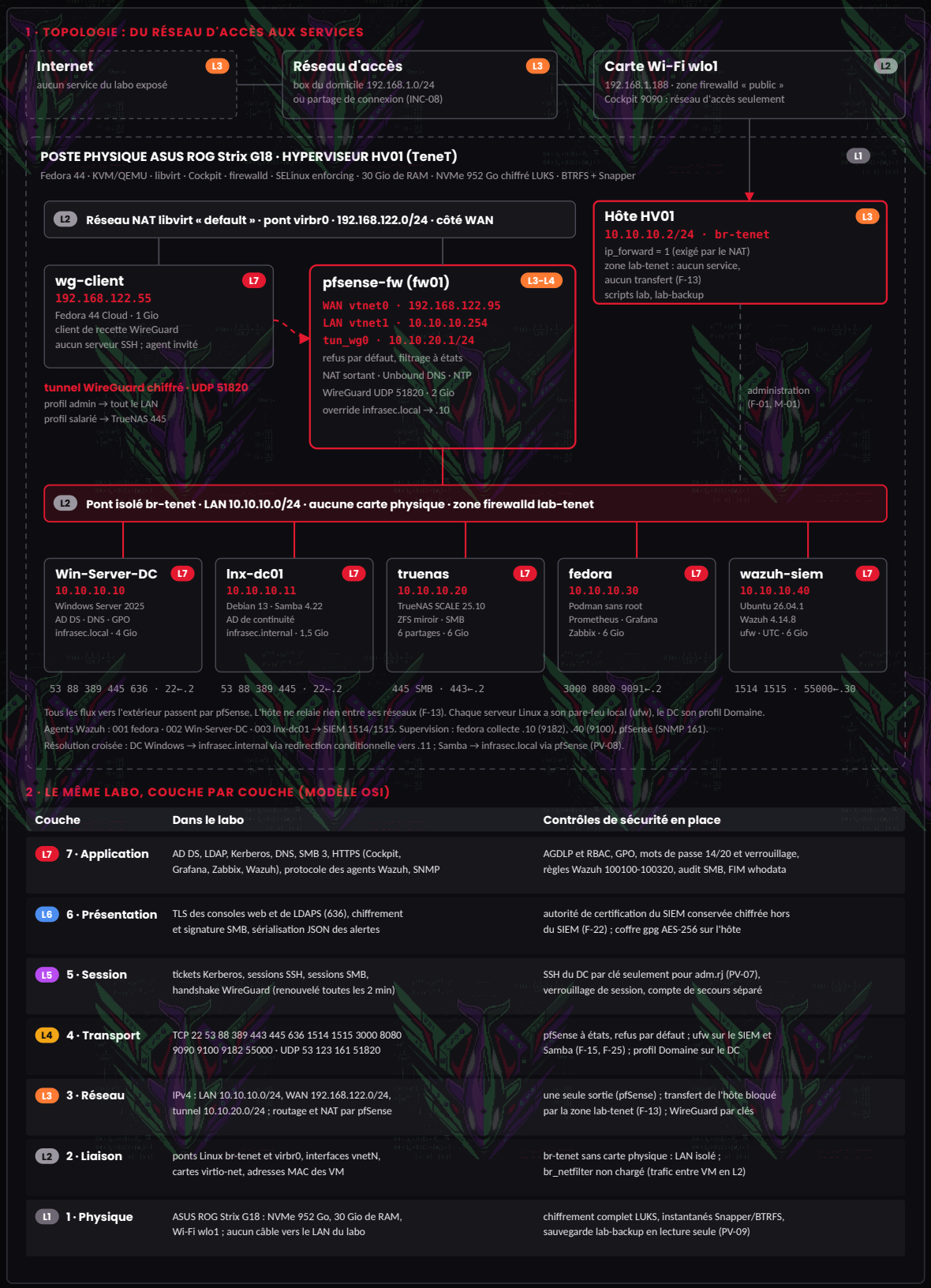
Restart — in the order set by the security policy (firewall, directory, then dependent services):

```
for vm in pfsense-fw Win-Server-DC truenas fedora wazuh-siem; do sudo virsh start
"$vm"; sleep 30; done
```

Manuel d'exploitation MAN-2026-01 — Hybrid InfraSec, du 11 octobre 2026. Operations manual MAN-2026-01, October 11, 2026.

Annexe N · Schéma réseau de référence et couches OSI

Ce schéma réunit en une seule vue l'architecture décrite dans le dossier : le firewall pfSense, seul point de passage entre l'extérieur et le segment interne `10.10.10.0/24` ; le réseau de transport WireGuard `10.10.20.0/24` ; les hôtes du segment, leurs services et les contrôles qui les protègent. Il se lit en trois zones : le réseau d'accès et Internet ; le WAN du laboratoire `192.168.122.0/24`, réseau NAT de libvirt dont l'hôte TeneT est le router et `virbr0` le switch ; le LAN `10.10.10.0/24`, derrière le switch virtuel isolé `br-tenet`. La seconde partie du schéma relit le même labo couche par couche, du matériel (L1) aux services (L7). La matrice des flux suit.



2 · LE MÊME LABO, COUCHE PAR COUCHE (MODÈLE OSI)

Couche	Dans le labo	Contrôles de sécurité en place
L7 7 · Application	AD DS, LDAP, Kerberos, DNS, SMB 3, HTTPS (Cockpit, Grafana, Zabbix, Wazuh), protocole des agents Wazuh, SNMP	AGDLP et RBAC, GPO, mots de passe 14/20 et verrouillage, règles Wazuh 100100-100320, audit SMB, FIM whodata
L6 6 · Présentation	TLS des consoles web et de LDAPS (636), chiffrement et signature SMB, sérialisation JSON des alertes	autorité de certification du SIEM conservée chiffrée hors du SIEM (F-22) ; coffre gpg AES-256 sur l'hôte
L5 5 · Session	tickets Kerberos, sessions SSH, sessions SMB, handshake WireGuard (renouvelé toutes les 2 min)	SSH du DC par clé seulement pour adm.rj (PV-07), verrouillage de session, compte de secours séparé
L4 4 · Transport	TCP 22 53 88 389 443 445 636 1514 1515 3000 8080 9090 9100 9182 55000 · UDP 53 123 161 51820	pfSense à états, refus par défaut ; ufw sur le SIEM et Samba (F-15, F-25) ; profil Domaine sur le DC
L3 3 · Réseau	IPv4 : LAN 10.10.10.0/24, WAN 192.168.122.0/24, tunnel 10.10.20.0/24 ; routage et NAT par pfSense	une seule sortie (pfSense) ; transfert de l'hôte bloqué par la zone lab-tenet (F-13) ; WireGuard par clés
L2 2 · Liaison	ponts Linux br-tenet et virbr0, interfaces vnetN, cartes virtio-net, adresses MAC des VM	br-tenet sans carte physique : LAN isolé ; br_netfilter non chargé (trafic entre VM en L2)
L1 1 · Physique	ASUS ROG Strix G18 : NVMe 952 Go, 30 Gio de RAM, Wi-Fi wlo1 ; aucun câble vers le LAN du labo	chiffrement complet LUKS, instantanés Snapper/BTRFS, sauvegarde lab-backup en lecture seule (PV-09)

Figure 38 Architecture réseau générale du labo Hybrid InfraSec : topologie complète et lecture couche par couche du modèle OSI (état au 26/10/2026).

Abréviations — **L1…L7** : couches du modèle OSI : 1 physique, 2 liaison, 3 réseau, 4 transport, 5 session, 6 présentation, 7 application · **OSI** : modèle de référence en 7 couches (Open Systems Interconnection) · **HV01** : hyperviseur du labo, nom d'hôte TeneT · **KVM** : hyperviseur intégré au noyau Linux (Kernel-based Virtual Machine) · **LUKS** : chiffrement complet du disque sous Linux (Linux Unified Key Setup) · **BTRFS** : système de fichiers à instantanés (B-tree file system) · **NAT** : traduction d'adresses (Network Address Translation) · **WAN** : côté extérieur du pare-feu (réseau NAT 192.168.122.0/24) · **LAN** : réseau local du labo 10.10.10.0/24 · **WG** : WireGuard : tunnel VPN chiffré, port UDP 51820 · **DNS** : résolution des noms (Domain Name System) · **NTP** : synchronisation de l'heure (Network Time Protocol) · **AD DS** : services de domaine Active Directory · **LDAP** : protocole d'accès à l'annuaire (Lightweight Directory Access Protocol) · **SMB** : partage de fichiers Windows (Server Message Block), port 445 · **SNMP** : supervision des équipements réseau (Simple Network Management Protocol), port UDP 161 · **TLS** : chiffrement des échanges (Transport Layer Security) · **SSH** : administration à distance chiffrée

(Secure Shell), port 22 · **GPO** : stratégie de groupe Windows (Group Policy Object) · **AGDLP** : comptes → groupes Globaux → groupes de Domaine Local → Permissions · **RBAC** : contrôle d'accès fondé sur les rôles (Role-Based Access Control) · **FIM** : surveillance de l'intégrité des fichiers (File Integrity Monitoring) · **whodata** : mode FIM de Wazuh qui enregistre aussi l'auteur et le processus · **TCP / UDP** : protocoles de transport, avec ou sans connexion · **ufw** : pare-feu local de Debian et Ubuntu (Uncomplicated Firewall) · **DC** : contrôleur de domaine (Domain Controller) · **SIEM** : collecte et corrélation des journaux de sécurité (Security Information and Event Management) · **VM** : machine virtuelle · **Gio / Go** : gibioctets (mémoire, 2^{30} octets) / gigaoctets (disque, 10^9 octets) · **agent invité** : service QEMU dans la VM qui reçoit les ordres de l'hyperviseur (guest agent)

Matrice des flux autorisés

Source	Destination	Protocole et port	Usage	Contrôle
Internet	pfSense WAN `192.168.122.95`	UDP 51820	Négociation et trafic WireGuard	Redirection firewalld sur l'hôte ; règle WAN pfSense
`admin-remote10.10.20.2`	`10.10.10.0/24`	Tous	Administration à distance	Règle WG_REMOTE ; restriction aux interfaces d'administration prévue
`employe-remote10.10.20.3`	TrueNAS `10.10.10.20`	TCP 445	Partage de fichiers	Règle WG_REMOTE ; ACL du groupe Active Directory sur le partage
fedora `10.10.10.30` (Prometheus)	DC `10.10.10.10`	TCP 9182	Métriques windows_exporter	Collecte en *pull*
fedora `10.10.10.30` (Prometheus)	fedora (local)	TCP 9100	Métriques node_exporter	Port retiré du firewall local (F-05)
fedora `10.10.10.30` (Zabbix)	pfSense LAN `10.10.10.254`	UDP 161	Interrogation SNMP v2c du firewall	Règle LAN réservée au collecteur ; toute autre source refusée et journalisée (PV-04)
DC, fedora (agents Wazuh)	wazuh-siem `10.10.10.40`	TCP 1514, 1515	Logs, intégrité, conformité ; enrôlement des agents	Agents authentifiés parle gestionnaire
Postes du segment	DC `10.10.10.10`	DNS 53, Kerberos 88, LDAP 389/636, SMB 445	Services d'annuaire	Firewall local Windows
Segment interne	pfSense LAN `10.10.10.254`	DNS 53, HTTPS 443	Résolution, administration	HTTP 80 encore ouvert (F-02, correction planifiée)
Tout autre flux depuis WG_REMOTE	—	—	—	Refusé et journalisé (refus implicite)

Couches OSI de chaque composant Les schémas du dossier portent en badge la couche OSI de chaque composant. Chaque badge donne la couche la plus haute qu'utilise le composant pour son rôle dans le schéma : un switch s'arrête à la trame (L2), le firewall route et filtre par adresse et par port (L3-L4), un serveur rend un service (L7).

Composant	Couche OSI	Ce qu'il traite à cette couche
Postes `admin-remote` et `employe-remote`, client de recette `wg-client`	L7	Les applications de l'utilisateur ; le client WireGuard chiffre leurs paquets IP
Internet	L3	L'acheminement des paquets IP d'un réseau à l'autre

Composant	Couche OSI	Ce qu'il traite à cette couche
Router d'accès (box), hôte TeneT (NAT)	L3-L4	Le routage et la traduction des adresses et des ports ; l'hôte redirige UDP 51820 vers le WAN de pfSense
`virbr0`, `br-tenet` (switch du LAN)	L2	La commutation des trames Ethernet par adresse MAC, sans lecture de l'adresse IP
pfSense `fw01`	L3-L4	Le routage entre le WAN, le LAN et le tunnel ; le filtrage par adresse, protocole et port, avec suivi d'état
Tunnel WireGuard `tun_wg0`	L3 dans L4	Des paquets IP chiffrés (couche 3) transportés dans de l'UDP, port 51820 (couche 4)
Win-Server-DC, truenas, fedora, wazuh-siem	L7	Les services : annuaire et DNS, partage SMB, supervision, SIEM
Hôte TeneT `.2` sur le LAN	L3	Une adresse IP sur le segment interne (constat F-01)

Lecture. Le seul port ouvert sur le WAN est un port UDP parce que le tunnel transporte de l'IP chiffrée dans de l'UDP. Les trois barrières de la figure 7 se lisent aussi par couches : la clé WireGuard au niveau du tunnel (couche 3, dans UDP), la règle pfSense au niveau des adresses et des ports (couches 3 et 4), les droits Active Directory au niveau du partage SMB (couche 7).

Annexe O · Procès-verbal de recette et de supervision (PV-04)

Projet : Hybrid InfraSec · **Date des essais :** 11/10/2026 · **Opérateur :** RJ (`admin`)

Référentiel : plan de mise en production (étapes E8 à E10, grille d'acceptation), cahier des charges (EF5, SLA, RTO), dossier de supervision (chapitre 6.1)

Horodatage. Les heures sont données en heure de Paris (UTC+2). Les machines Linux de test journalisent en UTC : 09:05 UTC sur une capture correspond à 11:05 à Paris.

1. Banc de recette Le client de recette `wg-client` est une machine virtuelle dédiée (Fedora Cloud 44, 1 Go), placée sur le réseau WAN du laboratoire. Avant l'essai, sa table de routage ne contenait que la route par défaut et le réseau WAN : **aucune route vers `10.10.10.0/24` hors du tunnel**. Sa paire de clés a été générée sur le poste (`umask 077`) ; seule la clé publique a été déclarée sur le firewall, sur le peer `employe-remote` (`10.10.20.3/32`). Le client achemine tout le segment `10.10.10.0/24` dans le tunnel, afin que chaque flux interdit soit présenté au firewall et que le test de refus puisse échouer.

Points de retour préalables : snapshot de l'hyperviseur `PRE-RECETTE-WG-STABLE` ; snapshot de la VM firewall avant l'essai de restauration.

2. Accès distant WireGuard

Critère	Mesure	Seuil	Résultat
Établissement du tunnel	`wg show` : `latest handshake:` `Now` , octets dans les deux sens	Oui	✅ Conforme
Chiffrement des flux	Capture côté WAN (`tcpdump -ni ens3 udp port 51820`) : 20 paquets, tous UDP 51820 entre le client et le WAN du firewall	Aucune donnée en clair	✅ Conforme
Session du collaborateur	`nc -zv 10.10.10.20 445` depuis le client : `succeeded` (après correction INC-07)	Établie	✅ Conforme
Refus des autres flux	11:00:00 — contrôleur de domaine 445 et 3389, nœud de containers 22, console Wazuh 443 : quatre `timed out` , quatre blocages journalisés sur `WG_REMOTE` (*Default deny rule IPv4*)	Refusées	✅ Conforme
Révocation d'un accès	Sonde chaque seconde vers le partage ; peer désactivé sur le firewall : dernier succès 11:05:32, premier échec 11:05:33	< 5 min	✅ Conforme — coupure au cycle de sonde suivant (granularité 1 s)
Refus de la clé révoquée	Accès refusé sans interruption pendant toute la désactivation (≥ 35 s observées) ; nouvelle négociation et accès rétabli après réactivation du peer	Refus	✅ Conforme

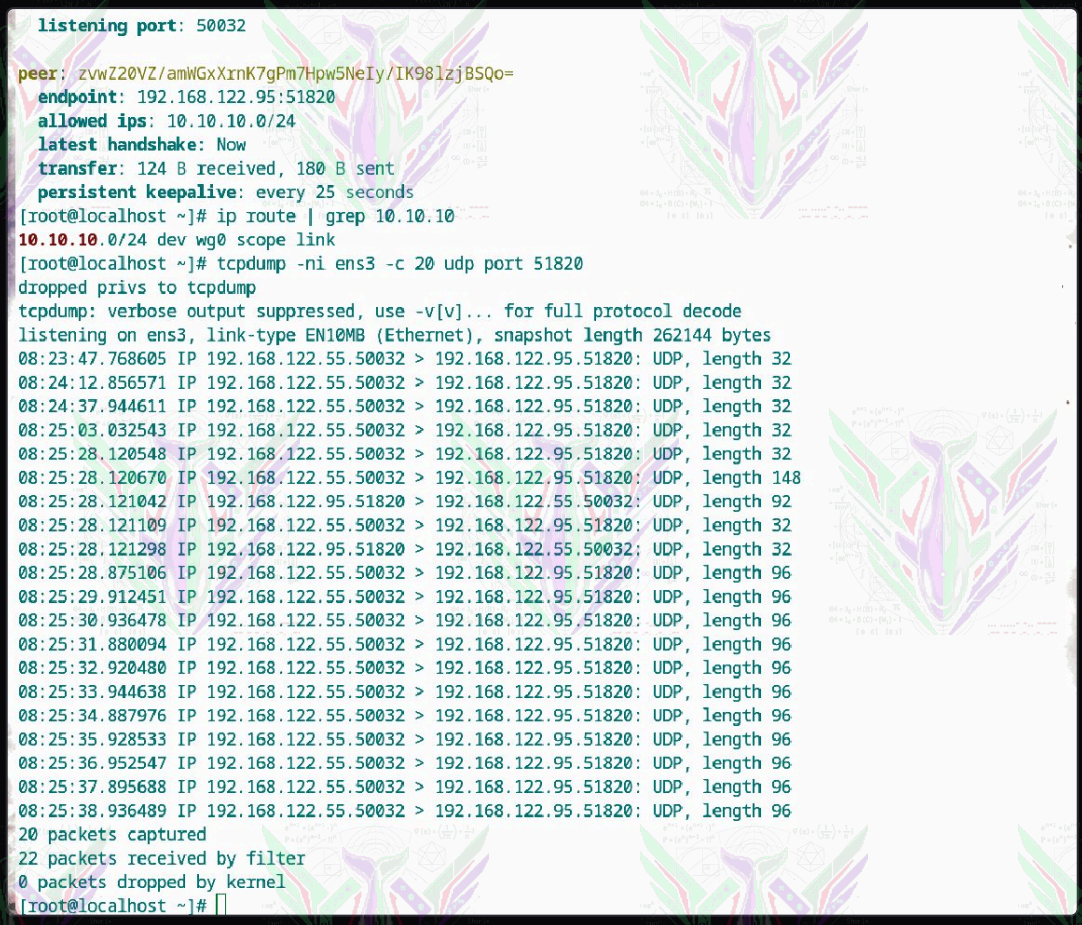


Figure 39 Négociation établie et capture côté WAN : seul du trafic UDP 51820 chiffré circule

Capture d'écran réelle du labo ; les adresses sont privées (RFC 1918).

30 Matched Firewall Log Entries. (Maximum 500)

Action	Time	Interface	Rule	Source	Destination	Protocol
✕	Oct 6 12:45:38	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:53992	10.10.10.20:443	TCP:S
✕	Oct 6 12:45:39	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:53992	10.10.10.20:443	TCP:S
✕	Oct 6 12:45:40	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:53992	10.10.10.20:443	TCP:S
✕	Oct 6 12:45:41	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:45184	10.10.10.40:443	TCP:S
✕	Oct 6 12:45:42	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:45184	10.10.10.40:443	TCP:S
✕	Oct 6 12:45:43	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:45184	10.10.10.40:443	TCP:S
✕	Oct 11 10:25:32	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:57978	10.10.10.10:445	TCP:S
✕	Oct 11 10:25:33	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:57978	10.10.10.10:445	TCP:S
✕	Oct 11 10:25:34	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:57978	10.10.10.10:445	TCP:S
✕	Oct 11 10:25:35	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:54894	10.10.10.10:3389	TCP:S
✕	Oct 11 10:25:36	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:54894	10.10.10.10:3389	TCP:S
✕	Oct 11 10:25:37	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:54894	10.10.10.10:3389	TCP:S
✕	Oct 11 10:25:38	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:46102	10.10.10.30:22	TCP:S
✕	Oct 11 10:25:39	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:46102	10.10.10.30:22	TCP:S
✕	Oct 11 10:25:40	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:46102	10.10.10.30:22	TCP:S
✕	Oct 11 10:25:41	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:45580	10.10.10.40:443	TCP:S
✕	Oct 11 10:25:42	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:45580	10.10.10.40:443	TCP:S
✕	Oct 11 10:25:43	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:45580	10.10.10.40:443	TCP:S
✕	Oct 11 11:00:01	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:54002	10.10.10.10:445	TCP:S
✕	Oct 11 11:00:02	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:54002	10.10.10.10:445	TCP:S
✕	Oct 11 11:00:03	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:54002	10.10.10.10:445	TCP:S
✕	Oct 11 11:00:04	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:41592	10.10.10.10:3389	TCP:S
✕	Oct 11 11:00:05	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:41592	10.10.10.10:3389	TCP:S
✕	Oct 11 11:00:06	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:41592	10.10.10.10:3389	TCP:S

Figure 40 Journal de filtrage : flux interdits du collaborateur bloqués sur WG_REMOTE (essais de 11:00)

Capture d'écran réelle du labo ; les adresses sont privées (RFC 1918).

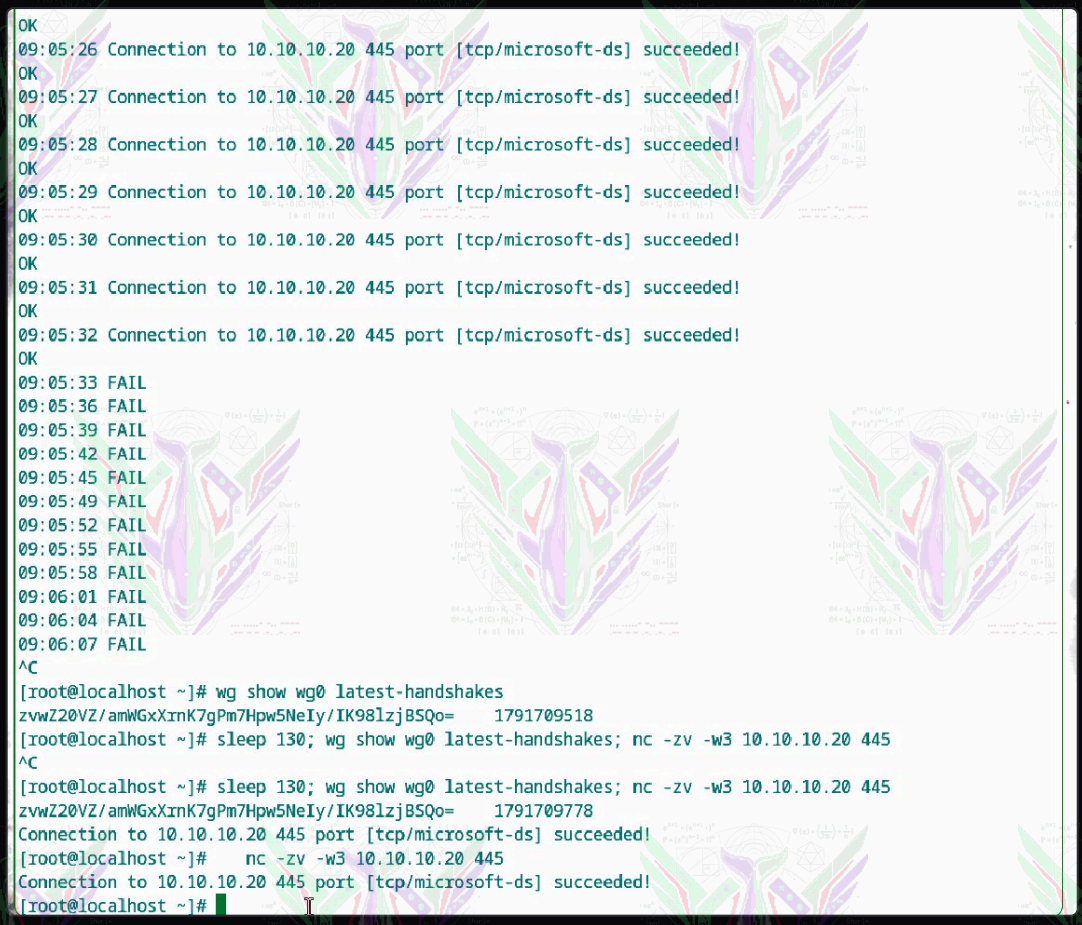


Figure 41 Révocation : passage du succès à l'échec à la seconde près, puis rétablissement après réactivation

Capture d'écran réelle du labo ; les adresses sont privées (RFC 1918).

Incident pendant la recette. Le premier essai de session a échoué malgré une négociation établie. Le diagnostic par captures successives a localisé la cause dans l'adressage de l'interface `WG_REMOTE` (INC-07, annexe J). L'essai a été rejoué après correction ; les essais de refus ont été rejoués ensuite, car un refus n'est probant que si le flux autorisé passe.

Hors périmètre de cet essai. Le profil administrateur (`admin-remote`) n'a pas été rejoué avec le client de recette : sa règle (réseau interne complet) est vérifiée dans la configuration, et sa restriction aux seules interfaces d'administration reste planifiée. Le refus vers Internet n'est pas testable avec cette configuration du client, qui n'achemine que le segment interne dans le tunnel.

3. Reprise de la configuration du firewall

Étape	Heure	Constat
Snapshot de la VM firewall	11:14	`pre-restore-test` créé
Export de la configuration	11:15	Fichier XML conservé hors ligne (il contient des secrets)
Modification témoin	11:21	Domaine DNS du firewall passé de `infrasec.lab` à `restoretest.lab`
Restauration de l'export	≈ 11:21	Redémarrage du firewall
Paquets réinstallés	11:23:43	Notification « Package reinstall process finished successfully »
Vérification	11:28	Domaine du firewall revenu à `infrasec.lab` ; session SMB par le tunnel `succeeded`

Résultat : ✅ Conforme. La configuration complète — règles, interface et peers du tunnel — est restaurée depuis l'export en moins de cinq minutes, service vérifié de bout en bout. L'objectif de reprise (< 1 heure) est tenu.

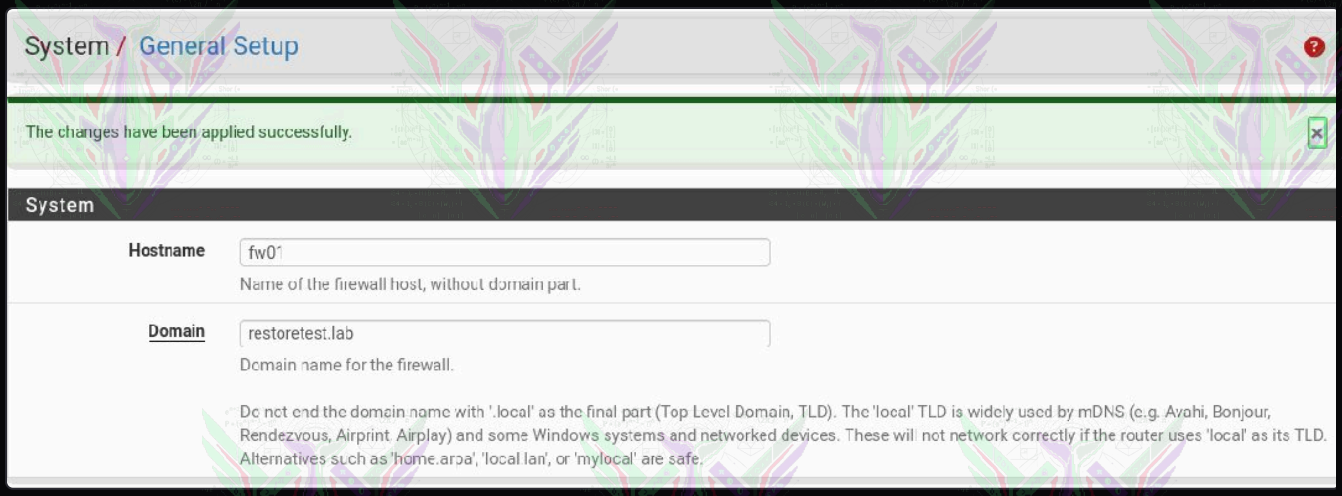


Figure 42 Avant restauration : modification témoin du domaine

Capture d'écran réelle du labo ; les adresses sont privées (RFC 1918).

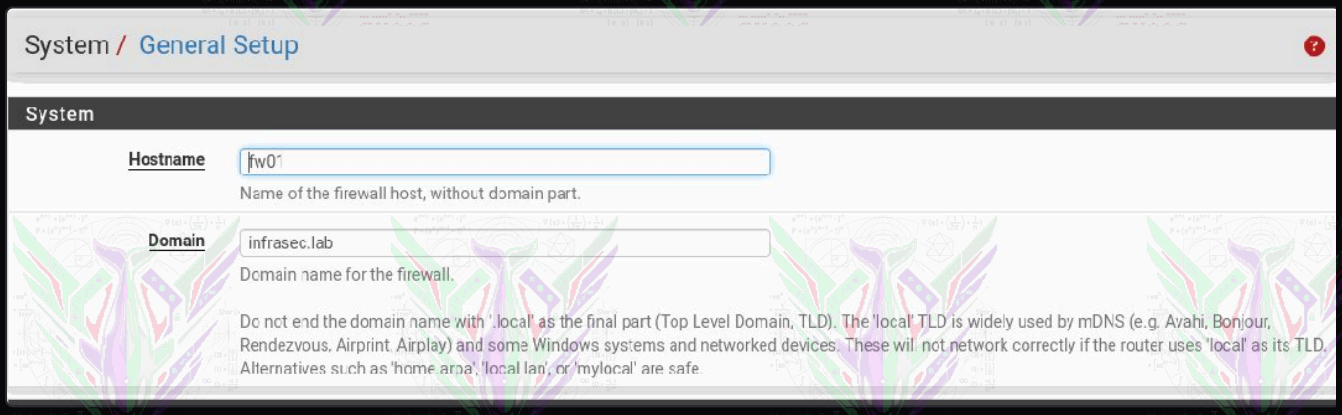


Figure 43 Après restauration : domaine d'origine rétabli

Capture d'écran réelle du labo ; les adresses sont privées (RFC 1918).

4. Supervision réseau du firewall (SNMP et Zabbix)

Mise en œuvre. Zabbix 7.0 est déployé sur le nœud de containers en **Podman rootless** (pod `zabbix` : base PostgreSQL, serveur, interface web sur le port 8080, sans privilège). Les secrets (mot de passe de la base, communauté SNMP) sont générés aléatoirement et stockés dans un fichier `.env` en mode 600, hors de tout livrable. Le firewall est déclaré avec le modèle *PFSense by SNMP*.

Hardening. Le démon SNMP du firewall est lié à la seule interface LAN, avec une communauté aléatoire de 24 caractères hexadécimaux (la valeur par défaut `public` de la configuration n'est plus utilisée). Deux règles placées avant la règle LAN par défaut restreignent l'interrogation au seul collecteur :

Règle LAN	Source	Destination	Action
SNMP — collecteur Zabbix	`10.10.10.30`	firewall, UDP 161	Autoriser
SNMP — refus hors collecteur	réseau LAN	firewall, UDP 161	Bloquer et journaliser

Critère	Mesure	Résultat
Interrogation depuis le collecteur	`snmpget … sysName.0` → `fw01.infrasec.lab`	✅ Répond
Interrogation depuis un autre hôte du LAN	Même requête depuis l'hyperviseur → `Timeout`	✅ Refusée

Critère	Mesure	Résultat
Collecte Zabbix	Disponibilité SNMP au vert ; 100 éléments collectés (interfaces WAN, LAN et `tun_wg0`, état DHCP et DNS, 92 règles de filtrage)	✅ Opérationnelle
État du tunnel visible	Élément `tun_wg0 (WG_REMOTE): Operational status = up (1)`	✅ Visible

Floating WireGuard WAN LAN WG_REMOTE

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
✓	0/561 KiB	*	*	*	LAN Address	443 80	*	*		Anti-Lockout Rule	⚙
✓	0/0 B	IPv4 UDP	10.10.10.30	*	This Firewall (self)	161 (SNMP)	*	none		SNMP - collecteur Zabbix (fedora)	
✗	0/13 KiB	IPv4 UDP	LAN subnets	*	This Firewall (self)	161 (SNMP)	*	none		SNMP - refus hors collecteur	
✓	1/197.91 MiB	IPv4 *	LAN subnets	*	*	*	*	none		Default allow LAN to any rule	
✓	0/0 B	IPv6 *	LAN subnets	*	*	*	*	none		Default allow LAN IPv6 to any rule	

Figure 44 Règles LAN : interrogation SNMP réservée au collecteur

Capture d'écran réelle du labo ; les adresses sont privées (RFC 1918).



Figure 45 Zabbix : firewall interrogé en SNMP (disponibilité au vert)

Capture d'écran réelle du labo ; les adresses sont privées (RFC 1918).



Figure 46 Zabbix : données collectées sur le firewall, dont l'état du tunnel

Capture d'écran réelle du labo ; les adresses sont privées (RFC 1918).

Limite assumée. SNMP v2c reste admis en laboratoire, compensé par la restriction au collecteur et l'écoute limitée au LAN ; **SNMP v3** (*authPriv*) reste la cible de production.

5. Alerte de disponibilité (Grafana)

Règle. « Cible injoignable » : requête Prometheus `up`, condition *inférieur à 1*, évaluation toutes les 30 s, période d'attente 2 min, étiquette `severity=critical`, dossier `Hybrid-InfraSec`. Elle couvre les trois cibles : contrôleur de domaine, nœud de containers, Prometheus.

Heure	Événement
13:11:18	Arrêt du service `node-exporter` du nœud de containers
≈ 13:11:30	`up = 0` ; règle en **Pending**
≈ 13:13:30	Règle en **Firing** (après les 2 min d'attente)
13:16:52	Redémarrage du service ; `up = 1`
≈ 13:17	Retour à **Normal**

Résultat : ✅ **Conforme** au seuil défini (« cible injoignable > 2 min : critique »).

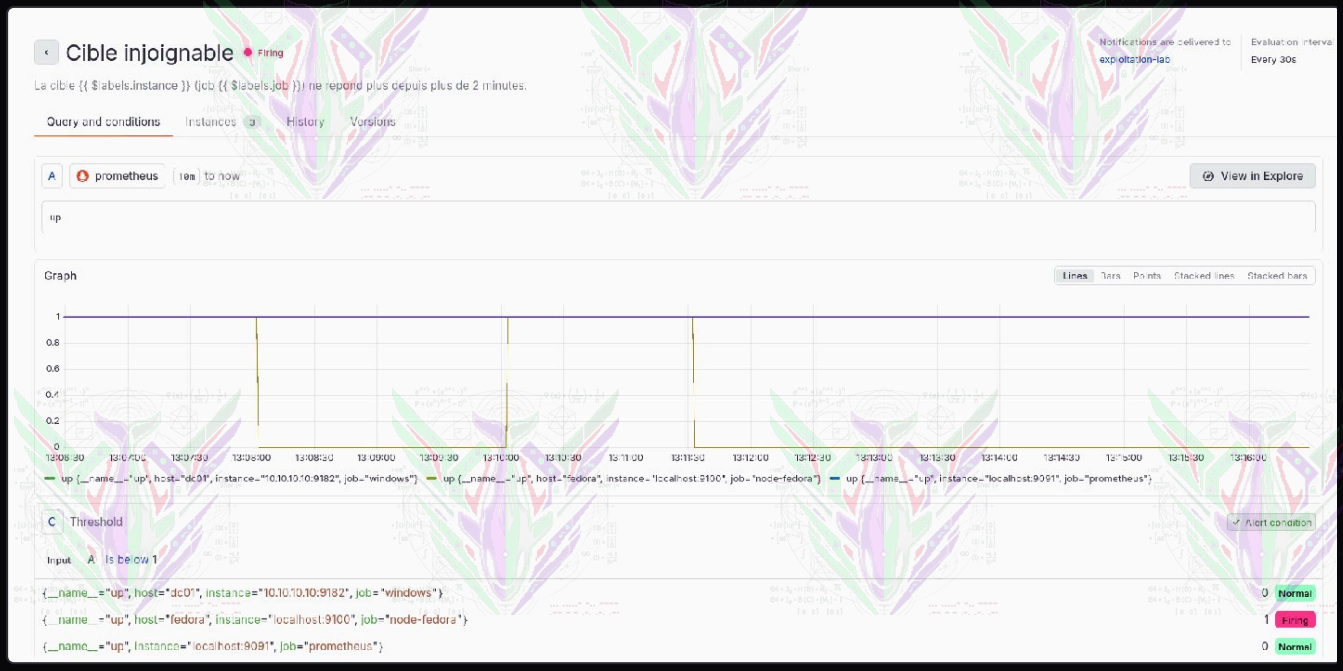


Figure 47 Alerte « Cible injoignable » au déclenchement

Capture d'écran réelle du labo ; les adresses sont privées (RFC 1918).

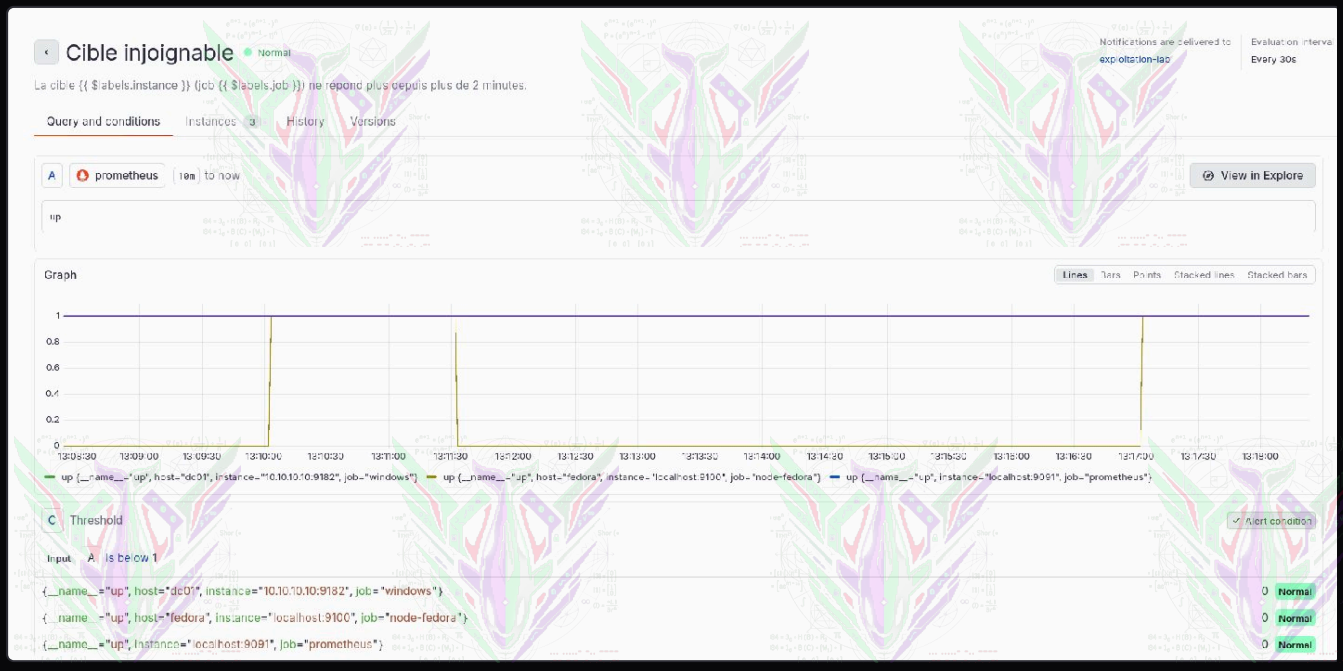


Figure 48 Retour à l'état normal après redémarrage du service

Capture d'écran réelle du labo ; les adresses sont privées (RFC 1918).

Constat utile. Un premier essai par `podman stop` n'a provoqué aucune alerte : le container est piloté par un service *systemd* utilisateur qui le redémarre en moins d'une seconde. C'est une résilience réelle de la supervision ; l'essai a donc été conduit en arrêtant le service lui-même.

Limite assumée. Le point de contact `exploitation-lab` est déclaré, mais aucun relais de messagerie n'existe dans le laboratoire : l'alerte est visible dans la console, pas encore envoyée. Le raccordement à un relais SMTP est la prochaine étape d'exploitation.

6. Règle de détection Wazuh 100100 (force brute SSH)

Déploiement. Règle locale ajoutée à `local_rules.xml` depuis la console Wazuh (*Server management* → *Rules*), ensemble de règles rechargé sur le gestionnaire (« Cluster reloaded in 1 node »). Contenu : annexe K, §6.

Rejeu de l'attaque de PV-03. À 13:44:10, huit tentatives SSH sur des comptes inexistants (`fake1` à `fake8`) depuis l'hyperviseur vers le nœud de containers.

Champ de l'alerte	Valeur
Horodatage	13:44:12.463, soit environ 2 s après le début de l'attaque
Règle	100100, niveau **12**
Agent	`fedora` (`10.10.10.30`)
Source	`10.10.10.2` , déclenchement à la 5e tentative (`fake5`)
Corrélation	quatre tentatives précédentes rattachées (`previous_output`)
MITRE ATT&CK	T1110.001 — *Credential Access, Password Guessing*

Résultat : ✅ Conforme. La corrélation native (règle 5712) attendait huit tentatives en deux minutes, au niveau 10 ; la règle locale déclenche dès la cinquième tentative en soixante secondes, au niveau 12.

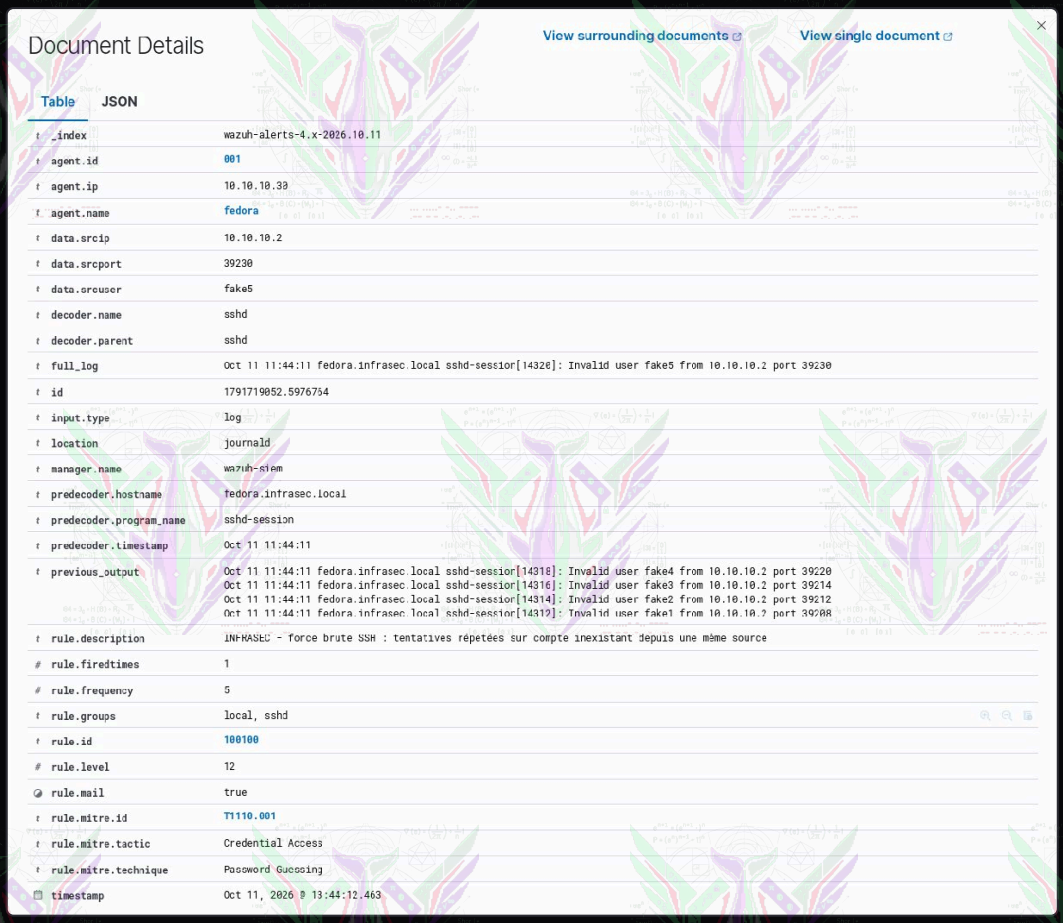


Figure 49 Alerte 100100 : source, compte visé, corrélation et technique MITRE

Capture d'écran réelle du labo ; les adresses sont privées (RFC 1918).

7. Gel de fin de recette

Élément	Constat
Snapshots de l'hyperviseur (Snapper)	`POST-RECETTE-WG-STABLE`, `POST-RESTORE-PFSENSE-STABLE`, `POST-SNMP-ZABBIX-STABLE`, `POST-ALERTE-GRAFANA-STABLE`, `POST-REGLE-100100-STABLE`, `POST-RECETTE-COMPLETE-STABLE`
Snapshots des cinq VM	`gel-20261011` créé à chaud sur le firewall, le contrôleur de domaine, TrueNAS, le nœud de containers et Wazuh, sans arrêt de service
Registre d'intégrité de l'infrastructure	Empreintes SHA-256 des définitions des cinq VM et de leurs listes de snapshots (tableau ci-dessous). Les fichiers de définition restent hors ligne : ils contiennent les adresses matérielles des interfaces

Fichier	Empreinte SHA-256
`fedora.xml`	`a2d52fac951f7e7a1113688268c3df297b3056f307ded16fade5be1881514a91`
`pfsense-fw.xml`	`ec29739e051ff52d83b4cd78cee00d9a85f0af82732afd2803e017cc62a4e7f7`
`truenas.xml`	`789dafc9699cb278c37a3976ce2ea982352411f77cc308c3bd71866c663db8de`
`wazuh-siem.xml`	`df6b563447e2ae6a801f45cbbbb67363c480d22d8c5b9ad96464ee773a3a86b5`
`Win-Server-DC.xml`	`222f4555860fd8aff0f04dd3079bff9ebd3ffa7f37ce43508cd684d896846317`
`fedora.snapshots.txt`	`fb353f71e7ac9397abee459150c0b566095a94548e7fb566352a0fd1375aa59c`
`pfsense-fw.snapshots.txt`	`84f374a37602b294dd7539fad53c1dbd81484fd670fe086c9c8159c043064c0c`

Fichier	Empreinte SHA-256
`truenas.snapshots.txt`	`e966c30cd4f807d6cd0c600b9da847c9d02c78abd0549b5e32f1ed6b81c0f5c1`
`wazuh-siem.snapshots.txt`	`b2f98dc56101ebb8fc5af56e379aacc2e7f74db541b35969971fdc46ccb3452e`
`Win-Server-DC.snapshots.txt`	`1ead8823ab104e87e785d45657943477398be7f4c4a7769a579b9b5654dfab9f`

8. Conclusion Les critères essentiels de la grille d'acceptation sont satisfaits : tunnel chiffré, session du collaborateur limitée à son seul service, refus journalisés, révocation effective à la seconde, reprise de configuration en moins de cinq minutes. La supervision couvre désormais l'équipement réseau (SNMP restreint au collecteur), alerte sur l'indisponibilité d'une cible et détecte la force brute SSH dès la cinquième tentative. **La mise en production de l'accès distant est prononcée.**

Réserves, suivies au plan d'action : rotation du mot de passe administrateur de Wazuh (à effectuer) ; essai du profil administrateur et restriction de sa règle aux seules interfaces d'administration ; passage de SNMP en v3 ; raccordement de l'alerte à un relais de messagerie.

Annexe P · Fiches CCP3 complètes (octobre 2026)

◆ INC-08 — Disponibilité : Cockpit de l'hyperviseur injoignable hors du réseau domestique

Date du constat : 21/10/2026 · **Correction :** 23/10/2026
Actif concerné : hyperviseur `HV01` (hôte `TeneT`, Fedora Linux 44) — service `cockpit.socket`, firewall de l'hôte (`firewalld`, zone `public`)
Impact : perte de la console d'administration web de l'hyperviseur ; les VM et leurs services ne sont pas touchés. Administration poursuivie par l'accès de secours (`virsh` / virt-manager sur la console locale).

Symptôme

Connecté au partage de connexion d'un smartphone au lieu du réseau domestique, l'hôte n'offre plus Cockpit, ni depuis le réseau ni en local (`https://localhost:9090`).

Diagnostic

1. `systemctl cat cockpit.socket` : un fichier local (drop-in) remplace l'écoute par défaut — `ListenStream=` (remise à zéro) puis `ListenStream=192.168.1.188:9090`.
2. `ss -tlnp | grep 9090` : Cockpit n'écoute que sur `192.168.1.188:9090`, l'adresse de l'hôte sur le réseau domestique.
3. `firewall-cmd --list-all` : le service `cockpit` n'est pas ouvert à toute la zone ; une règle riche l'autorise depuis `192.168.1.0/24` seulement.

Cause racine

Deux mesures de durcissement superposées, dont une mal placée. La règle firewalld restreint qui peut joindre Cockpit : c'est le bon niveau. L'écoute épinglée sur une adresse lie en plus la **disponibilité** du service à un réseau précis : sur un autre réseau, l'adresse n'existe plus et Cockpit n'écoute plus nulle part, même en local.

Résolution

`systemctl revert cockpit.socket` (suppression de la surcharge locale), `daemon-reload`, redémarrage du socket. La règle firewalld est conservée : l'accès distant reste limité au réseau d'administration.

Preuve

- Aucun drop-in local ; unité d'origine `/usr/lib/systemd/system/cockpit.socket` : `ListenStream=9090`.
- `ss` : écoute sur `*:9090`.
- `curl -skI https://localhost:9090` → `HTTP/1.1 200 OK` ; console ouverte sur `localhost:9090`.
- Règle conservée : `rule family="ipv4" source address="192.168.1.0/24" service name="cockpit" accept`.
- **Test en conditions réelles (23/10, 23:52-23:54)**, poste sur le partage de connexion (`wlo1` = `172.20.10.2`) :
- avant (ancienne adresse) : `192.168.1.188:9090` → *The connection has timed out* (l'adresse n'existe pas sur ce réseau) ;
- après : `https://localhost:9090` ouvert, terminal disponible.

Enseignement

(1) On restreint l'accès au niveau du firewall, pas en liant le service à une adresse : la première mesure protège, la seconde ne fait que casser la disponibilité. (2) Un durcissement se teste sur tous les réseaux où l'on travaille réellement. (3) Un accès de secours documenté et éprouvé (console locale, `virsh`) est ce qui a permis de continuer : sécurité et disponibilité se conçoivent ensemble.

◆ INC-09 — Supervision : le pod Zabbix ne redémarre pas avec la VM (déploiement hors systemd)

Date : 23/10/2026
Actif concerné : VM `fedora` (`10.10.10.30`), utilisateur rootless `ais` — pod `zabbix` (`zbx-db`, `zbx-server`, `zbx-web`)
Impact : supervision SNMP du firewall `fw01` interrompue (zone aveugle) ; aucune perte de données. Prometheus, node-exporter et Grafana non affectés.

Symptôme

Après le redémarrage de la VM `fedora`, l'interface web de Zabbix (port 8080) ne répond plus. `podman ps -a` montre les trois conteneurs du pod `Exited (0) 2 days ago`, alors que `prometheus`, `node-exporter` et `grafana` sont `Up 18 minutes` : ils ont redémarré seuls.

Diagnostic

1. `systemctl --failed` : aucune unité en échec. Le pod ne plante pas : il n'est simplement pas lancé.
2. `loginctl list-users` : `Linger=yes` pour `ais`, donc les services utilisateur démarrent au boot sans session ouverte.
3. `ls ~/.config/containers/systemd/` : Prometheus, node-exporter et Grafana sont déclarés en fichiers **Quadlet** (`*.container`), transformés en services systemd au démarrage (`grafana.service` : `generated`). Le pod `zabbix`, créé à la main douze jours plus tôt (`podman pod create` / `podman run`), n'a **aucun** fichier Quadlet.

Cause racine

Déploiement incohérent de la chaîne de supervision : trois composants déclarés à systemd, un composant lancé manuellement. Rien ne relance ce dernier au démarrage.

Constat associé (écart à la PSSI, art. 11 — secrets)

`podman secret ls` vide : le mot de passe de la base PostgreSQL était passé en variable d'environnement en clair, donc lisible par `podman inspect` et probablement présent dans l'historique du shell.

Résolution

1. Point de retour : instantané `pre-zabbix-quadlet` de la VM (`virsh snapshot-create-as`).
2. Mot de passe transféré dans un secret Podman `zbx-db-password` **sans affichage** (`podman inspect … | sed … | podman secret create zbx-db-password -`).
3. Pod décrit en Quadlet : `zabbix.pod`, `zbx-db.container`, `zbx-server.container`, `zbx-web.container` (dépendances `Requires=` / `After=`, `Restart=always`, `WantedBy=default.target`, `Secret=…,type=env`). Validation par `quadlet -dryrun -user` avant toute bascule.
4. Bascule : `podman pod rm zabbix` (le volume nommé `zbx-pg` est conservé), `daemon-reload`, démarrage.

Incident secondaire pendant la bascule : refus SELinux

`zbx-db` s'arrête aussitôt : `chmod: /var/lib/postgresql/data: Permission denied`, alors que les fichiers appartiennent bien à `70:70` (utilisateur `postgres` de l'image) dans l'espace de noms. Le journal d'audit le confirme :

```
avc: denied { setattr } comm="chmod" name="_data" scontext=…container_t:s0:c272,c377
tcontext=…container_file_t:s0:c125,c516 permissive=0
```

Les types sont corrects ; seules les **catégories MCS** diffèrent : le volume portait l'étiquette privée de l'ancien conteneur. Correction : option `:Z` sur le volume (`Volume=zbx-pg:/var/lib/postgresql/data:Z`), qui le ré-étiquette pour son nouveau propriétaire. SELinux reste en mode `enforcing`.

Preuve

- Après bascule : les quatre unités `active (running)`, `curl -sI http://127.0.0.1:8080` → `HTTP/1.1 200 OK`, PostgreSQL `database system is ready to accept connections` (récupération WAL terminée, aucune perte).
- `podman inspect zbx-db … | grep -c '^POSTGRES_PASSWORD='` → `0` : le mot de passe n'apparaît plus dans la configuration du conteneur.
- **Test de non-régression** : arrêt puis démarrage complets de la VM ; à `up 1 min`, les sept conteneurs (dont `zbx-db`, `zbx-server`, `zbx-web`) sont `Up` sans intervention, et l'interface répond `200 OK`.

Contrôle fonctionnel

Zabbix → Hosts : `fw01` (`10.10.10.254:161`) disponible en **SNMP**, 100 éléments collectés. Le graphe « Packet filter reason codes » montre un trou de collecte (zone aveugle) puis la reprise des valeurs à 23:14, juste après la bascule.

Fausse alerte ouverte depuis 12 jours (constat associé)

Le tableau de bord affichait depuis le 11/10 « Linux: Zabbix agent is not available » sur l'hôte `Zabbix server` : le modèle « Linux by Zabbix agent » attendait un agent sur `127.0.0.1:10050`, alors qu'aucun agent n'est déployé. L'architecture répartit pourtant les rôles : Prometheus et node-exporter supervisent Linux, Zabbix supervise le firewall en SNMP. Correction : modèle délié et nettoyé (« Unlink and clear », 121 → 78 éléments), interface agent supprimée ; seul « Zabbix server health » (éléments internes) est conservé. Widget « Host availability » étendu au SNMP ; widget Geomap supprimé (aucune localisation renseignée). Résultat : 0 problème, 78 déclencheurs dont 0 en état problème, `fw01` « Available ».

Clôture du constat « secret en clair »

- Rotation du mot de passe PostgreSQL : nouveau mot de passe aléatoire de 32 caractères, généré dans une variable du shell, transmis à `psql` par l'entrée standard (`ALTER ROLE`), puis écrit dans le secret (`podman secret create --replace`) ; jamais affiché. Redémarrage de `zbx-server` et `zbx-web` : connexion à la base sans erreur, `HTTP/1.1 200 OK`.
- Historique du shell : **5** lignes contenaient l'ancien mot de passe (`grep -c 'POSTGRES_PASSWORD=' ~/.bash_history` → `5`), ce qui confirme l'exposition ; supprimées (`→ 0`).
- Volumes : plus aucun volume orphelin ; restent `prometheus-data`, `grafana-data`, `zbx-pg`, `zbx-export`, `zbx-snmptraps`.

Enseignement

(1) Un service n'est en production que s'il est **déclaré** : tout conteneur lancé à la main est un incident différé ; la règle devient « un service = un fichier Quadlet versionné ». (2) Un refus d'accès alors que les droits Unix sont corrects se lit dans `ausearch -m AVC` : on corrige l'étiquette, on ne désactive pas SELinux. (3) La preuve d'une correction de redémarrage est un redémarrage. (4) Un secret en variable d'environnement est un secret exposé : `podman secret` sépare la valeur de la configuration, et un secret exposé se change (rotation), il ne se cache pas. (5) Une alerte qui reste ouverte sans action n'informe plus personne : le périmètre de la supervision doit correspondre à l'architecture.

◆ INC-10 — Changement F-13 : l'hôte perd son adresse sur le LAN du labo (configuration non persistante révélée)

Date : 24/10/2026, 01:11 → 01:20 (durée de l'interruption : environ 8 minutes)
Actif concerné : hyperviseur `HV01` (hôte `TeneT`) — pont `br-tenet`, connexion NetworkManager `br-tenet`
Impact : l'hôte ne joint plus aucun service du labo (Cockpit de `fedora`, TrueNAS, API Wazuh, Grafana, Zabbix, pfSense) ; les VM restent en marche et continuent de communiquer entre elles. Aucune perte de données.
Changement à l'origine : correction de F-13 (`nmcli con mod br-tenet connection.zone lab-tenet` puis `nmcli dev reapply br-tenet`), précédée de l'instantané `PRE-F13-ZONE-LAB`.

Symptôme

Quelques minutes après le changement, toutes les interfaces web du labo expirent (*Connection has timed out*, *API is down*, *NetworkError*). `ping 10.10.10.30` depuis l'hôte : 100 % de pertes.

Diagnostic (service d'abord, puis cause)

1. Hypothèse 1, les ports des VM détachés du pont par le `reapply` : écartée. `ip -br link show master br-tenet` liste les 5 ports côté LAN (`vnet2`, `vnet3`, `vnet4`, `vnet6`, `vnet8`), tous `forwarding` (`bridge link`).
2. Hypothèse 2, la nouvelle zone bloque les réponses : remise de `br-tenet` dans `public` à chaud ; le ping échoue toujours. La zone n'est pas en cause.
3. `ip -br addr show dev br-tenet` : le pont est `UP` **sans adresse** ; plus de route `10.10.10.0/24`. `nmcli con show br-tenet` : `ipv4.method: disabled`, `ipv4.addresses: --`.

Cause racine

L'adresse `10.10.10.2/24` de l'hôte n'avait jamais été déclarée dans NetworkManager : elle avait été ajoutée à la main (`ip addr add`), comme l'indiquait déjà la route `10.10.10.0/24` sans métrique (les routes créées par NetworkManager en portent une). Le `reapply` a remis la connexion dans l'état déclaré, sans adresse. La même fragilité existait à chaque redémarrage de l'hôte.

Rétablissement et correction

1. Rétablissement : `ip addr add 10.10.10.2/24 dev br-tenet` → ping `0 % de pertes`, Zabbix `HTTP/1.1 200 OK`.
2. Test isolé de la zone : `br-tenet` remis dans `lab-tenet` à chaud → ping toujours `0 % de pertes`, Zabbix `200 OK`. La zone fermée ne gêne pas les connexions sortantes de l'hôte.
3. Correction durable : adresse déclarée dans NetworkManager — `ipv4.method manual`, `ipv4.addresses 10.10.10.2/24`, `ipv4.never-default yes` (le pont ne devient jamais la route par défaut), `ipv6.method disabled` ; `reapply` rejoué volontairement : adresse présente, zone `lab-tenet`, ping `0 % de pertes`.

Enseignement

(1) Un changement « mineur » sur le réseau de l'hôte (zone firewall) a révélé une configuration non déclarée : tout ce qui n'est pas dans l'outil de configuration disparaît au premier rechargement. Règle : aucune configuration réseau à la main sur l'hôte, tout passe par `nmcli`. (2) Diagnostic par élimination : une hypothèse à la fois, chacune vérifiée par une commande (ports du pont, zone, adresse), sans toucher aux VM. (3) Le service est rétabli d'abord (adresse remise à chaud), la cause est corrigée ensuite (configuration persistante), puis la correction est éprouvée en rejouant le geste qui avait provoqué la panne. (4) Le point de retour `PRE-F13-ZONE-LAB` existait ; il n'a pas été nécessaire, parce que la cause a été trouvée en moins de dix minutes.

◆ INC-11 — Détection : le manager Wazuh échoue au démarrage, SIEM aveugle pendant 3 h 10 sans alerte

Date : 23-24/10/2026 · **Heures en UTC (journaux du SIEM)**, heure de Paris entre parenthèses
Actif concerné : VM `wazuh-siem` (`10.10.10.40` , Ubuntu 26.04.1 LTS, Wazuh 4.14.8) — service `wazuh-manager` (analyse, API `55000` , réception des agents `1514`)
Impact : de 20:17 à 23:27 UTC (22:17 → 01:27), aucun événement des agents n'est analysé et aucune alerte ne peut être levée. L'indexeur et le tableau de bord tournent : l'interface s'affiche, mais indique *[API connection] API is down*. Aucune supervision ne signale la panne.

Symptôme

24/10 à 01:16 (Paris), le tableau de bord Wazuh affiche *API is down* et *Error getting the authorization token*.

Diagnostic

1. Session de 01:49 : `systemctl is-active wazuh-manager wazuh-indexer wazuh-dashboard` → `active` ×3 ; `api.log` : authentifications `wazuh-wui` en `200` . Le service fonctionne dans le démarrage en cours ; la panne est antérieure.
2. `journalctl --list-boots` : quatre démarrages le 23/10 (UTC) — `-3` 20:17:02 → 23:27:20, `-2` 23:27:24 → 23:28:18, `-1` 23:28:20 → 23:37:12, `0` depuis 23:49:41. Le symptôme (23:16-23:21 UTC) tombe dans le démarrage `-3` .
3. `journalctl -u wazuh-manager -b -3` : `wazuh-apid: Process 1485 not used by Wazuh, removing...` → `Killed` → `wazuh-apid did not start correctly` → `Failed with result 'exit-code'` (20:17:10, après 3,4 s).
4. `journalctl -u wazuh-indexer -b -3` : indexeur démarré à 20:17:17, actif jusqu'à 23:27:17. Seul le manager manquait.
5. Démarrage `-1` : manager démarré normalement à 23:28:24 ; le service est revenu avec le redémarrage de la VM de 23:27, pas par une action corrective.

Cause racine

Un fichier PID resté d'un arrêt non propre désignait, au démarrage suivant, un numéro de processus réattribué à un autre programme. Le script de démarrage de Wazuh a retiré ce processus, l'API n'a pas démarré et le manager entier s'est arrêté en échec. Deux défauts ont transformé cet échec ponctuel en panne de trois heures :

- **aucun redémarrage automatique** : l'unité `wazuh-manager.service` n'a pas de `Restart=` ; un échec au démarrage reste un échec ;
- **personne ne surveille le SIEM** : Prometheus collecte `localhost` et le contrôleur de domaine, Zabbix le firewall en SNMP ; ni l'API (`55000`) ni la réception des agents (`1514`) ne sont contrôlées.

Correction

1. Redémarrage automatique (surcharge systemd, sans toucher à l'unité du paquet) : `/etc/systemd/system/wazuh-manager.service.d/restart.conf` → `[Service]` `Restart=on-failure` `RestartSec=30` ; `daemon-reload` . Contrôle : `systemctl show wazuh-manager -p Restart -p RestartUSec` → `Restart=on-failure` , `RestartUSec=30s` .
2. Supervision du SIEM dans Zabbix : hôte `wazuh-siem` , deux contrôles *Simple check* depuis le serveur Zabbix (`fedora`), toutes les minutes — `net.tcp.service[tcp,10.10.10.40,55000]` (API) et `net.tcp.service[tcp,10.10.10.40,1514]` (réception des agents), valeur `1` au repos. Deux déclencheurs de sévérité **High** : `max(…,#3)=0` , soit trois échecs consécutifs (un incident ou un redémarrage automatique de 30 s ne déclenche pas de fausse alerte).

Test de la détection (24/10, heure de Paris)

- 02:18:50 : `systemctl stop wazuh-manager` → `inactive` (arrêt propre : `Restart=on-failure` ne relance pas, ce qui permet le test) ;
- 02:21:13 et 02:21:14 : problèmes *SIEM : API Wazuh injoignable (55000)* et *SIEM : réception des agents arrêtée (1514)*, sévérité High, sur le tableau de bord ;
- 02:38:12 : `systemctl start wazuh-manager` → `active`. **Délai de détection : 2 min 23 s**, contre 3 h 10 sans aucune alerte lors de l'incident.

Constat associé : accès d'administration au SIEM perdu

Le mot de passe du compte `ais` de `wazuh-siem` n'était consigné dans aucun gestionnaire de mots de passe. Récupération par la console hors bande (KVM) : démarrage avec `rw init=/bin/bash`, `passwd ais`, redémarrage. Piège rencontré : dans ce shell de secours, le clavier est en QWERTY. Le nouveau mot de passe est enregistré dans le gestionnaire.

Enseignement

(1) Un service de sécurité qui peut échouer au démarrage doit redémarrer seul ; sinon un incident de quelques secondes devient une panne de plusieurs heures. (2) Il faut superviser l'outil de détection lui-même : un SIEM arrêté ne lève aucune alerte, c'est le pire des silences. (3) On lit les journaux du **bon** démarrage : `journalctl --list-boots` d'abord, puis `-b -N`. (4) Les comptes d'administration vont dans un gestionnaire de mots de passe dès leur création.

◆ F-13 — L'hyperviseur peut relayer du trafic entre le réseau extérieur et le LAN du labo, hors pfSense

Date : 23-24/10/2026 · **Type :** constat de configuration (audit) · **Gravité :** moyenne à élevée · **Lien :** F-01 (hôte sur le LAN), scénario EBIOS SO-3

Actif concerné : hyperviseur `HV01` (hôte `TeneT`, Fedora Linux 44) — interfaces `wlo1` (réseau extérieur : domicile ou partage de connexion) et `br-tenet` (pont du LAN `10.10.10.0/24`, adresse de l'hôte `.2`), firewall de l'hôte `firewalld`

Constat

Trois conditions réunies, relevées le 23/10 :

1. L'hôte route les paquets : `net.ipv4.ip_forward = 1` (nécessaire au NAT libvirt de `virbr0`, côté WAN de pfSense).
2. L'hôte a une patte dans chaque réseau : `10.10.10.0/24` sur `br-tenet` (`src 10.10.10.2`) et `192.168.1.0/24` sur `wlo1` (`src 192.168.1.188`).
3. `br-tenet` et `wlo1` sont dans la **même zone** firewalld `public`, dont le transfert intra-zone est actif (`firewall-cmd --zone=public --query-forward` → `yes`). La zone ouvre aussi le service `ssh` de l'hôte au LAN.

Risque

Une machine du réseau extérieur qui ajoute la route « `10.10.10.0/24` via l'hôte » peut envoyer des paquets directement dans le LAN du labo, **sans passer par pfSense**, seul point de passage prévu par l'architecture. Les réponses des serveurs repartent par leur passerelle pfSense ; le filtrage à états de pfSense casse en pratique les connexions TCP (routage asymétrique), mais c'est un effet de bord, pas une protection. En sens inverse, toute machine du LAN joint le service SSH de l'hôte (rebond vers l'hyperviseur, F-01).

Limite de la preuve : constat établi sur la configuration (règles et tables de routage), sans exploitation depuis une seconde machine du réseau domestique.

Vérifications avant correction

- `lsmod | grep br_netfilter` : module non chargé ; `net.bridge.bridge-nf-call-iptables` absent. Le trafic entre VM sur le pont reste au niveau 2 et ne traverse pas le firewall de l'hôte : changer la zone du pont ne peut pas couper les échanges DC, TrueNAS, fedora.
- `firewall-cmd --list-all-policies` : aucune politique active de transfert entre zones (`gateway-*` désactivées) ; la zone `libvirt` (`virbr0`) est gérée séparément.
- `ss -tunap` sur l'hôte : toutes les connexions sur `10.10.10.2` sont **sortantes** (navigateur vers Zabbix, Grafana, Prometheus, TrueNAS, pfSense) ; `prometheus.yml` ne collecte pas l'hôte. Rien dans le labo n'a besoin de joindre l'hôte.
- Point de retour : `snapper -c root create -d "PRE-F13-ZONE-LAB"` (instantané 188, 24/10 01:10).

Correction

Zone dédiée au pont du labo, sans service et sans transfert, rattachée par NetworkManager (persistante) :

```
firewall-cmd --permanent --new-zone=lab-tenet
firewall-cmd --permanent --zone=lab-tenet --remove-forward
firewall-cmd --reload
nmcli con mod br-tenet connection.zone lab-tenet
nmcli dev reapply br-tenet
```

Preuve

- `firewall-cmd --get-active-zones` : `lab-tenet` → `br-tenet` ; `public` → `wlo1` seul.
- `lab-tenet` : `target: default`, `services:` vide, `forward: no` (`--query-forward` → `no`).
- Depuis le LAN (VM `fedora`), 24/10 02:05, hôte joignable (adresse rétablie) : `10.10.10.2:22` fermé, `10.10.10.2:9090` fermé ; témoins `10.10.10.20:445` ouvert, `10.10.10.40:55000` et `:1514` ouverts. La zone ferme les services de l'hôte au LAN sans gêner le labo.
- Un premier test (01:11) avait eu lieu pendant INC-10, alors que l'hôte n'avait plus d'adresse sur le LAN ; il n'est pas retenu comme preuve.
- Incident pendant le changement : voir INC-10 (adresse de l'hôte non persistante, révélée par le `reapply`).
- Après INC-10 : zone `lab-tenet` active sur `br-tenet` avec l'adresse `10.10.10.2/24` déclarée dans NetworkManager ; l'hôte joint toujours le labo (ping `0 %` de pertes, Zabbix `200 OK`).
- Point de stabilité : `POST-F13-ZONE-LAB-STABLE`.

Effet sur F-01

La jambe « le LAN peut joindre l'hyperviseur » est fermée. Reste l'autre jambe : l'hôte a toujours une adresse dans le LAN et peut l'atteindre (navigateur d'administration). Le traitement complet reste la mesure M-01 (réseau d'administration séparé). Conséquence assumée : l'administration de l'hôte depuis le tunnel WireGuard n'est plus possible ; l'hyperviseur était hors du périmètre de l'accès distant.

Enseignement

(1) Une zone firewalld par réseau de confiance : deux réseaux de niveaux différents dans la même zone, c'est un pont ouvert. (2) Sur un hyperviseur, `ip_forward` est souvent obligatoire ; c'est donc le firewall qui doit dire où le transfert est permis. (3) Avant de durcir, on mesure les dépendances (`ss`, configuration des collecteurs, `br_netfilter`) : la correction n'a coupé aucun service.

◆ F-14 — Disponibilité : la base de vulnérabilités du SIEM échoue à se mettre à jour quand le labo démarre dans le désordre

Période : 03/10 → 11/10/2026 (constat le 24/10) · **Type :** constat (CP8), corrigé (CP9) · **Gravité :** moyenne
Actifs concernés : VM `wazuh-siem` (module `vulnerability-scanner`, flux CVE), `Win-Server-DC` (seul DNS du labo), démarrage des VM sur l'hyperviseur `HV01`

Constat

Le journal de Wazuh, archivé à la rotation dans `/var/ossec/logs/wazuh/2026/Oct/ossec-23.log.gz` (et non dans `ossec.log`, vidé à minuit), contient 7 échecs `content-updater … Could not resolve hostname` (14 lignes : un avertissement et une erreur par échec) entre le 04/10 08:37 et le 11/10 07:59 UTC.

Corrélation

`journalctl --list-boots` sur le SIEM : chaque échec survient **47 à 48 s après le démarrage de la VM** (04/10, 05/10, 06/10, 07/10 ×2, 10/10, 11/10). Le premier téléchargement du flux part avant que le contrôleur de domaine, son unique serveur DNS, réponde. Les 21 et 23/10, le DC était déjà démarré : aucun échec. Deux démarrages (04/10, 9 h de fonctionnement ; 06/10, 5 h 30) n'ont été suivis d'aucun succès : du 03/10 09:18 au 05/10 18:45 UTC, la base CVE n'a pas été mise à jour, sans aucune alerte.

Cause racine

Aucun ordre de démarrage : aucune VM n'est en démarrage automatique, elles sont lancées à la main. Ubuntu (SIEM) démarre plus vite que Windows (DC) et dépend de son DNS.

Correction

Script `/usr/local/bin/lab` (root:root, 0755, empreinte vérifiée) :

- `lab start` : pfSense, attente de `10.10.10.254:443` ; DC, attente d'une **vraie** réponse DNS (`status: NOERROR` et au moins un enregistrement pour `infrasec.local`) ; puis TrueNAS, fedora, wazuh-siem, wg-client ;
- `lab stop` : arrêt propre ACPI dans l'ordre inverse, sans coupure forcée (supprime aussi la cause d'INC-11, le fichier PID laissé par un arrêt brutal) ;
- chaque étape tracée dans le journal : `journalctl -t lab`.

Sur le DC : arrêt accepté depuis l'écran de connexion (`shutdownwithoutlogon = 1`, bouton d'alimentation = arrêter). Accès réservé à qui a la console de la VM, donc déjà administrateur de l'hyperviseur.

Défaut trouvé pendant le test (corrigé)

Premier essai : `DNS du DC opérationnel (0 s)`, deux secondes après le démarrage de Windows. Le test vérifiait seulement que `dig` écrivait quelque chose, or `dig` écrit aussi ses messages d'échec. Corrigé (exigence de `NOERROR` et d'une réponse), vérifié sur trois cas simulés (pas de réponse, SERVFAIL, réponse valide).

Preuve (24/10 et 25/10)

- `lab start` : attente DNS réelle de 35 s, SIEM démarré 20 s après la réponse du DNS (24/10 13:24:46 → 13:25:06 ; même résultat le 25/10).
- SIEM : module démarré à 11:25:20 UTC, **aucune** erreur de résolution au moment où elle survenait auparavant ; flux à jour (`Feed update process completed`).

Point ouvert, suivi dans F-26

Le DC a ignoré la demande d'arrêt à trois reprises : 24/10 13:43 (180 s), 26/10 00:20 (180 s, arrêt seul après le délai), 26/10 20:32 (300 s, script modifié). Le script n'a jamais rien forcé. Cause et correction : F-26.

Évolution du script (26/10)

`lnx-dc01` ajouté à l'ordre (démarré après le DC Windows, avec attente d'une vraie réponse de son DNS) ; attente d'arrêt du DC Windows portée à 300 s. Empreinte `825baad6…`, copie précédente conservée (24/10). Test d'arrêt : cinq VM arrêtées proprement dans l'ordre (dont `lnx-dc01` en 5 s), deux refus signalés sans coupure (F-26).

Enseignement

(1) Une dépendance non déclarée (le DNS) transforme un ordre de démarrage en panne silencieuse. (2) Les journaux tournent : une enquête couvre aussi les archives. (3) Un contrôle de disponibilité doit exiger une vraie réponse, pas une sortie non vide : « 0 s » était le signe que le test ne pouvait pas échouer.

◆ F-15 — Le SIEM n'a aucun firewall local : tous ses services sont ouverts au LAN

Date : 25/10/2026 · **Type :** constat d'audit (CP8), corrigé (CP9) · **Gravité :** moyenne
Actif concerné : VM `wazuh-siem` (`10.10.10.40`, Ubuntu 26.04.1 LTS, Wazuh 4.14.8)

Constat

`ufw status` → `inactive`. `ss -tlnpu` montre sept services en écoute sur toutes les interfaces (`0.0.0.0` / `*`) : réception des agents (`1514`), enrôlement (`1515`), API (`55000`), tableau de bord (`443`), SSH (`22`), Cockpit (`9090`) et node-exporter (`9100`, ajouté le même jour). Seuls l'indexeur (`9200`) et son port de cluster (`9300`) écoutent en local. Toute machine du LAN, et le profil administrateur du tunnel WireGuard autorisé vers le LAN, peut donc joindre l'administration du SIEM.

Risque

Le SIEM est la machine qui détecte les attaques : sa compromission rend le labo aveugle. Exposer son API, son tableau de bord et son SSH à tout le LAN élargit la surface d'attaque sans besoin métier (moindre privilège non appliqué, PSSI art. réseau).

Analyse des flux légitimes (avant toute règle)

Port	Service	Besoin réel
1514, 1515	agents, enrôlement	agents du LAN (`fedora`, `dc01`, futurs postes)
55000	API	tableau de bord (local) et contrôle Zabbix (`10.10.10.30`, INC-11)
443, 22, 9090	tableau de bord, SSH, Cockpit	administrateur depuis l'hôte (`10.10.10.2`)
9100	node-exporter	Prometheus (`10.10.10.30`)
9200, 9300	indexeur	local seulement (déjà le cas)

Correction

Point de retour : instantané `pre-ufw` de la VM. Politique par défaut `deny incoming` / `allow outgoing`, sept règles commentées, une par flux légitime, journalisation `low`, puis `ufw enable` (l'activation conserve la session SSH ouverte, autorisée par la règle 1). Secours documenté : console KVM puis `ufw disable`.

Preuve (25/10, 12:01–12:02)

- Depuis `fedora` (`10.10.10.30`) : `1514`, `55000`, `9100` ouverts ; `22`, `443`, `9090` fermés.
- Depuis l'hôte (`10.10.10.2`) : `22`, `443`, `9090` ouverts ; `9100` fermé.
- Agents `fedora` et `dc01` toujours `Active` (`agent_control -l`).
- Un premier test lancé depuis le SIEM lui-même affichait tout « ouvert » : la connexion à sa propre adresse passe par la boucle locale, toujours autorisée. Ce test ne pouvait pas échouer ; il n'est pas retenu.

Enseignement

(1) On liste les flux légitimes avant d'écrire la première règle : chaque port s'ouvre à la seule source qui en a besoin. (2) Un test de filtrage se lance depuis une machine tierce, jamais depuis la cible. (3) On active un firewall à distance avec la règle d'accès d'administration déjà en place et une console de secours.

◆ F-16 — Le disque du SIEM n'est pas supervisé (et une fausse alerte de croissance)

Date : 24-25/10/2026 · **Type :** constat (CP8), corrigé (CP7/CP9) · **Gravité :** moyenne
Actif concerné : VM `wazuh-siem` (`10.10.10.40`), disque `/dev/vda2` (ext4, 40 Go)

Point de départ : une alarme qui était une erreur de mesure

Le 24/10, la bannière de connexion affichait 56,1 % d'utilisation et `df -h /` 60 % treize minutes plus tard ; j'en avais déduit une croissance de 1,6 Go en 13 minutes. Le 25/10, la même paire de valeurs (56,0 % puis 60 %) réapparaît, et deux `df` à une minute d'intervalle donnent 60 % et 60 %. La bannière est calculée à l'avance et mise en cache ; seul `df` mesure l'instant. Il n'y avait pas de croissance.

Analyse

- `du -xh --max-depth=1 /var/ossec/queue` : `vd` = 11 Go (base de vulnérabilités CVE de Wazuh), `indexer` = 910 Mo, le reste < 200 Mo.
- `/var/ossec/queue/vd` existe depuis le 03/10 ; la taille de la base CVE est normale pour cette version et stable.
- Conclusion : rien à supprimer. Le vrai constat : **personne ne surveille ce disque**. Prometheus collectait `fedora` et le DC ; Zabbix, le firewall et les ports du SIEM. Un doublement de la base pendant une mise à jour aurait rempli le disque sans alerte, et un SIEM au disque plein cesse d'indexer.

Correction

1. `prometheus-node-exporter` installé sur le SIEM ; port `9100` ouvert **au seul Prometheus** (`10.10.10.30`) par le firewall local (F-15).
2. Cible ajoutée par ajout en fin de fichier à `~/prometheus/prometheus.yml` sur `fedora` (copie de sauvegarde datée, fichier monté dans le conteneur, même inode conservé), validée par `promtool check config` (`SUCCESS`) avant redémarrage. Les 4 cibles sont `up = 1`.
3. Règle Grafana « Disque presque plein (Linux) », dossier `Hybrid-InfraSec`, groupe `infra` (évaluation toutes les 30 s) : `100 - 100 * node_filesystem_avail_bytes{mountpoint="/", fstype!~"tmpfs|overlay"} / node_filesystem_size_bytes{…}` , seuil **> 80**, attente 5 min, maintien 1 min, `severity = warning`. Une seule règle couvre tous les serveurs Linux, présents et futurs.
   La métrique compte l'espace utilisable sans la réserve root d'ext4 (62,1 % contre 60 % dans `df`) : c'est l'espace dont Wazuh, qui ne tourne pas en root, dispose réellement.

Preuve (25/10)

- Seuil de test à 60 : `wazuh-siem` (62,1 %) → *Firing*, `fedora` (36 %) → *Normal* ; état de la règle *Firing*. L'instance était déjà en attente depuis ~13:52 à cause d'une première sauvegarde avec un seuil à 0, d'où un passage rapide à *Firing*.
- Seuil de production à 80 : les deux instances *Normal*.

Enseignement

(1) Avant de conclure à une croissance, on mesure deux fois avec le **même** outil. (2) Ce qui n'est pas supervisé finit par tomber en silence : chaque serveur entre dans la supervision dès sa mise en service. (3) On éprouve une alerte en abaissant son seuil, pas en remplissant un disque de production.

◆ F-17 — Navigation web sur le contrôleur de domaine, avec le compte Administrateur intégré

Date : 25/10/2026 · **Type :** constat (CP8), corrigé (CP9) · **Gravité :** élevée
Actif : `Win-Server-DC` (`dc01`, `infrasec.local`)

Constat

`Get-Process` et `quser` sur le DC (20:55) :

- une session console du compte **`Administrator` intégré**, ouverte à 14:57 ;
- **15 processus `msedge`** dans cette session, depuis 14:58 (environ 6 h), avec de nouveaux processus à 17:21, 19:26 et 20:54 ; un onglet de messagerie web ouvert ;
- test avant correction (21:01) : `https://example.com` s'affiche, le DC a un accès web sortant libre.

Risque

Le navigateur est la première porte d'entrée des attaques (lien piégé, téléchargement à l'insu, pièce jointe). Sur un DC, il s'exécute avec les droits d'administrateur du domaine : une seule page malveillante peut compromettre tout l'annuaire. Deuxième écart : l'usage quotidien du compte `Administrator` intégré, que le modèle de tiers de la PSSI réserve au secours ; le compte d'administration nominatif est `adm.rj`.

Correction

Point de retour : instantané `pre-gpo-navigation`. Navigateur fermé (`Stop-Process msedge`). GPO **`DC - Navigation interdite`**, liée à la seule OU `Domain Controllers` :

- `HKLM\SOFTWARE\Policies\Microsoft\Edge\URLBlocklist\1 = *` : tous les sites bloqués ;
- `StartupBoostEnabled = 0` et `BackgroundModeEnabled = 0` : Edge ne se précharge plus et ne tourne plus en arrière-plan. Windows Update n'est pas concerné (il ne passe pas par le navigateur).

Preuve (25/10, 21:06–21:07)

- `gpresult /r /scope computer` : `DC - Navigation interdite` appliquée.
- Même test qu'avant : `https://example.com` → **« This page is blocked — Your organization doesn't allow you to view this site »**.

Incident pendant la mise en œuvre

Premier essai : erreurs `GpoWithNameNotFound` sur les trois réglages, la ligne de création de la GPO ayant été sautée. `gpupdate` a ensuite « réussi » sans rien appliquer : un succès d'outil n'est pas un résultat. Le test de navigation l'a montré.

Limites et suite

- Une GPO peut être défaite par un administrateur du domaine. La défense en profondeur serait une règle pfSense interdisant le web sortant au DC.
- Usage du compte `Administrator` intégré : à remplacer par `adm.rj` pour l'administration courante ; `Administrator` passe en compte de secours.
- Le 26/10, une demande de rouvrir le navigateur pour copier des commandes a été écartée au profit de SSH (PV-07).

Enseignement

(1) Un serveur d'infrastructure n'a pas de navigateur. (2) Un correctif se prouve par le même test qu'avant, rejoué après. (3) Une erreur rouge suivie d'un `gpupdate` réussi reste un échec.

◆ F-18 — Arrêter l'agent Wazuh du contrôleur de domaine ne déclenche aucune alerte

Date : 25/10/2026 · **Type :** constat (CP8, découvert pendant le scénario F-19), corrigé (CP9) · **Gravité :** élevée
Actifs : `Win-Server-DC` (agent `dc01`), `wazuh-siem`
Technique correspondante : MITRE ATT&CK T1562.001 (*Impair Defenses : Disable or Modify Tools*).

Découverte

Pendant la préparation de F-19, un `Restart-Service WazuhSvc` a expiré (« Cannot stop WazuhSvc ») : l'arrêt a eu lieu, le redémarrage jamais. Journal de l'agent : `Received exit signal` 19:23:48, `Exit completed success-fully` 19:24:21. Le DC est resté **sans surveillance environ 9 minutes**, et le fichier de test déposé pendant ce temps (19:24:47) n'a produit aucun événement.

Ce que le SIEM a vu

- Tableau de bord des agents : `Disconnected (1)`, visible seulement si quelqu'un le regarde.
- Alertes : règle **506** *Wazuh agent stopped*, **niveau 3**, à 19:22:22 et 19:24:21. Pas de 504 : l'arrêt était propre, l'agent l'a annoncé lui-même.
- Niveau 3 sur un seuil de 10 : **aucune alerte**.

Correction

Règle locale **100310**, niveau **10**, enfant de 506, MITRE T1562.001, dans `local_rules.xml` (sauvegarde `.bak-20261025b`, validation `wazuh-analysisd -t`). Elle couvre tous les agents. Un redémarrage planifié la déclenchera aussi : c'est voulu.

Preuve (25/10)

- `sc.exe stop WazuhSvc` (`STATE: 1 STOPPED`), redémarrage 45 s plus tard → `Running`.
- Alerte **100310, niveau 10, agent `dc01`, 18:52:35.508 UTC**.

Limite connue

Un arrêt brutal (coupure de la VM, processus tué) n'envoie pas de 506 : le manager passe l'agent en *disconnected* (règle 504), qui reste au niveau 3.

Enseignement

(1) Un capteur de sécurité qu'on peut couper sans alerte ne protège rien. (2) Un incident pendant un test est une donnée, pas un contretemps.

◆ F-19 — Persistance par le dossier de démarrage : détectée, mais sous le seuil d'alerte

Date : 25/10/2026 · **Type :** scénario d'attaque (CP10), constat puis correction (CP9) · **Gravité :** élevée
Actifs : `Win-Server-DC` (agent `dc01`), `wazuh-siem` (Wazuh 4.14.8)
Technique simulée : MITRE ATT&CK T1547.001 — un fichier déposé dans `C:\ProgramData\Microsoft\Windows\Start Menu\Programs\StartUp` s'exécute à chaque ouverture de session, pour tous les utilisateurs.

Mise en place de la surveillance

Configuration centralisée sur le manager (`/var/ossec/etc/shared/default/agent.conf`, sauvegarde `.bak-20261025`, validée par `verify-agent-conf`) : surveillance FIM du dossier en mode **whodata** (temps réel + identité de l'auteur). L'agent l'a reçue et redémarré seul : `real-time Whodata engine started` (19:22:35).

Constat 1 : le tableau de bord ne montrait rien

Recherche `syscheck.path:*StartUp*` vide, deux fois. Lecture du journal brut sur le SIEM (`grep -i maj.bat /var/ossec/logs/alerts/alerts.json`) : l'événement existait. Wazuh enregistre les chemins Windows **en minuscules** et le joker de la requête est sensible à la casse.

Constat 2 : détecté, mais personne n'est alerté

Alerte du 25/10 18:43:16.671 UTC (fichier créé à 18:43:15) : règle **554** *File added to the system*, **niveau 5**, aucune étiquette MITRE ; whodata : utilisateur `Administrator`, processus `powershell.exe` (PID 7660), SHA-256 `c97a25b5…`. Le seuil d'alerte du labo est 10.

Correction

Règle locale **100300**, niveau **12**, enfant de 550 et 554, champ `file` filtré par `(?i)\\start menu\\programs\\startup\\` (insensible à la casse), MITRE T1547.001.

Preuve (25/10)

Fichier `maj.bat` créé à 18:52:00 UTC → alerte **100300, niveau 12, agent `dc01`, 18:52:01.582 UTC** : délai de détection **1,6 s**. Fichier de test supprimé ensuite (`Test-Path` → `False`).

Enseignement

(1) Voir un événement ne suffit pas : il doit atteindre le niveau qui déclenche une alerte. (2) Quand l'interface ne montre rien, on lit le journal brut. (3) Sur Windows, une règle qui filtre un chemin doit ignorer la casse.

◆ F-20 — L'audit des partages ne voyait que les connexions, pas les fichiers

Date : 25/10/2026 · **Type :** constat (CP8, découvert pendant PV-06), corrigé (CP9) · **Gravité :** moyenne
Actif : `truenas` (`10.10.10.20`), partages SMB

Constat

Pendant l'enquête de PV-06, le journal d'audit SMB de TrueNAS ne contenait que 19 lignes, toutes de type `Authentication`. Aucune lecture, écriture ni suppression de fichier n'était enregistrée : la colonne *Audit Logging* des partages valait `No`. On savait qui s'était connecté, jamais ce qu'il avait fait.

Correction

Audit activé sur les cinq partages de l'entreprise (`Commun`, `Comptabilite`, `Direction`, `Projets`, `RH`) : *Enable Logging*, liste de surveillance `INFRASEC\domain users`, liste d'exclusion vide (administrateurs compris). L'ancien partage `partage`, oublié au premier passage, a été activé le 26/10 : les 6 partages affichent `Yes`.

Preuve (25/10, 20:20–20:21 heure de Paris)

Depuis `fedora`, compte `k.haddad` : dépôt puis suppression de `audit-test.txt` sur `Projets`, tentative sur `RH`. Lecture par l'API (`midclt call audit.query`, filtré avec `jq`) :

UTC	Événement	Objet	Résultat
19:20:38	AUTHENTICATION	–	`NT_STATUS_WRONG_PASSWORD` (faute de frappe)
19:20:55	AUTHENTICATION / CONNECT	`10.10.10.30`	SUCCESS
19:20:55	CREATE / WRITE / CLOSE	`audit-test.txt` (11 octets écrits)	SUCCESS
19:20:55	CREATE / **UNLINK** / CLOSE	`audit-test.txt`	SUCCESS
19:21:12	AUTHENTICATION / CONNECT / DISCONNECT	`10.10.10.30`	SUCCESS

L'API impose une limite de lignes par requête (`EINVAL` sans `limit`) : protection contre l'extraction massive du journal.

Limite constatée

Le refus de lister `RH` n'est pas enregistré comme un échec. La trace existe de façon indirecte : `CONNECT` puis `DISCONNECT` avec `"service":"RH"`, et le bilan de session `create 0, read 0, write 0`. Une connexion d'un compte hors service sur RH est en soi un signal à surveiller.

Enseignement

(1) « Audit activé » ne veut rien dire tant qu'on n'a pas vérifié ce qui est enregistré. (2) Une piste d'audit répond à : qui, quoi, quand, depuis où. (3) Quand l'interface filtre mal, l'API donne la même donnée.

◆ F-21 — Journaux du SIEM : aucune durée de conservation, et 9 jours sur 10 jamais scellés

Date : 25-26/10/2026 · **Type :** constat (CP8), corrigé (CP7/CP9) · **Gravité :** moyenne
Actif : `wazuh-siem` (`10.10.10.40` , Wazuh 4.14.8, disque 40 Go, horloge en UTC)

Mesure avant décision

Emplacement	Volume	Rôle
`/var/ossec/logs/alerts`	115 Mo	copie brute des alertes (preuve)
`/var/ossec/logs/archives`	20 Ko	vide : `logall` désactivé
indexeur (`wazuh-alerts-4.x-*`)	11 index, ~19 000 alertes, ~48 Mo	copie consultable
disque `/`	22 Go sur 40 (60 %)	dont 11 Go de base CVE (F-16)

Volume moyen : ~8 Mo bruts par jour, ~113 Ko compressés ; ~4,4 Mo par jour dans l'indexeur.

Constat 1 : rien n'est jamais supprimé

Ni Wazuh ni l'indexeur n'ont de durée de conservation. À 95 % de disque, l'indexeur passe ses index en lecture seule : le SIEM devient aveugle.

Constat 2 : les journaux ne sont pas scellés

Wazuh compresse et scelle chaque journal (fichier `.sum`) à minuit. Sur les 10 jours terminés, un seul l'était : le 23, seule nuit où le labo est resté allumé. Le labo est éteint la nuit, donc la rotation de minuit ne s'exécute jamais. Sans sceau, rien ne prouve qu'un journal n'a pas été modifié après coup.

Décision de conservation

- Copie consultable (indexeur) : **90 jours**, ~400 Mo.
- Copie brute scellée : **365 jours**, ~100 Mo compressés.
- Ordre des seuils : alerte Grafana à 80 % (F-16) **avant** le premier seuil de l'indexeur (85 %) et son blocage (95 %).

Correction

1. Politique ISM `infrasec-retention-90j` : suppression à 90 jours, gabarit pour les futurs index, rattachée aux 11 index existants (`updated_indices: 11, failures: false`). Appels avec le **certificat d'administration** de l'indexeur, vérification TLS complète (le certificat ne couvre que `127.0.0.1`).
2. Script `/usr/local/sbin/wazuh-sceller-journaux` (root:root, 0755) : pour chaque jour terminé, compression puis empreinte SHA-256 dans un fichier `.sha256` ; suppression des copies de plus de 365 jours ; traces `journalctl -t wazuh-sceller` . Testé d'abord sur une arborescence factice.
3. Service systemd durci (`ProtectSystem=strict` , écriture limitée à `/var/ossec/logs/alerts` , `NoNewPrivileges`) et minuteur quotidien à 00:30 UTC, `Persistent=true` .

Preuve (25/10, 19:40 UTC)

- Aperçu : exactement les 18 fichiers attendus (jours 03 à 24), jour en cours exclu.
- Exécution : `status=0/SUCCESS` , 18 lignes `scelle :` .
- `sha256sum -c *.sha256` → **18 × OK** ; fichiers `wazuh:wazuh` , mode `640` , dates d'origine conservées.

Preuve du rattrapage (26/10)

SIEM éteint dans la nuit du 25 au 26. Au démarrage du labo (18:53 heure de Paris), dernière exécution à 17:53:18 UTC, et scellement du 25/10 : `ossec-alerts-25.log.gz` (`135d0eb5…`) à 17:53:35, `ossec-alerts-25.json.gz` (`fc1fd2c9…`) à 17:53:36 UTC.

Limite connue

Les empreintes sont sur la même machine que les journaux : root sur le SIEM pourrait modifier les deux. Pour une valeur probante complète, les empreintes doivent partir ailleurs.

Enseignement

(1) Une durée de conservation se décide à partir de mesures. (2) Une tâche « à minuit » n'existe pas sur une machine éteinte la nuit : `Persistent=true`. (3) Un journal non scellé ne prouve rien.

◆ F-22 — Les secrets d'installation du SIEM traînaient en clair sur le SIEM

Date : 25/10/2026 · **Type :** constat (CP8, découvert pendant F-21), corrigé (CP9) · **Gravité :** élevée
Actifs : `wazuh-siem`, hôte `HV01`

Constat

Dans le dossier du compte `ais` : `wazuh-install-files.tar` (root, 600, du 03/10), laissé par l'installeur. Contenu (noms seulement) : `wazuh-passwords.txt` (mots de passe en clair), les clés privées du serveur, de l'indexeur, du tableau de bord, du certificat d'administration, et **`root-ca.key`**, clé privée de l'autorité qui a signé tous les certificats du SIEM.

Pourquoi ne pas simplement le supprimer

La clé de l'autorité sert à renouveler un certificat ou ajouter un nœud. La détruire aurait créé un problème de disponibilité ; la garder en clair, un problème de confidentialité. Réponse : la conserver **chiffrée, hors du SIEM**.

Correction

1. Mots de passe relevés une fois et enregistrés dans le gestionnaire de mots de passe.
2. Chiffrement AES-256 (`gpg --symmetric --cipher-algo AES256`), phrase de passe dans le gestionnaire.
3. Contrôle : le déchiffrement redonne exactement l'original (SHA-256 `84d479f9…` des deux côtés).
4. Copie vers l'hôte (`~/coffre`, dossier 700, fichier 600) ; empreinte du fichier chiffré identique des deux côtés (`a34d743c…`), déchiffrement réussi sur l'hôte.
5. Destruction sur le SIEM : `shred -u` de l'original puis de la copie chiffrée.

Incidents pendant l'opération

- Premier déchiffrement en échec (phrase mal saisie) : empreinte `e3b0c442…`, celle d'une entrée **vide**. C'est la comparaison des empreintes qui prouve, pas l'absence d'erreur.
- La copie « vers l'hôte » a d'abord été lancée depuis la session SSH du SIEM : le SIEM s'est copié le fichier à lui-même. Repéré à l'invite `ais@wazuh-siem`, vérifié, refait depuis l'hôte.

Complément (26/10)

Le coffre contient aussi l'export XML de la configuration pfSense (`config-fw01.infrasec.lab-20261026212439.xml`, 600).

Reste à faire

Copie de `~/coffre` sur le disque externe chiffré du plan de sauvegarde.

Enseignement

(1) L'inventaire après installation fait partie de l'installation. (2) Un secret indispensable se chiffre et se range ailleurs. (3) Avant chaque commande sensible, on lit l'invite.

◆ F-23 — L'hyperviseur manquait de mémoire : 29 Gio alloués sur 30, l'hôte utilisait son swap

Date : 25/10/2026 · **Type :** constat (CP8, mesure de capacité avant un nouveau service), corrigé (CP7) · **Gravité :** moyenne

Actif : hôte `HV01` (Fedora, 30 Gio de RAM, 8 Gio de swap, disque LUKS 952 Go dont 425 libres)

Constat (21:09)

`free -h` : 26 Gio utilisés sur 30, **4,0 Gio de swap utilisés**, 4,0 Gio disponibles. Mémoire allouée : DC 6 + TrueNAS 6 + SIEM 6 + fedora 6 + pfSense 4 + wg-client 1 = **29 Gio**.

Mesure par VM (`virsh dommemstat`)

VM	Allouée	Occupée (rss)	Libre dans l'invité	Décision
pfSense	4,0	3,1	(pas de pilote)	2 Go
DC	6,0	6,0	3,3	4 Go
TrueNAS	6,0	2,4	4,0	inchangé (cache ZFS)
fedora	6,0	3,4	2,2	inchangé
wazuh-siem	6,0	4,8	**0,9**	inchangé : la plus juste
wg-client	1,0	0,5	0,5	inchangé

Correction

Arrêt ordonné (`lab stop`), `virsh setmem` puis `setmaxmem --config` , vérification `dominfo` , redémarrage ordonné.

Preuve (21:25)

	Avant	Après
Mémoire allouée aux VM	29 Gio	**25 Gio**
RAM utilisée sur l'hôte	26 Gio	**22 Gio**
Disponible	4,0 Gio	**8,6 Gio**
Swap utilisé	4,0 Gio	**1,4 Gio**

La VM Samba (1,5 Gio) tient désormais sans priver le SIEM.

Enseignement

(1) La capacité se mesure avant d'ajouter un service. (2) On réduit d'après la consommation réelle, VM par VM. (3) Un swap actif sur un hyperviseur est une alerte.

◆ F-24 — Mots de passe : aucun verrouillage dans les deux domaines, puis un verrouillage sans alerte

Date : 25-26/10/2026 · **Type :** constat (CP8), corrigé (CP9) et scénario de détection (CP10) · **Gravité :** élevée
Actifs : `Win-Server-DC` (`infrasec.local`), `lnx-dc01` (`infrasec.internal`), `wazuh-siem`
Technique correspondante : MITRE ATT&CK T1110 (*Brute Force*), y compris sa forme lente.

Constat 1 : la PSSI n'était pas appliquée par les domaines

Windows et Samba avaient les mêmes valeurs par défaut : 7 caractères minimum, **aucun seuil de verrouillage**, 42 jours. La PSSI exige 14 caractères (20 pour les comptes à privilèges). Les comptes existants la respectaient parce que le script avait généré leurs mots de passe, pas parce que le domaine l'imposait.

Correction 1 (26/10)

Instantanés `pre-politique-mdp-26oct` des deux contrôleurs. Même politique dans les deux domaines :

	Comptes ordinaires	Administrateurs (PSO-Admins, Admins du domaine)
Longueur minimale	14	20
Verrouillage	après 10 échecs, 15 min	après 5 échecs, 30 min
Durée de vie	365 jours	180 jours

Groupe Windows désigné par son SID (`-512`). Contrôles : `Get-ADUserResultantPasswordPolicy adm.rj` → `PSO-Admins` (20, 5) ; `pso show-user administrator` côté Samba → `PSO-Admins`.

Preuve du verrouillage (19:25 heure de Paris)

Depuis `fedora`, 11 connexions SMB avec un mot de passe faux pour `k.haddad` : 10 × `NT_STATUS_LOGON_FAILURE`, puis `NT_STATUS_ACCOUNT_LOCKED_OUT`. Événement 4740 sur le DC : `Caller Computer Name: FEDORA`.

Constat 2 : le verrouillage lui-même ne déclenche pas d'alerte

SIEM (UTC) : chaque échec en règle 60122 (niveau 5) ; 18:25:44, **60204** *Multiple Windows Logon Failures* (niveau 10) ; 18:25:48, **60115** *User account locked out* au **niveau 9**. La 60204 ne se déclenche que pour des échecs rapprochés : un attaquant lent verrouille quand même les comptes, sans alerte (déni de service).

Correction 2

Règle locale **100320**, niveau **10**, enfant de 60115, MITRE T1110 (sauvegarde `.bak-20261026`, validation `wazuh-analysisd -t`).

Preuve par une attaque lente (19:39–19:49)

10 échecs comptés entre 18:40:56 et 18:49:09 UTC (environ 37 s d'écart). **Aucune 60204** ; **100320, niveau 10, à 18:49:09.212 UTC**, au moment du verrouillage. Compte ensuite déverrouillé (`LockedOut : False`, `badPwdCount : 0`).

Enseignement

(1) Une politique écrite n'est appliquée que si le système l'impose. (2) Un seuil de verrouillage crée un risque de déni de service : le verrouillage doit lui-même alerter. (3) On teste aussi l'attaque lente.

◆ F-25 — Le contrôleur Samba n'avait aucun pare-feu

Date : 26/10/2026 · **Type :** constat (CP8), corrigé (CP9) · **Gravité :** moyenne
Actif : `lnx-dc01` (`10.10.10.11` , Debian 13.7, Samba AD `infrasec.internal`)

Constat

`ufw` absent, `nft list ruleset` vide. `ss -tulpn` : SSH et tous les services de l'annuaire en écoute sur toutes les interfaces, IPv4 et IPv6 — 53, 88, 464, 135, 137-139, 389, 445, 636, 3268, 3269, 49152-49154. Même défaut que le SIEM (F-15).

Analyse des flux légitimes

Ports	Service	Décision
22/tcp	SSH	hôte `10.10.10.2` seulement
53, 88, 389, 464 (tcp et udp) ; 135, 445, 636, 3268, 3269 (tcp)	annuaire	LAN `10.10.10.0/24`
49152-65535/tcp	RPC dynamique	LAN
137, 138, 139	NetBIOS	fermés

Correction

Point de retour : instantané `post-politique-mdp-stable`. `ufw` : refus par défaut en entrée, journalisation `low` , quatre règles commentées, vérifiées par `ufw show added` avant activation (règle SSH en tête).

Preuve (26/10, 19:59)

- Depuis `fedora` : 22 et 139 **fermés** ; 389, 445, 88 **ouverts** ; DNS `lnx-dc01.infrasec.internal` → `10.10.10.11` .
- Depuis l'hôte : 22 **ouvert**.

Enseignement

(1) Toute nouvelle machine entre avec son pare-feu. (2) On ferme ce dont on n'a pas besoin (NetBIOS).

◆ F-26 — Deux machines ignorent la demande d'arrêt de l'hyperviseur

Date : 26/10/2026 · **Type :** constat (CP8, révélé par le test du script `lab`), correction engagée (CP7) · **Gravité :** moyenne
Actifs : `Win-Server-DC`, `wg-client` (Fedora 44 Cloud Edition), hôte `HV01`

Constat

`sudo lab stop` (20:29-20:38) : cinq machines arrêtées proprement et dans l'ordre. Deux refus, signalés par le script sans coupure forcée :

- `wg-client` : `ÉCHEC … après 180 s` ;
- `Win-Server-DC` : `ÉCHEC … après 300 s` (troisième refus, voir F-14), alors qu'aucune session SSH n'était ouverte. `virsh qemu-agent-command … guest-ping` → `QEMU guest agent is not configured` sur les deux : l'arrêt ne peut passer que par le bouton d'alimentation simulé (ACPI).

Diagnostic

- **Win-Server-DC** : console = écran de verrouillage, aucune boîte de dialogue. Arrêt réussi depuis Windows lui-même. Conclusion : l'arrêt piloté par le système fonctionne ; seul le signal ACPI est ignoré. Hypothèse retenue : session console `Administrator` restée ouverte derrière le verrouillage (Windows refuse alors un arrêt par le bouton d'alimentation).
- **wg-client** : console = invite `localhost login:`, aucune session ouverte, aucun serveur SSH. Signal ACPI (`virsh shutdown`) puis touche `KEY_POWER` (`virsh send-key`) : aucune réaction, toujours `running`. Image Cloud allégée : aucun signal d'arrêt externe n'est traité.

Mesure immédiate

`wg-client` : vidage du cache disque (`virsh send-key … KEY_LEFTALT KEY_SYSRQ KEY_S`), puis `virsh destroy`. Coupure justifiée et tracée : machine sans service ni donnée métier, disque synchronisé, tous les moyens d'arrêt propre essayés auparavant.

Correction

1. Canal de l'agent invité QEMU ajouté aux deux définitions (`virt-xml … --add-device --channel unix,target.type=virtio,target.name=org.qemu.guest_agent.0`).
2. Windows : agent installé depuis `virtio-win.iso` (`E:\guest-agent\qemu-ga-x86_64.msi`, installation silencieuse) → service `QEMU-GA Running`, `Automatic`. `wg-client` : agent déjà présent dans l'image Fedora Cloud.
3. `guest-ping` → `{"return":{}}` sur les deux.
4. Script `lab` (empreinte `98df9b18…`, copie précédente conservée) : arrêt par l'agent invité quand il répond (`virsh shutdown --mode agent`), ACPI sinon.

Preuve (26/10, 21:25–21:26)

`sudo lab stop` : **7 machines sur 7 arrêtées proprement, en 66 s, sans aucun échec ni coupure** — `wg-client` 5 s, `wazuh-siem` 5 s (ACPI), `fedora` 15 s, `truenas` 5 s, `lnx-dc01` 5 s, **`Win-Server-DC` 10 s** (contre trois refus en 180-300 s), `pfsense-fw` 20 s (ACPI). Le script a choisi seul la méthode : agent pour 5 machines, ACPI pour les 2 qui n'en ont pas.

Enseignement

(1) Un script qui ne force rien rend visibles les machines qui ne s'arrêtent pas : son refus est une information. (2) Un arrêt « propre » depuis l'hyperviseur suppose un canal que l'invité écoute réellement : on le vérifie, on ne le suppose pas. (3) Une coupure forcée n'est acceptable qu'en dernier recours, justifiée et tracée.

◆ PV-05 — Entreprise INFRASEC : annuaire, partages par service et contrôle d'accès (AGDLP)

Date : 25/10/2026 · **Compétences :** CP9 (politique de sécurité appliquée : RBAC, moindre privilège, tiering), CP8 (mesure par test)

Actifs : `Win-Server-DC` (`infrasec.local`), `truenas` (`10.10.10.20`, pool `tank` en miroir), client de test `fedora` (`10.10.10.30`)

1. Annuaire

Script PowerShell idempotent `New-InfrasecCompany.ps1` (empreinte SHA-256 vérifiée à l'arrivée sur le DC : `1E6E9C76…`, CSV `7228C38A…`), lancé d'abord en simulation (`-WhatIf`), précédé de l'instantané `pre-entreprise-ad`.

- 14 OU, 27 groupes : 7 `GG_` (6 services + télétravail), 10 `DL_SMB_<partage>_RW/RO`, 8 `ROLE_` (matrice RBAC de la PSSI art. 5.2) ; 10 objets ordinateurs.
- 12 comptes : 10 collaborateurs (mots de passe aléatoires de 24 caractères, changement imposé à la première connexion, jamais affichés), `adm.rj` (compte d'administration séparé, 32 caractères, seul membre ajouté aux Admins du domaine), `aud.externe` (désactivé hors mission d'audit).
- Contrôle indépendant après exécution : 12 comptes, `aud.externe Enabled = False`, Admins du domaine = `Administrator` + `adm.rj` (pas `rj`), `DL_SMB_Projets_RW` = `GG_Consultants` + `GG_Commercial`, 10 postes.
- Détection : le SIEM a reçu les 12 événements Windows **4720** de `dc01` (règle Wazuh 60109, niveau 8, MITRE T1098), tous entre 15:49:26.931 et 15:49:28.270. Constat pour CP10 : le niveau 8 est sous le seuil d'alerte (≥ 10).
- Politique de mots de passe éprouvée : un mot de passe de 7 caractères est refusé par le domaine (`ADPasswordComplexityException`).

2. Partages TrueNAS

TrueNAS joint au domaine (`HEALTHY`), les 10 groupes `INFRASEC\dl_smb_*` visibles (GID 100001120 → 100001129).

- Dataset parent `tank/entreprise`, non partagé. **Constat corrigé :** le préréglage SMB donnait `INFRASEC\domain users` et `builtin_users` en **Modify**, donc les 12 comptes du domaine en écriture partout. ACL ramenée à : `owner@` et administrateurs (Full Control), `domain users` en **Traverse sans héritage** (passer, ne pas lire).
- Cinq datasets enfants partagés en SMB : Commun, Direction, Comptabilite, RH, Projets. ACL de chacun : `DL_SMB_<partage>_RW` → Modify, `DL_SMB_<partage>_RO` → lecture (Read Data, Read Attributes, Read Named Attributes, Read ACL, Execute, Synchronize), administrateurs → Full Control. Aucun accès général.
- Le validateur de TrueNAS signale que les groupes `DL_` n'ont pas le droit de traverser le parent : il évalue chaque groupe seul, sans tenir compte de `Domain Users`. L'avertissement est compris ; l'accès réel est prouvé par le test ci-dessous.

3. Test d'accès (25/10, 17:36–17:37, `smbclient` depuis `fedora`)

#	Compte (service)	Partage	Action	Attendu	Obtenu
1	k.haddad (Commercial)	Projets	écriture	OK	OK (`k.haddad.txt`)
2	k.haddad (Commercial)	RH	lecture	refus	`NT_STATUS_ACCESS_DENIED listing`
3	n.rousseau (RH)	RH	écriture	OK	OK (`rousseau.txt`)
4	c.morel (Direction)	RH	lecture	OK	OK (voit `rousseau.txt`)

#	Compte (service)	Partage	Action	Attendu	Obtenu
5	c.morel (Direction)	RH	écriture	refus	`NT_STATUS_ACCESS_DENIED opening remote file`
6	k.haddad (Commercial)	Commun	écriture	OK	OK (`commun.txt`)

6 résultats sur 6 conformes, dont 2 refus attendus. Un premier essai (`NT_STATUS_LOGON_FAILURE`) venait d'une faute de saisie du mot de passe ; il n'est pas retenu.

Enseignement

(1) Un préréglage n'est pas une politique : celui de TrueNAS ouvrait tout le domaine en écriture. (2) AGDLP sépare qui sont les gens (`GG_`) de ce qu'ils peuvent faire (`DL_`) : un nouvel arrivant ne demande qu'un ajout de groupe, jamais une ACL. (3) Un contrôle d'accès se prouve par des refus autant que par des succès.

◆ PV-06 — Sauvegarde éprouvée : restauration d'un fichier supprimé par un utilisateur

Date : 25/10/2026 · **Compétences :** CP7 (disponibilité, sauvegarde), CP8 (mesure par test)
Actifs : `truenas` (`tank/entreprise`, miroir), client `fedora`, compte `k.haddad`

Dispositif

Tâche d'instantanés sur `tank/entreprise`, récursive, toutes les heures, conservation 2 semaines, instantanés vides désactivés. Vérification en ligne de commande : `zfs list -t snapshot -r tank/entreprise` → un instantané `auto-2026-10-25_18-00` par dataset. Horloge de TrueNAS contrôlée (`date` / `date -u`).

Lecture d'un faux doute

L'interface indiquait « dernière exécution : il y a 1 heure » alors que le seul instantané datait de 18:00 : la tâche a tourné à 19:00 sans rien créer, rien n'ayant changé.

Scénario : un utilisateur supprime un fichier par erreur

1. 20:04:06, depuis `fedora`, en tant que `k.haddad` : `del commun.txt` → fichier absent.
2. Sur TrueNAS : fichier intact dans `.zfs/snapshot/auto-2026-10-25_18-00/` ; copie vers le partage.
3. 20:05, `k.haddad` relit le fichier (`test`, 5 octets). Délai de restauration : environ **1 minute**, sans perte.

Défaut observé

La copie restaure contenu et droits, **pas le propriétaire** (`root` au lieu de `INFRASEC\k.haddad`). Correction : `chown`. Amélioration : « versions précédentes » de Windows par SMB.

Une modification inexpliquée, élucidée par les journaux

Le fichier portait une date de modification de 19:59:34. Audit SMB : entre 17:37:54 et 20:04:06, seulement des **échecs** d'authentification de `k.haddad`. Journal de sudo : `truenas_admin` a lancé la copie de restauration à 19:59:34, avant que la suppression ait réussi. Retracé à la seconde par deux journaux indépendants.

Incident de préparation

Trois connexions refusées (`NT_STATUS_LOGON_FAILURE`) : mot de passe réinitialisé par erreur plus tôt. Arrêt avant verrouillage, contrôle `badPwdCount`, réinitialisation masquée.

Enseignement

(1) Une sauvegarde n'existe qu'une fois restaurée, du point de vue de l'utilisateur. (2) Restaurer, c'est aussi restaurer les métadonnées.

◆ PV-07 — Administration du contrôleur de domaine en SSH, limitée à l'hyperviseur

Date : 25-26/10/2026 · **Compétences :** CP9, réponse à la remarque du jury sur l'usage de l'interface graphique
Actif : `Win-Server-DC` (`dc01`, Windows Server 2025, `10.10.10.10`)

Besoin

La console graphique de la VM ne permet pas le copier-coller et altère la saisie (virgules transformées en points), source d'erreurs répétées. Rouvrir le navigateur du DC a été écarté : cela annulait F-17.

Mise en œuvre

- OpenSSH Server, déjà présent dans Windows Server 2025 : `Start-Service sshd`, démarrage automatique.
- Règle `OpenSSH-Server-In-TCP` restreinte à la source `10.10.10.2`.
- PowerShell défini comme shell SSH par défaut (`HKLM:\SOFTWARE\OpenSSH\DefaultShell`).

Défaut trouvé pendant le test

`Connection timed out` : la règle était attachée au profil **Private** ; un DC est en profil **Domain**. Correction : `-Profile Domain`. Un *timeout* signale un pare-feu qui jette ; un refus répond `Connection refused`.

Preuve (26/10)

- Depuis l'hôte : `ssh -l 'INFRASEC\Administrator' 10.10.10.10` → invite `infrasec\administrator@DC01`.
- Port 22 **ouvert** depuis l'hôte, **fermé** depuis `fedora`.
- Un premier test lancé par erreur dans la session SSH du DC affichait « FERME » : Windows n'a pas `bash`, la branche `|| echo FERME` s'exécutait. Ce test ne pouvait pas échouer ; non retenu.

Durcissement (26/10, 21:31–21:43) : `adm.rj` par clé uniquement

- Clé ED25519 générée sur l'hôte (`~/.ssh/id_ed25519_admrj`, 100 tours de dérivation, protégée par phrase de passe) ; empreinte `SHA256:… (masquée / redacted)`.
- Clé publique dans `C:\ProgramData\ssh\administrators_authorized_keys` (fichier lu par OpenSSH pour les membres d'Administrators), droits réduits à `Administrators` et `SYSTEM` (`icacls /inheritance:r`).
- `sshd_config` (sauvegarde `.bak-20261026`) : `PasswordAuthentication no`, `AllowUsers infrasec\adm.rj` ; syntaxe validée par `sshd -t` avant redémarrage ; session `Administrator` gardée ouverte en secours pendant le changement.
- Tests depuis l'hôte : `adm.rj` par clé → `infrasec\adm.rj`, membre de `Domain Admins` (accepté) ; `adm.rj` par mot de passe → `Permission denied` ; `Administrator` → `Permission denied (publickey,keyboard-interactive)`, sans demande de mot de passe. Le compte `Administrator` intégré redevient un compte de secours, accessible seulement par la console (tiering, F-17).

Enseignement

(1) Une contrainte d'outil ne justifie pas de défaire une mesure de sécurité. (2) Sous Windows, une règle de pare-feu vaut pour un profil réseau.

◆ PV-08 — Domaine Linux de continuité `infrasec.internal` : entreprise, détection et résolution croisée

Date : 25-26/10/2026 · **Compétences :** CP7 (continuité), CP9 (politique appliquée), CP8 (mesure par test)
Actifs : `lnx-dc01` (`10.10.10.11` , Debian 13.7, Samba 4.22), `Win-Server-DC` , `pfsense-fw` , `wazuh-siem`

1. Agent Wazuh

Dépôt officiel signé (clé GPG), version **4.14.8-1 identique au manager** (un agent plus récent que le manager est refusé), bloquée par `apt-mark hold` . Enrôlement : ID 003 `Pending` , puis `Active` 30 s plus tard (premier message reçu sur 1514). Les deux contrôleurs de domaine sont désormais supervisés.

2. Entreprise INFRASEC

Script `infrasec-samba-societe.sh` (bash, `samba-tool`), équivalent de `New-InfrasecCompany.ps1` , à partir du **même** `employes.csv` . Intégrité vérifiée à l'arrivée : CSV `7228c38a…` (identique à celui du DC Windows), script `e120caac…` . Mots de passe aléatoires (`--random-password`), jamais saisis ni affichés ; changement imposé à la première connexion.

- Simulation (`--dry-run`) avant exécution.
- Contrôle indépendant : 15 comptes (12 de l'entreprise + `Administrator` , `Guest` , `krbtgt`) ; Admins du domaine = `Administrator` et `adm.rj` ; `aud.externe` `userAccountControl: 514` (désactivé) ; `GG_Consultants` = `t.girard` , `i.lambert` , `h.mercier` .
- **Idempotence prouvée** : seconde exécution → une seule ligne `=== terminé` , rien de recréé.
- Défaut corrigé avant exécution : des tests `[[ … ]] && action` en fin de boucle auraient arrêté le script sous `set -e` (`pipefail`) dès le premier salarié non télétravailleur ; remplacés par des `if` .

3. Résolution DNS entre les deux domaines

Avant : `dig @10.10.10.10 lnx-dc01.infrasec.internal` → rien ; depuis `lnx-dc01` , `_ldap._tcp.infrasec.local has no SRV record` .

- Windows → Samba : zone de redirection conditionnelle `infrasec.internal` → `10.10.10.11` sur le DC. Premier test en `SERVER FAILURE` ; diagnostic maillon par maillon : Samba interrogé directement depuis le DC → répond `10.10.10.11` ; port 53 → `TcpTestSucceeded : True` ; cache DNS vidé → la redirection répond. Cause : un échec mis en cache à la seconde de création de la zone.
- Samba → Windows : redirection de domaine sur pfSense (*Domain Override* `infrasec.local` → `10.10.10.10`) plutôt que dans Samba : Samba envoie déjà tout ce qu'il ne connaît pas à pfSense, la règle est donc unique pour tout le labo. Après (26/10, 20:16-20:22) :
- depuis l'hôte, via le DC Windows : `lnx-dc01.infrasec.internal` → `10.10.10.11` ;
- depuis `lnx-dc01` : `dc01.infrasec.local has address 10.10.10.10` ; `_ldap._tcp.infrasec.local has SRV record 0 100 389 dc01.infrasec.local.`

Enseignement

(1) Un même fichier source, vérifié par son empreinte, garantit que deux annuaires décrivent la même entreprise. (2) Un script d'administration se rejoue : l'idempotence se prouve en le relançant. (3) Devant une panne, on teste chaque maillon séparément avant d'accuser un composant.

◆ PV-09 — Sauvegarde du labo : `lab-backup`, niveau local immuable

Date : 26/10/2026 · **Compétences :** CP7 (sauvegarde, continuité), CP9 (protection des sauvegardes)
Actifs : hôte `HV01` (disque LUKS + BTRFS), 7 VM, coffre `~/coffre`

Besoin et contrainte

Aucune sauvegarde complète du labo n'existait hors des instantanés internes des VM. Pas de disque externe disponible. Repartitionner le disque de l'hôte (LUKS + BTRFS) a été écarté : réduire la partition chiffrée est l'opération la plus risquée possible sur ce disque.

Préparation : ménage et inventaire

- `/vm/iso` : 12 fichiers inutiles supprimés (ISO Windows client, doublons, CoreOS, Parrot, image Cloud), noms exacts, sans joker, après vérification des disques branchés sur chaque VM (`virsh domblklist`) : 74 Go → 19 Go, 7 images conservées (une par VM à reconstruire, plus `virtio-win`).
- Découverte : `wg-client` est rangé hors de `/vm`, dans `/var/lib/libvirt/images`, et dépend d'une image de base (`wg-client-base.qcow2`, `qemu-img info -U`). Sans cet inventaire, la sauvegarde l'aurait oublié ou rendu inutilisable.
- `/vm` est un sous-volume BTRFS (ID 259) ; `/vm/images` est sans copy-on-write (attribut `C`), ce qui n'empêche pas les instantanés.

Conception

Script `/usr/local/bin/lab-backup` (root:root 0755, empreinte `5ed4dcb1…`) :

1. arrêt ordonné (`lab stop`) ; annulation et redémarrage si une VM refuse de s'arrêter ;
2. instantané BTRFS **en lecture seule** du sous-volume `/vm` ;
3. sous-volume annexe : `wg-client` et son image de base, définitions des 7 VM et listes de leurs instantanés, coffre (secrets chiffrés, export pfSense), scripts `lab` et `lab-backup` ; puis passage **en lecture seule** ;
4. empreinte SHA-256 de chaque fichier ; dépôt `/srv/lab-backup` réservé à root (700) ;
5. redémarrage ordonné (`lab start`) ; rétention : 4 sauvegardes. Commande `export /dev/sdX` prête : copie de la dernière sauvegarde sur disque USB chiffré LUKS2, refus de tout disque non USB.

Preuve (26/10, 21:56–22:05)

- Arrêt des 7 VM en 67 s, sans échec (agent invité pour 5, ACPI pour 2).
- Empreintes : 20 fichiers annexes + 9 disques de VM (21:57 → 22:02).
- Redémarrage ordonné, DNS des deux contrôleurs opérationnels ; sauvegarde `20261026-2156` terminée à 22:04:58. Interruption totale du labo : 9 minutes.

Contrôles après coup (22:06–22:12)

- `lab-backup list` → `20261026-2156 disques:ro=true annexe:ro=true` : les deux parties sont immuables.
- `lab-backup verify` → `intégrité : OK` (recalcul complet des empreintes en 5 min 30 s).
- Test d'écriture par root : `touch /srv/lab-backup/20261026-2156-vm/test` → `Read-only file system`.

Limite assumée

Niveau local seulement : protège contre la fausse manipulation, la corruption et un rançongiciel (lecture seule), pas contre la panne ou le vol du disque de l'hôte. Le niveau externe (`lab-backup export`) attend un disque USB.

Enseignement

(1) Une sauvegarde commence par un inventaire : ce qu'on ne sait pas exister, on ne le sauvegarde pas. (2) Une sauvegarde qu'on peut modifier peut être chiffrée par un rançongiciel : lecture seule. (3) On dit précisément contre quoi une sauvegarde protège, et contre quoi elle ne protège pas.

◆ PROC-01 — Procédure de migration de l'annuaire vers `infrasec.internal`

Déclencheur : fin de l'évaluation de Windows Server 2025 (vers le 27/03/2027 ; dernier réarmement possible, échéance au plus tard vers 09/2027), ou perte définitive du contrôleur `dc01`.
Objectif : que les salariés retrouvent comptes, groupes et accès aux partages sur le domaine Samba, sans perte de données ni de traçabilité.
État de départ (26/10/2026) : domaine `infrasec.internal` en service, même entreprise (même `employes.csv`, empreinte `7228c38a…`), même politique de mots de passe, agent Wazuh actif, résolution DNS croisée en place (PV-08).

Registre des risques

Risque	Probabilité	Impact	Mesure
Expiration de l'évaluation Windows : arrêts horaires puis indisponibilité de l'annuaire	certaine (date connue)	élevé : authentification, partages, GPO	domaine de continuité prêt ; bascule planifiée au moins 1 mois avant
Divergence entre les deux annuaires (comptes créés d'un seul côté)	moyenne	moyen	une seule source : `employes.csv`, rejoué des deux côtés (scripts idempotents)
Perte des GPO lors de la bascule (Samba ne reprend pas les GPO Windows)	certaine	moyen	GPO critiques recensées (F-17 navigation, politique de mots de passe) et recréées côté Samba ou portées par le pare-feu
Droits des partages TrueNAS liés aux SID de `INFRASEC`	certaine	élevé	jonction de TrueNAS au nouveau domaine et réapplication des ACL par groupes `DL_` (AGDLP : seule la liaison groupe → ACL change)

Étapes

1. **J-30 — Préparer.** Instantanés de toutes les VM ; export de la configuration pfSense ; `samba-tool dbcheck` sans erreur ; relecture de la liste des GPO Windows à reproduire.
2. **J-30 — Aligner les annuaires.** Rejouer `infrasec-samba-societe.sh employes.csv` (idempotent) ; comparer les deux listes de comptes et de membres de groupes (`Get-ADUser` / `samba-tool user list`) ; écarts = 0.
3. **J-15 — Créer les groupes de partage.** Créer les 10 `DL_SMB_<partage>_RW/RO` dans Samba avec les mêmes membres `GG_` que sous Windows (matrice de PV-05).
4. **J-7 — Basculer TrueNAS.** Quitter le domaine `INFRASEC`, joindre `INFRALNX` ; réappliquer sur chaque partage les ACL des `DL_` (Modify / lecture) ; vérifier l'héritage depuis `tank/entreprise`.
5. **J-7 — Recetter.** Rejouer le test d'accès de PV-05 (6 cas, dont 2 refus) avec les comptes du nouveau domaine ; rejouer le scénario de verrouillage de F-24 ; vérifier l'arrivée des événements dans Wazuh (agent 003).
6. **J0 — Basculer les services.** DNS des machines du LAN vers `10.10.10.11` ; mots de passe des salariés initialisés (`samba-tool user setpassword`, saisie masquée) et changement imposé ; `dc01` arrêté mais conservé (pas supprimé) 30 jours.
7. **J+30 — Clôturer.** Supprimer la redirection `infrasec.local` de pfSense et la zone conditionnelle ; archiver le dernier instantané de `dc01` ; mettre à jour la PSSI (annuaire de référence) et les fiches d'architecture.

Retour arrière : jusqu'à J+30, `dc01` est redémarrable ; restauration de TrueNAS sur l'instantané de J-7 et retour des DNS du LAN vers `10.10.10.10`.

Critère de réussite : les 6 cas de PV-05 donnent le résultat attendu sur le nouveau domaine, et une connexion échouée y produit l'alerte Wazuh correspondante.

Annexe Q · Scripts d'exploitation lab et lab-backup

lab

```
#!/usr/bin/env bash
# lab — démarrage et arrêt ordonnés du labo INFRASEC (hôte HV01)
#   sudo lab start   : pfSense → attente du firewall → DC Windows → attente de son DNS
#                      → DC Samba → attente de son DNS → TrueNAS, fedora, wazuh-siem, wg-client
#   sudo lab stop    : arrêt propre (ACPI) dans l'ordre inverse, sans coupure forcée
#   sudo lab status  : état de chaque VM
# Chaque étape est tracée dans le journal système : journalctl -t lab
# Origine : F-14 (flux de vulnérabilités en échec quand le SIEM démarre avant le DNS)
#           et INC-11 (fichier PID resté après un arrêt non propre).
# 26/10 : ajout de lnx-dc01 (PV-08) ; attente d'arrêt du DC Windows portée à 300 s
#             (refus d'arrêt en 180 s constaté deux fois, F-14).
# 26/10 : arrêt par l'agent invité QEMU quand il répond, ACPI sinon (F-26).
set -euo pipefail

ORDER=(pfsense-fw Win-Server-DC lnx-dc01 truenas fedora wazuh-siem wg-client)
FW=10.10.10.254          # pfSense, interface LAN
DC=10.10.10.10           # Win-Server-DC, DNS de infrasec.local
DOMAIN=infrasec.local
LDC=10.10.10.11          # lnx-dc01, DNS de infrasec.internal
LDOMAIN=infrasec.internal

log()       { printf '%s  %s\n' "$(date '+%F %T')" "$*"; logger -t lab -- "$*"; }
state()     { virsh domstate "$1" 2>/dev/null | head -1; }
port_open() { timeout 2 bash -c "</dev/tcp/$1/$2" 2>/dev/null; }
# Vraie réponse DNS exigée : en cas d'échec, dig écrit aussi sur sa sortie (« connection timed out »),
# donc une sortie non vide ne prouve rien. On exige l'en-tête NOERROR et au moins un enregistrement.
dns_ok() {   # dns_ok <serveur> <domaine>
    command -v dig >/dev/null 2>&1 || { echo "dig absent : sudo dnf install bind-utils" >&2; return 1; }
    local out
    out=$(dig +time=2 +tries=1 @"$1" "$2" SOA 2>/dev/null) || return 1
    grep -q 'status: NOERROR' <<<"$out" && grep -q 'ANSWER: [1-9]' <<<"$out"
}
is_off()    { [[ "$(state "$1")" == "shut off" ]]; }

# wait_for <description> <délai max en s> <commande…> : réessaie toutes les 5 s
wait_for() {
    local what=$1 max=$2 t=0
    shift 2
    until "$@"; do
        if (( t >= max )); then log "ÉCHEC : $what après ${max} s"; return 1; fi
        sleep 5; t=$((t + 5))
    done
    log "OK : $what (${t} s)"
}

start_vm() {
    if [[ "$(state "$1")" == running ]]; then log "$1 déjà en marche"
    else virsh start "$1" >/dev/null && log "démarrage de $1"; fi
}

[[ $EUID -eq 0 ]] || { echo "À lancer avec sudo : sudo lab ${1:-status}"; exit 1; }

case "${1:-}" in
start)
    log "=== démarrage ordonné du labo"
    start_vm pfsense-fw
    wait_for "pfSense joignable ($FW:443)" 180 port_open "$FW" 443 || exit 1
    start_vm Win-Server-DC
    wait_for "DNS du DC Windows opérationnel ($DC, $DOMAIN)" 300 dns_ok "$DC" "$DOMAIN" || exit 1
    start_vm lnx-dc01
    wait_for "DNS du DC Samba opérationnel ($LDC, $LDOMAIN)" 180 dns_ok "$LDC" "$LDOMAIN" \
        || log "ATTENTION : DC Samba sans réponse DNS ; le reste du labo démarre quand même"
```

```
    for vm in truenas fedora wazuh-siem wg-client; do start_vm "$vm"; sleep 10; done
    log "=== labo démarré dans l'ordre"
    ;;
stop)
    log "=== arrêt ordonné du labo"
    for (( i = ${#ORDER[@]} - 1; i >= 0; i-- )); do
        vm=${ORDER[i]}
        [[ "$(state "$vm")" == running ]] || continue
        delai=180
        if [[ $vm == Win-Server-DC ]]; then delai=300; fi
        # Arrêt par l'agent invité si présent (demande au système lui-même), sinon bouton ACPI (F-26)
        if virsh qemu-agent-command "$vm" '{"execute":"guest-ping"}' >/dev/null 2>&1; then
            virsh shutdown "$vm" --mode agent >/dev/null && log "arrêt propre demandé par l'agent invité
: $vm"
        else
            virsh shutdown "$vm" --mode acpi >/dev/null && log "arrêt propre demandé par ACPI : $vm"
        fi
        wait_for "$vm arrêtée" "$delai" is_off "$vm" \
            || log "ATTENTION : $vm ne s'arrête pas ; vérifier sa console (aucune coupure forcée)"
    done
    log "=== labo arrêté"
    ;;
status)
    for vm in "${ORDER[@]}"; do printf '%-15s %s\n' "$vm" "$(state "$vm")"; done
    ;;
*)
    echo "Usage : sudo lab start | stop | status"; exit 2
    ;;
esac
```

lab-backup

```
#!/usr/bin/env bash
# lab-backup — sauvegarde du labo INFRASEC (hôte HV01)
#   sudo lab-backup local          : arrêt ordonné → instantané BTRFS en LECTURE SEULE de /vm
#                                    + wg-client, définitions des VM, coffre → redémarrage
#   sudo lab-backup list           : sauvegardes locales disponibles
#   sudo lab-backup verify         : contrôle les empreintes de la dernière sauvegarde locale
#   sudo lab-backup export /dev/sdX : copie la dernière sauvegarde sur un disque USB chiffré (LUKS)
# Niveau 1 (local) : protège contre fausse manipulation, corruption, rançongiciel (lecture seule, root
700).
# Ne protège PAS contre la panne ou le vol du disque de l'hôte : c'est le rôle de « export ».
# Traces : journalctl -t lab-backup
set -euo pipefail
REPO=/srv/lab-backup          # sous-volume BTRFS dédié, root:root 700
GARDER=4                      # nombre de sauvegardes locales conservées
WG=(/var/lib/libvirt/images/wg-client.qcow2 /var/lib/libvirt/images/wg-client-base.qcow2)
COFFRE=/home/TENET/coffre
VMS=(pfsense-fw Win-Server-DC lnx-dc01 truenas fedora wazuh-siem wg-client)
NAME=labbackup; MNT=/mnt/$NAME

log() { printf '%s  %s\n' "$(date '+%F %T')" "$*"; logger -t lab-backup -- "$*"; }
die() { log "ERREUR : $*"; exit 1; }
[[ $EUID -eq 0 ]] || die "à lancer avec sudo"

init_repo() {
    if ! btrfs subvolume show "$REPO" >/dev/null 2>&1; then
        btrfs subvolume create "$REPO" >/dev/null; chown root:root "$REPO"; chmod 700 "$REPO"
        log "dépôt créé : $REPO (sous-volume BTRFS, root 700)"
    fi
}
last_backup() { ls -1d "$REPO"/20* 2>/dev/null | grep -v -- '-vm$' | tail -1; }

case ${1:-} in
local)
    init_repo
    d=$(date +%Y%m%d-%H%M); dest=$REPO/$d
```

```
    log "=== sauvegarde locale $d"
    lab stop
    for vm in "${VMS[@]}"; do
        if [[ $(virsh domstate "$vm") != "shut off" ]]; then lab start; die "$vm n'est pas arrêtée :
sauvegarde annulée, labo relancé"; fi
    done
    # 1. disques des VM : instantané BTRFS en lecture seule du sous-volume /vm
    btrfs subvolume snapshot -r /vm "$dest-vm" >/dev/null
    # 2. le reste dans un sous-volume annexe : wg-client (hors /vm), définitions, coffre, scripts
    btrfs subvolume create "$dest" >/dev/null
    mkdir -p "$dest"/{wg-client,xml,coffre}
    cp --reflink=auto --sparse=always "${WG[@]}" "$dest/wg-client/"
    for vm in "${VMS[@]}"; do
        virsh dumpxml --security-info "$vm" > "$dest/xml/$vm.xml"
        virsh snapshot-list "$vm" --name > "$dest/xml/$vm.snapshots.txt"
    done
    cp -a "$COFFRE"/. "$dest/coffre/"
    cp -a /usr/local/bin/lab /usr/local/bin/lab-backup "$dest/"
    ( cd "$dest" && find . -type f ! -name 'SHA256SUMS*' -print0 | sort -z | xargs -0 sha256sum >
SHA256SUMS )
    ( cd "$dest-vm/images" && sha256sum ./*.qcow2 > "$dest/SHA256SUMS-vm" )
    chmod -R go-rwx "$dest"
    btrfs property set -ts "$dest" ro true
    log "empreintes : $(wc -l < "$dest/SHA256SUMS") fichiers + $(wc -l < "$dest/SHA256SUMS-vm") disques
de VM"
    lab start
    # rétention : on garde les $GARDER plus récentes
    mapfile -t old < <(ls -1d "$REPO"/20*-vm 2>/dev/null | head -n -"$GARDER")
    for v in "${old[@]}"; do
        b=${v%-vm}
        btrfs subvolume delete "$v" >/dev/null
        btrfs property set -ts "$b" ro false; btrfs subvolume delete "$b" >/dev/null
        log "rétention : $(basename "$b") supprimée"
    done
    log "=== sauvegarde locale terminée : $d"
    ;;
list)
    for v in "$REPO"/20*-vm; do
        if [[ -e $v ]]; then echo "$(basename "${v%-vm}")  disques:$(btrfs property get -ts "$v" ro)
annexe:$(btrfs property get -ts "${v%-vm}" ro)"; fi
    done
    ;;
verify)
    b=$(last_backup); [[ -n $b ]] || die "aucune sauvegarde"
    log "vérification de $(basename "$b")"
    ( cd "$b" && sha256sum --quiet -c SHA256SUMS ) || die "annexe : empreinte incorrecte"
    ( cd "$b-vm/images" && sha256sum --quiet -c "$b/SHA256SUMS-vm" ) || die "disques : empreinte
incorrecte"
    log "intégrité : OK"
    ;;
export)
    dev=${2:-}; [[ -b $dev ]] || die "périphérique absent : ${dev:-?}"
    [[ $(lsblk -dno TRAN "$dev") == usb ]] || die "$dev n'est pas un disque USB : refus"
    b=$(last_backup); [[ -n $b ]] || die "aucune sauvegarde locale"
    if ! cryptsetup isLuks "$dev"; then
        lsblk -o NAME,SIZE,MODEL,TRAN "$dev"
        read -rp "TOUT le contenu de $dev sera effacé. Taper EFFACER : " ok; [[ $ok == EFFACER ]] || die
"annulé"
        cryptsetup luksFormat --type luks2 "$dev"; cryptsetup open "$dev" "$NAME"
        mkfs.ext4 -qL labbackup /dev/mapper/$NAME; cryptsetup close "$NAME"
    fi
    cryptsetup open "$dev" "$NAME"; mkdir -p "$MNT"; mount /dev/mapper/$NAME "$MNT"
    trap 'sync; umount "$MNT"; cryptsetup close "$NAME"; log "support refermé"' EXIT
    out=$MNT/$(basename "$b"); mkdir -p "$out/vm"
    cp -a "$b"/. "$out/"; cp --sparse=always "$b-vm/images"/*.qcow2 "$out/vm/"
    ( cd "$out/vm" && sha256sum --quiet -c "$out/SHA256SUMS-vm" ) && log "export vérifié : $out"
    ;;
```

```
  *) echo "Usage : sudo lab-backup local | list | verify | export /dev/sdX"; exit 2 ;;
  esac
```

Annexe R · Registre d'intégrité des pièces (SHA-256)

Empreinte SHA-256 de chaque pièce source au 26/10/2026 : scripts d'exploitation, fichiers de l'entreprise et fiches. Une empreinte différente signifie une pièce modifiée.

Pièce	SHA-256
01_entreprise_AD/New-InfrasecCompany.ps1	14a369993eb6cda756af172da2860a5b0d05f990ad25cb9f974c3672ebb96949
01_entreprise_AD/employes.csv	7228c38ac738ef14d5d02374da9a5f7da83b79c9ed357bc2e1e820e13831ea8e
01_entreprise_AD/infrasec-samba-societe.sh	e120caacd942d3d69aa37ad18486159659381ddf994fe24eda1d0726b74e695d
03_scripts/lab	98df9b18610bc695d17f93a04e09f6b3014fc12fab54a76e7b7f26f4660802e6
03_scripts/lab-backup	5ed4dcb1d3c9758e8ec85144e90da3963298137f37a524ccc7c2dccf5aa836de
02_incidents/ARCH_Fiches-machines.md	094164eaab375c582db2bd6d8d338a457b68cf6a7cefe5bdd702872e5e2a8ec7
02_incidents/F-13_Hote-contournement-pfSense.md	6915b02b1312ea8cb7424f73309b84ffca4c61578e80aacc0007fa3db638009b
02_incidents/F-14_Flux-vulnerabilites-ordre-demarrage.md	29aaf12e1214671fc35d1d984e83bf70cd5691dde10531edbf3b5d21aa08f27f
02_incidents/F-15_SIEM-sans-firewall.md	3ca7cd0d75e4159f4c6dec2c99e63f67ceb91a6fb9cb542251215f84d2155aec
02_incidents/F-16_Disque-SIEM-non-supervise.md	0df7605e3464059a49f6e4503a158d6486c33b2ab4d323ac14746081778a07b8
02_incidents/F-17_Navigation-sur-le-DC.md	a166308cdb1a027f510337a6d9e3ae0cdf54fc5574129ed0d3d4ddc47674581c
02_incidents/F-18_Arret-agent-non-alerte.md	7dfac99f884c1e2dea91d05a96cb4540fea47d1ce7639c8455f926d0532c74d3
02_incidents/F-19_Persistance-dossier-demarrage.md	3dd5464d8cb89c88bc8e77a249fc8261d55f6dc3bec2f42be230c699d506bec2
02_incidents/F-20_Audit-SMB-fichiers.md	04536ca0e5f5bc6cfe8009d0d3db5c76cc50aad8acd8b2b1524a2b92cd71f700
02_incidents/F-21_Retention-et-scellement-journaux.md	6a2449f31b0e14af712c287920a3b29970a860ed207e3bd4821b7bdff3a2a5d3
02_incidents/F-22_Secrets-installation-SIEM.md	4dc2880179b475a653b5e1975e12684e6ecd90e98400e02e9f51a0c900ba24c4
02_incidents/F-23_Capacite-memoire-hyperviseur.md	b8e936a9c69b2d94146dc6a4b12f68accb35eef00e8dfe4284b4e4d7414b2025

Pièce	SHA-256
02_incidents/F-24_Verrouillage-sans-alerte.md	878095c29253b4f85f5ef39b4a7d10fbbef7fd77a6b574b5b7bd827132f833ac
02_incidents/F-25_Samba-sans-pare-feu.md	f0b1c8aeeedff552fb2b0ffe0b297f1e66d19f3e6f1871e90490ca56647ebb75
02_incidents/F-26_Arret-ACPI-ignore.md	5ca21bd36ffc512988b3d4f914527ed44f1ad3680e63bdaa8a19548cbae3e04c
02_incidents/INC-08_Cockpit-hors-reseau.md	34a6d9593622a0fbabf5e82abf6272f0041c5cf6c3262f1718b3bef11a06c19f
02_incidents/INC-09_Zabbix-redemarrage.md	87956d071897da64484c5e54fa26c94be88b1f3b15369c7cd66e8454e7620363
02_incidents/INC-10_Adresse-hote-perdue.md	debaed39bbdc2056cfcd282446e2fa9fa4fa73e167d8778e786f75f6187cd9e6
02_incidents/INC-11_SIEM-aveugle.md	e3c09cc08329744ee4ebe5d8e9a3a7dd180c5c76e9daeaafb55006f1a9574249
02_incidents/PROC-01_Migration-annuaire.md	6a65d5916072ea275d4ae92935e41a2dc8f5376edf787c7f937f2a6ddb9042de
02_incidents/PV-05_Entreprise-AD-Partages.md	8b1d328cf1e731e2b457850a3e67b3e42cf894daf72439fe7c971b9eebfcdb45
02_incidents/PV-06_Restauration-instantane.md	b1c7ae4eec39815112e01042f10aee5264c44bd8c1ea671bd7de7429dd1e3024
02_incidents/PV-07_SSH-administration-DC.md	730449f11e4fcb639b7381a19c5136eed723c306786bd887fad4d1e797181310
02_incidents/PV-08_Domaine-Samba-continuite.md	ce48c1488f09e14f892deeb65be264bfe3e7e8ee484f5e624e1a6b5b0fef8668
02_incidents/PV-09_Sauvegarde-locale-lab-backup.md	916b107f4299730203152f5e8a8851aaf48ee59663efdfb372a2908bd1b5827b

Annexe S · Commandes de construction, de A à Z

Ce livret rassemble les commandes qui ont construit le labo, dans l'ordre où je les ai passées, de l'hôte jusqu'au dernier service. Le jury m'a conseillé de les réunir : elles permettent à un autre administrateur de reconstruire l'infrastructure sans avoir suivi le projet. Les étapes faites dans une interface web sont données sous forme de chemin de menus.

Où taper. Chaque bloc indique la machine : **HV01** (terminal de l'hyperviseur), **pfSense** (interface web ou console, option 8), **DC** (PowerShell administrateur, par SSH depuis HV01), **lnx-dc01**, **TrueNAS** (System → Shell), **fedora** (`ssh ais@10.10.10.30`), **SIEM** (`ssh ais@10.10.10.40`), **wg-client** (console série de Cockpit).

Trois règles tenues tout au long. Un instantané avant chaque changement. Aucun secret dans une commande ni dans un fichier : toutes les saisies sensibles sont masquées (`Read-Host -AsSecureString` , invites interactives). Un mot entre chevrons (`<vm>` , `<UUID>`) est à remplacer.

◆ A · Hôte HV01 : paquets, services, stockage

HV01 — paquets de virtualisation, de containers et d'outillage :

```
sudo dnf upgrade --refresh -y
sudo dnf install -y qemu-kvm libvirt libvirt-daemon-config-network virt-install \
  edk2-ovmf swtpm libosinfo guestfs-tools \
  cockpit cockpit-machines cockpit-podman cockpit-storaged cockpit-selinux \
  podman buildah skopeo policycoreutils-python-utils setroubleshoot-server \
  snapper btrfs-progs wireguard-tools nmap tcpdump bind-utils
```

HV01 — démons modulaires de libvirt, Cockpit, pare-feu :

```
for d in virtqemud virtnetworkd virtstoraged virtinterfaced virtnodedevd; do
  sudo systemctl enable --now ${d}.socket
done
sudo systemctl enable --now virtlogd.socket cockpit.socket firewalld
sudo usermod -aG libvirt,kvm "$USER"
```

HV01 — sous-volumes BTRFS sans copy-on-write pour les disques des VM et les couches des containers :

```
sudo btrfs subvolume create /vm
sudo btrfs subvolume create /var/lib/containers
sudo chattr +C /vm /var/lib/containers
lsattr -d /vm /var/lib/containers            # attribut C attendu
# /etc/fstab
# UUID=<UUID>  /vm                  btrfs  subvol=vm,nodatacow,noatime 0 0
# UUID=<UUID>  /var/lib/containers  btrfs  subvol=var/lib/containers,nodatacow,noatime 0 0
sudo systemctl daemon-reload && sudo mount -a && findmnt -t btrfs
```

HV01 — SELinux (jamais désactivé) et pool de stockage `tenet` :

```
sudo mkdir -p /vm/images /vm/iso
sudo semanage fcontext -a -t virt_image_t '/vm/images(/.*)?'
sudo restorecon -Rv /vm/images
sudo chmod 711 /vm/images
ls -dZ /vm/images                            # system_u:object_r:virt_image_t:s0
sudo virsh pool-define-as tenet dir --target /vm/images
sudo virsh pool-build tenet && sudo virsh pool-start tenet && sudo virsh pool-autostart tenet
```

HV01 — instantanés de l'hôte avec Snapper :

```
sudo snapper -c root create-config /
sudo snapper -c root set-config NUMBER_LIMIT=10 NUMBER_LIMIT_IMPORTANT=5
sudo systemctl enable --now snapper-timeline.timer snapper-cleanup.timer
sudo snapper -c root create -d "POST-SOCLE-FEDORA-TENET-STABLE"
```

◆ B · Hôte HV01 : réseaux et filtrage

HV01 — réseau NAT `default` (WAN de pfSense) et pont isolé `br-tenet` (LAN), déclarés dans NetworkManager pour survivre à tout rechargement (INC-10) :

```
sudo virsh net-start default && sudo virsh net-autostart default
sudo nmcli con add type bridge ifname br-tenet con-name br-tenet \
  ipv4.method manual ipv4.addresses 10.10.10.2/24 ipv4.never-default yes ipv6.method disabled
cat > tenet.xml <<'EOF'
<network><name>tenet</name><forward mode='bridge'/><bridge name='br-tenet'/></network>
EOF
sudo virsh net-define tenet.xml && sudo virsh net-start tenet && sudo virsh net-autostart tenet
```

HV01 — zone firewalld dédiée au pont, sans service ni transfert (F-13) :

```
sudo snapper -c root create -d "PRE-F13-ZONE-LAB"
sudo firewall-cmd --permanent --new-zone=lab-tenet
sudo firewall-cmd --permanent --zone=lab-tenet --remove-forward
sudo firewall-cmd --reload
sudo nmcli con mod br-tenet connection.zone lab-tenet
sudo nmcli dev reapply br-tenet
sudo firewall-cmd --get-active-zones
```

HV01 — Cockpit écoute partout, l'accès est filtré par le pare-feu (INC-08) :

```
sudo systemctl revert cockpit.socket
sudo systemctl daemon-reload && sudo systemctl restart cockpit.socket
sudo firewall-cmd --permanent --zone=public --remove-service=cockpit
sudo firewall-cmd --permanent --zone=public \
  --add-rich-rule='rule family="ipv4" source address="192.168.1.0/24" service name="cockpit" accept'
sudo firewall-cmd --reload
```

HV01 — publication du tunnel WireGuard vers le WAN de pfSense :

```
sudo firewall-cmd --permanent --add-masquerade
sudo firewall-cmd --permanent --zone=libvirt --add-masquerade
sudo firewall-cmd --permanent \
  --add-forward-port=port=51820:proto=udp:toaddr=192.168.122.95:toport=51820
sudo firewall-cmd --reload
```

◆ C · pfSense (fw01)

HV01 — VM créée dans Cockpit (deux cartes virtio : `default` puis `tenet`), renommée, média éjecté :

```
sudo virsh shutdown tenet-pfsense
sudo virsh domrename tenet-pfsense pfsense-fw
sudo virsh start pfsense-fw
sudo virsh domblklist pfsense-fw
sudo virsh change-media pfsense-fw sda --eject --config
```

pfSense (console) — menu 1 : `vtnet0` = WAN (DHCP sur le NAT), `vtnet1` = LAN ; menu 2 : LAN `10.10.10.254/24`. Puis, dans l'interface web :

- **System → Setup Wizard** : nom `fw01`, domaine `infrasec.lab`, NTP, mot de passe administrateur changé.
- **System → Advanced → Admin Access** : HTTPS seul (écoute HTTP 80 retirée, constat F-02).
- **Services → DNS Resolver → Domain Overrides** : `infrasec.local` → `10.10.10.10` (PV-08).
- **VPN → WireGuard → Tunnels → Add** : `tun_wg0`, port `51820`, adresse `10.10.20.1/24`.
- **Interfaces → Assignments** : `tun_wg0` → `WG_REMOTE`, **IPv4 statique `10.10.20.1/24`** (INC-07).
- **VPN → WireGuard → Peers → Add Peer** : une clé publique par appareil, *Allowed IPs* unique en `/32` (`10.10.20.2/32` admin, `10.10.20.3/32` salarié, INC-06).
- **Firewall → Rules → WAN** : une seule règle, UDP 51820. **WG_REMOTE** : admin → `10.10.10.0/24` ; salarié → `10.10.10.20` TCP 445 ; tout le reste refusé et journalisé.
- **Services → SNMP** : écoute sur le LAN, communauté aléatoire ; **Firewall → Rules → LAN** : UDP 161 permis depuis `10.10.10.30` seul, refusé et journalisé pour toute autre source.
- **Diagnostics → Backup & Restore** : export XML chiffré, rangé dans le coffre de l'hôte.

pfSense (console, option 8) — contrôle :

```
ping -c3 1.1.1.1
host cloudflare.com
```

◆ D · Contrôleur de domaine Windows (Win-Server-DC)

DC (console) — adresse fixe, nom, forêt `infrasec.local` (mot de passe DSRM saisi masqué) :

```
New-NetIPAddress -InterfaceAlias "Ethernet" -IPAddress 10.10.10.10 `
  -PrefixLength 24 -DefaultGateway 10.10.10.254
Set-DnsClientServerAddress -InterfaceAlias "Ethernet" -ServerAddresses 127.0.0.1
Rename-Computer -NewName "DC01" -Restart
Install-WindowsFeature AD-Domain-Services -IncludeManagementTools
$dsrm = Read-Host -AsSecureString "Mot de passe DSRM"
Install-ADDSForest -DomainName "infrasec.local" -DomainNetbiosName "INFRASEC" `
  -InstallDns -SafeModeAdministratorPassword $dsrm -Force
w32tm /config /manualpeerlist:10.10.10.254 /syncfromflags:manual /update
```

DC — agents : Wazuh (vers le SIEM) et windows_exporter (pour Prometheus) :

```
Start-Process msiexec.exe -Wait -ArgumentList '/i','C:\chemin\wazuh-agent.msi', `
  'WAZUH_MANAGER=10.10.10.40','WAZUH_AGENT_NAME=Win-Server-DC','/qn'
Start-Service WazuhSvc
msiexec /i windows_exporter.msi `
  ENABLED_COLLECTORS="cpu,logical_disk,net,os,service,system,memory,process,tcp,ad,dns" /qn
```

DC — l'entreprise INFRASEC, après vérification de l'empreinte du script et du CSV (PV-05) :

```
Get-FileHash .\New-InfrasecCompany.ps1, .\employes.csv -Algorithm SHA256
.\New-InfrasecCompany.ps1 -CsvPath .\employes.csv -WhatIf     # simulation
.\New-InfrasecCompany.ps1 -CsvPath .\employes.csv             # création
```

DC — politique de mots de passe du domaine et `PSO-Admins` pour les Admins du domaine (F-24) :

```
Set-ADDefaultDomainPasswordPolicy -Identity infrasec.local -MinPasswordLength 14 `
  -LockoutThreshold 10 -LockoutDuration 00:15:00 -LockoutObservationWindow 00:15:00 `
  -MaxPasswordAge 365.00:00:00 -ComplexityEnabled $true
```

```
New-ADFineGrainedPasswordPolicy -Name "PSO-Admins" -Precedence 10 -MinPasswordLength 20 `
  -LockoutThreshold 5 -LockoutDuration 00:30:00 -LockoutObservationWindow 00:30:00 `
  -MaxPasswordAge 180.00:00:00 -ComplexityEnabled $true
$da = Get-ADGroup -Identity "$((Get-ADDomain).DomainSID)-512"     # Admins du domaine, par SID
Add-ADFineGrainedPasswordPolicySubject -Identity "PSO-Admins" -Subjects $da
```

DC — GPO qui interdit la navigation sur les contrôleurs de domaine (F-17) :

```
$g = "DC - Navigation interdite"
New-GPO -Name $g | New-GPLink -Target "OU=Domain Controllers,DC=infrasec,DC=local"
Set-GPRegistryValue -Name $g -Key "HKLM\SOFTWARE\Policies\Microsoft\Edge\URLBlocklist" `
  -ValueName "1" -Type String -Value "*"
Set-GPRegistryValue -Name $g -Key "HKLM\SOFTWARE\Policies\Microsoft\Edge" `
  -ValueName "StartupBoostEnabled" -Type DWord -Value 0
Set-GPRegistryValue -Name $g -Key "HKLM\SOFTWARE\Policies\Microsoft\Edge" `
  -ValueName "BackgroundModeEnabled" -Type DWord -Value 0
gpupdate /force
```

DC — OpenSSH limité à l'hyperviseur, PowerShell par défaut (PV-07) :

```
Start-Service sshd; Set-Service sshd -StartupType Automatic
Set-NetFirewallRule -Name OpenSSH-Server-In-TCP -RemoteAddress 10.10.10.2 -Profile Domain
New-ItemProperty -Path "HKLM:\SOFTWARE\OpenSSH" -Name DefaultShell -PropertyType String -Force `
  -Value "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe"
```

HV01 puis DC — `adm.rj` par clé uniquement (la clé privée reste sur l'hôte, protégée par phrase de passe) :

```
ssh-keygen -t ed25519 -a 100 -f ~/.ssh/id_ed25519_admrj      # HV01
```

```
# DC : clé publique dans le fichier lu pour les membres d'Administrators
icacls C:\ProgramData\ssh\administrators_authorized_keys /inheritance:r `
  /grant "Administrators:F" /grant "SYSTEM:F"
# sshd_config (copie .bak-20261026) : PasswordAuthentication no ; AllowUsers infrasec\adm.rj
& C:\Windows\System32\OpenSSH\sshd.exe -t
Restart-Service sshd
```

DC — redirection DNS vers le domaine Samba (PV-08) :

```
Add-DnsServerConditionalForwarderZone -Name "infrasec.internal" -MasterServers 10.10.10.11
Clear-DnsServerCache -Force
```

HV01 puis DC — agent invité QEMU, pour un arrêt propre depuis l'hyperviseur (F-26) :

```
sudo virt-xml Win-Server-DC --add-device \
  --channel unix,target.type=virtio,target.name=org.qemu.guest_agent.0
```

```
msiexec /i E:\guest-agent\qemu-ga-x86_64.msi /qn
Get-Service QEMU-GA
```

◆ E · Stockage TrueNAS

HV01 — VM avec trois disques virtio, passée en BIOS pour démarrer l'installateur (INC-01) :

```
sudo virt-install --name truenas \
  --disk path=/vm/images/truenas-os.qcow2,size=16,format=qcow2,bus=virtio \
  --disk path=/vm/images/truenas-d1.qcow2,size=40,format=qcow2,bus=virtio \
```

```
  --disk path=/vm/images/truenas-d2.qcow2,size=40,format=qcow2,bus=virtio \
  --cdrom /vm/iso/<truenas-scale>.iso --network network=tenet,model=virtio \
  --graphics vnc --noautoconsole
sudo virsh dumpxml truenas > truenas.xml     # retrait de <firmware>, <loader>, <nvram>
sudo virsh define truenas.xml && sudo virsh start truenas
```

TrueNAS (interface web) :

- **Storage → Create Pool** : `tank`, miroir sur les deux disques de 40 Go.
- **Credentials → Directory Services** : domaine `INFRASEC.LOCAL`, compte de service dédié (heure du DC corrigée d'abord, INC-02).
- **Datasets** : `tank/entreprise` (non partagé, `Domain Users` en *Traverse* sans héritage), puis `Commun`, `Direction`, `Comptabilite`, `RH`, `Projets`.
- **Shares → SMB** : un partage par dataset ; ACL : `DL_SMB_<partage>_RW` → Modify, `DL_SMB_<partage>_RO` → lecture (PV-05) ; *Audit Logging* activé, liste de surveillance `INFRASEC\domain users` (F-20).
- **Data Protection → Periodic Snapshot Tasks** : `tank/entreprise`, récursif, toutes les heures, conservation 2 semaines (PV-06).

◆ F · Nœud de supervision fedora

fedora — services utilisateur au démarrage, sans session ouverte :

```
sudo loginctl enable-linger ais
grep ais /etc/subuid /etc/subgid
mkdir -p ~/.config/containers/systemd
```

fedora — un service = un fichier Quadlet (exemple node-exporter ; Prometheus, Grafana et le pod Zabbix suivent le même modèle) :

```
# ~/.config/containers/systemd/node-exporter.container
[Unit]
Description=Prometheus node-exporter (rootless)
[Container]
Image=quay.io/prometheus/node-exporter:latest
Network=host
Volume=/:/host:ro,rslave
Exec=--path.rootfs=/host --collector.systemd
[Install]
WantedBy=default.target
```

```
/usr/libexec/podman/quadlet -dryrun -user          # validation avant bascule
systemctl --user daemon-reload
systemctl --user start node-exporter prometheus grafana zabbix-pod
podman top node-exporter huser                     # UID réel : jamais root
sudo firewall-cmd --permanent --remove-port=9100/tcp && sudo firewall-cmd --reload
```

fedora — secret Podman de la base Zabbix, puis rotation sans affichage (INC-09) :

```
podman inspect zbx-db --format '{{range .Config.Env}}{{println .}}{{end}}' \
  | sed -n 's/^POSTGRES_PASSWORD=//p' | podman secret create zbx-db-password -
NEW=$(tr -dc 'A-Za-z0-9' </dev/urandom | head -c 32)
printf "ALTER ROLE zabbix WITH PASSWORD '%s';\n" "$NEW" | podman exec -i zbx-db psql -U zabbix -d zabbix
printf '%s' "$NEW" | podman secret create --replace zbx-db-password - ; unset NEW
# zbx-db.container : Secret=zbx-db-password,type=env,target=POSTGRES_PASSWORD
#                    Volume=zbx-pg:/var/lib/postgresql/data:Z
```

fedora — cible Prometheus ajoutée, configuration validée avant redémarrage (F-16) :

```
cp ~/prometheus/prometheus.yml ~/prometheus/prometheus.yml.bak-$(date +%F)
# ajout de la cible 10.10.10.40:9100 en fin de fichier
podman exec prometheus promtool check config /etc/prometheus/prometheus.yml
systemctl --user restart prometheus
```

fedora — durcissement SSH (drop-in) et mises à jour automatiques :

```
# /etc/ssh/sshd_config.d/99-hardening.conf : PermitRootLogin no, AllowTcpForwarding no,
# X11Forwarding no, MaxAuthTries 3, ClientAliveInterval 300, ClientAliveCountMax 2, LogLevel VERBOSE
sudo sshd -t && sudo systemctl reload sshd
sudo systemctl enable --now dnf5-automatic.timer
sudo lynis audit system
```

◆ G · SIEM wazuh-siem

SIEM — installation tout-en-un, puis redémarrage automatique du manager (INC-11) :

```
curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh
sudo bash ./wazuh-install.sh -a
sudo mkdir -p /etc/systemd/system/wazuh-manager.service.d
printf '[Service]\nRestart=on-failure\nRestartSec=30\n' \
  | sudo tee /etc/systemd/system/wazuh-manager.service.d/restart.conf
sudo systemctl daemon-reload
```

SIEM — pare-feu local : une règle par flux légitime (F-15) :

```
sudo ufw default deny incoming && sudo ufw default allow outgoing
sudo ufw allow from 10.10.10.2 to any port 22,443,9090 proto tcp comment 'admin depuis HV01'
sudo ufw allow from 10.10.10.0/24 to any port 1514,1515 proto tcp comment 'agents, enrolement'
sudo ufw allow from 10.10.10.30 to any port 55000,9100 proto tcp comment 'Zabbix, Prometheus'
sudo ufw logging low && sudo ufw enable
sudo apt install -y prometheus-node-exporter
```

SIEM — surveillance whodata du dossier de démarrage, poussée aux agents Windows (F-19) :

```
<!-- /var/ossec/etc/shared/default/agent.conf -->
<agent_config os="Windows">
  <syscheck>
    <directories realtime="yes" whodata="yes">C:\ProgramData\Microsoft\Windows\Start
Menu\Programs\StartUp</directories>
  </syscheck>
</agent_config>
```

```
sudo /var/ossec/bin/verify-agent-conf
```

SIEM — règles locales, validées avant rechargement (100100, 100300, 100310, 100320) :

```
<!-- /var/ossec/etc/rules/local_rules.xml (extrait) -->
<rule id="100300" level="12">
  <if_sid>550, 554</if_sid>
  <field name="file" type="pcre2">(?i)\\start menu\\programs\\startup\\</field>
  <description>INFRASEC - persistance : fichier dans le dossier de démarrage</description>
  <mitre><id>T1547.001</id></mitre>
</rule>
<rule id="100310" level="10">
  <if_sid>506</if_sid>
```

```
  <description>INFRASEC - agent Wazuh arrêté</description>
  <mitre><id>T1562.001</id></mitre>
</rule>
<rule id="100320" level="10">
  <if_sid>60115</if_sid>
  <description>INFRASEC - compte verrouillé</description>
  <mitre><id>T1110</id></mitre>
</rule>
```

```
sudo cp /var/ossec/etc/rules/local_rules.xml /var/ossec/etc/rules/local_rules.xml.bak-$(date +%Y%m%d)
sudo /var/ossec/bin/wazuh-analysisd -t && sudo systemctl restart wazuh-manager
```

SIEM — conservation : politique ISM de 90 jours, appelée avec le certificat d'administration (F-21) :

```
C=/etc/wazuh-indexer/certs
sudo curl --cacert $C/root-ca.pem --cert $C/admin.pem --key $C/admin-key.pem \
  -X PUT https://127.0.0.1:9200/_plugins/_ism/policies/infrasec-retention-90j \
  -H 'Content-Type: application/json' -d @ism-retention-90j.json
sudo curl --cacert $C/root-ca.pem --cert $C/admin.pem --key $C/admin-key.pem \
  -X POST 'https://127.0.0.1:9200/_plugins/_ism/add/wazuh-alerts-*' \
  -H 'Content-Type: application/json' -d '{"policy_id":"infrasec-retention-90j"}'
```

SIEM — scellement quotidien avec rattrapage au démarrage :

```
sudo install -o root -g root -m 0755 wazuh-sceller-journaux /usr/local/sbin/
sudo install -m 0644 wazuh-sceller-journaux.service wazuh-sceller-journaux.timer /etc/systemd/system/
sudo systemctl daemon-reload && sudo systemctl enable --now wazuh-sceller-journaux.timer
```

SIEM puis HV01 — secrets d'installation chiffrés et sortis du SIEM (F-22) :

```
sudo gpg --symmetric --cipher-algo AES256 wazuh-install-files.tar        # SIEM
sha256sum wazuh-install-files.tar.gpg
scp ais@10.10.10.40:wazuh-install-files.tar.gpg ~/coffre/                # HV01
chmod 700 ~/coffre && chmod 600 ~/coffre/*
sudo shred -u wazuh-install-files.tar wazuh-install-files.tar.gpg       # SIEM, après contrôle
```

◆ H · Contrôleur de continuité lnx-dc01 (Samba AD)

lnx-dc01 — Debian 13 minimale, adresse fixe `10.10.10.11`, `root` verrouillé, provisionnement du domaine (mot de passe administrateur saisi à l'invite) :

```
sudo apt install -y samba winbind krb5-user smbclient ldb-tools dnsutils ufw
sudo systemctl disable --now smbd nmbd winbind
sudo mv /etc/samba/smb.conf /etc/samba/smb.conf.orig
sudo samba-tool domain provision --use-rfc2307 --realm=INFRASEC.INTERNAL --domain=INFRALNX \
  --server-role=dc --dns-backend=SAMBA_INTERNAL --option="dns forwarder = 10.10.10.254"
sudo cp /var/lib/samba/private/krb5.conf /etc/krb5.conf
sudo systemctl unmask samba-ad-dc && sudo systemctl enable --now samba-ad-dc
sudo passwd -l root
```

lnx-dc01 — même politique de mots de passe que le domaine Windows (F-24) :

```
sudo samba-tool domain passwordsettings set --min-pwd-length=14 --account-lockout-threshold=10 \
  --account-lockout-duration=15 --reset-account-lockout-after=15 --max-pwd-age=365
sudo samba-tool domain passwordsettings pso create PSO-Admins 10 --min-pwd-length=20 \
  --account-lockout-threshold=5 --account-lockout-duration=30 --reset-account-lockout-after=30 \
  --max-pwd-age=180
sudo samba-tool domain passwordsettings pso apply PSO-Admins "Domain Admins"
```

lnx-dc01 — même entreprise, même fichier source, vérifié par empreinte (PV-08) :

```
sha256sum employes.csv infrasec-samba-societe.sh
sudo ./infrasec-samba-societe.sh employes.csv --dry-run
sudo ./infrasec-samba-societe.sh employes.csv
```

lnx-dc01 — agent Wazuh de la version du manager, bloqué ; pare-feu (F-25) :

```
sudo WAZUH_MANAGER=10.10.10.40 apt install -y wazuh-agent=4.14.8-1
sudo apt-mark hold wazuh-agent && sudo systemctl enable --now wazuh-agent
sudo ufw default deny incoming && sudo ufw logging low
sudo ufw allow from 10.10.10.2 to any port 22 proto tcp comment 'SSH depuis HV01'
sudo ufw allow from 10.10.10.0/24 to any port 53,88,389,464 comment 'annuaire tcp/udp'
sudo ufw allow from 10.10.10.0/24 to any port 135,445,636,3268,3269 proto tcp comment 'annuaire tcp'
sudo ufw allow from 10.10.10.0/24 to any port 49152:65535 proto tcp comment 'RPC dynamique'
sudo ufw show added && sudo ufw enable
```

pfSense — redirection du domaine Windows pour Samba : **Services → DNS Resolver → Domain Overrides**, `infrasec.local` → `10.10.10.10`.

◆ I · Client distant wg-client

wg-client — clé générée sur l'appareil ; seule la clé publique part vers le pare-feu :

```
umask 077
wg genkey > user.key
wg pubkey < user.key > user.pub
cat user.pub
# /etc/wireguard/wg0.conf : Address = 10.10.20.3/32 ; Endpoint = 192.168.122.95:51820
sudo wg-quick up wg0
```

HV01 — agent invité pour un arrêt propre (F-26) :

```
sudo virt-xml wg-client --add-device \
  --channel unix,target.type=virtio,target.name=org.qemu.guest_agent.0
```

◆ J · Exploitation depuis HV01

HV01 — capacité : mémoire des VM réduite d'après la mesure (F-23) :

```
sudo virsh dommemstat <vm>
sudo virsh setmaxmem pfsense-fw 2G --config && sudo virsh setmem pfsense-fw 2G --config
sudo virsh setmaxmem Win-Server-DC 4G --config && sudo virsh setmem Win-Server-DC 4G --config
```

HV01 — scripts d'exploitation (annexe des scripts) :

```
sha256sum lab lab-backup
sudo install -o root -g root -m 0755 lab lab-backup /usr/local/bin/
sudo lab start            # démarrage ordonné, attente DNS réelle
sudo lab stop             # arrêt propre : agent invité, sinon ACPI ; jamais forcé
sudo lab-backup local     # instantané BTRFS en lecture seule + annexe + empreintes
```

HV01 — instantanés avant et après chaque opération :

```
sudo virsh shutdown <vm>; sleep 25
sudo virsh snapshot-create-as <vm> <étiquette> "<description>"
```

```
sudo virsh start <vm>
sudo snapper -c root create -d "POST-<OPÉRATION>-STABLE"
```

Annexe T · Commandes de test (preuve de fonctionnement)

Ces commandes prouvent que le labo fonctionne, sans rien modifier sauf mention contraire. Pour chacune : où la taper, et ce qu'on doit voir. Un test de filtrage se lance toujours depuis une machine tierce, jamais depuis la cible ; un test d'accès distant part toujours de wg-client, jamais de l'hôte (INC-05).

1 · Hôte HV01

```
sudo lab status                          # 7 VM « running »
getenforce                               # Enforcing
sudo ls -lZ /vm/images/                  # svirt_image_t et une paire c…,c… par VM
sudo firewall-cmd --get-active-zones     # lab-tenet → br-tenet ; public → wlo1
sudo firewall-cmd --zone=lab-tenet --query-forward   # no
journalctl -t lab --since today          # chaque étape du démarrage et de l'arrêt
sudo snapper -c root list | grep STABLE # points de retour
sudo lab-backup list                     # disques:ro=true  annexe:ro=true
sudo lab-backup verify                   # intégrité : OK
free -h                                  # swap quasi nul, mémoire disponible
```

2 · Accès distant (wg-client)

```
sudo wg show                             # latest handshake : quelques secondes
nc -zv -w3 10.10.10.20 445               # succeeded : partage autorisé
nc -zv -w3 10.10.10.10 3389              # timed out : refus, journalisé sur WG_REMOTE
ip route get 10.10.10.10                 # sort par wg0, jamais par ens3
```

pfSense — Status → System Logs → Firewall : les refus de `10.10.20.3` sur `WG_REMOTE` ; **VPN → WireGuard → Status** : négociation récente.

3 · Contrôleur de domaine Windows (SSH depuis HV01)

```
ssh -i ~/.ssh/id_ed25519_admrj -l 'infrasec\adm.rj' 10.10.10.10    # accepté, par clé
ssh -l 'INFRASEC\Administrator' 10.10.10.10                        # Permission denied
```

```
Get-ADDomain | Select-Object Forest,DNSRoot      # infrasec.local
nltest /dsgetdc:infrasec.local                   # DC01, réussi
Get-ADUserResultantPasswordPolicy adm.rj         # PSO-Admins : 20, verrou à 5
Get-ADDefaultDomainPasswordPolicy                # 14 caractères, verrou à 10
gpresult /r /scope computer                      # « DC - Navigation interdite » appliquée
Get-Service WazuhSvc, windows_exporter, sshd, QEMU-GA    # Running
Resolve-DnsName lnx-dc01.infrasec.internal       # 10.10.10.11
w32tm /query /source                             # 10.10.10.254
```

4 · Contrôleur Samba lnx-dc01

```
sudo samba-tool domain level show                # niveau du domaine
sudo samba-tool user list | wc -l                # 15 comptes
sudo samba-tool domain passwordsettings pso show-user administrator   # PSO-Admins
host -t SRV _ldap._tcp.infrasec.local            # 0 100 389 dc01.infrasec.local.
sudo ufw status verbose                          # refus par défaut, 4 règles
sudo ./infrasec-samba-societe.sh employes.csv    # idempotence : « === terminé » seul
```

5 · Stockage TrueNAS (System → Shell)

```
zpool status tank                                # mirror-0 ONLINE, No known data errors
zfs list -t snapshot -r tank/entreprise | tail -6   # instantanés horaires
wbinfo -t && net ads testjoin                    # relation d'approbation OK, Join is OK
midclt call audit.query '[["service","=","SMB"]]' '{"limit":20,"order_by":["-message_timestamp"]}' | jq
'.[].event'
```

6 · Contrôle d'accès aux partages (fedora, comptes du test PV-05)

```
smbclient //10.10.10.20/Projets -U 'INFRASEC\k.haddad' -c 'put /etc/hostname k.haddad.txt'   # OK
smbclient //10.10.10.20/RH -U 'INFRASEC\k.haddad' -c 'ls'      # NT_STATUS_ACCESS_DENIED
smbclient //10.10.10.20/RH -U 'INFRASEC\c.morel' -c 'ls'       # OK, lecture
smbclient //10.10.10.20/RH -U 'INFRASEC\c.morel' -c 'put /etc/hostname x.txt'   # ACCESS_DENIED
```

7 · Supervision (fedora)

```
podman ps                                        # 7 conteneurs Up
systemctl --user status prometheus grafana node-exporter --no-pager   # active (running)
curl -s localhost:9091/api/v1/targets | jq '.data.activeTargets[].health'   # "up" × 4
podman inspect zbx-db --format '{{.Config.Env}}' | grep -c POSTGRES_PASSWORD=   # 0
nc -zv -w3 10.10.10.40 22                        # timed out : SSH du SIEM fermé à fedora (F-15)
nc -zv -w3 10.10.10.40 1514                      # succeeded : réception des agents
```

Navigateur de HV01 — Grafana `http://10.10.10.30:3000` : règles « Cible injoignable » et « Disque presque plein » en *Normal* ; Zabbix `http://10.10.10.30:8080` : `fw01` disponible en SNMP, `tun_wg0 = up (1)`, deux contrôles du SIEM à 1.

8 · SIEM wazuh-siem

```
sudo systemctl is-active wazuh-manager wazuh-indexer wazuh-dashboard   # active × 3
systemctl show wazuh-manager -p Restart -p RestartUSec                 # on-failure, 30s
sudo /var/ossec/bin/agent_control -l             # 001 fedora, 002 dc01, 003 lnx-dc01 : Active
sudo ufw status numbered                         # 7 règles, refus par défaut
cd /var/ossec/logs/alerts/2026/Oct && sha256sum -c *.sha256   # OK pour chaque jour scellé
systemctl list-timers wazuh-sceller-journaux.timer             # prochaine exécution 00:30 UTC
sudo grep -c '"rule":{"level":1[0-5]' /var/ossec/logs/alerts/alerts.json   # alertes ≥ 10 du jour
```

9 · Scénarios de détection (modifient l'état ; à défaire aussitôt)

DC — persistance (F-19) : alerte 100300, niveau 12, en moins de 2 s.

```
New-Item "C:\ProgramData\Microsoft\Windows\Start Menu\Programs\StartUp\maj.bat" -Value "rem test"
Remove-Item "C:\ProgramData\Microsoft\Windows\Start Menu\Programs\StartUp\maj.bat"
```

DC — neutralisation de l'agent (F-18) : alerte 100310, niveau 10.

```
sc.exe stop WazuhSvc; Start-Sleep 45; sc.exe start WazuhSvc
```

fedora — attaque lente sur un compte (F-24) : verrouillage au 10e échec, alerte 100320 sans 60204. Déverrouiller ensuite.

```
for i in $(seq 1 10); do smbclient //10.10.10.20/Commun -U 'INFRASEC\k.haddad%faux' -c ls; sleep 40;
```

```
done
```

```
Unlock-ADAccount k.haddad; Get-ADUser k.haddad -Properties LockedOut,badPwdCount
```

HV01 — force brute SSH (PV-03, PV-04) : alerte 100100, niveau 12, dès la 5e tentative.

```
for i in $(seq 1 8); do ssh -o BatchMode=yes -o ConnectTimeout=3 fake$i@10.10.10.30 true; done
```

SIEM — SIEM arrêté (INC-11) : deux problèmes *High* dans Zabbix en moins de 3 minutes.

```
sudo systemctl stop wazuh-manager      # attendre l'alerte Zabbix, puis :
sudo systemctl start wazuh-manager
```

fedora — cible injoignable : Grafana passe en *Firing* après 2 minutes, puis revient à *Normal*.

```
systemctl --user stop node-exporter    # attendre Firing, puis :
systemctl --user start node-exporter
```

02

BLOCK 2

English version

The complete report, written in English. It follows the same plan as block 1, chapter by chapter.

CCP1 CCP2 CCP3

Notice and summary

The setting. This report presents a project I carried out during my training as a secure infrastructure administrator. The company INFRASEC is fictitious. It gives me a client, a need and realistic constraints. The infrastructure itself is real: I built it, ran it and secured it myself, in a virtual lab. Every measurement, capture, log and incident in this report is real.

What this document does not contain. All addresses are private addresses (RFC 1918). No password, no private key, no public IP address and no personal data appears in this report. Only public keys may be quoted. In the technical annexes, `admin` is my administrator ID. Every document is sealed with a SHA- 256 hash (Annex P).

How to read it. The report follows the plan required by the assessment guidelines: skills, requirements, project management, choice of solutions, implementation, stakeholders, summary. Chapter 6 covers monitoring and cybersecurity. The CCP1 part, right after chapter 1, describes the foundation. The full documents are in the annexes, at the end of the report. The annexes are shared by both blocks and written in French; an English guide to each annex opens that section. The glossary (Annex L) explains the technical terms.

The format. The report is written in a simple style, with this English block, guard pages and clickable contents. The acceptance test of October 11, 2026 is described in report PV-04 (Annex O).

The full title. This report takes the project report presented for CCP2 and CCP3 and adds, in French and in English, the CCP1 part: the foundation administered and secured in the first stage. It brings together the three certificates of the title.

00

INTRODUCTION

The project

Who INFRASEC is, where the need comes from, where I come from, and what this report proves.

Context

Introduction: the project

The company and the service

INFRASEC is a small service company. About ten employees regularly work remotely. Its information system is small but complete: a firewall that is the only way in, an Active Directory domain, a file server, a monitoring platform and a SIEM. The IT team is one secure infrastructure administrator. That is my role in this project, reporting to the CISO for security decisions.

Where the project comes from

The project came in two stages. In the first stage, I built and secured the internal foundation: virtualization, segmentation, directory, storage, hardening. That stage matches the certificate “Administer and secure infrastructures”, which I passed. The CCP1 part of this report describes that first stage. The rest covers the second stage: evolving that foundation to meet a new need, and managing the security of the whole system over time.

The need came with remote work. Employees must open the file share from home, and the administrator must be able to work on the infrastructure while traveling. The easy answer would have been to open a service to the Internet. I did not choose it, because it would break the whole security model of the foundation. So the project is to design, cost, deploy and secure Zero-Trust remote access, and then to show that the security of the infrastructure is measured, managed and able to react to an incident.

What this report proves

Area	What I prove	Where
Administer and secure	A virtualized, filtered and hardened foundation: network, systems, virtualization, documented operations	CCP1 part
Design	A need turned into measurable requirements, four solutions compared with a weighted matrix and a three-year cost	Chapters 2 and 4
Plan	A project split into phases, with milestones, tracking and quality goals	Chapter 3
Deploy	A controlled change: validated steps, acceptance test, rollback, tested recovery, handover	Chapter 5
Monitor	Chosen and justified indicators, useful dashboards, a tested alert	Chapter 6.1
Manage cybersecurity	Audit with an engagement letter, EBIOS RM analysis, security policy, measured hardening, verified backup, awareness, detection, incidents, threat watch	Chapters 6.2 to 6.4

01

CHAPTER 1

Skills demonstrated

The skills of the certification framework, and where each one is proven in this report.

CCP1 | CP1 to CP4 | CCP2 | CP5 CP6 CP7 | CCP3 | CP8 CP9 CP10

1. Skills demonstrated

This table uses the exact skill names of the framework for the three certificates of the title (translated from French). For each skill, I show what I did and where the proof is.

Skill (framework title)	What I did	Proof
CP1. Apply good practice in infrastructure administration	Operating rules, a snapshot before every operation, shutdown and restart order, logged incidents, scheduled maintenance, documentation	CCP1 part · Annexes J, M
CP2. Administer and secure network infrastructures	Firewall as the single point of passage, deny by default, segment DNS and time, host filtering, troubleshooting with captures	CCP1 part · Annexes B, N
CP3. Administer and secure system infrastructures	Active Directory and DNS, ZFS storage joined to the domain, measured Linux hardening, PowerShell scripts, proven backup	CCP1 part · Annexes F, G
CP4. Administer and secure virtualized infrastructures	KVM/libvirt hypervisor under SELinux, virtual networks, snapshots, *rootless* Podman containers	CCP1 part · Annex M
CP5. Design a technical solution that meets infrastructure evolution needs	Requirements, comparison of four solutions, weighted decision matrix, three-year total cost, target architecture	Ch. 2 and 4
CP6. Put infrastructure changes into production	Step-by-step deployment plan, acceptance test, rollback plan, recovery and continuity plans, operations documentation, handover	Ch. 5 · Annexes G, M, O
CP7. Implement and optimize infrastructure monitoring	Prometheus, Grafana, exporters, Wazuh, Zabbix over SNMP; justified indicators and thresholds; tested alert; dashboards	Ch. 6.1 · Annex O
CP8. Take part in measuring and analyzing the security level of the infrastructure	Audit engagement letter, technical audit (11 findings), assessment of the report, EBIOS Risk Manager analysis	Ch. 6.2 · Annexes A to D
CP9. Take part in writing and applying the security policy	Twelve-article security policy, measured hardening, 3-2-1-0 backup with proven restore, awareness session	Ch. 6.3 · Annexes E to H
CP10. Take part in detecting and handling security incidents	Wazuh detection chain, simulated attack and lessons learned, real incident handled, incident log, threat watch, tested local detection rule	Ch. 6.4 · Annexes I to K, O

Cross-cutting skills. To *communicate in French and English*, this report exists in both languages (blocks 1 and 2), and the operations manual is bilingual (Annex M). Most of the technical documentation I use is in English. To *keep learning*, the threat watch (Annex K) and the incident log (Annex J) show how each difficulty gave me a rule, a procedure or a documentation fix.

The first certificate. Skills CP1 to CP4 are already validated. The CCP1 part, right after this chapter, describes the foundation as it runs today.

C1

FOUNDATION

Administering and securing the infrastructure (CCP1)

The foundation of the lab: virtualization, network, systems, and the operating rules that keep it running.

CCP1 | CP1 CP2 CP3 CP4



github.com/0x1void/hybrid-infrasec

CCP1 · Administering and securing the infrastructure

This part tells the first stage of the project: building the foundation that the evolution in the next chapters relies on. I rebuilt it on a new Fedora 44 hypervisor, machine by machine, in the order set by the dependencies. It has been in service since October 2, 2026, with its five VMs, the directory and the file share.

I first describe the method, then each build step with its commands, its acceptance check and the problems I ran into. Next come a sheet for each machine, then day-to-day administration, organized by the four skills of the certificate: good practice and operating procedures (CP1), the network (CP2), the systems (CP3) and virtualization (CP4). As in the rest of this report, I only state what I actually did and checked. When the execution departed from the build plan, I say so and explain why. What the lab does not cover is listed at the end.

The foundation at a glance

Everything runs on a single physical machine, an ASUS ROG Strix G18 (32 GB of RAM, NVMe SSD encrypted with LUKS, BTRFS with Snapper snapshots). It is the hypervisor, running Fedora 44 with KVM/QEMU and libvirt. I administer it with Cockpit and from the command line.

Machine	Address	Role	System	Administration
TeneT (host)	physical host	Hypervisor	Fedora 44, KVM/QEMU, libvirt, SELinux *enforcing*	Cockpit, terminal
`pfsense-fw`	`10.10.10.254`	Firewall, router, DNS, single point of passage	pfSense CE	Web interface, console
`Win-Server-DC`	`10.10.10.10`	Active Directory and DNS, forest `infrasec.local`	Windows Server 2025	Console, PowerShell
`truenas`	`10.10.10.20`	Mirrored ZFS storage, SMB share joined to the domain	TrueNAS SCALE 25.10	Web interface, shell
`fedora`	`10.10.10.30`	*Rootless* containers and monitoring	Fedora 44 Server	Cockpit, SSH
`wazuh-siem`	`10.10.10.40`	SIEM	Ubuntu 26.04 LTS, Wazuh 4.14	Dashboard, SSH

Two virtual networks shape the whole. On the WAN side, the libvirt NAT network `192.168.122.0/24` (switch `virbr0`). On the LAN side, an isolated bridge, `br-tenet`, carries the internal segment `10.10.10.0/24`. Among the VMs, only the firewall is connected to both. The host itself still has an address on the LAN: this is finding F-01, covered below. The diagram below shows the physical architecture (it is also Figure 3 in section 3.4); the reference network diagram, with its flow matrix, is in Annex N.

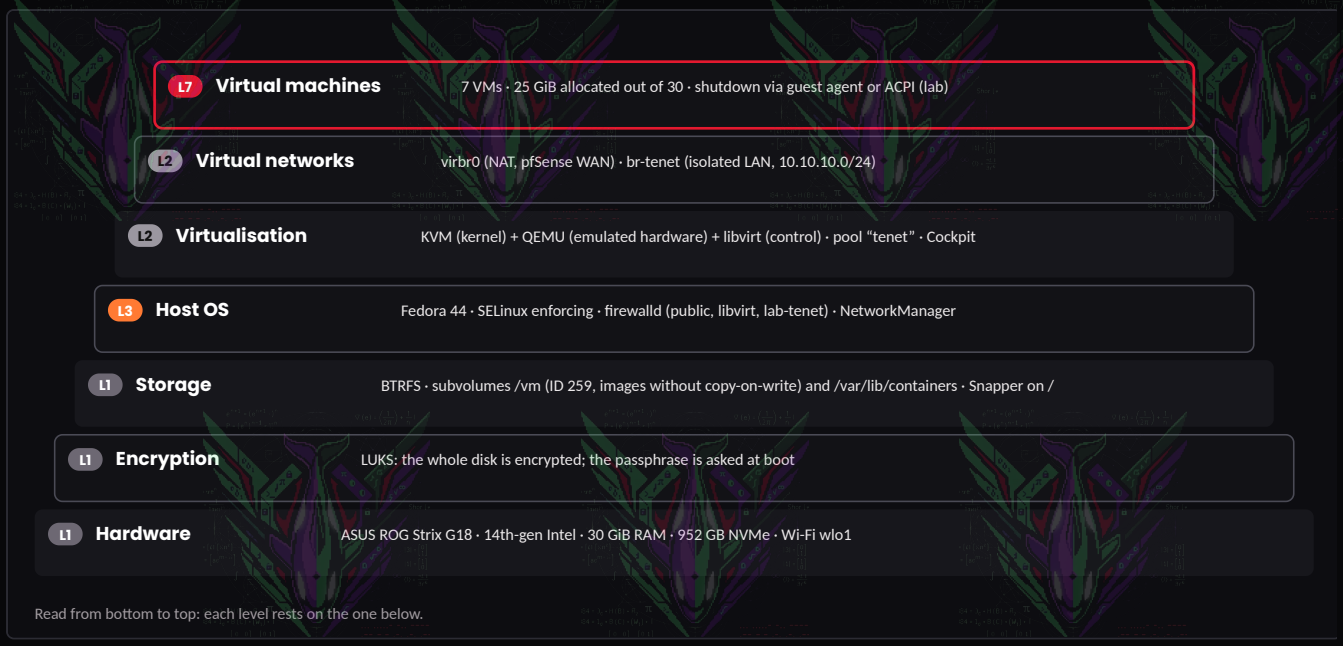


Figure 1 Physical architecture and virtualisation: from the hardware to the virtual machines.

Abbreviations — **L1…L7**: OSI layers: 1 physical, 2 data link, 3 network, 4 transport, 5 session, 6 presentation, 7 application · **LUKS**: Linux Unified Key Setup, full-disk encryption · **BTRFS**: B-tree file system, with snapshots · **KVM**: Kernel-based Virtual Machine · **NAT**: Network Address Translation · **LAN**: lab local network 10.10.10.0/24 · **WAN**: outside of the firewall (NAT network 192.168.122.0/24) · **VM**: virtual machine · **ACPI**: power signal emulated by the hypervisor (Advanced Configuration and Power Interface) · **agent invité**: QEMU guest agent: service in the VM that takes orders from the hypervisor · **Gio / Go**: gibibytes (memory, 2^{30} bytes) / gigabytes (disk, 10^{9} bytes)

The five VMs run at the same time within a memory budget set at 22 GB out of 32, which leaves the host the headroom it needs.

Why these choices. KVM is the hypervisor built into the Linux kernel: QEMU emulates the hardware of each VM, and libvirt provides a single interface to define them, start them, back them up and connect them to networks. Fedora brings a recent kernel, SELinux on by default and Cockpit, in the same family as Red Hat Enterprise Linux, which is common in companies. pfSense is an open-source firewall widely used in small organizations. Windows Server remains the standard for the directory. TrueNAS SCALE brings ZFS, which protects data integrity. Wazuh is a complete open-source SIEM. Each building block is therefore representative of what is administered in production.

◆ The build method

An order set by dependencies. The LAN is isolated: nothing on it reaches the Internet until the firewall routes. The domain controller then provides the DNS and the time that TrueNAS needs to join the domain. The build order follows from that:

```
pfsense-fw  ->  Win-Server-DC  ->  truenas  ->  fedora  ->  wazuh-siem
(gateway)       (DNS, directory)   (joins AD)   (containers)  (SIEM)
```

During installs, each machine uses pfSense as its gateway and DNS resolver. As soon as the directory is in service, the servers' DNS switches to the domain controller (`10.10.10.10`), because Kerberos needs to find its service records.

One acceptance check per step. A machine is not finished until its acceptance test is green: nobody moves on with a red check. The check is always a test that proves the service, not a status light: a DNS query that answers, a verified domain join, a metric that comes through.

A snapshot at every passed check. Two kinds of restore points, always named the same way:

```
# VM: cold snapshot, for a consistent state
sudo virsh shutdown <vm>; sleep 25
```

```
sudo virsh snapshot-create-as <vm> <label> "<description>"
sudo virsh start <vm>

# host: after any change to packages, network or SELinux
sudo snapper -c root create -d "POST-<OPERATION>-STABLE"
```

A snapshot taken with the VM stopped is consistent: no write is in progress. This is essential for the domain controller, whose database must not be frozen in the middle of a transaction.

Traps written down as they came. Three traps cost me time early in the build. I wrote them at the top of the plan so that they would not catch me again:

Trap	What happens	Fix
UEFI boot order	The global boot option is ignored: the order is set disk by disk	`sudo virt-xml <vm> --edit target=<disk> --disk boot_order=<n>`
Lost installation media	After the VM is redefined, the CD drive has no image any more	`sudo virsh change-media <vm> <drive> /vm/iso/<image>.iso -- config`
Windows: “Press any key to boot from CD”	The prompt times out before the console is opened	Open the Cockpit console before the first boot, or `sudo virsh reset <vm>`

A rule for secrets. No password, key or token in a file or a command. All sensitive input is interactive: `Read-Host -AsSecureString` on Windows, the web interfaces’ prompts elsewhere. None of it goes into the report.

The build timeline

Period	Step	Marker
September 2026	Preparing the Fedora 44 host: packages, subvolumes, SELinux, pool, networks, Cockpit, Snapper	Snapper point `POST-SOCLE-FEDORA-TENET-STABLE`
Late September to October 2	Building the five VMs in dependency order; TrueNAS on October 2 (INC-01, INC-02)	October 2 milestone: five VMs in service, directory and share working
October 4	Domain controller metrics (INC-03), audit (PV-02), restore test (PV-01), hardening	Lynis 69 → 76, freeze report
October 5 and 6	WireGuard remote access (evolution, CCP2)	Chapter 5
October 11	Acceptance test of the evolution (PV-04), freeze snapshots `gel-20261011`	Annexes F and O

The date that drove everything was the report deadline. So I built the foundation as early as possible, so that the security steps (audit, restore, hardening) would rest on a stable base.

Step 1 · The TeneT host

The host is the foundation of everything else: if it is badly prepared, no VM starts or the disks degrade. So I treated its installation like that of a production server. The disk is encrypted with LUKS from the Fedora installation onward: if the machine is lost or stolen, the VM disks cannot be read.

Packages. I only install what is used: virtualization, its administration, containers, SELinux and snapshots, plus a few network tools.

```
sudo dnf upgrade --refresh -y
sudo dnf install -y qemu-kvm libvirt libvirt-daemon-config-network virt-install \
```

```
  edk2-ovmf swtpm libosinfo guestfs-tools \
  cockpit cockpit-machines cockpit-podman cockpit-storaged cockpit-selinux \
  podman buildah skopeo policycoreutils-python-utils setroubleshoot-server \
  snapper btrfs-progs wireguard-tools nmap tcpdump bind-utils
```

Package	Role
`qemu-kvm`, `libvirt`, `virt-install`	Hypervisor, VM management, command-line creation
`edk2-ovmf`, `swtpm`	UEFI firmware and emulated TPM for the VMs that need them
`cockpit-*`	Web console: VMs, containers, storage, SELinux
`podman`, `buildah`, `skopeo`	Daemonless containers, image building and copying
`policycoreutils-python-utils`, `setroubleshoot-server`	`semanage` for SELinux contexts, `sealert` to read denials
`snapper`, `btrfs-progs`	System snapshots and subvolume management
`wireguard-tools`, `nmap`, `tcpdump`, `bind-utils`	Network tests and troubleshooting

libvirt services. Fedora 44 splits libvirt into modular daemons, started on demand by systemd sockets. I enable each socket, then add my account to the `libvirt` and `kvm` groups so I can administer without being root for every command:

```
for d in virtqemud virtnetworkd virtstoraged virtinterfaced virtnodedevd; do
  sudo systemctl enable --now ${d}.socket
done
sudo systemctl enable --now virtlogd.socket cockpit.socket firewalld
sudo usermod -aG libvirt,kvm "$USER"
```

Dedicated subvolumes. VM disks and container layers each have their own BTRFS subvolume, `/vm` and `/var/lib/containers`. This keeps them out of the system snapshots and lets me give them their own options. The most important one is the NOCOW attribute (`chattr +C`). A qcow2 file is rewritten constantly; on a copy-on-write file system it fragments and performance collapses. The attribute is not retroactive: it must be set on the empty directory, before the first image is created.

```
sudo btrfs subvolume create /vm
sudo btrfs subvolume create /var/lib/containers
sudo chattr +C /vm /var/lib/containers
lsattr -d /vm /var/lib/containers        # must show the C attribute
```

Both subvolumes are mounted from `/etc/fstab`, with the UUID of the root file system:

```
UUID=<UUID> /vm btrfs subvol=vm,nodatacow,noatime 0 0
UUID=<UUID> /var/lib/containers btrfs subvol=var/lib/containers,nodatacow,noatime 0 0
sudo systemctl daemon-reload && sudo mount -a
findmnt -t btrfs
```

SELinux, never disabled. This is the step that catches people out most: without it, no VM starts, and libvirt's error message does not mention SELinux. The images must carry the `virt_image_t` context. I declare the rule permanently, then apply it. The directory can only be traversed by its owner and the authorized services (`chmod 711`):

```
sudo mkdir -p /vm/images /vm/iso
sudo semanage fcontext -a -t virt_image_t '/vm/images(/.*)?'
sudo restorecon -Rv /vm/images
```

```
sudo chmod 711 /vm/images
ls -dZ /vm/images          # expected: system_u:object_r:virt_image_t:s0
```

The rule declared with `semanage` survives a full relabel of the system; a plain `chcon` would have been lost at the next `restorecon`.

The storage pool. A libvirt pool named `tenet` points to `/vm/images`. I tested it end to end with a throwaway image, which must inherit both the SELinux context and the NOCOW attribute:

```
sudo virsh pool-define-as tenet dir --target /vm/images
sudo virsh pool-build tenet && sudo virsh pool-start tenet && sudo virsh pool-autostart tenet
sudo qemu-img create -f qcow2 /vm/images/test.qcow2 1G
ls -Z /vm/images/test.qcow2 && lsattr /vm/images/test.qcow2
sudo rm /vm/images/test.qcow2
```

The two networks. The libvirt `default` network (NAT, `192.168.122.0/24`, switch `virbr0`) is the WAN: the host acts as its router and translates addresses to the Internet. A second network, `tenet`, is an isolated bridge (`br-tenet`) with no routing to the outside: it carries the LAN `10.10.10.0/24`, and its only way out is the firewall. I check both with `sudo virsh net-list --all`, which must show them active and set to start automatically.

Cockpit. Fedora's web console replaces `virt-manager`. From a single interface it creates VMs, opens their consoles, manages snapshots, containers and storage, and shows SELinux denials in plain language, with a suggested fix. It has one trap: when creating a VM, it offers `/var/lib/libvirt/images` by default. The `tenet` pool must be chosen explicitly, otherwise the disk loses both the SELinux context and the NOCOW attribute. After every creation I therefore check `ls -Z /vm/images` and `lsattr /vm/images/*.qcow2`.

Snapper. The host takes its own restore points. I configured Snapper on the root, with bounded retention and its timers, then took the baseline point of the foundation:

```
sudo snapper -c root create-config /
sudo snapper -c root set-config NUMBER_LIMIT=10 NUMBER_LIMIT_IMPORTANT=5
sudo systemctl enable --now snapper-timeline.timer snapper-cleanup.timer
sudo snapper -c root create -d "POST-SOCLE-FEDORA-TENET-STABLE"
```

The `/vm` and `/var/lib/containers` subvolumes are not included in the root snapshots: rolling the system back never rolls back the VM disks, which have their own snapshots.

Acceptance check for the host.

Check	Command	Expected
SELinux	`getenforce`	`Enforcing`
Subvolumes	`findmnt -t btrfs` ; `lsattr -d /vm`	mounted; `C` attribute
Image context	`ls -dZ /vm/images`	`virt_image_t`
Pool	`sudo virsh pool-info tenet`	`running`, autostart
Networks	`sudo virsh net-list --all`	`default` and `tenet` active
Containers	`podman info --format '{{.Host.Security.Rootless}}'`	`true`
SELinux denials	`sudo ausearch -m AVC -ts today`	none
Services	`systemctl --failed`	no failed unit

What to understand. KVM turns the Linux kernel into a hypervisor: each VM is a QEMU process that emulates its hardware, and the processor instructions run directly thanks to the virtualization extensions. libvirt drives the whole and provides the virtual networks. A NAT network gives the VMs a way out to the Internet behind the host's address, without making them reachable from outside. An isolated network has no way out at all: this is why the firewall must be the only machine connected to both. Finally, SELinux labels every QEMU process and every disk: a process can only open the files that carry its label.

◆ Step 2 · The pfSense firewall

The VM. I created it from Cockpit, in the `tenet` pool, with two virtio network cards: the first on the `default` network (WAN), the second on `tenet` (LAN). The Netgate installer installs pfSense CE. The VM was first created under the name `tenet-pfsense`. I renamed it `pfsense-fw` to keep the lab's naming convention:

```
sudo virsh shutdown tenet-pfsense
sudo virsh domrename tenet-pfsense pfsense-fw
sudo virsh start pfsense-fw
```

Interfaces. From the console (menu 1, then 2): `vtnet0` becomes the WAN, on DHCP from the libvirt NAT (it gets `192.168.122.95`); `vtnet1` becomes the LAN, at `10.10.10.254/24`. I then check the way out to the Internet from the pfSense shell (menu 8):

```
ping -c3 1.1.1.1
host cloudflare.com
```

Once the installation is confirmed, I eject the media, so that a reboot never starts the installer again:

```
sudo virsh domblklist pfsense-fw                  # find the CD drive
sudo virsh change-media pfsense-fw sda --eject --config
```

The setup wizard. In the web interface (*System → Setup Wizard*), the firewall gets its name, `fw01`, and its DNS domain, `infrasec.lab`, kept separate from the Active Directory forest `infrasec.local` so that the two are never confused. The administration password is typed interactively and written nowhere in the report.

Filtering. The principle is deny by default:

Setting	Path	Value
WAN rules	*Firewall → Rules → WAN*	None: all inbound traffic is denied
LAN rules	*Firewall → Rules → LAN*	Explicit outbound: DNS, updates, log and metric forwarding
Log of denied traffic	*Status → System Logs → Firewall*	Checked during every test

Segment services. pfSense runs the segment's DNS resolver (*Services → DNS Resolver*, Unbound). Once the directory is in service, the `infrasec.local` zone is held by the domain controller, and pfSense forwards it (security policy, article 6.5). It also runs the NTP service (*Services → NTP*): it is the segment's time reference, which the domain controller syncs with.

Backing up its configuration. The pfSense XML export (*Diagnostics → Backup & Restore*) is encrypted with a passphrase and stored offline. It never goes into the report: it contains the hash of the administration password and the TLS key of the web interface. This recovery was tested on October 11 (PV-04, Annex O): after a test change, the full configuration was restored from the export in less than five minutes, with the service verified end to end.

Acceptance check. From the LAN, the Internet answers and names resolve. From the WAN, the administration interface cannot be reached. The CD drive is empty.

A gap found later. The October 4 audit showed that the administration interface still answered over HTTP on port 80, in addition to HTTPS (finding F-02). The fix is scheduled: force HTTPS and restrict the management source (Annex F).

What to understand. pfSense is a stateful firewall: when an outbound connection is allowed, the replies that belong to it are accepted automatically. So it is enough to allow specific outbound traffic and deny everything inbound. By default, the Unbound resolver works in recursive mode: it queries the root DNS servers itself, without depending on a provider. Giving the firewall a DNS domain separate from the forest prevents a firewall host name from being confused with a directory record.

◆ Step 3 · The domain controller

The VM. Windows Server 2025 runs with a virtio disk and network card, the fastest options under KVM. Windows cannot see a virtio disk without a driver: when choosing the installation disk, I load the `viostor` driver from the `virtio-win` ISO, mounted as a second drive. I open the Cockpit console before the first boot, so as not to miss the boot-from-CD prompt.

Network and name. In an elevated PowerShell, a fixed address, DNS pointing to itself (the future DNS server of the domain), then the name `DC01`:

```
New-NetIPAddress -InterfaceAlias "Ethernet" -IPAddress 10.10.10.10 `
  -PrefixLength 24 -DefaultGateway 10.10.10.254
Set-DnsClientServerAddress -InterfaceAlias "Ethernet" -ServerAddresses 127.0.0.1
Rename-Computer -NewName "DC01" -Restart
```

Promotion. I install the AD DS role, then create the `infrasec.local` forest with integrated DNS. The restore mode (DSRM) password is typed interactively: it goes through neither a file nor the history.

```
Install-WindowsFeature AD-Domain-Services -IncludeManagementTools
$dsrm = Read-Host -AsSecureString "DSRM password"
Install-ADDSForest -DomainName "infrasec.local" -DomainNetbiosName "INFRASEC" `
  -InstallDns -SafeModeAdministratorPassword $dsrm -Force
```

The server restarts as a domain controller: it holds the forest, the domain, the global catalog and the directory-integrated DNS zone. I check all of it with four commands, which I run again after every change:

```
Get-ADDomain | Select-Object Forest,DNSRoot,DomainMode
Get-ADForest  | Select-Object ForestMode,GlobalCatalogs
nltest /dsgetdc:infrasec.local
Resolve-DnsName infrasec.local
```

Command	What it proves
`Get-ADDomain`	The domain exists, with its DNS root and functional level
`Get-ADForest`	The forest is in place and the controller is a global catalog
`nltest /dsgetdc`	A client finds a domain controller through DNS
`Resolve-DnsName`	The `infrasec.local` zone answers

Time. Kerberos refuses any authentication beyond a 5-minute skew. The domain controller is the time reference of the domain; it syncs itself with pfSense. I had not set this up at first, and it made the TrueNAS join fail (INC-02, step 4): the controller's time zone was wrong.

Accounts. A service account is dedicated to joining TrueNAS to the domain. A group carries access to the file share: rights follow groups, never individuals. Passwords are typed interactively. Since INC-02, accounts used across several platforms only use characters that sit in the same place on French and US keyboards (security policy, article 5.4.3).

A lab trick. The Cockpit noVNC console does not allow pasting text into the VM. To avoid retyping a script, I serve it from another node through a temporary HTTP server and run it on the controller. This is for the lab only: in production, one goes through an administrative share or a deployment tool.

Agents. The Wazuh agent installs from an MSI. I use an installation that waits for the installer to finish, so that the service is only started once the installation is complete:

```
Start-Process msiexec.exe -Wait -ArgumentList '/i','C:\path\wazuh-agent.msi', `
  'WAZUH_MANAGER=10.10.10.40','WAZUH_AGENT_NAME=Win-Server-DC','/qn'
Start-Service WazuhSvc
Get-Service WazuhSvc
```

The windows_exporter metrics exporter (port 9182) took more work. Version 0.31.8 removed two collectors that my plan asked for (`cs` and `logon`): the service stopped as soon as it started, with no message (INC-03). Running it in the foreground gave the error `unknown collector cs` , then `unknown collector logon` . I wrote a script that tests the set of collectors, removes the ones the service rejects, then reconfigures the service. The final set includes `ad` and `dns` , specific to the domain controller role:

```
msiexec /i windows_exporter.msi `
  ENABLED_COLLECTORS="cpu,logical_disk,net,os,service,system,memory,process,tcp,ad,dns" `
  /qn
Get-Service windows_exporter
Invoke-WebRequest http://localhost:9182/metrics -UseBasicParsing |
  Select-Object -Expand Content | Select-String windows_
```

A rule specific to the domain controller. It is never stopped with `virsh destroy` : a hard power-off can corrupt the Active Directory database. Always `virsh shutdown` , and a cold snapshot before any risky operation.

What to understand. An Active Directory forest contains one or more domains; each domain controller holds a copy of the database. The global catalog makes it possible to find an object anywhere in the forest. Clients do not find the controller by its name: they query DNS for service (SRV) records, such as `_ldap._tcp.dc._msdcs.infrasec.local` . This is what `nltest /dsgetdc` checks, and it is why every server in the domain must use the controller's DNS. Kerberos authenticates with time-stamped tickets: beyond a 5-minute skew, a ticket is treated as a replay and refused. Finally, DSRM mode starts the controller outside the directory to repair or restore it: its password is a critical secret.

◆ Step 4 · TrueNAS storage

The VM. Three virtio disks: a 16 GB system disk and two 40 GB data disks for the ZFS mirror. The system disk stays separate from the data, so that TrueNAS can be reinstalled without touching the pool.

```
sudo virt-install --name truenas \
  --disk path=/vm/images/truenas-os.qcow2,size=16,format=qcow2,bus=virtio \
  --disk path=/vm/images/truenas-d1.qcow2,size=40,format=qcow2,bus=virtio \
  --disk path=/vm/images/truenas-d2.qcow2,size=40,format=qcow2,bus=virtio \
```

```
  --cdrom /vm/iso/<truenas-scale>.iso --network network=tenet,model=virtio \
  --graphics vnc --noautoconsole
```

First incident: the installer does not start (INC-01). The VM stayed stuck on the UEFI firmware (OVMF) menu, "Please select boot device". The firmware did not pick the CD drive despite the boot order, and the Cockpit web console did not pass the Enter key through. Sending the key from the host (`virsh send-key`) failed too, because the VM had stopped in the meantime. I switched the VM to BIOS firmware (SeaBIOS): in its XML definition, I removed the `<firmware>` block, the `<loader>` and `<nvram>` elements and the `firmware='efi'` attribute of the `<os>` section, then redefined the VM:

```
sudo virsh dumpxml truenas > truenas.xml     # UEFI elements removed
sudo virsh define truenas.xml
sudo virsh start truenas
```

SeaBIOS booted straight from the CD, and the TrueNAS SCALE 25.10.7 installer started. Since then, I choose BIOS for VMs whose installation goes through the web console.

Installation and network. TrueNAS installs on the 16 GB disk. From its console, I give it a fixed address `10.10.10.20/24` , the gateway `.254` and the domain controller as DNS, `10.10.10.10` : Kerberos needs the domain's DNS to find its service records.

The pool. In the web interface (*Storage → Create Pool*), the `tank` pool is a ZFS mirror on the two data disks. A mirror survives the loss of a disk. ZFS computes a checksum for every block: it detects silent errors and repairs them from the other copy of the mirror, provided a regular *scrub* runs.

Joining the domain. In *Credentials → Directory Services*, I enter the domain `INFRASEC.LOCAL` , the dedicated service account and its password, typed interactively. This is where the second incident happened.

Second incident: the join is refused (INC-02). The first attempt was refused: "Time offset from the domain controller exceeds the maximum permitted value". I compared the clocks from the host with `virsh domtime` . TrueNAS was on the correct UTC time; the domain controller was more than 5 minutes off, because of a wrong time zone. After fixing the time zone and syncing the controller to pfSense over NTP, a second error appeared: "The bind password is not correct". The join account's password had been typed on two different keyboard layouts (QWERTY and AZERTY), which produced two different strings. I reset the password with neutral characters, and the join succeeded. The TrueNAS Active Directory service went to HEALTHY: realm `INFRASEC.LOCAL` , machine account keytab created, account cache enabled.

The share. The `tank/partage` dataset carries the SMB share `partage` (*Shares → Windows (SMB) Shares*). Access is controlled by NFSv4 ACLs, set in the dataset's permission editor and granted to the Active Directory group created for it.

Data protection. In *Data Protection*:

Task	Setting
Periodic snapshots of `tank/partage`	Every hour, kept two weeks, named `auto-%Y-%m-%d_%H-%M` (visible in Windows Previous Versions)
Replication	To `tank/partage_backup` , with `zfs send` and `zfs recv`
Scrub of the `tank` pool	Scheduled, to verify every checksum

Acceptance check. From the TrueNAS shell (*System Settings → Shell*), the join is proven through Kerberos, not only through access to the share:

```
wbinfo -t              # trust relationship with the domain: OK
net ads testjoin       # join is valid
zpool status tank      # mirror ONLINE, 0 errors
```

The restore was then proven by report PV-01 (Annex G): three files deleted, then restored in less than one second, with matching SHA-256 hashes.

What to understand. With two data disks, a mirror is the only redundant layout: every block is written to both disks. ZFS always writes changed data to a new location (copy on write). A snapshot is therefore instantaneous: it freezes the list of blocks at a given moment and only takes space for the blocks changed afterwards. It is read-only, which protects it from deletion or from encryption by ransomware on a client. NFSv4 ACLs are finer than POSIX permissions (inheritance, separate read, write and delete rights) and map to Windows ACLs, which makes them a natural fit for an SMB share. Joining the domain creates a machine account in the directory and a *keytab*, the key file that lets TrueNAS authenticate with Kerberos.

◆ Step 5 · The container node

```
            fedora
```

The VM. Fedora 44 Server, at the fixed address `10.10.10.30/24`, gateway `.254`, DNS `.10`. It is administered through Cockpit (port 9090) and SSH. It also serves as the audit workstation: the Parrot VM planned for the audit never booted, and the October 4 audit was run from this node.

An unprivileged account for containers. Containers run under the `ais` account, without root rights. *Rootless* Podman relies on UID and GID ranges delegated to this account (`/etc/subuid`, `/etc/subgid`): root inside a container maps to an unprivileged user on the host. systemd *lingering* lets the account's services run without an open session:

```
sudo loginctl enable-linger ais
grep ais /etc/subuid /etc/subgid
mkdir -p ~/.config/containers/systemd
```

Services described by Quadlets. Each container is described by a `.container` file in `~/.config/containers/systemd/`. systemd generates a user unit from it: automatic start, restart on failure, logs in `journalctl`. These files are the reference: image, published port, volumes, arguments. node_exporter shows a special case. It must read the host's file system, but `/proc` and `/sys` cannot be relabeled for SELinux with the `:Z` option. So it shares the host's network and mounts the root read-only:

```
[Unit]
Description=Prometheus node-exporter (rootless)
[Container]
```

```
Image=quay.io/prometheus/node-exporter:latest
Network=host
Volume=/:/host:ro,rslave
Exec=--path.rootfs=/host --collector.systemd
[Install]
WantedBy=default.target
systemctl --user daemon-reload
systemctl --user start node-exporter
systemctl --user status node-exporter
podman top node-exporter huser # the real UID on the host: not root
```

The monitoring stack. Prometheus and Grafana run on the same model. The plan put Prometheus on its usual port, 9090, but Cockpit already uses it on this node: I published it on 9091. Grafana listens on 3000. Zabbix, added during the evolution, polls pfSense over SNMP. Configuring the monitoring itself belongs to skill CP7 and is described in section 6.1.

The local firewall. firewalld only opens the ports that are needed. When a port is no longer used, I close it: the node_exporter port (9100) was removed, since Prometheus queries it locally (finding F-05):

```
sudo firewall-cmd --permanent --remove-port=9100/tcp
sudo firewall-cmd --reload && sudo firewall-cmd --list-all
```

Acceptance check. `systemctl --user status` active for each service, `podman ps` shows the containers, `podman top … huser` shows a non-root UID, and the metrics answer (`curl -s localhost:9100/metrics | head`). The hardening of this node is described with skill CP3.

What to understand. A *rootless* container relies on *user namespaces*: UID 0 inside the container maps, on the host, to a UID taken from the `ais` account's subordinate range, with no rights at all. If an attacker broke out of the container, they would land on an unprivileged account, not on root. For the same reason, a *rootless* container cannot listen on a port below 1024 by default. Quadlets replace a composition tool: systemd itself starts, watches and restarts the containers, like any other service. The `:Z` option on a volume asks Podman to give it a private SELinux label, readable by that container only.

◆ Step 6 · The Wazuh SIEM

The VM. Ubuntu Server 26.04 LTS. I chose this distribution because it is in the Wazuh 4.14 support matrix and is maintained until 2031: a supportability criterion, the same one used in the requirements. Fixed address `10.10.10.40/24` , gateway `.254` .

Installation. The official assistant installs the manager, the indexer and the dashboard in one go, in a pinned version:

```
curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh
sudo bash ./wazuh-install.sh -a
sudo systemctl status wazuh-manager wazuh-indexer wazuh-dashboard
```

Component	Role
Manager	Receives agent events, applies detection rules, raises alerts
Indexer	Stores and indexes events and alerts
Dashboard	Web interface: alerts, SCA compliance, file integrity, search

The assistant generates an administration password and stores it in an archive. I write it in no deliverable; rotating it with the official tool (`wazuh-passwords-tool.sh`) is still to be done.

Agents. Two agents send their events: the domain controller and the `fedora` node. They connect to the manager on ports 1514 and 1515, with authentication handled by the manager. The SCA module checks their configuration against CIS benchmarks, and file integrity monitoring (FIM) watches sensitive files. The firewall, TrueNAS and the hypervisor are not connected yet: this is a known limit.

Acceptance check. The dashboard answers at `https://10.10.10.40` , the three services are active and both agents show as connected.

What to understand. An agent first enrolls with the manager on port 1515, which gives it its key; it then sends its events, encrypted, on port 1514. Centralizing logs has a direct security benefit: an attacker who takes over a server can no longer erase the traces already sent to the SIEM. The SCA module checks the configuration (does it match the benchmark?), while FIM watches for changes (has this file been modified?). The two complement each other.

◆ Step 7 · Checking and freezing the foundation

After each machine. Three checks on the host, always the same:

```
sudo virsh list --all
sudo ls -lZ /vm/images/      # svirt_image_t (VM running) or virt_image_t (stopped)
free -h
```

If a VM refuses to start, I look at SELinux first (`sudo ausearch -m AVC -ts recent` , or Cockpit's SELinux page, which explains it in plain language).

Build summary.

Machine	Acceptance check	Proof
Host	SELinux *enforcing*, NOCOW subvolumes, `virt_image_t` context, active pool, *rootless* Podman	Snapper point `POST-SOCLE-FEDORA-TENET-STABLE`
`pfsense-fw`	Internet from the LAN, administration interface unreachable from the WAN	pfSense shell, firewall log
`Win-Server-DC`	`infrasec.local` forest, global catalog, DNS	`Get-ADDomain` , `nltest` , `Resolve-DnsName`
`truenas`	Kerberos join, healthy mirrored pool	`wbinfo -t` , `net ads testjoin` , `zpool status`
`fedora`	*Rootless* services active, non-root UID	`systemctl --user status` , `podman top`
`wazuh-siem`	Dashboard, services and agents active	`systemctl status` , dashboard

The freeze. On October 11, before the oral exam, I froze the whole lab. A loop shuts the five VMs down cleanly and takes their freeze snapshots (`gel-20261011`), then a Snapper point is taken on the host (Annex F):

```
for v in pfsense-fw Win-Server-DC truenas fedora wazuh-siem; do sudo virsh shutdown
"$v"; done
sleep 45
for v in pfsense-fw Win-Server-DC truenas fedora wazuh-siem; do
  sudo virsh snapshot-create-as "$v" gel-20261011 "Frozen state for the oral exam"
done
sudo snapper -c root create -d "POST-FREEZE-STABLE"
```

What changed compared with the plan. The build plan was a guide, not a fixed text. Here are the differences, and why:

Planned	Done	Reason
TrueNAS with UEFI firmware	BIOS (SeaBIOS)	INC-01: installer stuck in the web console
Prometheus on port 9090	Port 9091	Cockpit already uses 9090 on the node

Planned	Done	Reason
windows_exporter with the `cs` and `logon` collectors	Corrected set, without those two	INC-03: collectors removed in 0.31.8
Grafana dashboard 14694	Dashboard 23942	14694 depends on the removed metrics (INC-03)
Parrot audit VM	Audit run from the `fedora` node	Prebuilt image would not boot

Machine sheets

Each sheet gathers what an operator needs to know about a machine: its role, what it exposes, how to administer it, how it is monitored and backed up, and what is still to be fixed. The exposed ports are those found by the October 4 audit (Annex B).

TeneT host.

Item	Content
Role	Hypervisor, router of the WAN `192.168.122.0/24`
System	Fedora 44, KVM/QEMU, libvirt, Cockpit, firewalld, SELinux *enforcing*, LUKS-encrypted disk
Exposure on the segment	Administration address `10.10.10.2`, all ports filtered
Administration	Cockpit, local terminal
Recovery	Snapper points `POST-…-STABLE`
To fix	F-01: the address on the segment bypasses the firewall; target: dedicated administration network (M-01)

`pfsense-fw` (`fw01.infrasec.lab`).

Item	Content
Role	Single point of passage, router, DNS (Unbound), NTP
Exposed ports	53 (DNS), 80 (HTTP), 443 (HTTPS)
Administration	Web interface, Cockpit console (menu 8 for the shell)
Monitoring	SNMP to the Zabbix collector, added during the evolution
Recovery	Encrypted XML export kept offline, restore tested in under five minutes (PV-04); VM snapshot
To fix	F-02: interface still on HTTP port 80

`Win-Server-DC` (`DC01`).

Item	Content
Role	`infrasec.local` forest, DNS, time reference of the domain
Exposed ports	53, 88, 135, 139, 389, 445, 464, 593, 636, 3268, 3269 (AD services), 3389 (RDP)
Administration	Console, PowerShell
Monitoring	Wazuh agent, windows_exporter (port 9182)

Item	Content
Recovery	Cold VM snapshot, never `virsh destroy`
To fix	F-03: RDP open to the whole segment, although it is not used

`truenas`.

Item	Content
Role	Mirrored ZFS pool `tank`, SMB share `partage` joined to the domain
Exposed ports	80, 443 (interface), 139, 445 (SMB), 5357 (WS-Discovery)
Administration	Web interface, shell
Monitoring	Not connected to the SIEM (known limit)
Recovery	Hourly snapshots, replication to `tank/partage_backup`, restore proven (PV-01)
To fix	F-04: WS-Discovery exposed

`fedora`.

Item	Content
Role	*Rootless* containers: Prometheus, Grafana, node_exporter, Zabbix; audit workstation
Exposed ports	22 (SSH), 3000 (Grafana), 9090 (Cockpit), 9091 (Prometheus); 9100 closed since F-05
Administration	Cockpit, SSH
Monitoring	Wazuh agent, node_exporter
Recovery	VM snapshot; the Quadlets describe every service
To fix	F-06: administration plane (SSH, Cockpit) reachable from the whole segment

`wazuh-siem`.

Item	Content
Role	SIEM: manager, indexer, dashboard
Exposed ports	22 (SSH), 443 (dashboard), 9090 (Cockpit)
Administration	Dashboard, SSH
Recovery	VM snapshot
To fix	Rotate the administration password generated at installation

◆ Health checks, machine by machine

After any change or restart, a green light is not enough for me: I rerun the checks from the command booklet, machine by machine. Each one has a precise expected result. If a result differs, I stop and troubleshoot before going further, as during the build.

Machine	Command	Expected result
Host	`sudo virsh list --all`	All five VMs in the `running` state

Machine	Command	Expected result
Host	`sudo ls -lZ /vm/images/`	`svirt_image_t` for a running VM, `virt_image_t` for a stopped one
Host	`free -h`	Memory left for the host
Host	`sudo ausearch -m AVC -ts recent`	No recent SELinux denial
pfSense, shell (menu 8)	`ping -c3 1.1.1.1`, then `host cloudflare.com`	A reply, then the name resolved
pfSense, web interface	*Status → System Logs → Firewall*	The filtering log, up to date
Domain controller	`Get-ADDomain` and `Get-ADForest`	The `infrasec.local` forest and domain, the global catalog
Domain controller	`nltest /dsgetdc:infrasec.local`	A controller found through DNS
Domain controller	`Resolve-DnsName infrasec.local`	The zone answers
Domain controller	`Get-Service WazuhSvc` and `Get-Service windows_exporter`	`Running`
TrueNAS, shell	`zpool status tank`	Mirror `ONLINE`, 0 errors
TrueNAS, shell	`wbinfo -t` and `net ads testjoin`	Valid trust and valid join
fedora	`systemctl --user status <unit>`	`active (running)` for each service
fedora	`podman top <container> huser`	A mapped, non-root UID
fedora	`curl -s localhost:9100/metrics`	`node_` metrics
wazuh-siem	`sudo systemctl status wazuh-manager wazuh-indexer wazuh-dashboard`	All three services `active (running)`
Prometheus	`http://10.10.10.30:9091`, *Status → Targets*	Every target `UP`
Grafana	`http://10.10.10.30:3000`	The dashboards show data

The last check has a trap, learned with INC-03: a “No data” dashboard does not mean that collection is down. If the target is `UP` in Prometheus, I first check that the data source was linked at import time, then that the dashboard matches the exporter version. The job name matters too: the domain controller’s job is called `windows`, the convention that community dashboards expect.

◆ The addressing plan and the flows of the foundation

The segment is flat: a single range, `10.10.10.0/24`, with fixed addresses for every server. The security policy gives each asset a classification and a criticality, which set its backup and recovery objectives and its rank at restart (supplement E.1):

Host	Address	Role	Classification	Criticality
`pfSense`	`10.10.10.254`	Point of passage: firewall, DNS, gateway	C2	Vital
`Win-Server-DC`	`10.10.10.10`	AD DS, DNS, roles and access	C3	Vital
`TrueNAS`	`10.10.10.20`	ZFS storage, SMB (NFSv4 ACLs)	C3/C2	High



Host	Address	Role	Classification	Criticality
`fedora`	`10.10.10.30`	*Rootless* containers, Prometheus, Grafana, Zabbix	C1	Medium
`wazuh-siem`	`10.10.10.40`	Wazuh 4.14 SIEM (SCA, FIM)	C2	High
`TeneT`	physical host	Fedora 44 hypervisor, Cockpit, KVM/libvirt	C2	Vital

C3 means critical information (secrets, directory database), C2 confidential information (configurations, security logs), C1 internal information (dashboards, metrics). Vital machines restart first.

The allowed flows of the foundation are few, and each one has a reason (the reference diagram and the full matrix, with the remote access flows, are in Annex N):

Source	Destination	Protocol and port	Use
Servers of the segment	DC `10.10.10.10`	DNS 53, Kerberos 88, LDAP 389 and 636, SMB 445	Directory services
Internal segment	pfSense `10.10.10.254`	DNS 53, HTTPS 443	Resolution, administration
fedora (Prometheus)	DC `10.10.10.10`	TCP 9182	windows_exporter metrics
fedora (Prometheus)	fedora, locally	TCP 9100	node_exporter metrics
fedora (Zabbix)	pfSense `10.10.10.254`	UDP 161	SNMP, added during the evolution
DC and fedora (agents)	wazuh-siem `10.10.10.40`	TCP 1514 and 1515	Events, agent enrollment

◆ Recovery objectives of the foundation

The security policy sets, for each type of asset, the acceptable data loss (RPO) and the recovery time (RTO). The table below lists them, with what was actually tested:

Asset	RPO	RTO	Mechanism	Tested
Share data (ZFS)	1 hour at most (hourly snapshots)	Under one second at file level	ZFS snapshots and replication	Yes, on October 4 (PV-01)
pfSense configuration	Last export	Under five minutes	Encrypted export, import	Yes, on October 11 (PV-04)
State of a VM after a major operation	None: snapshot taken before	Immediate: back to the snapshot	libvirt snapshots, Snapper	Mechanism in place; no timed test
Active Directory	Low	According to the restore procedure	System state backup, cold VM snapshot	No: no directory restore has been tested yet

The backup follows the 3-2-1-0 model:

Figure	Requirement	In the lab
3	Three copies of the data	Data, ZFS snapshots, replication
2	Two different media	Not met: the replication is on the same pool; second medium in production

Figure	Requirement	In the lab
1	One off-site copy	Not met: replication to a remote site in production
0	Zero verified errors	SHA-256 hashes after the restore and on the replica

The recovery order follows criticality: firewall, directory, then the services that depend on them. It is the restart order of the operations manual, and it is the core of the recovery plan for the foundation. The weakest point is the directory: no restore of it has been tested yet, and going back to the VM snapshot would take the whole controller back to an earlier state. Testing a system state restore, object by object, is the next step.

◆ CP1 · Operating with good practice

Rules set before acting. At the top of the command booklet, I wrote the rules I do not break. A snapshot before any destructive operation: `virsh snapshot-create-as` for a VM, `snapper` for the host. Never a `virsh destroy` on the domain controller. Never `chmod 777` : permissions are set through ownership (`chown`), groups and, for containers, *user namespaces*. *Rootless* containers by default. No plaintext secret in a file or a command. And never `/var/run/docker.sock` mounted into a container without warning about the risk, since it amounts to giving root access to the host.

Handling incidents with a method. Every difficulty goes into the incident log (Annex J) with the same structure: symptom, diagnosis, root cause, fix, proof, lesson. The three build incidents (INC-01 to INC-03) are described in the steps above. I handled them the way level 2 or 3 support does: no workaround, a root cause found, and a rule kept for the future.

Each incident left a rule, written where the operator will find it:

Incident	Rule kept	Where it is written
INC-01, installer stuck	BIOS for installations that go through the web console	Log (Annex J), build plan
INC-02, join refused	Time synchronized before any Kerberos join; neutral characters for accounts used on several platforms	Security policy (articles 5.4.3 and 9.1.3), log
INC-03, exporter stopped	Read the release notes before deploying; a self-correcting deployment script; a dashboard matching the version	Threat watch (Annex K), command booklet
INC-05, skewed test	Test from a machine that is really outside the protected network	Log; measure M-01

Routine maintenance tasks. The operations manual sets their frequency:

Frequency	Task
Daily	Wazuh dashboard: alerts of level 10 and above, disconnected agents; CERT-FR advisories
Weekly	SCA compliance score; status of ZFS snapshots and replication
Monthly	Access review, patches, threat-watch summary
After any incident	Log entry; lessons-learned review for a P1 or P2 incident

The rest is automated: hourly ZFS snapshots, a pool *scrub*, and automatic updates on the `fedora` node (`dnf5-automatic.timer`).

Routine procedures. These are the ones I apply, written so that another operator can replay them.

Shutting down and restarting the infrastructure. Shutdown starts with the services that depend on the others and ends with the firewall; restart follows the reverse order. The VMs also start automatically with the host (`virsh autostart`).

```
for vm in wazuh-siem fedora truenas Win-Server-DC pfsense-fw; do sudo virsh shutdown
"$vm"; done
sudo virsh list --all          # wait until every VM is "shut off"
for vm in pfsense-fw Win-Server-DC truenas fedora wazuh-siem; do sudo virsh start
"$vm"; sleep 30; done
```

Updating a server. Every update is preceded by a snapshot and followed by a check of the service (security policy, article 7). On the `fedora` node, automatic updates go through `dnf5-automatic` . For a manual update:

```
sudo virsh shutdown fedora; sleep 25
sudo virsh snapshot-create-as fedora pre-update "Before update"
sudo virsh start fedora
# on the node: update, then check the services
sudo dnf upgrade --refresh -y
systemctl --user status prometheus grafana node-exporter
```

Restoring a file from the share. ZFS snapshots can be read in the dataset's hidden `.zfs` directory. The restore takes a few seconds, and the SHA-256 hash proves that it is exact:

```
ls /mnt/tank/partage/.zfs/snapshot/
rsync -aA /mnt/tank/partage/.zfs/snapshot/<snapshot>/<file> /mnt/tank/partage/
sha256sum -c <register>.sha256          # must print "OK"
```

I use `rsync -A` , not `cp` , to keep the ACLs: during the October 4 test, `cp` restored the content correctly but reported "Operation not permitted" on the permissions (Annex G).

Recovering the firewall configuration. VM snapshot, then *Diagnostics → Backup & Restore → Restore Backup* with the encrypted export. The firewall restarts and reinstalls its packages. I then check the rules, interfaces and services. Time measured on October 11: under five minutes (Annex O). The test change was on the firewall's DNS domain:

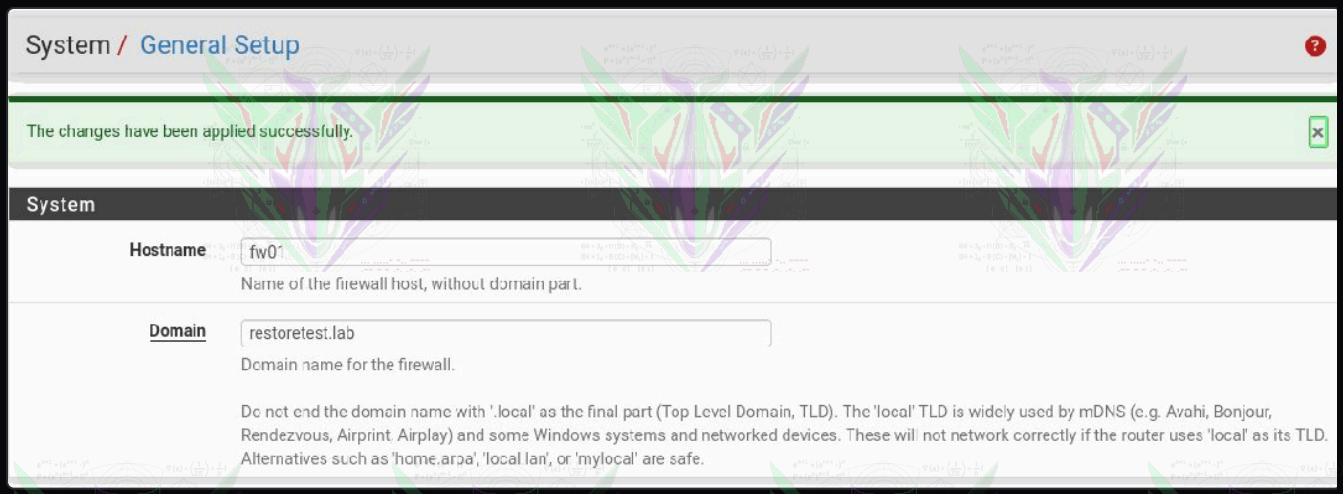


Figure 2 Before the restore: the firewall domain changed for the test

Real screenshot from the lab; addresses are private (RFC 1918).

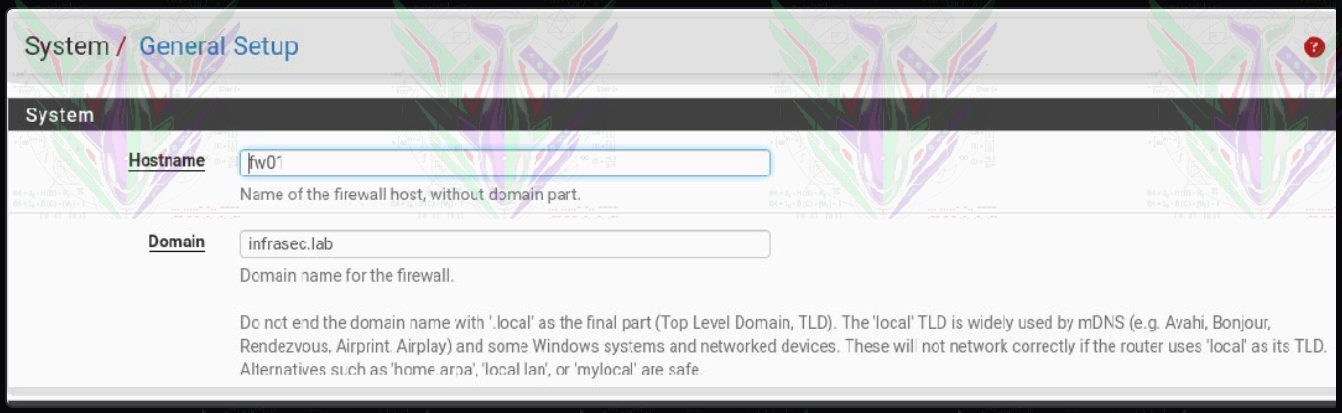


Figure 3 After the restore: the original domain is back with the export

Real screenshot from the lab; addresses are private (RFC 1918).

Checking the storage pool.

```
zpool scrub tank
zpool status tank      # expected: ONLINE, no read, write or checksum errors
```

Troubleshooting a VM that will not start. SELinux first, then the disk contexts, then memory:

```
sudo ausearch -m AVC -ts recent
sudo ls -lZ /vm/images/
free -h
```

Checking the health of the directory. The four commands of step 3 (`Get-ADDomain` , `Get-ADForest` , `nltest` , `Resolve-DnsName`), plus `wbinfo -t` on TrueNAS for the trust relationship.

Managing a containerized service. After any change to a Quadlet file:

```
systemctl --user daemon-reload
systemctl --user restart <service>
systemctl --user status <service>
journalctl --user -u <service> --since "10 min ago"
```

Adding a machine to the foundation. This checklist gathers everything the build taught me:

Step	Check
Create the disk in the `tenet` pool	`ls -Z /vm/images` : `virt_image_t` ; `lsattr` : `C` attribute
Choose the firmware	BIOS if the installation goes through the web console (INC-01)
Virtio disk and network card	`virtio-win` drivers loaded for Windows
Fixed address from the plan, gateway `.254` , DNS `.10`	Domain resolution and a way out to the Internet
Time synchronized with the segment's reference	Skew under 5 minutes before any join
Basic hardening and local firewall	Only the necessary ports are open
Wazuh agent and metrics exporter	Agent connected, Prometheus target up
Inventory, classification and criticality	Security policy, supplement E.1, up to date
Cold snapshot and Snapper point	`POST-<MACHINE>-STABLE`

Documenting for another operator. Three documents follow the foundation: the command booklet, which only contains commands I actually used, with the machine and the terminal to run them in; the bilingual operations manual (Annex M); and the incident log. I have no asset and ticket management tool such as GLPI in the lab. The inventory is kept in the security policy (supplement E.1) and the follow-up in the log. In a company, GLPI would play that role.

Classifying changes. I apply the three ITIL 4 change types to the foundation, as already used for the evolution (section 5.1):

Type	Example on the foundation	Handling
Standard	Enroll or revoke an access, restore a file	Written procedure, authorized in advance
Normal	Add a VM, change a firewall rule, update a major component	Impact analysis, snapshot, approval, then implementation and check
Emergency	Revoke an exposed key (INC-04)	Immediate action, then regularization and lessons learned

◆ CP2 · Securing the network

A single point of passage. pfSense is the only VM connected to both the WAN and the LAN. On the WAN side, no inbound connection is accepted by default; the one exception, the WireGuard tunnel port, belongs to the evolution in chapter 5. Denied traffic is logged, which gave me evidence during the tests.

Segment services. pfSense resolves names (Unbound); the `infrasec.local` zone is held by the domain controller and forwarded by pfSense (security policy, article 6.5). It is also the time reference. The servers have fixed addresses, listed in the addressing plan of the security policy (supplement E.1).

Filtering inside the segment. Traffic between two VMs on the same segment does not go through pfSense. I therefore restricted it on each machine: firewalld on the Fedora hosts, Windows Firewall on the domain controller. The October 4 audit confirms it: on every host, almost all the ports tested are filtered, and no legacy or unencrypted service (Telnet, FTP, SMBv1) is exposed (Annex B).

Troubleshooting layer by layer. For network faults, my method is successive captures: WAN, then the rule counters, then LAN (*Diagnostics → Packet Capture*). This is what located the two faults of the remote access in a few minutes (INC-06 and INC-07, Annex J). It also taught me that a network test must start from the right place: a test run from the hypervisor, which has a direct route to the segment, "succeeded" without proving anything (INC-05).

What the audit found, and what I did about it. The foundation is not perfect, and I would rather say so. The host keeps an administration address on the production segment, which bypasses the firewall (F-01). The pfSense interface still answers over HTTP on port 80 (F-02). The administration plane can be reached from the whole segment (F-06). Each finding received a written decision: F-01 is temporarily accepted, with a compensating measure and a target, a dedicated administration network (measure M-01); F-02 and F-06 are scheduled (Annex F).

◆ CP3 · Securing the systems

Hardening a Linux server. On the `fedora` node, I applied the recommendations of the Lynis audit. Each measure sits in its own file, so that it stays readable and reversible:

Measure	File
SSH: no root login, no forwarding, 3 attempts at most, verbose logging, idle sessions closed	`/etc/ssh/sshd_config.d/99-hardening.conf`
Password lifetime, `umask 027`	`/etc/login.defs`

Measure	File
Unneeded network protocols disabled (`dccp`, `sctp`, `rds`, `tipc`)	`/etc/modprobe.d/99-disable-protocols.conf`
USB storage disabled	`/etc/modprobe.d/99-usb-storage.conf`
No *core dumps*	`/etc/security/limits.d/99-coredump.conf`
Automatic updates	`dnf5-automatic.timer`

The SSH file, in full:

```
PermitRootLogin no
AllowTcpForwarding no
X11Forwarding no
MaxAuthTries 3
ClientAliveInterval 300
ClientAliveCountMax 2
LogLevel VERBOSE
```

Before reloading SSH, I always validate the configuration, so as not to lock myself out:

```
sudo sshd -t && sudo systemctl reload sshd
sudo systemctl enable --now dnf5-automatic.timer
sudo lynis audit system
```

The Lynis index went from 69 to 76 out of 100 (253 tests, Annex F). The module-blocking measures only take full effect after a reboot.

Exposed services. RDP is enabled on the domain controller, but I do not use it: I administer through the console. Restricting it is scheduled (finding F-03). WS-Discovery, exposed by TrueNAS, will be disabled (F- 04).

Logs and compliance. The Wazuh agents on the domain controller and on the `fedora` node send their events to the SIEM. The SCA module checks their configuration against CIS benchmarks (Windows Server and Linux). Connecting the firewall, TrueNAS and the hypervisor to the SIEM is still to be done.

Backup, proven by a restore. On October 4, I deleted three test files from the share, then restored them from a ZFS snapshot: recovery time under one second at file level, SHA-256 hashes matching (3 out of 3) on the restored copy and on the replicated copy (Annex G). The replicated copy sits on the same pool: the “2 media” and “1 off-site copy” criteria of the 3-2-1-0 rule will only be met in production.

Secrets. No secret is written in a file or a command: sensitive input is interactive. The administration password generated by the Wazuh installer appears in no deliverable; rotating it is still to be done. The pfSense configuration export is encrypted and kept offline.

Roles and access. The security policy defines eight roles and their rights on each component (article 5.2). I held all of them, one after the other, which is a limit of the lab; the model is still the one a team would apply:

Role	Hypervisor	pfSense	Directory	TrueNAS	Containers	Wazuh
CISO	Read	Read	Read	Read	Read	Read (administration)
Virtualization administrator	Administration	—	—	—	—	Agent

Role	Hypervisor	pfSense	Directory	TrueNAS	Containers	Wazuh
Directory administrator	—	—	Administration	—	—	Agent
Network administrator	—	Administration	—	—	—	Agent
Storage administrator	—	—	Domain join	Administration	—	Agent
Container operator	—	—	—	Read on dedicated datasets	Administration (non-root)	Agent
Security analyst	Logs	Logs	Logs	Logs	Logs	Administration
Auditor	Read	Read	Read	Read	Read	Read

The policy also sets the password requirements (article 5.5): at least 14 characters for users and 20 for privileged and service accounts, complexity, a history of the last 24, lockout after 5 failures in 15 minutes, rotation of privileged accounts at least every 90 days, and a change of every default password at installation. Multi-factor authentication is recommended there for administration, with a documented compensation when a component does not offer it.

What must be logged. The policy lists, for each source, the events to send to the SIEM (article 9.2), with a retention of at least 90 days:

Source	Events	Purpose
Domain controller	Successful and failed logons, account and group changes, privilege escalations	Access traceability, abuse detection
pfSense	Blocked and allowed flows, rule changes, VPN and administration events	Watching the point of passage
TrueNAS	Share access, ACL changes, ZFS errors, snapshots and replication	Data integrity and access
fedora	Container start and stop, use of privileges	Detecting container abuse
Hypervisor	Administration logons, libvirt actions, snapshots	Watching the hypervisor

Today, only the domain controller and the `fedora` node send their events. The three other sources are the main gap between the policy and reality; it is tracked in the policy itself.

The security baseline, measure by measure.

Measure	Status	Where to check it
Host disk encrypted (LUKS)	Applied	Step 1
SELinux *enforcing* on the host, image contexts	Applied	`getenforce`, `ls -dZ /vm/images`
Deny by default on the WAN	Applied	Empty WAN rules
Local filtering on every server	Applied	Audit (Annex B)
SSH, password, module and *core dump* hardening (`fedora`)	Applied	Lynis 69 → 76 (Annex F)
Automatic updates (`fedora`)	Applied	`dnf5-automatic.timer`
Rootless containers	Applied	`podman top … huser`

Measure	Status	Where to check it
Group-based access to the share (NFSv4 ACLs)	Applied	Dataset permissions
Snapshot and replication backup, verified restore	Applied	PV-01 (Annex G)
SIEM agents on the domain controller and `fedora`	Applied	Wazuh dashboard
HTTPS only on the pfSense interface	Scheduled	F-02
RDP restricted or disabled	Scheduled	F-03
WS-Discovery disabled on TrueNAS	Scheduled	F-04
Restricted administration plane, dedicated administration network	Scheduled	F-01, F-06, M-01
Firewall, TrueNAS and hypervisor connected to the SIEM	Scheduled	Security policy, article 9
Rotation of the Wazuh administration password	Scheduled	Freeze report (Annex F)

ANSSI recommendations. The ANSSI IT hygiene guide was my reference for the foundation. Theme by theme, here is where the lab stands:

Theme of the guide	In the lab
Know your information system	Inventory, classification and criticality of assets (security policy, article 4)
Control accounts and rights	Dedicated service accounts, group-based rights, role model; separate named accounts still to be generalized
Authenticate	Written password policy; MFA to come
Secure the servers	Measured hardening on `fedora`, SCA on the domain controller; the rest to extend
Secure the network	A single point of passage, deny by default, local filtering; administration network to create (M-01)
Secure administration	Encrypted access; administration plane still too open (F-02, F-06)
Update	Automatic on `fedora`, manual elsewhere, always after a snapshot
Monitor and log	SIEM in place for two sources, three to connect
Back up and test the restore	Snapshots, replication, timed and verified restore (PV-01)

◆ CP4 · Securing virtualization

Isolation through SELinux. SELinux stays in *enforcing* mode. The disks carry the `virt_image_t` context, which becomes `svirt_image_t` while the VM runs: each VM gets its own categories, which isolates it from the others and from the host. If a VM were compromised, it could not read another VM's disk. If a VM refuses to start, I look for the denial and fix the context: I never disable SELinux.

Virtual networks. The libvirt NAT on the WAN side and the isolated bridge `br-tenet` on the LAN side. The host still has an address on this bridge: this is finding F-01. It even skewed a test (INC-05), which confirms that a separate administration network is a priority.

Containers. They run *rootless*, under an unprivileged account, with *user namespaces*. No daemon socket is mounted into a container, and no container exposes a privileged port (below 1024).

Resources. The memory budget (22 GB out of 32) leaves the host the headroom it needs; `free -h` after each VM start shows that it is not exceeded. Monitoring of the host and the VMs with Prometheus is described in section 6.1.

Recovery. Each VM can go back to a named snapshot, the host to a Snapper point, and the pfSense configuration to its encrypted export. The operations manual orders these rollbacks from the lightest to the most complete (Annex M, section 8):

```
sudo virsh snapshot-list <vm>
sudo virsh snapshot-revert <vm> <label>     # back to a known state
sudo snapper -c root list
```

The framework's criteria, and where I demonstrate them

The certification framework sets performance criteria for each competency. I go through them one by one here, with the place in this report that proves each of them. Where the proof is only partial, I say so. In the lab, the "service level agreements" are the recovery objectives set by the security policy, presented above.

CP1 · Apply good practice in infrastructure administration.

Performance criterion	Where I demonstrate it
Problems and incidents are resolved	INC-01 to INC-03, each resolved down to its root cause, with a proof and a rule kept (steps 3 and 4, Annex J)
Scheduled tasks for keeping the infrastructure in operational condition are carried out in line with good practice	Daily, weekly and monthly tasks from the operations manual; a snapshot before any update; ZFS snapshots, scrub and automatic updates (CP1 section)
Service quality is kept at the expected level	Recovery objectives met wherever they were tested: under one second for a file (PV-01), under five minutes for the firewall configuration (PV-04). Partial: no directory restore has been tested yet
The procedures in place comply with good practice	Procedures written so that another operator can replay them: ordered shutdown and restart, update, restore checked by SHA-256, firewall recovery, adding a machine (CP1 section)
Interventions and configuration changes, as well as scheduled maintenance tasks, are documented in a tracking tool	Incident log, command booklet, operations manual, security policy inventory, ITIL 4 change types. Partial: no GLPI-type tracking tool in the lab

CP2 · Administer and secure network infrastructures.

Performance criterion	Where I demonstrate it
The network infrastructure is operational in line with the service level agreements	A single point of passage, Internet access and name resolution from the LAN (step 2); firewall configuration recovered in under five minutes (PV-04)
Tasks are carried out in line with good practice	Default deny on the WAN, explicit outbound rules on the LAN, denials logged, layer-by-layer troubleshooting with packet captures (CP2 section)
Security rules are applied	Local filtering on every server; no legacy or unencrypted protocol exposed (Annex B); F-01, F-02 and F-06 tracked with a written decision
Current regulations are complied with	The security policy sets what must be logged at the point of passage and for how long, at least 90 days (article 9.2). Partial: pfSense is not connected to the SIEM yet

CP3 · Administer and secure system infrastructures.

Performance criterion	Where I demonstrate it
The system infrastructure is operational in line with the service level agreements	`infrasec.local` forest and DNS, TrueNAS join in the HEALTHY state, *rootless* services active (steps 3 to 6); restore proven (PV-01)
Tasks are carried out in line with good practice	Hardening kept in dedicated files, SSH configuration validated before any reload, SELinux contexts declared with `semanage`, secrets entered interactively (step 1, CP3 section)
Security rules are applied	Lynis 69 → 76; password policy and role matrix of the security policy; SCA compliance of the agents. Scheduled: F-03, F-04, rotation of the Wazuh password
Current regulations are complied with	The security policy takes the GDPR into account: notifying a data breach to the CNIL within 72 hours (article 10.5.2) and log retention (article 9.2). The host disk is encrypted

CP4 · Administer and secure virtualized infrastructures.

Performance criterion	Where I demonstrate it
The virtualized infrastructure (on-premise and cloud) is operational in line with the service level agreements	Five VMs in service within a 22 GB memory budget out of 32, automatic start with the host, health checks after every change (step 7). Partial: no public cloud (see below)
Tasks are carried out in line with good practice	Cold snapshots before any risky operation, NOCOW subvolumes prepared before the first image, a dedicated pool, never a `virsh destroy` on the domain controller; five servers consolidated on a single machine, which keeps hardware and energy use low
Security rules are applied	SELinux *enforcing* and VM isolation by categories, an isolated LAN bridge, *rootless* containers with *user namespaces*, no daemon socket mounted (CP4 section)
Current regulations are complied with	VM disks protected at rest by the host's LUKS encryption; hypervisor logging required by the security policy (article 9.2). Partial: the hypervisor is not connected to the SIEM yet

The two criteria shared by CP2, CP3 and CP4: English.

Performance criterion	Where I demonstrate it
Technical information and documentation are understood, including when they are in English	The product interfaces and messages, in English, quoted as they are in this chapter; vendor release notes and advisories followed by the threat watch (Annex K); the INC-03 diagnosis, made from the error messages and release notes of windows_exporter
Written exchanges with professionals are clear, concise, structured and suited to the readers, including when they are in English	The English version of this report, including this chapter; the bilingual operations manual (Annex M)

The "Partial" entries are the limits already written in this chapter, each tied to a decision.

◆ What the lab does not cover

The framework describes a broader job than a lab on a single machine. Here is what I did not implement here, so that the picture stays accurate:

Framework area	Status in the lab
Physical layer 2 and 3 switches, VLANs, link aggregation, STP, HSRP, QoS	Not covered: a single segment on a virtual bridge
Wireless networks, BYOD, captive portal	Not covered
Filtering proxy, administration bastion	Not built; the bastion is the target of measure M-01
Network IDS/IPS	Not covered: detection relies on Wazuh, at host level
Strong authentication (MFA, OTP), internal PKI	Not covered: MFA is planned in the next steps (section 8.4)
Hybrid directory (Entra ID), Microsoft 365, Remote Desktop Services	Not covered
Asset and ticket management tool (GLPI)	Replaced here by the policy inventory and the incident log
Dedicated backup software (Veeam, Backup Exec)	Replaced by ZFS snapshots and replication, libvirt snapshots and Snapper
Hypervisor high availability, clustering, load balancing	Not covered: a single hypervisor
Public cloud (IaaS, PaaS), image registry, Kubernetes	Not covered

Summary of the foundation

The foundation was built in the order of its dependencies, each step closed by a test and a snapshot. It provides a single filtered point of passage, a central identity, storage controlled by groups and a backup proven by a restore. Hardening is measured (Lynis 69 → 76), and every step can be undone. Each of the three build incidents left a rule: BIOS for installations through the web console, time synchronized before any Kerberos join, release notes read before deploying an exporter. Its limits are known, written down and tied to a decision: the host's address on the segment, administration that is still too open, a SIEM that does not cover every machine yet. It is on this documented and reversible base that I could design and deploy the Zero-Trust remote access (chapters 4 and 5) and manage the security of the whole (chapter 6).

02

CHAPTER 2

Requirements

What the company asks for, and how I turned it into requirements that can be measured.

CCP2 CP5

2. Requirements

The full requirements document has the reference CDC-2026-01. This chapter summarizes it. The choice of solution and its cost are explained in chapter 4.

2.1 Context and existing system

INFRASEC's whole information system runs on a single hypervisor. A pfSense firewall filters traffic and is the only way into the internal network `10.10.10.0/24`. Behind it, the LAN switch connects an Active Directory domain controller (forest `infrasec.local`), a TrueNAS file server, a container server that runs monitoring (Prometheus, Grafana) and a Wazuh SIEM. There is no controlled remote access.

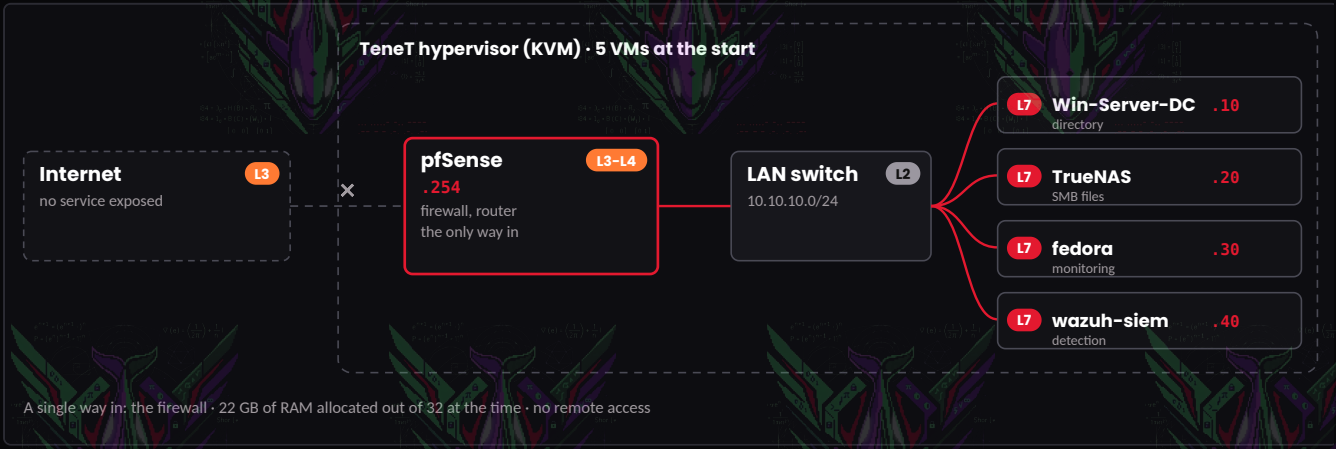


Figure 4 The existing information system: one way in, four internal servers, no remote access.

Abbreviations — **L1…L7**: OSI layers: 1 physical, 2 data link, 3 network, 4 transport, 5 session, 6 presentation, 7 application · **LAN**: lab local network 10.10.10.0/24 · **SMB**: Server Message Block file sharing, port 445 · **KVM**: Kernel-based Virtual Machine · **VM**: virtual machine · **SIEM**: Security Information and Event Management · **RAM**: Random Access Memory

2.2 The need

In one sentence: **let remote users reach, from the Internet, only the internal resources they need, without exposing the information system.**

I identified two profiles, with deliberately different needs. The traveling administrator must reach the management plane to work remotely. The remote employee must reach the file share, and nothing else. This difference is the heart of the project: it is least privilege, the base of the Zero-Trust approach, applied to a real case.

2.3 Scope

In the project: the VPN server on the existing firewall, the two access profiles and their rights, the filtering rules per profile, key management and device enrollment, service monitoring, operations documentation and the revocation procedure.

Out of the project: redesigning the internal network (done in the first stage), client device posture, multi- factor authentication and firewall redundancy. The last two are kept for later.

2.4 Constraints

Constraint	What it changes in the project
Budget	Use what exists and open-source software. No hardware purchase, no recurring license

Constraint	What it changes in the project
Security	Least privilege per profile, modern cryptography, no secret in clear text. Private keys are created on, and stay on, each device. ANSSI recommendations
Production	No outage of internal services during deployment. A reversible change, documented so someone else can run it
Environment	No extra server. A protocol that is light on CPU, and so on energy
Regulation	GDPR: encryption of personal data in transit and proportionate logs. ANSSI as the best-practice reference

2.5 Functional and technical requirements

Ref.	Functional requirement	Priority
EF1	Open an encrypted tunnel to the information system from any Internet connection	Essential
EF2	Two profiles: administrator (management plane) and employee (file share only)	Essential
EF3	Each profile reaches only what it is allowed to; everything else is blocked	Essential
EF4	Simple and fast device enrollment (file or QR code)	Important
EF5	Central and immediate revocation of compromised access	Essential
EF6	The operator can see the state of connections	Important

Ref.	Technical requirement	Threshold or type
ET1	Modern, proven cryptography	Curve25519, ChaCha20-Poly1305
ET2	Two-level isolation: routing by key and stateful filtering	One dedicated rule per profile
ET3	Service availability	≥ 99.5% during business hours
ET4	Low performance cost	Lightweight protocol
ET5	No secret in clear text, private keys not centralized	Keys created on the client device
ET6	Monitoring of the tunnel state	Plugged into the existing chain
ET7	Proportionate connection logs	GDPR compliant
ET8	Reversible deployment	Written rollback plan

2.6 Expected service levels

Indicator	Target
Remote access availability (business hours)	≥ 99.5%
Recovery time after an incident (RTO)	< 1 hour
Time to enroll a new user	< 15 minutes
Time to revoke compromised access	< 5 minutes

2.7 Expected deliverables

The requirements document, the architecture diagrams, the deployment and rollback plan, the operations documentation with the revocation procedure, the monitoring documentation and the acceptance test report. All of them are in this report or its annexes. The acceptance test report (PV-04) is Annex O.

03

CHAPTER 3

Project management

How I split the work, how I tracked it, and the risks I planned for.

CCP2 CP5 CP6

3. Project management

3.1 Method and phases

I ran the project in phases. Each phase closes on a criterion that can be checked. The phases follow the ITIL service lifecycle: design, transition, operation. I set myself a simple rule from the start: **a phase is only finished when its proof exists**. A proof is a report, a measurement, a capture or a log entry. “Almost done” does not count.

Phase	Purpose	End-of-phase deliverable	Skill
P0	Rebuild the foundation on a new hypervisor	Working foundation, gaps recorded	CP6
P1	Design the evolution	Requirements, comparison, TCO	CP5
P2	Prototype and test the solution	Validated test bench	CP5
P3	Put remote access into production	Deployment plan, acceptance test	CP6
P4	Monitoring	Dashboards, indicators, thresholds	CP7
P5	Backup and restore	PV-01: measured RTO, RPO from snapshot frequency	CP6, CP9
P6	Audit and risk analysis	Engagement letter, PV-02, assessment, EBIOS RM	CP8
P7	Security policy and awareness	Security policy, awareness material	CP9
P8	Incident detection and handling	PV-03, lessons learned	CP10
P9	Hardening and freeze	Freeze report, SHA-256 register	CP9
P10	Documentation and preparation	Report, slides, rehearsals	Cross-cutting

3.2 Schedule and tracking

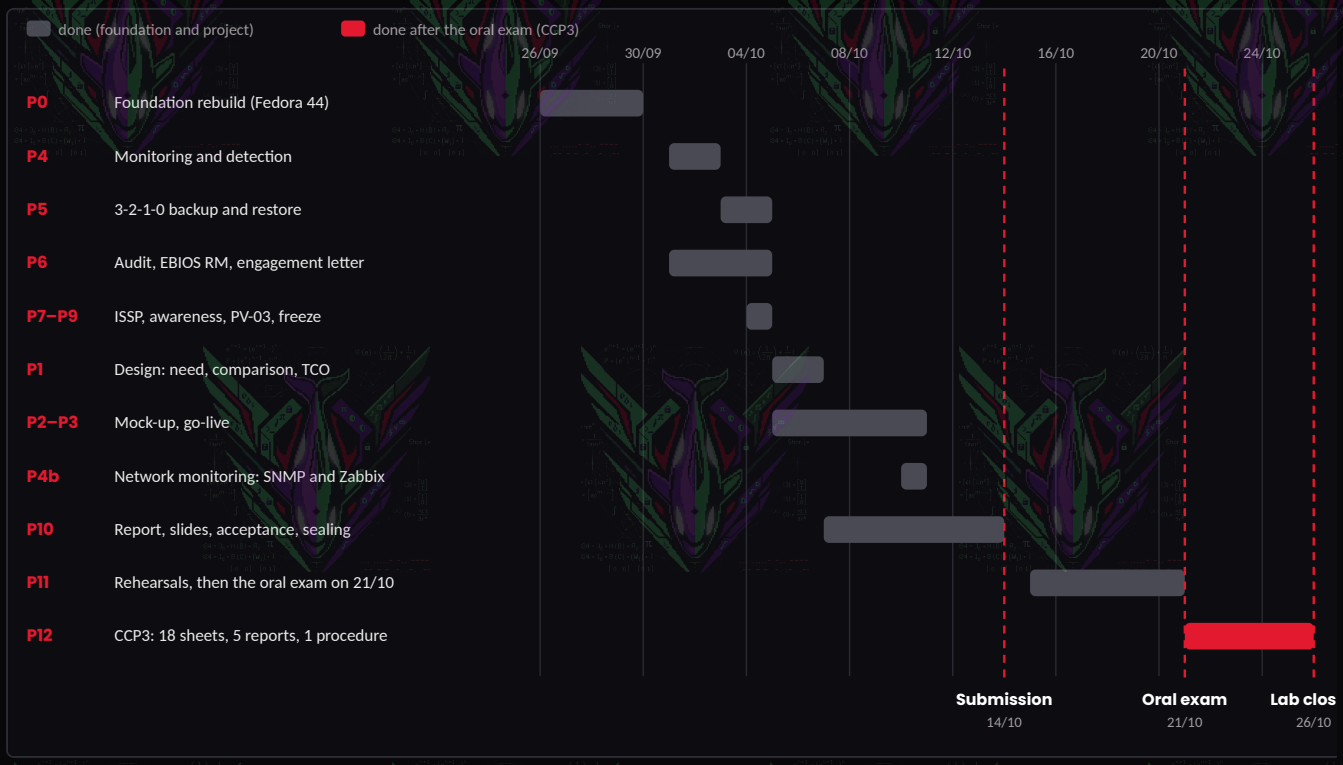


Figure 5 Project schedule, from the foundation to the lab closure on 26/10/2026.

Abbreviations — **EBIOS RM**: ANSSI risk analysis method (EBIOS Risk Manager) · **TCO**: Total Cost of Ownership · **SNMP**: Simple Network Management Protocol, UDP port 161 · **PV**: implementation or acceptance report · **INC / F**: incident sheet / finding sheet

What sets the end of the project is not the technical work but the documentation: the fixed date is the report deadline, October 14. So I put the technical phases early. I also decided in advance what I would drop if I fell behind: the options (network monitoring with Zabbix, an extra detection rule) would be dropped before the report, never the other way around. In the end, both options were done on October 11.

Design (P1) and prototype (P2) overlapped on purpose. The prototype checked on the existing firewall that the planned solution worked, before the decision of October 6. Its incidents (INC-04 to INC-06) fed the deployment plan written on October 7.

To track the project, I used three simple tools. First, a coverage table that links each criterion of the framework to the deliverable that covers it, with its status. Second, the incident log (Annex J), where I write down each difficulty with its diagnosis, its cause and what I learned. Third, a snapshot at the end of each phase, named `POST-[OPERATION]-STABLE`, so I can go back at any time.

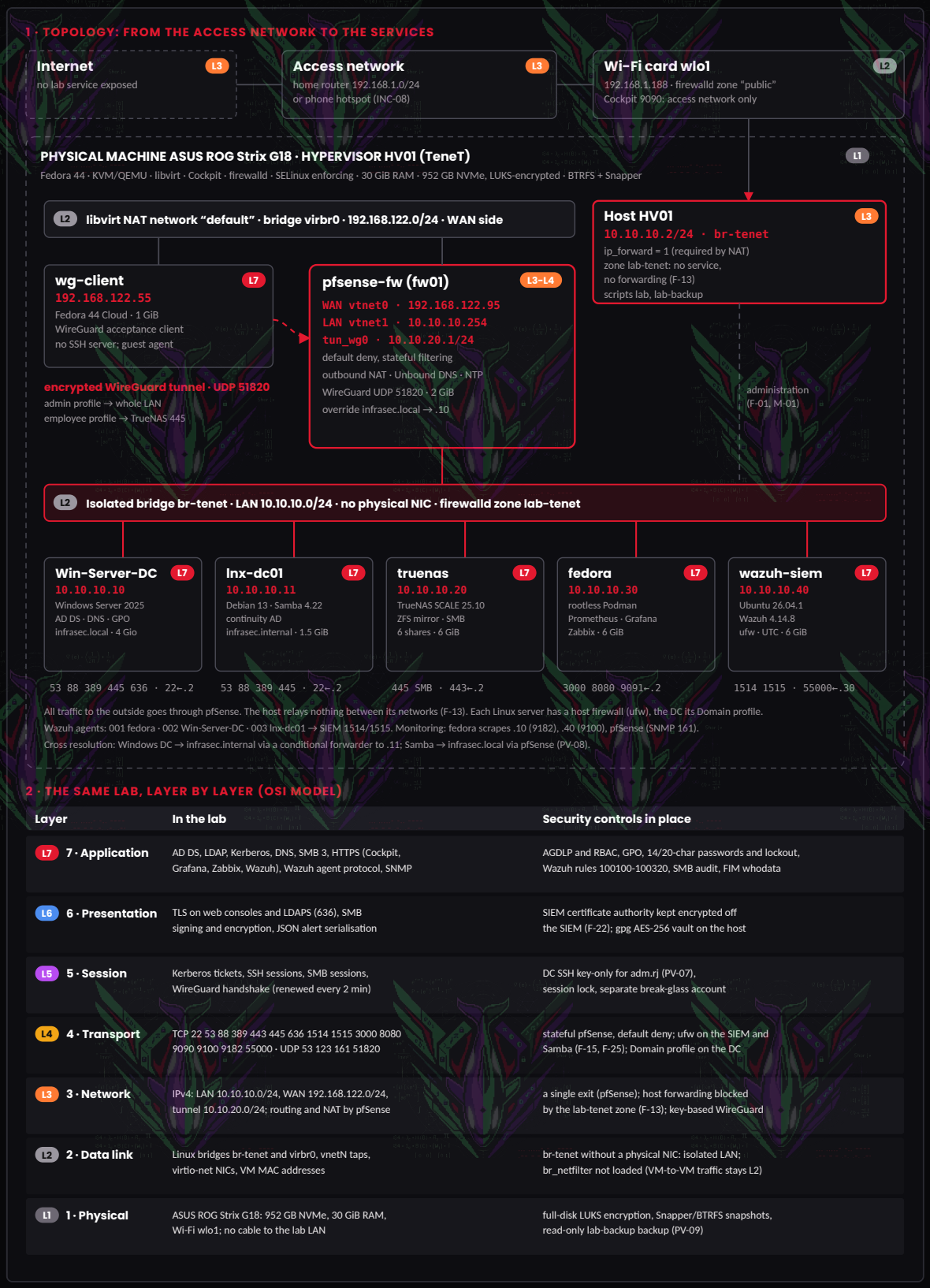
Milestone	Date	Exit criterion
Foundation rebuilt	Oct 2	Five VMs running, directory and share working
Monitoring live, security measured	Oct 4	Monitoring live; PV-01, PV-02, PV-03, EBIOS RM, security policy, freeze report
Evolution designed and costed	Oct 6	Requirements and TCO approved
Evolution in production	Oct 11	Acceptance test passed (PV-04), freeze, integrity register up to date
Report submitted	Oct 14	Report, slides and admin documents on the Drive
Oral exam	Oct 21	(final milestone)

3.3 People

I ran this project alone, but with an organization. The security policy defines eight roles: CISO, system administrator, directory, network, storage, container operator, security analyst and auditor. I held them one after another, and I recorded each decision in the document that belongs to the role. When I write the engagement letter, I am the client of the audit. When I write the report, I am the auditor. When I compare that report to the letter, I am the client again. This separation on paper partly makes up for the fact that one person holds every role.

The real people I worked with are presented in chapter 7.

3.4 Technical environment



2 · THE SAME LAB, LAYER BY LAYER (OSI MODEL)

Layer	In the lab	Security controls in place
L7 7 · Application	AD DS, LDAP, Kerberos, DNS, SMB 3, HTTPS (Cockpit, Grafana, Zabbix, Wazuh), Wazuh agent protocol, SNMP	AGDLP and RBAC, GPO, 14/20-char passwords and lockout, Wazuh rules 100100-100320, SMB audit, FIM whodata
L6 6 · Presentation	TLS on web consoles and LDAPS (636), SMB signing and encryption, JSON alert serialisation	SIEM certificate authority kept encrypted off the SIEM (F-22); gpg AES-256 vault on the host
L5 5 · Session	Kerberos tickets, SSH sessions, SMB sessions, WireGuard handshake (renewed every 2 min)	DC SSH key-only for adm.rj (PV-07), session lock, separate break-glass account
L4 4 · Transport	TCP 22 53 88 389 443 445 636 1514 1515 3000 8080 9090 9100 9182 55000 · UDP 53 123 161 51820	stateful pfSense, default deny; ufw on the SIEM and Samba (F-15, F-25); Domain profile on the DC
L3 3 · Network	IPv4: LAN 10.10.10.0/24, WAN 192.168.122.0/24, tunnel 10.10.20.0/24; routing and NAT by pfSense	a single exit (pfSense); host forwarding blocked by the lab-tenet zone (F-13); key-based WireGuard
L2 2 · Data link	Linux bridges br-tenet and virbr0, vnetN taps, virtio-net NICs, VM MAC addresses	br-tenet without a physical NIC: isolated LAN; br_netfilter not loaded (VM-to-VM traffic stays L2)
L1 1 · Physical	ASUS ROG Strix G18: 952 GB NVMe, 30 GiB RAM, Wi-Fi wlo1; no cable to the lab LAN	full-disk LUKS encryption, Snapper/BTRFS snapshots, read-only lab-backup backup (PV-09)

Figure 6 Overall network architecture of the Hybrid InfraSec lab: full topology and a layer-by-layer reading of the OSI model (as of 26/10/2026).

Abbreviations — **L1…L7**: OSI layers: 1 physical, 2 data link, 3 network, 4 transport, 5 session, 6 presentation, 7 application · **OSI**: 7-layer reference model (Open Systems Interconnection) · **HV01**: lab hypervisor, host name TeneT · **KVM**: Kernel-based Virtual Machine · **LUKS**: Linux Unified Key Setup, full-disk encryption · **BTRFS**: B-tree file system, with snapshots · **NAT**: Network Address Translation · **WAN**: outside of the firewall (NAT network 192.168.122.0/24) · **LAN**: lab local network 10.10.10.0/24 · **WG**: WireGuard: encrypted VPN tunnel, UDP port 51820 · **DNS**: Domain Name System · **NTP**: Network Time Protocol · **AD DS**: Active Directory Domain Services · **LDAP**: Lightweight Directory Access Protocol · **SMB**: Server Message Block file sharing, port 445 · **SNMP**: Simple Network Management Protocol, UDP port 161 · **TLS**: Transport Layer Security · **SSH**: Secure Shell remote administration, port 22 · **GPO**: Group Policy Object · **AGDLP**: Accounts → Global groups → Domain Local groups → Permissions · **RBAC**: Role-Based Access Control · **FIM**: File Integrity Monitoring · **whodata**: Wazuh FIM mode that also records the user and the process · **TCP / UDP**: transport protocols, connection-oriented or not · **ufw**:

Debian/Ubuntu host firewall (Uncomplicated Firewall) · **DC**: Domain Controller · **SIEM**: Security Information and Event Management · **VM**: virtual machine · **Gio / Go**: gibibytes (memory, 2^{30} bytes) / gigabytes (disk, 10^{9} bytes) · **agent invité**: QEMU guest agent: service in the VM that takes orders from the hypervisor

Layer	Components
Physical machine	ASUS ROG Strix G18: 32 GB RAM, NVMe SSD, LUKS encryption, BTRFS with Snapper snapshots
Hypervisor	Fedora 44, KVM/QEMU, libvirt, Cockpit, firewalld, SELinux in *enforcing* mode
Virtual networks	libvirt NAT `192.168.122.0/24` on the WAN side (switch `virbr0`); isolated bridge `br-tenet` for the LAN `10.10.10.0/24`
Firewall	pfSense CE: filtering, router, DNS, WireGuard server (`10.10.20.0/24`)
Identity	Windows Server 2025: AD DS, DNS, forest `infrasec.local`
Storage	TrueNAS SCALE 25.10: mirrored ZFS, SMB share joined to the domain
Containers and monitoring	Fedora 44 Server: rootless Podman, Prometheus, Grafana, node_exporter, Zabbix; windows_exporter on the domain controller
Detection	Ubuntu 26.04 LTS: Wazuh 4.14 (manager, indexer, dashboard, agents)
Audit	nmap, Lynis, Wazuh SCA module

3.5 Quality goals

Goal	Indicator	Result
No secret in the deliverables	Check before sealing: passwords, private keys, public addresses	Met
Each step validated by a test, not by a status light	A written exit criterion for each deployment step	Applied (ch. 5)
Each incident explained	Diagnosis, cause and lesson for each log entry	7 incidents documented
Security measured, not just claimed	Lynis hardening index before and after	69 → 76 / 100
Proven recovery	Restore done, timed and checked with hashes	RTO < 1 s, 0 errors
Integrity of the documents	SHA-256 hash of each deliverable	Register kept up to date
Reversibility	A snapshot before each major operation	Convention applied

3.6 Project risks and responses

Risk	What happened or what I feared	Response
Not enough memory on the host	Unable to run every VM at the same time	Memory budget set (22 GB out of 32); audit VM started only during the audit
A tool that fails	The ready-made audit VM did not boot	Coverage with nmap, Lynis and Wazuh SCA; gap recorded in the report assessment
Software that changes between versions	Collectors removed in windows_exporter (INC-03)	Self-correcting deployment script; release notes added to the threat watch

Risk	What happened or what I feared	Response
A schedule slip	Less time for the report	Drop rule set in advance: options first, never the report

04

CHAPTER 4

Choosing the solution

Four solutions compared with the same method, a choice explained and costed over three years.

CCP2 CP5

4. Why I chose this solution

4.1 Solutions studied

I studied four families of solutions: three VPNs that you host yourself, and one commercial ZTNA offer run by a provider.

WireGuard. A recent protocol with deliberately very short code (a few thousand lines, so it can be audited) and modern, fixed cryptography. It is built into pfSense. It is fast, uses little CPU, and it is free and open source. On the other hand, it is younger, and enterprise features such as multi-factor authentication are not built in.

OpenVPN. Mature, widely used, based on TLS, flexible, with many options including multi-factor authentication. It is heavier and slower, and its configuration is more complex, so it costs more to run and to audit.

IPsec / IKEv2. A recognized standard, often built into operating systems. Its configuration is known to be complex, it handles NAT poorly and it uses more resources.

Commercial ZTNA (offers like Zscaler Private Access or Twingate). The richest option: identity-based access, multi-factor authentication, no inbound port open. On the other hand, there is a subscription per user, a dependency on the provider, and traffic goes through a third party's cloud. That is a sensitive point for GDPR and for control over the data.

4.2 Selection method: a weighted decision matrix

I used seven criteria, with weights that come from INFRASEC's constraints (chapter 2.4). Each solution is scored from 1 (poor) to 5 (excellent), and the weighted score guides the decision. I set the weights **before** scoring the solutions. Otherwise, there is a risk of tuning the matrix to justify a choice already made.

Criterion	Weight	WireGuard	OpenVPN	IPsec/IKEv2	Commercial ZTNA
Purchase and running cost	20%	5	4	4	2
Security level, cryptography	20%	5	4	4	5
Performance and efficiency	15%	5	3	3	4
Ease of deployment and operation	15%	4	3	2	5
Integration with the existing firewall	10%	5	4	4	1
Auditable, transparent code	10%	5	4	3	1
Control over data (GDPR)	10%	5	5	5	2
Weighted score out of 5	**100%**	**4.85**	**3.80**	**3.55**	**3.15**

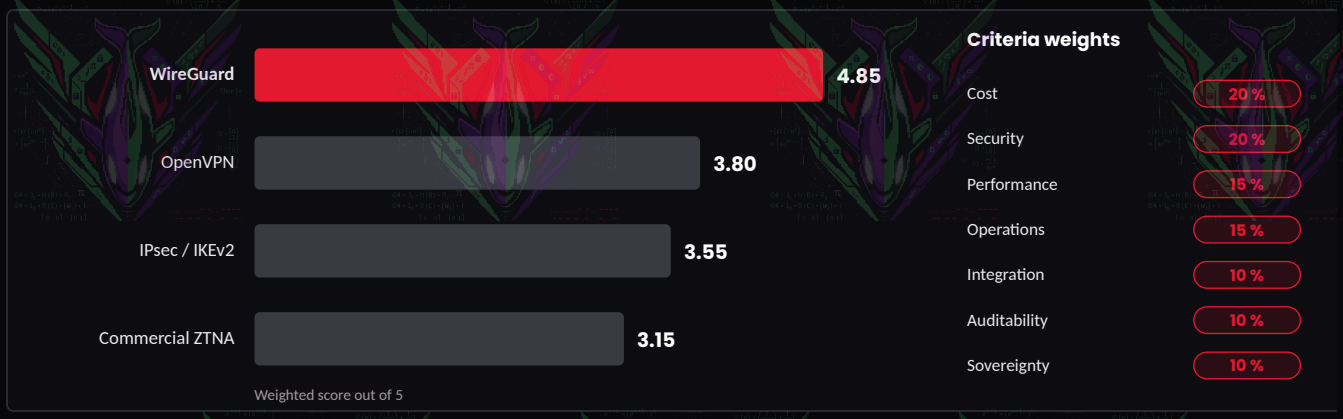


Figure 7 Weighted scores of the four solutions and criteria weights.

Abbreviations — **ZTNA**: Zero Trust Network Access · **WG**: WireGuard: encrypted VPN tunnel, UDP port 51820

The matrix also shows where WireGuard is not the best: for ease of operation and richness of features, the commercial offer comes first. I was not looking for the best technology in absolute terms, but for the best one for this need and these constraints.

4.3 Total cost of ownership over three years

The calculation uses assumptions that I state clearly, so they can be adjusted: an internal cost of €350 per day for an administrator, ten remote users, no hardware or license to buy for the self-hosted solution.

Item	Self-hosted WireGuard	Commercial ZTNA
Hardware	€0 (existing firewall)	€0
Licenses	€0 (open source)	(included in the subscription)
Implementation (CAPEX)	4 days × €350 = €1,400	setup fee: €500
Subscription (OPEX per year)	none	10 users × €6/month × 12 = €720
Operation (OPEX per year)	3 days × €350 = €1,050	2 days × €350 = €700 (managed service)
Energy (OPEX per year)	≈ €20 (light protocol, existing hardware)	(not costed)
OPEX per year	**€1,070**	**€1,420**
TCO over 3 years	**1,400 + 3 × 1,070 = €4,610**	**500 + 3 × 1,420 = €4,760**

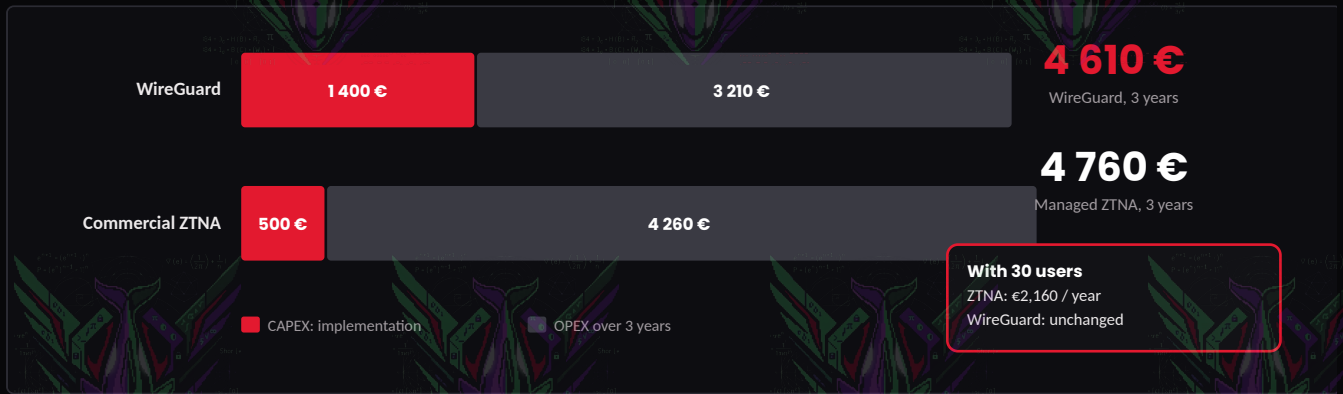


Figure 8 Total cost over three years: implementation and cumulative operation.

Abbreviations — **TCO**: Total Cost of Ownership · **CAPEX**: capital expenditure: implementation cost · **OPEX**: cumulative operating expenditure · **ZTNA**: Zero Trust Network Access

What I take from this calculation. The two costs are close: €150 apart over three years, less than 4%. So cost does not decide, and I prefer to say it plainly. Two things still make a difference over time. First, the cost of WireGuard does not depend on the number of users, while the commercial subscription grows with each user: at thirty users, it would reach €2,160 per year. Second, with WireGuard no traffic goes through a third party, no data is handed to a provider, and no subscription ties the company down.

I also costed, separately, an option with an access point hosted in the cloud (a small instance, about €11 per month): €396 over three years. It is not required for the current need.

4.4 Chosen solution and architecture

I chose **WireGuard on the existing pfSense firewall, with two profiles separated by least privilege.** It is first in the matrix (4.85 out of 5), and it meets every constraint: no purchase cost, modern cryptography, efficiency, firewall integration, auditable code and full control over data.

Element	Choice
VPN server	Tunnel `tun_wg0` on pfSense, listening on a single UDP port (51820)
Tunnel network	`10.10.20.0/24`, separate from the internal network; firewall at `10.10.20.1`
Administrator profile	Peer `admin-remote`, `10.10.20.2/32`, to the internal network `10.10.10.0/24` for management; rule to be narrowed to the management interfaces only
Employee profile	Peer `employe-remote`, `10.10.20.3/32`, to the TrueNAS SMB share (TCP 445) **only**
Authentication	One key pair per device; the private key is created on, and stays on, the device; only the public key is declared on the firewall
Isolation	Routing by key (each peer owns only its own address) + one stateful rule per profile + Active Directory group rights on the share
OSI layers	Layer-3 tunnel (encrypted IP packets) carried in UDP (layer 4); pfSense filtering at layers 3 and 4; share rights at layer 7 (Annex N)

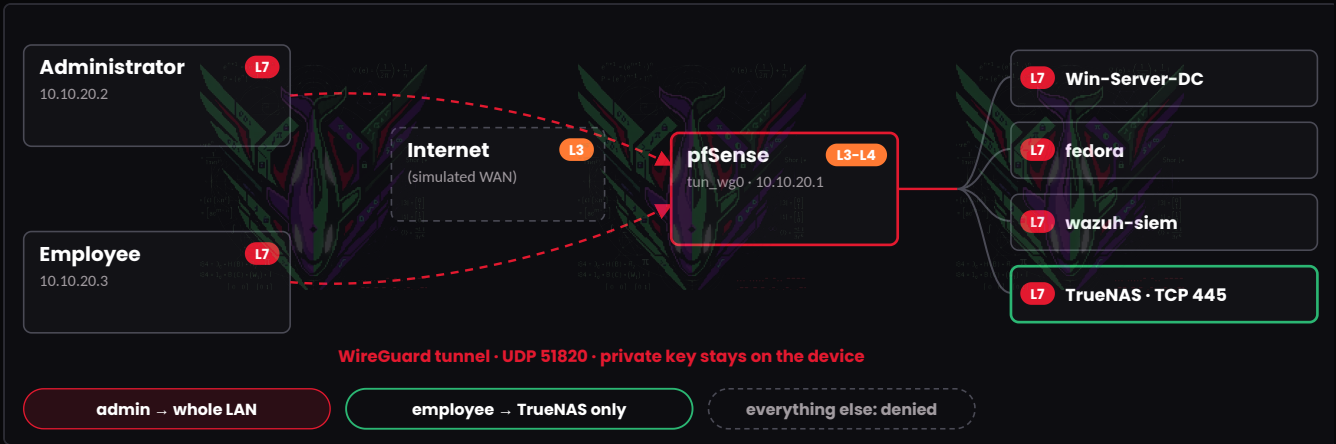


Figure 9 Chosen architecture: one UDP port, one tunnel, two separate profiles.

Abbreviations — **WG**: WireGuard: encrypted VPN tunnel, UDP port 51820 · **WAN**: outside of the firewall (NAT network 192.168.122.0/24) · **LAN**: lab local network 10.10.10.0/24 · **TCP / UDP**: transport protocols, connection-oriented or not · **L1…L7**: OSI layers: 1 physical, 2 data link, 3 network, 4 transport, 5 session, 6 presentation, 7 application

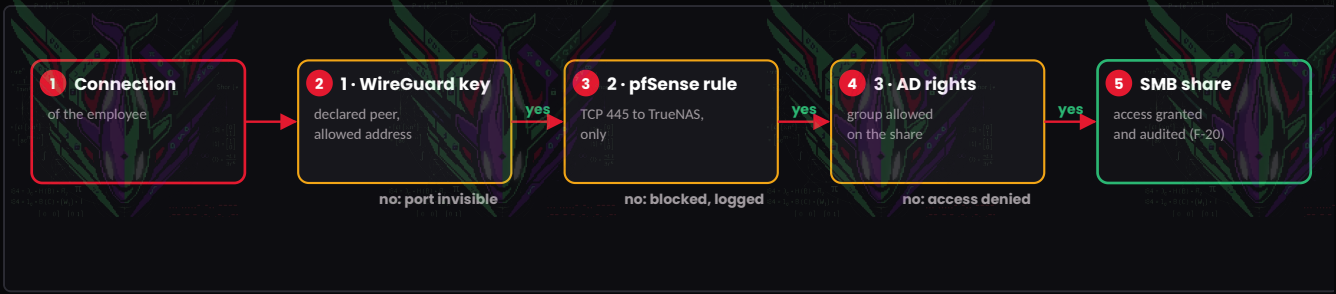


Figure 10 What an employee connection goes through: three barriers.

Abbreviations — **WG**: WireGuard: encrypted VPN tunnel, UDP port 51820 · **SMB**: Server Message Block file sharing, port 445 · **AD DS**: Active Directory Domain Services

This diagram sums up the security idea. An employee connection goes through three different checks. First the key: an unknown device gets no answer, and the port stays invisible to a scan. Then the firewall rule: only TCP 445 to the file server is open. Last, the directory rights on the share. None of these checks is enough on its own to open access: that is defense in depth. Two of these checks rely on pfSense, so its hardening, its backup and its monitoring are part of remote access security. The third depends on the directory and stays independent of the firewall.

The solution can grow easily. To add a user, I declare a peer and attach it to the rule of its profile. To add a profile, I create a rule. The architecture does not change.

◆ 4.5 The other technical choices of the project

Remote access is not the only choice I had to justify. Here are the others, with the criterion that decided.

Choice	Alternative not chosen	What decided
Prometheus and Grafana for monitoring	Zabbix alone	Pull-based collection and a time-series database, suited to a container infrastructure. Zabbix remains the right tool for the firewall over SNMP and completes the set
Wazuh for detection	Several separate tools	One open-source platform that brings together the agent (integrity, detection, active response), the SIEM (collection and correlation) and compliance (SCA)
ZFS snapshots and replication for backup	Separate backup software	Immutable, near-instant snapshots, block-level integrity checks, native replication: file-level restore in under one second
Rootless Podman for containers	Docker with a root daemon	No privileged daemon, containers run by an unprivileged user, no daemon socket exposed
Infrastructure as code (Terraform, local state) for the firewall, from the first stage	Manual configuration only	Everything can be rebuilt the same way; state stays local, with no dependency on a third-party service

05

CHAPTER 5

Implementation

Step-by-step deployment, the October 11 acceptance test, rollback and recovery.

CCP2 CP6

5. How I organized the implementation

This chapter summarizes the deployment plan MEP-2026-01.

5.1 The framework: a controlled change

I relied on ITIL 4 practices for change management, release management and service validation. The evolution is a **normal change**: it changes what the information system exposes, so it must be assessed and then authorized before it is done. The assessment is based on the requirements, and the authorization is the approval of the deployment plan.

In the lab, the prototype and the target are in the same environment. I wrote the plan on October 7 from what the prototype had taught me, with a validation criterion for each step. Steps E0 to E7 were checked on the configuration that came out of the prototype. Steps E8 to E10 were done on October 11.

Once the service is live, adding or revoking a user becomes a **standard change**: approved in advance, repeatable, done by following a written procedure, without a full new assessment.

5.2 Impact analysis and prior backups

The change is **additive**: it adds an interface and rules, without touching the rules of the internal network. On the WAN side, a single port is open (UDP 51820), and WireGuard does not answer any unauthenticated packet. Before starting, I created three restore points: a snapshot of the firewall VM, an export of the pfSense configuration **kept offline** (it contains the hash of the admin password and the TLS key of the web interface), and a Snapper snapshot of the host.

A gap specific to the lab. pfSense's WAN is connected to the hypervisor's NAT network, so to a private address. I turned off the "block private networks" option on that interface to let the tunnel through. In production, the WAN has a public address and this option stays on.

5.3 Steps and validation gates

A step is only passed if its validation criterion is met.

Step	Action	Validation criterion	Result
E0	Prior backups, user notice	Snapshot and export present	✅
E1	Install the WireGuard package	Package installed, service available	✅
E2	Create the tunnel `tun_wg0`, server key created on the firewall	Tunnel up	✅
E3	Interface `WG_REMOTE` (`10.10.20.1/24`)	Interface up	✅ static addressing fixed during acceptance (INC-07)
E4	Declare the two peers (public keys, one `/32` per peer)	Unique *Allowed IPs* ranges	✅ after a fix (INC-06)
E5	Rules: WAN UDP 51820; administrator to the internal network; employee to TCP 445 on TrueNAS; everything else denied	Isolation as specified	✅

Step	Action	Validation criterion	Result
E6	Publish: forward UDP 51820 from the host to the firewall WAN	Port reachable	✅
E7	Enroll devices (keys created on the device, QR code)	Handshake up; application traffic checked at acceptance (E8)	✅
E8	Acceptance test against the acceptance grid	All criteria met	✅ Oct 11 (PV-04), after fixing INC-07
E9	Connect to monitoring	The operator sees the tunnel state	✅ `tun_wg0` state collected by Zabbix (SNMP)
E10	Freeze: snapshots, integrity register, documentation	Register and documentation up to date	✅ snapshots `gel-20261011`, SHA-256 register

What steps E3 and E4 taught me. At first, the two peers had the same *Allowed IPs* range. The tunnel came up, the status light was green, but the file server's reply never got back to the employee, because no key "owned" their address. A packet capture showed where it stopped: the server answered, but the firewall sent nothing back into the tunnel. I fixed it with a unique `/32` per peer (INC-06). The acceptance test then showed me that this fix was needed, but not enough: the tunnel interface had no fixed address, so pfSense had no return route to the clients (INC-07). Since then, a successful handshake is only a step for me. I only validate on real application traffic, observed end to end.

5.4 Acceptance test

Acceptance criterion	Measurement	Threshold	Status
The tunnel comes up	Successful handshake, bytes exchanged both ways	Yes	✅ Passed
The employee's allowed traffic gets through	LAN capture: the request reaches `10.10.10.20:445` and the server answers	As specified	✅ Passed
Full employee session	End-to-end SMB connection from a remote device	Established	✅ Passed (after INC-07)
Any other employee traffic is denied	Attempts to the domain controller (445, 3389), the container server (22), the Wazuh console (443)	Denied	✅ Passed, 4 denials in the `WG_REMOTE` logs
Administrator access	Access to management interfaces	As specified	🟡 Rule checked in the configuration; not retested with the acceptance client
Traffic is encrypted	WAN-side capture: only encrypted UDP 51820	No clear-text data	✅ Passed, 20 packets, all UDP 51820
Revoking access	Peer disabled, access denied	< 5 min	✅ Passed, cut-off within 1 second (one-second probe)
Monitoring	The operator sees the tunnel state	Yes	✅ Passed, `tun_wg0` at `up (1)` in Zabbix



Choosing the test bench. My first test from the hypervisor "succeeded" without proving anything. The hypervisor has a direct route to the internal network (audit finding F-01), and the traffic went around the tunnel (INC-05). I then isolated the test client in a network namespace with no route to the internal network. That let me validate the handshake and find INC-06. The final acceptance test was run from a separate client VM, truly outside the protected network. For the deny tests to mean something, this client sends the whole `10.10.10.0/24` segment into the tunnel. Otherwise, forbidden traffic would never reach the firewall, and the test could not fail. I read the denials in the pfSense logs. The minute-by- minute detail and the captures are in PV-04 (Annex O).

5.5 Rollback

I start a rollback if access to internal services is lost, if a rule blocks production traffic, if the firewall becomes unstable, or if an essential criterion fails during the change window. I act from the lightest to the heaviest step: disable the tunnel (immediate effect, the internal network is not touched), remove the tunnel rules and the WAN rule, restore the configuration export, go back to the VM snapshot, then to the host's Snapper snapshot. The goal is to get the previous service back in under one hour, as the RTO in the requirements asks. In almost every case, the first two actions are enough.

5.6 Recovery and continuity

Procedure	Test	Status
Recovery of the **data** reachable remotely (SMB share)	Restore timed and checked with SHA-256 hashes (PV-01): RTO < 1 s, 0 errors	✅ Tested and passed
Recovery of the **configuration** of the firewall and tunnel	Restore of the export after a safety snapshot; a marker change undone; tunnel and peers checked end to end	✅ Tested, service back in under 5 min
Revocation of compromised access	Real rotation of the administrator key after exposure (INC-04), then a timed revocation during acceptance	✅ Exercised

Continuity. If remote access goes down, the administrator keeps an emergency path through the hypervisor console. Employees work in degraded mode on authorized local copies, within the RTO.

5.7 Service levels, documentation and handover

Commitment	How I measure it	Status
Availability ≥ 99.5%	Monitoring of the tunnel and firewall state	Measurable: tunnel state collected (Zabbix), availability alert active (Grafana)
Recovery < 1 hour	Rollback procedure, recovery plan	Configuration restore tested: < 5 min ✅
Enrollment < 15 minutes	Timed standard procedure	Procedure written
Revocation < 5 minutes	Revocation procedure	Timed during acceptance: within 1 second ✅

Updated documentation: the command handbook (WireGuard section: key creation, enrollment, troubleshooting, revocation), the bilingual operations manual (Annex M), the incident log (INC-04 to INC- 07), the awareness material (QR code rule) and the integrity register.

Handover. It relies on documentation that can be run as written: an administrator who did not build the project must be able to enroll, troubleshoot and revoke access without help. It also relies on a commented demo (the tunnel, proof of isolation, revoking a peer) and on a user instruction in the awareness session. I consider the handover

done when the operator performs one enrollment and one revocation alone.

06

CHAPTER 6

Monitoring and cybersecurity

Monitor, measure security, apply a policy, detect and handle incidents.

CCP2 CP7 CCP3 CP8 CP9 CP10

6. Results: monitoring and cybersecurity management

A change is only safe if the infrastructure that receives it is watched, measured and able to react. This chapter shows what I did for that, skill by skill.

6.1 Infrastructure monitoring (CP7)

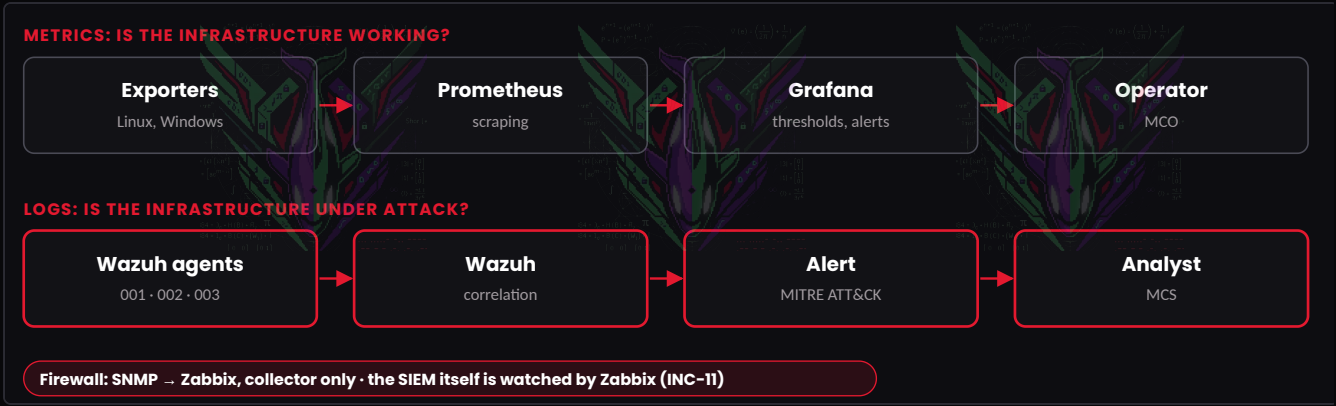


Figure 11 Two monitoring flows: operational metrics and security logs.

Abbreviations — **MCO / MCS**: keeping systems running / keeping them secure · **MITRE ATT&CK**: public catalogue of attack techniques; T1110 brute force, T1547.001 boot persistence, T1562.001 impair defenses · **SNMP**: Simple Network Management Protocol, UDP port 161 · **SIEM**: Security Information and Event Management · **Wazuh**: open-source SIEM: agents, manager, indexer, dashboard

I split monitoring into two flows, because they answer two different questions. **Metrics** answer “is the infrastructure working?”. Prometheus pulls data from the exporters on the container server (node_exporter) and the domain controller (windows_exporter), and Grafana displays it. **Security logs** answer “is the infrastructure under attack?”. Wazuh agents send logs, file integrity and configuration compliance to the manager, which correlates them and raises alerts.

Indicators chosen, not piled up. I kept each indicator because it protects something that matters to the business or a service commitment, not because it was available.

Indicator	Source	Why	Alert threshold	Status
Targets reachable	Prometheus (`up`)	See a machine or service stop	Target unreachable > 2 min: critical	Collected ✅
Directory services (AD DS, DNS, Netlogon)	windows_exporter	The directory is the most critical asset (EBIOS VM-1)	Service stopped: critical	Collected ✅
CPU	exporters	A saturated service	> 85% for 10 min: warning	Collected ✅
Memory	exporters	The host has little headroom (22 GB out of 32)	> 90%: warning	Collected ✅
Disk space	exporters	Logs and snapshots fill the volumes	> 80%: warning · > 90%: critical	Collected ✅
Security alerts level ≥ 10	Wazuh	An attack in progress	Every alert is handled	Active ✅

Indicator	Source	Why	Alert threshold	Status
Wazuh agents connected	Wazuh	A silent agent is a blind spot (EBIOS ER-4)	Agent disconnected > 5 min: critical	Active ✅
SCA compliance score	Wazuh	Configuration drift	Score drops: review	Active ✅
WireGuard tunnel state	pfSense, through Zabbix	Remote access availability (≥ 99.5%)	No handshake > 3 min for an active peer	Collected ✅ (alert to set up)
Firewall interfaces and traffic	SNMP, collected by Zabbix	Load on the only way in	Interface saturated	Collected ✅

An alert tested for real. I created the "Target unreachable" rule in Grafana and tested it on October 11 (PV-04). At 13:11:18, I stopped the collection service on the container server. The alert went to **Pending**, then to **Firing** after the planned two minutes, and back to **Normal** when I restarted the service. A first try triggered nothing: a systemd service restarted the container in under one second. That was a good surprise about resilience, but I had to stop the service itself to test the alert. The other thresholds will follow the same model. Sending alerts by email is waiting for a mail server.

Useful dashboards. The domain controller has a dashboard that works with the recent version of windows_exporter (CPU, memory, disks, network, service state), chosen after the diagnosis of INC-03. Wazuh provides the threat hunting, compliance and MITRE ATT&CK mapping views that I used in PV-03.

Monitoring that is itself secured. The monitoring containers run without privileges (rootless Podman). I closed the node_exporter port on the local firewall, since Prometheus queries it locally (finding F-05). The web admin interfaces use TLS, except the firewall's HTTP listener found in F-02, whose fix is planned.

Optimizing also means removing. I reduced windows_exporter to the useful, valid collectors only (`cpu` , `logical_disk` , `net` , `os` , `service` , `system` , `memory` , `process` , `tcp` , plus `ad` and `dns` for the domain controller). Less noise, no dead metric.

Network monitoring of the firewall. A firewall is a network device, so I query it over SNMP with Zabbix, the tool made for that. Zabbix runs in rootless containers and collects 100 items, including the tunnel state. SNMP v3 (authentication and encryption) is the goal. Version 2c, where the community string travels in clear text, is accepted in the lab only, with protections: a random community string, listening on the LAN only, and a firewall rule that allows queries from the Zabbix server only. I checked it: Zabbix gets an answer, the hypervisor is denied and the denial appears in the logs (PV-04).

6.2 Measuring and analyzing the security level (CP8)

I followed a full loop: engagement letter, then audit, then assessment of the report, then risk analysis, then treatment.

The engagement letter first (Annex A, October 1, 2026). Before checking anything, I wrote the mandate: context, objectives, scope (five components and the internal segment; the hypervisor and client devices are out of scope), reference frameworks (ANSSI, CIS, EBIOS RM, MITRE ATT&CK, GDPR), method, rules of engagement (active tests allowed, nothing destructive, no data taken out, a single point of contact), deliverables and compliance criteria. Written before the audit, it is then used to judge the report: you can only assess a report by comparing it to what was asked.

The audit (Annex B, PV-02 of October 4, 2026) was a white-box audit, on three layers that complete each other:

Layer	Tool	Result
Network exposure	nmap 7.92	Six hosts and their services mapped; most ports filtered by the local firewalls (the internal scan does not go through pfSense); no old dangerous service (Telnet, FTP, SMBv1)
System hardening	Lynis 3.1.7	Index **69/100** on the Linux server, 253 tests, 0 warnings, 20 suggestions
Configuration compliance	Wazuh SCA	Gaps against the CIS benchmark per agent, including Windows, where Lynis does not run

Finding	Description	Severity
F-01	The hypervisor's management address is on the production segment	High
F-02	Firewall administration is reachable over HTTP	Medium
F-03	The domain controller's RDP is open to the whole segment	Medium to high
F-04	WS-Discovery exposed on TrueNAS	Low
F-05	node_exporter without authentication	Low
F-06	The management plane (SSH, Cockpit) is reachable from the whole segment	Medium
F-07 to F-11	SSH, passwords and umask, unused protocols, removable storage, automatic updates	Low

Assessing the report against the letter (Annex C) concludes that it complies, with one gap that I own: the dedicated vulnerability scan (OpenVAS) planned in the letter could not be run, because the ready-made audit VM did not boot. The other layers provided the coverage, and the gap is recorded as an improvement action.

The EBIOS Risk Manager analysis (Annex D) treats the findings as real vulnerabilities. It identifies four business values, six supporting assets and seven feared events. It keeps four "risk source / target objective" pairs and describes four operational scenarios:

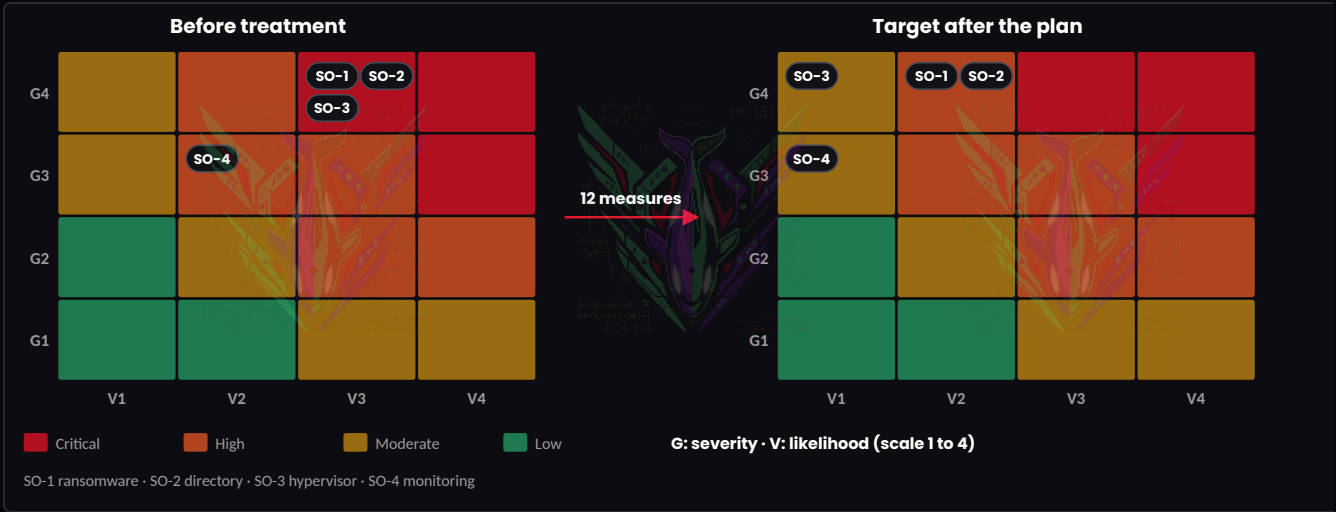


Figure 12 EBIOS RM risk map: starting level and target level after the treatment plan.

Abbreviations — **G / V**: severity (gravité) / likelihood (vraisemblance): the two axes of the EBIOS RM risk map (1 to 4) · **SO-1…SO-4**: operational scenarios of the EBIOS RM analysis · **EBIOS RM**: ANSSI risk analysis method (EBIOS Risk Manager)

Before treatment, three scenarios are critical: ransomware on the SMB share (SO-1), compromise of the directory through RDP (SO-2) and a pivot to the hypervisor (SO-3). All three come from the same flaw: a management plane that is not isolated enough. The treatment plan has twelve measures, from M-01 (dedicated management network) to M-12 (Cockpit hardening). It relies first on what already exists (backup, SIEM, rootless containers). Once applied,

it takes every scenario out of the critical zone. It is a target: today, the hardening measures (M-05 to M-09) are partly applied on the Linux server, and the isolation measures M-01 to M-04 are planned. So the pivot to the hypervisor (SO-3) remains the priority scenario, with a compensating measure. SO-1 and SO-2 will stay high, because their severity comes from the core of the system. They are accepted under watch: backup guarantees recovery and detection guarantees reaction.

The loop closes. Finding F-01 did not stay theoretical. It was the starting point of the simulated attack in PV-03, and then it skewed a remote access test (INC-05). What I take from it: an audit finding left untreated is a real attack path.

◆ 6.3 The security policy and how it is applied (CP9)

A twelve-article security policy (Annex E): purpose and scope, framework and references, organization and roles, asset classification, identities and access, network security and isolation, hardening of systems and containers, data protection, backup and continuity, logging, monitoring and detection, incident management (including escalation to CERT-FR and notification to the CNIL within 72 hours), secrets and cryptography, compliance and continuous improvement. I wrote the rules so they can be checked ("MUST", "MUST NOT"), and I turned them into concrete procedures: command handbook, deployment plan, enrollment and revocation procedures.

Hardening that is measured, not just announced (Annex F). I fixed the Lynis findings on the Linux server, then I ran the audit again:

Finding	Measure applied
F-07	SSH: root login forbidden, forwarding off, three attempts maximum, idle timeouts, detailed logs
F-08	Password policy (lifetimes) and umask 027
F-09	Unused network protocols disabled (dccp, sctp, rds, tipc)
F-10	USB storage disabled
F-11	Automatic updates enabled
F-05	node_exporter port closed on the local firewall
Result	**Lynis index: 69 → 76 / 100**

For the network findings, I made **clear treatment decisions**, as EBIOS workshop 5 requires. F-01 is accepted for now, with a compensating measure (isolated segment, a single operator, active Wazuh detection), until the dedicated management network exists. F-02, F-03, F-04 and F-06 are planned. Accepting a risk does not mean forgetting it: you decide it, you explain why, and you write down the date.

A 3-2-1-0 backup, and a proven restore (Annex G, PV-01). The SMB share has three copies: production on a mirrored ZFS pool, hourly snapshots kept for two weeks, and `zfs send/recv` replication to a second dataset. I simulated a total loss of the data, then restored from the snapshot:

Indicator	Result
RTO, file level	**< 1 second**
RPO	≤ 1 hour (snapshot frequency)
Integrity after restore	**0 errors**, 3 out of 3 SHA-256 hashes match
Integrity of the replicated copy	**0 errors**, 3 out of 3



The report also states its limits. In the lab, the replicated copy is on the same pool. In production, it would go to a remote server: the mechanism is the same, but the “2 media” and “1 off-site copy” criteria are only met in production. Also, restoring by simple copy does not keep ACLs, so I recommend a restore method that preserves them.

An awareness session designed to change habits (Annex H). The short session “Good security habits every day” lasts 45 minutes. It is for two audiences, users and the technical team, with vocabulary suited to each. It covers passwords, phishing, the workstation and remote access, data protection, and how to report an incident. To measure its effect, I plan a five-question quiz at the end, then a fake phishing campaign thirty days later. After incident INC-04, I added an instruction: a configuration QR code contains a secret key, and it must only be read with the WireGuard app.

◆ 6.4 Detecting and handling incidents (CP10)

The detection chain (figure 8) connects the Wazuh agents on the domain controller and the container server to the manager. The manager decodes the logs, applies rules, correlates and classifies events with MITRE ATT&CK. The response follows the security policy: detection, classification, containment, eradication, recovery, closure, then lessons learned.

An exercise: the brute-force attack of PV-03 (Annex I). I launched fifteen SSH login attempts on an account that does not exist, from the hypervisor’s management address (the F-01 vector), against the container server.

Step	What happened
Detection	Wazuh rule 5710 fired 15 times, exactly as many as the attempts; level 10 correlation in under one minute
Classification	MITRE ATT&CK T1110 (brute force), T1110.001 (password guessing), T1021.004 (SSH), T1078 (valid accounts)
Containment	On the targeted host: the traffic stays inside the segment and does not go through pfSense, so blocking happens on the local firewall, which Wazuh active response can automate
Eradication	Treatment of the root cause F-01 decided (accepted for now at freeze); SSH hardened
Recovery	No compromise: the account does not exist, every attempt failed
Lessons learned	Turn on active response, limit SSH to one admin workstation, key-based authentication and MFA, treat F-01 first

A real incident: a private key exposed (INC-04). While enrolling my smartphone, I scanned the administrator profile’s QR code with the camera app instead of the WireGuard app. The camera sent the content to an online search service: the private key had left the phone. I handled it as a real security incident, with the same chain. Classification: a secret tied to a privileged profile, so the key is considered compromised, without waiting for proof that it was used. Containment: I removed the old public key from the firewall right away. Eradication: new key pair, new QR code, enrollment redone with the right app. Recovery: handshake checked with the new key. Lessons learned: instruction added to the awareness session and to the handover. No part of any private key appears in this report.

This incident taught me more than an exercise. It proves in real conditions that revocation works (requirement EF5), and it shows that a human error is handled with the procedure, not by hiding it.

Keeping the evidence. The evidence of an incident is timestamped, sealed with a SHA-256 hash and kept offline. The security policy (article 10.5) covers how it is passed to analysts, escalation to CERT-FR, and notification to the CNIL when personal data is involved.

The incident log (Annex J) applies the same method to every difficulty in the project: symptom, diagnosis, cause, resolution, proof, lesson.

Ref.	Incident	What I learned
INC-01	The TrueNAS installer does not boot	Pick the right firmware for how the console is used
INC-02	Domain join refused (clock, then password)	Kerberos needs clocks synchronized within five minutes
INC-03	Windows monitoring: collectors removed, dashboard incompatible	Never assume software stays stable from one version to the next
INC-04	Exposure of an administrator access private key	An exposed secret is a compromised secret
INC-05	Remote access test skewed by the hypervisor's position	A remote access test starts from a truly external device
INC-06	WireGuard tunnel with no return path, because of duplicate *Allowed IPs*	A green light does not prove traffic gets through
INC-07	Replies not routed back into the tunnel: interface without a fixed address	Two causes can produce the same symptom; fixing the first one proves nothing

A threat watch that makes detection evolve (Annex K). It starts from the infrastructure inventory and prefers primary sources: CERT-FR, ANSSI, CVE and NVD, CISA's Known Exploited Vulnerabilities catalog, vendors, MITRE ATT&CK, the CNIL. Each piece of information is qualified, then I decide (fix, compensate or accept), I record it in a register and, when an attack technique is involved, I turn it into a detection rule. One example: Wazuh's default correlation tolerates eight failures in two minutes. For an infrastructure of this size, I deployed a stricter local rule (100100, level 12, five attempts in sixty seconds). I replayed the PV-03 attack on October 11: the alert fired in two seconds, from the fifth attempt, linked to MITRE technique T1110.001 (PV-04).

07

CHAPTER 7

Working with stakeholders

Who the project is built with, and how I adapt my writing to each reader.

Cross-cutting

7. Relations with the main stakeholders

I ran this project alone, but it concerns several people. Each one gets information suited to their role and technical level, and always in writing, to keep a record.

Stakeholder	Role	Exchanges and documents
Management, client (INFRASEC IT management, fictitious)	States the need, decides the budget	Requirements and TCO for approval; deployment plan for authorization; monthly threat watch summary
CISO	Security authority	Approves the security policy; authorizes active tests (engagement letter); decides risk treatment (F-01 accepted for now); receives incident escalation
Users: remote employees, traveling administrator	Those the change is made for	Notice before the change; enrollment of their device; usage instructions; awareness session; incident reporting
Auditor (internal, or a PASSI-qualified provider)	Measures the security level	Mandated by the engagement letter; delivers the report; assessed against the letter
Operations team	Runs the service over time	Command handbook, bilingual operations manual, commented demo, enrollment and revocation procedures
Vendors and communities (Netgate, Microsoft, Wazuh, Grafana…)	Provide the software	Security advisories and release notes, followed by the threat watch
ANSSI, CERT-FR, CNIL	Authorities and references	Frameworks and alerts; escalation of a major incident; notification of a personal data breach

Writing for the right reader. I do not write the same way for everyone. For the client, I talk about requirements and measurable criteria. For the operator, I write step-by-step procedures. For the user, I give simple, concrete instructions. The awareness material uses no technical word without explaining it. The command handbook only contains commands I have checked.

The real people. Outside the fictitious company, the project was built with my trainer and the program advisor of the training, whose assessments set the pace of the skills, and with my tutor during my internship, where I worked on automating infrastructure deployment.

08

CHAPTER 8

Summary and conclusion

Results against the goals, what I learned, the limits I own, and what comes next.

Review

8. Summary and conclusion

8.1 Results against the goals

Goal	Result	Proof
Design a change that meets the need	Zero-Trust remote access specified, four solutions compared, WireGuard chosen (4.85/5), TCO of €4,610 over 3 years	Ch. 2 and 4
Put it into production without risk to what exists	Additive change, eleven steps out of eleven validated, acceptance test passed on Oct 11, written rollback, timed revocation	Ch. 5, Annex O
Monitor	Justified indicators, dashboards, firewall monitored over SNMP, tested alert	Ch. 6.1
Measure security	Audit compliant with its engagement letter, 11 findings, EBIOS RM with a plan that leaves no critical scenario (target)	Ch. 6.2
Apply the policy	Security policy, Lynis 69 → 76, restore in under one second with no errors, awareness session ready	Ch. 6.3
Detect and handle	Attack detected in under one minute, local rule alerting in two seconds, real incident handled, seven incidents documented, threat watch organized	Ch. 6.4

8.2 What the project taught me

A green light proves nothing. The WireGuard tunnel came up while no reply could get back to the employee (INC-06), and the acceptance test showed a second cause for the same symptom (INC-07). Today, I no longer take a displayed state as proof. I validate on real traffic, observed end to end.

An exposed secret is a compromised secret. When the key was read by the camera app (INC-04), the right decision was not to estimate the risk, but to revoke right away. It worked because the architecture makes revocation simple: removing a public key is enough.

Test from the right place. A test run from the hypervisor "succeeded" by going around the tunnel (INC- 05). A test that cannot fail teaches nothing.

Accepting a risk is a decision. I did not fix finding F-01 before the oral exam, because today it carries the only management path. I accepted it for now, explaining why, with a compensating measure, and the decision is dated in the freeze report (Annex F). That is very different from forgetting it.

8.3 Limits I own

- The hypervisor's management plane is still on the production segment (F-01), until the dedicated management network exists (M-01).
- The dedicated vulnerability scan (OpenVAS) planned in the engagement letter was not run. Coverage was provided another way.
- In the lab, the replicated backup copy is on the same pool. In production, it would go to a remote site.
- The administrator profile rule still covers the whole internal segment. I need to limit it to the management interfaces, then retest this profile with the acceptance client.
- Remote access has no multi-factor authentication yet, and SNMP is still version 2c (protected, but the target is v3).

- Alerts show in Grafana but are not sent by email yet, for lack of a mail server.
- Changing the Wazuh administrator password is still to be done.

8.4 Next steps

Short term: the dedicated management network and the removal of F-01 (M-01), narrowing the remote access administrator rule, restricting RDP (M-02), firewall administration over HTTPS only (M-04), and changing the Wazuh administrator password. Medium term: multi-factor authentication on remote access, SNMP v3, a regular vulnerability scan, automatic active response, sending alerts, and a Wazuh upgrade after testing. Later: a second firewall for redundancy (CARP) to go beyond the availability target, and taking client device posture into account.

8.5 Conclusion

This project took me from building an infrastructure to running it. I learned to turn a need into measurable requirements, to compare solutions with a method, to cost them honestly, to go to production without putting what exists at risk, and then to measure, decide and react. The results that matter most to me are the ones I can prove: a timed restore, a hardening index that goes up, an attack detected in under one minute, access revoked within one second, a real incident handled by revoking a key.

C3

CCP3 COMPLEMENT

October 2026: operations, incidents and detection

The work done from 21 to 26 October after the oral exam: answers to the jury, architecture per machine, 18 sheets, 5 reports, one procedure.

CP8 CP9 CP10

CHAPTER

C1

Context and answers to the jury

What this report proves, and how it answers the five remarks made at the oral exam of 21/10/2026.

CCP3 CP8 CP9 CP10

C1 · Context and answers to the jury

C1.1 Purpose of the report

This report presents the work done on the Hybrid InfraSec lab for the certificate "Taking part in cybersecurity management" (CCP3) of the AIS title. After the oral exam of 21/10/2026, I went back to the lab for six days, from 21 to 26 October, with one simple rule: each remark from the jury had to lead to real work, measured and proven, not to one more paragraph.

The result is **18 incident and finding sheets** (INC-08 to INC-11, F-13 to F-26), **5 implementation reports** (PV-05 to PV-09) and **1 procedure** (PROC-01). Every sheet follows the same plan: finding, root cause, fix, proof, lesson. Every fix is proven by a test replayed afterwards, from a third machine when filtering is involved. The full sheets are in the annex.

All evidence was collected on the real lab, from the machines' logs, on the command line. Times marked "UTC" come from the SIEM, whose clock runs in universal time; the others are Paris time.

C1.2 Answers to the jury's remarks

Jury remark	What I did	Where to check
Logs read through the graphical interface	All evidence is collected on the command line: `journalctl --list-boots` then `-b -N`, `zgrep` on archives, `grep` in `alerts.json`, `midclt call audit.query`, `journalctl -t lab`. The Windows domain controller is administered over SSH from the hypervisor, with a key only.	INC-11, F-14, F-19, F-20, PV-06, PV-07
Architecture per machine	One overall network schema, layer by layer (OSI), then one sheet per machine: table, network flow schema, flowchart of what happens inside.	Chapters 2 and 3
The 10 virtual employees	INFRASEC company created by an idempotent script from a single `employes.csv` file: 6 departments, 10 employees, AGDLP model, shares tested with 6 accesses including 2 denials, and the same company replayed on a second Samba domain.	Chapter 4, PV-05, PV-06, PV-08
Confusion between availability and security	A dedicated section (1.3) and several sheets where a security measure broke availability, or the other way round, with how both were reconciled.	1.3, INC-08, F-22, F-23, F-24
Abbreviations (CERT, G/V on figures)	Under every figure, the list of all the abbreviations it contains. CERT: Computer Emergency Response Team. G/V: gravité and vraisemblance, i.e. severity and likelihood, the two axes of the EBIOS RM risk map. Full glossary in chapter 9.	All figures, chapter 9

C1.3 Availability and security: the distinction I use

Security protects the confidentiality, integrity and traceability of information. **Availability** ensures the service answers when it is needed. In the classic triad, availability is part of security; but in operations, the two goals often pull in opposite directions. They are not opposed: they are designed together, and a good measure protects without breaking anything.

Situation	The measure that broke the other goal	The measure kept
Hypervisor Cockpit (INC-08)	Binding the service to an address: the console disappears as soon as the network changes (availability lost).	Restricting access with the firewall; the service listens everywhere, only the source is filtered.

Situation	The measure that broke the other goal	The measure kept
SIEM certificate authority key (F-22)	Destroying it: no certificate could ever be renewed (future availability lost). Keeping it in clear: confidentiality lost.	Keeping it AES-256 encrypted, off the SIEM, in the host vault.
Hypervisor memory (F-23)	Reducing all machines blindly: the SIEM, already tight, would have failed.	Measuring each machine, reducing only the two oversized ones.
Account lockout (F-24)	The lockout threshold protects against brute force, but a slow attacker can lock every account (denial of service).	Keeping the threshold and making the lockout itself raise an alert (rule 100320).
Lab backup (PV-09)	A backup that can be modified can be encrypted by ransomware.	A read-only backup: available for restore, untouchable for an attacker.

C2

CHAPTER

Lab architecture

One hypervisor, seven virtual machines, a single exit: the firewall. The overall schema, layer by layer.

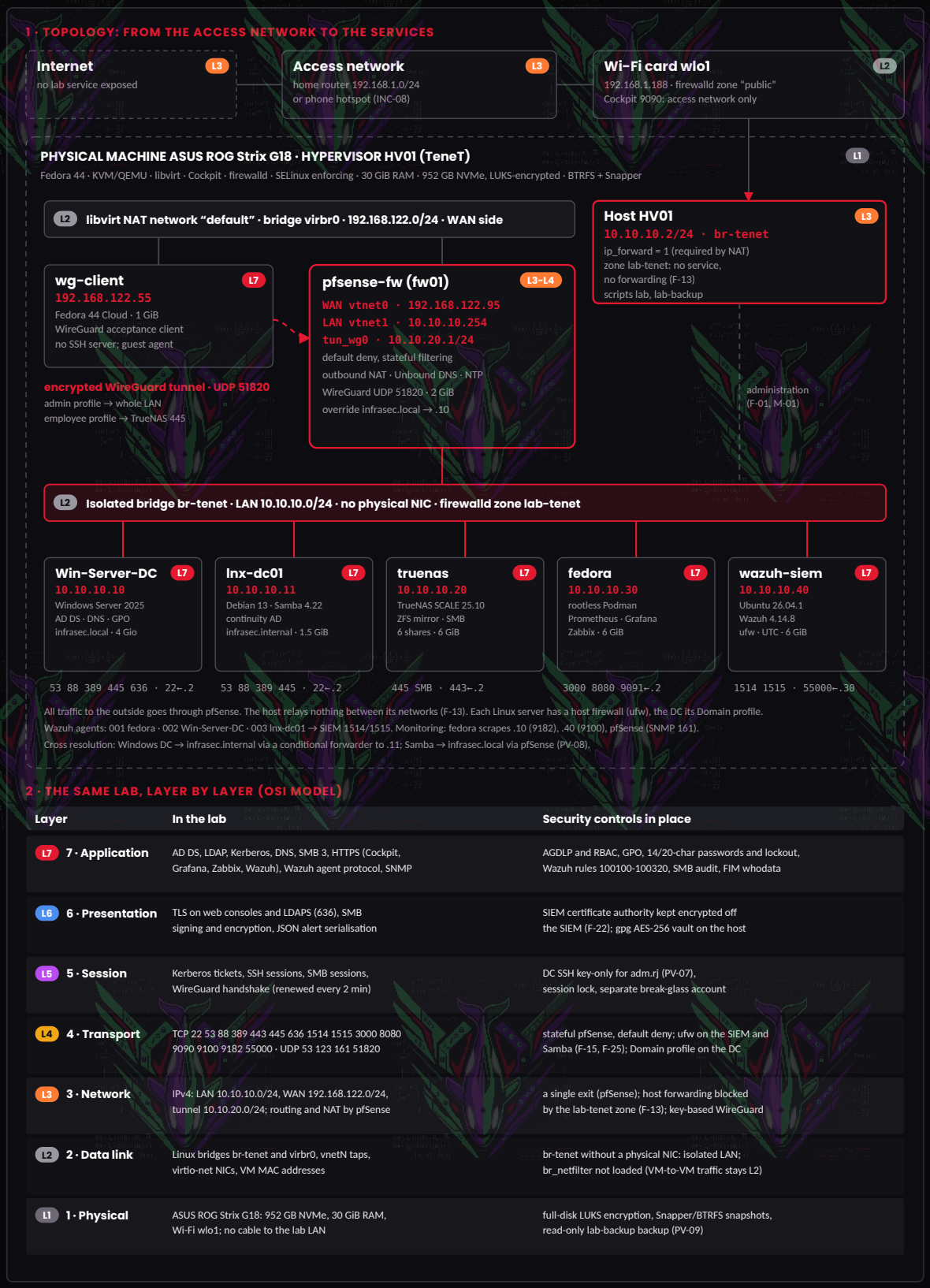
OSI L1 → L7 | HV01 | br-tenet

C2 · Lab architecture

C2.1 Overview

The lab runs on a single hypervisor, **HV01** (host name TeneT): an ASUS ROG Strix G18 laptop running Fedora 44, with KVM and libvirt, 30 GiB of memory and a 952 GB NVMe disk encrypted with LUKS. The virtual machines share an isolated network, `10.10.10.0/24`, carried by the `br-tenet` bridge, which has no physical card. Only pfSense touches the outside, through the hypervisor's `virbr0` NAT network.

The schema below reads in two steps: first the topology, from the access network to the services; then the same lab layer by layer, from the hardware (layer 1) to the applications (layer 7), with for each layer what exists and the security controls in place.



2 · THE SAME LAB, LAYER BY LAYER (OSI MODEL)

Layer	In the lab	Security controls in place
L7 7 · Application	AD DS, LDAP, Kerberos, DNS, SMB 3, HTTPS (Cockpit, Grafana, Zabbix, Wazuh), Wazuh agent protocol, SNMP	AGDLP and RBAC, GPO, 14/20-char passwords and lockout, Wazuh rules 100100-100320, SMB audit, FIM whodata
L6 6 · Presentation	TLS on web consoles and LDAPS (636), SMB signing and encryption, JSON alert serialisation	SIEM certificate authority kept encrypted off the SIEM (F-22); gpg AES-256 vault on the host
L5 5 · Session	Kerberos tickets, SSH sessions, SMB sessions, WireGuard handshake (renewed every 2 min)	DC SSH key-only for adm.rj (PV-07), session lock, separate break-glass account
L4 4 · Transport	TCP 22 53 88 389 443 445 636 1514 1515 3000 8080 9090 9100 9182 55000 · UDP 53 123 161 51820	stateful pfSense, default deny; ufw on the SIEM and Samba (F-15, F-25); Domain profile on the DC
L3 3 · Network	IPv4: LAN 10.10.10.0/24, WAN 192.168.122.0/24, tunnel 10.10.20.0/24; routing and NAT by pfSense	a single exit (pfSense); host forwarding blocked by the lab-tenet zone (F-13); key-based WireGuard
L2 2 · Data link	Linux bridges br-tenet and virbr0, vnetN taps, virtio-net NICs, VM MAC addresses	br-tenet without a physical NIC: isolated LAN; br_netfilter not loaded (VM-to-VM traffic stays L2)
L1 1 · Physical	ASUS ROG Strix G18: 952 GB NVMe, 30 GiB RAM, Wi-Fi wlo1; no cable to the lab LAN	full-disk LUKS encryption, Snapper/BTRFS snapshots, read-only lab-backup backup (PV-09)

Figure 13 Overall network architecture of the Hybrid InfraSec lab: full topology and a layer-by-layer reading of the OSI model (as of 26/10/2026).

Abbreviations — **L1…L7**: OSI layers: 1 physical, 2 data link, 3 network, 4 transport, 5 session, 6 presentation, 7 application · **OSI**: 7-layer reference model (Open Systems Interconnection) · **HV01**: lab hypervisor, host name TeneT · **KVM**: Kernel-based Virtual Machine · **LUKS**: Linux Unified Key Setup, full-disk encryption · **BTRFS**: B-tree file system, with snapshots · **NAT**: Network Address Translation · **WAN**: outside of the firewall (NAT network 192.168.122.0/24) · **LAN**: lab local network 10.10.10.0/24 · **WG**: WireGuard: encrypted VPN tunnel, UDP port 51820 · **DNS**: Domain Name System · **NTP**: Network Time Protocol · **AD DS**: Active Directory Domain Services · **LDAP**: Lightweight Directory Access Protocol · **SMB**: Server Message Block file sharing, port 445 · **SNMP**: Simple Network Management Protocol, UDP port 161 · **TLS**: Transport Layer Security · **SSH**: Secure Shell remote administration, port 22 · **GPO**: Group Policy Object · **AGDLP**: Accounts → Global groups → Domain Local groups → Permissions · **RBAC**: Role-Based Access Control · **FIM**: File Integrity Monitoring · **whodata**: Wazuh FIM mode that also records the user and the process · **TCP / UDP**: transport protocols, connection-oriented or not · **ufw**:

Debian/Ubuntu host firewall (Uncomplicated Firewall) · **DC**: Domain Controller · **SIEM**: Security Information and Event Management · **VM**: virtual machine · **Gio / Go**: gibibytes (memory, 2^{30} bytes) / gigabytes (disk, 10^{9} bytes) · **agent invité**: QEMU guest agent: service in the VM that takes orders from the hypervisor

C2.2 The machines

Machine	Role	Address	Memory
`pfsense-fw` (`fw01`)	Firewall, gateway, recursive DNS, NTP, WireGuard VPN	`10.10.10.254`	2 GiB
`Win-Server-DC` (`dc01`)	Controller of the `infrasec.local` domain, Windows Server 2025	`10.10.10.10`	4 GiB
`lnx-dc01`	Samba controller of the continuity domain `infrasec.internal`	`10.10.10.11`	1.5 GiB
`truenas`	Storage: mirrored `tank` pool, SMB shares per department	`10.10.10.20`	6 GiB
`fedora`	Monitoring: Prometheus, Grafana, Zabbix in rootless Podman	`10.10.10.30`	6 GiB
`wazuh-siem`	Wazuh 4.14.8 SIEM: manager, indexer, dashboard	`10.10.10.40`	6 GiB
`wg-client`	WireGuard tunnel client (simulated remote access)	`192.168.122.55`	1 GiB

The whole lab takes its time from pfSense, except the SIEM, which follows Canonical's NTP servers and runs its clock in UTC. The Windows domain's DNS is the domain controller; the Samba domain's DNS is `lnx-dc01`, and resolution between the two domains is in place (PV-08).

C2.3 Allowed administration and collection flows

Source	Destination	Port	Use
Host `10.10.10.2`	SIEM	22, 443, 9090	SSH, Wazuh dashboard, Cockpit
Host `10.10.10.2`	Windows domain controller	22	PowerShell over SSH, `adm.rj` key only (PV-07)
Host `10.10.10.2`	`lnx-dc01`	22	Samba domain administration
Network `10.10.10.0/24`	SIEM	1514, 1515	agent events and enrolment
`fedora`	SIEM	55000, 9100	Zabbix API check, Prometheus metrics
`fedora`	pfSense	UDP 161	SNMP restricted to the collector
Network `10.10.10.0/24`	`lnx-dc01`	53, 88, 389, 445, 464, 636, 3268-3269, RPC	Samba directory services

Any other inbound flow to the SIEM and to `lnx-dc01` is denied by default (F-15, F-25). Every rule was checked from a third machine, never from the target: a test run from the target goes through the loopback and cannot fail.

C2.4 Hypervisor capacity

Before adding the Samba controller, I measured memory machine by machine (F-23). The host was using 4 GiB of swap with 29 GiB allocated out of 30. I reduced the two oversized machines based on their real usage; the SIEM, the tightest machine, was left untouched.

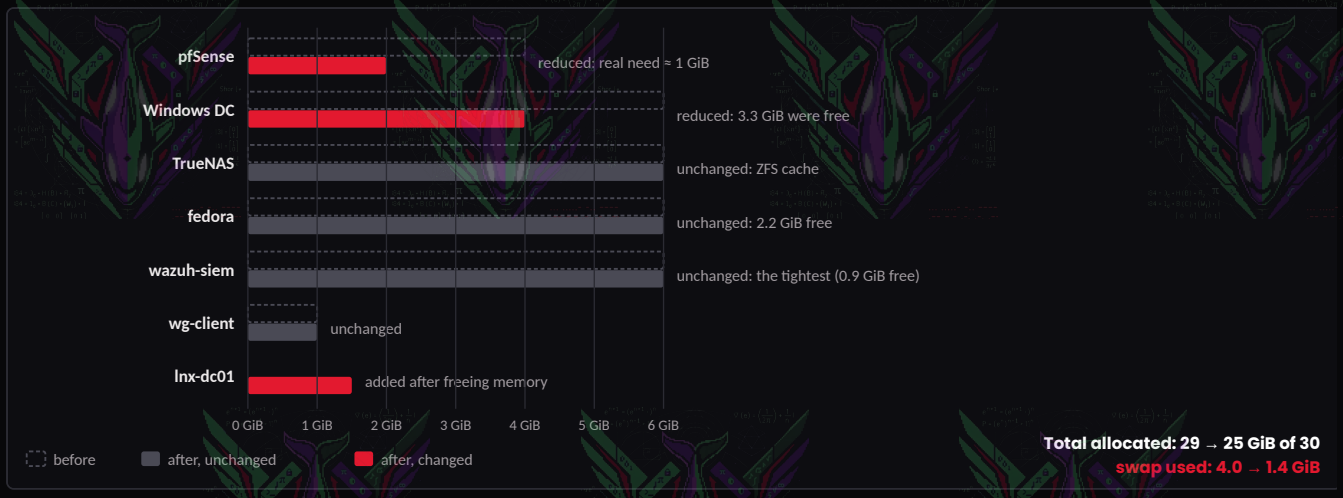


Figure 14 Memory allocated per machine, before and after the fix of 25/10 (F-23).

Abbreviations — **Gio / Go**: gibibytes (memory, 2^{30} bytes) / gigabytes (disk, 10^{9} bytes) · **ZFS**: TrueNAS file system, with mirror and snapshots · **VM**: virtual machine

◆ C2.5 Starting and stopping the lab in the right order

The lab is off at night. Started in the wrong order, it failed silently: the SIEM, faster than Windows, fetched its vulnerability feed before the domain controller's DNS answered (F-14). The `lab` script now starts the machines in dependency order and waits for a **real** answer from each service before moving on. To stop, it uses the QEMU guest agent when the machine has one, the ACPI signal otherwise, and never forces anything (F-26). On 26/10, all 7 machines shut down cleanly in 66 seconds, against three refusals from the Windows controller before.

CHAPTER

C3

Architecture per machine

For each machine: its sheet, the schema of its network flows and the flowchart of what happens inside.

8 sheets · network · flowchart

C3 · Architecture per machine

This chapter answers the jury's remark on the architecture per machine directly. Each sheet has three parts: a table (role, measured configuration, filtering, monitoring, related sheets), the schema of its network flows (who can reach it, on which port, and what it contacts itself), then the flowchart of the main work it does. Units are written in full: GB for disk, GiB for memory, vCPU for a virtual processor.

C3.1 Hypervisor HV01 (TeneT)

Role	hosts the 7 VMs; administration workstation
Hardware	ASUS ROG Strix G18, 30 GiB memory, 8 GiB swap
System	Fedora 44, KVM/libvirt, Cockpit, SELinux enforcing
Storage	LUKS 952 GB (425 GB free), BTRFS, Snapper; /vm/images, /vm/iso (19 GB after clean-up)
Network	br-tenet 10.10.10.2/24 (NetworkManager, INC-10); virbr0 192.168.122.0/24; wlo1
Filtering	zone lab-tenet with no service or forwarding (F-13); Cockpit 9090 limited to the access network (INC-08)
Operations	lab (ordered start/stop), lab-backup (PV-09), vault ~/coffre (F-22)
Sheets	INC-08, INC-10, F-13, F-14, F-22, F-23, F-26, PV-09



Figure 15 Network flows of HV01 · TeneT: allowed sources on the left, destinations on the right.

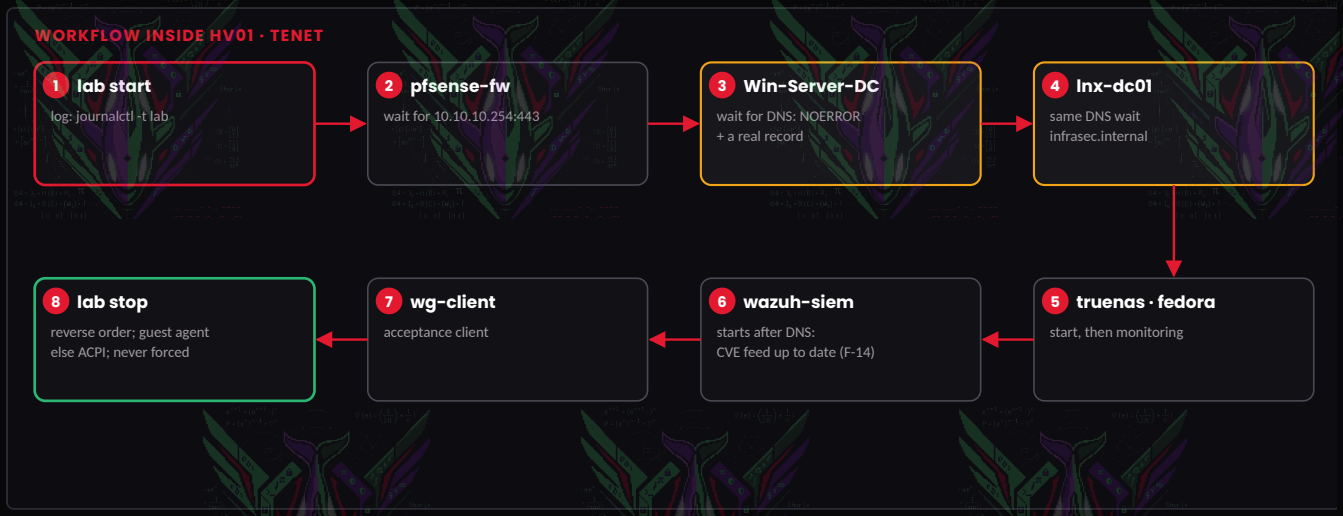


Figure 16 Host operations flowchart: dependency-ordered start then clean shutdown (lab script).

Abbreviations (figures 15 and 16) — **HV01**: lab hypervisor, host name TeneT · **KVM**: Kernel-based Virtual Machine · **LUKS**: Linux Unified Key Setup, full-disk encryption · **BTRFS**: B-tree file system, with snapshots · **LAN**: lab local network 10.10.10.0/24 · **WAN**: outside of the firewall (NAT network 192.168.122.0/24) · **DNS**: Domain Name System · **SSH**: Secure Shell remote administration, port 22 · **ACPI**: power signal emulated by the hypervisor (Advanced Configuration and Power Interface) · **agent invité**: QEMU guest agent: service in the VM that takes orders from the hypervisor · **CVE**: Common Vulnerabilities and Exposures · **VM**: virtual machine · **L1...L7**: OSI layers: 1 physical, 2 data link, 3 network, 4 transport, 5 session, 6 presentation, 7 application · **Gio / Go**: gibibytes (memory, 2^{30} bytes) / gigabytes (disk, 10^{9} bytes) · **INC / F**: incident sheet / finding sheet · **PV**: implementation or acceptance report

C3.2 Firewall pfsense-fw (fw01)

Role	firewall, gateway, recursive DNS (Unbound), time source, WireGuard VPN
Resources	2 GiB memory (F-23)
Addresses	LAN 10.10.10.254; WAN 192.168.122.95 on virbr0; tun_wg0 10.10.20.1/24 (WG_REMOTE)
DNS	Domain Override infrasec.local → 10.10.10.10 (PV-08)
Administration	web UI 443 from the LAN; HTTP 80 closed since the audit
Backup	encrypted XML export, stored in the host vault
Watch point	ISC DHCP end of life reported: move to Kea
Sheets	F-13, F-14, PV-08

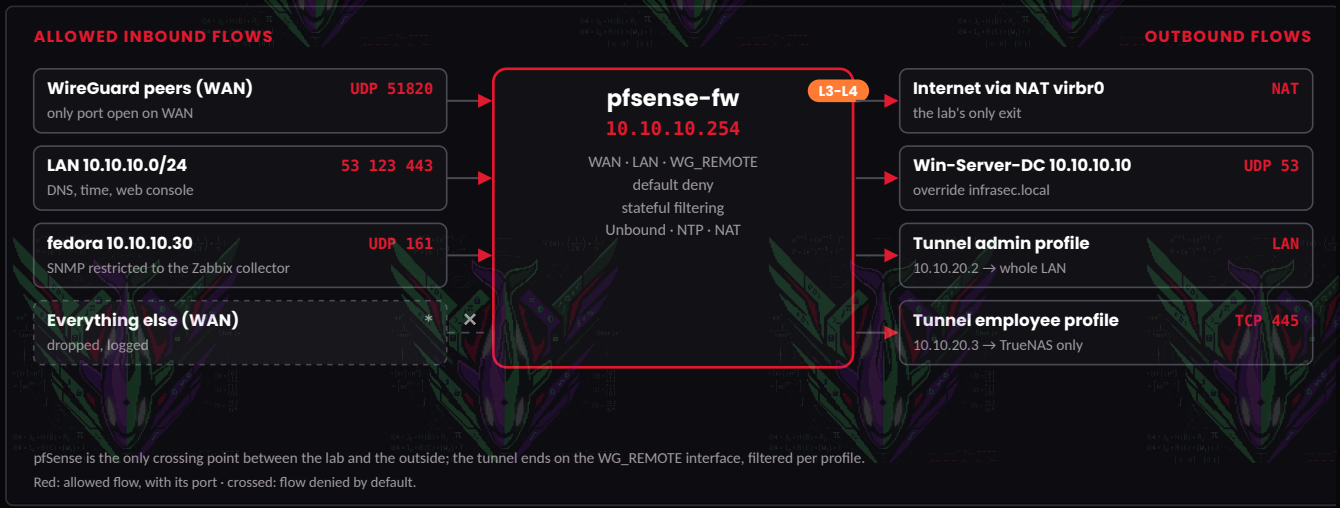


Figure 17 Network flows of pfsense-fw (fw01): allowed sources on the left, destinations on the right.

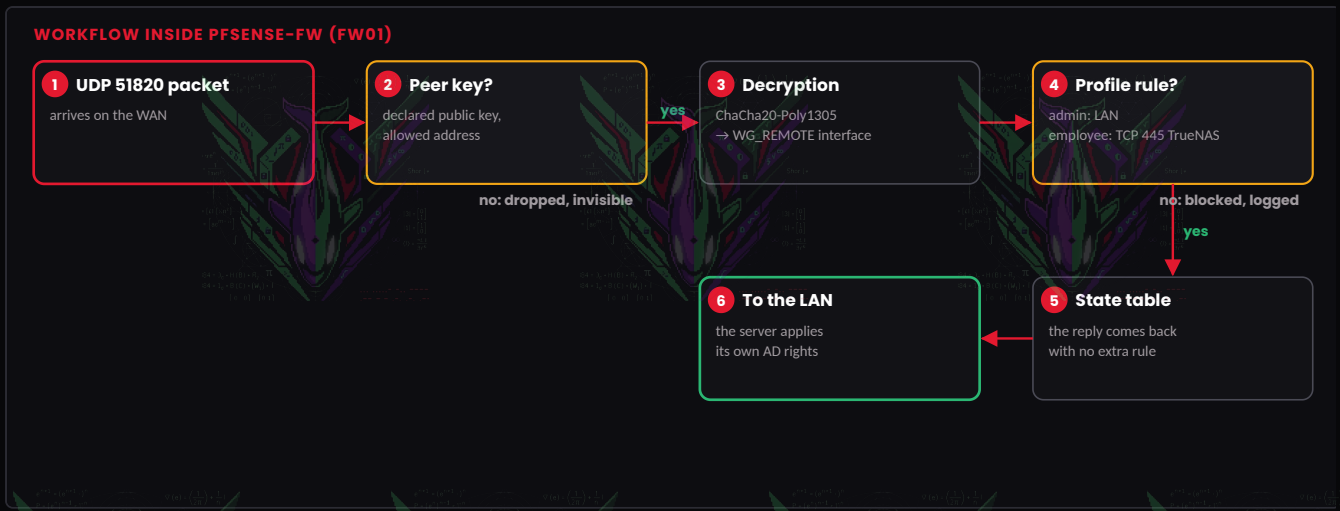


Figure 18 Flowchart of how pfSense handles a remote connection: key, profile rule, state.

Abbreviations (figures 17 and 18) — **WAN**: outside of the firewall (NAT network 192.168.122.0/24) · **LAN**: lab local network 10.10.10.0/24 · **WG**: WireGuard: encrypted VPN tunnel, UDP port 51820 · **NAT**: Network Address Translation · **DNS**: Domain Name System · **NTP**: Network Time Protocol · **SNMP**: Simple Network Management Protocol, UDP port 161 · **TCP / UDP**: transport protocols, connection-oriented or not · **L1...L7**: OSI layers: 1 physical, 2 data link, 3 network, 4 transport, 5 session, 6 presentation, 7 application · **Gio / Go**: gibibytes (memory, 2^{30} bytes) / gigabytes (disk, 10^{9} bytes) · **AD DS**: Active Directory Domain Services · **INC / F**: incident sheet / finding sheet · **PV**: implementation or acceptance report

C3.3 Domain controller Win-Server-DC (dc01)

Role	controller of infrasec.local (NetBIOS INFRASEC), DNS, global catalogue
System	Windows Server 2025 Standard, evaluation (ends around 27/03/2027, one rearm left)
Resources	4 GiB, 4 vCPU, UEFI, 60 GB disk
Directory	12 accounts, 27 groups (AGDLP, ROLE_), 14-char passwords and lockout, PSO-Admins 20 (F-24)
Hardening	GPO “DC - Navigation interdite” (F-17); OpenSSH limited to 10.10.10.2, adm.rj key only (PV-07)
DNS	conditional forwarder infrasec.internal → 10.10.10.11 (PV-08)
Monitoring	Wazuh agent 002; whodata FIM of the StartUp folder (F-19); windows_exporter 9182; QEMU guest agent
Watch point	17 internal snapshots (124 GB on the host for a 60 GB disk): to prune
Sheets	PV-05, PV-07, PV-08, F-17, F-18, F-19, F-24, F-26

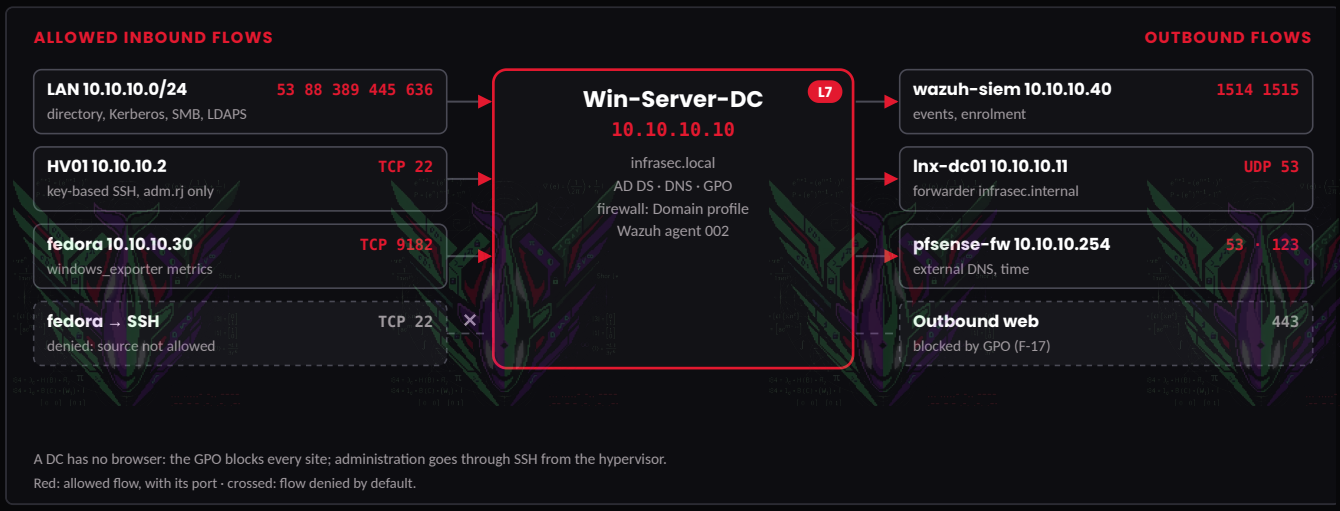


Figure 19 Network flows of Win-Server-DC (dc01): allowed sources on the left, destinations on the right.

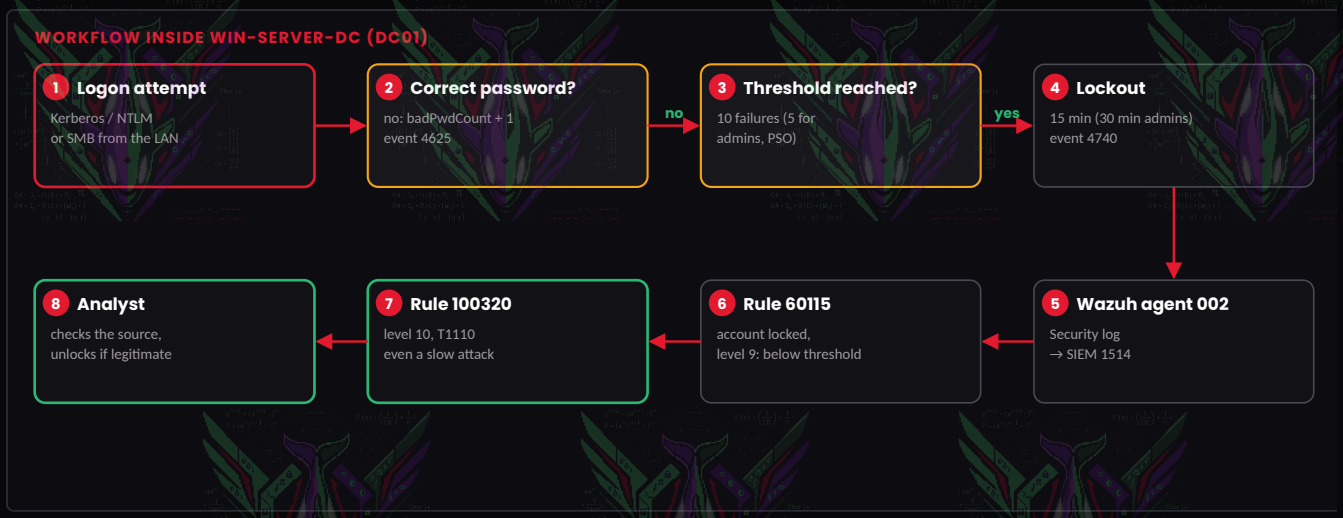


Figure 20 Flowchart of an authentication failure on the DC, up to the SIEM alert (F-24).

Abbreviations (figures 19 and 20) — **DC**: Domain Controller · **AD DS**: Active Directory Domain Services · **DNS**: Domain Name System · **GPO**: Group Policy Object · **LDAP**: Lightweight Directory Access Protocol · **SMB**: Server Message Block file sharing, port 445 · **SSH**: Secure Shell remote administration, port 22 · **PSO**: fine-grained Password Settings Object · **MITRE ATT&CK**: public catalogue of attack techniques; T1110 brute force, T1547.001 boot persistence, T1562.001 impair defenses · **FIM**: File Integrity Monitoring · **whodata**: Wazuh FIM mode that also records the user and the process · **LAN**: lab local network 10.10.10.0/24 · **L1…L7**: OSI layers: 1 physical, 2 data link, 3 network, 4 transport, 5 session, 6 presentation, 7 application · **vCPU**: virtual CPU · **UEFI**: boot firmware · **Gio / Go**: gibibytes (memory, 2^{30} bytes) / gigabytes (disk, 10^{9} bytes) · **agent invité**: QEMU guest agent: service in the VM that takes orders from the hypervisor · **INC / F**: incident sheet / finding sheet · **PV**: implementation or acceptance report

C3.4 Continuity controller lnx-dc01 (Samba AD)

Role	controller of the continuity domain infrasec.internal (NetBIOS INFRALNX)
System	minimal Debian 13.7, Samba 4.22 (internal DNS)
Resources	1.5 GiB, 2 vCPU, 12 GB disk
Directory	same company as dc01 (same employes.csv, 7228c38a…); same password policy (F-24)
System accounts	rj with sudo; root locked
Time / DNS	pfSense only; DNS forwarding to pfSense
Filtering	ufw: SSH from the host, directory from the LAN, NetBIOS closed (F-25)
Monitoring	Wazuh agent 003 (same version as the manager, held)
Sheets	PV-08, F-24, F-25, PROC-01

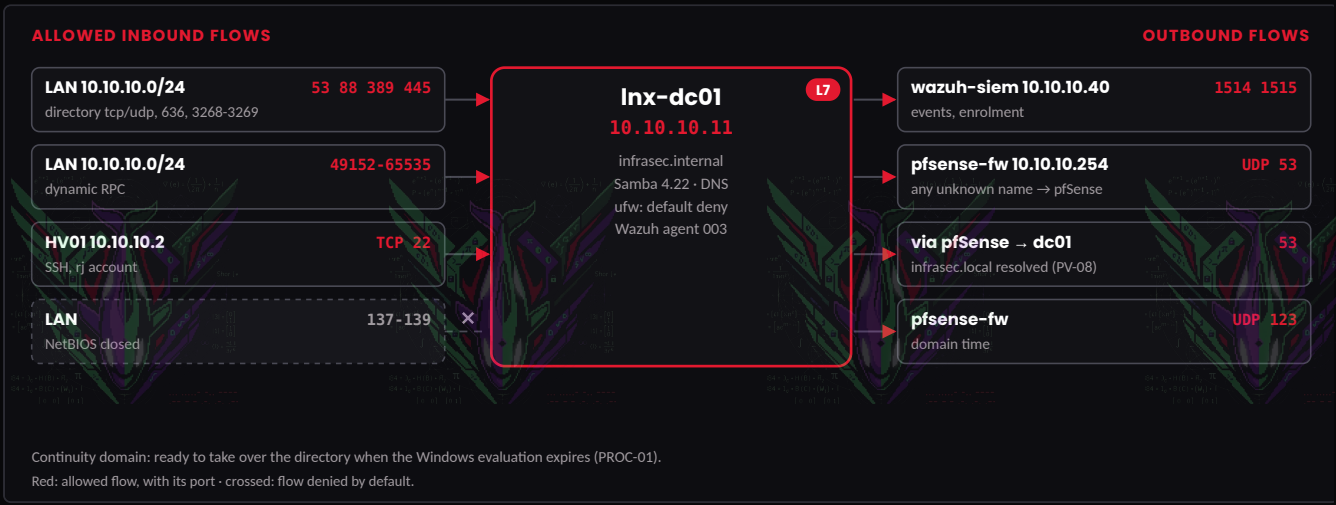


Figure 21 Network flows of lnx-dc01: allowed sources on the left, destinations on the right.

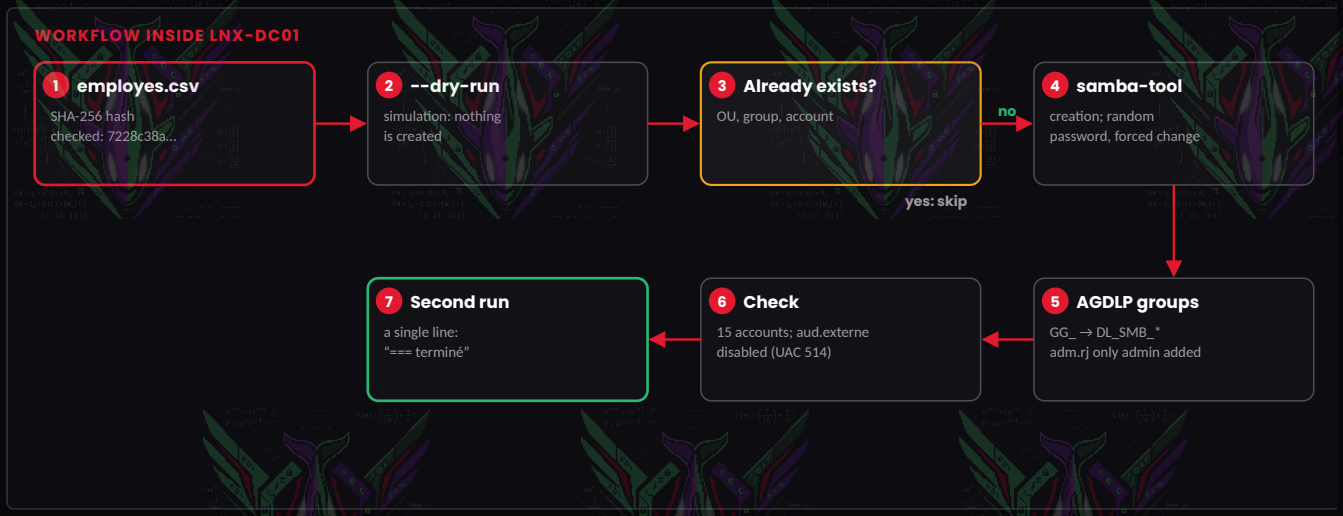


Figure 22 Flowchart of the idempotent provisioning of the company on the Samba domain (PV-08).

Abbreviations (figures 21 and 22) — **AD DS**: Active Directory Domain Services · **DNS**: Domain Name System · **LDAP**: Lightweight Directory Access Protocol · **SMB**: Server Message Block file sharing, port 445 · **RPC**: Remote Procedure Call (dynamic ports 49152-65535) · **ufw**: Debian/Ubuntu host firewall (Uncomplicated Firewall) · **OU**: Organizational Unit · **AGDLP**: Accounts → Global groups → Domain Local groups → Permissions · **GG_**: prefix of global groups: who people are (their department) · **DL_**: prefix of domain local groups: what the group allows on a share · **SHA-256**: 256-bit cryptographic hash · **LAN**: lab local network 10.10.10.0/24 · **vCPU**: virtual CPU · **Gio / Go**: gibibytes (memory, 2^{30} bytes) / gigabytes (disk, 10^{9} bytes) · **L1...L7**: OSI layers: 1 physical, 2 data link, 3 network, 4 transport, 5 session, 6 presentation, 7 application · **INC / F**: incident sheet / finding sheet · **PV**: implementation or acceptance report

C3.5 Storage truenas

Role	storage of the company shares
System	TrueNAS SCALE 25.10
Resources	6 GiB; tank pool, ZFS mirror (2 × 40 GB)
Address	10.10.10.20; joined to the INFRASEC domain
Shares	tank/entreprise (not shared) and 5 SMB shares per department, AGDLP rights (PV-05)
Backup	hourly recursive ZFS snapshots, kept 2 weeks; restore proven (PV-06)
Traceability	file access audit on the 6 shares (F-20)
Sheets	PV-05, PV-06, F-20

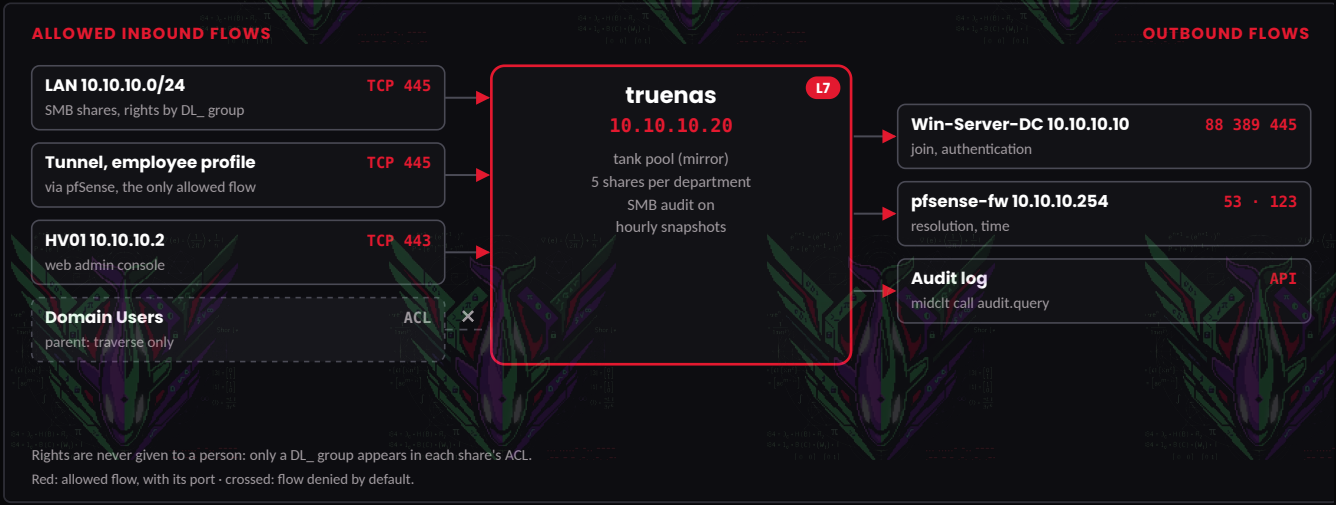


Figure 23 Network flows of truenas: allowed sources on the left, destinations on the right.

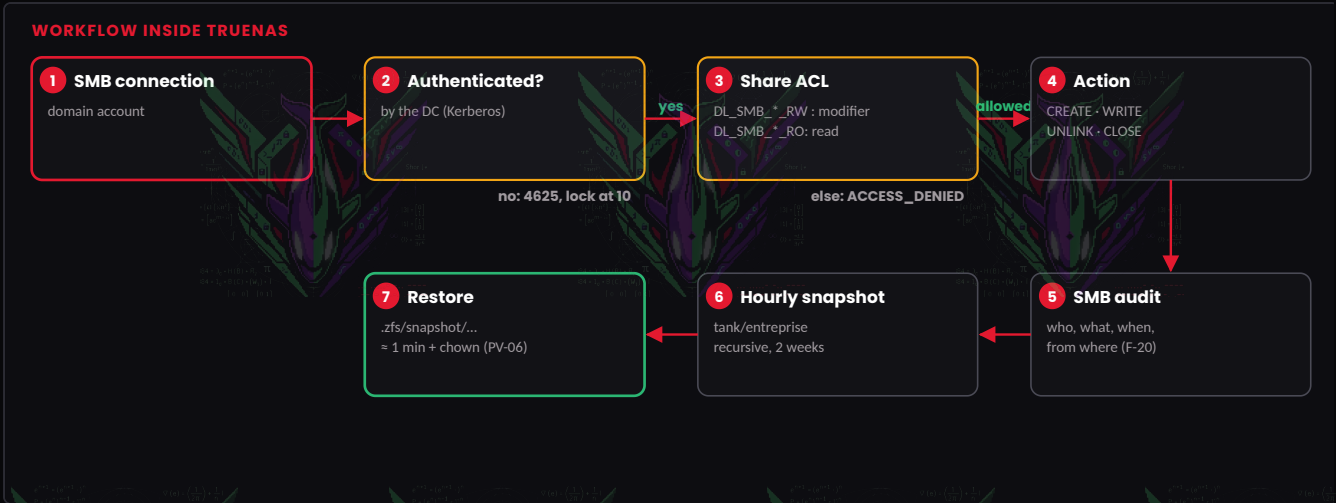


Figure 24 Flowchart of a share access: authentication, group ACL, audit, snapshot, restore.

Abbreviations (figures 23 and 24) — **SMB**: Server Message Block file sharing, port 445 · **ZFS**: TrueNAS file system, with mirror and snapshots · **ACL**: Access Control List · **DL_**: prefix of domain local groups: what the group allows on a share · **AGDLP**: Accounts → Global groups → Domain Local groups → Permissions · **DC**: Domain Controller · **API**: Application Programming Interface · **LAN**: lab local network 10.10.10.0/24 · **L1...L7**: OSI layers: 1 physical, 2 data link, 3 network, 4 transport, 5 session, 6 presentation, 7 application · **Gio / Go**: gibibytes (memory, 2^{30} bytes) / gigabytes (disk, 10^{9} bytes) · **INC / F**: incident sheet / finding sheet · **PV**: implementation or acceptance report

C3.6 Monitoring node fedora

Role	monitoring (metrics and availability)
Resources	6 GiB memory
Address	10.10.10.30
Services	rootless Podman (ais account, linger), Quadlet units: Prometheus 9091, Grafana 3000, node-exporter, Zabbix 8080 (PostgreSQL, Podman secret, SELinux label :Z)
Checks	Linux and Windows metrics; disk > 80 % alert (F-16); SIEM ports 55000 and 1514 (INC-11); firewall SNMP
Monitoring	Wazuh agent 001
Sheets	INC-09, INC-11, F-16

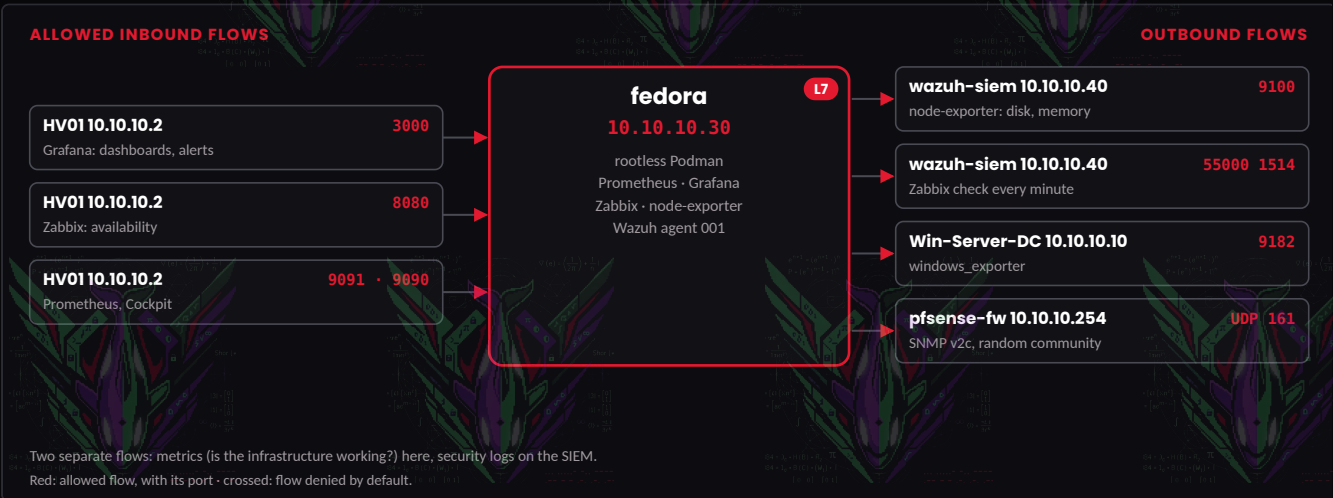


Figure 25 Network flows of fedora: allowed sources on the left, destinations on the right.

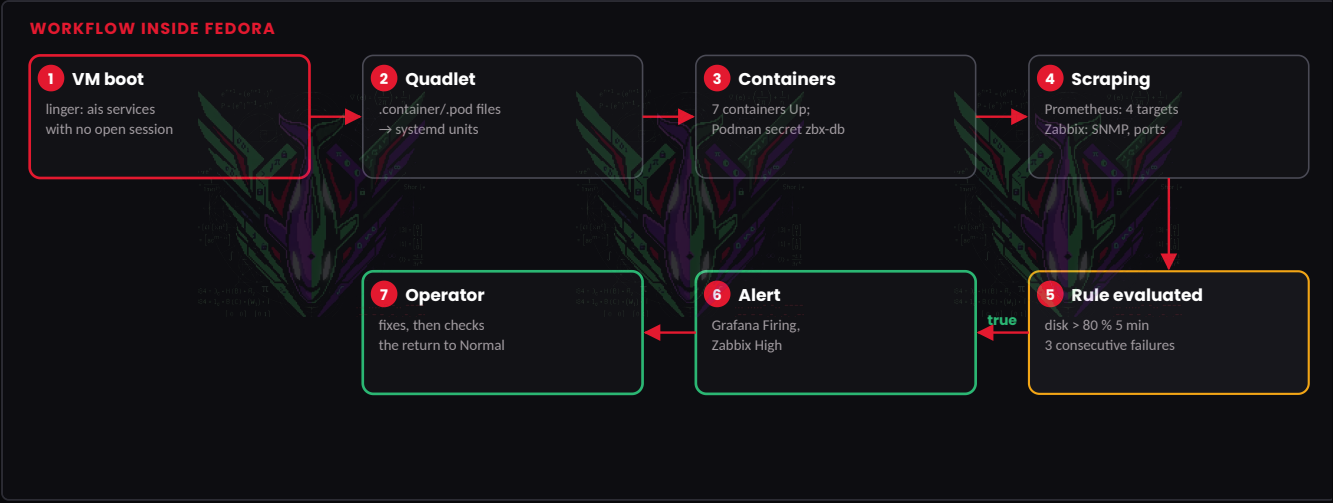


Figure 26 Monitoring node flowchart: declared services, scraping, rule, alert (INC-09, INC-11, F-16).

Abbreviations (figures 25 and 26) — **Quadlet**: file that declares a Podman container as a systemd service · **SNMP**: Simple Network Management Protocol, UDP port 161 · **MCO / MCS**: keeping systems running / keeping them secure · **SIEM**: Security Information and Event Management · **API**: Application Programming Interface · **L1...L7**: OSI layers: 1 physical, 2 data link, 3 network, 4 transport, 5 session, 6 presentation, 7 application · **Gio / Go**: gibibytes (memory, 2^{30} bytes) / gigabytes (disk, 10^{9} bytes) · **INC / F**: incident sheet / finding sheet

C3.7 SIEM wazuh-siem

Role	SIEM: collection, correlation, alerts
System	Ubuntu 26.04.1, Wazuh 4.14.8 (manager, indexer, dashboard), clock in UTC
Resources	6 GiB, 40 GB disk (11 GB of CVE database)
Address	10.10.10.40
Filtering (ufw)	22, 443, 9090 from the host; 1514, 1515 from the LAN; 55000, 9100 from fedora (F-15)
Local rules	100100 SSH brute force, 100300 persistence, 100310 agent stopped, 100320 lockout
Logs	90 days searchable (ISM), 365 days sealed with SHA-256 (F-21)
Resilience	manager Restart=on-failure (INC-11); monitored by Zabbix
Sheets	INC-11, F-14, F-15, F-16, F-18, F-19, F-21, F-22, F-24

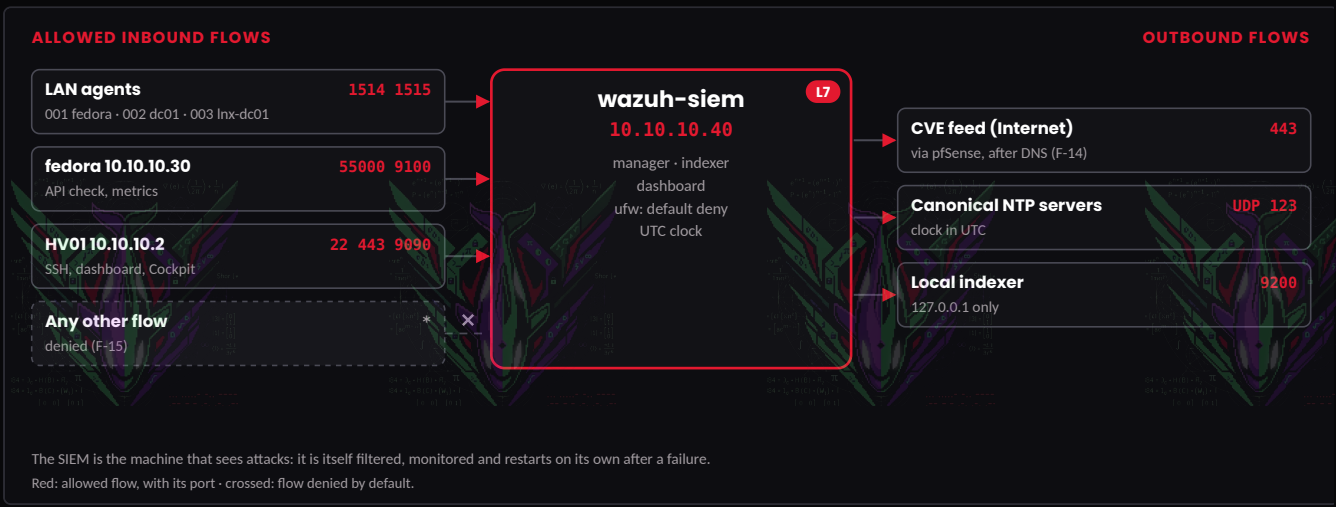


Figure 27 Network flows of wazuh-siem: allowed sources on the left, destinations on the right.

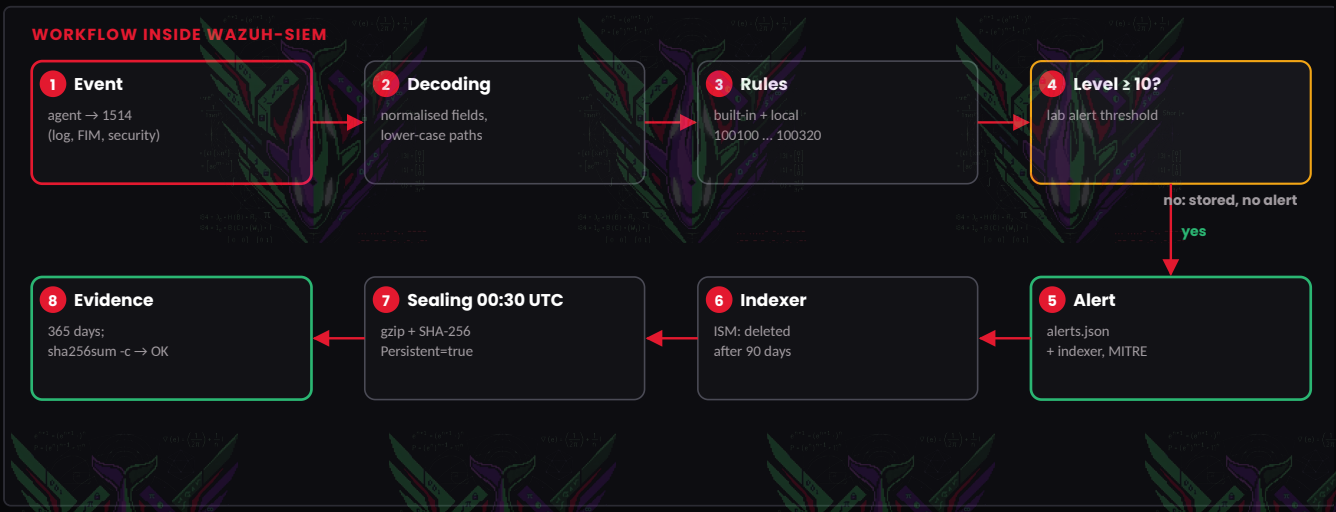


Figure 28 Flowchart of how the SIEM handles an event, from the agent to the sealed log (F-19, F-21).

Abbreviations (figures 27 and 28) — **SIEM**: Security Information and Event Management · **FIM**: File Integrity Monitoring · **ISM**: Index State Management (Wazuh indexer) · **SHA-256**: 256-bit cryptographic hash · **CVE**: Common Vulnerabilities and Exposures · **NTP**: Network Time Protocol · **UTC**: Coordinated Universal Time; Paris time = UTC + 2 h until 25/10, + 1 h after · **ufw**: Debian/Ubuntu host firewall (Uncomplicated Firewall) · **MITRE ATT&CK**: public catalogue of attack techniques; T1110 brute force, T1547.001 boot persistence, T1562.001 impair defenses · **API**: Application Programming Interface · **LAN**: lab local network 10.10.10.0/24 · **L1…L7**: OSI layers: 1 physical, 2 data link, 3 network, 4 transport, 5 session, 6 presentation, 7 application · **Gio / Go**: gibibytes (memory, 2^{30} bytes) / gigabytes (disk, 10^{9} bytes) · **INC / F**: incident sheet / finding sheet

C3.8 Remote client wg-client

Role	WireGuard tunnel client (simulated remote access, acceptance)
System	Fedora 44 Cloud Edition
Resources	1 GiB, 1 vCPU, 10 GB disk (base image wg-client-base.qcow2)
Address	192.168.122.55 (NAT network, simulated Internet side); tunnel address in 10.10.20.0/24
Storage	/var/lib/libvirt/images, outside /vm: included separately in lab-backup (PV-09)
Watch point	no SSH server; ignored every shutdown signal: shutdown via the guest agent (F-26)
Sheets	F-26, PV-09

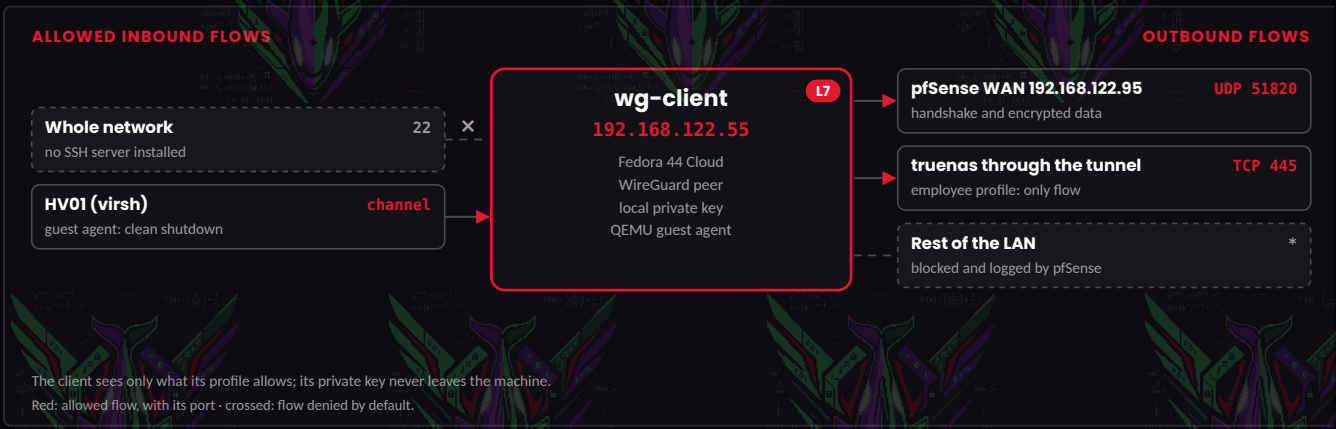


Figure 29 Network flows of wg-client: allowed sources on the left, destinations on the right.

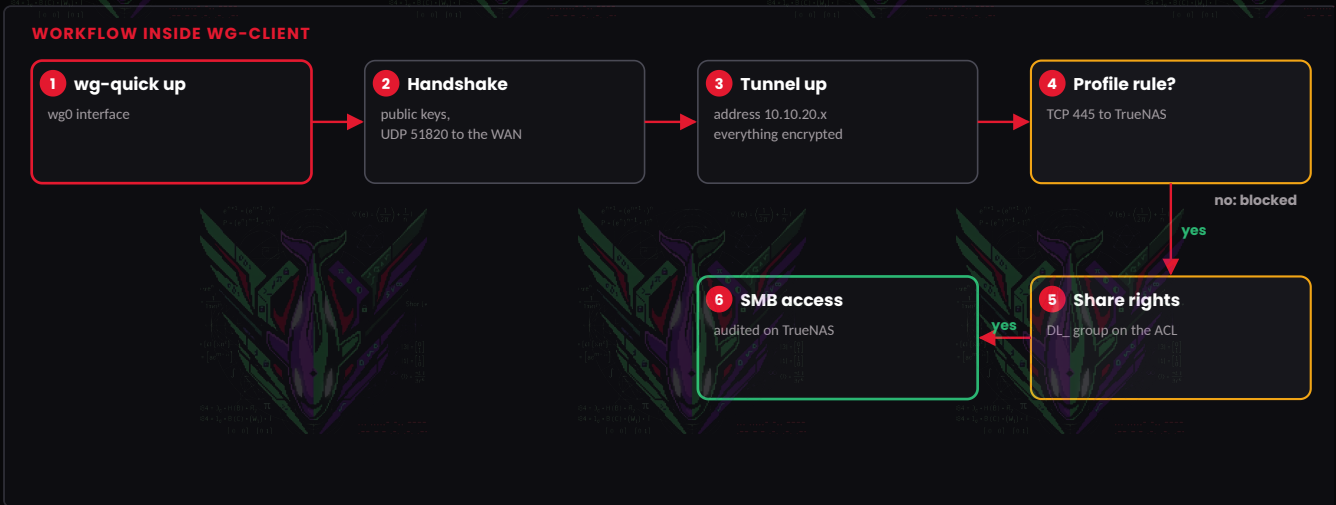


Figure 30 Flowchart of an employee's remote access: three barriers in a row.

Abbreviations (figures 29 and 30) — **WG**: WireGuard: encrypted VPN tunnel, UDP port 51820 · **WAN**: outside of the firewall (NAT network 192.168.122.0/24) · **LAN**: lab local network 10.10.10.0/24 · **NAT**: Network Address Translation · **SMB**: Server Message Block file sharing, port 445 · **SSH**: Secure Shell remote administration, port 22 · **ACL**: Access Control List · **DL_**: prefix of domain local groups: what the group allows on a share · **vCPU**: virtual CPU · **agent invité**: QEMU guest agent: service in the VM that takes orders from the hypervisor · **L1...L7**: OSI layers: 1 physical, 2 data link, 3 network, 4 transport, 5 session, 6 presentation, 7 application · **Gio / Go**: gibibytes (memory, 2^{30} bytes) / gigabytes (disk, 10^9 bytes) · **INC / F**: incident sheet / finding sheet · **PV**: implementation or acceptance report

CHAPTER

C4

The INFRASEC organisation

A fictitious company of 10 employees, rights given through groups, shares per department, and a password policy finally enforced.

AGDLP RBAC PV-05 F-24

C4 · The INFRASEC organisation

C4.1 The directory

The fictitious company INFRASEC has 10 employees in 6 departments. They are created in the `infrasec.local` directory by the idempotent script `New-InfrasecCompany.ps1`, from a single `employes.csv` file (PV-05). The script first ran as a simulation (`-WhatIf`), after a VM snapshot; its SHA-256 hash was checked on arrival on the controller.

- **14 organisational units and 27 groups**: 7 `GG_` (6 departments and remote work), 10 `DL_SMB_<share>_RW/RO`, 8 `ROLE_` mirroring the ISSP RBAC matrix; 10 computer objects.
- **12 accounts**: the 10 employees (random 24-character passwords, change forced at first logon, never displayed), `adm.rj` (separate admin account, the only one added to Domain Admins) and `aud.externe` (disabled outside audit missions).
- **Account separation**: the everyday account `rj` has no admin rights; `adm.rj` administers; the built-in `Administrator` account is kept for emergencies and can no longer be reached over SSH (PV-07).

The SIEM received the 12 Windows 4720 account-creation events, all within two seconds. Finding noted: they arrive at level 8, below the alert threshold. Bulk account creation therefore remains a point to watch.

C4.2 The AGDLP model

People join a global group (`GG_` : who they are), member of a domain local group (`DL_` : what it allows), the only group placed on the share's ACL. A newcomer only needs a group membership, never an ACL change.

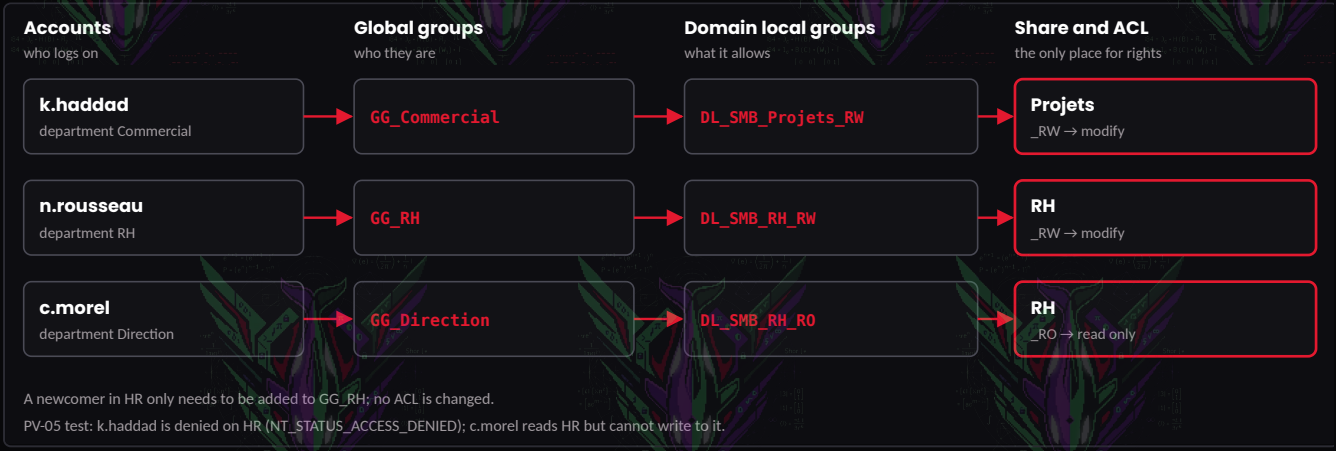


Figure 31 The AGDLP model applied to the company shares, with the accounts of the PV-05 test.

Abbreviations — **AGDLP**: Accounts → Global groups → Domain Local groups → Permissions · **GG_**: prefix of global groups: who people are (their department) · **DL_**: prefix of domain local groups: what the group allows on a share · **ACL**: Access Control List · **SMB**: Server Message Block file sharing, port 445 · **PV**: implementation or acceptance report

C4.3 The TrueNAS shares

The parent dataset `tank/entreprise` is not shared; `Domain Users` only has the right to traverse it, without inheritance. Five child datasets are shared over SMB: Commun, Direction, Comptabilite, RH, Projets. On each, `DL_SMB_<share>_RW` may modify, `DL_SMB_<share>_RO` may read, and nothing else is allowed.

FINDING FIXED

The TrueNAS SMB preset gave `Domain Users` the Modify right: all 12 domain accounts could write everywhere. A preset is not a policy. The ACL was brought back to least privilege, then proven with 6 accesses, including 2 expected denials (PV-05).

The shares are protected by recursive hourly ZFS snapshots, kept for two weeks. Restore was proven from the user's point of view: a file deleted by `k.haddad` came back in about one minute (PV-06). File access auditing is on for the 6 shares: we now know who did what, not only who logged on (F-20).

C4.4 The password policy, enforced by both domains

The ISSP required 14 characters for users and 20 for privileged accounts. Both domains had stayed on the defaults: 7 characters and no lockout. Accounts complied with the ISSP because the script had generated their passwords, not because the domain enforced it. This is fixed since 26/10, identically in both domains (F-24):

Setting	Ordinary accounts	Administrators (`PSO-Admins`)
Minimum length	14 characters	20 characters
Lockout	after 10 failures, for 15 min	after 5 failures, for 30 min
Lifetime	365 days	180 days

The lockout was proven: 11 SMB logons with a wrong password give 10 failures then `NT_STATUS_ACCOUNT_LOCKED_OUT` , and event 4740 names the source machine.

CHAPTER

C5

Incident and finding log

18 sheets in six days, all fixed and proven; two points remain open and are stated plainly.

INC-08 → INC-11

F-13 → F-26

C5 · Incident and finding log

C5.1 Timeline

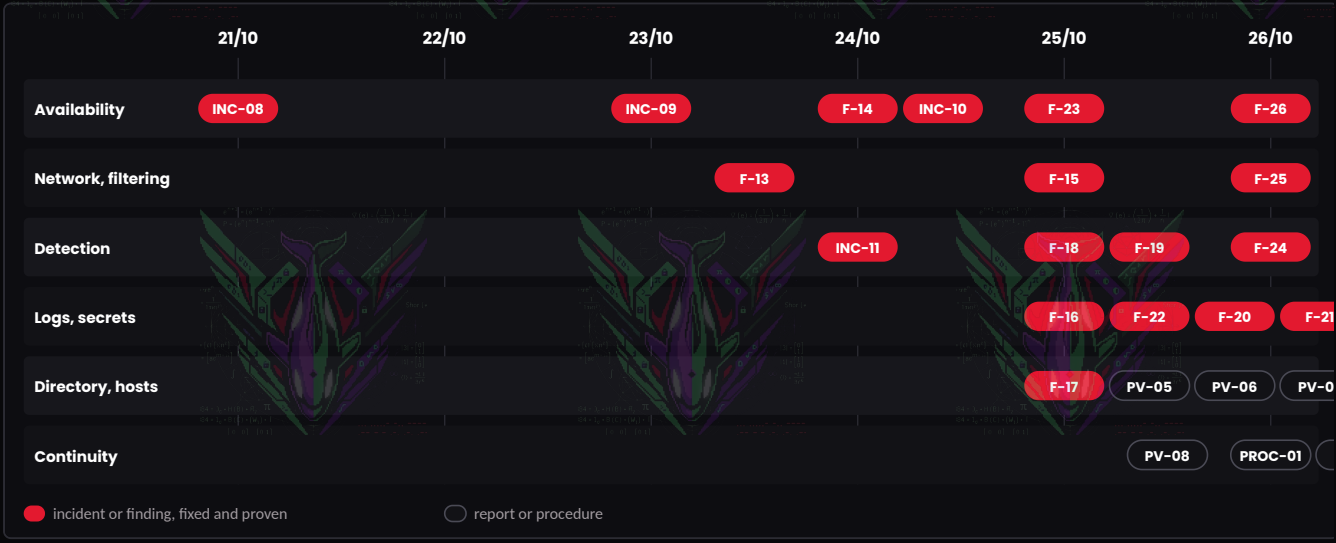


Figure 32 Timeline of the sheets from 21 to 26/10/2026, by area.

Abbreviations — **INC / F**: incident sheet / finding sheet · **PV**: implementation or acceptance report

C5.2 The sheets in one table

Sheet	Finding	Severity	Fix and proof
INC-08	Cockpit unreachable outside the home network: service bound to an address	medium	listening restored, access filtered by firewalld; tested on a phone hotspot
INC-09	Zabbix pod started by hand, not restarted at boot; password in clear	medium	Quadlet units, Podman secret, rotation; full reboot proven
INC-10	Host loses its LAN address at the first network reload	medium	address declared in NetworkManager; outage replayed on purpose
INC-11	SIEM blind for 3 h 10 with no alert (manager failed at boot)	high	`Restart=on-failure` and Zabbix check; detection in 2 min 23 s
F-13	Host can relay traffic into the LAN outside pfSense	medium to high	firewalld zone `lab-tenet` with no service or forwarding
F-14	SIEM CVE database not updated when the lab starts out of order	medium	`lab` script: ordered start with a real DNS wait
F-15	SIEM with no firewall: 7 services open to the LAN	medium	ufw, one rule per legitimate flow; tested from two third machines
F-16	SIEM disk not monitored (and a false growth alarm)	medium	node-exporter, Grafana alert at 80 % proven
F-17	Web browsing on the DC with the built-in Administrator account	high	GPO blocking every site; same test replayed
F-18	Stopping the DC Wazuh agent raises no alert	high	rule 100310, level 10, T1562.001
F-19	StartUp folder persistence detected below threshold	high	rule 100300, level 12, alert in 1.6 s

Sheet	Finding	Severity	Fix and proof
F-20	SMB audit: logons only, not files	medium	audit on for the 6 shares; read through the API
F-21	Logs with no retention, 9 days out of 10 never sealed	medium	ISM 90 days, daily SHA-256 sealing, catch-up proven
F-22	SIEM installation secrets in clear on the SIEM	high	AES-256 encrypted, moved to the host vault, destroyed on the SIEM
F-23	29 GiB allocated out of 30, swap in use on the hypervisor	medium	measured reduction of two VMs; swap 4.0 → 1.4 GiB
F-24	No lockout in either domain, then a lockout with no alert	high	14/20 policy and lockout; rule 100320 proven by a slow attack
F-25	Samba controller with no firewall at all	medium	ufw, NetBIOS closed; tested from fedora and the host
F-26	Two VMs ignore the hypervisor's shutdown request	medium	QEMU guest agent, `lab` : 7 of 7 stopped in 66 s

◆ C5.3 Defects that keep coming back

Reading the 18 sheets again, four defects come back. They are the ones I learned the most from.

1. **A test that cannot fail.** A DNS check that accepted error messages (F-14), a firewall test run from the target itself (F-15, PV-07), a "successful" `gpupdate` while the GPO did not exist (F-17), an "error-free" decryption that had produced an empty file (F-22). Rule drawn: before trusting a test, I check that it could have failed.
2. **An undeclared configuration.** An address added by hand (INC-10), a pod started by hand (INC-09). Anything that is not in the configuration tool disappears at the first reload.
3. **An event seen but below the threshold.** Persistence (level 5), agent stop (level 3), lockout (level 9), account creation (level 8). Seeing is not enough: the event must reach the level that raises an alert.
4. **A machine arriving without firewall or monitoring.** The SIEM (F-15, F-16), the Samba controller (F-25). From now on, a machine enters the lab with its firewall, its agent and its monitoring.

C6

CHAPTER

Detection and logs

What the SIEM saw without alerting, what it alerts on now, and how its logs are kept and sealed.

MITRE ATT&CK | 100300 → 100320 | F-21

C6 · Detection and logs

C6.1 Before and after the local rules

Three attack scenarios were played on the domain controller. In all three, Wazuh saw the event, but at a level below the lab's alert threshold (10). I wrote a local rule for each, validated with `wazuh-analysisd -t` before reloading, then replayed the attack.

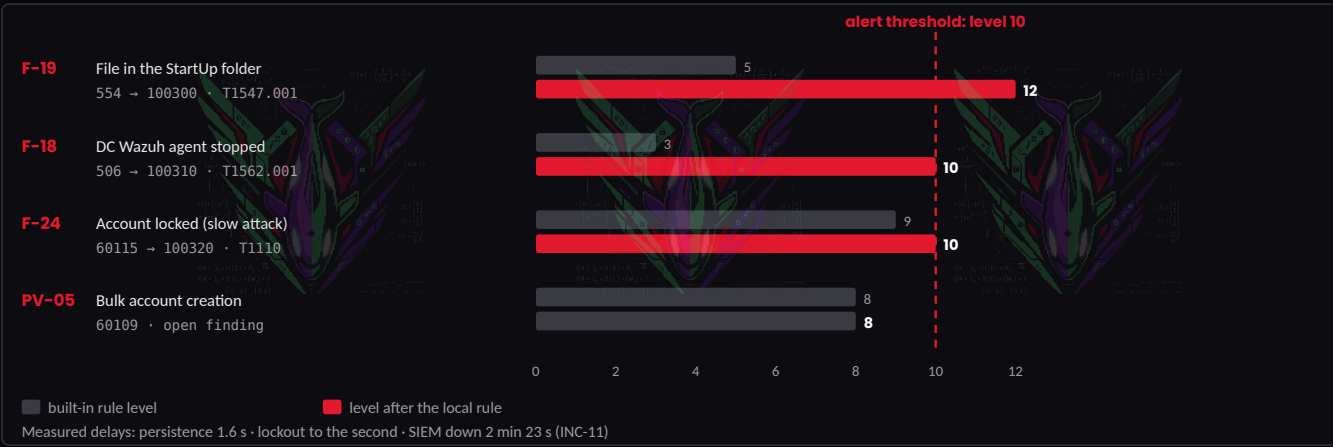


Figure 33 Alert levels before and after the local rules: what was seen without alerting becomes an alert.

Abbreviations — **MITRE ATT&CK**: public catalogue of attack techniques; T1110 brute force, T1547.001 boot persistence, T1562.001 impair defenses · **DC**: Domain Controller · **SIEM**: Security Information and Event Management · **INC / F**: incident sheet / finding sheet · **PV**: implementation or acceptance report

Rule	MITRE technique	Parent	Level	Proof
100300	T1547.001: persistence through the StartUp folder	550, 554	12	`maj.bat` created at 18:52:00 UTC, alert at 18:52:01.582
100310	T1562.001: impairing a defence tool	506	10	`sc.exe stop WazuhSvc`, alert at 18:52:35 UTC
100320	T1110: brute force, including slow	60115	10	10 failures in 8 min, alert at 18:49:09.212 UTC with no 60204
100100	T1110: SSH brute force	(project)	12	project rule, from PV-03

KEY POINT

The path filter of rule 100300 ignores case: Wazuh records Windows paths in lower case, which is why the dashboard search found nothing. When the interface shows nothing, I read the raw log (`grep` in `alerts.json`).

C6.2 The SIEM watched in turn

A stopped SIEM raises no alert: it is the worst kind of silence. After INC-11, the manager restarts on its own after a failure, and Zabbix checks its API (55000) and agent reception (1514) every minute, with an alert after three consecutive failures. The SIEM disk is watched by Prometheus, with a Grafana alert above 80 %, before the indexer thresholds (85 %, then blocking at 95 %).

C6.3 Log retention and sealing

I measured before deciding: about 8 MB of raw alerts a day, 113 KB once compressed, 4.4 MB a day in the indexer. The searchable copy is kept **90 days** (indexer ISM policy), the sealed raw copy **365 days**. Sealing runs every day at 00:30 UTC with `Persistent=true` : since the lab is off at night, the timer catches up the missed day at the next boot. The catch-up was proven on 26/10.

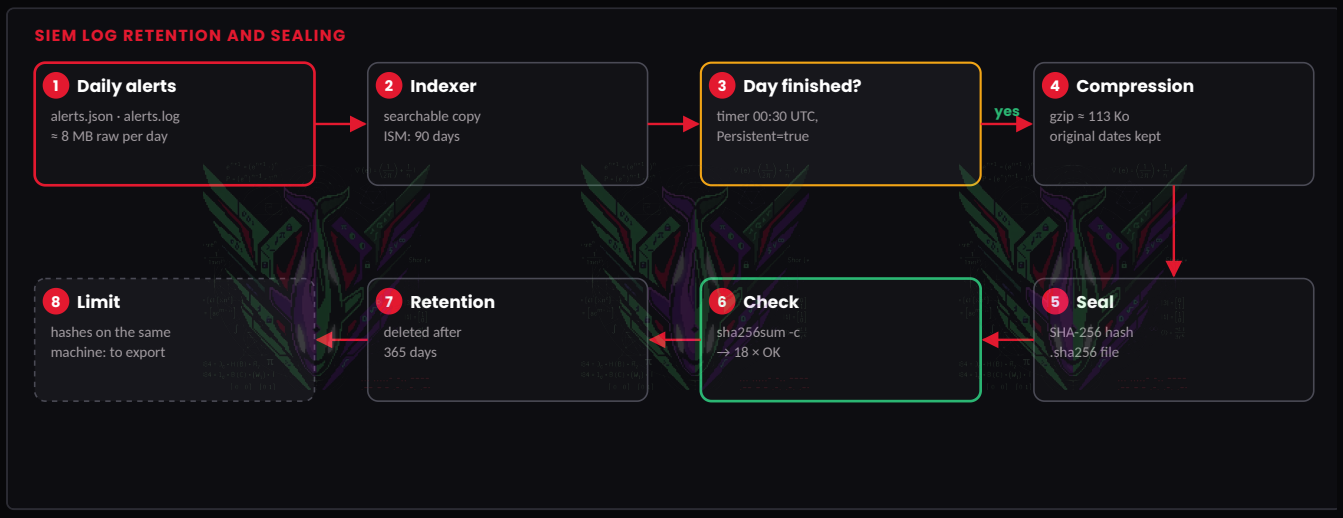


Figure 34 Retention and sealing of SIEM logs, including catch-up when the lab was off (F-21).

Abbreviations — **ISM**: Index State Management (Wazuh indexer) · **SHA-256**: 256-bit cryptographic hash · **UTC**: Coordinated Universal Time; Paris time = UTC + 2 h until 25/10, + 1 h after · **SIEM**: Security Information and Event Management · **Gio / Go**: gibibytes (memory, 2^{30} bytes) / gigabytes (disk, 10^{9} bytes)

CHAPTER

C7

Continuity and backup

A second domain ready to take over the directory, a migration procedure, an immutable lab backup.

PV-08 PROC-01 PV-09

C7 · Continuity and backup

C7.1 Why a second domain

The Windows controller runs an evaluation version, which expires around 27/03/2027. On that date, the directory would stop: no more authentication, no more shares. So I built a continuity domain, `infrasec.internal`, on a Samba 4.22 controller under Debian 13 (`lnx-dc01`), with the same company and the same policy.

C7.2 What is in place (PV-08)

- **The same company**: the bash script `infrasec-samba-societe.sh` replays the **same** `employes.csv` (same hash, `7228c38a…`). Simulation first, then the real run; a second run recreates nothing (idempotence proven).
- **The same monitoring**: Wazuh agent 003, same version as the manager, held against upgrades.
- **The same filtering**: ufw, one rule per legitimate flow, NetBIOS closed (F-25).
- **Cross resolution** between the two domains:

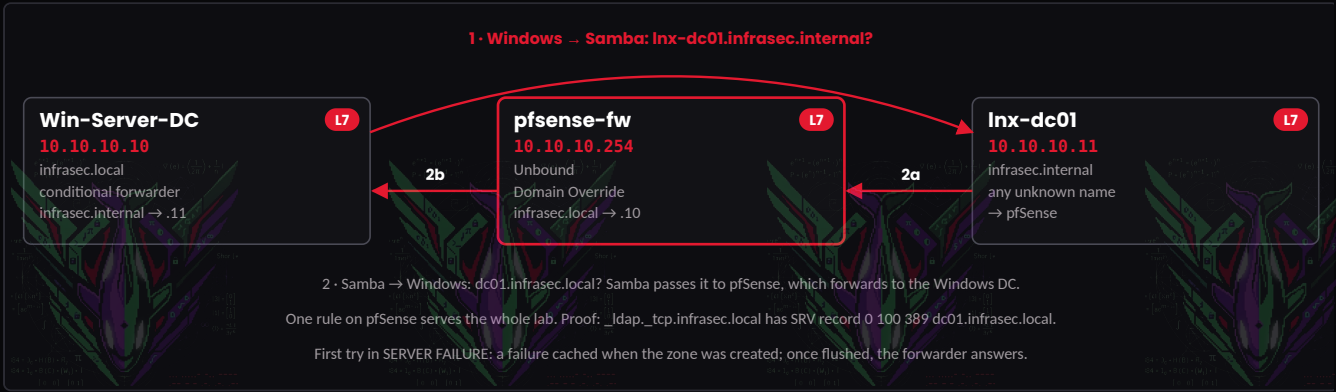


Figure 35 Cross DNS resolution between the two domains (PV-08).

Abbreviations — **DNS**: Domain Name System · **DC**: Domain Controller · **LDAP**: Lightweight Directory Access Protocol · **L1…L7**: OSI layers: 1 physical, 2 data link, 3 network, 4 transport, 5 session, 6 presentation, 7 application · **PV**: implementation or acceptance report

C7.3 The migration, written before it is needed (PROC-01)

The procedure sets the steps from D-30 to D+30, with a risk register and a roll-back possible until D+30. Its success criterion is measurable: the 6 test cases of PV-05 give the expected result on the new domain, and a failed logon there raises the matching Wazuh alert.

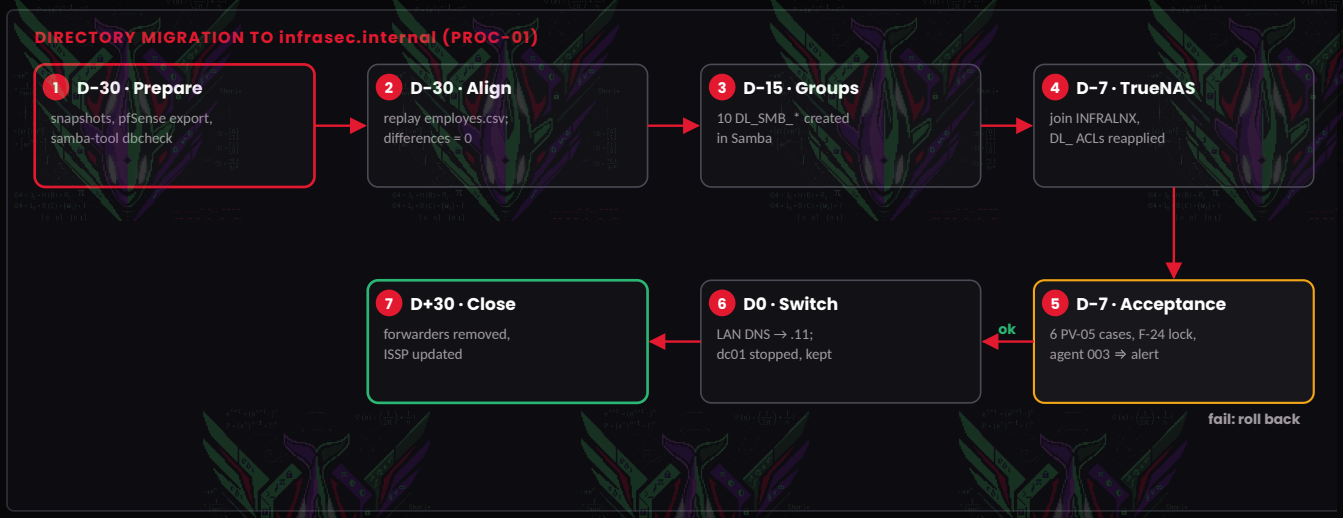


Figure 36 Directory migration procedure, with its roll-back point (PROC-01).

Abbreviations — **DL_**: prefix of domain local groups: what the group allows on a share · **ACL**: Access Control List · **DNS**: Domain Name System · **PV**: implementation or acceptance report · **INC / F**: incident sheet / finding sheet

◆ C7.4 The lab backup (PV-09)

No full backup of the lab existed apart from the VMs' internal snapshots. With no external disk, I ruled out repartitioning the host disk: shrinking an encrypted partition is the riskiest possible operation on that disk. Instead, I built an **immutable** local level, using the existing `/vm` BTRFS subvolume.

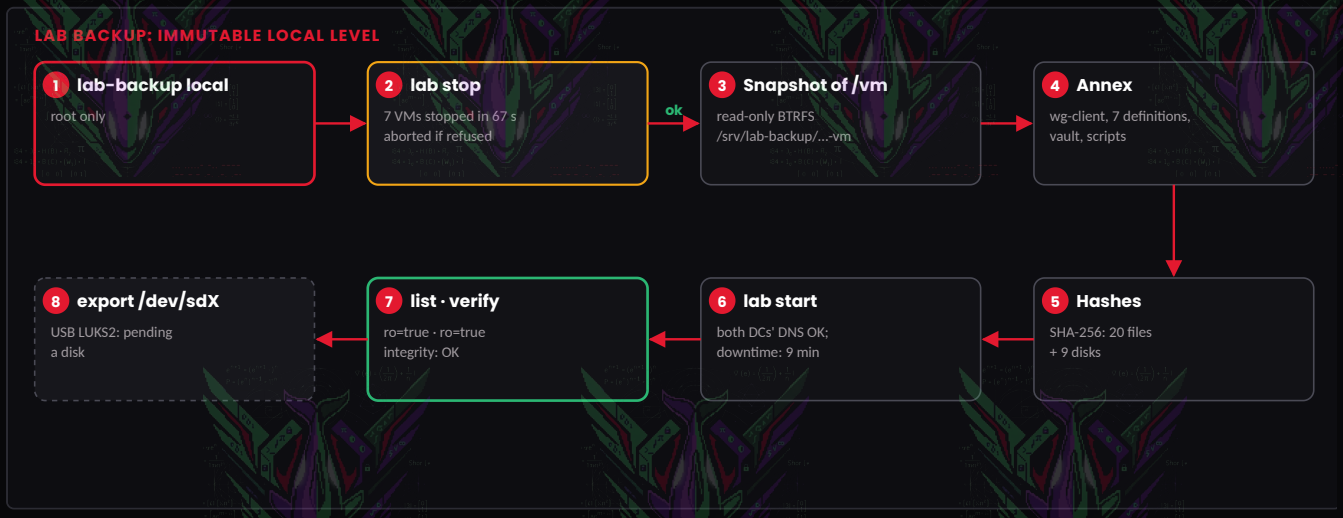


Figure 37 The lab-backup script: clean stop, read-only snapshot, hashes, restart (PV-09).

Abbreviations — **BTRFS**: B-tree file system, with snapshots · **SHA-256**: 256-bit cryptographic hash · **LUKS**: Linux Unified Key Setup, full-disk encryption · **VM**: virtual machine · **DNS**: Domain Name System · **DC**: Domain Controller · **PV**: implementation or acceptance report

The inventory beforehand avoided two traps: `wg-client` was stored outside `/vm` and depended on a base image, and `/vm/iso` held 55 GB of useless images, deleted one by one after checking. After the backup, `lab-backup list` shows both parts read-only, `lab-backup verify` recomputes every hash, and a write attempt by root is refused (`Read-only file system`).

STATED LIMIT

This level protects against mistakes, corruption and ransomware. It does not protect against failure or theft of the host disk. The command `lab-backup export /dev/sdX` is ready: it will copy the latest backup to a LUKS2-encrypted USB disk as soon as one is available.

CHAPTER

C8

Results, limits and next steps

What is done, what stays open, and what these six days taught me.

Results

C8 · Results, limits and next steps

C8.1 Results

Area	Before 21/10	On 26/10
Detection	built-in rules, several attacks seen below threshold	4 proven local rules, the SIEM itself monitored
Logs	no retention, missing seals	90 days searchable, 365 days sealed, catch-up proven
Filtering	SIEM and Samba controller open to the LAN	one rule per legitimate flow, tested from third machines
Directory	default policy, no lockout	14/20 characters, lockout, alert on lockout
Continuity	a single directory, on evaluation	second domain ready, migration procedure written
Backup	VM internal snapshots only	full backup, read-only, verified
Operations	manual start and stop	`lab` script: ordered, logged, 7 of 7 machines stopped

C8.2 Remaining work

- **External copy of the backup**: the `lab-backup export` command is ready; the USB disk is missing.
- **Log hashes off the SIEM**: root on the SIEM could change both the logs and their seals.
- **Prune the Windows controller's internal snapshots**: 17 snapshots take 124 GB on the host for a 60 GB disk.
- **pfSense**: replace ISC DHCP, now end of life, with Kea.
- **Bulk account creation**: raise the grouped 4720 event above the alert threshold.
- **Separate administration network** (measure M-01): the host still has an address in the LAN it administers.

C8.3 What I take away

I take away three habits. I prove a fix by replaying the test that revealed the defect, from a third machine. I read raw logs when the interface shows nothing, and I read those of the right boot. And I always state exactly what a measure protects against, and what it does not: that is what lets security and availability work together instead of against each other.

CHAPTER

C9

Glossary

Every abbreviation in the report, explained one by one.

CERT G/V OSI

C9 · Glossary

Abbreviation	Meaning
ACL	Access Control List
ACPI	power signal emulated by the hypervisor (Advanced Configuration and Power Interface)
AD DS	Active Directory Domain Services
AES	Advanced Encryption Standard
AGDLP	Accounts → Global groups → Domain Local groups → Permissions
agent invité	QEMU guest agent: service in the VM that takes orders from the hypervisor
API	Application Programming Interface
BTRFS	B-tree file system, with snapshots
CAPEX	capital expenditure: implementation cost
CERT	Computer Emergency Response Team (in France, CERT-FR at ANSSI)
CP7…CP10	professional skills of the AIS framework
CVE	Common Vulnerabilities and Exposures
DC	Domain Controller
DL_	prefix of domain local groups: what the group allows on a share
DNS	Domain Name System
EBIOS RM	ANSSI risk analysis method (EBIOS Risk Manager)
FIM	File Integrity Monitoring
G / V	severity (gravité) / likelihood (vraisemblance): the two axes of the EBIOS RM risk map (1 to 4)
GG_	prefix of global groups: who people are (their department)
Gio / Go	gibibytes (memory, 2^{30} bytes) / gigabytes (disk, 10^{9} bytes)
GPO	Group Policy Object
HTTPS	web over TLS
HV01	lab hypervisor, host name TeneT
INC / F	incident sheet / finding sheet
ISM	Index State Management (Wazuh indexer)
KVM	Kernel-based Virtual Machine
L1…L7	OSI layers: 1 physical, 2 data link, 3 network, 4 transport, 5 session, 6 presentation, 7 application
LAN	lab local network 10.10.10.0/24
LDAP	Lightweight Directory Access Protocol
LUKS	Linux Unified Key Setup, full-disk encryption
MCO / MCS	keeping systems running / keeping them secure

Abbreviation	Meaning
MITRE ATT&CK	public catalogue of attack techniques; T1110 brute force, T1547.001 boot persistence, T1562.001 impair defenses
NAT	Network Address Translation
NTP	Network Time Protocol
OPEX	cumulative operating expenditure
OSI	7-layer reference model (Open Systems Interconnection)
OU	Organizational Unit
PSO	fine-grained Password Settings Object
PV	implementation or acceptance report
Quadlet	file that declares a Podman container as a systemd service
RAM	Random Access Memory
RBAC	Role-Based Access Control
RPC	Remote Procedure Call (dynamic ports 49152-65535)
SHA-256	256-bit cryptographic hash
SIEM	Security Information and Event Management
SMB	Server Message Block file sharing, port 445
SNMP	Simple Network Management Protocol, UDP port 161
SO-1...SO-4	operational scenarios of the EBIOS RM analysis
SSH	Secure Shell remote administration, port 22
TCO	Total Cost of Ownership
TCP / UDP	transport protocols, connection-oriented or not
TLS	Transport Layer Security
UEFI	boot firmware
ufw	Debian/Ubuntu host firewall (Uncomplicated Firewall)
UTC	Coordinated Universal Time; Paris time = UTC + 2 h until 25/10, + 1 h after
vCPU	virtual CPU
VM	virtual machine
WAN	outside of the firewall (NAT network 192.168.122.0/24)
Wazuh	open-source SIEM: agents, manager, indexer, dashboard
WG	WireGuard: encrypted VPN tunnel, UDP port 51820
whodata	Wazuh FIM mode that also records the user and the process
ZFS	TrueNAS file system, with mirror and snapshots
ZTNA	Zero Trust Network Access

ANNEXES

Annexes A to O

The full documents of the project, in English. Annex M (operations manual) was written in both languages.

Evidence

Annex guide

The annexes are formal documents: they keep their original tone. Technical terms are in English, as in the rest of the report; the glossary (Annex L) gives the French term with its English equivalent. This guide gives the content of each annex.

Annex	Document	Contents
A	Audit engagement letter	Audit engagement letter: scope, rules of engagement, compliance criteria
B	Security audit report (PV-02)	Security audit report: nmap, Lynis, Wazuh SCA, 11 findings
C	Compliance assessment of the audit report	Assessment of the audit report against the engagement letter
D	EBIOS Risk Manager risk analysis	EBIOS RM risk analysis: five workshops, twelve treatment measures
E	Information systems security policy (ISSP)	Information security policy in twelve articles
F	Freeze and hardening report	Freeze and hardening report: Lynis 69 → 76
G	Backup and restore report (PV-01)	Backup and restore test report: RTO < 1 s, 0 errors
H	Awareness material and short training session	45-minute security awareness session and how its effect is measured
I	Incident detection report and lessons learned (PV-03)	Simulated SSH brute-force attack, detection and lessons learned
J	Technical and security incident log	Incident log, INC-01 to INC-07
K	Cybersecurity threat watch process	Threat watch process and local detection rule 100100
L	Glossary and definition sheets	Glossary and definition sheets
M	Bilingual operations manual	Operations manual, in French then in English
N	Reference network diagram and OSI layers	Reference network diagram, flow matrix and OSI layers
O	Acceptance and monitoring report (PV-04)	Acceptance test of Oct 11: remote access, restore, SNMP, alerting, rule 100100

Annex A · Audit engagement letter

Project: Hybrid InfraSec — Zero-Trust infrastructure of the company INFRASEC

Reference: LM-AUDIT-2026-01

Issue date: 01/10/2026

Sponsor: IT department (DSI), INFRASEC

Addressee: appointed audit team (internal audit carried out under the responsibility of the secure infrastructure administrator; this framework applies identically to a third-party provider)

Author / technical contact: admin (secure infrastructure administrator)

1. Context INFRASEC runs a target infrastructure segmented along Zero-Trust lines (single crossing point pfSense, Active Directory domain `infrasec.local`, TrueNAS storage, container node, Wazuh SIEM). Before putting a remote access evolution (WireGuard VPN) into production, and as part of keeping the systems secure (MCS), management wants an objective assessment of the security level of the scope.

This letter defines the mandate, scope, expected method, rules of engagement and deliverables of the audit. It also serves as the reference against which the audit report will be assessed.

2. Purpose and objectives Assess the security level of the INFRASEC infrastructure and provide a usable report to decide on treatment measures. Objectives:

- identify the vulnerabilities and exposures of the components in scope;
- characterise the related risks and threats (criticality);
- measure the gap with good practice (ANSSI, CIS);
- make prioritised remediation recommendations;
- feed the risk analysis (EBIOS Risk Manager) and the ISSP.

3. Scope

In scope:

Component	Address	Type of check
pfSense (firewall / gateway)	`10.10.10.254`	exposure, filtering rules, admin interface
Win-Server-DC (AD DS / DNS)	`10.10.10.10`	exposed services, hardening, account policy
TrueNAS (storage / SMB)	`10.10.10.20`	exposed services, shares, AD join
fedora (container node)	`10.10.10.30`	system hardening, SSH, rootless containers
wazuh-siem (SIEM)	`10.10.10.40`	exposure, configuration
Segment	`10.10.10.0/24`	exposure mapping, segmentation

Out of scope: the physical virtualisation host, the upstream home network, client devices, simulated public cloud services. Any extension of the scope requires a written amendment.

4. Regulatory framework and references The audit takes into account:

- the **ANSSI** recommendations (hygiene and hardening guides);
- the **GDPR** for the protection of personal data (processing scope);

- a risk management method of the **EBIOS Risk Manager / ISO 27005** type;
- the **CIS** configuration benchmarks (through the Lynis tool);
- the **MITRE ATT&CK** framework to qualify threats.

5. Expected methodology

Phase	Method / tool	Expected result
Reconnaissance /exposure	network scan (nmap)	map of open services per host
System compliance	hardening audit (Lynis)	hardening index + CIS gaps per host
Configuration compliance	Wazuh SCA (Security Configuration Assessment)	gaps per agent
Risk analysis	EBIOS Risk Manager	scenarios, criticality, security baseline
Threat qualification	MITRE ATT&CK	mapping findings to techniques
Additional tests	dedicated vulnerability scan (OpenVAS/GVM) from a Kali- or Parrot-type audit workstation; controlled authentication attempt	referenced vulnerabilities (CVE) per service; detection validation

6. Rules of engagement

- **Authorised time window**: on the mock-up, with no production constraint.
- **Explicit authorisation** from the sponsor for active tests (scanning, controlled authentication attempt).
- **Non-destructive**: no deliberate alteration of data; no unplanned service interruption.
- **No exfiltration** of real data; work on lab data.
- **Single point of contact**: the technical contact, reachable throughout the window.
- **Confidentiality**: findings are treated as sensitive and are not shared outside the agreed scope.

7. Expected deliverables 1. **Audit report** presenting the control points, the measurements taken and the assessment of the security level.

2. **List of vulnerabilities** identified, rated by severity, with a remediation recommendation and treatment phase.

3. **Characterisation of the related risks and threats** (MITRE ATT&CK mapping where relevant).

4. **Integrity register (SHA-256)** of the deliverables produced.

The report must be **clear, structured and usable** by someone who did not carry out the audit.

8. Criteria for assessing the work The audit report will be considered compliant if it:

- covers the whole scope defined in §3;
- applies the methodology of §5;
- identifies the vulnerabilities and characterises the risks (§2);
- provides prioritised, actionable recommendations;
- complies with the rules of engagement of §6;
- complies with the distribution policy of §9.

9. Confidentiality and distribution The deliverables contain **no public IP address, real MAC address, authentication secret or personal data**. The addressing plan uses **RFC 1918** private ranges (`10.10.10.0/24`). Documents are sealed with a **SHA-256** hash.

10. Schedule

Milestone	Date
Engagement letter issued	01/10/2026
Audit carried out	04/10/2026
Audit report delivered (PV-02)	04/10/2026
Compliance assessment of the report	04/10/2026

11. Approval

Role	Name	Date	Signature
Sponsor (INFRASEC IT department)	*(fictitious — training report)*	01/10/2026	—
Technical contact	admin	01/10/2026	—

Audit engagement letter — Project Hybrid InfraSec · fictitious company INFRASEC · AIS report (CCP3 / CP8).

Annex B · Security audit report (PV-02)

Project: Hybrid InfraSec — Zero-Trust lab

Scope: segment `10.10.10.0/24`, pfSense chokepoint, 5 assets (pfSense, DC, TrueNAS, fedora, Wazuh) + hypervisor

Audit date: 04/10/2026

Auditor: admin

Audit workstation: node `fedora` (10.10.10.30) — administration/audit workstation. *In production, a dedicated hardened workstation (Parrot/Kali) would separate the roles.*

1. Methodology Audit in three complementary layers:

1. **Network exposure mapping** — service and OS scan (`nmap -sS -sV -O`) over the whole segment.

2. **System hardening** — CIS audit of the Linux hosts (`Lynis 3.1.7`).

3. **Configuration compliance** — Wazuh's native Security Configuration Assessment (SCA), already active on the Windows (DC) and Linux (fedora) agents.

Tools: `nmap 7.92`, `Lynis 3.1.7`, Wazuh 4.14 (SCA module).

2. Layer 1 — Exposure mapping (nmap) 6 active hosts detected. Exposure surface per asset:

Asset	IP	Open ports/services	Comment
pfSense (fw01)	.254	53 (DNS Unbound), **80 (HTTP nginx)**, 443 (HTTPS nginx)	Admin interface reachable **in clear on :80**
Domain controller	.10	53, 88, 135, 139, 389, 445, 464, 593, 636, 3268, 3269 (AD DS), **3389 (RDP)**	Expected AD services; **RDP open to the whole segment**
TrueNAS	.20	80, 443 (UI), 139/445 (SMB 4.6.2), 5357 (WS-Discovery)	Web UI and WSD exposed
fedora	.30	22 (SSH), 3000 (Grafana), 9090 (Cockpit), 9091 (Prometheus), 9100 (node-exporter)	Monitoring stack; 9100 without authentication
Wazuh	.40	22, 443 (dashboard), 9090 (Cockpit)	Matches the need
Hypervisor (TeneT)	.2	all filtered	**Hypervisor administration address present on the production segment**

Strengths observed:

- On each host, most of the 1,000 ports tested are filtered: the scan, run from the segment, does not cross pfSense, so this filtering comes from the hosts' local firewalls. pfSense itself only exposes DNS resolution and its administration interfaces (including HTTP :80, finding F-02).
- No dangerous legacy or unencrypted service (no Telnet, FTP, SMBv1).
- TLS available on the administration interfaces (443, Cockpit 9090, Grafana, Wazuh dashboard), except pfSense's HTTP :80 listener (F-02).

3. Layer 2 — System hardening (Lynis / fedora)

- **Hardening index: 69/100** (253 tests run)
- **Warnings: 0**
- **Suggestions: 20** (areas for improvement, no critical defect)

Main suggestions:

- **SSH (SSH-7408)**: `AllowTcpForwarding` → NO, `ClientAliveCountMax` → 2, `LogLevel` → VERBOSE.
- **Password policy (AUTH-9230/9286)**: set `PASS_MIN_DAYS`, `PASS_MAX_DAYS`, hashing rounds in `/etc/login.defs`.
- **umask (AUTH-9328)**: set the default value to `027`.
- **Unneeded network protocols (NETW-3200)**: disable `dccp`, `sctp`, `rds`, `tipc`.
- **Removable storage drivers (USB-1000, STRG-1846)**: disable USB/FireWire storage if not needed.
- **Automatic updates (PKGS-7420)**: enable `dnf-automatic`.
- **Disk partitioning (FILE-6310)**: separate partitions for `/home` and `/var`.

4. Layer 3 — Configuration compliance (Wazuh SCA) Wazuh's **Security Configuration Assessment** module continuously checks the agents against CIS benchmarks:

- **DC01 (Windows Server 2025)** — CIS Microsoft Windows Server benchmark.
- **fedora (Linux)** — CIS Distribution Independent Linux benchmark.

Evidence: Wazuh dashboard → "Configuration Assessment" module (screenshots kept offline by the auditor). Benefit: Windows coverage where Lynis does not apply.

5. Summary of findings and remediation plan

ID	Finding	Severity	Remediation	Phase
F-01	Hypervisor administration IP (.2) present on the production segment (admin plane and data plane mixed)	**High**	Remove the temporary IP `10.10.10.2` (systemd service)	Freeze
F-02	pfSense admin reachable in clear over HTTP :80	**Medium**	Force HTTPS, disable the :80 listener, restrict the management source	Freeze
F-03	RDP (3389) open to the whole segment on the DC	**Medium-High**	Restrict the source (firewall rule) to the admin workstation, enforce NLA	Freeze
F-04	WS-Discovery (5357) exposed on TrueNAS	Low	Disable WSD if not required	Freeze
F-05	node-exporter (9100) without authentication	Low	Restrict :9100 to the Prometheus host with the local firewall	Freeze
F-06	Administration plane (SSH 22, Cockpit 9090) reachable from the whole segment	Medium	Restrict admin access to a dedicated workstation/segment (Zero-Trust principle)	Hardening
F-07	SSH hardening could be improved (forwarding, timeout, verbosity)	Low	Apply the SSH-7408 recommendations	Hardening
F-08	Default password policy and umask	Low	Configure `/etc/login.defs`, umask 027	Hardening
F-09	Unneeded loadable network protocols (dccp, sctp, rds, tipc)	Low	Blacklist with modprobe	Hardening
F-10	Removable storage drivers active	Low	Blacklist USB/FireWire storage	Hardening
F-11	No automatic updates	Low	Enable `dnf-automatic` / `unattended-upgrades`	Hardening

6. Security measures already in place (strengths)



- **Single chokepoint** pfSense with default deny filtering between zones; inside the segment, filtering relies on the hosts' local firewalls.
- **Monitoring**: Wazuh SIEM (events + SCA + FIM) with agents on the domain controller and the fedora node, and Prometheus/Grafana metrics on both hosts.
- **Rootless containers** (Podman) on the fedora node — no root daemon, reduced surface.
- **Backup designed on 3-2-1-0**, restore verified (PV-01) — ZFS snapshots + replication + SHA-256 check.
- **Encryption in transit** (TLS) on the administration interfaces, except pfSense's HTTP :80 listener (F-02).
- **AD integration** with NFSv4 ACLs on the file share (centralised access control).

7. Conclusion The lab shows a **sound security posture** (hardening index 69/100, no dangerous legacy service, effective firewall, full monitoring). The findings are mostly of low to medium severity and fall under incremental hardening; the three priority findings were decided on during the freeze phase: F-01 accepted temporarily with a compensating measure, F-02 and F-03 planned (see the freeze report). The related risk analysis is developed in the EBIOS Risk Manager document, and the organisational measures in the ISSP.

Appendices: full `nmap` output (`/tmp/nmap-infrasec_20261004.txt`), Lynis report (`/var/log/lynis-report.dat`), Wazuh SCA screenshots.

Annex C · Compliance assessment of the audit report

Project: Hybrid InfraSec — company INFRASEC

Reference: EVAL-AUDIT-2026-01

Date: 04/10/2026

Assessor: admin (secure infrastructure administrator)

Document assessed: `PV-02 — Security audit` (audit report produced)

Assessment reference: `LM-AUDIT-2026-01` (engagement letter)

Purpose — Check that the audit report (PV-02) meets every requirement set by the engagement letter, in line with performance criterion CP8 ("the compliance of the audit report with the engagement letter is assessed correctly").

1. Compliance grid Key: ✅ compliant · 🟡 partly compliant · ❌ not compliant

#	Requirement (engagement letter)	Coverage in the audit report (PV-02)	Verdict
§3	**Full scope** (5 components + segment)	nmap map of the six hosts (five components and the admin host) + segment `10.10.10.0/24`	✅
§5	**Reconnaissance / exposure** (nmap)	Map of open services per host	✅
§5	**System compliance** (Lynis)	fedora hardening index (69/100) + gaps	✅
§5	**Configuration compliance** (Wazuh SCA)	SCA results per agent	✅
§5	**Risk analysis** (EBIOS RM)	Covered in the dedicated `EBIOS-RM` deliverable, reusing findings F-01..F-11	✅
§5	**MITRE ATT&CK qualification**	Applied to the incident scenario (PV-03); mapping of the F-01 vector	✅
§2 /§7	**Vulnerabilities identified and rated**	Findings **F-01 to F-11**, rated by severity	✅
§2	**Risks and threats characterised**	Criticality per finding + reused in EBIOS RM	✅
§7	**Prioritised, actionable recommendations**	Remediation + treatment phase per finding	✅
§7	**SHA-256 integrity register**	`Registre-Integrite-SHA256` covering the deliverables	✅
§7	**Clear, structured, usable report**	Structure per host + findings table	✅
§6	**Rules of engagement** (non-destructive, authorisation, no exfiltration)	Complied with — controlled internal audit, no alteration	✅
§9	**Distribution** (RFC 1918, no secret)	Complied with — `10.10.10.0/24` plan, no real secret	✅
§5	**Additional tests** (dedicated vulnerability scan, Kali/Parrot-type audit workstation)	Partial — scan + controlled brute-force test (PV-03); dedicated vulnerability scan (OpenVAS) not done (audit VM abandoned for a technical reason; gap recorded in this assessment)	🟡

2. Gap identified A single partial gap: the engagement letter mentions Kali-type audit tools. The dedicated vulnerability scanner (OpenVAS) could not be used — the prebuilt audit machine did not boot. Coverage was ensured another way: nmap scan for exposure, Lynis for hardening, Wazuh SCA for configuration, and a controlled brute-force test for detection (PV-03). The goal of the engagement letter — identify and rate the vulnerabilities — is met; only the method of one tool differs.

Treatment: adding an OpenVAS/GVM scan is recorded as an improvement for the next audit cycle. It does not call the established findings into question.

3. Overall verdict The audit report (PV-02) is assessed as **compliant** with the engagement letter `LM-AUDIT-2026-01`. All requirements on scope, method, deliverables, rules of engagement and distribution are met. The single gap (dedicated vulnerability scanning tool) is partial, justified, has no impact on the validity of the findings, and is the subject of a recorded improvement action.

Compliance assessment — Project Hybrid InfraSec · AIS report (CCP3 / CP8). Full loop: engagement letter → audit → assessment.

Annex D · EBIOS Risk Manager risk analysis

AIS certification lab "Hybrid InfraSec" — Zero-Trust architecture

Subject	Digital risk assessment using the EBIOS Risk Manager method (ANSSI, 2018 edition)
Scope	DevSecOps / CloudSec lab "Hybrid InfraSec"
Type of deliverable	Formal security assessment document — presented to a jury
Date	4 October 2026
Author	admin — secure infrastructure administrator (security analyst role)
References	EBIOS RM (ANSSI), MITRE ATT&CK, ANSSI IT hygiene guide, ISO/IEC 27005
Input documents reused	PV-01 (backup / RTO validation), PV-02 (configuration audit — findings F-01 to F-11)

Confidentiality notice — This document describes an isolated lab environment. No public IP address, real authentication secret or personal data appears in this deliverable. The addresses mentioned belong to the lab's private RFC 1918 addressing plan.

Summary for the jury (executive summary) The "Hybrid InfraSec" lab implements a hybrid virtualisation infrastructure (KVM/libvirt on Fedora 44) organised around a **single crossing point** — the pfSense firewall — following a **Zero-Trust** approach. It hosts an Active Directory trust core (`infrasec.local`), ZFS storage (TrueNAS), a **rootless Podman** container node monitored by Prometheus/Grafana, and a Wazuh 4.14 SIEM for detection (SCA, FIM, correlation).

The EBIOS RM assessment below identifies **four business values** (directory and authentication service, integrity/availability of stored data, monitoring and detection chain, business continuity) and **six supporting assets**. The most severe feared events (severity **G4 — Critical**) are the **compromise of the Active Directory forest** and the **malicious encryption (ransomware) of the SMB shares**.

The PV-02 audit findings (F-01 to F-11) are used as **proven vulnerabilities** feeding the operational scenarios. The two structural vulnerabilities are the **presence of the hypervisor's administration plane on the production segment** (F-01) and the **exposure of RDP to the whole segment** (F-03), which open high-likelihood attack paths.

The treatment plan (workshop 5) relies on the measures **already in place** (Wazuh, pfSense, 3-2-1-0 backup with RTO < 1 s, rootless containers) and on the prioritised remediation of the PV-02 findings. Once the plan is applied, **no risk remains in the critical zone** (target; to date, hardening is partly applied and segmentation M-01 to M-04 is planned); the residual risks are considered acceptable, provided the short-term measures are followed up.

Workshop 1 — Framing and security baseline

1.1 Purpose of the workshop Define the study framework, identify the business values and supporting assets, formalise the related feared events with their severity, then assess the gap between the expected security baseline and the real state of the environment.

1.2 Business and technical scope



Business scope The "Hybrid InfraSec" lab aims to **demonstrate control of a hardened Zero-Trust architecture** combining enterprise infrastructure services (directory, files), a containerised DevSecOps chain and security monitoring. The "mission" of the system is to provide and prove:

- a centralised authentication and authorisation service (Active Directory, RBAC);
- a resilient, backed-up file storage service;
- an observability and incident detection chain (metrics + SIEM);
- business continuity (3-2-1-0 backup, controlled RTO).

Technical scope Single-segment virtualised infrastructure with a single chokepoint.

Component	Role	Address	Technical details
TeneT (host)	Hypervisor	— (administration)	Fedora 44, Cockpit, KVM/libvirt
pfSense	Firewall /chokepoint	`10.10.10.254`	Gateway, DNS, DHCP — single crossing point
Win-Server-DC	Domain controller	`10.10.10.10`	AD DS, forest `infrasec.local`, DNS, RBAC (OUs/groups)
TrueNAS	Storage	`10.10.10.20`	ZFS mirror, SMB share "partage" joined to the domain, NFSv4 ACLs
fedora	Container node	`10.10.10.30`	**Rootless** Podman: node-exporter, Prometheus, Grafana
wazuh-siem	SIEM	`10.10.10.40`	Wazuh 4.14 all-in-one, agents on DC and fedora, SCA/FIM/detection

Single network segment: `10.10.10.0/24`. All inter-zone traffic theoretically goes through pfSense (`.254`).

Assumptions: lab environment not exposed to the Internet for internal services; administration access assumed to be done from an operator workstation; no real production data (fictitious demo data).

1.3 Business values

Ref.	Business value	Type	Description
VM-1	Directory and authentication service	Process	Ability to authenticate and authorise (AD DS, Kerberos, RBAC). Trust foundation of the whole architecture.
VM-2	Integrity and availability of stored data	Information	Files of the SMB share "partage", datasets, configurations. Must stay available, intact and confidential.
VM-3	Monitoring and detection chain	Process	Metrics collection (Prometheus/Grafana) and incident detection (Wazuh: SCA, FIM, correlation). Guarantees visibility.
VM-4	Business continuity	Process	Ability to restore a healthy state (3-2-1-0 backup, RTO < 1 s validated in PV-01).

1.4 Supporting assets Each supporting asset is linked to the business values it carries.

Ref.	Supporting asset	Values carried	Component / scope
BS-1	Domain controller	VM-1	`Win-Server-DC` (AD DS, DNS, Kerberos, NTDS database)
BS-2	ZFS storage and shares	VM-2, VM-4	`TrueNAS` (mirrored ZFS pool, SMB, snapshots, replication)
BS-3	Container node	VM-3	`fedora` (rootless Podman, node-exporter, Prometheus, Grafana)

Ref.	Supporting asset	Values carried	Component / scope
BS-4	SIEM	VM-3	`wazuh-siem` (indexer, manager, DC/fedora agents)
BS-5	Firewall / chokepoint	VM-1 to VM-4	`pfSense` (filtering, DNS, DHCP, gateway)
BS-6	Hypervisor	VM-1 to VM-4	`TeneT` (Fedora 44, KVM/libvirt, Cockpit) — cross-cutting supporting asset of highest criticality

Architecture note — BS-6 (hypervisor) is a **cross-cutting** supporting asset: its compromise leads to the compromise of every virtualised supporting asset. BS-5 (pfSense) is the **segmentation asset**: its compromise neutralises the Zero-Trust model.

1.5 Severity scale

Level	Label	Criterion (impact on the lab's business values)
G1	Minor	Occasional nuisance, degraded service, no data loss, immediate recovery.
G2	Significant	Partial unavailability, loss of monitoring visibility, short remediation.
G3	Serious	Prolonged unavailability of a key service, partial loss of data integrity, loss of confidence in detection.
G4	Critical	Compromise of the trust core (AD) or loss/encryption of data; the lab's mission called into question.

1.6 Feared events

Ref.	Feared event	Business value	Supporting asset	Impact	Severity
ER-1	Compromise / takeover of the AD forest `infrasec.local` (escalation up to Domain Admin)	VM-1	BS-1	Total loss of trust in authentication; pivot to the whole domain	G4
ER-2	Malicious encryption (ransomware) or destruction of the SMB share data	VM-2, VM-4	BS-2	Unavailability and loss of integrity of the data; service interruption	G4
ER-3	Takeover of the TeneT hypervisor (escape / administration pivot)	VM-1 to VM-4	BS-6	Compromise of every VM; collapse of segmentation	G4
ER-4	Neutralising or blinding the monitoring chain (stopping Wazuh/agents, erasing traces)	VM-3	BS-4, BS-3	Loss of detection; attack not seen; no response possible	G3
ER-5	Bypassing segmentation through the pfSense firewall (taking over the chokepoint)	VM-1 to VM-4	BS-5	Loss of the Zero-Trust model; free lateral movement	G3
ER-6	Exfiltration of sensitive data (files, configuration secrets, credential hashes)	VM-2	BS-1, BS-2	Loss of confidentiality; reuse outside the scope	G3
ER-7	Alteration / unavailability of the metrics chain (Prometheus/Grafana)	VM-3	BS-3	Loss of operational visibility; decisions based on wrong data	G2

1.7 Security baseline and gaps The expected security baseline is based on the **ANSSI IT hygiene guide** and the Zero-Trust principles claimed by the lab. The PV-02 audit (hardening index **Lynis 69/100**) reveals the following gaps, reused as **vulnerabilities** in workshops 3 and 4.

Finding ref.	Gap with the baseline	Hygiene rule / principle	Level
F-01	Hypervisor administration IP present on the production segment	Separate administration networks (dedicated admin plane)	**High**
F-02	pfSense administration in clear over HTTP :80	Encrypted administration flows (TLS everywhere)	Medium
F-03	RDP (3389) open to the whole segment on the DC	Restricted administration access, minimal exposure	**Medium-High**
F-04	WS-Discovery exposed (TrueNAS)	Reduced attack surface (unneeded protocols)	Low
F-05	node-exporter :9100 without authentication	Authentication of exposed services	Low
F-06	Administration plane (SSH, Cockpit) reachable from the whole segment	Segmentation of the administration plane	Medium
F-07	Insufficient SSH hardening	Hardened SSH configuration	Low
F-08	Password policy could be improved	Robust credential management	Low
F-09	Unneeded protocols active	Disabling unneeded services	Low
F-10	Removable storage drivers active (USB /FireWire)	Reduced physical attack surface	Low
F-11	No automatic updates	Keeping systems secure (MCS)	Low

Workshop 1 conclusion — The architecture has a consistent baseline (chokepoint, RBAC, backup, SIEM) but **three structural gaps** (F-01, F-03, F-06) weaken the claimed Zero-Trust model: the administration plane is not segmented and sensitive accesses (hypervisor, RDP) are exposed to the whole segment.

Workshop 2 — Risk sources and targeted objectives

2.1 Purpose of the workshop Identify the relevant **Risk Source (SR) / Targeted Objective (OV)** pairs with regard to the business values, then assess them to keep the highest-priority ones for the rest of the study.

2.2 Assessment criteria

- **Motivation**: interest of the SR in reaching the OV (low / medium / high).
- **Resources**: technical, financial and human capabilities (limited / medium / high).
- **Activity / relevance**: plausibility with regard to the lab's scope.

Each pair receives an overall **relevance**: *Not very relevant* / *Relevant* / *Very relevant*.

2.3 SR/OV pairs identified and assessed

Ref.	Risk source	Targeted objective	Motivation	Resources	Relevance	Kept
SR-1	Organised cybercriminal (ransomware operator)	Financial gain through encryption / extortion (ER-2)	High	High	**Very relevant**	✅
SR-2	Opportunistic attacker /script kiddie	Easy compromise of an exposed service, defacement, pivot (ER-4, ER-7)	Medium	Limited	**Relevant**	✅

Ref.	Risk source	Targeted objective	Motivation	Resources	Relevance	Kept
SR-3	Malicious or careless employee / operator (insider threat)	Privilege abuse, exfiltration, sabotage (ER-6, ER-1)	Medium	Medium (legitimate access)	**Relevant**	✅
SR-4	State actor / APT	Espionage, long persistence, targeted exfiltration (ER-1, ER-6)	Low (lab with no strategic value)	High	**Not very relevant** (kept as a robustness benchmark)	⚠️
SR-5	Supplier / supply chain (container image, package)	Malicious code introduced through a dependency (ER-3, ER-4)	Medium	Medium	**Relevant**	✅

2.4 Justification of the selection

- **SR-1 (cybercriminal/ransomware)**: the dominant threat today; directly targets the SMB shares and AD. **Top priority.**
- **SR-2 (script kiddie)**: services exposed without authentication (F-05 node-exporter, F-04 WS-Discovery, F-02 clear HTTP) are low-effort targets. Relevant given the proven vulnerabilities.
- **SR-3 (insider)**: an operator with legitimate access (RDP open to the whole segment, SSH/Cockpit reachable) can abuse their rights. Relevant.
- **SR-4 (APT)**: kept as a **robustness benchmark** but ruled out as a priority scenario (the lab has no espionage value). It is not turned into an operational scenario.
- **SR-5 (supply chain)**: the DevSecOps chain (container images) introduces an external dependency. Relevant and current.

Pairs kept for workshops 3 and 4: SR-1, SR-2, SR-3, SR-5.

Workshop 3 — Strategic scenarios

3.1 Purpose of the workshop Map the ecosystem and stakeholders, draw the **strategic attack paths** (macro view SR → target), and confirm the severity of the scenarios.

3.2 Ecosystem and stakeholder map Since the lab is an almost self-contained internal environment, the ecosystem is small. Stakeholders are assessed by their **threat level** (dependency × penetration × cyber maturity × trust), on a simple scale from 1 (low) to 4 (high).

Stakeholder	Type	Dependency	Penetration	Cyber maturity	Threat level	Position
Operator / administrator	Internal	High (4)	High (4)	Medium (2)	**High**	Control zone — to watch (insider threat)
Container image supplier / registry	External digital	Medium (3)	Medium (2)	Variable (2)	**Medium**	Danger zone — supply chain
OS package repositories (Fedora, pfSense, Windows Update)	External digital	High (3)	Low (1)	High (3)	**Low-Medium**	Tolerated, to keep up to date (F-11)
Administration workstation /access network	Internal	High (4)	High (3)	Medium (2)	**High**	Favoured entry point for attack paths

Zero-Trust reading — The stakeholders with the highest threat level are **internal** (operator, admin workstation), which confirms that hardening the administration plane (F-01, F-03, F-06) is the central issue.

3.3 Strategic attack paths

Ref.	Risk source	Strategic attack path (macro)	Feared event(s) targeted	Severity
CS-1	SR-1 Cybercriminal	Entry point on the segment → service discovery → access to the SMB share → mass encryption → extortion	ER-2, ER-6	**G4**
CS-2	SR-1 / SR-3	Network access to the DC → exploiting exposed RDP → escalation to Domain Admin → control of the forest	ER-1	**G4**
CS-3	SR-2 / SR-3	Access to the poorly segmented administration plane → pivot to the hypervisor → control of every VM	ER-3, ER-5	**G4**
CS-4	SR-2	Segment scan → service exposed without authentication → neutralising/blinding monitoring	ER-4, ER-7	**G3**
CS-5	SR-5 Supply chain	Booby-trapped container image → execution on the fedora node → persistence / pivot	ER-3, ER-4	**G3**

Workshop 3 conclusion — Three strategic paths converge on severity **G4** and all rely on **vulnerabilities already found** in PV-02. They are detailed technically in workshop 4.

Workshop 4 — Operational scenarios

4.1 Purpose of the workshop Describe the strategic scenarios kept in technical terms, following the **kill chain / MITRE ATT&CK** logic, and assess their **likelihood**.

4.2 Likelihood scale

Level	Label	Criterion
V1	Minimal	Very difficult method of operation; no exploitable vulnerability identified.
V2	Significant	Feasible for a skilled attacker; one vulnerability to exploit.
V3	High	Direct path exploiting a proven vulnerability (PV-02); common skills.
V4	Maximal	Trivial exploitation; vulnerability exposed with no notable prerequisite.

4.3 Operational scenario SO-1 — Ransomware through the SMB share (SR-1)

Related strategic path: CS-1 — Feared events: ER-2 / ER-6 — Severity G4.

Kill chain phase	MITRE ATT&CK technique	Concrete action on the lab	Vulnerability exploited
Reconnaissance	T1046 Network Service Scanning	Scan of the segment `10.10.10.0/24` from a compromised host; discovery of SMB on `.20` and of WS-Discovery	F-04
Initial access /Credentials	T1078 Valid Accounts /T1110 Brute Force	Obtaining a domain account (weak password policy) giving SMB access	F-08
Discovery	T1135 Network Share Discovery	Enumeration of the "partage" share joined to the domain	—

Kill chain phase	MITRE ATT&CK technique	Concrete action on the lab	Vulnerability exploited
Impact	T1486 Data Encrypted for Impact	Mass encryption of the SMB share files	—
Impact	T1490 Inhibit System Recovery	Attempt to delete the snapshots	Countered by ZFS/3-2-1-0
Exfiltration	T1048 Exfiltration Over Alternative Protocol	File theft before encryption (double extortion)	F-06

Aggravating factors: SMB access from the whole segment, authentication policy could be improved (F-08).

Mitigating factors already in place: ZFS snapshots + replication + SHA-256 check (RTO < 1 s, PV-01); DC Wazuh agent detecting repeated authentication failures. Detection of mass changes on the share is still to be set up (M-03): TrueNAS has no Wazuh agent.

Likelihood: V3 (High) — detection is partial (authentications only) and access to the share is too broad.

4.4 Operational scenario SO-2 — AD compromise through exposed RDP (SR-1 / SR-3)

Related strategic path: CS-2 — Feared event: ER-1 — Severity G4.

Kill chain phase	MITRE ATT&CK technique	Concrete action on the lab	Vulnerability exploited
Reconnaissance	T1046	Discovery of port 3389 open on `Win-Server-DC` (`.10`) from the whole segment	**F-03**
Initial access	T1133 External Remote Services /T1110.001 Password Guessing	RDP access, brute-force attack or valid credentials	F-03, F-08
Execution	T1059 Command and Scripting Interpreter	Running commands on the DC	—
Escalation / Credential access	T1003.001 LSASS Memory /T1558 Kerberoasting	Extracting secrets, Kerberos tickets (service accounts with weak passwords)	F-08
Lateral movement	T1021.001 Remote Desktop Protocol	Pivot to Domain Admin, control of the forest `infrasec.local`	F-03
Persistence	T1098 Account Manipulation	Creating accounts/backdoors in the directory	—

Aggravating factors: RDP reachable from the **whole** segment (direct breach of Zero-Trust).

Mitigating factors already in place: Wazuh agent on the DC (detection of abnormal authentications, SCA, FIM); RBAC restricting some accounts.

Likelihood: V3 (High) — exposed RDP is a classic, proven vector; only Wazuh detection reduces the impact.

4.5 Operational scenario SO-3 — Pivot from the administration plane to the hypervisor (SR- 2 / SR-3)

Related strategic path: CS-3 — Feared events: ER-3 / ER-5 — Severity G4.

Kill chain phase	MITRE ATT&CK technique	Concrete action on the lab	Vulnerability exploited
Reconnaissance	T1046	Scan revealing SSH/Cockpit and the hypervisor administration IP on the production segment	**F-01**, F-06

Kill chain phase	MITRE ATT&CK technique	Concrete action on the lab	Vulnerability exploited
Initial access	T1078 / T1110	SSH/Cockpit access (insufficient SSH hardening)	F-07, F-01
Escalation	T1068 Exploitation for Privilege Escalation	Gaining privileges on the TeneT host (Fedora 44 / KVM)	F-11
Hypervisor control	T1611 Escape to Host (VM context)	Control of libvirt/KVM → access to every VM	—
Lateral movement	T1021.004 SSH	Access to the other VMs from the hypervisor	—
Impact	T1565 Data Manipulation	Altering / stopping any VM, including pfSense (ER-5)	F-01

Aggravating factors: F-01 (hypervisor administration IP on the production segment) is the **worst structural gap** — it puts the most critical supporting asset (BS-6) within reach of the segment.

Mitigating factors already in place: Cockpit over an encrypted channel; system logging; updates (partial — F-11).

Likelihood: V3 (High) — direct path exploiting the high-severity vulnerability F-01.

4.6 Operational scenario SO-4 — Blinding monitoring and exploiting an unauthenticated service (SR-2 / SR-5)

Related strategic path: CS-4 / CS-5 — Feared events: ER-4 / ER-7 — Severity G3.

Kill chain phase	MITRE ATT&CK technique	Concrete action on the lab	Vulnerability exploited
Reconnaissance	T1046	Discovery of node-exporter `:9100` without authentication on `fedora (.30)`	**F-05**
Initial access	T1190 Exploit Public-Facing Application / T1195 Supply Chain Compromise	Exploiting an exposed service or a booby-trapped container image	F-05, SR-5
Execution	T1610 Deploy Container / T1059	Execution in a Podman container	Limited by **rootless**
Defence evasion	T1562.001 Disable or Modify Tools	Attempt to stop the Wazuh agent /node-exporter	—
Defence evasion	T1070 Indicator Removal	Erasing traces, fake metric signals (ER-7)	F-05
Impact	T1498 Network Denial of Service	Disrupting Prometheus/Grafana collection	—

Aggravating factors: metrics service without authentication (F-05); dependency on the image chain (SR-5).

Mitigating factors already in place: **rootless Podman** strongly limits container escape and escalation; Wazuh SCA/FIM on fedora; SIEM correlation detecting an agent stop.

Likelihood: V2 (Significant) — the exposure is real but rootless confinement and SIEM detection reduce its reach.

4.7 Summary of the operational scenarios (severity × likelihood)



Scenario	SR	ER targeted	Severity	Likelihood	Risk level (before treatment)
SO-1 Ransomware through SMB	SR-1	ER-2, ER-6	**G4**	**V3**	**Critical**
SO-2 AD compromise through RDP	SR-1/SR-3	ER-1	**G4**	**V3**	**Critical**
SO-3 Pivot to the hypervisor	SR-2/SR-3	ER-3, ER-5	**G4**	**V3**	**Critical**
SO-4 Blinding monitoring /unauthenticated service	SR-2/SR-5	ER-4, ER-7	**G3**	**V2**	**High**

Workshop 5 — Risk treatment

5.1 Purpose of the workshop Define the **continuous security improvement plan (PACS)**, derive the measures from the existing controls and the remediation of the PV-02 findings, then assess the **residual risks** and produce the before/after map.

5.2 Treatment strategy The strategy chosen is risk **reduction** (lowering likelihood through segmentation and authentication), backed by a restored Zero-Trust posture. **Transfer** does not apply (lab); **avoidance** is not desirable (the services are the lab's mission); **acceptance** is reserved for low residual risks or, for a high residual risk whose severity is intrinsic, for an explicit decision by the CISO: justified, backed by detection and recovery measures, dated and reviewed periodically.

5.3 Security measures already in place (baseline to build on)

Existing measure	Risk covered	Contribution
3-2-1-0 backup (ZFS snapshots + replication + SHA-256 check, RTO < 1 s — PV-01)	SO-1	Almost immediate restore after encryption; neutralises extortion through unavailability
Wazuh 4.14 (SCA, FIM, correlation, DC + fedora agents)	SO-1, SO-2, SO-4	Detection of abnormal authentications, of file changes on hosts with an agent (FIM), of agent stops
pfSense single chokepoint	SO-2, SO-3	Native micro-segmentation capability to enable fully
Rootless Podman	SO-4	Drastic reduction of the impact of a container escape
Active Directory RBAC (OUs/groups)	SO-2	Least privilege on the directory
Prometheus/Grafana	SO-4	Detection of availability anomalies

5.4 Treatment plan (PACS) — remediation measures Priorities: **P1** short term (immediate) · **P2** medium term · **P3** continuous improvement.

Measure ref.	Measure	Finding(s) /scenario(s) treated	Type	Priority	Expected effect
M-01	Create a **dedicated administration VLAN / network** for the hypervisor, SSH and Cockpit; remove the hypervisor admin IP from the production segment	F-01, F-06 → SO-3	Preventive	**P1**	SO-3 likelihood: V3 → V1

Measure ref.	Measure	Finding(s) /scenario(s) treated	Type	Priority	Expected effect
M-02	Restrict **RDP** to the admin workstation only with a *host-based* rule (DC Windows firewall, the flow staying inside the segment); enable NLA; log in Wazuh	F-03 → SO-2	Preventive	**P1**	SO-2 likelihood: V3 → V2
M-03	Micro-segment the **SMB** share: limit access to the AD groups that need it; enable SMB hardening; FIM alerts on an abnormal change rate	SO-1	Preventive + Detection	**P1**	SO-1 likelihood: V3 → V2
M-04	Force **pfSense administration over HTTPS/TLS**; disable HTTP :80	F-02 → SO-3	Preventive	**P1**	Removes clear-text listening for admin credentials
M-05	Authenticate and restrict **node-exporter** (TLS + token /filtering by Prometheus IP)	F-05 → SO-4	Preventive	**P2**	SO-4 likelihood: V2 → V1
M-06	Disable **WS-Discovery**, unneeded protocols and removable storage drivers	F-04, F-09, F-10 → SO-1	Preventive	**P2**	Reduced attack surface
M-07	**Harden SSH** (keys only, root disabled, MFA if possible) and apply a robust AD **password policy**	F-07, F-08 → SO-2/SO-3	Preventive	**P2**	Reduces brute force and credential abuse
M-08	Generalise **automatic updates** and vulnerability tracking (Wazuh SCA)	F-11 → SO-3	Corrective	**P2**	Reduces exploitation of known flaws (T1068)
M-09	Harden the OSes to **raise the Lynis index** above 80/100; replay the audit	F-07 to F-10 → all	Corrective	**P3**	Measurable continuous improvement
M-10	Check and **sign the container image chain** (trusted images, scanning, registry policy)	SR-5 → SO-4	Preventive	**P3**	Reduces the supply chain risk
M-11	**Protect the backups** (read-only / immutable snapshots, isolated replication channel)	SO-1 (T1490)	Preventive	**P2**	Guarantees restore despite a destruction attempt
M-12	Harden **Cockpit** access (TLS, strong authentication, admin network)	F-06 → SO-3	Preventive	**P2**	Reduces the hypervisor administration vector

5.5 Residual risks

Scenario	Level before	Plan measures	Residual severity	Residual likelihood	Residual level	Decision
SO-1 SMB ransomware	Critical (G4×V3)	M-03, M-06, M-11 + 3-2-1-0, Wazuh	G4	**V2**	**High**	Reduced — accepted under monitoring (restore RTO < 1 s)

Scenario	Level before	Plan measures	Residual severity	Residual likelihood	Residual level	Decision
SO-2 AD compromise	Critical (G4×V3)	M-02, M-07 + RBAC, Wazuh	G4	**V2**	**High**	Reduced — closer monitoring of RDP detection
SO-3 Hypervisor pivot	Critical (G4×V3)	M-01, M-04, M-08, M-12	G4	**V1**	**Moderate**	Strongly reduced — admin plane segmented
SO-4 Blinding monitoring	High (G3×V2)	M-05, M-06, M-10 + rootless, Wazuh	G3	**V1**	**Moderate**	Strongly reduced — accepted

Main residual risk — Even after treatment, SO-1 and SO-2 keep a G4 severity (intrinsic to the trust core) with likelihood brought down to V2. They are **accepted** because: (1) the 3-2-1-0 backup guarantees continuity (ER-2), and (2) Wazuh detection ensures reactivity. Quarterly follow-up of detection effectiveness is recommended.

5.6 Risk map — before / after treatment Severity (G1–G4) × Likelihood (V1–V4) matrix. Position of each scenario.

Before treatment

Severity / likelihood	V1	V2	V3	V4
G4			SO-1, SO-2, SO-3	
G3		SO-4		
G2				
G1				

After treatment

Severity / likelihood	V1	V2	V3	V4
G4	SO-3	SO-1, SO-2		
G3	SO-4			
G2				
G1				

Reading — Treatment moves the three critical scenarios out of column V3: SO-3 goes to V1 (segmented admin plane), SO-1 and SO-2 to V2 (access restriction + detection). **No scenario remains in the critical zone (G4×V3/V4).** The residual risks sit between the "controlled high" and "moderate" zones.

General conclusion The EBIOS RM assessment of the "Hybrid InfraSec" lab confirms the relevance of the targeted Zero-Trust architecture, while objectively measuring the gap between the stated intent and the audited configuration (PV-02, Lynis 69/100). The three critical risks identified — **ransomware on the SMB share (SO-1)**, **compromise of Active Directory through RDP (SO-2)** and **pivot to the hypervisor (SO-3)** — all stem from a **lack of segmentation of the administration plane and overly broad access** (F-01, F-03, F-06).

The proposed treatment plan relies first on the measures **already present** (3-2-1-0 backup with RTO < 1 s, Wazuh SIEM, rootless Podman, pfSense chokepoint) and on targeted, low-cost remediations (dedicated administration network, RDP restriction, SMB micro-segmentation, TLS everywhere, service authentication). Implementing them brings

every scenario out of the critical risk zone, restoring the consistency of the Zero-Trust model and raising the infrastructure to a maturity level in line with the AIS certification.

Addendum D.1 — Traceability PV-02 findings → scenarios → measures

Finding	Scenario(s)	Treatment measure(s)
F-01 (High)	SO-3	M-01
F-02 (Medium)	SO-3	M-04
F-03 (Medium-High)	SO-2	M-02
F-04 (Low)	SO-1	M-06
F-05 (Low)	SO-4	M-05
F-06 (Medium)	SO-3	M-01, M-12
F-07 (Low)	SO-2, SO-3	M-07
F-08 (Low)	SO-1, SO-2	M-07
F-09 (Low)	SO-1	M-06
F-10 (Low)	SO-1	M-06, M-09
F-11 (Low)	SO-3	M-08

Addendum D.2 — Business values / supporting assets / feared events

Business value	Supporting assets	Feared events
VM-1 Directory / authentication	BS-1, BS-5, BS-6	ER-1, ER-6
VM-2 Data integrity/availability	BS-2, BS-6	ER-2, ER-6
VM-3 Monitoring / detection	BS-3, BS-4, BS-6	ER-4, ER-7
VM-4 Business continuity	BS-2, BS-6	ER-2

End of document — EBIOS Risk Manager, "Hybrid InfraSec" lab.

Annex E · Information systems security policy (ISSP)

"Hybrid InfraSec" lab — Zero-Trust architecture (DevSecOps / CloudSec)

Item	Value
Document title	Information Systems Security Policy (ISSP, French PSSI)
Scope	AIS certification lab "Hybrid InfraSec"
Reference	PSSI-HIS-2026-01
Revision	11 October 2026
Classification	Restricted distribution (jury / operator)
Publication date	4 October 2026
Author	Chief Information Security Officer (CISO, French RSSI)
Approval	CISO
Review cycle	Yearly or after any major incident / structural change

Drafting note — This document uses normative terms: **MUST** / **MUST NOT** (mandatory requirement), **SHOULD** (strong recommendation), **MAY** (option). No public IP address, real secret or key fingerprint appears in this deliverable; the values shown are internal lab conventions.

Contents 1. Article 1 — Purpose, scope and reach

2. Article 2 — Framework and normative references

3. Article 3 — Security organisation and governance

4. Article 4 — Asset classification and management

5. Article 5 — Identity and access management

6. Article 6 — Network security and segmentation

7. Article 7 — Hardening of systems and containers

8. Article 8 — Data protection, backup and continuity

9. Article 9 — Logging, monitoring and detection

10. Article 10 — Security incident management

11. Article 11 — Secrets and cryptography management

12. Article 12 — Compliance, audit and continuous improvement

13. Appendices

Article 1 — Purpose, scope and reach

1.1 Purpose

1.1.1 This Information Systems Security Policy (hereafter "ISSP") defines all the rules, guiding principles and technical and organisational requirements that apply to the AIS certification lab "**Hybrid InfraSec**".

1.1.2 The purpose of the ISSP is to guarantee, in a verifiable and auditable way, the following security properties across the whole scope:

- **Confidentiality**: information is accessible only to authorised entities.
- **Integrity**: data, configurations and logs cannot be altered in an unauthorised or undetected way.
- **Availability**: services and data are accessible according to the continuity objectives defined in Article 8.
- **Traceability / accountability**: every significant action is logged and attributable to an identity.
- **Evidence**: the elements needed for audit and litigation are kept and protected.

1.2 Technical scope

1.2.1 The scope covers the whole infrastructure hosted on the physical host **TeneT** and its hosting network:

Component	Host / Role	Address	Main functions
TeneT	Fedora 44 hypervisor	physical host	Cockpit, KVM/libvirt, virtualisation administration
pfSense	Firewall / single crossing point	`10.10.10.254`	Filtering, routing, DNS resolver, gateway, DHCP
Win-Server-DC	Domain controller	`10.10.10.10`	Active Directory DS (forest `infrasec.local`), AD DNS, RBAC
TrueNAS	Storage	`10.10.10.20`	ZFS mirror, SMB share joined to the domain, NFSv4 ACLs
fedora	Container node	`10.10.10.30`	Rootless Podman: node-exporter, Prometheus, Grafana, Zabbix
wazuh-siem	SIEM	`10.10.10.40`	Wazuh 4.14 (manager, SCA, FIM, detection)

1.2.2 The lab's single network segment is `10.10.10.0/24`. All traffic entering or leaving the segment **MUST** go through the single crossing point (*chokepoint*) pfSense (`10.10.10.254`). Inside the segment, flows between machines do not cross pfSense: they are restricted by the hosts' local filtering (see 6.3).

1.3 Organisational scope and reach

1.3.1 The ISSP applies to:

- the lab operator and anyone with access (administrator, auditor, jury member during assessment);
- all the hardware, software, virtual, containerised and information assets listed in Article 4;
- any third-party provider or tool working on the scope.

1.3.2 Any exception to a rule of this ISSP **MUST** be the subject of a formal, justified request, recorded, limited in time and approved by the CISO. Active exceptions **MUST** be listed in the exceptions register (Addendum E.3) and reviewed at each audit cycle.

1.3.3 Failure to comply with the ISSP rules is a non-compliance that may lead to the immediate suspension of the access concerned and, where applicable, to failing the certification.

Article 2 — Framework and normative references

2.1 Alignment principle

2.1.1 The ISSP aligns, **as a methodological reference**, with the frameworks below. Since the lab is a training certification environment, this alignment aims at consistency and verifiability, with no claim to formal certification against the frameworks cited.

2.2 Reference frameworks

Framework	Area covered	Use in the ISSP
ISO/IEC 27001	Information security management system (ISMS)	Governance structure, risk-based approach, PDCA cycle (Art. 3, 12)
ISO/IEC 27002	Security controls (good practice)	Selection and wording of the measures (Art. 4 to 11)
ISO/IEC 27005	Risk management	Risk assessment and treatment
ANSSI guides	IT hygiene, secure administration, logging, Active Directory	Hardening, administration plane, logging policy (Art. 5, 6, 7, 9)
CIS Benchmarks	Hardened configurations (Windows Server / AD, Linux, Docker/Podman)	Hardening of systems and containers (Art. 7)
CIS Controls v8	Prioritised security controls	Asset and access management, logging
NIST SP 800-207	Zero-Trust architecture	Cross-cutting guiding principle (Art. 6)
OWASP (ASVS, Secrets Management)	Application and secrets security	Secrets management (Art. 11)

2.3 Guiding principles

2.3.1 The whole ISSP is governed by the following guiding principles, which prevail whenever a rule is ambiguous:

1. **Zero-Trust** — No implicit trust is granted based on network location. Every request is authenticated, authorised and checked.

2. **Least privilege** — Each identity, service or container only has the rights strictly needed for its function.

3. **Defence in depth** — Security measures are layered (network, system, container, application, data) so that no single failure compromises the scope.

4. **Secure by default** — Delivered configurations are restrictive (*deny by default*); opening is the justified exception.

5. **Full traceability** — Every administration or security action is logged centrally and timestamped.

6. **Encryption in transit** — Any flow carrying authentication, administration or sensitive data **MUST** be encrypted (TLS, SSH or WireGuard).

Article 3 — Security organisation and governance

3.1 Roles and responsibilities

3.1.1 Security governance relies on a separation of roles. One person **MAY** hold several roles in this single-operator lab, but actions **MUST** remain traceable by distinct functional role (dedicated accounts — see Article 5).

Role	Main responsibilities	Reports to
CISO	Defines, maintains and enforces the ISSP; approves exceptions; drives the risk analysis and the PDCA; approves structural changes	Security authority

Role	Main responsibilities	Reports to
System / Virtualisation administrator	Runs TeneT, KVM/libvirt, Cockpit; applies host hardening; manages snapshots	Operations
Active Directory administrator	Manages the forest `infrasec.local`, accounts, groups, GPOs and RBAC	Operations
Network / Firewall administrator	Manages pfSense, filtering rules, DHCP, DNS and segmentation	Operations
Storage administrator	Manages TrueNAS, ZFS pools, NFSv4 ACLs, SMB shares, replication	Operations
Container operator (DevSecOps)	Runs rootless Podman, Prometheus, Grafana, Zabbix; applies OCI hardening	Operations
Security analyst / SOC	Runs Wazuh; watches, qualifies and handles alerts; leads lessons-learned reviews	Detection & response
Auditor	Checks compliance; produces the audit reports (PV)	Control (read access)

3.1.2 The principle of **segregation of duties MUST** be respected in spirit: the entity that runs a service **MUST NOT** be the only one to check its own logs. The audit function and SIEM monitoring **MUST** have independent read access that operations administrators cannot modify.

3.2 Security committee and review

3.2.1 A security review **MUST** be held at least at the end of each audit cycle and after any major incident. It covers: the state of risks, incidents, active exceptions, SCA/FIM results, the state of backups and the improvement plan.

3.2.2 The review's decisions **MUST** be recorded in a dated decision log kept as evidence.

3.3 Documentation and upkeep

3.3.1 The ISSP, the related procedures and the registers (assets, exceptions, incidents, secrets) **MUST** be kept up to date and versioned.

3.3.2 Any change to the ISSP **MUST** be approved by the CISO, traced (version, date, reason) and communicated to the roles concerned.

Article 4 — Asset classification and management

4.1 Asset inventory

4.1.1 A complete asset inventory **MUST** be kept up to date. No asset (virtual machine, container, share, ZFS pool, service account) **MAY** exist outside the inventory.

4.1.2 Each asset **MUST** have an owner (responsible role), a classification level and a criticality level.

4.2 Classification scale

4.2.1 Information and assets are classified on the following scale:

Level	Label	Examples in scope	Minimum requirement
C3	Critical / Secret	Authentication secrets, private keys, NTDS database (AD), password hashes	Encryption, restricted named access, enhanced logging
C2	Confidential	pfSense configurations, GPOs, Wazuh rules, security logs	Role-based access, encryption in transit, backup

Level	Label	Examples in scope	Minimum requirement
C1	Internal	Grafana dashboards, Prometheus metrics, operations documentation	Authenticated access
C0	Public / Not sensitive	Document templates, legal banners	No specific restriction

4.3 Criticality and link with continuity

4.3.1 The criticality of each asset determines its backup and recovery objectives (see Article 8).

Asset	Classification	Criticality	Impact of a compromise
`Win-Server-DC` (AD / forest `infrasec.local`)	C3	Vital	Loss of control of RBAC and of authentication across the whole scope
`pfSense` (chokepoint)	C2	Vital	Loss of segmentation and filtering; lateral exposure
`wazuh-siem`	C2	High	Loss of detection and traceability
`TrueNAS` (ZFS data)	C3/C2	High	Loss / leak of stored data
`fedora` (containers)	C1	Medium	Loss of application monitoring
`TeneT` (hypervisor)	C2	Vital	Compromise of every VM

4.4 Life cycle and disposal

4.4.1 Any end-of-life asset (VM, snapshot, share, account) **MUST** be disabled then deleted in a traceable way, and removed from the inventory.

4.4.2 Media and datasets holding C2 or C3 data **MUST** be securely erased (destruction of the ZFS datasets and their snapshots) before reuse or disposal.

Article 5 — Identity and access management

5.1 Principles

5.1.1 The single authentication and authorisation authority of the scope is **Active Directory** (forest `infrasec.local`), carried by `Win-Server-DC`. Resources that can be joined to the domain (e.g. TrueNAS SMB shares) **MUST** rely on Active Directory RBAC.

5.1.2 The principle of **least privilege MUST** apply to every identity. Rights are granted through group membership, never directly to an individual on the resources.

5.1.3 Every action **MUST** be attributable to a named identity. Shared generic accounts **ARE FORBIDDEN**, except explicitly listed service accounts (see 5.4).

5.2 Role and access matrix (RBAC)

5.2.1 Access is granted according to the following matrix. Any grant outside the matrix **MUST** be covered by an exception.

AD group / Role	TeneT /Cockpit	pfSense	AD (Win-Server-DC)	TrueNAS (SMB)	fedora (containers)	Wazuh
CISO	Read	Read	Read	Read	Read	Admin read

AD group / Role	TeneT /Cockpit	pfSense	AD (Win-Server-DC)	TrueNAS (SMB)	fedora (containers)	Wazuh
Virtualisation admin	Admin	—	—	—	—	Agent (read)
AD admin	—	—	Admin	—	—	Agent (read)
Network admin	—	Admin	—	—	—	Agent (read)
Storage admin	—	—	Domain join member	Admin	—	Agent (read)
Container operator	—	—	—	Read dedicated datasets	Admin (non-root)	Agent (read)
SOC analyst	Read logs	Read logs	Read logs	Read logs	Read logs	Admin
Auditor	Read	Read	Read	Read	Read	Read
Service user	—	—	per SPN	per dataset ACL	per service	Agent

Key: **Admin** = full administration · **Read** = read-only · **—** = no access · **Agent** = logs sent to the SIEM.

5.3 Privileged accounts

5.3.1 Domain administration accounts (e.g. members of *Domain Admins*, *Enterprise Admins*) **MUST** be strictly limited and named, and **MUST NOT** be used for everyday tasks or browsing.

5.3.2 Administration **MUST** follow the *tiering* principle: highly privileged accounts **MUST NOT** be exposed on less trusted machines. The administration plane is restricted according to Article 6.

5.3.3 Privileged accounts **MUST** be disabled as soon as they are no longer needed and reviewed at each audit cycle.

5.4 Service accounts

5.4.1 Each service (SMB domain join, Wazuh agent, metrics exporter, etc.) **MUST** have a dedicated service account, documented in the inventory, with the minimum scope of rights.

5.4.2 Service accounts **MUST NOT** have interactive logon rights when these are not required.

5.4.3 Passwords of multi-platform service accounts (Windows / Linux / NAS) **MUST** use characters that type identically across keyboard layouts to avoid input errors between platforms, while keeping high entropy (see 5.5).

5.5 Password policy and multi-factor authentication

5.5.1 The password policy is set by GPO on the domain and **MUST** meet at least:

Setting	Requirement
Minimum length (user accounts)	14 characters
Minimum length (privileged /service accounts)	20 characters
Complexity	Upper case, lower case, digits and special characters
Keyboard compatibility (multi-platform accounts)	Characters typed identically on the target layouts
History	Last 24 passwords cannot be reused

Setting	Requirement
Lockout	After 5 failed attempts, over a 15-minute window
Rotation of privileged / service accounts	At least every 90 days and at any suspicion of compromise
Storage	Never in clear; see Article 11

5.5.2 Multi-factor authentication (**MFA**) **SHOULD** be enabled for any administration access where the component allows it (e.g. pfSense interface, Cockpit access through a compatible solution). Where MFA is not natively available, the compensation **MUST** be documented (network restriction of the administration plane, high-entropy passwords, stricter rotation).

5.5.3 The default passwords of every component (pfSense, TrueNAS, Grafana, Wazuh, Cockpit) **MUST** be changed at installation.

5.6 Access life cycle

5.6.1 Any creation, change or removal of access **MUST** be traced and justified.

5.6.2 A review of accounts and group memberships **MUST** be carried out at each audit cycle to detect dormant or excessive rights.

Article 6 — Network security and segmentation

6.1 Single crossing point (chokepoint)

6.1.1 The **pfSense** firewall (`10.10.10.254`) is the single, mandatory crossing point for all flows entering or leaving the segment, including WireGuard remote access. It acts as gateway, DNS resolver, DHCP server and filter.

6.1.2 No flow **MAY** bypass the chokepoint. Any alternative route, unauthorised tunnel or extra network interface on a VM is a non-compliance and **MUST** be removed.

6.2 Deny by default filtering

6.2.1 The filtering policy **MUST** follow the *deny by default* principle: any flow not explicitly allowed is blocked.

6.2.2 Allow rules **MUST** be named (source, destination, port, protocol, justification) and listed. Any obsolete rule **MUST** be removed.

6.2.3 Reference matrix of allowed flows (any missing line is forbidden):

Source	Destination	Service / Port	Protocol	Justification
Segment workstations / VMs	`pfSense .254`	DNS (53), DHCP (67/68)	UDP/TCP	Resolution and addressing
All VMs	`Win-Server-DC .10`	Kerberos (88), LDAP (389/636), DNS (53), SMB (445)	TCP/UDP	Authentication, RBAC, domain join
`TrueNAS .20`	`Win-Server-DC .10`	Kerberos/LDAP	TCP/UDP	SMB join to the domain
Authorised clients	`TrueNAS .20`	SMB (445)	TCP	Share access per ACL (NFS service not enabled)
`fedora .30`	`Win-Server-DC .10`	DNS (53)	UDP/TCP	Resolution
Wazuh agents (`Win-Server-DC` , `fedora`)	`wazuh-siem .40`	1514/1515	TCP	Log forwarding /agent enrolment

Source	Destination	Service / Port	Protocol	Justification
`fedora .30` (Prometheus)	`Win-Server-DC .10` (windows_exporter)	9182	TCP	DC metrics; fedora's node-exporter queried locally (9100 not exposed, F-05)
Administration plane	Admin interfaces (Cockpit, pfSense, TrueNAS, Grafana, Wazuh)	HTTPS (443) / admin ports	TCP (TLS)	Administration (see 6.4)
Internet	pfSense WAN	WireGuard (51820)	UDP	Encrypted remote access (only port open on the WAN)
Peer `admin-remote10.10.20.2`	Segment `10.10.10.0/24`	Administration ports	TCP/UDP	Remote administration (restriction to the administration interfaces planned)
Peer `employe-remote10.10.20.3`	`TrueNAS .20`	SMB (445)	TCP	Employee file sharing
`fedora .30` (Zabbix)	`pfSense .254`	SNMP (161)	UDP	Network monitoring of the firewall, restricted to the collector (v2c in the lab, v3 required in production)

6.3 Segmentation and micro-segmentation

6.3.1 Although the lab relies on a single segment `10.10.10.0/24`, the Zero-Trust principle **MUST** be applied through **logical micro-segmentation**: flows entering or leaving the segment are filtered by pfSense; communications between VMs in the segment, which do not cross pfSense, are restricted by host filtering (local rules) to the strict minimum defined in 6.2.3, pending the dedicated administration network (EBIOS measure M-01).

6.3.2 Communications between VMs **MUST NOT** be allowed globally. The absence of an explicit rule means prohibition, including for machines in the same subnet.

6.4 Restricting the administration plane (Zero-Trust)

6.4.1 The administration interfaces (Cockpit on TeneT, pfSense console, TrueNAS interface, Grafana, Wazuh dashboard) **MUST NOT** be exposed to the whole segment. Access to them **MUST** be restricted to explicitly authorised administration-plane sources.

6.4.2 Any administration access **MUST** be encrypted (TLS / HTTPS / SSH). Clear-text administration protocols (HTTP, Telnet) **ARE FORBIDDEN**.

6.4.3 Administration services **MUST NOT** listen on unneeded interfaces or addresses.

6.5 Network services

6.5.1 Internal DNS resolution is provided by `Win-Server-DC` for the `infrasec.local` zone and relayed/filtered through pfSense. Unauthorised resolvers **ARE FORBIDDEN**.

6.5.2 The DHCP server runs exclusively on pfSense. Any other DHCP service on the segment is a non-compliance (rogue DHCP risk).

Article 7 — Hardening of systems and containers

7.1 System hardening

7.1.1 All systems (TeneT, Linux VMs, `Win-Server-DC`) **MUST** be hardened according to the applicable **CIS Benchmarks** and the ANSSI hygiene guides.

7.1.2 Unneeded services, accounts and software **MUST** be disabled or removed (attack surface reduction).

7.1.3 File permissions **MUST** follow least privilege. **Using `chmod 777` (or any mode granting write access to everyone) IS FORBIDDEN.** Rights **MUST** be controlled through an appropriate owner (`chown`), dedicated groups and, for containers, *user namespaces*.

7.1.4 A recovery snapshot (**Snapper** / **ZFS**) **MUST** be taken before any major operation (update, structural configuration change, deployment) to allow a quick rollback.

7.2 Container hardening (rootless OCI)

7.2.1 Containers **MUST** run in **rootless OCI mode by default** (Podman) on the `fedora` node. Isolation **MUST** rely on *user namespaces*.

7.2.2 Any need for **root privilege**, a privileged container or the exposure of a **privileged port (< 1024) MUST** be justified in writing, approved by the CISO and listed in the exceptions register. Without justification, such configurations **ARE FORBIDDEN**.

7.2.3 Container images **MUST** come from trusted sources, be versioned (no systematic use of `latest` in operations) and be scanned for vulnerabilities before deployment.

7.2.4 Containers **MUST** apply least privilege: removal of unneeded Linux capabilities, read-only file systems where possible, and no clear-text secret in the image or in persisted environment variables (see Article 11).

7.2.5 Summary of container rules:

Rule	Requirement
Execution mode	Rootless (Podman) by default
Isolation	User namespaces mandatory
Root / privileged	Forbidden unless a justified, approved exception
Port < 1024	Forbidden unless a justified, approved exception
`chmod 777` in volumes	Forbidden (use `chown` + groups)
Image origin	Trusted sources, pinned tag, scanned
Linux capabilities	Reduced to the strict minimum
Secrets	Never in clear (see Art. 11)

7.3 Vulnerability and update management

7.3.1 Systems and images **MUST** be watched and analysed for vulnerabilities regularly. Wazuh's **SCA** (Security Configuration Assessment) module **MUST** be enabled on the agents to assess compliance with the hardening baselines.

7.3.2 Security patches **MUST** be applied within delays proportionate to criticality: at once for an actively exploited critical vulnerability affecting a vital asset; in the planned maintenance cycle for the others.

7.3.3 Every update **MUST** be preceded by a recovery snapshot (see 7.1.4) and followed by a functional check.

Article 8 — Data protection, backup and continuity

8.1 Protection of data at rest and in transit

8.1.1 C2 and C3 data **MUST** be protected. Encryption at rest **SHOULD** be applied to sensitive TrueNAS datasets where the platform allows it (native ZFS encryption).

8.1.2 Any transport of authentication, administration or sensitive data **MUST** be encrypted in transit (TLS/signed SMB/secure NFS/SSH/HTTPS).

8.2 Data access control (ACL)

8.2.1 TrueNAS SMB shares **MUST** be joined to the `infrasec.local` domain and their access governed by Active Directory RBAC through groups.

8.2.2 NFSv4 ACLs MUST be defined on least privilege, avoiding any broad permission (`everyone` / world write access). Using `chmod 777` on shared datasets **IS FORBIDDEN** (see 7.1.3).

8.3 3-2-1-0 backup strategy

8.3.1 The backup strategy **MUST** follow the **3-2-1-0** model:

Digit	Meaning	Implementation in the lab
3	3 copies of the data	Production data + local ZFS snapshot + replication
2	2 different storage media	Separate replication target (`tank/partage_backup`); second physical medium in production (in the lab, same pool: see PV-01)
1	1 off-site / isolated copy	Replication to a remote site in production (not reached in the lab: see PV-01)
0	0 verified errors	Integrity check with a **SHA-256** hash

8.3.2 The mechanisms **MUST** include: scheduled ZFS snapshots, replication of the snapshots to a separate target, and integrity checks with a SHA-256 hash after each replication.

8.3.3 Restore **MUST** be tested periodically (documented restore test), since a backup that cannot be restored has no value.

8.4 Continuity objectives (RPO / RTO) and DRP

8.4.1 The recovery objectives per asset class are:

Asset / Data	RPO (max. data loss)	RTO (max. recovery time)	Mechanism
Critical ZFS datasets (TrueNAS)	≤ 1 h (hourly snapshots)	**< 1 s** (switch / snapshot rollback)	ZFS snapshots + replication
VM state after a major operation	0 (snapshot before the operation)	Immediate (rollback)	Snapper / ZFS
Active Directory (`infrasec.local`)	Low	Per AD restore procedure	System state backup /snapshot
pfSense configuration	Low	Fast (configuration import)	Configuration export

8.4.2 A disaster recovery plan (**DRP**, French PRA) **MUST** document the restart order (pfSense chokepoint, then AD, then dependent services), the restore procedures and the people responsible. The DRP **MUST** be tested at least once per cycle.

8.4.3 Snapshots and replications **MUST** be monitored; any failure **MUST** raise an alert handled according to Article 10.

Article 9 — Logging, monitoring and detection

9.1 Centralised logging

9.1.1 All assets in scope **MUST** send their logs to the central **Wazuh** SIEM (`wazuh-siem`, `10.10.10.40`) through an agent or a dedicated flow. *Status on 11/10/2026: agents deployed on* `Win-Server-DC` *and* `fedora`*; connecting pfSense, TrueNAS and the hypervisor to the SIEM remains to be done (tracked gap).*

9.1.2 Logs **MUST NOT** be modifiable or deletable by the operations administrators of the monitored machines. Integrity and retention are managed on the SIEM side.

9.1.3 The clocks of all systems **MUST** be synchronised (common time reference) to guarantee consistent correlations.

9.2 Logging policy

9.2.1 At least the following events **MUST** be logged and forwarded:

Source	Events logged	Purpose
`Win-Server-DC` (AD)	Authentications (success/failure), changes to accounts/groups, privilege escalations, GPOs	RBAC traceability, abuse detection
`pfSense`	Blocked/allowed flows, rule changes, VPN/admin events	Chokepoint monitoring
`TrueNAS`	Share access, ACL changes, ZFS errors, snapshots/replication	Data integrity and access
`fedora` / containers	Container start/stop, privilege use, Podman events	Container abuse detection
`TeneT` / Cockpit	Admin logons, libvirt actions, snapshots	Hypervisor monitoring
`wazuh-siem`	Alerts, SCA, FIM, agent status	Detection and compliance

9.2.2 The **retention period** of logs **MUST** be at least **90 days** online for security logs, and longer for events linked to an open incident (kept until closure and lessons learned). Logs **MUST** remain usable and protected throughout the retention period.

9.3 Detection (SCA, FIM)

9.3.1 Wazuh's **SCA** (Security Configuration Assessment) module **MUST** be enabled to continuously assess the systems' compliance with the hardening baselines (Article 7).

9.3.2 The **FIM** (File Integrity Monitoring) module **MUST** watch the integrity of sensitive files and folders (configurations, critical binaries, ACL files) and raise an alert on any unexpected change.

9.3.3 Detection rules **MUST** be maintained and tuned to limit false positives while covering the relevant threat scenarios (privilege escalation, lateral movement, log tampering, unjustified creation of a privileged port).

9.4 Operational monitoring

9.4.1 Metrics are monitored by **Prometheus** (collection through node-exporter and windows_exporter) and displayed by **Grafana** on the `fedora` node; the firewall is monitored over SNMP by **Zabbix**.

9.4.2 Alert thresholds **MUST** be set for vital indicators (service availability, resource saturation, snapshot/replication failure, loss of a Wazuh agent). Loss of an agent's reporting **MUST** be handled as a security event.

Article 10 — Security incident management

10.1 Definition and detection

10.1.1 A security incident is any event that actually or potentially harms the confidentiality, integrity, availability or traceability of the scope.

10.1.2 Detection relies mainly on Wazuh (alerts, SCA, FIM), Prometheus/Grafana monitoring and pfSense logs. Every qualified alert **MUST** be recorded in the incident register.

10.2 Classification and prioritisation

10.2.1 Incidents **MUST** be qualified by severity:

Level	Criterion	Example	Target handling time
P1 — Critical	Harm to a vital asset /proven compromise	AD compromise, chokepoint bypass, log tampering	Immediate
P2 — Major	Significant harm without global compromise	Unjustified privileged container, abnormal access to a C3 share	Within a few hours
P3 — Minor	Localised anomaly	SCA configuration drift, one-off snapshot failure	In the current cycle

10.3 Incident response

10.3.1 The response **MUST** follow the steps: **detection → qualification → containment → eradication → recovery → closure**.

10.3.2 Containment MAY rely on the pfSense chokepoint (isolating the VM concerned with a block rule), on the local firewall of the target host when the flow stays inside the segment, on disabling compromised accounts in AD, or on stopping the faulty container.

10.3.3 Recovery MUST favour a return to a known healthy state through a ZFS/Snapper snapshot or a verified backup restore (Article 8).

10.3.4 Evidence (logs, snapshots) **MUST** be preserved before any destructive action, as far as possible.

10.4 Lessons learned (RETEX)

10.4.1 Every P1 or P2 incident **MUST** lead to a documented lessons-learned review: timeline, root cause, corrective measures, and any update of the ISSP or the detection rules.

10.4.2 Corrective actions from the review **MUST** be followed up until closure and feed the continuous improvement cycle (Article 12).

10.5 Escalation, notification and transmission of evidence

10.5.1 Any P1 incident, or P2 incident beyond internal capabilities, **MUST** be escalated at once to the CISO, who decides whether to call on an ANSSI-qualified incident response provider (PRIS) and whether to report to **CERT-FR**.

10.5.2 When an incident is a personal data breach, the CISO **MUST** notify the **CNIL within 72 hours** of becoming aware of it (GDPR, article 33) and, where there is a high risk for the people concerned, inform them (article 34).

10.5.3 Items passed to analysts (exported logs, screenshots, snapshots) **MUST** come with their SHA-256 hash and a timestamped timeline; every handling (who, when, what) **MUST** be recorded to preserve the chain of custody.

10.5.4 Every incident **MUST** be entered in the incident log with its qualification, the actions taken and its closure.

Article 11 — Secrets and cryptography management

11.1 Secrets management



11.1.1 No secret or key MAY appear in clear in code, scripts, container images, versioned configuration files or logs.

11.1.2 Secrets **MUST** be managed through a dedicated mechanism: `.env` files excluded from version control with restricted rights, or, preferably, a **secrets vault (Vault)**.

11.1.3 Secrets **MUST** be injected into services / containers at run time, with no clear-text persistence on disk when this can be avoided.

11.1.4 Secrets **MUST** be **rotated** regularly (at least every 90 days) and immediately on any suspicion of compromise or when a contributor leaves.

11.1.5 A **secrets register** (identifier, owner, use, date of last rotation — never the value) **MUST** be kept up to date. Secret values **MUST NEVER** be recorded in this register or in this ISSP.

11.2 Cryptography

11.2.1 Communications **MUST** be protected by **TLS** in its current, robust versions, or by an equivalent protocol (SSH, WireGuard); obsolete protocols and cipher suites (e.g. SSLv3, TLS 1.0/1.1) **ARE FORBIDDEN**.

11.2.2 Integrity hashes (backups, FIM checks) **MUST** use **SHA-256** or stronger. Obsolete hash functions (MD5, SHA-1) **MUST NOT** be used for security purposes.

11.2.3 Private keys and certificates **MUST** be stored in a protected way, with restricted access, and renewed before expiry.

Article 12 — Compliance, audit and continuous improvement

12.1 Compliance

12.1.1 The compliance of the scope with this ISSP **MUST** be assessed at each audit cycle and at each structural change.

12.1.2 Gaps (non-compliances) **MUST** be recorded, rated by severity, given an action plan and an owner, and followed up until resolved.

12.2 Audit

12.2.1 Audits **MUST** rely on verifiable evidence: configurations, Wazuh logs, SCA/FIM reports, Grafana dashboards, registers (assets, access, secrets, exceptions, incidents) and restore tests.

12.2.2 Each audit **MUST** produce a dated, referenced and archived **audit report (PV)**, listing the scope checked, the findings, the non-compliances and the recommendations. Audit reports are the lab's enforceable compliance record.

12.3 Continuous improvement cycle (PDCA)

12.3.1 Security management **MUST** follow the **PDCA** cycle:

Phase	Purpose	Implementation
Plan	Plan	Risk analysis, definition/update of rules and objectives
Do	Implement	Applying the measures (hardening, RBAC, logging, backup)
Check	Check	Audits, SCA/FIM, incident review, restore tests, audit reports
Act	Improve	Corrective actions, lessons learned, ISSP update

12.3.2 Lessons from incidents (Article 10) and audits **MUST** feed the update of the ISSP, which **MUST** be revised at least once a year.

Appendices

Addendum E.1 — Summary of addresses and roles (internal addressing plan)

Host	Address	Role	Classification	Criticality
`pfSense`	`10.10.10.254`	Chokepoint (FW/DNS/DHCP/GW)	C2	Vital
`Win-Server-DC`	`10.10.10.10`	AD DS / DNS / RBAC	C3	Vital
`TrueNAS`	`10.10.10.20`	ZFS / SMB storage (NFSv4 ACLs)	C3/C2	High
`fedora`	`10.10.10.30`	Rootless Podman containers /Prometheus / Grafana / Zabbix	C1	Medium
`wazuh-siem`	`10.10.10.40`	SIEM Wazuh 4.14 (SCA/FIM)	C2	High
`TeneT`	physical host	Fedora 44 hypervisor / Cockpit /KVM-libvirt	C2	Vital

Addendum E.2 — Summary of the main prohibitions

Prohibited	Reference article
`chmod 777` / world write on files and datasets	Art. 7.1.3, 8.2.2
Root / privileged container without an exception	Art. 7.2.2
Exposing a port < 1024 without justification	Art. 7.2.2
Secret or key in clear in code / image / config / logs	Art. 11.1.1
Bypassing the pfSense chokepoint	Art. 6.1.2
Flow not explicitly allowed (deny by default)	Art. 6.2
Clear-text administration protocols (HTTP/Telnet)	Art. 6.4.2
Obsolete cryptographic protocols / hashes	Art. 11.2
Shared generic accounts (except listed service accounts)	Art. 5.1.3
Default passwords left unchanged	Art. 5.5.3
DHCP service other than pfSense	Art. 6.5.2

Addendum E.3 — Mandatory registers

Register	Contents	Article
Asset inventory	Assets, owners, classification, criticality	Art. 4
Access register	Accounts, groups, rights, reviews	Art. 5
Secrets register	Identifier, owner, use, last rotation (never the value)	Art. 11.1.5
Exceptions register	Active exceptions, reason, deadline, approval	Art. 1.3.2
Incident register	Incidents, severity, handling, lessons learned	Art. 10



Register	Contents	Article
Audit reports	Findings, non-compliances, recommendations	Art. 12.2.2

Addendum E.4 — Revision history

Date	Author	Subject
2026-10-04	CISO	Creation and first publication of the ISSP of the "Hybrid InfraSec" lab
2026-10-11	CISO	WireGuard remote access and SNMP monitoring flows added to the matrix (6.2.3), metrics and share flows aligned with the existing set-up; 3-2-1-0 implementation and RPO specified (8.3.1, 8.4.1); status of SIEM connection and SNMP monitoring (9.1.1, 9.4.1); encrypted protocols allowed (2.3.1, 11.2.1); intra-segment filtering specified (1.2.2, 6.1.1, 6.3.1, 10.3.2)

End of document — PSSI-HIS-2026-01 — Restricted distribution.

Annex F · Freeze and hardening report

Project: Hybrid InfraSec — Zero-Trust lab

Date: 04/10/2026

Operator: admin

Purpose: freeze the validated lab configuration and record the hardening resulting from the audit (PV-02), closing the **audit → treatment → proof** chain.

1. Hardening applied — fedora node (.30) Measures applied in response to the Lynis findings of audit PV-02:

Finding	Measure applied	Detail
F-07	SSH hardening	`PermitRootLogin no`, `AllowTcpForwarding no`, `ClientAliveInterval 300`, `ClientAliveCountMax 2`, `LogLevel VERBOSE`, `MaxAuthTries 3`, `X11Forwarding no` (drop-in `/etc/ssh/sshd_config.d/99-hardening.conf`, config validated with `sshd -t`)
F-08	Password policy + umask	`PASS_MAX_DAYS 90`, `PASS_MIN_DAYS 1`, `PASS_WARN_AGE 7`, `UMASK 027` (`/etc/login.defs`)
F-09	Disabling unneeded protocols	`dccp`, `sctp`, `rds`, `tipc` neutralised (`/etc/modprobe.d/99-disable-protocols.conf`)
F-10	Disabling removable storage	`usb-storage` neutralised (`/etc/modprobe.d/99-usb-storage.conf`)
—	Restricting core dumps	`* hard core 0` (`/etc/security/limits.d/99-coredump.conf`)
F-11	Automatic updates	`dnf5-automatic.timer` enabled
F-05	Closing the node-exporter port	Port `9100/tcp` removed from the firewall (Prometheus queries locally — network exposure not needed)

Result — Lynis hardening index

State	Index
Before hardening (audit PV-02)	**69 / 100**
After hardening	**76 / 100**

Module blacklist measures (protocols, USB) only take full effect after a reboot: the index will rise further at the next cycle.

2. Handling of the network findings (risk decisions) Some findings are **not fixed live** before the oral exam because they affect the administration/demonstration paths. In line with the EBIOS RM approach (workshop 5), each one is the subject of an **explicit treatment decision**:

Finding	Decision	Justification / deadline
F-01 — hypervisor administration IP on the segment	**Risk accepted temporarily + compensating measure**	It is the only way to reach the management interfaces from the operator workstation. Target remediation: **out-of-band administration** (dedicated network/bastion). Current compensating measure: isolated segment, single operator, active Wazuh monitoring (incident PV-03 proved detection).
F-02 — pfSense admin over HTTP :80	**Planned**	Force HTTPS, disable the :80 listener, restrict the management source. To apply after the demonstration rehearsal.
F-03 — RDP open on the DC	**Planned**	RDP not used (administration through console/Cockpit). Disable or restrict the source.
F-04 — WS-Discovery on TrueNAS	**Planned**	Disable the service if not required.
F-06 — administration plane reachable from the whole segment	**Planned**	Restrict to an administration workstation/bastion (Zero-Trust principle).

3. Freeze posture

- **Secrets** — rotation of the Wazuh `admin` password to be done with `/usr/share/wazuh-indexer/plugins/opensearch-security/tools/wazuh-passwords-tool.sh` (the password generated at installation appears in no deliverable).
- **WAN** — pfSense blocks inbound connections from the WAN by default ("deny by default" filtering); to be confirmed before the final freeze.
- **Report integrity** — SHA-256 hash register established (see `Registre-Integrite-SHA256`).
- **Freeze snapshots** — to be taken on every VM after hardening (`virsh snapshot-create-as ... freeze-YYYYMMDD`) + host Snapper point.
- **Distribution** — no secret, public IP, real MAC or personal data in the deliverables (RFC 1918 plan).

Update of 11/10/2026 (PV-04, Annex O). The freeze snapshots `gel-20261011` were taken on the five VMs, with the host's Snapper points; the WAN-side capture only shows the tunnel's UDP 51820 traffic. Rotation of the Wazuh `admin` password is still to be done.

4. Conclusion The hardening resulting from the audit is **applied and measured** (Lynis index 69 → 76 on fedora, node-exporter port closed). The remaining network findings are covered by traced treatment decisions, consistent with the EBIOS RM analysis and the ISSP. The loop **audit (PV-02) → risk analysis (EBIOS) → incident/detection (PV-03) → hardening (this report)** is complete and documented.

Annex G · Backup and restore report (PV-01)

Project: Hybrid InfraSec — Zero-Trust lab

Protected asset: SMB file share `partage` (dataset `tank/partage`), hosted on TrueNAS SCALE 25.10 (10.10.10.20), joined to the `infrasec.local` domain.

Test date: 04/10/2026

Operator: admin

1. Objective Demonstrate the implementation of the **3-2-1-0** backup rule and the verified ability to restore data, with a measured recovery time (RTO) and proof of integrity.

Reminder of the **3-2-1-0** rule:

- **3** copies of the data;
- **2** different storage media;
- **1** off-site copy;
- **0** errors (verified restore).

2. Backup architecture in place

Copy	Location	Type	Protection provided
1 — Production	`tank/partage` (mirrored ZFS pool, 2 disks)	Live data	Failure of one disk (ZFS mirror)
2 — Snapshots	`tank/partage@auto-*`	Timestamped, immutable ZFS snapshots	Deletion / corruption / ransomware
3 — Replication	`tank/partage_backup`	Replicated ZFS stream (`zfs send | zfs recv`)	Loss of the source dataset; off-site target in production

Automation: periodic TrueNAS snapshot task — dataset `tank/partage`, **hourly** frequency, **2-week** retention, naming scheme `auto-%Y-%m-%d_%H-%M` (compatible with Windows "Previous Versions" over SMB).

Native integrity: the ZFS file system computes a checksum on every block (detection and correction of silent errors), complemented by a scheduled pool *scrub*.

3. Restore test procedure

3.1. Reference data (before the incident) Three test files created in the share, then their SHA-256 hash recorded:

```
0b039914e2e1bcaee135e56ea7e827256326018cea19f6b71ca36e4e52e4f9b6
RESTORE-TEST/archive.bin
9df323f5008be2b99674fe9aa717f2442bcbbe295b6783df136436835ccbd05a
RESTORE-TEST/clients.csv
fd14fe25efccb093c98c124872639d771444292a9f302e177529163bf6a6eb87
RESTORE-TEST/rapport-q3.txt
```

Reference snapshot taken: `tank/partage@auto-2026-10-04_15-09-02`.

3.2. Incident simulation and restore

Step	Timestamp	Action
T1 — Incident	04/10/2026 15:10:35 CEST	Complete deletion of `RESTORE-TEST` (`rm -rf`) — data lost
T2 — Restore	04/10/2026 15:10:35 CEST	Restore from the ZFS snapshot (`/.zfs/snapshot/.../RESTORE-TEST`)

3.3. Integrity check (after the restore)

```
RESTORE-TEST/archive.bin: OK
RESTORE-TEST/clients.csv: OK
RESTORE-TEST/rapport-q3.txt: OK
```

3.4. Check of the replicated copy (copy 3)

```
RESTORE-TEST/archive.bin: OK
RESTORE-TEST/clients.csv: OK
RESTORE-TEST/rapport-q3.txt: OK
```

4. Results

Indicator	Result
RTO (recovery time, file level)	**< 1 second**
RPO (max. data loss)	≤ 1 hour (snapshot frequency)
Integrity after the restore	**0 errors** — 3/3 SHA-256 hashes match
Integrity of the replicated copy	**0 errors** — 3/3 SHA-256 hashes match
Number of copies verified	3 (production + snapshot + replication)

Conclusion: the 3-2-1-0 rule is implemented in principle — in the lab, the replicated copy sits on the same pool, so the "2 media" and "1 off-site copy" criteria are only met in production (see §5) — and the restore is proven, verified and timed.

5. Limits and areas for improvement (technical honesty)

- **NFSv4 ACLs:** restoring with `cp` produced "preserving permissions: Operation not permitted" warnings — the content is intact (SHA-256 matches), but `cp` does not carry the ACLs over. In production, favour a restore that preserves ACLs (`rsync -A` , or Windows' native "Previous Versions" exposed through SMB).
- **Real off-site copy:** in this single-NAS lab, copy 3 sits on the same pool. In production, the ZFS replication task targets a **remote TrueNAS on another site** (the `zfs send/recv` mechanism demonstrated is identical).
- **Stronger immutability:** consider snapshots with locked retention (ransomware protection) for copy 2.

6. Related evidence

- Periodic TrueNAS snapshot task (screenshot).
- Console log of the restore test (T1/T2, hashes, RTO).
- Datasets `tank/partage` and `tank/partage_backup` (`zfs list` output).

Annex H · Awareness material and short training session

Project: Hybrid InfraSec — company INFRASEC

Reference: SENS-2026-01

Date: 04/10/2026 · updated on 05/10/2026 (instruction on the QR code, after INC-04)

Author: admin (secure infrastructure administrator)

Audience: INFRASEC users (office staff, remote workers) and the technical team

Framework: operational application of the ISSP — performance criterion CP9 (raise user awareness, prepare and run a short training session)

Part 1 — Short training session sheet

Item	Contents
Title	Good everyday security habits
Learning objective	At the end, each participant can recognise a phishing email, manage a strong password, use secure remote access and report an incident.
Audience	Two groups: business users (awareness) and technical team (skills development).
Duration	45 minutes (30 min of content + 15 min of discussion / practical cases).
Format	In person or by video call, projected slides + handout.
Prerequisites	None for the user group.
Assessment	5-question quiz at the end + simulated phishing exercise at D+30.
Frequency	At hiring, then a yearly reminder and after any significant incident.

Part 2 — Awareness material (content given to users)

1. Passwords and authentication A weak password is an attacker's first way in. The INFRASEC policy (ISSP) requires:

- a long **passphrase** (at least 14 characters, as the ISSP requires, ideally a string of words) rather than a short, complex word;
- a **different password per service** — never the same one for email and the domain;
- using a **password manager** so you neither memorise nor write them down;
- **never** giving your password, even to a colleague or a "technical support" that asks for it (no legitimate service asks for it).

Remote access authentication relies on **one key per device**: your computer is recognised individually. The target evolution adds **multi-factor authentication (MFA)**.

2. Phishing Phishing is still the most common attack vector. Before clicking:

- check the **real sender address** (not only the displayed name);
- be wary of **urgency** and **threats** ("your account will be suspended") — they are manipulation levers;
- hover over a link to see the **real URL** before clicking; never enter your credentials from a link received by email;

- do not open an **unexpected attachment**, especially executable files or documents asking you to "enable macros".

When in doubt: **do not click, report it** (see §5).

3. Workstation and remote access

- **Lock your session** as soon as you leave your desk (clean desk, locked screen).
- Do not plug in an unknown **USB device** — removable storage is disabled on the servers for this reason.
- When **working remotely**, connect only through the **company VPN (WireGuard)** before accessing internal resources; never expose a file share on a public network.
- The **configuration QR code** given at enrolment contains your secret key: read it **only with the WireGuard app**, never with the camera or an assistant, which may send its content to online services. If you make a mistake, tell the technical contact at once: the key will be revoked and replaced (real case handled, INC-04).
- **Lost or stolen device**: report it without delay — that device's access is revoked remotely within minutes.
- Each profile only reaches what it needs (**least privilege**): a denied access is not a malfunction, it is the policy.

4. Data protection (GDPR)

- Only process **personal data** as part of your work and in the spaces provided (dedicated AD share).
- Do not copy sensitive data to a personal device or an unapproved cloud service.
- Report any suspected **loss or leak** of data — a GDPR incident must be qualified quickly.

5. Reporting an incident An incident reported early costs much less than an incident discovered late. **What to do:**

1. Do not try to "fix" it alone or erase traces.

2. Note the time, what you observed, any messages.

3. **Tell the technical contact immediately** (single point of contact).

4. Isolate the computer if asked (unplug the network), without switching it off if asked not to (evidence preservation).

The detection system (Wazuh SIEM) watches the infrastructure continuously: a human report **complements** technical detection, it does not replace it.

Part 3 — Assessment quiz (5 questions) 1. An "urgent" email from IT asks for your password for "verification". What do you do?

2. What is the difference between a good and a bad password?

3. Before accessing an internal share from home, what must you switch on?

4. You find a USB stick in the car park. What do you do?

5. You think you clicked on a phishing link. What are the first two things to do?

(Answer key given to the trainer; expected answers match §1 to §5.)

Awareness material and short training sheet — Project Hybrid InfraSec · fictitious company INFRASEC · AIS report (CCP3 / CP9).

Annex I · Incident detection report and lessons learned (PV-03)

Project: Hybrid InfraSec — Zero-Trust lab

Scenario: SSH brute-force attack detected by the Wazuh SIEM

Date: 04/10/2026

Operator / analyst: admin

Detection chain: Wazuh agent (fedora) → Wazuh manager (wazuh-siem .40) → dashboard

1. Objective Demonstrate the SIEM's ability to **detect, correlate and qualify** a real attack, and formalise the **detection → response → lessons learned** chain. The exercise deliberately links the attack to a finding of audit PV-02 (**F-01**) to prove the audit → risk → incident sequence.

2. Attack scenario (controlled simulation)

Item	Value
Technique	SSH brute force / password guessing
MITRE ATT&CK	**T1110** (Brute Force), **T1110.001** (Password Guessing), **T1021.004** (Remote Services: SSH), **T1078** (Valid Accounts)
Source	`10.10.10.2` — hypervisor administration address present on the segment (**finding PV-02 F-01**)
Target	`fedora` (10.10.10.30), SSH service (port 22)
Load	15 authentication attempts with the non-existent account `hacker`
Timestamp	04/10/2026 at 19:17:58 CEST

Command used (attacker workstation):

```
for i in $(seq 1 15); do ssh -o BatchMode=yes -o ConnectTimeout=3 hacker@10.10.10.30
true; done
```

Choosing `10.10.10.2` as the source matters: it exploits precisely the weakness found in the audit (hypervisor administration plane reachable from the production segment). The audit had therefore anticipated the attack vector.

3. Detection (Wazuh)

Single events — rule **5710** "sshd: Attempt to login using a non-existent user", **level 5**, agent `fedora`, **15 occurrences** timestamped 19:17:58 (exact match with the 15 attempts sent).

Correlation — **level 10** alert peak at 19:18 (Wazuh correlation rule 5712: brute force on a non-existent account, eight failures in two minutes), consolidating the repeated failures into a single high-severity event.

Automatic MITRE ATT&CK qualification — the "Threat Hunting" dashboard classifies the activity as **Brute Force**, **Password Guessing**, **SSH** and **Valid Accounts**.

Dashboard indicators (15-min window):

Indicator	Value
Authentication failures	**15**

Indicator	Value
Alerts of level ≥ 10	peak at 19:18 (brute-force correlation)
Agent concerned	`fedora` (10.10.10.30)
Detection delay	real time (< 1 min between the attack and the alert)

Evidence: screenshots of the Threat Hunting dashboard (MITRE + level trend) and of the event list filtered on `agent.name: fedora` *(rule 5710 ×15).*

4. Incident response (procedure)

Phase	Action
Identification	Wazuh level 10 alert (SSH brute force) on `fedora`, source `10.10.10.2`.
Containment	Blocking the source on the target host (local `firewalld` on the `fedora` node): the source and target are in the same segment, so the flow does **not** cross pfSense, which cannot filter it. Wazuh active response (`firewall-drop`) automates this block on the agent; enabling it permanently is kept as a lesson learned.
Eradication	Treating the root cause: removing the administration address `10.10.10.2` from the segment (finding F-01) is decided, then requalified at the freeze as a **risk accepted temporarily with a compensating measure**, pending a dedicated administration network (measure M-01). SSH hardening applied on the target (F-07: root login forbidden, three attempts at most, idle timeouts, detailed logging); key-only authentication is kept as an improvement.
Recovery	Service integrity checked (no successful access — account `hacker` does not exist, 0 compromise); back to normal operations.
Capitalisation	Writing this lessons-learned report and updating the ISSP / hardening plan.

Result: no compromise (every attempt failed on a non-existent account). The incident stayed at the attempt stage, **detected in real time**.

5. Lessons learned (RETEX)

What worked well

- The detection chain is **working end to end**: the agent forwarded the logs, the manager correlated, the dashboard qualified the attack and mapped it onto MITRE ATT&CK — all in real time.
- **Multi-source** monitoring (Wazuh SIEM + SCA + system logs) gives immediate visibility on suspicious activity.
- The exercise **validates the relevance of the audit**: the vector used (F-01) had been identified and rated before the incident.

Areas for improvement identified

- **Automate the response**: enable Wazuh *active response* to ban brute-force sources automatically (shorter reaction time).
- **Reduce the surface**: restrict SSH to an administration workstation/bastion (Zero-Trust principle) and move to key-based authentication + MFA.
- **Treat the root cause**: remove the hypervisor administration plane from the production segment (F-01) — priority of the freeze phase.
- **Enrich detection**: add suitable rules/thresholds and dashboards dedicated to access attempts.

Main lesson An untreated audit finding (F-01) is a **real, exploitable attack path**. The loop **audit → risk analysis (EBIOS) → detection (SIEM) → remediation (hardening)** is demonstrated here completely and consistently.

6. Traceability

Framework	Mapping
MITRE ATT&CK	T1110, T1110.001, T1021.004, T1078
Related audit finding	PV-02 / F-01 (administration IP on the segment)
Risk analysis	EBIOS RM — operational scenario SO-3 "pivot from the administration plane to the hypervisor"
ISSP measure	Articles 5 (identities and access), 6 (network security and segmentation) and 10 (incident management)

Annex J · Technical and security incident log

Register of the incidents met while building the lab and of their resolution. Each entry is evidence of diagnosis and technical control (CCP2 / CCP3). Sheets are numbered in the chronological order in which they occurred.

INC-01 — The installation ISO fails to boot (TrueNAS VM)

Date: 02/10/2026

Asset: VM `truenas` (Fedora 44 / KVM-libvirt hypervisor, managed through Cockpit)

Symptom The VM stays stuck on the OVMF firmware menu "Please select boot device"; the TrueNAS SCALE 25.10.7 ISO image does not start. In Cockpit's graphical console (noVNC), the arrow keys work but the **Enter** key is not passed to the virtual machine. The VM ends up stopping on its own.

Diagnosis

1. UEFI boot (OVMF) does not select the CD drive automatically despite a "CD first" boot order.

2. The web console does not reliably pass the Enter key → the highlighted entry cannot be confirmed.

3. Injecting the key from the host (`virsh send-key … KEY_ENTER`) fails intermittently because the VM is no longer running when the command arrives ("domain is not running").

Root cause An unfavourable combination: **OVMF/UEFI** firmware (firmware auto-selection + persistent NVRAM keeping a stale boot order) and the **keyboard transmission limit** of Cockpit's noVNC console.

Resolution Switching the VM firmware from **UEFI to BIOS (SeaBIOS)**:

- removal of the `<firmware>` block (auto-selection + secure boot), of the `<loader>` element and of the `<nvram>` element;
- removal of the `firmware='efi'` attribute from the `<os>` section;
- redefinition of the VM (`virsh define`) then start.

SeaBIOS boots the CD directly and starts the TrueNAS installer, with no intermediate menu or keyboard input needed.

Proof Screenshot of the "TrueNAS 25.10.7 Console Setup" screen obtained after the switch; timestamp 02/10/2026 12:07.

Lesson For lab VMs administered through Cockpit's web console, prefer **SeaBIOS** firmware when installation requires keyboard interaction in the console: booting removable media is more reliable and avoids depending on special key transmission.

INC-02 — Active Directory join fails (clock, then password)

Date: 02/10/2026

Asset: VM `truenas` (10.10.10.20) — join to the `infrasec.local` domain

Symptom 1 On validation, error: "Time offset from the domain controller exceeds the maximum permitted value". The join is refused.

Diagnosis 1 Clocks compared from the hypervisor (`virsh domtime`): TrueNAS has the correct UTC time; the domain controller `DC01` shows a UTC offset greater than 5 minutes. Cause: the DC's time zone was set wrongly, so its effective UTC time was off. Kerberos allows a maximum offset of 5 minutes.

Resolution 1 Time zone and time corrected on `DC01` (UTC+1 Paris, daylight saving on), which aligns its UTC time with real time and with TrueNAS. NTP synchronisation of the DC to the pfSense firewall (time authority of the segment) configured as well.

Symptom 2 New error: "The bind password is not correct."

Diagnosis 2 The join account password was typed on a keyboard layout different from the one used when it was set (US QWERTY vs FR AZERTY), producing a different string.

Resolution 2 Join account password reset with characters at the same position on both layouts (neutral characters), then input checked on screen.

Proof Active Directory status: **HEALTHY** — realm `INFRASEC.LOCAL`, keytab `AD_MACHINE_ACCOUNT` created, account cache enabled.

Lesson For any Kerberos join: (1) synchronise the time of every member on a single source (NTP from the DC or the chokepoint) before joining; (2) for multi-platform service accounts, avoid characters sensitive to the keyboard layout.

INC-03 — Windows monitoring: obsolete collectors and incompatible dashboard

Date: 04/10/2026

Asset: VM `Win-Server-DC` (10.10.10.10) — agent `windows_exporter` v0.31.8; Prometheus/Grafana server on `fedora` (10.10.10.30)

Context Deploying the `windows_exporter` metrics exporter on the domain controller for monitoring by Prometheus and display in Grafana. Installed through a script served by a temporary HTTP server (workaround for the copy-paste limitation of the noVNC web console).

Symptom 1 — service stopped After installing the MSI, the `windows_exporter` service stays **Stopped**; `Start-Service` returns no error but the service ends at once.

Diagnosis 1 Run in the foreground to capture the error: `couldn't enable collectors" err="unknown collector cs"`, then `unknown collector logon`. The `cs` (computer-system) and `logon` collectors were removed in recent versions; the requested set contained obsolete names.

Root cause 1 Version drift: invalid collector names in windows_exporter 0.31.8. The service fails as soon as an unknown collector is requested.

Resolution 1 Self-correcting deployment script: iterative test of the collector set, automatic removal of any collector reported as "unknown", then reconfiguration of the service's `ImagePath` (registry) with the validated set and restart. Final set: `cpu, logical_disk, net, os, service, system, memory, process, tcp, ad, dns` (including `ad` and `dns`, specific to the domain controller role).

Symptom 2 — "No data" dashboard Prometheus target `windows-dc` is **UP** (26 ms scrape), but Grafana dashboard ID 14694 shows no data; the "Server" variable stays empty (warning triangle).

Diagnosis 2 Two combined causes: (a) Prometheus job named `windows-dc` instead of the expected `windows` convention; (b) dashboard 14694 (published in 2021) built on the `windows_cs_*` metrics provided by the now removed `cs` collector — so the instance variable can no longer fill in.

Resolution 2 (a) Prometheus job name aligned on `windows` and service reloaded. (b) Dashboard replaced by an up-to-date template, explicitly compatible with windows_exporter v0.31+ (Grafana ID 23942), with the Prometheus data source correctly bound at import.

Proof "Windows Exporter Dashboard 2025" showing all the metrics of the DC01 domain controller: CPU, memory (5.93 GiB total / 3.65 GiB free), disk space, VirtIO network, disk I/O, service state, process and thread counts.

Lesson (1) Never assume collector/metric names are stable across exporter versions; industrialise deployment with an idempotent, self-correcting script. (2) Check a community dashboard's version compatibility with the exporter version before concluding there is a configuration error. (3) Follow the job naming conventions (`job`) expected by the tool ecosystem.

INC-04 — Security incident: exposure of the private key of an administrator access

Date: 05/10/2026

Asset: WireGuard peer `admin-remote` (`10.10.20.2`) — remote access to the administration plane; firewall `fw01`

Triggering event When enrolling the smartphone, the administrator profile's configuration QR code was read with the phone's **camera** app instead of the WireGuard app. This code contains the full client configuration, **private key included**. The camera sent its content to an online visual search service: the private key left the device and was passed to a third party.

Qualification Real security incident — breach of the **confidentiality of an authentication secret** tied to a privileged profile (access to the administration plane). Exploitation also requires reaching the tunnel endpoint, which lowers its likelihood in the lab; the key is nonetheless treated as **compromised**, on the principle: *an exposed secret is a compromised secret*, without waiting for proof of exploitation.

Containment Immediate removal of the old public key of the `admin-remote` peer on the firewall: the exposed key no longer opens any tunnel, whoever holds it.

Eradication and recovery Generation of a **new key pair** (rotation), new public key declared on the peer, new QR code produced, enrolment redone **only** with the WireGuard app. Check: the handshake succeeds with the new key; the firewall no longer knows the old one.

Preservation of evidence Timeline and screenshots kept offline. No private key material — old or new — appears in any deliverable; only public keys are referenced.

Lessons learned (1) A WireGuard configuration QR code **is a secret**: it carries the client's private key. (2) It must only be read with the WireGuard app; camera apps and assistants may send what they read to online services. (3) Revocation by removing the public key worked as planned: requirement EF5 of the specifications (centralised, immediate revocation) is demonstrated **in a real situation**. (4) Organisational measure: instruction added to the awareness material and to the skills transfer. Technical measure considered: distribute the configuration as a file over an encrypted channel and show the QR code only during enrolment.

INC-05 — Remote access test skewed by the hypervisor's presence on the segment

Date: 06/10/2026

Asset: remote access test bench — hypervisor `TeneT`

Symptom A first test of the employee profile was run from the hypervisor, used as a WireGuard client. The connection tool refused to add the tunnel route (`RTNETLINK answers: File exists`) and yet the connection test to the share **succeeded**.

Diagnosis The hypervisor already has a **direct** address and route to the `10.10.10.0/24` segment — that is audit finding **F-01**. So the flow did not go through the tunnel: the test "succeeded" without proving anything about remote access or segmentation.

Resolution The test client was isolated in a dedicated **network namespace**, with no route to the internal segment: any flow to `10.10.10.0/24` must go through the tunnel. This bench validated the handshake and located the key-based routing defect (INC-06). Final end-to-end validation is done from a separate client machine on the WAN side.

Lesson (1) A remote access test must start from a machine **really outside** the protected network; otherwise it measures the wrong path. (2) Finding F-01 is not theoretical: here it **skewed a test**, just as it served as the source of the simulated attack in PV-03. It confirms the priority of measure M-01 (dedicated administration network).

INC-06 — WireGuard: data plane broken by duplicated "Allowed IPs" (cryptokey routing)

Date: 06/10/2026

Asset: firewall `fw01` (pfSense CE, WireGuard package) — tunnel `tun_wg0` (10.10.20.0/24), peers `employe-remote` (10.10.20.3) and `admin-remote` (10.10.20.2)

Symptom The WireGuard handshake completes correctly (bytes exchanged both ways, tunnel "green"), but no TCP connection from the remote client `employe-remote` (10.10.20.3) to the TrueNAS SMB share (10.10.10.20:445) succeeds: `nc -zv -w3 10.10.10.20 445` always returns `TIMEOUT`. The packet capture on the firewall's LAN interface shows the client's `SYN` relayed to TrueNAS, which answers with a `SYN-ACK` — but that `SYN-ACK` is retransmitted in a loop and never goes back into the tunnel to the client.

Diagnosis

1. A working handshake rules out a key or endpoint problem.

2. The LAN capture proves the Zero-Trust filtering rule allows the flow and the destination server answers: the problem is on the firewall's **return path** to the tunnel.

3. Inspecting **VPN → WireGuard → Peers**: both peers had the same value **Allowed IPs =** `10.10.20.2/32`. No peer "owned" the address `10.10.20.3` used by the employee client.

Root cause A **cryptokey routing** configuration error. In WireGuard, the server-side *Allowed IPs* field does two jobs: (a) an access control list (which source addresses are accepted from this peer) and (b) an **internal routing table** (which peer to encrypt a packet for, by destination address). Since `10.10.20.3` was declared on no peer, pfSense could not determine which peer to encrypt the returning `SYN-ACK` for → packet dropped. On top of that came a **collision** (two peers claiming `10.10.20.2`), which pfSense reports explicitly: "traffic to the conflicting networks will only be routed to the last peer in the list". Since the handshake depends only on keys and endpoint, the tunnel looked healthy despite a broken data plane — a classic trap.

Resolution The *Allowed IPs* field of peer `employe-remote` corrected to `10.10.20.3/32` (peer `admin- remote` kept at `10.10.20.2/32`), guaranteeing unique ranges between peers. Saved (*Save Peer*) then applied (*Apply*). Check on the peer list: `employe-remote → 10.10.20.3/32`, `admin-remote → 10.10.20.2/32`.

Status / reach Fix applied and checked at configuration level. The end-to-end test run from the **network namespace (netns) validation bench** on the hypervisor remains inconclusive, because of an **asymmetry specific to the bench**: the netns client's endpoint is seen by the firewall as `192.168.122.1`, i.e. on the **same subnet as the pfSense WAN** (`192.168.122.0/24`), which creates a hairpin not representative of a really remote client. Representative end-to-end validation is therefore done in the **acceptance test** (step E8 of the go-live plan), from a separate client machine placed on the lab WAN network with no route to the internal segment outside the tunnel.

Proof Screenshots of the Peers tab before the fix (two peers at `10.10.20.2/32`) and after the fix (`.3/32` and `.2/32`); LAN packet capture showing the `SYN` relayed to TrueNAS and the `SYN-ACK` retransmitted.

Lesson (1) Distinguish the two roles of the *Allowed IPs* field in WireGuard: authorisation **and** cryptokey routing. (2) An established handshake does not prove the data plane works; always validate the application flow. (3) *Allowed IPs* ranges must be **unique** between the peers of a tunnel. (4) Choose a test bench whose topology does not reintroduce asymmetry (client endpoint outside the firewall's WAN subnet).

Update of 11/10/2026. The acceptance test run from a separate client machine (PV-04) showed that fixing the *Allowed IPs* was necessary but **not sufficient**: the same symptom remained, with a second cause on the firewall interface side (INC-07). The hypothesis of an asymmetry specific to the *netns* bench therefore did not, on its own, explain the failure seen on 06/10.

INC-07 — WireGuard: server replies not routed to the tunnel (WG_REMOTE interface without static addressing)

Date: 11/10/2026

Asset: firewall `fw01` — assigned interface `WG_REMOTE` (`tun_wg0`), peer `employe-remote` (`10.10.20.3`)

Symptom During the acceptance test, from the dedicated client `wg-client` on the WAN side: handshake established (`latest handshake: Now`), but `nc -zv -w3 10.10.10.20 445` fails (`Connection timed out`). The WAN-side capture shows the client sending encrypted packets every second with no answer from the firewall.

Diagnosis

1. The SMB share answers from the internal network: the TrueNAS service is not the cause.

2. The counters of the rule `employe-remote → TrueNAS SMB (445)` increase: the firewall **allows** and relays the request.

3. Capture on the firewall's LAN interface: TrueNAS **answers** (`SYN-ACK` to `10.10.20.3`). TrueNAS's default gateway (`10.10.10.254`) is correct.

4. So the defect is located, as for INC-06, on the firewall's **return path** to the tunnel.

Root cause The assigned interface `WG_REMOTE` was configured with IPv4 addressing type **"None"**. With no address or prefix on the interface, pfSense had no connected route to `10.10.20.0/24`: the server's reply followed the default route (WAN) instead of entering the tunnel. A first fix with `10.10.20.1/32` had no effect (the /32 prefix does not cover the clients' segment).

Resolution Interface `WG_REMOTE` set to **static IPv4** `10.10.20.1/24`, with no upstream gateway; state table reset. Immediate check: `Connection to 10.10.10.20 445 port`

```
[tcp/microsoft-ds] succeeded!
```

Proof WAN capture (encrypted packets with no answer), LAN capture (`SYN-ACK` present), connection successful after the fix; full acceptance test recorded in PV-04.

Lesson (1) On pfSense, the interface assigned to a WireGuard tunnel must carry the address and the **prefix of the clients' segment**: it is what creates the return route. (2) Two independent causes can produce the same symptom; fixing the first one (INC-06) was not proof. (3) Diagnosis by successive captures — WAN, rule, LAN — locates the failing link in a few minutes; it is the method kept for operations.

Annex K · Cybersecurity threat watch process

"Hybrid InfraSec" project — company INFRASEC

Reference	VEI-2026-01
Purpose	Organise the watch on threats, vulnerabilities, tool changes and regulation, and turn it into security maintenance actions and detection rules
Author	RJ — secure infrastructure administrator
Framework	AIS professional title — RNCP37680, CCP3 / CP10
Date	11 October 2026

1. Why a structured watch An infrastructure that is secure on its go-live day is no longer secure a few months later if nothing changes around it: new vulnerabilities are published every week, attack techniques evolve, vendors change their products. The watch is the sensor that triggers security maintenance. Without it, patches arrive late and detection rules age.

The process described here answers three questions: **what to watch** (the scope), **where to look** (the sources), and **what to do with what we find** (the decision process and its traceability).

2. Watch scope — inventory first An effective watch starts from the inventory: an alert is only worth something if it concerns a component that is really present. The scope covers the project's assets.

Area	Components watched
Perimeter and remote access	pfSense CE, WireGuard package
Identity	Windows Server 2025 — Active Directory, DNS, Kerberos
Storage	TrueNAS SCALE 25.10 — ZFS, SMB
Virtualisation	Fedora 44, KVM / libvirt / QEMU, Cockpit
Containers and monitoring	Podman (rootless), Prometheus, Grafana, node_exporter, windows_exporter
Detection	Wazuh 4.14 (manager, indexer, dashboard, agents)
Threats	attack techniques relevant to this architecture (brute force, ransomware, administration pivot)
Regulation	GDPR, NIS 2, ANSSI recommendations

3. Watch sources

Category	Source	Content used	Frequency
Institutional	**CERT-FR** (cert.ssi.gouv.fr)	Alerts, vulnerability notices, news bulletins — through RSS feeds	Daily
Institutional	**ANSSI** (cyber.gouv.fr)	Guides and recommendations, yearly threat overview	Monthly / yearly
Vulnerabilities	**CVE / NVD** (cve.org, nvd.nist.gov)	Description, CVSS score, affected products	At each relevant notice

Category	Source	Content used	Frequency
Vulnerabilities	**CISA KEV catalogue** (cisa.gov)	Vulnerabilities whose active exploitation is proven — prioritisation criterion	Weekly
Vendors	**Microsoft** (msrc.microsoft.com)	Monthly second-Tuesday patches	Monthly
Vendors	**Netgate** (pfSense security advisories), **TrueNAS**, **Fedora**, **Wazuh**, **Grafana**, **Prometheus**	Security advisories and release notes	Weekly
Threats	**MITRE ATT&CK** (attack.mitre.org)	Evolution of techniques; incident qualification	Quarterly
Regulatory	**CNIL** (cnil.fr), European texts	GDPR changes, NIS 2 obligations	Quarterly
Automated	**Wazuh vulnerability detection module**	Cross-checking the agents' software inventory with the CVE databases	Continuous (module active; screenshot of its results not attached to this report)

The choice favours **primary** sources — the national authority, the vendor, the reference database — rather than secondary relays, to avoid distorted or late information.

4. Process: from information to action

```
Collecte → Qualification → Décision → Action → Traçabilité → Diffusion
```

Qualification. Each piece of information is checked against the inventory (is the component present? in which version? exposed?) then rated: CVSS severity, known active exploitation (KEV catalogue, CERT-FR alert), real exposure in the architecture.

Decision. Three possible outcomes: fix (update, configuration change); apply a compensating measure until the patch is available (filtering, disabling a service, detection rule); accept the risk, with a dated justification.

Target handling times:

Criticality	Criterion	Time
Critical	CVSS ≥ 9, or proven active exploitation on an exposed component	Immediate compensating measure, patch within 72 h
High	CVSS 7 to 8.9	15 days
Medium	CVSS 4 to 6.9	Monthly maintenance cycle
Low	CVSS < 4	Next planned cycle

Action and adaptation of detection. When a relevant attack technique is identified, the watch does not stop at the patch: it questions the detection capability. A Wazuh rule is created or tuned so that the technique is seen if it is attempted.

Traceability. Each piece of information kept goes into the watch register (§5). **Distribution.** Immediate alert to the CISO for a critical item; monthly one-page summary to management; added to the awareness material when user behaviour is involved.

5. Watch register — real entries from the project

Date	Source	Information	Asset	Decision	Action	Status
04/10/2026	Vendor release notes	windows_exporter 0.31: removal of the `cs` and `logon` collectors; old community dashboards now incompatible	Domain controller	Fix	Self-correcting deployment script; compatible dashboard (INC-03)	Closed
04/10/2026	Wazuh release notes	Major versions announced after 4.14	SIEM	Accept temporarily	Version **frozen at 4.14** until the end of the certification period; upgrade planned afterwards, after testing	Follow-up
04/10/2026	MITRE ATT&CK	SSH brute force (T1110, T1110.001) — technique observed during the PV-03 exercise	Container node	Adapt detection	Local rule with a lowered threshold (§6)	Closed — deployed and proven on 11/10 (PV-04)
05/10/2026	Internal incident feedback	A camera app sends what it reads (configuration QR code) to an online service	Remote access	Fix	Key rotation; instruction added to the awareness material (INC-04)	Closed

6. Example of adapting detection Exercise PV-03 showed that Wazuh's native correlation (rule 5712) raises a level 10 alert after eight attempts on a non-existent account within two minutes. For an infrastructure of this size, where no legitimate user mistypes their account in bursts, that threshold is too tolerant. Watching this technique leads to a stricter local rule:

```
<group name="local,sshd,">
  <rule id="100100" level="12" frequency="5" timeframe="60">
    <if_matched_sid>5710</if_matched_sid>
    <same_srcip />
    <description>INFRASEC - force brute SSH : tentatives répétées sur compte
inexistant depuis une même source</description>
    <mitre>
      <id>T1110.001</id>
    </mitre>
  </rule>
</group>
```

The rule is placed in the manager's `/var/ossec/etc/rules/local_rules.xml`, validated with Wazuh's rule test tool, then proven by replaying the PV-03 attack. **Result (11/10/2026, PV- 04):** eight attempts launched at 13:44:10; alert 100100 at level 12 at 13:44:12, from the fifth attempt, source `10.10.10.2`, technique T1110.001. Where the native correlation waited for eight attempts at level 10, the local rule alerts earlier and higher.

7. Effectiveness indicators

Indicator	Target
Time between the publication of a relevant critical alert and the compensating measure	< 24 h
Share of relevant notices handled within the target time	≥ 90 %
Inventory components covered by at least one source	100 %
Detection rules reviewed or created as a result of the watch	at least one per quarter



8. Organisation The daily watch takes about ten minutes (reading the CERT-FR feeds and the vulnerability module alerts); the weekly review, about an hour. The monthly summary and the quarterly source review are presented at the security review (ISSP, article 3.2). The process itself is reassessed every year: a source that never produces usable information is removed, a new component adds its vendor sources.

Threat watch process VEI-2026-01 — Project Hybrid InfraSec, fictitious company INFRASEC. Framework RNCP37680, CCP3 / CP10, of 11 October 2026.

Annex L · Glossary and definition sheets

"Hybrid InfraSec" project — AIS framework vocabulary

Reference	GLO-2026-01
Purpose	Definitions of the REAC notions, network architecture, cybersecurity and monitoring used in the project
Author	RJ — secure infrastructure administrator
Date	11 October 2026

How to use it. Each notion is given in one or two sentences, then linked to something done in the project ("Project"), with its French equivalent ("FR") where useful. A definition is said without notes; linking it to the project turns recitation into proof.

1. Governance, risk and compliance

ISSP — Information systems security policy *(FR: PSSI)* Reference document approved by management, setting an organisation's security objectives, rules and responsibilities, and broken down into operational procedures. → *Project:* twelve-article ISSP (access, segmentation, hardening, backup, logging, incidents, secrets), broken down into procedures in the command booklet.

MCO — Operational maintenance *(FR: maintien en condition opérationnelle)* All activities that keep a system available and compliant with its specifications: preventive and corrective maintenance, monitoring, functional updates. → *Project:* Prometheus/Grafana monitoring, snapshots before each operation, incident log.

MCS — Security maintenance *(FR: maintien en condition de sécurité)* All activities that keep a system's security level over time, as threats evolve: watch, security patches, rights review, periodic audits. → *Project:* audit PV-02, measured hardening (Lynis 69 → 76), automatic updates, threat watch process.

SLA — Service Level Agreement *(FR: accord de niveau de service)* Measurable commitment between a service provider and its client: availability, recovery time, performance. It relies on objectives (SLO) and indicators (SLI). → *Project:* remote access availability ≥ 99.5 %, RTO < 1 h, enrolment < 15 min, revocation < 5 min (specifications).

EBIOS Risk Manager *(risk assessment method — ANSSI)* Method for assessing and treating digital risks published by ANSSI in 2018, organised in five workshops: framing and security baseline, risk sources, strategic scenarios, operational scenarios, risk treatment. → *Project:* four business values, six supporting assets, four operational scenarios of which three critical, brought out of the critical zone after treatment.

Threat, vulnerability, risk *(FR: menace, vulnérabilité, risque)* A threat is a potential cause of an incident (a source and an intent); a vulnerability is an exploitable weakness; risk combines the likelihood and the severity of a scenario in which a threat exploits a vulnerability. → *Project:* vulnerability F-01 (hypervisor on the segment) fed scenario SO-3 and served as the source of the simulated attack in PV-03.

CIA + T — Confidentiality, integrity, availability, traceability *(FR: DICT)* The four security criteria of a piece of information or a service. Traceability is sometimes called "proof". → *Project:* 3-2-1-0 backup (A, I), WireGuard encryption (C), SHA-256 register and Wazuh logs (I, T).

Defence in depth *(FR: défense en profondeur)* Layering independent lines of defence so that the failure of one does not compromise the whole. → *Project:* the remote employee is filtered by the key (cryptokey routing), by the firewall rule (TCP 445 only), then by the AD group ACLs on the share.

Zero Trust Security model that grants no implicit trust to a user, a device or a flow just because of its position on the network: every access is authenticated, authorised as narrowly as possible and checked. → *Project:* guiding principle of the architecture and of the remote access evolution.

ZTNA — Zero Trust Network Access Applying the Zero Trust model to remote access: the user reaches specific resources according to their profile, never the whole network. → *Project:* administrator profile to the administration plane, employee profile to the SMB share only.

Least privilege *(FR: moindre privilège)* Each identity only receives the rights strictly needed for its job, no more and no longer. → *Project:* rule `employe-remote` limited to `10.10.10.20:445` ; Active Directory RBAC; rootless containers.

ANSSI — French national cybersecurity agency National cybersecurity authority, attached to the SGDSN. It publishes guides and recommendations, qualifies products and providers, and runs CERT-FR. → *Project:* IT hygiene guide and remote access recommendations as the good-practice reference.

CERT / CSIRT — CERT-FR *(Computer Emergency Response Team)* Security incident response team. CERT-FR, part of ANSSI, publishes alerts, vulnerability notices and news bulletins. → *Project:* main source of the threat watch; escalation point planned by the incident procedure.

PASSI — ANSSI-qualified security audit provider Qualification issued by ANSSI to audit providers (architecture, configuration, source code, penetration testing, organisational and physical audit). → *Project:* engagement letter LM-AUDIT-2026-01 is written so that it can apply identically to a third-party provider of this kind.

White, grey, black box *(FR: boîte blanche, grise, noire)* Level of information given to the auditor: everything (architecture, accounts, code) in a white box, part in a grey box, nothing in a black box, which simulates an external attacker. → *Project:* audit PV-02 run as a white box, with access to the configuration and the accounts.

GDPR — General Data Protection Regulation *(FR: RGPD)* European regulation 2016/679, in force since 25 May 2018, governing the processing of personal data: lawfulness, minimisation, security of processing (article 32) and notification of a breach to the CNIL within 72 hours (article 33). → *Project:* encryption of remote flows, proportionate logging, no real personal data in the deliverables.

NIS 2 *(NIS 2 Directive)* European directive 2022/2555 strengthening the cybersecurity obligations of essential and important entities: risk management, incident notification, management accountability. → *Project:* regulatory framework cited to place the obligations of an organisation subject to it.

ISO/IEC 27001, 27002, 27005 *(ISO/IEC 27000 family)* 27001: requirements for an information security management system (ISMS), certifiable. 27002: catalogue of security controls. 27005: information security risk management. → *Project:* EBIOS RM is compatible with the 27005 approach; the ISSP follows the continuous improvement cycle (PDCA).

PDCA — Plan, Do, Check, Act Continuous improvement cycle at the heart of management systems. → *Project:* audit (check) → treatment of findings (act) → new Lynis measurement (check again).

ITIL *(IT Infrastructure Library)* Good-practice framework for IT service management. ITIL 4 describes 34 practices, including incident, problem, change and release management. → *Project:* the WireGuard evolution is handled as a normal change; enrolling a user then becomes a standard change (plan MEP-2026-01).

TCO, CAPEX, OPEX *(Total Cost of Ownership, capital / operating expenditure)* TCO is the total cost of a solution over a given period: capital expenditure (CAPEX: purchase, implementation) and recurring operating expenditure (OPEX: maintenance, energy, subscriptions). → *Project:* 3-year TCO of €4,610 for self-hosted WireGuard against €4,760 for a commercial ZTNA.

IaaS, PaaS, SaaS *(cloud service models)* Cloud service models: IaaS provides the infrastructure (VMs, network, storage) and the client manages the system and above; PaaS provides the platform and the client manages applications and data; SaaS provides ready-to-use software. Security responsibility is shared according to the model. → *Project:* the cloud access point option (IaaS-type instance) costed in the TCO.

IaC — Infrastructure as Code Describing the infrastructure with versioned, replayable files rather than manual operations. → *Project:* firewall described in Terraform (local state, `${path.module}`); internship devoted to automated virtual machine deployment.

2. Business continuity and backup

BCP — Business Continuity Plan *(FR: PCA)* Organisation and means that keep essential activities going during a crisis, possibly in degraded mode, without interruption.

DRP — Disaster Recovery Plan *(FR: PRA)* Procedures to restart activities after a disaster has interrupted them.

IT continuity and IT recovery plans *(FR: PCI and PRI)* The IT versions of the BCP and DRP: the IT continuity plan keeps IS services running during the incident (redundancy, failover); the IT recovery plan restores systems and data after the interruption (backups, snapshots, standby site). → *Project:* data recovery plan tested (PV-01); recovery of the firewall configuration and continuity of remote access described in the go-live plan.

RPO and RTO *(Recovery Point Objective, Recovery Time Objective)* RPO is the maximum acceptable data loss, expressed as a duration; RTO is the maximum acceptable interruption before recovery. → *Project:* RPO ≤ 1 h (hourly snapshots) and RTO < 1 s at file level, measured in PV-01.

3-2-1-0 rule Three copies of the data, on two different media, one of them off site, and zero errors found in a verified restore test. The "0" is the part most often forgotten: a backup never restored is not a proven backup. → *Project:* mirrored ZFS production, snapshots, `zfs send/recv` replication, restore verified with SHA-256 hashes (3/3 matching).

Full, incremental, differential backup A full backup copies everything; an incremental copies what changed since the last backup of any kind; a differential copies what changed since the last full backup.

Snapshot vs backup A snapshot freezes a system's state on the same medium: it protects against logical errors or ransomware, not against loss of the medium. A backup is an independent copy. The two complement each other. → *Project:* ZFS snapshots (copy 2) complemented by replication (copy 3).

Immutability *(WORM)* Property of a copy that can be neither changed nor deleted during its retention period, even by a compromised administrator. → *Project:* measure M-11 of the risk analysis (snapshots locked against backup destruction).

3. Network architecture

OSI and TCP/IP models The OSI model describes seven layers: physical, data link, network, transport, session, presentation, application. The TCP/IP model keeps four: network access, internet, transport, application. → *Project:* the firewall filters at layers 3 and 4 (addresses, protocols, ports).

IP address, subnet mask, CIDR notation The mask separates the network part from the host part. `10.10.10.0/24` (mask `255.255.255.0`) contains 256 addresses, 254 of them usable, from `.1` to `.254`. → *Project:* internal segment `10.10.10.0/24`; tunnel transport network `10.10.20.0/24`.

RFC 1918 *(private address space)* Private address ranges not routed on the Internet: `10.0.0.0/8`, `172.16.0.0/12`, `192.168.0.0/16`. → *Project:* all addressing in the report is RFC 1918; no public address is published.

Default gateway Router to which a host hands any traffic for another network. → *Project:* pfSense (`10.10.10.254`) for every machine in the segment.

Routing Forwarding packets between networks according to a routing table, static (declared routes) or dynamic (protocols such as OSPF or BGP).

VLAN — Virtual LAN Logical segmentation of a layer 2 network on the same physical infrastructure; each VLAN is a separate broadcast domain. → *Project:* dedicated administration network planned by measure M-01.

802.1Q trunk Link carrying several VLANs: each frame carries a 4-byte tag, including the 12-bit VLAN identifier (1 to 4094 usable).

Inter-VLAN routing Traffic passing from one VLAN to another through a layer 3 device (router, firewall, layer 3 switch). It is the natural place to filter between zones.

NAT — Network Address Translation Rewriting a packet's addresses. Outbound (SNAT, masquerade), several private hosts share one address; inbound (DNAT, port forwarding), an internal service is published to the outside. → *Project:* UDP 51820 forwarded from the hypervisor to the pfSense WAN to publish the tunnel.

DMZ — Demilitarised zone Isolated segment hosting the services exposed to the outside, separated from the internal network by the firewall, so that compromising an exposed service does not open the internal network.

Stateful firewall Firewall that tracks connection state: return traffic for an allowed connection is accepted automatically, with no dedicated rule.

Deny by default Any flow not explicitly allowed is refused. → *Project:* pfSense firewall policy; for the remote employee, only TCP 445 to TrueNAS is open.

Chokepoint Device through which all traffic between zones must pass, so filtering and logging can be concentrated there. → *Project:* pfSense, the segment's only crossing point.

Segmentation and micro-segmentation Segmentation splits the network into zones; micro-segmentation applies the finest possible isolation, per workload or per flow. → *Project:* rules per remote profile, each limited to its resource.

Management plane and data plane Flows used to administer devices must be separated from business flows, ideally on a dedicated administration network (ANSSI recommendation). → *Project:* finding F-01 (hypervisor on the production segment) and corrective measure M-01.

Bastion *(jump server)* Single, hardened and logged access point through which all administration actions go.

High availability, CARP, VRRP Redundant devices with automatic failover. CARP (on pfSense) and VRRP share a virtual address between two devices. → *Project:* firewall redundancy mentioned as a next step, out of scope.

DNS and DHCP *(Domain Name System, Dynamic Host Configuration Protocol)* DNS turns names into addresses; DHCP gives hosts their network configuration automatically. → *Project:* Active Directory DNS on the domain controller, essential for Kerberos.

4. Remote access and cryptography

Site-to-site VPN and remote access VPN A site-to-site VPN links two networks gateway to gateway; a remote access VPN links an isolated device to the company network. → *Project:* remote access for a travelling administrator and a remote employee.

IPsec Protocol suite securing communications at network level: IKE negotiates the keys, ESP encrypts and authenticates the packets. → *Project:* alternative studied and ruled out in the decision grid (complexity, footprint).

OpenVPN TLS-based VPN solution, mature and flexible, heavier to run and audit. → *Project:* alternative studied, second in the decision grid.

WireGuard Modern VPN protocol with minimal code and fixed cryptography (Curve25519, ChaCha20-Poly1305, BLAKE2s), running over UDP. Each peer is identified by its public key; an unauthenticated packet gets no answer. → *Project:* chosen solution (4.85/5 in the decision grid).

Cryptokey routing In WireGuard, the *Allowed IPs* field links address ranges to a peer's public key. It is both an inbound filter and an outbound routing table: without its own range, a peer cannot receive any reply. → *Project:* duplicated ranges defect diagnosed and fixed (INC-06).

Symmetric and asymmetric encryption Symmetric uses a shared key and is fast (AES, ChaCha20); asymmetric uses a public / private key pair, for key exchange and signing. → *Project:* WireGuard exchanges keys asymmetrically (Curve25519), then encrypts symmetrically (ChaCha20-Poly1305).

Hashing One-way function producing a fixed-size fingerprint; the slightest change to the data changes the fingerprint. Hashing guarantees integrity; it does not encrypt. → *Project:* SHA-256 hashes to prove the restore (PV-01) and seal the deliverables (integrity register).

PKI — Public Key Infrastructure Set of authorities, procedures and certificates that binds public keys to identities. → *Project:* internal certificate authority built in the first phase (CCP1).

TLS *(Transport Layer Security)* Protocol that encrypts and authenticates an application session (HTTPS, LDAPS, syslog over TLS). → *Project:* every administration interface over TLS; finding F-02 on pfSense's HTTP listener.

MFA — Multi-factor authentication Authentication combining at least two factors of different kinds: something you know, something you have, something you are. → *Project:* planned improvement of remote access.

5. Identity and access control

Active Directory: forest, domain, OU, GPO *(organizational unit, Group Policy Object)* The forest is the security boundary; the domain groups accounts and resources; organisational units structure the directory; group policies apply settings to objects. → *Project:* forest `infrasec.local`, domain controller on Windows Server 2025.

Kerberos Authentication protocol using tickets issued by a key distribution centre. It requires synchronised clocks: beyond five minutes of offset, authentication fails. → *Project:* TrueNAS join to the domain blocked by a clock offset, then resolved (INC-02).

RBAC — Role-Based Access Control Rights are given to roles, and users receive roles, rather than individual rights. → *Project:* directory groups and organisational units; ISSP role matrix.

Segregation of duties Whoever runs a service must not be the only one checking its own logs. → *Project:* principle written in the ISSP (article 3).

6. Incident detection and response

Antivirus and EDR *(Endpoint Detection and Response)* Antivirus detects known malicious files by signature. EDR continuously watches the behaviour of a workstation or server, detects suspicious activity even when unknown, and allows on-the-spot response (isolation, killing processes). → *Project:* the Wazuh agent plays this role on the domain controller and the fedora node (file integrity, detection); its active response is available but not yet enabled (PV-03 lessons learned).

XDR — Extended Detection and Response Extension of EDR beyond the endpoint — network, cloud, email, identities — with correlation across these sources, usually in one vendor's integrated platform.



SIEM — Security Information and Event Management Collects, normalises, correlates and keeps the logs of the whole IS, whatever their sources, to raise alerts, run investigations and prove compliance. → *Project:* Wazuh, which describes itself as a unified XDR and SIEM platform.

SOAR *(Security Orchestration, Automation and Response)* Orchestration and automation of the response through scenarios (*playbooks*), downstream of detection.

MDR *(Managed Detection and Response)* Detection and response service run by a provider: it is an offer, not a technology.

UEBA *(User and Entity Behavior Analytics)* Analysis of user and entity behaviour against a baseline, to detect anomalies.

IDS and IPS; NIDS and HIDS *(intrusion detection / prevention system)* An IDS detects and alerts, an IPS blocks. A NIDS analyses network traffic; a HIDS watches a host. → *Project:* the Wazuh agent acts as a HIDS on the domain controller and the container node.

SOC — Security Operations Center Team and tooling that watch the IS, qualify alerts and handle incidents. → *Project:* security analyst role defined by the ISSP, held while handling PV-03 and INC-04.

FIM and SCA *(File Integrity Monitoring, Security Configuration Assessment)* FIM watches changes to sensitive files; SCA compares a system's configuration with a hardening baseline (CIS). → *Project:* modules active on the Wazuh agents; SCA results used in audit PV-02.

Event and incident An event is an observed occurrence; a security incident is an event, or series of events, that harms or threatens to harm security.

Incident and problem (ITIL) An incident is an interruption or degradation to restore as fast as possible; a problem is the root cause of one or more incidents, to be eliminated. → *Project:* the PV-03 attack is the incident; F-01 is the underlying problem.

Incident response lifecycle Detection, qualification, containment, eradication, recovery, then lessons learned, preserving evidence at each step. → *Project:* applied to PV-03 (simulated attack) and INC-04 (real incident).

Lessons learned (RETEX) *(post-incident review)* Formal analysis, after an incident or an exercise, of what worked and of the gaps, to produce improvement actions. → *Project:* lessons learned from PV-03 and INC-04.

Evidence preservation *(chain of custody)* Timestamping, integrity hash, offline storage, no alteration and traceability of every handling. → *Project:* SHA-256 hashes and offline storage of screenshots.

IOC and IOA *(Indicator of Compromise / of Attack)* An indicator of compromise is a trace of a proven attack (hash, address, domain); an indicator of attack is an ongoing behaviour.

MITRE ATT&CK and kill chain ATT&CK is a knowledge base of the tactics and techniques observed among attackers; the kill chain describes the successive stages of an attack. → *Project:* attack PV-03 qualified as T1110 (brute force), T1110.001, T1021.004 and T1078.

CVE, CWE, CVSS *(Common Vulnerabilities and Exposures, Common Weakness Enumeration, Common Vulnerability Scoring System)* A CVE publicly identifies a specific vulnerability; a CWE classifies the type of weakness; CVSS scores severity from 0 to 10.

7. Monitoring

Monitoring and observability Monitoring watches known indicators and alerts when a threshold is crossed; observability lets you understand unexpected behaviour from metrics, logs and traces.

Metrics, logs, traces Metrics are timestamped numeric values; logs are text events; traces follow the path of a request. → *Project*: metrics with Prometheus, logs with Wazuh.

SNMP — Simple Network Management Protocol Protocol for querying devices (*polling*, UDP 161) and for unsolicited alerts (*traps*, UDP 162). Data is organised in a MIB, each value identified by an OID. Versions v1 and v2c authenticate with a "community" sent in clear; v3 adds authentication and encryption (*authPriv* level) and is the only one acceptable in production. → *Project*: SNMP v2c collection from the firewall by Zabbix, restricted to the collector (PV-04); v3 targeted in production.

WMI *(Windows Management Instrumentation)* Management and information-collection interface of Windows systems.

Syslog Standard log transmission protocol (UDP 514, or TCP 6514 over TLS).

Zabbix and Prometheus

	Zabbix	Prometheus
Model	central server, agents and proxies, relational database	HTTP *pull* collection from *exporters*, time-series database
Discovery	low-level discovery	service discovery
Alerts	triggers in the server	PromQL rules and Alertmanager
Favoured ground	network devices, native SNMP, heterogeneous estate	dynamic infrastructures, containers, cloud

Choice made in the project. Prometheus is the monitoring foundation for servers and containers: its *pull* model and time-series database suit a hybrid, containerised infrastructure. For network devices, SNMP remains the reference protocol: the firewall is queried over SNMP by Zabbix, a tool specialised in that ground (run in *rootless* containers, querying restricted to the collector — PV-04). Each tool is thus used where it excels.

Agent and agentless; pull and push An agent installed on the machine collects and sends; agentless queries remotely. In *pull*, the collector fetches the data; in *push*, the source sends it.

Threshold, alert, dashboard A threshold triggers an alert when an indicator leaves its normal range; a dashboard shows the indicators useful for decisions. → *Project*: 99.5 % availability over 30 days allows at most 3 h 36 of interruption.

8. Distinctions never to confuse

Pair	What separates them
MCO / MCS	keep running / keep secure over time
BCP / DRP	not stopping / restarting after the stop
IT continuity / IT recovery	IS continuity during / IS recovery after
RPO / RTO	how much data lost / how much downtime
Snapshot / backup	same medium / independent copy
Hashing / encryption	irreversible, integrity / reversible with the key, confidentiality
Antivirus / EDR	signature / behaviour and response
EDR / XDR / SIEM	the endpoint / several layers from one vendor / the whole IS, all sources

Pair	What separates them
IDS / IPS	alerts / blocks
Incident / problem	restore fast / remove the cause
Threat / vulnerability / risk	the cause / the weakness / likelihood × severity
Site-to-site VPN / remote access	network to network / device to network
VLAN / subnet	layer 2 separation / layer 3 addressing plan
SNMP v2c / v3	community in clear / authentication and encryption

Glossary GLO-2026-01 — Project Hybrid InfraSec, fictitious company INFRASEC. Framework RNCP37680.

Annex M · Operations manual

Zero-Trust remote access service and routine operations

Reference	MAN-2026-01
Project	Hybrid InfraSec — fictitious company INFRASEC
Author	RJ — secure infrastructure administrator
Date	October 11, 2026

This English block gives the US English part of the manual. The French part, which describes exactly the same procedures, is in the French block.

Part 2 — English (US)

1. Purpose This manual lets an administrator who did not build the project operate the remote access service: enroll a user, revoke access, troubleshoot a failure, back up and restore the configuration, roll back a change, and shut down or restart the infrastructure cleanly.

2. Reference values

Item	Value
pfSense firewall	LAN `10.10.10.254` · WAN `192.168.122.95` (hypervisor NAT network)
WireGuard tunnel	`tun_wg0`, UDP `51820`, interface `WG_REMOTE`, firewall at `10.10.20.1/24`
Administrator profile	`admin-remote` · `10.10.20.2/32` · access to the internal network `10.10.10.0/24`
Employee profile	`employe-remote` · `10.10.20.3/32` · access to TrueNAS `10.10.10.20`, TCP 445 only
Domain controller	`10.10.10.10` (forest `infrasec.local`)
File server	`10.10.10.20` (SMB share `partage`)
Monitoring	Grafana `10.10.10.30:3000` · Wazuh `https://10.10.10.40`

3. Golden rules 1. **No secret in a shared file.** A private key never leaves the device that generated it. Only public keys are declared on the firewall or quoted in a document.

2. **A configuration QR code is a secret.** Scan it only with the WireGuard app — never with the camera app or a voice assistant.

3. **Snapshot before any change.** No snapshot, no change.

4. **One unique Allowed IPs range per peer** (`/32`). Two peers never share an address.

5. **Test from a truly external device.** A test run from the hypervisor bypasses the tunnel (INC-05).

6. **Shut down gracefully.** `virsh shutdown`, never `virsh destroy` on the domain controller.

4. Enroll a user (standard change — target < 15 min)

On the user's device (Linux; on a smartphone, the WireGuard app generates the key pair itself):



```
umask 077
wg genkey > user.key
wg pubkey < user.key > user.pub
cat user.pub                # only this value is sent to the administrator
```

On the firewall (web interface):

1. **VPN → WireGuard → Peers → Add Peer.** Tunnel `tun_wg0` ; clear description; *Dynamic Endpoint* checked; the user's public key; *Allowed IPs*: one **unused** address from `10.10.20.0/24` , as a `/32` .

2. **Save Peer**, then **Apply Changes**.

3. **Firewall → Rules → WG_REMOTE**: attach the new peer's address to its profile rule (source = its `/32` address).

Client configuration file (example: employee profile):

```
[Interface]
PrivateKey = <client private key — stays on the device>
Address = 10.10.20.3/32

[Peer]
PublicKey = <firewall public key>
Endpoint = <public address of the access point>:51820
AllowedIPs = 10.10.10.20/32
PersistentKeepalive = 25
```

For the administrator profile: `Address = 10.10.20.2/32` and `AllowedIPs = 10.10.10.0/24` .

Delivery by QR code (shown in the terminal only during enrollment, then the file is destroyed):

```
qrencode -t ansiutf8 < user.conf
shred -u user.conf
```

Check: on the firewall, **VPN → WireGuard → Status** shows a recent handshake for the peer; from the device, `nc -zv -w3 10.10.10.20 445` succeeds.

5. Revoke access (target < 5 min) 1. **VPN → WireGuard → Peers**: disable the peer (prohibition icon), then delete it.

2. **Apply Changes.**

3. Remove the peer's address from its profile rule.

4. **Check:** in **Status**, no handshake remains for that peer; from the revoked device, the connection fails.

5. Log the revocation in the incident log if it follows a compromise.

Deny tests (acceptance). Temporarily set `AllowedIPs = 10.10.10.0/24` on the test client: traffic outside the client's range would never reach the firewall, so the test could not fail. Read the blocks in the pfSense logs (`WG_REMOTE` interface), then restore the client's nominal configuration.

6. Troubleshoot Work from the simplest check to the deepest, and write down every observation.

Step	Check	Where
1	Is the handshake recent? Do bytes flow both ways?	**VPN → WireGuard → Status**; on the client: `sudo wg show`
2	Does every peer have a **unique** *Allowed IPs* range?	**VPN → WireGuard → Peers** (*Allowed IPs* column)

Step	Check	Where
3	Does the profile rule exist, in the right order?	**Firewall → Rules → WG_REMOTE**; logs: **Status → System Logs → Firewall**
4	Does the traffic arrive, and does the reply go back?	**Diagnostics → Packet Capture**: interface `WG_REMOTE`, then `LAN`; *Host* field = client address, protocol TCP, port 445
5	Is the hypervisor port forward active?	`sudo firewall-cmd --list-forward-ports` on the hypervisor
6	Does the test start from a truly external device?	Never from the hypervisor (INC-05)

Restore the hypervisor port forward (without `--permanent`, the rule does not survive a reboot):

```
sudo firewall-cmd --permanent --add-masquerade
sudo firewall-cmd --permanent --zone=libvirt --add-masquerade
sudo firewall-cmd --permanent --add-forward-
port=port=51820:proto=udp:toaddr=192.168.122.95:toport=51820
sudo firewall-cmd --reload
```

7. Back up and restore the configuration pfSense configuration backup: Diagnostics → Backup & Restore → Download configuration as XML, with encryption enabled and the passphrase kept in the secrets vault. The file is stored **offline** and never added to a deliverable: it contains the administrator password hash and the web interface TLS key.

Firewall VM snapshot (graceful shutdown for a consistent snapshot):

```
sudo virsh shutdown pfsense-fw
sudo virsh snapshot-create-as pfsense-fw POST-WIREGUARD-STABLE
sudo virsh start pfsense-fw
sudo snapper -c root create -d "POST-WIREGUARD-STABLE"
```

Restore: Diagnostics → Backup & Restore → Restore Backup with the exported file; or, if the VM itself is at fault: `sudo virsh snapshot-revert pfsense-fw POST-WIREGUARD-STABLE`. Then confirm in **Status** that the tunnel and peers are back.

8. Roll back a change From the lightest action to the most complete, stopping as soon as the previous service is restored:

1. Disable the `tun_wg0` tunnel (immediate effect, internal network unaffected).
2. Remove the `WG_REMOTE` rules and the WAN UDP 51820 rule.
3. Restore the configuration export.
4. Revert the firewall VM snapshot.
5. Revert the hypervisor Snapper snapshot.

9. Routine security operations

Frequency	Operation
Daily	Wazuh dashboard: level ≥ 10 alerts, disconnected agents; CERT-FR feed
Weekly	SCA compliance score; vendor security advisories; snapshot and replication status
Monthly	Review active WireGuard peers (revoke unused access); monthly patches; threat-watch summary

Frequency	Operation
After any incident	Incident log entry; lessons-learned review for P1 or P2 incidents

10. Shutting down and restarting the infrastructure

Shutdown — dependent services first, firewall last:

```
for vm in wazuh-siem fedora truenas Win-Server-DC pfsense-fw; do sudo virsh shutdown
"$vm"; done
sudo virsh list --all          # wait until every VM is "shut off"
```

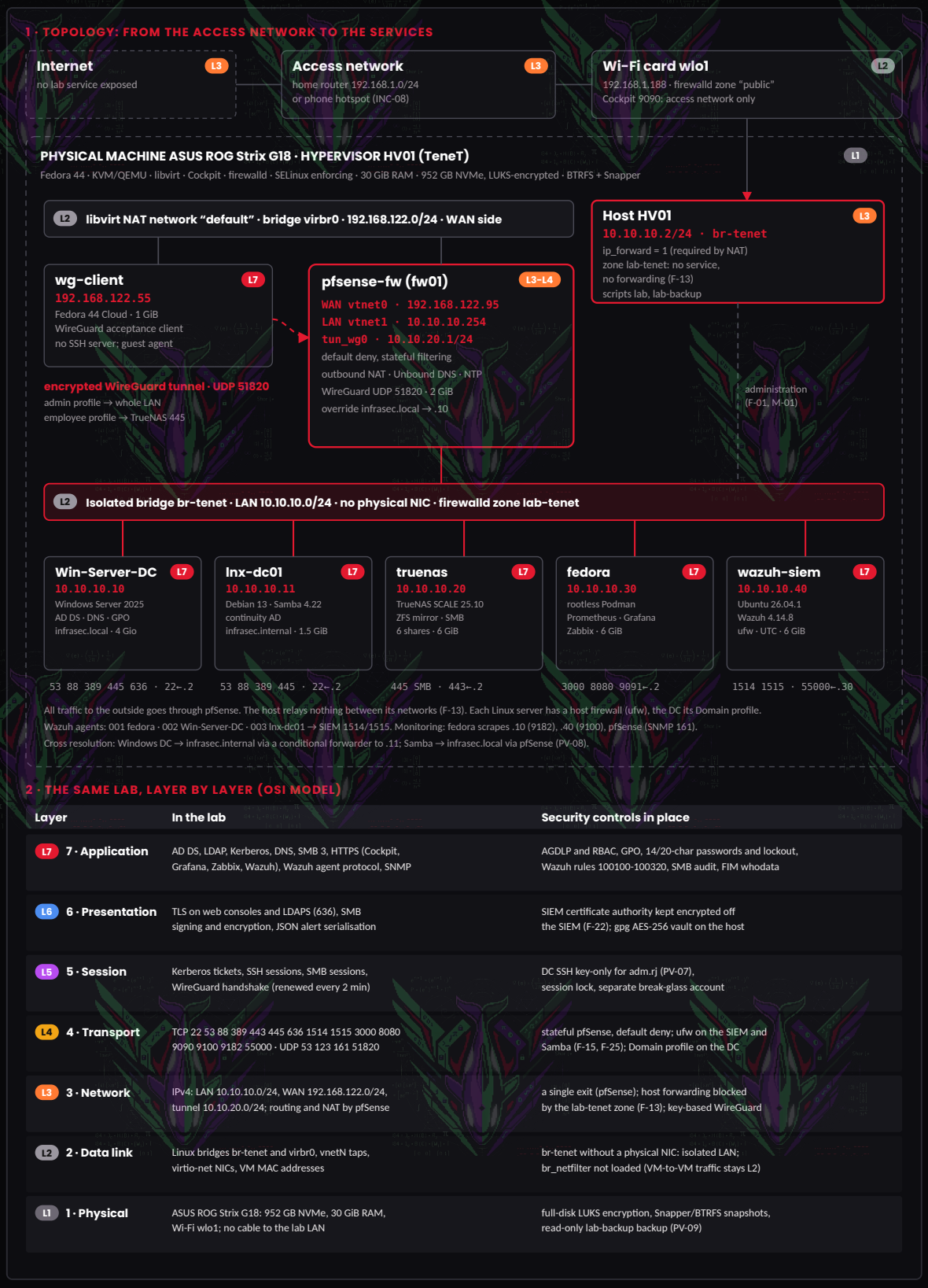
Restart — in the order set by the security policy (firewall, directory, then dependent services):

```
for vm in pfsense-fw Win-Server-DC truenas fedora wazuh-siem; do sudo virsh start
"$vm"; sleep 30; done
```

Operations manual MAN-2026-01, October 11, 2026.

Annex N · Reference network diagram and OSI layers

This diagram brings together in a single view the architecture described in the report: the pfSense firewall, the only crossing point between the outside and the internal segment `10.10.10.0/24`; the WireGuard transport network `10.10.20.0/24`; the hosts of the segment, their services and the controls that protect them. It reads in three zones: the access network and the Internet; the lab WAN `192.168.122.0/24`, the libvirt NAT network whose router is the TeneT host and whose switch is `virbr0`; the LAN `10.10.10.0/24`, behind the isolated virtual switch `br-tenet`. The second part of the diagram reads the same lab layer by layer, from the hardware (L1) to the services (L7). The flow matrix follows.



2 · THE SAME LAB, LAYER BY LAYER (OSI MODEL)

Layer	In the lab	Security controls in place
L7 7 · Application	AD DS, LDAP, Kerberos, DNS, SMB 3, HTTPS (Cockpit, Grafana, Zabbix, Wazuh), Wazuh agent protocol, SNMP	AGDLP and RBAC, GPO, 14/20-char passwords and lockout, Wazuh rules 100100-100320, SMB audit, FIM whodata
L6 6 · Presentation	TLS on web consoles and LDAPS (636), SMB signing and encryption, JSON alert serialisation	SIEM certificate authority kept encrypted off the SIEM (F-22); gpg AES-256 vault on the host
L5 5 · Session	Kerberos tickets, SSH sessions, SMB sessions, WireGuard handshake (renewed every 2 min)	DC SSH key-only for adm.rj (PV-07), session lock, separate break-glass account
L4 4 · Transport	TCP 22 53 88 389 443 445 636 1514 1515 3000 8080 9090 9100 9182 55000 · UDP 53 123 161 51820	stateful pfSense, default deny; ufw on the SIEM and Samba (F-15, F-25); Domain profile on the DC
L3 3 · Network	IPv4: LAN 10.10.10.0/24, WAN 192.168.122.0/24, tunnel 10.10.20.0/24; routing and NAT by pfSense	a single exit (pfSense); host forwarding blocked by the lab-tenet zone (F-13); key-based WireGuard
L2 2 · Data link	Linux bridges br-tenet and virbr0, vnetN taps, virtio-net NICs, VM MAC addresses	br-tenet without a physical NIC: isolated LAN; br_netfilter not loaded (VM-to-VM traffic stays L2)
L1 1 · Physical	ASUS ROG Strix G18: 952 GB NVMe, 30 GiB RAM, Wi-Fi wlo1; no cable to the lab LAN	full-disk LUKS encryption, Snapper/BTRFS snapshots, read-only lab-backup backup (PV-09)

Figure 38 Overall network architecture of the Hybrid InfraSec lab: full topology and a layer-by-layer reading of the OSI model (as of 26/10/2026).

Abbreviations — **L1…L7**: OSI layers: 1 physical, 2 data link, 3 network, 4 transport, 5 session, 6 presentation, 7 application · **OSI**: 7-layer reference model (Open Systems Interconnection) · **HV01**: lab hypervisor, host name TeneT · **KVM**: Kernel-based Virtual Machine · **LUKS**: Linux Unified Key Setup, full-disk encryption · **BTRFS**: B-tree file system, with snapshots · **NAT**: Network Address Translation · **WAN**: outside of the firewall (NAT network 192.168.122.0/24) · **LAN**: lab local network 10.10.10.0/24 · **WG**: WireGuard: encrypted VPN tunnel, UDP port 51820 · **DNS**: Domain Name System · **NTP**: Network Time Protocol · **AD DS**: Active Directory Domain Services · **LDAP**: Lightweight Directory Access Protocol · **SMB**: Server Message Block file sharing, port 445 · **SNMP**: Simple Network Management Protocol, UDP port 161 · **TLS**: Transport Layer Security · **SSH**: Secure Shell remote administration, port 22 · **GPO**: Group Policy Object · **AGDLP**: Accounts → Global groups → Domain Local groups → Permissions · **RBAC**: Role-Based Access Control · **FIM**: File Integrity Monitoring · **whodata**: Wazuh FIM mode that also records the user and the process · **TCP / UDP**: transport protocols, connection-oriented or not · **ufw**:

Debian/Ubuntu host firewall (Uncomplicated Firewall) · **DC**: Domain Controller · **SIEM**: Security Information and Event Management · **VM**: virtual machine · **Gio / Go**: gibibytes (memory, 2^{30} bytes) / gigabytes (disk, 10^{9} bytes) · **agent invité**: QEMU guest agent: service in the VM that takes orders from the hypervisor

Matrix of allowed flows

Source	Destination	Protocol and port	Use	Control
Internet	pfSense WAN `192.168.122.95`	UDP 51820	WireGuard handshake and traffic	firewalld forwarding on the host; pfSense WAN rule
`admin-remote10.10.20.2`	`10.10.10.0/24`	All	Remote administration	WG_REMOTE rule; restriction to admin interfaces planned
`employe-remote10.10.20.3`	TrueNAS `10.10.10.20`	TCP 445	File sharing	WG_REMOTE rule; Active Directory group ACL on the share
fedora `10.10.10.30` (Prometheus)	DC `10.10.10.10`	TCP 9182	windows_exporter metrics	*Pull* collection
fedora `10.10.10.30` (Prometheus)	fedora (local)	TCP 9100	node_exporter metrics	Port removed from the local firewall (F-05)
fedora `10.10.10.30` (Zabbix)	pfSense LAN `10.10.10.254`	UDP 161	SNMP v2c polling of the firewall	LAN rule restricted to the collector; any other source denied and logged (PV-04)
DC, fedora (Wazuh agents)	wazuh-siem `10.10.10.40`	TCP 1514, 1515	Logs, integrity, compliance; agent enrolment	Agents authenticated by the manager
Segment hosts	DC `10.10.10.10`	DNS 53, Kerberos 88, LDAP 389/636, SMB 445	Directory services	Windows local firewall
Internal segment	pfSense LAN `10.10.10.254`	DNS 53, HTTPS 443	Resolution, administration	HTTP 80 still open (F-02, fix planned)
Any other flow from WG_REMOTE	—	—	—	Denied and logged (implicit deny)

OSI layer of each component The report's diagrams carry the OSI layer of each component as a badge. Each badge gives the highest layer the component uses for its role in the diagram: a switch stops at the frame (L2), the firewall routes and filters by address and port (L3-L4), a server provides a service (L7).

Component	OSI layer	What it handles at this layer
`admin-remote` and `employe-remote` devices, acceptance client `wg-client`	L7	The user's applications; the WireGuard client encrypts their IP packets
Internet	L3	Routing IP packets from one network to another

Component	OSI layer	What it handles at this layer
Access router (home box), TeneT host (NAT)	L3-L4	Routing and address/port translation; the host forwards UDP 51820 to the pfSense WAN
`virbr0`, `br-tenet` (LAN switch)	L2	Switching Ethernet frames by MAC address, without reading the IP address
pfSense `fw01`	L3-L4	Routing between WAN, LAN and tunnel; filtering by address, protocol and port, with state tracking
WireGuard tunnel `tun_wg0`	L3 inside L4	Encrypted IP packets (layer 3) carried in UDP, port 51820 (layer 4)
Win-Server-DC, truenas, fedora, wazuh-siem	L7	The services: directory and DNS, SMB share, monitoring, SIEM
TeneT host `.2` on the LAN	L3	An IP address on the internal segment (finding F-01)

Reading. The only port open on the WAN is a UDP port because the tunnel carries encrypted IP inside UDP. The three barriers of figure 7 can also be read by layer: the WireGuard key at tunnel level (layer 3, inside UDP), the pf-Sense rule at address and port level (layers 3 and 4), Active Directory rights at SMB share level (layer 7).

Annex O · Acceptance and monitoring report (PV-04)

Project: Hybrid InfraSec · **Test date:** 11/10/2026 · **Operator:** RJ (`admin`)

Reference: go-live plan (steps E8 to E10, acceptance grid), specifications (EF5, SLA, RTO), monitoring section (chapter 6.1)

Timestamps. Times are given in Paris time (UTC+2). The Linux test machines log in UTC: 09:05 UTC on a screenshot means 11:05 in Paris.

1. Acceptance bench The acceptance client `wg-client` is a dedicated virtual machine (Fedora Cloud 44, 1 GB), placed on the lab WAN network. Before the test, its routing table only held the default route and the WAN network: **no route to `10.10.10.0/24` outside the tunnel**. Its key pair was generated on the machine (`umask 077`); only the public key was declared on the firewall, on peer `employe-remote` (`10.10.20.3/32`). The client routes the whole `10.10.10.0/24` segment into the tunnel, so that each forbidden flow is presented to the firewall and the denial test could fail.

Return points beforehand: hypervisor snapshot `PRE-RECETTE-WG-STABLE` ; firewall VM snapshot before the restore test.

2. WireGuard remote access

Criterion	Measurement	Threshold	Result
Tunnel established	`wg show` : `latest handshake:` `Now` , bytes both ways	Yes	✅ Compliant
Flow encryption	WAN-side capture (`tcpdump -ni ens3 udp port 51820`): 20 packets, all UDP 51820 between the client and the firewall WAN	No data in clear	✅ Compliant
Employee session	`nc -zv 10.10.10.20 445` from the client: `succeeded` (after fixing INC-07)	Established	✅ Compliant
Other flows denied	11:00:00 — domain controller 445 and 3389, container node 22, Wazuh console 443: four `timed out` , four blocks logged on `WG_REMOTE` (*Default deny rule IPv4*)	Denied	✅ Compliant
Revoking an access	Probe every second to the share; peer disabled on the firewall: last success 11:05:32, first failure 11:05:33	< 5 min	✅ Compliant — cut at the next probe cycle (1 s granularity)
Revoked key refused	Access refused without interruption during the whole deactivation (≥ 35 s observed); new handshake and access restored after reactivating the peer	Refused	✅ Compliant

```
  listening port: 50032

peer: zvwZ20VZ/amWGxXrnK7gPm7Hpw5NeIy/IK98lzjBSQo=
  endpoint: 192.168.122.95:51820
  allowed ips: 10.10.10.0/24
  latest handshake: Now
  transfer: 124 B received, 180 B sent
  persistent keepalive: every 25 seconds
[root@localhost ~]# ip route | grep 10.10.10
10.10.10.0/24 dev wg0 scope link
[root@localhost ~]# tcpdump -ni ens3 -c 20 udp port 51820
dropped privs to tcpdump
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on ens3, link-type EN10MB (Ethernet), snapshot length 262144 bytes
08:23:47.768605 IP 192.168.122.55.50032 > 192.168.122.95.51820: UDP, length 32
08:24:12.856571 IP 192.168.122.55.50032 > 192.168.122.95.51820: UDP, length 32
08:24:37.944611 IP 192.168.122.55.50032 > 192.168.122.95.51820: UDP, length 32
08:25:03.032543 IP 192.168.122.55.50032 > 192.168.122.95.51820: UDP, length 32
08:25:28.120548 IP 192.168.122.55.50032 > 192.168.122.95.51820: UDP, length 32
08:25:28.120670 IP 192.168.122.55.50032 > 192.168.122.95.51820: UDP, length 148
08:25:28.121042 IP 192.168.122.95.51820 > 192.168.122.55.50032: UDP, length 92
08:25:28.121109 IP 192.168.122.55.50032 > 192.168.122.95.51820: UDP, length 32
08:25:28.121298 IP 192.168.122.95.51820 > 192.168.122.55.50032: UDP, length 32
08:25:28.875106 IP 192.168.122.55.50032 > 192.168.122.95.51820: UDP, length 96
08:25:29.912451 IP 192.168.122.55.50032 > 192.168.122.95.51820: UDP, length 96
08:25:30.936478 IP 192.168.122.55.50032 > 192.168.122.95.51820: UDP, length 96
08:25:31.880094 IP 192.168.122.55.50032 > 192.168.122.95.51820: UDP, length 96
08:25:32.920480 IP 192.168.122.55.50032 > 192.168.122.95.51820: UDP, length 96
08:25:33.944638 IP 192.168.122.55.50032 > 192.168.122.95.51820: UDP, length 96
08:25:34.887976 IP 192.168.122.55.50032 > 192.168.122.95.51820: UDP, length 96
08:25:35.928533 IP 192.168.122.55.50032 > 192.168.122.95.51820: UDP, length 96
08:25:36.952547 IP 192.168.122.55.50032 > 192.168.122.95.51820: UDP, length 96
08:25:37.895688 IP 192.168.122.55.50032 > 192.168.122.95.51820: UDP, length 96
08:25:38.936489 IP 192.168.122.55.50032 > 192.168.122.95.51820: UDP, length 96
20 packets captured
22 packets received by filter
0 packets dropped by kernel
[root@localhost ~]#
```

Figure 39 Handshake established and WAN-side capture: only encrypted UDP 51820 traffic flows

Real screenshot from the lab; addresses are private (RFC 1918).

30 Matched Firewall Log Entries. (Maximum 500)

Action	Time	Interface	Rule	Source	Destination	Protocol
✕	Oct 6 12:45:38	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:53992	10.10.10.20:443	TCP:S
✕	Oct 6 12:45:39	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:53992	10.10.10.20:443	TCP:S
✕	Oct 6 12:45:40	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:53992	10.10.10.20:443	TCP:S
✕	Oct 6 12:45:41	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:45184	10.10.10.40:443	TCP:S
✕	Oct 6 12:45:42	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:45184	10.10.10.40:443	TCP:S
✕	Oct 6 12:45:43	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:45184	10.10.10.40:443	TCP:S
✕	Oct 11 10:25:32	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:57978	10.10.10.10:445	TCP:S
✕	Oct 11 10:25:33	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:57978	10.10.10.10:445	TCP:S
✕	Oct 11 10:25:34	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:57978	10.10.10.10:445	TCP:S
✕	Oct 11 10:25:35	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:54894	10.10.10.10:3389	TCP:S
✕	Oct 11 10:25:36	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:54894	10.10.10.10:3389	TCP:S
✕	Oct 11 10:25:37	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:54894	10.10.10.10:3389	TCP:S
✕	Oct 11 10:25:38	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:46102	10.10.10.30:22	TCP:S
✕	Oct 11 10:25:39	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:46102	10.10.10.30:22	TCP:S
✕	Oct 11 10:25:40	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:46102	10.10.10.30:22	TCP:S
✕	Oct 11 10:25:41	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:45580	10.10.10.40:443	TCP:S
✕	Oct 11 10:25:42	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:45580	10.10.10.40:443	TCP:S
✕	Oct 11 10:25:43	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:45580	10.10.10.40:443	TCP:S
✕	Oct 11 11:00:01	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:54002	10.10.10.10:445	TCP:S
✕	Oct 11 11:00:02	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:54002	10.10.10.10:445	TCP:S
✕	Oct 11 11:00:03	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:54002	10.10.10.10:445	TCP:S
✕	Oct 11 11:00:04	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:41592	10.10.10.10:3389	TCP:S
✕	Oct 11 11:00:05	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:41592	10.10.10.10:3389	TCP:S
✕	Oct 11 11:00:06	WG_REMOTE	Default deny rule IPv4 (1000000103)	10.10.20.3:41592	10.10.10.10:3389	TCP:S

Figure 40 Filter log: the employee's forbidden flows blocked on WG_REMOTE (tests at 11:00)

Real screenshot from the lab; addresses are private (RFC 1918).

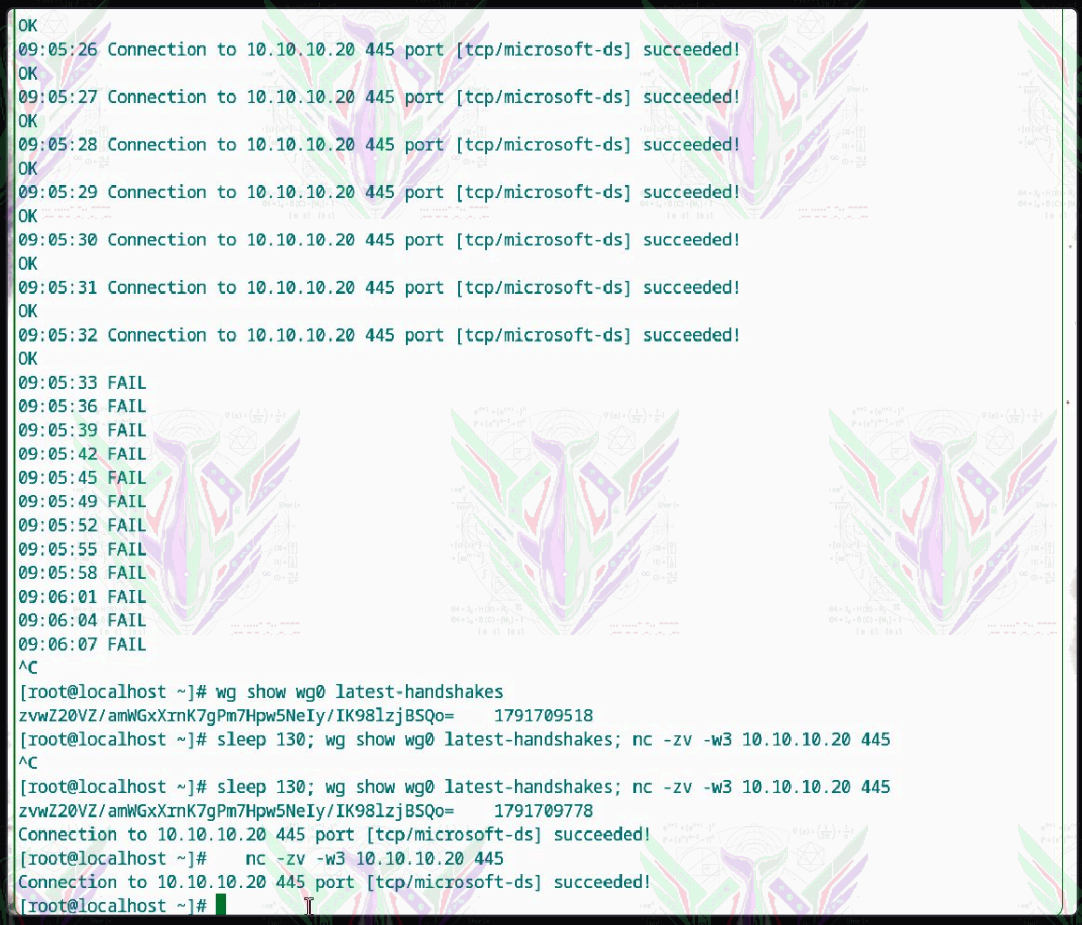


Figure 41 Revocation: from success to failure to the second, then restored after reactivation

Real screenshot from the lab; addresses are private (RFC 1918).

Incident during the acceptance test. The first session test failed despite an established handshake. Diagnosis by successive captures located the cause in the addressing of the `WG_REMOTE` interface (INC-07, Annex J). The test was replayed after the fix; the denial tests were then replayed, since a denial only proves something if the allowed flow goes through.

Out of scope of this test. The administrator profile (`admin-remote`) was not replayed with the acceptance client: its rule (whole internal network) is checked in the configuration, and its restriction to the administration interfaces only is still planned. Denial towards the Internet cannot be tested with this client configuration, which only routes the internal segment into the tunnel.

3. Firewall configuration recovery

Step	Time	Observation
Firewall VM snapshot	11:14	`pre-restore-test` created
Configuration export	11:15	XML file kept offline (it contains secrets)
Test change	11:21	Firewall DNS domain changed from `infrasec.lab` to `restoretest.lab`
Export restored	≈ 11:21	Firewall restarted
Packages reinstalled	11:23:43	Notification "Package reinstall process finished successfully"
Check	11:28	Firewall domain back to `infrasec.lab` ; SMB session through the tunnel `succeeded`

Result: ✅ **Compliant.** The full configuration — rules, tunnel interface and peers — is restored from the export in under five minutes, service checked end to end. The recovery objective (< 1 hour) is met.

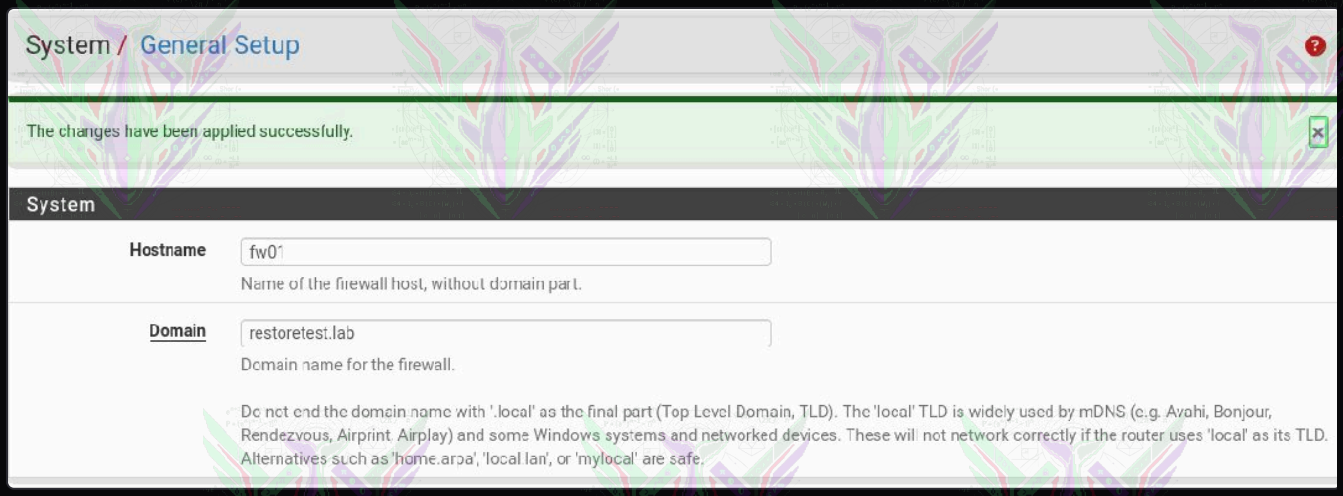


Figure 42 Before the restore: test change of the domain

Real screenshot from the lab; addresses are private (RFC 1918).

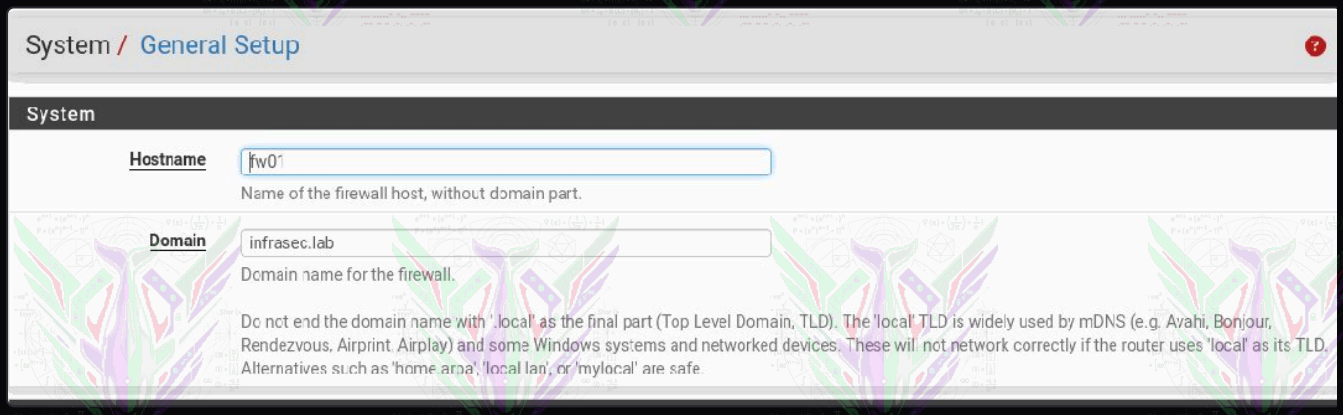


Figure 43 After the restore: original domain back

Real screenshot from the lab; addresses are private (RFC 1918).

4. Network monitoring of the firewall (SNMP and Zabbix)

Implementation. Zabbix 7.0 is deployed on the container node in **rootless Podman** (pod `zabbix` : PostgreSQL database, server, web interface on port 8080, no privilege). The secrets (database password, SNMP community) are generated randomly and stored in a `.env` file in mode 600, outside any deliverable. The firewall is declared with the *PFSense by SNMP* template.

Hardening. The firewall's SNMP daemon is bound to the LAN interface only, with a random community of 24 hex characters (the default `public` value is no longer used). Two rules placed before the default LAN rule restrict querying to the collector only:

LAN rule	Source	Destination	Action
SNMP — Zabbix collector	`10.10.10.30`	firewall, UDP 161	Allow
SNMP — deny other sources	LAN network	firewall, UDP 161	Block and log

Criterion	Measurement	Result
Query from the collector	`snmpget … sysName.0` → `fw01.infrasec.lab`	✅ Answers
Query from another LAN host	Same query from the hypervisor → `Timeout`	✅ Refused

Criterion	Measurement	Result
Zabbix collection	SNMP availability green; 100 items collected (WAN, LAN and `tun_wg0` interfaces, DHCP and DNS state, 92 filtering rules)	✅ Working
Tunnel state visible	Item `tun_wg0 (WG_REMOTE): Operational status = up (1)`	✅ Visible

Floating WireGuard WAN LAN WG_REMOTE

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
✓	0/561 KiB	*	*	*	LAN Address	443 80	*	*		Anti-Lockout Rule	⚙
✓	0/0 B	IPv4 UDP	10.10.10.30	*	This Firewall (self)	161 (SNMP)	*	none		SNMP - collecteur Zabbix (fedora)	⚓ ✎ ⧉ ⊘ 🗑 ✕
✗	0/13 KiB	IPv4 UDP	LAN subnets	*	This Firewall (self)	161 (SNMP)	*	none		SNMP - refus hors collecteur	⚓ ✎ ⧉ ⊘ 🗑
✓	1/197.91 MiB	IPv4 *	LAN subnets	*	*	*	*	none		Default allow LAN to any rule	⚓ ✎ ⧉ ⊘ 🗑 ✕
✓	0/0 B	IPv6 *	LAN subnets	*	*	*	*	none		Default allow LAN IPv6 to any rule	⚓ ✎ ⧉ ⊘ 🗑 ✕

Figure 44 LAN rules: SNMP querying restricted to the collector

Real screenshot from the lab; addresses are private (RFC 1918).



Figure 45 Zabbix: firewall queried over SNMP (availability green)

Real screenshot from the lab; addresses are private (RFC 1918).



Figure 46 Zabbix: data collected on the firewall, including the tunnel state

Real screenshot from the lab; addresses are private (RFC 1918).

Stated limit. SNMP v2c is still accepted in the lab, compensated by the restriction to the collector and listening limited to the LAN; **SNMP v3** (*authPriv*) remains the production target.

5. Availability alert (Grafana)

Rule. "Target unreachable": Prometheus query `up`, condition *below* 1, evaluated every 30 s, pending period 2 min, label `severity=critical`, folder `Hybrid-InfraSec`. It covers the three targets: domain controller, container node, Prometheus.

Time	Event
13:11:18	`node-exporter` service on the container node stopped
≈ 13:11:30	`up = 0` ; rule **Pending**
≈ 13:13:30	Rule **Firing** (after the 2-min pending period)
13:16:52	Service restarted; `up = 1`
≈ 13:17	Back to **Normal**

Result: ✅ **Compliant** with the defined threshold ("target unreachable > 2 min: critical").

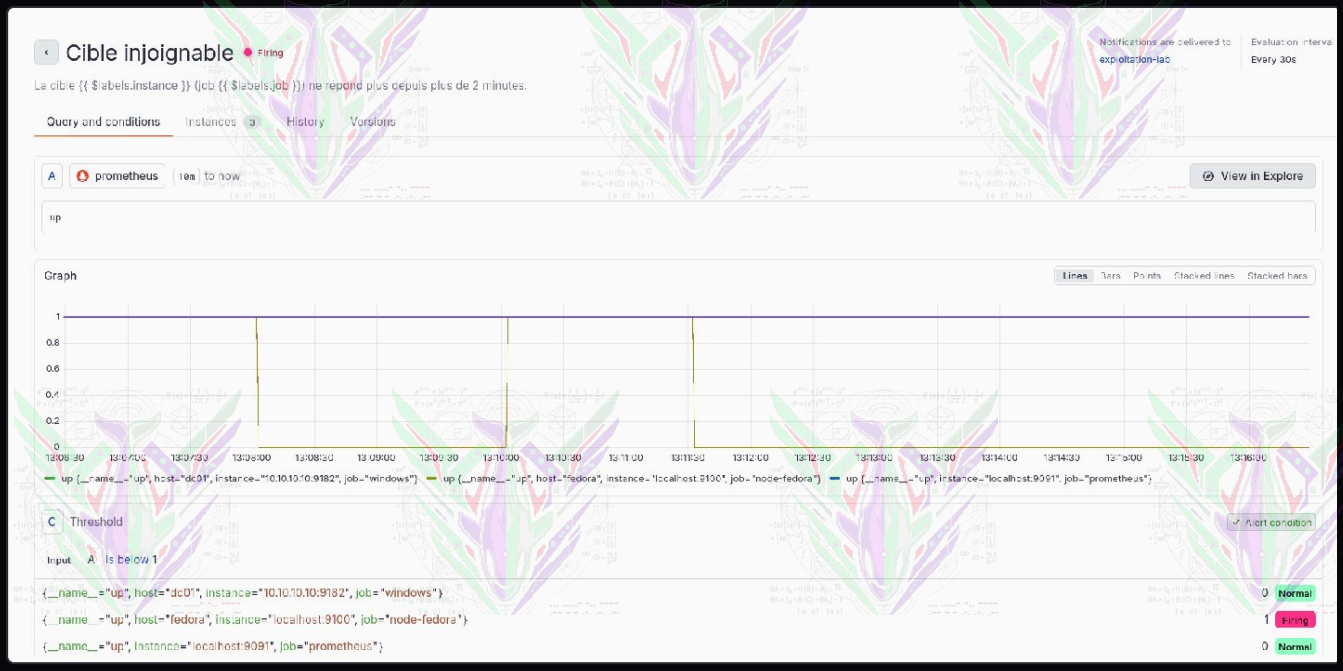


Figure 47 "Target unreachable" alert when it fires

Real screenshot from the lab; addresses are private (RFC 1918).

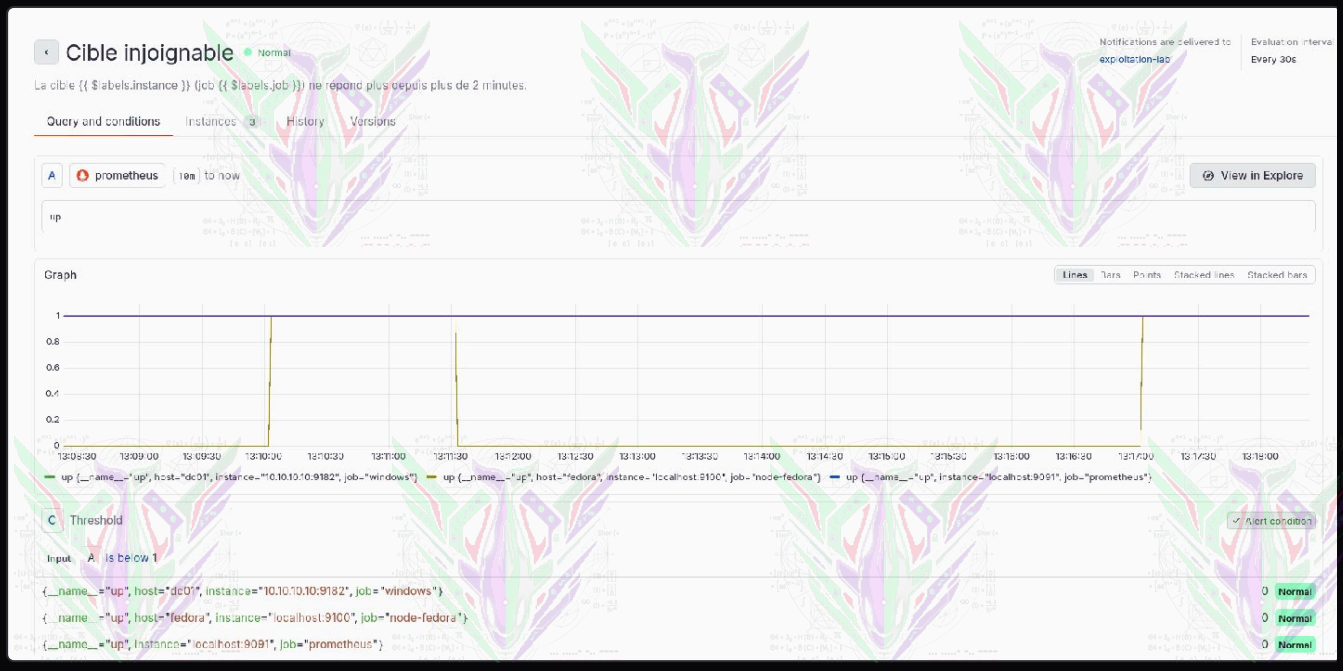


Figure 48 Back to normal after the service restarted

Real screenshot from the lab; addresses are private (RFC 1918).

Useful finding. A first test with `podman stop` raised no alert: the container is driven by a user *systemd* service that restarts it in under a second. That is real resilience of the monitoring; the test was therefore run by stopping the service itself.

Stated limit. The contact point `exploitation-lab` is declared, but there is no mail relay in the lab: the alert is visible in the console, not yet sent. Connecting to an SMTP relay is the next operations step.

6. Wazuh detection rule 100100 (SSH brute force)

Deployment. Local rule added to `local_rules.xml` from the Wazuh console (*Server management* → *Rules*), rule set reloaded on the manager ("Cluster reloaded in 1 node"). Content: Annex K, §6.

Replaying the PV-03 attack. At 13:44:10, eight SSH attempts on non-existent accounts (`fake1` to `fake8`) from the hypervisor to the container node.

Alert field	Value
Timestamp	13:44:12.463, about 2 s after the attack began
Rule	100100, level **12**
Agent	`fedora` (`10.10.10.30`)
Source	`10.10.10.2` , triggered at the 5th attempt (`fake5`)
Correlation	four previous attempts attached (`previous_output`)
MITRE ATT&CK	T1110.001 — *Credential Access*, *Password Guessing*

Result: ✅ **Compliant.** The native correlation (rule 5712) waited for eight attempts within two minutes, at level 10; the local rule fires from the fifth attempt within sixty seconds, at level 12.

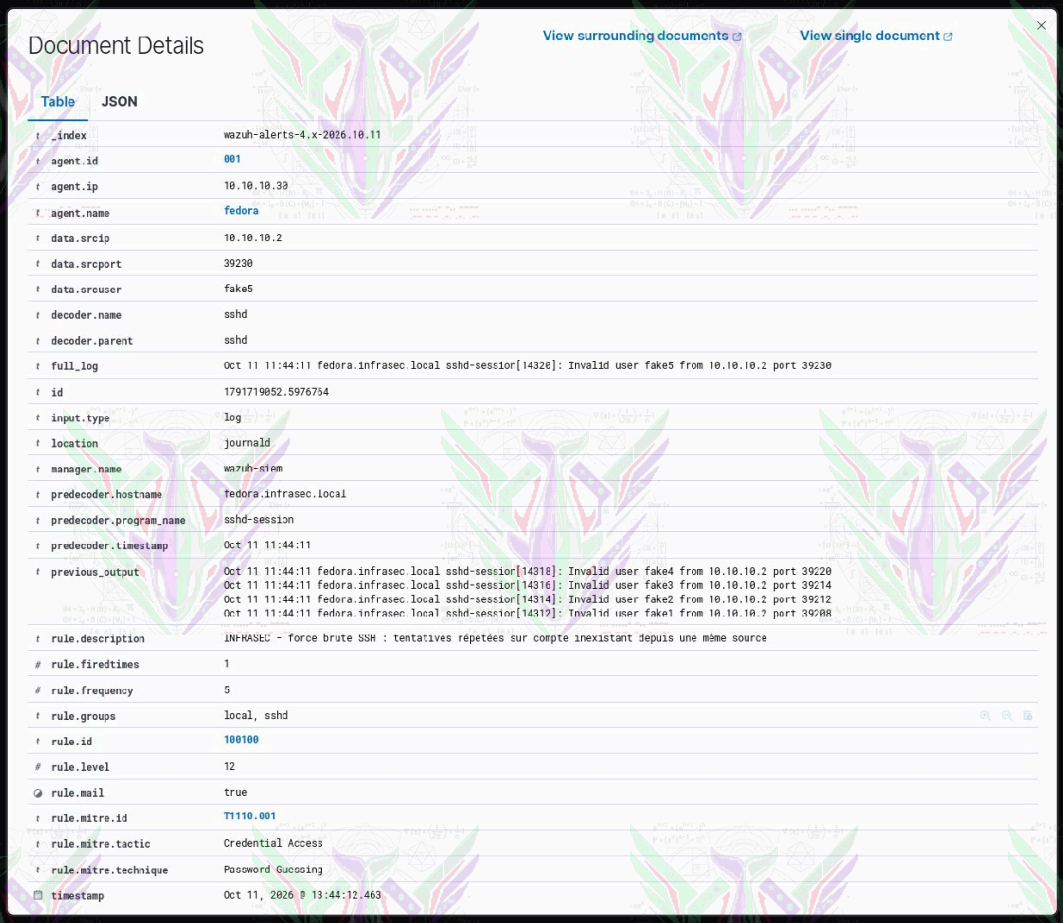


Figure 49 Alert 100100: source, targeted account, correlation and MITRE technique

Real screenshot from the lab; addresses are private (RFC 1918).

7. End-of-acceptance freeze

Item	Observation
Hypervisor snapshots (Snapper)	`POST-RECETTE-WG-STABLE`, `POST-RESTORE-PFSENSE-STABLE`, `POST-SNMP-ZABBIX-STABLE`, `POST-ALERTE-GRAFANA-STABLE`, `POST-REGLE-100100-STABLE`, `POST-RECETTE-COMPLETE-STABLE`
Snapshots of the five VMs	`gel-20261011` created live on the firewall, the domain controller, TrueNAS, the container node and Wazuh, with no service stop
Infrastructure integrity register	SHA-256 hashes of the five VM definitions and of their snapshot lists (table below). The definition files stay offline: they contain the interfaces' hardware addresses

File	SHA-256 hash
`fedora.xml`	`a2d52fac951f7e7a1113688268c3df297b3056f307ded16fade5be1881514a91`
`pfsense-fw.xml`	`ec29739e051ff52d83b4cd78cee00d9a85f0af82732afd2803e017cc62a4e7f7`
`truenas.xml`	`789dafc9699cb278c37a3976ce2ea982352411f77cc308c3bd71866c663db8de`
`wazuh-siem.xml`	`df6b563447e2ae6a801f45cbbbb67363c480d22d8c5b9ad96464ee773a3a86b5`
`Win-Server-DC.xml`	`222f4555860fd8aff0f04dd3079bff9ebd3ffa7f37ce43508cd684d896846317`
`fedora.snapshots.txt`	`fb353f71e7ac9397abee459150c0b566095a94548e7fb566352a0fd1375aa59c`
`pfsense-fw.snapshots.txt`	`84f374a37602b294dd7539fad53c1dbd81484fd670fe086c9c8159c043064c0c`

File	SHA-256 hash
truenas.snapshots.txt	e966c30cd4f807d6cd0c600b9da847c9d02c78abd0549b5e32f1ed6b81c0f5c1
wazuh-siem.snapshots.txt	b2f98dc56101ebb8fc5af56e379aacc2e7f74db541b35969971fdc46ccb3452e
Win-Server-DC.snapshots.txt	1ead8823ab104e87e785d45657943477398be7f4c4a7769a579b9b5654dfab9f

8. Conclusion The essential criteria of the acceptance grid are met: encrypted tunnel, employee session limited to its single service, logged denials, revocation effective to the second, configuration recovery in under five minutes. Monitoring now covers the network device (SNMP restricted to the collector), alerts on an unreachable target and detects SSH brute force from the fifth attempt. **The remote access go-live is declared.**

Reservations, followed in the action plan: rotation of the Wazuh administrator password (to do); test of the administrator profile and restriction of its rule to the administration interfaces only; move SNMP to v3; connect the alert to a mail relay.

Annex P · Full CCP3 sheets (October 2026)

◆ INC-08 — Availability: the hypervisor Cockpit is unreachable outside the home network

Finding date: 21/10/2026 · **Fix:** 23/10/2026
Asset: hypervisor `HV01` (host `TeneT`, Fedora Linux 44) — service `cockpit.socket`, host firewall (`firewalld`, zone `public`)
Impact: loss of the hypervisor's web administration console; the VMs and their services are not affected. Administration continued through the emergency access (`virsh` / virt-manager on the local console).

Symptom

Connected to a smartphone hotspot instead of the home network, the host no longer offers Cockpit, neither from the network nor locally (`https://localhost:9090`).

Diagnosis

1. `systemctl cat cockpit.socket`: a local drop-in file replaces the default listening — `ListenStream=` (reset) then `ListenStream=192.168.1.188:9090`.
2. `ss -tlnp | grep 9090`: Cockpit only listens on `192.168.1.188:9090`, the host's address on the home network.
3. `firewall-cmd --list-all`: the `cockpit` service is not open to the whole zone; a rich rule allows it from `192.168.1.0/24` only.

Root cause

Two hardening measures stacked, one of them in the wrong place. The firewalld rule restricts who can reach Cockpit: that is the right level. Pinning the listening to an address also ties the service's **availability** to one specific network: on another network the address no longer exists and Cockpit listens nowhere, not even locally.

Resolution

`systemctl revert cockpit.socket` (removal of the local override), `daemon-reload`, socket restart. The firewalld rule is kept: remote access stays limited to the administration network.

Proof

- No local drop-in; original unit `/usr/lib/systemd/system/cockpit.socket`: `ListenStream=9090`.
- `ss`: listening on `*:9090`.
- `curl -skI https://localhost:9090` → `HTTP/1.1 200 OK`; console open on `localhost:9090`.
- Rule kept: `rule family="ipv4" source address="192.168.1.0/24" service name="cockpit" accept`.
- **Real-conditions test (23/10, 23:52-23:54)**, laptop on the phone hotspot (`wlo1` = `172.20.10.2`):
- before (old address): `192.168.1.188:9090` → *The connection has timed out* (the address does not exist on this network);
- after: `https://localhost:9090` open, terminal available.

Lesson

(1) Access is restricted at the firewall, not by binding the service to an address: the first measure protects, the second only breaks availability. (2) Hardening is tested on every network where we actually work. (3) A documented, proven emergency access (local console, `virsh`) is what let work continue: security and availability are designed together.

◆ INC-09 — Monitoring: the Zabbix pod does not restart with the VM (deployed outside systemd)

Date: 23/10/2026
Asset: VM `fedora` (`10.10.10.30`), rootless user `ais` — pod `zabbix` (`zbx-db`, `zbx-server`, `zbx-web`)
Impact: SNMP monitoring of the `fw01` firewall interrupted (blind spot); no data loss. Prometheus, node-exporter and Grafana not affected.

Symptom

After the `fedora` VM restarted, the Zabbix web interface (port 8080) no longer answers. `podman ps -a` shows the pod's three containers `Exited (0) 2 days ago`, while `prometheus`, `node-exporter` and `grafana` are `Up 18 minutes`: they restarted on their own.

Diagnosis

1. `systemctl --failed`: no failed unit. The pod does not crash: it is simply not started.
2. `loginctl list-users`: `Linger=yes` for `ais`, so user services start at boot with no open session.
3. `ls ~/.config/containers/systemd/`: Prometheus, node-exporter and Grafana are declared as **Quadlet** files (`*.container`), turned into systemd services at boot (`grafana.service: generated`). The `zabbix` pod, created by hand twelve days earlier (`podman pod create` / `podman run`), has **no** Quadlet file.

Root cause

Inconsistent deployment of the monitoring chain: three components declared to systemd, one started by hand. Nothing restarts the latter at boot.

Related finding (gap with the ISSP, art. 11 — secrets)

`podman secret ls` empty: the PostgreSQL password was passed as a clear-text environment variable, so readable with `podman inspect` and probably present in the shell history.

Resolution

1. Return point: VM snapshot `pre-zabbix-quadlet` (`virsh snapshot-create-as`).
2. Password moved into a Podman secret `zbx-db-password` **without being displayed** (`podman inspect … | sed … | podman secret create zbx-db-password -`).
3. Pod described in Quadlet: `zabbix.pod`, `zbx-db.container`, `zbx-server.container`, `zbx-web.container` (dependencies `Requires=` / `After=`, `Restart=always`, `WantedBy=default.target`, `Secret=…,type=env`). Validated with `quadlet -dryrun -user` before any switch-over.
4. Switch-over: `podman pod rm zabbix` (the named volume `zbx-pg` is kept), `daemon-reload`, start.

Secondary incident during the switch-over: SELinux denial

`zbx-db` stops at once: `chmod: /var/lib/postgresql/data: Permission denied`, although the files belong to `70:70` (the image's `postgres` user) inside the namespace. The audit log confirms it:
`avc: denied { setattr } comm="chmod" name="_data" scontext=…container_t:s0:c272,c377 tcontext=…container_file_t:s0:c125,c516 permissive=0`
The types are right; only the **MCS categories** differ: the volume carried the private label of the old container. Fix: the `:Z` option on the volume (`Volume=zbx-pg:/var/lib/postgresql/data:Z`), which relabels it for its new owner. SELinux stays `enforcing`.

Proof

- After the switch-over: the four units `active (running)`, `curl -sI http://127.0.0.1:8080` → `HTTP/1.1 200 OK`, PostgreSQL `database system is ready to accept connections` (WAL recovery done, no loss).

- `podman inspect zbx-db … | grep -c '^POSTGRES_PASSWORD='` → `0` : the password no longer appears in the container configuration.
- **Non-regression test**: full stop and start of the VM; at `up 1 min` , the seven containers (including `zbx-db` , `zbx-server` , `zbx-web`) are `Up` with no action, and the interface answers `200 OK` .

Functional check

Zabbix → Hosts: `fw01` (`10.10.10.254:161`) available over **SNMP**, 100 items collected. The "Packet filter reason codes" graph shows a collection gap (blind spot) then values resuming at 23:14, right after the switch-over.

False alarm open for 12 days (related finding)

Since 11/10 the dashboard showed "Linux: Zabbix agent is not available" on the `Zabbix server` host: the "Linux by Zabbix agent" template expected an agent on `127.0.0.1:10050` , while no agent is deployed. Yet the architecture splits the roles: Prometheus and node-exporter monitor Linux, Zabbix monitors the firewall over SNMP. Fix: template unlinked and cleared ("Unlink and clear", 121 → 78 items), agent interface removed; only "Zabbix server health" (internal items) is kept. "Host availability" widget extended to SNMP; Geomap widget removed (no location set). Result: 0 problems, 78 triggers with 0 in problem state, `fw01` "Available".

Closing the "clear-text secret" finding

- PostgreSQL password rotation: new random 32-character password, generated in a shell variable, passed to `psql` on standard input (`ALTER ROLE`), then written to the secret (`podman secret create --replace`); never displayed. Restart of `zbx-server` and `zbx-web` : database connection with no error, `HTTP/1.1 200 OK` .
- Shell history: **5** lines contained the old password (`grep -c 'POSTGRES_PASSWORD=' ~/.bash_history` → `5`), which confirms the exposure; removed (`→ 0`).
- Volumes: no orphan volume left; remaining `prometheus-data` , `grafana-data` , `zbx-pg` , `zbx-export` , `zbx-snmptraps` .

Lesson

(1) A service is in production only if it is **declared**: any container started by hand is a delayed incident; the rule becomes "one service = one versioned Quadlet file". (2) An access denial while Unix rights are correct is read in `ausearch -m AVC` : we fix the label, we do not disable SELinux. (3) The proof of a restart fix is a restart. (4) A secret in an environment variable is an exposed secret: `podman secret` separates the value from the configuration, and an exposed secret is changed (rotation), not hidden. (5) An alert left open with no action no longer informs anyone: the monitoring scope must match the architecture.

◆ INC-10 — Change F-13: the host loses its address on the lab LAN (non-persistent configuration revealed)

Date: 24/10/2026, 01:11 → 01:20 (outage: about 8 minutes)
Asset: hypervisor `HV01` (host `TeneT`) — bridge `br-tenet`, NetworkManager connection `br-tenet`
Impact: the host can no longer reach any lab service (Cockpit on `fedora`, TrueNAS, Wazuh API, Grafana, Zabbix, pfSense); the VMs keep running and keep talking to each other. No data loss.
Originating change: fix of F-13 (`nmcli con mod br-tenet connection.zone lab-tenet` then `nmcli dev reapply br-tenet`), preceded by the snapshot `PRE-F13-ZONE-LAB`.

Symptom

A few minutes after the change, every lab web interface times out (*Connection has timed out*, *API is down*, *NetworkError*). `ping 10.10.10.30` from the host: 100 % loss.

Diagnosis (service first, then cause)

1. Hypothesis 1, VM ports detached from the bridge by the `reapply`: ruled out. `ip -br link show master br-tenet` lists the 5 LAN-side ports (`vnet2`, `vnet3`, `vnet4`, `vnet6`, `vnet8`), all `forwarding` (`bridge link`).
2. Hypothesis 2, the new zone blocks replies: `br-tenet` put back into `public` live; the ping still fails. The zone is not the cause.
3. `ip -br addr show dev br-tenet`: the bridge is `UP` **with no address**; no more `10.10.10.0/24` route. `nmcli con show br-tenet`: `ipv4.method: disabled`, `ipv4.addresses: --`.

Root cause

The host address `10.10.10.2/24` had never been declared in NetworkManager: it had been added by hand (`ip addr add`), as the `10.10.10.0/24` route without a metric already showed (routes created by NetworkManager carry one). The `reapply` put the connection back in its declared state, with no address. The same weakness existed at every host reboot.

Recovery and fix

1. Recovery: `ip addr add 10.10.10.2/24 dev br-tenet` → ping `0 % loss`, Zabbix `HTTP/1.1 200 OK`.
2. Isolated test of the zone: `br-tenet` put back into `lab-tenet` live → ping still `0 % loss`, Zabbix `200 OK`. The closed zone does not hinder the host's outbound connections.
3. Lasting fix: address declared in NetworkManager — `ipv4.method manual`, `ipv4.addresses 10.10.10.2/24`, `ipv4.never-default yes` (the bridge never becomes the default route), `ipv6.method disabled`; `reapply` replayed on purpose: address present, zone `lab-tenet`, ping `0 % loss`.

Lesson

(1) A "minor" change on the host network (firewall zone) revealed an undeclared configuration: anything that is not in the configuration tool disappears at the first reload. Rule: no hand-made network configuration on the host, everything goes through `nmcli`. (2) Diagnosis by elimination: one hypothesis at a time, each checked with a command (bridge ports, zone, address), without touching the VMs. (3) The service is restored first (address put back live), the cause is fixed next (persistent configuration), then the fix is proven by replaying the action that caused the outage. (4) The return point `PRE-F13-ZONE-LAB` existed; it was not needed, because the cause was found in under ten minutes.

◆ INC-11 — Detection: the Wazuh manager fails at boot, SIEM blind for 3 h 10 with no alert

Date: 23-24/10/2026 · **Times in UTC (SIEM logs)**, Paris time in brackets
Asset: VM `wazuh-siem` (`10.10.10.40` , Ubuntu 26.04.1 LTS, Wazuh 4.14.8) — service `wazuh-manager` (analysis, API `55000` , agent reception `1514`)
Impact: from 20:17 to 23:27 UTC (22:17 → 01:27), no agent event is analysed and no alert can be raised. The indexer and dashboard run: the interface displays, but shows *[API connection] API is down*. No monitoring reports the outage.

Symptom

24/10 at 01:16 (Paris), the Wazuh dashboard shows *API is down* and *Error getting the authorization token*.

Diagnosis

1. Session at 01:49: `systemctl is-active wazuh-manager wazuh-indexer wazuh-dashboard` → `active` ×3; `api.log` : `wazuh-wui` authentications with `200` . The service works in the current boot; the outage is earlier.
2. `journalctl --list-boots` : four boots on 23/10 (UTC) — `-3` 20:17:02 → 23:27:20, `-2` 23:27:24 → 23:28:18, `-1` 23:28:20 → 23:37:12, `0` since 23:49:41. The symptom (23:16-23:21 UTC) falls in boot `-3` .
3. `journalctl -u wazuh-manager -b -3` : `wazuh-apid: Process 1485 not used by Wazuh, removing...` → `Killed` → `wazuh-apid did not start correctly` → `Failed with result 'exit-code'` (20:17:10, after 3.4 s).
4. `journalctl -u wazuh-indexer -b -3` : indexer started at 20:17:17, active until 23:27:17. Only the manager was missing.
5. Boot `-1` : manager started normally at 23:28:24; the service came back with the VM restart at 23:27, not through a corrective action.

Root cause

A PID file left by an unclean shutdown pointed, at the next boot, to a process number reassigned to another program. The Wazuh start script removed that process, the API did not start and the whole manager stopped in failure. Two defects turned this one-off failure into a three-hour outage:

- **no automatic restart**: the `wazuh-manager.service` unit has no `Restart=` ; a failure at start stays a failure;
- **nobody watches the SIEM**: Prometheus scrapes `localhost` and the domain controller, Zabbix the firewall over SNMP; neither the API (`55000`) nor agent reception (`1514`) is checked.

Fix

1. Automatic restart (systemd override, without touching the package unit): `/etc/systemd/system/wazuh-manager.service.d/restart.conf` → `[Service]` `Restart=on-failure` `RestartSec=30` ; `daemon-reload` . Check: `systemctl show wazuh-manager -p Restart -p RestartUSec` → `Restart=on-failure` , `RestartUSec=30s` .
2. SIEM monitoring in Zabbix: host `wazuh-siem` , two *Simple check* items from the Zabbix server (`fedora`), every minute — `net.tcp.service[tcp,10.10.10.40,55000]` (API) and `net.tcp.service[tcp,10.10.10.40,1514]` (agent reception), value `1` at rest. Two **High** severity triggers: `max(…,#3)=0` , i.e. three consecutive failures (an incident or a 30 s automatic restart raises no false alarm).

Detection test (24/10, Paris time)

- 02:18:50: `systemctl stop wazuh-manager` → `inactive` (clean stop: `Restart=on-failure` does not restart, which allows the test);

- 02:21:13 and 02:21:14: problems *SIEM: Wazuh API unreachable (55000)* and *SIEM: agent reception stopped (1514)*, High severity, on the dashboard;
- 02:38:12: `systemctl start wazuh-manager` → `active`. **Detection delay: 2 min 23 s**, against 3 h 10 with no alert during the incident.

Related finding: administration access to the SIEM lost

The password of the `ais` account on `wazuh-siem` was recorded in no password manager. Recovered through the out-of-band console (KVM): boot with `rw init=/bin/bash`, `passwd ais`, reboot. Trap met: in this rescue shell the keyboard is QWERTY. The new password is stored in the manager.

Lesson

(1) A security service that can fail at boot must restart on its own; otherwise a few-second incident becomes an outage of several hours. (2) The detection tool itself must be monitored: a stopped SIEM raises no alert, the worst kind of silence. (3) We read the logs of the **right** boot: `journalctl --list-boots` first, then `-b -N`. (4) Admin accounts go into a password manager as soon as they are created.

◆ F-13 — The hypervisor can relay traffic between the outside network and the lab LAN, outside pfSense

Date: 23-24/10/2026 · **Type:** configuration finding (audit) · **Severity:** medium to high · **Link:** F-01 (host on the LAN), EBIOS scenario SO-3

Asset: hypervisor `HV01` (host `TeneT`, Fedora Linux 44) — interfaces `wlo1` (outside network: home or phone hotspot) and `br-tenet` (bridge of the LAN `10.10.10.0/24`, host address `.2`), host firewall `firewalld`

Finding

Three conditions met, observed on 23/10:

1. The host routes packets: `net.ipv4.ip_forward = 1` (required by the libvirt NAT on `virbr0`, pfSense's WAN side).
2. The host has a leg in each network: `10.10.10.0/24` on `br-tenet` (`src 10.10.10.2`) and `192.168.1.0/24` on `wlo1` (`src 192.168.1.188`).
3. `br-tenet` and `wlo1` are in the **same** firewalld zone `public`, whose intra-zone forwarding is on (`firewall-cmd --zone=public --query-forward` → `yes`). The zone also opens the host's `ssh` service to the LAN.

Risk

A machine on the outside network that adds the route "`10.10.10.0/24` via the host" can send packets straight into the lab LAN, **without going through pfSense**, the only crossing point planned by the architecture. Server replies go back through their pfSense gateway; pfSense's stateful filtering breaks TCP connections in practice (asymmetric routing), but that is a side effect, not a protection. The other way round, any LAN machine reaches the host's SSH service (pivot to the hypervisor, F-01).

Limit of the proof: finding established on the configuration (rules and routing tables), without exploitation from a second machine on the home network.

Checks before fixing

- `lsmod | grep br_netfilter`: module not loaded; `net.bridge.bridge-nf-call-iptables` absent. Traffic between VMs on the bridge stays at layer 2 and does not cross the host firewall: changing the bridge's zone cannot cut DC, TrueNAS, fedora exchanges.
- `firewall-cmd --list-all-policies`: no active forwarding policy between zones (`gateway-*` disabled); the `libvirt` zone (`virbr0`) is managed separately.
- `ss -tunap` on the host: every connection on `10.10.10.2` is **outbound** (browser to Zabbix, Grafana, Prometheus, TrueNAS, pfSense); `prometheus.yml` does not scrape the host. Nothing in the lab needs to reach the host.
- Return point: `snapper -c root create -d "PRE-F13-ZONE-LAB"` (snapshot 188, 24/10 01:10).

Fix

A dedicated zone for the lab bridge, with no service and no forwarding, attached by NetworkManager (persistent):

```
firewall-cmd --permanent --new-zone=lab-tenet
firewall-cmd --permanent --zone=lab-tenet --remove-forward
firewall-cmd --reload
nmcli con mod br-tenet connection.zone lab-tenet
nmcli dev reapply br-tenet
```

Proof

- `firewall-cmd --get-active-zones`: `lab-tenet` → `br-tenet`; `public` → `wlo1` only.
- `lab-tenet`: `target: default`, `services:` empty, `forward: no` (`--query-forward` → `no`).

- From the LAN (VM `fedora`), 24/10 02:05, host reachable (address restored): `10.10.10.2:22` closed, `10.10.10.2:9090` closed; controls `10.10.10.20:445` open, `10.10.10.40:55000` and `:1514` open. The zone closes the host's services to the LAN without hindering the lab.
- A first test (01:11) happened during INC-10, while the host had no LAN address; it is not kept as proof.
- Incident during the change: see INC-10 (non-persistent host address, revealed by the `reapply`).
- After INC-10: zone `lab-tenet` active on `br-tenet` with the address `10.10.10.2/24` declared in NetworkManager; the host still reaches the lab (ping `0 %` loss, Zabbix `200 OK`).
- Stability point: `POST-F13-ZONE-LAB-STABLE`.

Effect on F-01

The "LAN can reach the hypervisor" leg is closed. The other leg remains: the host still has an address in the LAN and can reach it (admin browser). The full treatment remains measure M-01 (separate administration network). Accepted consequence: administering the host through the WireGuard tunnel is no longer possible; the hypervisor was outside the scope of remote access.

Lesson

(1) One firewalld zone per trust network: two networks of different levels in the same zone make an open bridge. (2) On a hypervisor, `ip_forward` is often mandatory; so it is the firewall that must say where forwarding is allowed. (3) Before hardening, measure the dependencies (`ss`, collector configuration, `br_netfilter`): the fix cut no service.

◆ F-14 — Availability: the SIEM vulnerability database fails to update when the lab starts out of order

Period: 03/10 → 11/10/2026 (finding on 24/10) · **Type:** finding (CP8), fixed (CP9) · **Severity:** medium
Assets: VM `wazuh-siem` (`vulnerability-scanner` module, CVE feed), `Win-Server-DC` (the lab's only DNS), VM start-up on the hypervisor `HV01`

Finding

The Wazuh log, archived at rotation in `/var/ossec/logs/wazuh/2026/Oct/ossec-23.log.gz` (and not in `ossec.log`, emptied at midnight), contains 7 `content-updater … Could not resolve hostname` failures (14 lines: one warning and one error per failure) between 04/10 08:37 and 11/10 07:59 UTC.

Correlation

`journalctl --list-boots` on the SIEM: each failure happens **47 to 48 s after the VM boots** (04/10, 05/10, 06/10, 07/10 ×2, 10/10, 11/10). The first feed download starts before the domain controller, its only DNS server, answers. On 21 and 23/10 the DC was already up: no failure. Two boots (04/10, 9 h of uptime; 06/10, 5 h 30) were followed by no success: from 03/10 09:18 to 05/10 18:45 UTC, the CVE database was not updated, with no alert.

Root cause

No start order: no VM starts automatically, they are started by hand. Ubuntu (SIEM) boots faster than Windows (DC) and depends on its DNS.

Fix

Script `/usr/local/bin/lab` (root:root, 0755, hash checked):

- `lab start`: pfSense, wait for `10.10.10.254:443`; DC, wait for a **real** DNS answer (`status: NOERROR` and at least one record for `infrasec.local`); then TrueNAS, fedora, wazuh-siem, wg-client;
- `lab stop`: clean ACPI shutdown in reverse order, never forced (also removes the cause of INC-11, the PID file left by a brutal stop);
- every step logged: `journalctl -t lab`.

On the DC: shutdown accepted from the logon screen (`shutdownwithoutlogon = 1`, power button = shut down). Access reserved to whoever has the VM console, hence already administrator of the hypervisor.

Defect found during the test (fixed)

First run: `DC DNS operational (0 s)`, two seconds after Windows started. The test only checked that `dig` printed something, and `dig` also prints its failure messages. Fixed (`NOERROR` and an answer required), checked on three simulated cases (no answer, SERVFAIL, valid answer).

Proof (24/10 and 25/10)

- `lab start`: real DNS wait of 35 s, SIEM started 20 s after the DNS answered (24/10 13:24:46 → 13:25:06; same result on 25/10).
- SIEM: module started at 11:25:20 UTC, **no** resolution error at the moment it used to happen; feed up to date (`Feed update process completed`).

Open point, followed in F-26

The DC ignored the shutdown request three times: 24/10 13:43 (180 s), 26/10 00:20 (180 s, stopped on its own after the delay), 26/10 20:32 (300 s, updated script). The script never forced anything. Cause and fix: F-26.

Script evolution (26/10)

`lnx-dc01` added to the order (started after the Windows DC, with a wait for a real answer from its DNS); Windows DC shutdown wait raised to 300 s. Hash `825baad6…`, previous copy kept (24/10). Shutdown test: five VMs stopped cleanly in order (including `lnx-dc01` in 5 s), two refusals reported with no forced stop (F-26).

Lesson

(1) An undeclared dependency (DNS) turns a start order into a silent outage. (2) Logs rotate: an investigation also covers the archives. (3) An availability check must require a real answer, not a non-empty output: "0 s" was the sign that the test could not fail.

◆ F-15 — The SIEM has no host firewall: all its services are open to the LAN

Date: 25/10/2026 · **Type:** audit finding (CP8), fixed (CP9) · **Severity:** medium
Asset: VM `wazuh-siem` (`10.10.10.40`, Ubuntu 26.04.1 LTS, Wazuh 4.14.8)

Finding

`ufw status` → `inactive`. `ss -tlnpu` shows seven services listening on all interfaces (`0.0.0.0` / `*`): agent reception (`1514`), enrolment (`1515`), API (`55000`), dashboard (`443`), SSH (`22`), Cockpit (`9090`) and node-exporter (`9100`, added the same day). Only the indexer (`9200`) and its cluster port (`9300`) listen locally. Any LAN machine, and the WireGuard tunnel's admin profile allowed into the LAN, can therefore reach the SIEM's administration.

Risk

The SIEM is the machine that detects attacks: compromising it blinds the lab. Exposing its API, dashboard and SSH to the whole LAN widens the attack surface with no business need (least privilege not applied, ISSP network article).

Analysis of legitimate flows (before any rule)

Port	Service	Real need
1514, 1515	agents, enrolment	LAN agents (`fedora`, `dc01`, future workstations)
55000	API	dashboard (local) and Zabbix check (`10.10.10.30`, INC-11)
443, 22, 9090	dashboard, SSH, Cockpit	administrator from the host (`10.10.10.2`)
9100	node-exporter	Prometheus (`10.10.10.30`)
9200, 9300	indexer	local only (already the case)

Fix

Return point: VM snapshot `pre-ufw`. Default policy `deny incoming` / `allow outgoing`, seven commented rules, one per legitimate flow, logging `low`, then `ufw enable` (enabling keeps the open SSH session, allowed by rule 1). Documented emergency path: KVM console then `ufw disable`.

Proof (25/10, 12:01–12:02)

- From `fedora` (`10.10.10.30`): `1514`, `55000`, `9100` open; `22`, `443`, `9090` closed.
- From the host (`10.10.10.2`): `22`, `443`, `9090` open; `9100` closed.
- Agents `fedora` and `dc01` still `Active` (`agent_control -l`).
- A first test run from the SIEM itself showed everything "open": a connection to its own address goes through the loopback, always allowed. That test could not fail; it is not kept.

Lesson

(1) List the legitimate flows before writing the first rule: each port opens to the only source that needs it. (2) A filtering test is run from a third machine, never from the target. (3) A firewall is enabled remotely with the admin access rule already in place and an emergency console.

◆ F-16 — The SIEM disk is not monitored (and a false growth alarm)

Date: 24-25/10/2026 · **Type:** finding (CP8), fixed (CP7/CP9) · **Severity:** medium
Asset: VM `wazuh-siem` (`10.10.10.40`), disk `/dev/vda2` (ext4, 40 GB)

Starting point: an alarm that was a measurement error

On 24/10 the login banner showed 56.1 % usage and `df -h /` 60 % thirteen minutes later; I had concluded a growth of 1.6 GB in 13 minutes. On 25/10 the same pair of values (56.0 % then 60 %) came back, and two `df` one minute apart gave 60 % and 60 %. The banner is computed in advance and cached; only `df` measures the moment. There was no growth.

Analysis

- `du -xh --max-depth=1 /var/ossec/queue` : `vd` = 11 GB (Wazuh CVE vulnerability database), `indexer` = 910 MB, the rest < 200 MB.
- `/var/ossec/queue/vd` exists since 03/10; the CVE database size is normal for this version and stable.
- Conclusion: nothing to delete. The real finding: **nobody watches this disk**. Prometheus scraped `fedora` and the DC; Zabbix, the firewall and the SIEM ports. A doubling of the database during an update would have filled the disk with no alert, and a SIEM with a full disk stops indexing.

Fix

1. `prometheus-node-exporter` installed on the SIEM; port `9100` open **to Prometheus only** (`10.10.10.30`) by the host firewall (F-15).
2. Target added by appending to `~/prometheus/prometheus.yml` on `fedora` (dated backup copy, file mounted in the container, same inode kept), validated with `promtool check config` (`SUCCESS`) before the restart. The 4 targets are `up = 1`.
3. Grafana rule "Disk almost full (Linux)", folder `Hybrid-InfraSec` , group `infra` (evaluated every 30 s): `100 - 100 * node_filesystem_avail_bytes{mountpoint="/", fstype!~"tmpfs|overlay"} / node_filesystem_size_bytes{…}` , threshold **> 80**, pending 5 min, keep firing 1 min, `severity = warning` . A single rule covers every Linux server, present and future.
   The metric counts usable space without the ext4 root reserve (62.1 % against 60 % in `df`): it is the space Wazuh, which does not run as root, really has.

Proof (25/10)

- Test threshold at 60: `wazuh-siem` (62.1 %) → *Firing*, `fedora` (36 %) → *Normal*; rule state *Firing*. The instance was already pending since ~13:52 because of a first save with a threshold of 0, hence the quick move to *Firing*.
- Production threshold at 80: both instances *Normal*.

Lesson

(1) Before concluding there is growth, measure twice with the **same** tool. (2) What is not monitored ends up failing silently: every server enters monitoring when it goes into service. (3) An alert is proven by lowering its threshold, not by filling a production disk.

◆ F-17 — Web browsing on the domain controller, with the built-in Administrator account

Date: 25/10/2026 · **Type:** finding (CP8), fixed (CP9) · **Severity:** high
Asset: `Win-Server-DC` (`dc01`, `infrasec.local`)

Finding

`Get-Process` and `quser` on the DC (20:55):

- a console session of the **built-in** `Administrator` account, opened at 14:57;
- **15** `msedge` **processes** in that session, since 14:58 (about 6 h), with new processes at 17:21, 19:26 and 20:54; a webmail tab open;
- test before the fix (21:01): `https://example.com` displays, the DC has free outbound web access.

Risk

The browser is the first way in for attacks (booby-trapped link, drive-by download, attachment). On a DC it runs with domain administrator rights: a single malicious page can compromise the whole directory. Second gap: everyday use of the built-in `Administrator` account, which the ISSP tier model keeps for emergencies; the named admin account is `adm.rj`.

Fix

Return point: snapshot `pre-gpo-navigation`. Browser closed (`Stop-Process msedge`). GPO **`DC - Navigation interdite`** (no browsing), linked to the `Domain Controllers` OU only:

- `HKLM\SOFTWARE\Policies\Microsoft\Edge\URLBlocklist\1 = *`: every site blocked;
- `StartupBoostEnabled = 0` and `BackgroundModeEnabled = 0`: Edge no longer preloads and no longer runs in the background. Windows Update is not affected (it does not go through the browser).

Proof (25/10, 21:06–21:07)

- `gpresult /r /scope computer`: `DC - Navigation interdite` applied.
- Same test as before: `https://example.com` → **"This page is blocked — Your organization doesn't allow you to view this site"**.

Incident during implementation

First try: `GpoWithNameNotFound` errors on all three settings, the GPO creation line having been skipped. `gpupdate` then "succeeded" without applying anything: a tool success is not a result. The browsing test showed it.

Limits and follow-up

- A GPO can be undone by a domain administrator. Defence in depth would be a pfSense rule forbidding outbound web for the DC.
- Use of the built-in `Administrator` account: to be replaced by `adm.rj` for everyday administration; `Administrator` becomes an emergency account.
- On 26/10, a request to reopen the browser to copy commands was turned down in favour of SSH (PV-07).

Lesson

(1) An infrastructure server has no browser. (2) A fix is proven by the same test as before, replayed afterwards. (3) A red error followed by a successful `gpupdate` is still a failure.



◆ F-18 — Stopping the domain controller's Wazuh agent raises no alert

Date: 25/10/2026 · **Type:** finding (CP8, found during the F-19 scenario), fixed (CP9) · **Severity:** high
Assets: `Win-Server-DC` (agent `dc01`), `wazuh-siem`
Matching technique: MITRE ATT&CK T1562.001 (*Impair Defenses: Disable or Modify Tools*).

Discovery

While preparing F-19, a `Restart-Service WazuhSvc` timed out ("Cannot stop WazuhSvc"): the stop happened, the restart never did. Agent log: `Received exit signal` 19:23:48, `Exit completed successfully` 19:24:21. The DC stayed **unwatched for about 9 minutes**, and the test file dropped meanwhile (19:24:47) produced no event.

What the SIEM saw

- Agents dashboard: `Disconnected (1)`, visible only if someone looks at it.
- Alerts: rule **506** *Wazuh agent stopped*, **level 3**, at 19:22:22 and 19:24:21. No 504: the stop was clean, the agent announced it itself.
- Level 3 against a threshold of 10: **no alert**.

Fix

Local rule **100310**, level **10**, child of 506, MITRE T1562.001, in `local_rules.xml` (backup `.bak-20261025b`, validated with `wazuh-analysisd -t`). It covers every agent. A planned restart will trigger it too: that is intended.

Proof (25/10)

- `sc.exe stop WazuhSvc` (`STATE: 1 STOPPED`), restart 45 s later → `Running`.
- Alert **100310, level 10, agent `dc01`, 18:52:35.508 UTC**.

Known limit

A brutal stop (VM power cut, process killed) sends no 506: the manager marks the agent *disconnected* (rule 504), which stays at level 3.

Lesson

(1) A security sensor that can be switched off with no alert protects nothing. (2) An incident during a test is data, not a setback.

◆ F-19 — Persistence through the StartUp folder: detected, but below the alert threshold

Date: 25/10/2026 · **Type:** attack scenario (CP10), finding then fix (CP9) · **Severity:** high
Assets: `Win-Server-DC` (agent `dc01`), `wazuh-siem` (Wazuh 4.14.8)
Simulated technique: MITRE ATT&CK T1547.001 — a file dropped in `C:\ProgramData\Microsoft\Windows\Start Menu\Programs\StartUp` runs at every logon, for every user.

Setting up the monitoring

Central configuration on the manager (`/var/ossec/etc/shared/default/agent.conf`, backup `.bak-20261025`, validated with `verify-agent-conf`): FIM monitoring of the folder in **whodata** mode (real time + identity of the author). The agent received it and restarted on its own: `real-time Whodata engine started` (19:22:35).

Finding 1: the dashboard showed nothing

Search `syscheck.path:*StartUp*` empty, twice. Reading the raw log on the SIEM (`grep -i maj.bat /var/ossec/logs/alerts/alerts.json`): the event existed. Wazuh records Windows paths **in lower case** and the query wildcard is case-sensitive.

Finding 2: detected, but nobody is alerted

Alert of 25/10 18:43:16.671 UTC (file created at 18:43:15): rule **554** *File added to the system*, **level 5**, no MITRE tag; whodata: user `Administrator`, process `powershell.exe` (PID 7660), SHA-256 `c97a25b5…`. The lab alert threshold is 10.

Fix

Local rule **100300**, level **12**, child of 550 and 554, `file` field filtered with `(?i)\\start menu\\programs\\startup\\` (case-insensitive), MITRE T1547.001.

Proof (25/10)

File `maj.bat` created at 18:52:00 UTC → alert **100300, level 12, agent `dc01`, 18:52:01.582 UTC**: detection delay **1.6 s**. Test file removed afterwards (`Test-Path` → `False`).

Lesson

(1) Seeing an event is not enough: it must reach the level that raises an alert. (2) When the interface shows nothing, read the raw log. (3) On Windows, a rule that filters a path must ignore case.

◆ F-20 — The share audit only saw logons, not files

Date: 25/10/2026 · **Type:** finding (CP8, found during PV-06), fixed (CP9) · **Severity:** medium
Asset: `truenas` (`10.10.10.20`), SMB shares

Finding

During the PV-06 investigation, the TrueNAS SMB audit log held only 19 lines, all of type `Authentication`. No file read, write or deletion was recorded: the shares' *Audit Logging* column read `No`. We knew who had logged on, never what they had done.

Fix

Audit enabled on the five company shares (`Commun`, `Comptabilite`, `Direction`, `Projets`, `RH`): *Enable Logging*, watch list `INFRASEC\domain users`, empty ignore list (administrators included). The old share `partage`, forgotten in the first pass, was enabled on 26/10: the 6 shares show `Yes`.

Proof (25/10, 20:20–20:21 Paris time)

From `fedora`, account `k.haddad`: upload then deletion of `audit-test.txt` on `Projets`, attempt on `RH`. Read through the API (`midclt call audit.query`, filtered with `jq`):

UTC	Event	Object	Result
19:20:38	AUTHENTICATION	–	`NT_STATUS_WRONG_PASSWORD` (typo)
19:20:55	AUTHENTICATION / CONNECT	`10.10.10.30`	SUCCESS
19:20:55	CREATE / WRITE / CLOSE	`audit-test.txt` (11 bytes written)	SUCCESS
19:20:55	CREATE / **UNLINK** / CLOSE	`audit-test.txt`	SUCCESS
19:21:12	AUTHENTICATION / CONNECT / DISCONNECT	`10.10.10.30`	SUCCESS

The API enforces a row limit per query (`EINVAL` without `limit`): a protection against bulk extraction of the log.

Limit observed

The refusal to list `RH` is not recorded as a failure. The trace exists indirectly: `CONNECT` then `DISCONNECT` with `"service":"RH"`, and the session summary `create 0, read 0, write 0`. A logon of an account from another department on RH is itself a signal to watch.

Lesson

(1) "Audit enabled" means nothing until we have checked what is recorded. (2) An audit trail answers: who, what, when, from where. (3) When the interface filters badly, the API gives the same data.

◆ F-21 — SIEM logs: no retention period, and 9 days out of 10 never sealed

Date: 25-26/10/2026 · **Type:** finding (CP8), fixed (CP7/CP9) · **Severity:** medium
Asset: `wazuh-siem` (`10.10.10.40`, Wazuh 4.14.8, 40 GB disk, clock in UTC)

Measurement before deciding

Location	Volume	Role
`/var/ossec/logs/alerts`	115 MB	raw copy of alerts (evidence)
`/var/ossec/logs/archives`	20 KB	empty: `logall` disabled
indexer (`wazuh-alerts-4.x-*`)	11 indices, ~19,000 alerts, ~48 MB	searchable copy
disk `/`	22 GB out of 40 (60 %)	including 11 GB of CVE database (F-16)

Average volume: ~8 MB raw per day, ~113 KB compressed; ~4.4 MB per day in the indexer.

Finding 1: nothing is ever deleted

Neither Wazuh nor the indexer has a retention period. At 95 % disk, the indexer puts its indices in read-only mode: the SIEM goes blind.

Finding 2: logs are not sealed

Wazuh compresses and seals each log (`.sum` file) at midnight. Of the 10 finished days, only one was: the 23rd, the only night the lab stayed on. The lab is off at night, so the midnight rotation never runs. Without a seal, nothing proves a log was not changed afterwards.

Retention decision

- Searchable copy (indexer): **90 days**, ~400 MB.
- Sealed raw copy: **365 days**, ~100 MB compressed.
- Threshold order: Grafana alert at 80 % (F-16) **before** the indexer's first threshold (85 %) and its blocking (95 %).

Fix

1. ISM policy `infrasec-retention-90j`: deletion at 90 days, template for future indices, attached to the 11 existing indices (`updated_indices: 11, failures: false`). Calls made with the indexer's **admin certificate**, full TLS verification (the certificate only covers `127.0.0.1`).
2. Script `/usr/local/sbin/wazuh-sceller-journaux` (root:root, 0755): for each finished day, compression then SHA-256 hash in a `.sha256` file; deletion of copies older than 365 days; traces `journalctl -t wazuh-sceller`. Tested first on a dummy tree.
3. Hardened systemd service (`ProtectSystem=strict`, writes limited to `/var/ossec/logs/alerts`, `NoNewPrivileges`) and a daily timer at 00:30 UTC, `Persistent=true`.

Proof (25/10, 19:40 UTC)

- Preview: exactly the 18 expected files (days 03 to 24), current day excluded.
- Run: `status=0/SUCCESS`, 18 `scelle :` lines.
- `sha256sum -c *.sha256` → **18 × OK**; files `wazuh:wazuh`, mode `640`, original dates kept.

Proof of the catch-up (26/10)

SIEM off on the night of 25 to 26. At lab start (18:53 Paris time), last run at 17:53:18 UTC, and sealing of 25/10: `ossec-alerts-25.log.gz` (`135d0eb5…`) at 17:53:35, `ossec-alerts-25.json.gz` (`fc1fd2c9…`) at 17:53:36 UTC.

Known limit

The hashes are on the same machine as the logs: root on the SIEM could change both. For full evidential value, the hashes must be sent elsewhere.

Lesson

(1) A retention period is decided from measurements. (2) A "midnight" task does not exist on a machine that is off at night: `Persistent=true`. (3) An unsealed log proves nothing.

◆ F-22 — The SIEM installation secrets were lying in clear on the SIEM

Date: 25/10/2026 · **Type:** finding (CP8, found during F-21), fixed (CP9) · **Severity:** high
Assets: `wazuh-siem`, host `HV01`

Finding

In the `ais` account folder: `wazuh-install-files.tar` (root, 600, from 03/10), left by the installer. Contents (names only): `wazuh-passwords.txt` (clear-text passwords), the private keys of the server, the indexer, the dashboard, the admin certificate, and **`root-ca.key`**, private key of the authority that signed every SIEM certificate.

Why not simply delete it

The authority key is needed to renew a certificate or add a node. Destroying it would have created an availability problem; keeping it in clear, a confidentiality problem. Answer: keep it **encrypted, off the SIEM**.

Fix

1. Passwords read once and stored in the password manager.
2. AES-256 encryption (`gpg --symmetric --cipher-algo AES256`), passphrase in the manager.
3. Check: decryption gives back exactly the original (SHA-256 `84d479f9…` on both sides).
4. Copy to the host (`~/coffre`, folder 700, file 600); hash of the encrypted file identical on both sides (`a34d743c…`), decryption successful on the host.
5. Destruction on the SIEM: `shred -u` of the original then of the encrypted copy.

Incidents during the operation

- First decryption failed (passphrase mistyped): hash `e3b0c442…`, the hash of an **empty** input. Comparing hashes is what proves, not the absence of an error.
- The copy "to the host" was first started from the SIEM's SSH session: the SIEM copied the file to itself. Spotted at the `ais@wazuh-siem` prompt, checked, redone from the host.

Addendum (26/10)

The vault also holds the XML export of the pfSense configuration (`config-fw01.infrasec.lab-20261026212439.xml`, 600).

Still to do

Copy `~/coffre` to the encrypted external disk of the backup plan.

Lesson

(1) The post-install inventory is part of the installation. (2) An essential secret is encrypted and stored elsewhere. (3) Before every sensitive command, read the prompt.

◆ F-23 — The hypervisor was short of memory: 29 GiB allocated out of 30, the host was swapping

Date: 25/10/2026 · **Type:** finding (CP8, capacity measured before a new service), fixed (CP7) · **Severity:** medium
Asset: host `HV01` (Fedora, 30 GiB of RAM, 8 GiB of swap, 952 GB LUKS disk with 425 free)

Finding (21:09)

`free -h` : 26 GiB used out of 30, **4.0 GiB of swap used**, 4.0 GiB available. Allocated memory: DC 6 + TrueNAS 6 + SIEM 6 + fedora 6 + pfSense 4 + wg-client 1 = **29 GiB**.

Measurement per VM (`virsh dommemstat`)

VM	Allocated	Used (rss)	Free in the guest	Decision
pfSense	4.0	3.1	(no driver)	2 GB
DC	6.0	6.0	3.3	4 GB
TrueNAS	6.0	2.4	4.0	unchanged (ZFS cache)
fedora	6.0	3.4	2.2	unchanged
wazuh-siem	6.0	4.8	**0.9**	unchanged: the tightest
wg-client	1.0	0.5	0.5	unchanged

Fix

Ordered shutdown (`lab stop`), `virsh setmem` then `setmaxmem --config` , check with `dominfo` , ordered restart.

Proof (21:25)

	Before	After
Memory allocated to VMs	29 GiB	**25 GiB**
RAM used on the host	26 GiB	**22 GiB**
Available	4.0 GiB	**8.6 GiB**
Swap used	4.0 GiB	**1.4 GiB**

The Samba VM (1.5 GiB) now fits without starving the SIEM.

Lesson

(1) Capacity is measured before adding a service. (2) Reduce based on real usage, VM by VM. (3) Active swap on a hypervisor is a warning.

◆ F-24 — Passwords: no lockout in either domain, then a lockout with no alert

Date: 25-26/10/2026 · **Type:** finding (CP8), fixed (CP9) and detection scenario (CP10) · **Severity:** high
Assets: `Win-Server-DC` (`infrasec.local`), `lnx-dc01` (`infrasec.internal`), `wazuh-siem`
Matching technique: MITRE ATT&CK T1110 (*Brute Force*), including its slow form.

Finding 1: the ISSP was not enforced by the domains

Windows and Samba had the same defaults: 7 characters minimum, **no lockout threshold**, 42 days. The ISSP requires 14 characters (20 for privileged accounts). Existing accounts complied because the script had generated their passwords, not because the domain enforced it.

Fix 1 (26/10)

Snapshots `pre-politique-mdp-26oct` of both controllers. Same policy in both domains:

	Ordinary accounts	Administrators (PSO-Admins, Domain Admins)
Minimum length	14	20
Lockout	after 10 failures, 15 min	after 5 failures, 30 min
Lifetime	365 days	180 days

Windows group designated by its SID (`-512`). Checks: `Get-ADUserResultantPasswordPolicy adm.rj` → `PSO-Admins` (20, 5); `pso show-user administrator` on Samba → `PSO-Admins`.

Proof of the lockout (19:25 Paris time)

From `fedora`, 11 SMB logons with a wrong password for `k.haddad`: 10 × `NT_STATUS_LOGON_FAILURE`, then `NT_STATUS_ACCOUNT_LOCKED_OUT`. Event 4740 on the DC: `Caller Computer Name: FEDORA`.

Finding 2: the lockout itself raises no alert

SIEM (UTC): each failure as rule 60122 (level 5); 18:25:44, **60204** *Multiple Windows Logon Failures* (level 10); 18:25:48, **60115** *User account locked out* at **level 9**. Rule 60204 only fires for failures close together: a slow attacker still locks accounts, with no alert (denial of service).

Fix 2

Local rule **100320**, level **10**, child of 60115, MITRE T1110 (backup `.bak-20261026`, validated with `wazuh-analysisd -t`).

Proof with a slow attack (19:39–19:49)

10 failures counted between 18:40:56 and 18:49:09 UTC (about 37 s apart). **No 60204**; **100320, level 10, at 18:49:09.212 UTC**, at the moment of the lockout. Account unlocked afterwards (`LockedOut : False`, `badPwdCount : 0`).

Lesson

(1) A written policy is applied only if the system enforces it. (2) A lockout threshold creates a denial-of-service risk: the lockout itself must raise an alert. (3) Test the slow attack too.

◆ F-25 — The Samba controller had no firewall at all

Date: 26/10/2026 · **Type:** finding (CP8), fixed (CP9) · **Severity:** medium
Asset: `lnx-dc01` (`10.10.10.11`, Debian 13.7, Samba AD `infrasec.internal`)

Finding

`ufw` absent, `nft list ruleset` empty. `ss -tulpn`: SSH and every directory service listening on all interfaces, IPv4 and IPv6 — 53, 88, 464, 135, 137-139, 389, 445, 636, 3268, 3269, 49152-49154. Same defect as the SIEM (F-15).

Analysis of legitimate flows

Ports	Service	Decision
22/tcp	SSH	host `10.10.10.2` only
53, 88, 389, 464 (tcp and udp); 135, 445, 636, 3268, 3269 (tcp)	directory	LAN `10.10.10.0/24`
49152-65535/tcp	dynamic RPC	LAN
137, 138, 139	NetBIOS	closed

Fix

Return point: snapshot `post-politique-mdp-stable`. `ufw`: default deny inbound, logging `low`, four commented rules, checked with `ufw show added` before enabling (SSH rule first).

Proof (26/10, 19:59)

- From `fedora`: 22 and 139 **closed**; 389, 445, 88 **open**; DNS `lnx-dc01.infrasec.internal` → `10.10.10.11`.
- From the host: 22 **open**.

Lesson

(1) Every new machine comes in with its firewall. (2) Close what is not needed (NetBIOS).

◆ F-26 — Two machines ignore the hypervisor's shutdown request

Date: 26/10/2026 · **Type:** finding (CP8, revealed by the test of the `lab` script), fix applied (CP7) · **Severity:** medium
Assets: `Win-Server-DC`, `wg-client` (Fedora 44 Cloud Edition), host `HV01`

Finding

`sudo lab stop` (20:29-20:38): five machines stopped cleanly and in order. Two refusals, reported by the script with no forced stop:

- `wg-client` : `ÉCHEC … après 180 s` (failure after 180 s);
- `Win-Server-DC` : `ÉCHEC … après 300 s` (third refusal, see F-14), while no SSH session was open. `virsh qemu-agent-command … guest-ping` → `QEMU guest agent is not configured` on both: shutdown can only go through the emulated power button (ACPI).

Diagnosis

- **Win-Server-DC**: console = lock screen, no dialog box. Shutdown successful from Windows itself. Conclusion: a shutdown driven by the system works; only the ACPI signal is ignored. Hypothesis kept: an `Administrator` console session left open behind the lock screen (Windows then refuses a power-button shutdown).
- **wg-client**: console = `localhost login:` prompt, no open session, no SSH server. ACPI signal (`virsh shutdown`) then `KEY_POWER` key (`virsh send-key`): no reaction, still `running`. Slimmed-down Cloud image: no external shutdown signal is handled.

Immediate measure

`wg-client` : disk cache flushed (`virsh send-key … KEY_LEFTALT KEY_SYSRQ KEY_S`), then `virsh destroy`. Power cut justified and logged: a machine with no service or business data, disk synced, every clean-shutdown method tried first.

Fix

1. QEMU guest agent channel added to both definitions (`virt-xml … --add-device --channel unix,target.type=virtio,target.name=org.qemu.guest_agent.0`).
2. Windows: agent installed from `virtio-win.iso` (`E:\guest-agent\qemu-ga-x86_64.msi`, silent install) → service `QEMU-GA` `Running`, `Automatic`. `wg-client` : agent already present in the Fedora Cloud image.
3. `guest-ping` → `{"return":{}}` on both.
4. `lab` script (hash `98df9b18…`, previous copy kept): shutdown through the guest agent when it answers (`virsh shutdown --mode agent`), ACPI otherwise.

Proof (26/10, 21:25–21:26)

`sudo lab stop` : **7 machines out of 7 stopped cleanly, in 66 s, with no failure and no forced stop** — `wg-client` 5 s, `wazuh-siem` 5 s (ACPI), `fedora` 15 s, `truenas` 5 s, `lnx-dc01` 5 s, **`Win-Server-DC` 10 s** (against three refusals at 180-300 s), `pfsense-fw` 20 s (ACPI). The script chose the method by itself: agent for 5 machines, ACPI for the 2 that have none.

Lesson

(1) A script that forces nothing makes the machines that do not stop visible: its refusal is information. (2) A "clean" shutdown from the hypervisor assumes a channel the guest really listens to: check it, do not assume it. (3) A forced power cut is acceptable only as a last resort, justified and logged.

◆ PV-05 — INFRASEC company: directory, shares per department and access control (AGDLP)

Date: 25/10/2026 · **Skills:** CP9 (security policy applied: RBAC, least privilege, tiering), CP8 (measurement by test)
Assets: `Win-Server-DC` (`infrasec.local`), `truenas` (`10.10.10.20`, mirrored `tank` pool), test client `fedora` (`10.10.10.30`)

1. Directory

Idempotent PowerShell script `New-InfrasecCompany.ps1` (SHA-256 hash checked on arrival on the DC: `1E6E9C76…`, CSV `7228C38A…`), first run as a simulation (`-WhatIf`), preceded by the snapshot `pre-entreprise-ad`.

- 14 OUs, 27 groups: 7 `GG_` (6 departments + remote work), 10 `DL_SMB_<share>_RW/RO`, 8 `ROLE_` (ISSP RBAC matrix, art. 5.2); 10 computer objects.
- 12 accounts: 10 employees (random 24-character passwords, change forced at first logon, never displayed), `adm.rj` (separate admin account, 32 characters, the only member added to Domain Admins), `aud.externe` (disabled outside audit missions).
- Independent check after the run: 12 accounts, `aud.externe` `Enabled = False`, Domain Admins = `Administrator` + `adm.rj` (not `rj`), `DL_SMB_Projets_RW` = `GG_Consultants` + `GG_Commercial`, 10 computers.
- Detection: the SIEM received the 12 Windows **4720** events from `dc01` (Wazuh rule 60109, level 8, MITRE T1098), all between 15:49:26.931 and 15:49:28.270. Finding for CP10: level 8 is below the alert threshold (≥ 10).
- Password policy tested: a 7-character password is refused by the domain (`ADPasswordComplexityException`).

2. TrueNAS shares

TrueNAS joined to the domain (`HEALTHY`), the 10 groups `INFRASEC\dl_smb_*` visible (GID 100001120 → 100001129).

- Parent dataset `tank/entreprise`, not shared. **Finding fixed:** the SMB preset gave `INFRASEC\domain users` and `builtin_users` **Modify**, so all 12 domain accounts could write everywhere. ACL brought back to: `owner@` and administrators (Full Control), `domain users` with **Traverse, no inheritance** (pass through, not read).
- Five child datasets shared over SMB: Commun, Direction, Comptabilite, RH, Projets. ACL of each: `DL_SMB_<share>_RW` → Modify, `DL_SMB_<share>_RO` → read (Read Data, Read Attributes, Read Named Attributes, Read ACL, Execute, Synchronize), administrators → Full Control. No general access.
- The TrueNAS validator warns that the `DL_` groups cannot traverse the parent: it evaluates each group alone, ignoring `Domain Users`. The warning is understood; real access is proven by the test below.

3. Access test (25/10, 17:36–17:37, `smbclient` from `fedora`)

#	Account (department)	Share	Action	Expected	Got
1	k.haddad (Sales)	Projets	write	OK	OK (`k.haddad.txt`)
2	k.haddad (Sales)	RH	read	denied	`NT_STATUS_ACCESS_DENIED listing`
3	n.rousseau (HR)	RH	write	OK	OK (`rousseau.txt`)
4	c.morel (Management)	RH	read	OK	OK (sees `rousseau.txt`)
5	c.morel (Management)	RH	write	denied	`NT_STATUS_ACCESS_DENIED opening remote file`

#	Account (department)	Share	Action	Expected	Got
6	k.haddad (Sales)	Commun	write	OK	OK (`commun.txt`)

6 results out of 6 as expected, including 2 expected denials. A first try (`NT_STATUS_LOGON_FAILURE`) came from a password typo; it is not kept.

Lesson

(1) A preset is not a policy: the TrueNAS one opened the whole domain in write mode. (2) AGDLP separates who people are (`GG_`) from what they can do (`DL_`): a newcomer only needs a group membership, never an ACL. (3) Access control is proven by denials as much as by successes.

◆ PV-06 — Backup proven: restoring a file deleted by a user

Date: 25/10/2026 · **Skills:** CP7 (availability, backup), CP8 (measurement by test)
Assets: `truenas` (`tank/entreprise`, mirror), client `fedora`, account `k.haddad`

Set-up

Snapshot task on `tank/entreprise`, recursive, hourly, kept 2 weeks, empty snapshots disabled. Check on the command line: `zfs list -t snapshot -r tank/entreprise` → one `auto-2026-10-25_18-00` snapshot per dataset. TrueNAS clock checked (`date` / `date -u`).

Reading a false doubt

The interface said "last run: 1 hour ago" while the only snapshot was from 18:00: the task ran at 19:00 without creating anything, since nothing had changed.

Scenario: a user deletes a file by mistake

1. 20:04:06, from `fedora`, as `k.haddad` : `del commun.txt` → file gone.
2. On TrueNAS: file intact in `.zfs/snapshot/auto-2026-10-25_18-00/`; copied back to the share.
3. 20:05, `k.haddad` reads the file again (`test`, 5 bytes). Restore time: about **1 minute**, with no loss.

Defect observed

The copy restores content and rights, **not the owner** (`root` instead of `INFRASEC\k.haddad`). Fix: `chown`. Improvement: Windows "previous versions" over SMB.

An unexplained change, solved by the logs

The file had a modification time of 19:59:34. SMB audit: between 17:37:54 and 20:04:06, only authentication **failures** by `k.haddad`. Sudo log: `truenas_admin` ran the restore copy at 19:59:34, before the deletion had succeeded. Traced to the second by two independent logs.

Preparation incident

Three refused logons (`NT_STATUS_LOGON_FAILURE`): password reset by mistake earlier. Stopped before lockout, `badPwdCount` checked, masked reset.

Lesson

(1) A backup exists only once restored, from the user's point of view. (2) Restoring also means restoring metadata.

◆ PV-07 — Administering the domain controller over SSH, limited to the hypervisor

Date: 25-26/10/2026 · **Skills:** CP9, answer to the jury's remark on the use of the graphical interface
Asset: `Win-Server-DC` (`dc01`, Windows Server 2025, `10.10.10.10`)

Need

The VM's graphical console does not allow copy-paste and alters typing (commas turned into dots), a source of repeated errors. Reopening the DC's browser was ruled out: it would have undone F-17.

Implementation

- OpenSSH Server, already present in Windows Server 2025: `Start-Service sshd`, automatic start.
- Rule `OpenSSH-Server-In-TCP` restricted to the source `10.10.10.2`.
- PowerShell set as the default SSH shell (`HKLM:\SOFTWARE\OpenSSH\DefaultShell`).

Defect found during the test

`Connection timed out`: the rule was attached to the **Private** profile; a DC is in the **Domain** profile. Fix: `-Profile Domain`. A *timeout* means a firewall that drops; a refusal answers `Connection refused`.

Proof (26/10)

- From the host: `ssh -l 'INFRASEC\Administrator' 10.10.10.10` → prompt `infrasec\administrator@DC01`.
- Port 22 **open** from the host, **closed** from `fedora`.
- A first test run by mistake inside the DC's SSH session showed "FERME" (closed): Windows has no `bash`, so the `|| echo FERME` branch ran. That test could not fail; not kept.

Hardening (26/10, 21:31–21:43): `adm.rj` with a key only

- ED25519 key generated on the host (`~/.ssh/id_ed25519_admrj`, 100 derivation rounds, protected by a passphrase); fingerprint `SHA256:… (masquée / redacted)`.
- Public key in `C:\ProgramData\ssh\administrators_authorized_keys` (the file OpenSSH reads for members of Administrators), rights reduced to `Administrators` and `SYSTEM` (`icacls /inheritance:r`).
- `sshd_config` (backup `.bak-20261026`): `PasswordAuthentication no`, `AllowUsers infrasec\adm.rj`; syntax validated with `sshd -t` before restart; `Administrator` session kept open as a fallback during the change.
- Tests from the host: `adm.rj` with the key → `infrasec\adm.rj`, member of `Domain Admins` (accepted); `adm.rj` with a password → `Permission denied`; `Administrator` → `Permission denied (publickey,keyboard-interactive)`, with no password prompt. The built-in `Administrator` account becomes an emergency account again, reachable only from the console (tiering, F-17).

Lesson

(1) A tool constraint does not justify undoing a security measure. (2) On Windows, a firewall rule applies to a network profile.

◆ PV-08 — Linux continuity domain `infrasec.internal`: company, detection and cross resolution

Date: 25-26/10/2026 · **Skills:** CP7 (continuity), CP9 (policy applied), CP8 (measurement by test)
Assets: `lnx-dc01` (`10.10.10.11` , Debian 13.7, Samba 4.22), `Win-Server-DC` , `pfsense-fw` , `wazuh-siem`

1. Wazuh agent

Official signed repository (GPG key), version **4.14.8-1, identical to the manager** (an agent newer than the manager is refused), held with `apt-mark hold` . Enrolment: ID 003 `Pending` , then `Active` 30 s later (first message received on 1514). Both domain controllers are now monitored.

2. INFRASEC company

Script `infrasec-samba-societe.sh` (bash, `samba-tool`), equivalent of `New-InfrasecCompany.ps1` , from the **same** `employes.csv` . Integrity checked on arrival: CSV `7228c38a…` (identical to the Windows DC's), script `e120caac…` . Random passwords (`--random-password`), never typed or displayed; change forced at first logon.

- Simulation (`--dry-run`) before the run.
- Independent check: 15 accounts (12 from the company + `Administrator` , `Guest` , `krbtgt`); Domain Admins = `Administrator` and `adm.rj` ; `aud.externe` `userAccountControl: 514` (disabled); `GG_Consultants` = `t.girard` , `i.lambert` , `h.mercier` .
- **Idempotence proven**: second run → a single `=== terminé` line, nothing recreated.
- Defect fixed before the run: `[[ … ]] && action` tests at the end of a loop would have stopped the script under `set -e` (`pipefail`) at the first employee not working remotely; replaced by `if` statements.

3. DNS resolution between the two domains

Before: `dig @10.10.10.10 lnx-dc01.infrasec.internal` → nothing; from `lnx-dc01` , `_ldap._tcp.infrasec.local has no SRV record` .

- Windows → Samba: conditional forwarder zone `infrasec.internal` → `10.10.10.11` on the DC. First test in `SERVER FAILURE` ; diagnosis link by link: Samba queried directly from the DC → answers `10.10.10.11` ; port 53 → `TcpTestSucceeded : True` ; DNS cache flushed → the forwarder answers. Cause: a failure cached at the very second the zone was created.
- Samba → Windows: domain override on pfSense (*Domain Override* `infrasec.local` → `10.10.10.10`) rather than in Samba: Samba already sends everything it does not know to pfSense, so the rule is unique for the whole lab. After (26/10, 20:16-20:22):
- from the host, through the Windows DC: `lnx-dc01.infrasec.internal` → `10.10.10.11` ;
- from `lnx-dc01` : `dc01.infrasec.local has address 10.10.10.10` ; `_ldap._tcp.infrasec.local has SRV record 0 100 389 dc01.infrasec.local.`

Lesson

(1) One source file, checked by its hash, guarantees that two directories describe the same company. (2) An administration script is replayed: idempotence is proven by running it again. (3) Facing an outage, test each link separately before blaming a component.

◆ PV-09 — Lab backup: `lab-backup`, immutable local level

Date: 26/10/2026 · **Skills:** CP7 (backup, continuity), CP9 (protecting backups)
Assets: host `HV01` (LUKS + BTRFS disk), 7 VMs, vault `~/coffre`

Need and constraint

No full backup of the lab existed apart from the VMs' internal snapshots. No external disk available. Repartitioning the host disk (LUKS + BTRFS) was ruled out: shrinking the encrypted partition is the riskiest possible operation on that disk.

Preparation: clean-up and inventory

- `/vm/iso` : 12 useless files deleted (Windows client ISO, duplicates, CoreOS, Parrot, Cloud image), exact names, no wildcard, after checking the disks attached to each VM (`virsh domblklist`): 74 GB → 19 GB, 7 images kept (one per VM to rebuild, plus `virtio-win`).
- Discovery: `wg-client` is stored outside `/vm` , in `/var/lib/libvirt/images` , and depends on a base image (`wg-client-base.qcow2` , `qemu-img info -U`). Without this inventory, the backup would have missed it or made it unusable.
- `/vm` is a BTRFS subvolume (ID 259); `/vm/images` has no copy-on-write (attribute `C`), which does not prevent snapshots.

Design

Script `/usr/local/bin/lab-backup` (root:root 0755, hash `5ed4dcb1…`):

1. ordered shutdown (`lab stop`); abort and restart if a VM refuses to stop;
2. **read-only** BTRFS snapshot of the `/vm` subvolume;
3. annex subvolume: `wg-client` and its base image, definitions of the 7 VMs and lists of their snapshots, vault (encrypted secrets, pfSense export), `lab` and `lab-backup` scripts; then switched to **read-only**;
4. SHA-256 hash of each file; repository `/srv/lab-backup` reserved to root (700);
5. ordered restart (`lab start`); retention: 4 backups. Command `export /dev/sdX` ready: copy of the latest backup to a LUKS2-encrypted USB disk, refusing any non-USB disk.

Proof (26/10, 21:56–22:05)

- 7 VMs stopped in 67 s, with no failure (guest agent for 5, ACPI for 2).
- Hashes: 20 annex files + 9 VM disks (21:57 → 22:02).
- Ordered restart, DNS of both controllers working; backup `20261026-2156` finished at 22:04:58. Total lab downtime: 9 minutes.

Checks afterwards (22:06–22:12)

- `lab-backup list` → `20261026-2156 disques:ro=true annexe:ro=true` : both parts are immutable.
- `lab-backup verify` → `intégrité : OK` (integrity OK; full recomputation of the hashes in 5 min 30 s).
- Write test by root: `touch /srv/lab-backup/20261026-2156-vm/test` → `Read-only file system` .

Stated limit

Local level only: protects against mistakes, corruption and ransomware (read-only), not against failure or theft of the host disk. The external level (`lab-backup export`) waits for a USB disk.

Lesson

(1) A backup starts with an inventory: what we do not know exists, we do not back up. (2) A backup that can be modified can be encrypted by ransomware: read-only. (3) State exactly what a backup protects against, and what it does not.

◆ PROC-01 — Procedure for migrating the directory to `infrasec.internal`

Trigger: end of the Windows Server 2025 evaluation (around 27/03/2027; one last rearm possible, deadline around 09/2027 at the latest), or permanent loss of the `dc01` controller.
Goal: employees get their accounts, groups and share access back on the Samba domain, with no loss of data or traceability.
Starting state (26/10/2026): domain `infrasec.internal` in service, same company (same `employes.csv`, hash `7228c38a…`), same password policy, Wazuh agent active, cross DNS resolution in place (PV-08).

Risk register

Risk	Likelihood	Impact	Measure
Windows evaluation expires: hourly shutdowns, then directory unavailable	certain (known date)	high: authentication, shares, GPO	continuity domain ready; switch planned at least 1 month ahead
The two directories drift apart (accounts created on one side only)	medium	medium	a single source: `employes.csv`, replayed on both sides (idempotent scripts)
GPOs lost in the switch (Samba does not take over Windows GPOs)	certain	medium	critical GPOs listed (F-17 browsing, password policy) and recreated on Samba or enforced by the firewall
TrueNAS share rights tied to the `INFRASEC` SIDs	certain	high	join TrueNAS to the new domain and reapply the ACLs with `DL_` groups (AGDLP: only the group → ACL link changes)

Steps

1. **D-30 — Prepare.** Snapshots of every VM; export of the pfSense configuration; `samba-tool dbcheck` with no error; review of the list of Windows GPOs to reproduce.
2. **D-30 — Align the directories.** Replay `infrasec-samba-societe.sh employes.csv` (idempotent); compare both lists of accounts and group members (`Get-ADUser` / `samba-tool user list`); differences = 0.
3. **D-15 — Create the share groups.** Create the 10 `DL_SMB_<share>_RW/RO` in Samba with the same `GG_` members as on Windows (PV-05 matrix).
4. **D-7 — Switch TrueNAS.** Leave the `INFRASEC` domain, join `INFRALNX`; reapply the `DL_` ACLs (Modify / read) on each share; check inheritance from `tank/entreprise`.
5. **D-7 — Acceptance.** Replay the PV-05 access test (6 cases, including 2 denials) with the new domain's accounts; replay the F-24 lockout scenario; check that events reach Wazuh (agent 003).
6. **D0 — Switch the services.** DNS of LAN machines to `10.10.10.11`; employee passwords initialised (`samba-tool user setpassword`, masked input) and change forced; `dc01` stopped but kept (not deleted) for 30 days.
7. **D+30 — Close.** Remove the `infrasec.local` override from pfSense and the conditional zone; archive the last `dc01` snapshot; update the ISSP (reference directory) and the architecture sheets.

Roll-back: until D+30, `dc01` can be restarted; restore TrueNAS to the D-7 snapshot and point the LAN DNS back to `10.10.10.10`.

Success criterion: the 6 cases of PV-05 give the expected result on the new domain, and a failed logon there raises the matching Wazuh alert.

Annex Q · Operations scripts lab and lab-backup

lab

```
#!/usr/bin/env bash
# lab — démarrage et arrêt ordonnés du labo INFRASEC (hôte HV01)
#   sudo lab start   : pfSense → attente du firewall → DC Windows → attente de son DNS
#                      → DC Samba → attente de son DNS → TrueNAS, fedora, wazuh-siem, wg-client
#   sudo lab stop    : arrêt propre (ACPI) dans l'ordre inverse, sans coupure forcée
#   sudo lab status  : état de chaque VM
# Chaque étape est tracée dans le journal système : journalctl -t lab
# Origine : F-14 (flux de vulnérabilités en échec quand le SIEM démarre avant le DNS)
#           et INC-11 (fichier PID resté après un arrêt non propre).
# 26/10 : ajout de lnx-dc01 (PV-08) ; attente d'arrêt du DC Windows portée à 300 s
#             (refus d'arrêt en 180 s constaté deux fois, F-14).
# 26/10 : arrêt par l'agent invité QEMU quand il répond, ACPI sinon (F-26).
set -euo pipefail

ORDER=(pfsense-fw Win-Server-DC lnx-dc01 truenas fedora wazuh-siem wg-client)
FW=10.10.10.254          # pfSense, interface LAN
DC=10.10.10.10           # Win-Server-DC, DNS de infrasec.local
DOMAIN=infrasec.local
LDC=10.10.10.11          # lnx-dc01, DNS de infrasec.internal
LDOMAIN=infrasec.internal

log()       { printf '%s  %s\n' "$(date '+%F %T')" "$*"; logger -t lab -- "$*"; }
state()     { virsh domstate "$1" 2>/dev/null | head -1; }
port_open() { timeout 2 bash -c "</dev/tcp/$1/$2" 2>/dev/null; }
# Vraie réponse DNS exigée : en cas d'échec, dig écrit aussi sur sa sortie (« connection timed out »),
# donc une sortie non vide ne prouve rien. On exige l'en-tête NOERROR et au moins un enregistrement.
dns_ok() {   # dns_ok <serveur> <domaine>
    command -v dig >/dev/null 2>&1 || { echo "dig absent : sudo dnf install bind-utils" >&2; return 1; }
    local out
    out=$(dig +time=2 +tries=1 @"$1" "$2" SOA 2>/dev/null) || return 1
    grep -q 'status: NOERROR' <<<"$out" && grep -q 'ANSWER: [1-9]' <<<"$out"
}
is_off()    { [[ "$(state "$1")" == "shut off" ]]; }

# wait_for <description> <délai max en s> <commande…> : réessaie toutes les 5 s
wait_for() {
    local what=$1 max=$2 t=0
    shift 2
    until "$@"; do
        if (( t >= max )); then log "ÉCHEC : $what après ${max} s"; return 1; fi
        sleep 5; t=$((t + 5))
    done
    log "OK : $what (${t} s)"
}

start_vm() {
    if [[ "$(state "$1")" == running ]]; then log "$1 déjà en marche"
    else virsh start "$1" >/dev/null && log "démarrage de $1"; fi
}

[[ $EUID -eq 0 ]] || { echo "À lancer avec sudo : sudo lab ${1:-status}"; exit 1; }

case "${1:-}" in
start)
    log "=== démarrage ordonné du labo"
    start_vm pfsense-fw
    wait_for "pfSense joignable ($FW:443)" 180 port_open "$FW" 443 || exit 1
    start_vm Win-Server-DC
    wait_for "DNS du DC Windows opérationnel ($DC, $DOMAIN)" 300 dns_ok "$DC" "$DOMAIN" || exit 1
    start_vm lnx-dc01
    wait_for "DNS du DC Samba opérationnel ($LDC, $LDOMAIN)" 180 dns_ok "$LDC" "$LDOMAIN" \
        || log "ATTENTION : DC Samba sans réponse DNS ; le reste du labo démarre quand même"
```

```
    for vm in truenas fedora wazuh-siem wg-client; do start_vm "$vm"; sleep 10; done
    log "=== labo démarré dans l'ordre"
    ;;
stop)
    log "=== arrêt ordonné du labo"
    for (( i = ${#ORDER[@]} - 1; i >= 0; i-- )); do
        vm=${ORDER[i]}
        [[ "$(state "$vm")" == running ]] || continue
        delai=180
        if [[ $vm == Win-Server-DC ]]; then delai=300; fi
        # Arrêt par l'agent invité si présent (demande au système lui-même), sinon bouton ACPI (F-26)
        if virsh qemu-agent-command "$vm" '{"execute":"guest-ping"}' >/dev/null 2>&1; then
            virsh shutdown "$vm" --mode agent >/dev/null && log "arrêt propre demandé par l'agent invité
: $vm"
        else
            virsh shutdown "$vm" --mode acpi >/dev/null && log "arrêt propre demandé par ACPI : $vm"
        fi
        wait_for "$vm arrêtée" "$delai" is_off "$vm" \
            || log "ATTENTION : $vm ne s'arrête pas ; vérifier sa console (aucune coupure forcée)"
    done
    log "=== labo arrêté"
    ;;
status)
    for vm in "${ORDER[@]}"; do printf '%-15s %s\n' "$vm" "$(state "$vm")"; done
    ;;
*)
    echo "Usage : sudo lab start | stop | status"; exit 2
    ;;
esac
```

lab-backup

```
#!/usr/bin/env bash
# lab-backup — sauvegarde du labo INFRASEC (hôte HV01)
#   sudo lab-backup local          : arrêt ordonné → instantané BTRFS en LECTURE SEULE de /vm
#                                    + wg-client, définitions des VM, coffre → redémarrage
#   sudo lab-backup list           : sauvegardes locales disponibles
#   sudo lab-backup verify         : contrôle les empreintes de la dernière sauvegarde locale
#   sudo lab-backup export /dev/sdX : copie la dernière sauvegarde sur un disque USB chiffré (LUKS)
# Niveau 1 (local) : protège contre fausse manipulation, corruption, rançongiciel (lecture seule, root
700).
# Ne protège PAS contre la panne ou le vol du disque de l'hôte : c'est le rôle de « export ».
# Traces : journalctl -t lab-backup
set -euo pipefail
REPO=/srv/lab-backup          # sous-volume BTRFS dédié, root:root 700
GARDER=4                      # nombre de sauvegardes locales conservées
WG=(/var/lib/libvirt/images/wg-client.qcow2 /var/lib/libvirt/images/wg-client-base.qcow2)
COFFRE=/home/TENET/coffre
VMS=(pfsense-fw Win-Server-DC lnx-dc01 truenas fedora wazuh-siem wg-client)
NAME=labbackup; MNT=/mnt/$NAME

log() { printf '%s  %s\n' "$(date '+%F %T')" "$*"; logger -t lab-backup -- "$*"; }
die() { log "ERREUR : $*"; exit 1; }
[[ $EUID -eq 0 ]] || die "à lancer avec sudo"

init_repo() {
    if ! btrfs subvolume show "$REPO" >/dev/null 2>&1; then
        btrfs subvolume create "$REPO" >/dev/null; chown root:root "$REPO"; chmod 700 "$REPO"
        log "dépôt créé : $REPO (sous-volume BTRFS, root 700)"
    fi
}
last_backup() { ls -1d "$REPO"/20* 2>/dev/null | grep -v -- '-vm$' | tail -1; }

case ${1:-} in
local)
    init_repo
    d=$(date +%Y%m%d-%H%M); dest=$REPO/$d
```

```
    log "=== sauvegarde locale $d"
    lab stop
    for vm in "${VMS[@]}"; do
        if [[ $(virsh domstate "$vm") != "shut off" ]]; then lab start; die "$vm n'est pas arrêtée :
sauvegarde annulée, labo relancé"; fi
    done
    # 1. disques des VM : instantané BTRFS en lecture seule du sous-volume /vm
    btrfs subvolume snapshot -r /vm "$dest-vm" >/dev/null
    # 2. le reste dans un sous-volume annexe : wg-client (hors /vm), définitions, coffre, scripts
    btrfs subvolume create "$dest" >/dev/null
    mkdir -p "$dest"/{wg-client,xml,coffre}
    cp --reflink=auto --sparse=always "${WG[@]}" "$dest/wg-client/"
    for vm in "${VMS[@]}"; do
        virsh dumpxml --security-info "$vm" > "$dest/xml/$vm.xml"
        virsh snapshot-list "$vm" --name > "$dest/xml/$vm.snapshots.txt"
    done
    cp -a "$COFFRE"/. "$dest/coffre/"
    cp -a /usr/local/bin/lab /usr/local/bin/lab-backup "$dest/"
    ( cd "$dest" && find . -type f ! -name 'SHA256SUMS*' -print0 | sort -z | xargs -0 sha256sum >
SHA256SUMS )
    ( cd "$dest-vm/images" && sha256sum ./*.qcow2 > "$dest/SHA256SUMS-vm" )
    chmod -R go-rwx "$dest"
    btrfs property set -ts "$dest" ro true
    log "empreintes : $(wc -l < "$dest/SHA256SUMS") fichiers + $(wc -l < "$dest/SHA256SUMS-vm") disques
de VM"
    lab start
    # rétention : on garde les $GARDER plus récentes
    mapfile -t old < <(ls -1d "$REPO"/20*-vm 2>/dev/null | head -n -"$GARDER")
    for v in "${old[@]}"; do
        b=${v%-vm}
        btrfs subvolume delete "$v" >/dev/null
        btrfs property set -ts "$b" ro false; btrfs subvolume delete "$b" >/dev/null
        log "rétention : $(basename "$b") supprimée"
    done
    log "=== sauvegarde locale terminée : $d"
    ;;
list)
    for v in "$REPO"/20*-vm; do
        if [[ -e $v ]]; then echo "$(basename "${v%-vm}")  disques:$(btrfs property get -ts "$v" ro)
annexe:$(btrfs property get -ts "${v%-vm}" ro)"; fi
    done
    ;;
verify)
    b=$(last_backup); [[ -n $b ]] || die "aucune sauvegarde"
    log "vérification de $(basename "$b")"
    ( cd "$b" && sha256sum --quiet -c SHA256SUMS ) || die "annexe : empreinte incorrecte"
    ( cd "$b-vm/images" && sha256sum --quiet -c "$b/SHA256SUMS-vm" ) || die "disques : empreinte
incorrecte"
    log "intégrité : OK"
    ;;
export)
    dev=${2:-}; [[ -b $dev ]] || die "périphérique absent : ${dev:-?}"
    [[ $(lsblk -dno TRAN "$dev") == usb ]] || die "$dev n'est pas un disque USB : refus"
    b=$(last_backup); [[ -n $b ]] || die "aucune sauvegarde locale"
    if ! cryptsetup isLuks "$dev"; then
        lsblk -o NAME,SIZE,MODEL,TRAN "$dev"
        read -rp "TOUT le contenu de $dev sera effacé. Taper EFFACER : " ok; [[ $ok == EFFACER ]] || die
"annulé"
        cryptsetup luksFormat --type luks2 "$dev"; cryptsetup open "$dev" "$NAME"
        mkfs.ext4 -qL labbackup /dev/mapper/$NAME; cryptsetup close "$NAME"
    fi
    cryptsetup open "$dev" "$NAME"; mkdir -p "$MNT"; mount /dev/mapper/$NAME "$MNT"
    trap 'sync; umount "$MNT"; cryptsetup close "$NAME"; log "support refermé"' EXIT
    out=$MNT/$(basename "$b"); mkdir -p "$out/vm"
    cp -a "$b"/. "$out/"; cp --sparse=always "$b-vm/images"/*.qcow2 "$out/vm/"
    ( cd "$out/vm" && sha256sum --quiet -c "$out/SHA256SUMS-vm" ) && log "export vérifié : $out"
    ;;
```

```
  *) echo "Usage : sudo lab-backup local | list | verify | export /dev/sdX"; exit 2 ;;
  esac
```

Annex R · Integrity register (SHA-256)

SHA-256 hash of every source item on 26/10/2026: operations scripts, company files and sheets. A different hash means a modified item.

Item	SHA-256
01_entreprise_AD/New-InfrasecCompany.ps1	14a369993eb6cda756af172da2860a5b0d05f990ad25cb9f974c3672ebb96949
01_entreprise_AD/employes.csv	7228c38ac738ef14d5d02374da9a5f7da83b79c9ed357bc2e1e820e13831ea8e
01_entreprise_AD/infrasec-samba-societe.sh	e120caacd942d3d69aa37ad18486159659381ddf994fe24eda1d0726b74e695d
03_scripts/lab	98df9b18610bc695d17f93a04e09f6b3014fc12fab54a76e7b7f26f4660802e6
03_scripts/lab-backup	5ed4dcb1d3c9758e8ec85144e90da3963298137f37a524ccc7c2dccf5aa836de
02_incidents/ARCH_Fiches-machines.md	094164eaab375c582db2bd6d8d338a457b68cf6a7cefe5bdd702872e5e2a8ec7
02_incidents/F-13_Hote-contournement-pfSense.md	6915b02b1312ea8cb7424f73309b84ffca4c61578e80aacc0007fa3db638009b
02_incidents/F-14_Flux-vulnerabilites-ordre-demarrage.md	29aaf12e1214671fc35d1d984e83bf70cd5691dde10531edbf3b5d21aa08f27f
02_incidents/F-15_SIEM-sans-firewall.md	3ca7cd0d75e4159f4c6dec2c99e63f67ceb91a6fb9cb542251215f84d2155aec
02_incidents/F-16_Disque-SIEM-non-supervise.md	0df7605e3464059a49f6e4503a158d6486c33b2ab4d323ac14746081778a07b8
02_incidents/F-17_Navigation-sur-le-DC.md	a166308cdb1a027f510337a6d9e3ae0cdf54fc5574129ed0d3d4ddc47674581c
02_incidents/F-18_Arret-agent-non-alerte.md	7dfac99f884c1e2dea91d05a96cb4540fea47d1ce7639c8455f926d0532c74d3
02_incidents/F-19_Persistance-dossier-demarrage.md	3dd5464d8cb89c88bc8e77a249fc8261d55f6dc3bec2f42be230c699d506bec2
02_incidents/F-20_Audit-SMB-fichiers.md	04536ca0e5f5bc6cfe8009d0d3db5c76cc50aad8acd8b2b1524a2b92cd71f700
02_incidents/F-21_Retention-et-scellement-journaux.md	6a2449f31b0e14af712c287920a3b29970a860ed207e3bd4821b7bdff3a2a5d3
02_incidents/F-22_Secrets-installation-SIEM.md	4dc2880179b475a653b5e1975e12684e6ecd90e98400e02e9f51a0c900ba24c4
02_incidents/F-23_Capacite-memoire-hyperviseur.md	b8e936a9c69b2d94146dc6a4b12f68accb35eef00e8dfe4284b4e4d7414b2025
02_incidents/F-24_Verrouillage-sans-alerte.md	878095c29253b4f85f5ef39b4a7d10fbbef7fd77a6b574b5b7bd827132f833ac

Item	SHA-256
02_incidents/F-25_Samba-sans-pare-feu.md	f0b1c8aeeedff552fb2b0ffe0b297f1e66d19f3e6f1871e90490ca56647ebb75
02_incidents/F-26_Arret-ACPI-ignore.md	5ca21bd36ffc512988b3d4f914527ed44f1ad3680e63bdaa8a19548cbae3e04c
02_incidents/INC-08_Cockpit-hors-reseau.md	34a6d9593622a0fbabf5e82abf6272f0041c5cf6c3262f1718b3bef11a06c19f
02_incidents/INC-09_Zabbix-redemarrage.md	87956d071897da64484c5e54fa26c94be88b1f3b15369c7cd66e8454e7620363
02_incidents/INC-10_Adresse-hote-perdue.md	debaed39bbdc2056cfcd282446e2fa9fa4fa73e167d8778e786f75f6187cd9e6
02_incidents/INC-11_SIEM-aveugle.md	e3c09cc08329744ee4ebe5d8e9a3a7dd180c5c76e9daeaafb55006f1a9574249
02_incidents/PROC-01_Migration-annuaire.md	6a65d5916072ea275d4ae92935e41a2dc8f5376edf787c7f937f2a6ddb9042de
02_incidents/PV-05_Entreprise-AD-Partages.md	8b1d328cf1e731e2b457850a3e67b3e42cf894daf72439fe7c971b9eebfcdb45
02_incidents/PV-06_Restauration-instantane.md	b1c7ae4eec39815112e01042f10aee5264c44bd8c1ea671bd7de7429dd1e3024
02_incidents/PV-07_SSH-administration-DC.md	730449f11e4fcb639b7381a19c5136eed723c306786bd887fad4d1e797181310
02_incidents/PV-08_Domaine-Samba-continuite.md	ce48c1488f09e14f892deeb65be264bfe3e7e8ee484f5e624e1a6b5b0fef8668
02_incidents/PV-09_Sauvegarde-locale-lab-backup.md	916b107f4299730203152f5e8a8851aaf48ee59663efdfb372a2908bd1b5827b

Annex S · Build commands, A to Z

This booklet gathers the commands that built the lab, in the order I ran them, from the host to the last service. The jury advised me to bring them together: they let another administrator rebuild the infrastructure without having followed the project. Steps done in a web interface are given as menu paths.

Where to type. Each block names the machine: **HV01** (hypervisor terminal), **pfSense** (web interface or console, option 8), **DC** (administrator PowerShell, over SSH from HV01), **lnx-dc01**, **TrueNAS** (System → Shell), **fedora** (`ssh ais@10.10.10.30`), **SIEM** (`ssh ais@10.10.10.40`), **wg-client** (Cockpit serial console).

Three rules kept throughout. A snapshot before every change. No secret in a command or a file: every sensitive input is masked (`Read-Host -AsSecureString` , interactive prompts). A word in angle brackets (`<vm>` , `<UUID>`) is to be replaced.

A · Host HV01: packages, services, storage

HV01 — virtualisation, container and tooling packages:

```
sudo dnf upgrade --refresh -y
sudo dnf install -y qemu-kvm libvirt libvirt-daemon-config-network virt-install \
  edk2-ovmf swtpm libosinfo guestfs-tools \
  cockpit cockpit-machines cockpit-podman cockpit-storaged cockpit-selinux \
  podman buildah skopeo policycoreutils-python-utils setroubleshoot-server \
  snapper btrfs-progs wireguard-tools nmap tcpdump bind-utils
```

HV01 — modular libvirt daemons, Cockpit, firewall:

```
for d in virtqemud virtnetworkd virtstoraged virtinterfaced virtnodedevd; do
  sudo systemctl enable --now ${d}.socket
done
sudo systemctl enable --now virtlogd.socket cockpit.socket firewalld
sudo usermod -aG libvirt,kvm "$USER"
```

HV01 — BTRFS subvolumes without copy-on-write for VM disks and container layers:

```
sudo btrfs subvolume create /vm
sudo btrfs subvolume create /var/lib/containers
sudo chattr +C /vm /var/lib/containers
lsattr -d /vm /var/lib/containers            # attribute C expected
# /etc/fstab
# UUID=<UUID>  /vm                btrfs  subvol=vm,nodatacow,noatime 0 0
# UUID=<UUID>  /var/lib/containers  btrfs  subvol=var/lib/containers,nodatacow,noatime 0 0
sudo systemctl daemon-reload && sudo mount -a && findmnt -t btrfs
```

HV01 — SELinux (never disabled) and the `tenet` storage pool:

```
sudo mkdir -p /vm/images /vm/iso
sudo semanage fcontext -a -t virt_image_t '/vm/images(/.*)?'
sudo restorecon -Rv /vm/images
sudo chmod 711 /vm/images
ls -dZ /vm/images                            # system_u:object_r:virt_image_t:s0
sudo virsh pool-define-as tenet dir --target /vm/images
sudo virsh pool-build tenet && sudo virsh pool-start tenet && sudo virsh pool-autostart tenet
```

HV01 — host snapshots with Snapper:

```
sudo snapper -c root create-config /
sudo snapper -c root set-config NUMBER_LIMIT=10 NUMBER_LIMIT_IMPORTANT=5
sudo systemctl enable --now snapper-timeline.timer snapper-cleanup.timer
sudo snapper -c root create -d "POST-SOCLE-FEDORA-TENET-STABLE"
```

◆ B · Host HV01: networks and filtering

HV01 — `default` NAT network (pfSense WAN) and isolated bridge `br-tenet` (LAN), declared in NetworkManager so they survive any reload (INC-10):

```
sudo virsh net-start default && sudo virsh net-autostart default
sudo nmcli con add type bridge ifname br-tenet con-name br-tenet \
  ipv4.method manual ipv4.addresses 10.10.10.2/24 ipv4.never-default yes ipv6.method disabled
cat > tenet.xml <<'EOF'
<network><name>tenet</name><forward mode='bridge'/><bridge name='br-tenet'/></network>
EOF
sudo virsh net-define tenet.xml && sudo virsh net-start tenet && sudo virsh net-autostart tenet
```

HV01 — dedicated firewalld zone for the bridge, with no service and no forwarding (F-13):

```
sudo snapper -c root create -d "PRE-F13-ZONE-LAB"
sudo firewall-cmd --permanent --new-zone=lab-tenet
sudo firewall-cmd --permanent --zone=lab-tenet --remove-forward
sudo firewall-cmd --reload
sudo nmcli con mod br-tenet connection.zone lab-tenet
sudo nmcli dev reapply br-tenet
sudo firewall-cmd --get-active-zones
```

HV01 — Cockpit listens everywhere, access is filtered by the firewall (INC-08):

```
sudo systemctl revert cockpit.socket
sudo systemctl daemon-reload && sudo systemctl restart cockpit.socket
sudo firewall-cmd --permanent --zone=public --remove-service=cockpit
sudo firewall-cmd --permanent --zone=public \
  --add-rich-rule='rule family="ipv4" source address="192.168.1.0/24" service name="cockpit" accept'
sudo firewall-cmd --reload
```

HV01 — publishing the WireGuard tunnel to the pfSense WAN:

```
sudo firewall-cmd --permanent --add-masquerade
sudo firewall-cmd --permanent --zone=libvirt --add-masquerade
sudo firewall-cmd --permanent \
  --add-forward-port=port=51820:proto=udp:toaddr=192.168.122.95:toport=51820
sudo firewall-cmd --reload
```

◆ C · pfSense (fw01)

HV01 — VM created in Cockpit (two virtio NICs: `default` then `tenet`), renamed, media ejected:

```
sudo virsh shutdown tenet-pfsense
sudo virsh domrename tenet-pfsense pfsense-fw
sudo virsh start pfsense-fw
sudo virsh domblklist pfsense-fw
sudo virsh change-media pfsense-fw sda --eject --config
```

pfSense (console) — menu 1: `vtnet0` = WAN (DHCP on the NAT), `vtnet1` = LAN; menu 2: LAN `10.10.10.254/24`. Then, in the web interface:

- **System → Setup Wizard**: name `fw01`, domain `infrasec.lab`, NTP, administrator password changed.
- **System → Advanced → Admin Access**: HTTPS only (HTTP 80 listener removed, finding F-02).
- **Services → DNS Resolver → Domain Overrides**: `infrasec.local` → `10.10.10.10` (PV-08).
- **VPN → WireGuard → Tunnels → Add**: `tun_wg0`, port `51820`, address `10.10.20.1/24`.
- **Interfaces → Assignments**: `tun_wg0` → `WG_REMOTE`, **static IPv4** **`10.10.20.1/24`** (INC-07).
- **VPN → WireGuard → Peers → Add Peer**: one public key per device, unique *Allowed IPs* as `/32` (`10.10.20.2/32` admin, `10.10.20.3/32` employee, INC-06).
- **Firewall → Rules → WAN**: a single rule, UDP 51820. **WG_REMOTE**: admin → `10.10.10.0/24`; employee → `10.10.10.20` TCP 445; everything else denied and logged.
- **Services → SNMP**: listening on the LAN, random community; **Firewall → Rules → LAN**: UDP 161 allowed from `10.10.10.30` only, denied and logged for any other source.
- **Diagnostics → Backup & Restore**: encrypted XML export, stored in the host vault.

pfSense (console, option 8) — check:

```
ping -c3 1.1.1.1
host cloudflare.com
```

◆ D · Windows domain controller (Win-Server-DC)

DC (console) — fixed address, name, forest `infrasec.local` (DSRM password typed masked):

```
New-NetIPAddress -InterfaceAlias "Ethernet" -IPAddress 10.10.10.10 `
  -PrefixLength 24 -DefaultGateway 10.10.10.254
Set-DnsClientServerAddress -InterfaceAlias "Ethernet" -ServerAddresses 127.0.0.1
Rename-Computer -NewName "DC01" -Restart
Install-WindowsFeature AD-Domain-Services -IncludeManagementTools
$dsrm = Read-Host -AsSecureString "DSRM password"
Install-ADDSForest -DomainName "infrasec.local" -DomainNetbiosName "INFRASEC" `
  -InstallDns -SafeModeAdministratorPassword $dsrm -Force
w32tm /config /manualpeerlist:10.10.10.254 /syncfromflags:manual /update
```

DC — agents: Wazuh (to the SIEM) and windows_exporter (for Prometheus):

```
Start-Process msiexec.exe -Wait -ArgumentList '/i','C:\path\wazuh-agent.msi', `
  'WAZUH_MANAGER=10.10.10.40','WAZUH_AGENT_NAME=Win-Server-DC','/qn'
Start-Service WazuhSvc
msiexec /i windows_exporter.msi `
  ENABLED_COLLECTORS="cpu,logical_disk,net,os,service,system,memory,process,tcp,ad,dns" /qn
```

DC — the INFRASEC company, after checking the hash of the script and the CSV (PV-05):

```
Get-FileHash .\New-InfrasecCompany.ps1, .\employes.csv -Algorithm SHA256
.\New-InfrasecCompany.ps1 -CsvPath .\employes.csv -WhatIf     # simulation
.\New-InfrasecCompany.ps1 -CsvPath .\employes.csv              # creation
```

DC — domain password policy and `PSO-Admins` for Domain Admins (F-24):

```
Set-ADDefaultDomainPasswordPolicy -Identity infrasec.local -MinPasswordLength 14 `
  -LockoutThreshold 10 -LockoutDuration 00:15:00 -LockoutObservationWindow 00:15:00 `
  -MaxPasswordAge 365.00:00:00 -ComplexityEnabled $true
New-ADFineGrainedPasswordPolicy -Name "PSO-Admins" -Precedence 10 -MinPasswordLength 20 `
  -LockoutThreshold 5 -LockoutDuration 00:30:00 -LockoutObservationWindow 00:30:00 `
  -MaxPasswordAge 180.00:00:00 -ComplexityEnabled $true
```

```
$da = Get-ADGroup -Identity "$((Get-ADDomain).DomainSID)-512"     # Domain Admins, by SID
Add-ADFineGrainedPasswordPolicySubject -Identity "PSO-Admins" -Subjects $da
```

DC — GPO forbidding web browsing on domain controllers (F-17):

```
$g = "DC - Navigation interdite"
New-GPO -Name $g | New-GPLink -Target "OU=Domain Controllers,DC=infrasec,DC=local"
Set-GPRegistryValue -Name $g -Key "HKLM\SOFTWARE\Policies\Microsoft\Edge\URLBlocklist" `
  -ValueName "1" -Type String -Value "*"
Set-GPRegistryValue -Name $g -Key "HKLM\SOFTWARE\Policies\Microsoft\Edge" `
  -ValueName "StartupBoostEnabled" -Type DWord -Value 0
Set-GPRegistryValue -Name $g -Key "HKLM\SOFTWARE\Policies\Microsoft\Edge" `
  -ValueName "BackgroundModeEnabled" -Type DWord -Value 0
gpupdate /force
```

DC — OpenSSH limited to the hypervisor, PowerShell as default shell (PV-07):

```
Start-Service sshd; Set-Service sshd -StartupType Automatic
Set-NetFirewallRule -Name OpenSSH-Server-In-TCP -RemoteAddress 10.10.10.2 -Profile Domain
New-ItemProperty -Path "HKLM:\SOFTWARE\OpenSSH" -Name DefaultShell -PropertyType String -Force `
  -Value "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe"
```

HV01 then DC — `adm.rj` with a key only (the private key stays on the host, protected by a passphrase):

```
ssh-keygen -t ed25519 -a 100 -f ~/.ssh/id_ed25519_admrj      # HV01
```

```
# DC: public key in the file read for members of Administrators
icacls C:\ProgramData\ssh\administrators_authorized_keys /inheritance:r `
  /grant "Administrators:F" /grant "SYSTEM:F"
# sshd_config (copy .bak-20261026): PasswordAuthentication no; AllowUsers infrasec\adm.rj
& C:\Windows\System32\OpenSSH\sshd.exe -t
Restart-Service sshd
```

DC — DNS forwarding to the Samba domain (PV-08):

```
Add-DnsServerConditionalForwarderZone -Name "infrasec.internal" -MasterServers 10.10.10.11
Clear-DnsServerCache -Force
```

HV01 then DC — QEMU guest agent, for a clean shutdown from the hypervisor (F-26):

```
sudo virt-xml Win-Server-DC --add-device \
  --channel unix,target.type=virtio,target.name=org.qemu.guest_agent.0
```

```
msiexec /i E:\guest-agent\qemu-ga-x86_64.msi /qn
Get-Service QEMU-GA
```

◆ E · TrueNAS storage

HV01 — VM with three virtio disks, switched to BIOS to boot the installer (INC-01):

```
sudo virt-install --name truenas \
  --disk path=/vm/images/truenas-os.qcow2,size=16,format=qcow2,bus=virtio \
  --disk path=/vm/images/truenas-d1.qcow2,size=40,format=qcow2,bus=virtio \
  --disk path=/vm/images/truenas-d2.qcow2,size=40,format=qcow2,bus=virtio \
  --cdrom /vm/iso/<truenas-scale>.iso --network network=tenet,model=virtio \
  --graphics vnc --noautoconsole
```

```
sudo virsh dumpxml truenas > truenas.xml     # remove <firmware>, <loader>, <nvram>
sudo virsh define truenas.xml && sudo virsh start truenas
```

TrueNAS (web interface):

- **Storage → Create Pool**: `tank`, mirror on the two 40 GB disks.
- **Credentials → Directory Services**: domain `INFRASEC.LOCAL`, dedicated service account (DC clock fixed first, INC-02).
- **Datasets**: `tank/entreprise` (not shared, `Domain Users` with *Traverse* and no inheritance), then `Commun`, `Direction`, `Comptabilite`, `RH`, `Projets`.
- **Shares → SMB**: one share per dataset; ACL: `DL_SMB_<share>_RW` → Modify, `DL_SMB_<share>_RO` → read (PV-05); *Audit Logging* on, watch list `INFRASEC\domain users` (F-20).
- **Data Protection → Periodic Snapshot Tasks**: `tank/entreprise`, recursive, hourly, kept 2 weeks (PV-06).

◆ F · Monitoring node fedora

fedora — user services at boot, with no open session:

```
sudo loginctl enable-linger ais
grep ais /etc/subuid /etc/subgid
mkdir -p ~/.config/containers/systemd
```

fedora — one service = one Quadlet file (node-exporter example; Prometheus, Grafana and the Zabbix pod follow the same model):

```
# ~/.config/containers/systemd/node-exporter.container
[Unit]
Description=Prometheus node-exporter (rootless)
[Container]
Image=quay.io/prometheus/node-exporter:latest
Network=host
Volume=/:/host:ro,rslave
Exec=--path.rootfs=/host --collector.systemd
[Install]
WantedBy=default.target
```

```
/usr/libexec/podman/quadlet -dryrun -user          # validation before switching
systemctl --user daemon-reload
systemctl --user start node-exporter prometheus grafana zabbix-pod
podman top node-exporter huser                     # real UID: never root
sudo firewall-cmd --permanent --remove-port=9100/tcp && sudo firewall-cmd --reload
```

fedora — Podman secret for the Zabbix database, then rotation without display (INC-09):

```
podman inspect zbx-db --format '{{range .Config.Env}}{{println .}}{{end}}' \
  | sed -n 's/^POSTGRES_PASSWORD=//p' | podman secret create zbx-db-password -
NEW=$(tr -dc 'A-Za-z0-9' </dev/urandom | head -c 32)
printf "ALTER ROLE zabbix WITH PASSWORD '%s';\n" "$NEW" | podman exec -i zbx-db psql -U zabbix -d zabbix
printf '%s' "$NEW" | podman secret create --replace zbx-db-password - ; unset NEW
# zbx-db.container: Secret=zbx-db-password,type=env,target=POSTGRES_PASSWORD
#                   Volume=zbx-pg:/var/lib/postgresql/data:Z
```

fedora — Prometheus target added, configuration validated before restart (F-16):

```
cp ~/prometheus/prometheus.yml ~/prometheus/prometheus.yml.bak-$(date +%F)
# target 10.10.10.40:9100 appended at the end of the file
```

```
podman exec prometheus promtool check config /etc/prometheus/prometheus.yml
systemctl --user restart prometheus
```

fedora — SSH hardening (drop-in) and automatic updates:

```
# /etc/ssh/sshd_config.d/99-hardening.conf: PermitRootLogin no, AllowTcpForwarding no,
# X11Forwarding no, MaxAuthTries 3, ClientAliveInterval 300, ClientAliveCountMax 2, LogLevel VERBOSE
sudo sshd -t && sudo systemctl reload sshd
sudo systemctl enable --now dnf5-automatic.timer
sudo lynis audit system
```

◆ G · SIEM wazuh-siem

SIEM — all-in-one installation, then automatic restart of the manager (INC-11):

```
curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh
sudo bash ./wazuh-install.sh -a
sudo mkdir -p /etc/systemd/system/wazuh-manager.service.d
printf '[Service]\nRestart=on-failure\nRestartSec=30\n' \
  | sudo tee /etc/systemd/system/wazuh-manager.service.d/restart.conf
sudo systemctl daemon-reload
```

SIEM — host firewall: one rule per legitimate flow (F-15):

```
sudo ufw default deny incoming && sudo ufw default allow outgoing
sudo ufw allow from 10.10.10.2 to any port 22,443,9090 proto tcp comment 'admin from HV01'
sudo ufw allow from 10.10.10.0/24 to any port 1514,1515 proto tcp comment 'agents, enrolment'
sudo ufw allow from 10.10.10.30 to any port 55000,9100 proto tcp comment 'Zabbix, Prometheus'
sudo ufw logging low && sudo ufw enable
sudo apt install -y prometheus-node-exporter
```

SIEM — whodata monitoring of the StartUp folder, pushed to Windows agents (F-19):

```
<!-- /var/ossec/etc/shared/default/agent.conf -->
<agent_config os="Windows">
  <syscheck>
    <directories realtime="yes" whodata="yes">C:\ProgramData\Microsoft\Windows\Start
Menu\Programs\StartUp</directories>
  </syscheck>
</agent_config>
```

```
sudo /var/ossec/bin/verify-agent-conf
```

SIEM — local rules, validated before reloading (100100, 100300, 100310, 100320):

```
<!-- /var/ossec/etc/rules/local_rules.xml (excerpt) -->
<rule id="100300" level="12">
  <if_sid>550, 554</if_sid>
  <field name="file" type="pcre2">(?i)\\start menu\\programs\\startup\\</field>
  <description>INFRASEC - persistence: file in the StartUp folder</description>
  <mitre><id>T1547.001</id></mitre>
</rule>
<rule id="100310" level="10">
  <if_sid>506</if_sid>
  <description>INFRASEC - Wazuh agent stopped</description>
  <mitre><id>T1562.001</id></mitre>
</rule>
<rule id="100320" level="10">
  <if_sid>60115</if_sid>
```

```
  <description>INFRASEC - account locked out</description>
  <mitre><id>T1110</id></mitre>
</rule>
```

```
sudo cp /var/ossec/etc/rules/local_rules.xml /var/ossec/etc/rules/local_rules.xml.bak-$(date +%Y%m%d)
sudo /var/ossec/bin/wazuh-analysisd -t && sudo systemctl restart wazuh-manager
```

SIEM — retention: 90-day ISM policy, called with the admin certificate (F-21):

```
C=/etc/wazuh-indexer/certs
sudo curl --cacert $C/root-ca.pem --cert $C/admin.pem --key $C/admin-key.pem \
  -X PUT https://127.0.0.1:9200/_plugins/_ism/policies/infrasec-retention-90j \
  -H 'Content-Type: application/json' -d @ism-retention-90j.json
sudo curl --cacert $C/root-ca.pem --cert $C/admin.pem --key $C/admin-key.pem \
  -X POST 'https://127.0.0.1:9200/_plugins/_ism/add/wazuh-alerts-*' \
  -H 'Content-Type: application/json' -d '{"policy_id":"infrasec-retention-90j"}'
```

SIEM — daily sealing with catch-up at boot:

```
sudo install -o root -g root -m 0755 wazuh-sceller-journaux /usr/local/sbin/
sudo install -m 0644 wazuh-sceller-journaux.service wazuh-sceller-journaux.timer /etc/systemd/system/
sudo systemctl daemon-reload && sudo systemctl enable --now wazuh-sceller-journaux.timer
```

SIEM then HV01 — installation secrets encrypted and moved off the SIEM (F-22):

```
sudo gpg --symmetric --cipher-algo AES256 wazuh-install-files.tar        # SIEM
sha256sum wazuh-install-files.tar.gpg
scp ais@10.10.10.40:wazuh-install-files.tar.gpg ~/coffre/                # HV01
chmod 700 ~/coffre && chmod 600 ~/coffre/*
sudo shred -u wazuh-install-files.tar wazuh-install-files.tar.gpg        # SIEM, after checking
```

◆ H · Continuity controller lnx-dc01 (Samba AD)

lnx-dc01 — minimal Debian 13, fixed address `10.10.10.11`, `root` locked, domain provisioning (administrator password typed at the prompt):

```
sudo apt install -y samba winbind krb5-user smbclient ldb-tools dnsutils ufw
sudo systemctl disable --now smbd nmbd winbind
sudo mv /etc/samba/smb.conf /etc/samba/smb.conf.orig
sudo samba-tool domain provision --use-rfc2307 --realm=INFRASEC.INTERNAL --domain=INFRALNX \
  --server-role=dc --dns-backend=SAMBA_INTERNAL --option="dns forwarder = 10.10.10.254"
sudo cp /var/lib/samba/private/krb5.conf /etc/krb5.conf
sudo systemctl unmask samba-ad-dc && sudo systemctl enable --now samba-ad-dc
sudo passwd -l root
```

lnx-dc01 — same password policy as the Windows domain (F-24):

```
sudo samba-tool domain passwordsettings set --min-pwd-length=14 --account-lockout-threshold=10 \
  --account-lockout-duration=15 --reset-account-lockout-after=15 --max-pwd-age=365
sudo samba-tool domain passwordsettings pso create PSO-Admins 10 --min-pwd-length=20 \
  --account-lockout-threshold=5 --account-lockout-duration=30 --reset-account-lockout-after=30 \
  --max-pwd-age=180
sudo samba-tool domain passwordsettings pso apply PSO-Admins "Domain Admins"
```

lnx-dc01 — same company, same source file, checked by its hash (PV-08):

```
sha256sum employes.csv infrasec-samba-societe.sh
sudo ./infrasec-samba-societe.sh employes.csv --dry-run
sudo ./infrasec-samba-societe.sh employes.csv
```

lnx-dc01 — Wazuh agent at the manager's version, held; firewall (F-25):

```
sudo WAZUH_MANAGER=10.10.10.40 apt install -y wazuh-agent=4.14.8-1
sudo apt-mark hold wazuh-agent && sudo systemctl enable --now wazuh-agent
sudo ufw default deny incoming && sudo ufw logging low
sudo ufw allow from 10.10.10.2 to any port 22 proto tcp comment 'SSH from HV01'
sudo ufw allow from 10.10.10.0/24 to any port 53,88,389,464 comment 'directory tcp/udp'
sudo ufw allow from 10.10.10.0/24 to any port 135,445,636,3268,3269 proto tcp comment 'directory tcp'
sudo ufw allow from 10.10.10.0/24 to any port 49152:65535 proto tcp comment 'dynamic RPC'
sudo ufw show added && sudo ufw enable
```

pfSense — Windows domain forwarding for Samba: **Services → DNS Resolver → Domain Overrides**, `infrasec.local` → `10.10.10.10`.

◆ I · Remote client wg-client

wg-client — key generated on the device; only the public key goes to the firewall:

```
umask 077
wg genkey > user.key
wg pubkey < user.key > user.pub
cat user.pub
# /etc/wireguard/wg0.conf: Address = 10.10.20.3/32; Endpoint = 192.168.122.95:51820
sudo wg-quick up wg0
```

HV01 — guest agent for a clean shutdown (F-26):

```
sudo virt-xml wg-client --add-device \
  --channel unix,target.type=virtio,target.name=org.qemu.guest_agent.0
```

◆ J · Operations from HV01

HV01 — capacity: VM memory reduced from measurement (F-23):

```
sudo virsh dommemstat <vm>
sudo virsh setmaxmem pfsense-fw 2G --config && sudo virsh setmem pfsense-fw 2G --config
sudo virsh setmaxmem Win-Server-DC 4G --config && sudo virsh setmem Win-Server-DC 4G --config
```

HV01 — operations scripts (scripts annex):

```
sha256sum lab lab-backup
sudo install -o root -g root -m 0755 lab lab-backup /usr/local/bin/
sudo lab start            # ordered start, real DNS wait
sudo lab stop             # clean shutdown: guest agent, else ACPI; never forced
sudo lab-backup local     # read-only BTRFS snapshot + annex + hashes
```

HV01 — snapshots before and after each operation:

```
sudo virsh shutdown <vm>; sleep 25
sudo virsh snapshot-create-as <vm> <label> "<description>"
sudo virsh start <vm>
sudo snapper -c root create -d "POST-<OPERATION>-STABLE"
```

Annex T · Test commands (proof of concept)

These commands prove the lab works, without changing anything unless stated. For each: where to type it, and what you should see. A filtering test always runs from a third machine, never from the target; a remote access test always starts from wg-client, never from the host (INC-05).

1 · Host HV01

```
sudo lab status                          # 7 VMs "running"
getenforce                               # Enforcing
sudo ls -lZ /vm/images/                  # svirt_image_t and a c…,c… pair per VM
sudo firewall-cmd --get-active-zones     # lab-tenet → br-tenet; public → wlo1
sudo firewall-cmd --zone=lab-tenet --query-forward   # no
journalctl -t lab --since today          # every start and stop step
sudo snapper -c root list | grep STABLE # return points
sudo lab-backup list                     # disques:ro=true  annexe:ro=true
sudo lab-backup verify                   # intégrité : OK (integrity OK)
free -h                                  # almost no swap, memory available
```

2 · Remote access (wg-client)

```
sudo wg show                             # latest handshake: a few seconds ago
nc -zv -w3 10.10.10.20 445               # succeeded: share allowed
nc -zv -w3 10.10.10.10 3389              # timed out: denied, logged on WG_REMOTE
ip route get 10.10.10.10                 # leaves through wg0, never ens3
```

pfSense — Status → System Logs → Firewall: the denials from `10.10.20.3` on `WG_REMOTE` ; **VPN → WireGuard → Status**: recent handshake.

3 · Windows domain controller (SSH from HV01)

```
ssh -i ~/.ssh/id_ed25519_admrj -l 'infrasec\adm.rj' 10.10.10.10    # accepted, with the key
ssh -l 'INFRASEC\Administrator' 10.10.10.10                        # Permission denied
```

```
Get-ADDomain | Select-Object Forest,DNSRoot      # infrasec.local
nltest /dsgetdc:infrasec.local                   # DC01, success
Get-ADUserResultantPasswordPolicy adm.rj         # PSO-Admins: 20, lockout at 5
Get-ADDefaultDomainPasswordPolicy                # 14 characters, lockout at 10
gpresult /r /scope computer                      # "DC - Navigation interdite" applied
Get-Service WazuhSvc, windows_exporter, sshd, QEMU-GA    # Running
Resolve-DnsName lnx-dc01.infrasec.internal       # 10.10.10.11
w32tm /query /source                             # 10.10.10.254
```

4 · Samba controller lnx-dc01

```
sudo samba-tool domain level show                # domain level
sudo samba-tool user list | wc -l                # 15 accounts
sudo samba-tool domain passwordsettings pso show-user administrator   # PSO-Admins
host -t SRV _ldap._tcp.infrasec.local            # 0 100 389 dc01.infrasec.local.
sudo ufw status verbose                          # default deny, 4 rules
sudo ./infrasec-samba-societe.sh employes.csv    # idempotence: "=== terminé" only
```

5 · TrueNAS storage (System → Shell)

```
zpool status tank                                # mirror-0 ONLINE, No known data errors
zfs list -t snapshot -r tank/entreprise | tail -6   # hourly snapshots
wbinfo -t && net ads testjoin                    # trust OK, Join is OK
midclt call audit.query '[["service","=","SMB"]]' '{"limit":20,"order_by":["-message_timestamp"]}' | jq
'.[].event'
```

6 · Share access control (fedora, PV-05 test accounts)

```
smbclient //10.10.10.20/Projets -U 'INFRASEC\k.haddad' -c 'put /etc/hostname k.haddad.txt'   # OK
smbclient //10.10.10.20/RH -U 'INFRASEC\k.haddad' -c 'ls'      # NT_STATUS_ACCESS_DENIED
smbclient //10.10.10.20/RH -U 'INFRASEC\c.morel' -c 'ls'       # OK, read
smbclient //10.10.10.20/RH -U 'INFRASEC\c.morel' -c 'put /etc/hostname x.txt'   # ACCESS_DENIED
```

7 · Monitoring (fedora)

```
podman ps                                        # 7 containers Up
systemctl --user status prometheus grafana node-exporter --no-pager   # active (running)
curl -s localhost:9091/api/v1/targets | jq '.data.activeTargets[].health'   # "up" × 4
podman inspect zbx-db --format '{{.Config.Env}}' | grep -c POSTGRES_PASSWORD=   # 0
nc -zv -w3 10.10.10.40 22                        # timed out: SIEM SSH closed to fedora (F-15)
nc -zv -w3 10.10.10.40 1514                      # succeeded: agent reception
```

HV01 browser — Grafana `http://10.10.10.30:3000` : rules "Cible injoignable" and "Disque presque plein" in *Normal*; Zabbix `http://10.10.10.30:8080` : `fw01` available over SNMP, `tun_wg0 = up (1)` , both SIEM checks at 1.

8 · SIEM wazuh-siem

```
sudo systemctl is-active wazuh-manager wazuh-indexer wazuh-dashboard   # active × 3
systemctl show wazuh-manager -p Restart -p RestartUSec                 # on-failure, 30s
sudo /var/ossec/bin/agent_control -l             # 001 fedora, 002 dc01, 003 lnx-dc01: Active
sudo ufw status numbered                         # 7 rules, default deny
cd /var/ossec/logs/alerts/2026/Oct && sha256sum -c *.sha256   # OK for each sealed day
systemctl list-timers wazuh-sceller-journaux.timer             # next run 00:30 UTC
sudo grep -c '"rule":{"level":1[0-5]' /var/ossec/logs/alerts/alerts.json   # today's alerts ≥ 10
```

9 · Detection scenarios (change state; undo right after)

DC — persistence (F-19): alert 100300, level 12, within 2 s.

```
New-Item "C:\ProgramData\Microsoft\Windows\Start Menu\Programs\StartUp\maj.bat" -Value "rem test"
Remove-Item "C:\ProgramData\Microsoft\Windows\Start Menu\Programs\StartUp\maj.bat"
```

DC — disabling the agent (F-18): alert 100310, level 10.

```
sc.exe stop WazuhSvc; Start-Sleep 45; sc.exe start WazuhSvc
```

fedora — slow attack on an account (F-24): lockout at the 10th failure, alert 100320 with no 60204. Unlock afterwards.

```
for i in $(seq 1 10); do smbclient //10.10.10.20/Commun -U 'INFRASEC\k.haddad%wrong' -c ls; sleep 40;
```

```
done
```

```
Unlock-ADAccount k.haddad; Get-ADUser k.haddad -Properties LockedOut,badPwdCount
```

HV01 — SSH brute force (PV-03, PV-04): alert 100100, level 12, from the 5th attempt.

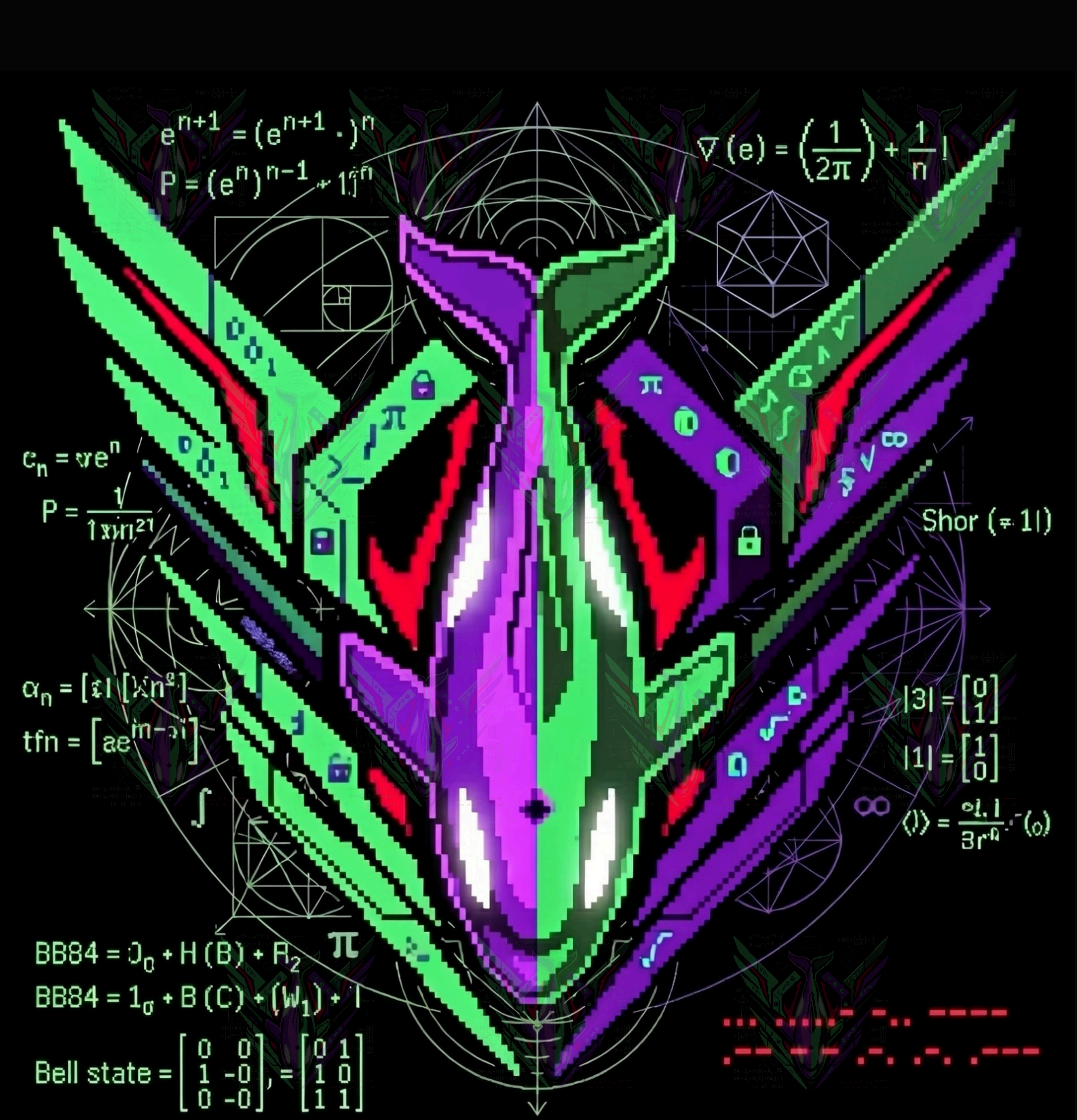
```
for i in $(seq 1 8); do ssh -o BatchMode=yes -o ConnectTimeout=3 fake$i@10.10.10.30 true; done
```

SIEM — SIEM stopped (INC-11): two *High* problems in Zabbix within 3 minutes.

```
sudo systemctl stop wazuh-manager      # wait for the Zabbix alert, then:
sudo systemctl start wazuh-manager
```

fedora — unreachable target: Grafana goes *Firing* after 2 minutes, then back to *Normal*.

```
systemctl --user stop node-exporter    # wait for Firing, then:
systemctl --user start node-exporter
```



// END OF REPORT · FIN DU DOSSIER

Hybrid InfraSec

Dossier de projet complet · CCP1 · CCP2 · CCP3 · FR / EN

λ ~/hybrid-infrasec ❯ exit 0

github.com/0x1void/hybrid-infrasec